

OWASP AI Security Verification Standard 1.0 – Panjabi (Gurmukhi) Bilingual Edition

OWASP AI Security Verification Standard (AISVS) 1.0 Panjabi (Gurmukhi) Bilingual Edition – Print Draft

ਓਵਾਸਪ ਆਈ ਸੁਰੱਖਿਆ ਪਰਮਾਣਕਿਤਾ ਮਿਆਰ 1.0 – ਪੰਜਾਬੀ (ਗੁਰਮੁਖੀ) ਦੋਭਾਸ਼ੀ ਐਡੀਸ਼ਨ

Status: v0.1 – AI-assisted draft translation, pending Sangat (community) review. This edition has not yet completed community linguistic review and should be treated as a working draft. Terminology choices are footnoted throughout and cross-referenced to an open-questions log for community input.

ਸਥਿਤੀ: v0.1 – ਆਈ-ਸਹਾਇਤਾ ਪਰਾਪਤ ਖਰੜਾ ਅਨੁਵਾਦ, ਸੰਗਤ (ਕਮਿਊਨਿਟੀ) ਸਮੀਖਿਆ ਬਾਕੀ ਹੈ। ਇਸ ਐਡੀਸ਼ਨ ਨੇ ਅਜੇ ਤੱਕ ਕਮਿਊਨਿਟੀ ਭਾਸ਼ਾਈ ਸਮੀਖਿਆ ਪੂਰੀ ਨਹੀਂ ਕੀਤੀ ਅਤੇ ਇਸਨੂੰ ਇੱਕ ਕਾਰਜਸ਼ੀਲ ਖਰੜੇ ਵਜੋਂ ਮੰਨਿਆ ਜਾਣਾ ਚਾਹੀਦਾ ਹੈ। ਸ਼ਬਦਾਵਲੀ ਦੀਆਂ ਚੋਣਾਂ ਨੂੰ ਪੂਰੇ ਦਸਤਾਵੇਜ਼ ਵਿੱਚ ਫੁੱਟਨੋਟ ਕੀਤਾ ਗਿਆ ਹੈ ਅਤੇ ਕਮਿਊਨਿਟੀ ਦੇ ਸੁਝਾਵਾਂ ਲਈ ਇੱਕ ਖੁੱਲ੍ਹੇ-ਸਵਾਲ ਲੌਗ ਨਾਲ ਕਰਾਸ-ਰੈਫਰੈਂਸ ਕੀਤਾ ਗਿਆ ਹੈ।

Build date: 2026-08-27

This edition shares its translation framework and terminology base with the sibling **OWASP Application Security Verification Standard (ASVS) 5.0 – Panjabi Edition**; term choices that carry over from that project are noted where relevant in the footnotes below.

ਇਹ ਐਡੀਸ਼ਨ ਆਪਣਾ ਅਨੁਵਾਦ ਢਾਂਚਾ ਅਤੇ ਸ਼ਬਦਾਵਲੀ ਆਧਾਰ ਸਹਯੋਗੀ **ਓਵਾਸਪ ਐਪਲੀਕੇਸ਼ਨ ਸੁਰੱਖਿਆ ਪਰਮਾਣਕਿਤਾ ਮਿਆਰ (ASVS) 5.0 – ਪੰਜਾਬੀ ਐਡੀਸ਼ਨ** ਨਾਲ ਸਾਂਝਾ ਕਰਦੀ ਹੈ; ਉਸ ਪ੍ਰੋਜੈਕਟ ਤੋਂ ਲਿਆਂਦੀਆਂ ਸ਼ਬਦ ਚੋਣਾਂ ਨੂੰ ਹੇਠਾਂ ਦਿੱਤੇ ਫੁੱਟਨੋਟਾਂ ਵਿੱਚ ਸੰਬੰਧਿਤ ਥਾਵਾਂ 'ਤੇ ਨੋਟ ਕੀਤਾ ਗਿਆ ਹੈ।

Table of Contents / ਵਸ਼ਿ-ਸੂਚੀ

Front Matter / ਫਰੰਟ ਮੈਟਰ

- Frontispiece / ਸਰਿਲੇਖ ਪੰਨਾ
- Preface / ਮੁਖਬੰਧ
- Using the AISVS / AISVS ਦੀ ਵਰਤੋਂ

Control Family Chapters (C01-C12) / ਨਿਯੰਤਰਣ ਪਰਿਵਾਰ ਅਧਿਆਇ (C01-C12)

- C1 Training Data Integrity & Traceability / C1 ਸਿਖਲਾਈ ਡਾਟਾ ਅਖੰਡਤਾ ਅਤੇ ਟਰੇਸਯੋਗਤਾ
- C2 Input Validation / C2 ਇਨਪੁੱਟ ਪ੍ਰਮਾਣਿਕਤਾ
- C3 Model Lifecycle Management & Change Control / C3 ਮਾਡਲ ਜੀਵਨ-ਚੱਕਰ ਪ੍ਰਬੰਧਨ ਅਤੇ ਤਬਦੀਲੀ ਨਿਯੰਤਰਣ
- C4 Infrastructure, Configuration & Deployment Security / C4 ਬੁਨਿਆਦੀ ਢਾਂਚਾ, ਸੰਰਚਨਾ ਅਤੇ ਤੈਨਾਤੀ ਸੁਰੱਖਿਆ
- C5 Access Control & Identity for AI Components & Users / C5 AI ਕੰਪੋਨੈਂਟਾਂ ਅਤੇ ਉਪਭੋਗਤਾਵਾਂ ਲਈ ਪਹੁੰਚ ਕੰਟਰੋਲ ਅਤੇ ਪਛਾਣ
- C6 Supply Chain Security for Models / C6 ਮਾਡਲਾਂ ਲਈ ਸਪਲਾਈ ਚੇਨ ਸੁਰੱਖਿਆ
- C7 Model Behavior, Output Control & Safety Assurance / C7 ਮਾਡਲ ਵਿਵਹਾਰ, ਆਊਟਪੁੱਟ ਨਿਯੰਤਰਣ ਅਤੇ ਸਲਾਮਤੀ ਭਰੋਸਾ
- C8 Memory, Embeddings & Vector Database Security / C8 ਮੈਮੋਰੀ, Embeddings ਅਤੇ ਵੈਕਟਰ ਡਾਟਾਬੇਸ ਸੁਰੱਖਿਆ
- C9 Orchestration & Agentic Security / C9 ਆਰਕੈਸਟ੍ਰੇਸ਼ਨ (orchestration) ਅਤੇ ਏਜੈਂਟ-ਆਧਾਰਤ ਸੁਰੱਖਿਆ
- C10 Model Context Protocol (MCP) Security / C10 Model Context Protocol (MCP) ਸੁਰੱਖਿਆ
- C11 Adversarial Robustness / C11 ਵਰਿਧੀ ਮਜ਼ਬੂਤੀ
- C12 Monitoring, Logging & Anomaly Detection / C12 ਨਿਗਰਾਨੀ, ਲੌਗਿੰਗ ਅਤੇ ਅਸਧਾਰਨਤਾ ਪਛਾਣ

Appendices / ਅੰਤਰਿਕਾਵਾਂ

- Appendix A: Glossary / ਅੰਤਰਿਕਾ A: ਸ਼ਬਦਾਵਲੀ
- Appendix B: AI Security Controls Inventory / ਅੰਤਰਿਕਾ B: AI ਸੁਰੱਖਿਆ ਨਿਯੰਤਰਣ ਇਨਵੈਂਟਰੀ
- Appendix C: AI-Assisted Secure Coding / ਅੰਤਰਿਕਾ C: AI-ਸਹਾਇਤ ਪ੍ਰਾਪਤ ਸੁਰੱਖਿਅਤ ਕੋਡਿੰਗ

Frontispiece

ਸਰਿਲੇਖ ਪੰਨਾ

About the Standard

ਮਿਆਰ ਬਾਰੇ

The **Artificial Intelligence Security Verification Standard (AISVS)** is a community-driven catalogue of testable security requirements for AI-enabled systems. It gives data scientists, MLOps engineers, software architects, developers, testers, security professionals, tool vendors, regulators, and consumers a common language for specifying security controls across the AI lifecycle. That lifecycle spans data collection and model development through deployment, monitoring, and retirement. With a shared vocabulary, organizations can measure and improve the resilience, privacy, and safety of their AI solutions.

ਬਣਾਉਣੀ ਬੁੱਧੀ¹ ਸੁਰੱਖਿਆ ਤਸਦੀਕ ਮਿਆਰ (Artificial Intelligence Security Verification Standard, AISVS) AI-ਸਮਰੱਥ ਸਸਿਟਮਾਂ ਲਈ ਟੈਸਟਯੋਗ ਸੁਰੱਖਿਆ ਲੋੜਾਂ ਦਾ ਇੱਕ ਭਾਈਚਾਰਾ-ਸੰਚਾਲਤ ਸੂਚੀ-ਪੱਤਰ ਹੈ। ਇਹ ਡਾਟਾ ਵਗਿਆਨੀਆਂ, MLOps ਇੰਜੀਨੀਅਰਾਂ, ਸਾਫਟਵੇਅਰ ਆਰਕੀਟੈਕਟਾਂ, ਵਕੀਲਾਂ, ਟੈਸਟਰਾਂ, ਸੁਰੱਖਿਆ ਪੇਸ਼ੇਵਰਾਂ, ਟੂਲ ਵਕੀਲਾਂ, ਨਿਯਮਕਾਂ, ਅਤੇ ਖਪਤਕਾਰਾਂ ਨੂੰ AI ਜੀਵਨ-ਚੱਕਰ² (AI lifecycle) ਦੇ ਸਾਰੇ ਪੜਾਵਾਂ ਵਿੱਚ ਸੁਰੱਖਿਆ ਨਿਯੰਤਰਣ ਨਿਰਧਾਰਤ ਕਰਨ ਲਈ ਇੱਕ ਸਾਂਝੀ ਭਾਸ਼ਾ ਦਿੰਦਾ ਹੈ। ਉਹ ਜੀਵਨ-ਚੱਕਰ ਡਾਟਾ ਇਕੱਤਰੀਕਰਨ ਅਤੇ ਮਾਡਲ ਵਕਾਸ ਤੋਂ ਲੈ ਕੇ ਤੈਨਾਤੀ³ (deployment), ਨਿਗਰਾਨੀ, ਅਤੇ ਸੇਵਾ-ਮੁਕਤੀ⁴ (retirement) ਤੱਕ ਫੈਲਿਆ ਹੋਇਆ ਹੈ। ਇੱਕ ਸਾਂਝੀ ਸ਼ਬਦਾਵਲੀ ਨਾਲ, ਸੰਸਥਾਵਾਂ ਆਪਣੇ AI ਹੱਲਾਂ ਦੇ ਲਚਕੀਲੇਪਣ⁵ (resilience), ਨਜ਼ਤਾ⁶ (privacy), ਅਤੇ ਸਲਾਮਤੀ⁷ (safety) ਨੂੰ ਮਾਪ ਅਤੇ ਸੁਧਾਰ ਸਕਦੀਆਂ ਹਨ।

Every requirement in AISVS has been developed from the ground up to reflect the AI threat landscape. While AISVS draws inspiration from broader security best practices, it is purpose-built for artificial intelligence systems and complements (rather than duplicates) governance frameworks such as NIST AI RMF and ISO/IEC 42001.

AISVS ਦੀ ਹਰ ਲੋੜ ਨੂੰ AI ਖ਼ਤਰਾ ਪਰਦਿਰਸ਼ਿ⁸ (AI threat landscape) ਨੂੰ ਦਰਸਾਉਣ ਲਈ ਮੁੱਢ ਤੋਂ ਵਕਿਸਤ ਕੀਤਾ ਗਿਆ ਹੈ। ਭਾਵੇਂ AISVS ਵਿਆਪਕ ਸੁਰੱਖਿਆ ਦੇ ਬਹਿਤਰੀਨ ਅਮਲਾਂ ਤੋਂ ਪ੍ਰਭਾਵਿਤ ਹੋਇਆ ਹੈ, ਇਹ ਬਣਾਉਣੀ ਬੁੱਧੀ ਸਸਿਟਮਾਂ ਲਈ ਵਸ਼ਿਸ਼ ਤੌਰ 'ਤੇ ਬਣਾਇਆ ਗਿਆ ਹੈ ਅਤੇ NIST AI RMF ਅਤੇ ISO/IEC 42001 ਵਰਗੇ ਸ਼ਾਸਨ ਫਰੇਮਵਰਕਾਂ⁹ (governance frameworks) ਦਾ ਪੂਰਕ ਹੈ, ਨਾ ਕਿ ਉਹਨਾਂ ਦੀ ਨਕਲ।

Copyright and License

ਕਾਪੀਰਾਈਟ ਅਤੇ ਲਾਇਸੈਂਸ

Version 1.0, 2026

¹**artificial intelligence** (EN) -> ਬਣਾਉਣੀ ਬੁੱਧੀ — chosen over ਨਕਲੀ ਬੁੱਧੀ (pejorative “fake/imitation”) and ਮਸਨੂਈ ਬੁੱਧੀ (less familiar to Gurmukhi readers) because ਬਣਾਉਣੀ ਬੁੱਧੀ is the Punjabi University Patiala encyclopedic form and avoids devotional vocabulary. Full discussion: OPEN-QUESTIONS.md Q8.

²**AI lifecycle** (EN) -> AI ਜੀਵਨ-ਚੱਕਰ — the hybrid keeps ਚੱਕਰ (“cycle”) in its ordinary technical sense, not the yoga-cakra sense, while retaining the AI acronym per the retained-terms rule. Full discussion: OPEN-QUESTIONS.md Q9.

³**deployment** (EN) -> ਤੈਨਾਤੀ — chosen over ਲਾਗੂ ਕਰਨਾ (“apply/enforce”), which the corpus already uses for “enforce,” so the two senses do not blur in later chapters. Full discussion: OPEN-QUESTIONS.md Q16.

⁴**retirement** (EN) -> ਸੇਵਾ-ਮੁਕਤੀ — names the lifecycle stage (“release from service”) rather than a single act, keeping ਨਿਪਟਾਰਾ free for data disposal. Full discussion: OPEN-QUESTIONS.md Q15.

⁵**resilience** (EN) -> ਲਚਕੀਲੇਪਣ — carries the “recovers its shape after stress” security sense, keeping ਸਹਣਸੀਲਤਾ free for “fault tolerance” elsewhere in the corpus. Full discussion: OPEN-QUESTIONS.md Q12.

⁶**privacy** (EN) -> ਨਜ਼ਤਾ — native Panjabi register, deliberately kept distinct from ਗੋਪਨੀਯਤਾ, which is reserved for “confidentiality.” Full discussion: OPEN-QUESTIONS.md Q13.

⁷**safety** (EN) -> ਸਲਾਮਤੀ — needed because AISVS treats “security” and “safety” as distinct concepts in the same sentence, so they cannot share ਸੁਰੱਖਿਆ. Full discussion: OPEN-QUESTIONS.md Q10.

⁸**threat landscape** (EN) -> ਖ਼ਤਰਾ ਪਰਦਿਰਸ਼ਿ — ਪਰਦਿਰਸ਼ਿ is neutral Sanskrit-register vocabulary for an overall scene, chosen over the vaguer ਖ਼ਤਰਿਆਂ ਦਾ ਮਾਹੌਲ. Full discussion: OPEN-QUESTIONS.md Q11.

⁹**governance frameworks** (EN) -> ਸ਼ਾਸਨ ਫਰੇਮਵਰਕ — ਸ਼ਾਸਨ carries the oversight/direction sense of “governance,” keeping ਪ੍ਰਬੰਧਨ free for “management/handling” elsewhere in the corpus. Full discussion: OPEN-QUESTIONS.md Q14.

ਸੰਸਕਰਣ 1.0, 2026

Copyright © 2025-2026 The AISVS Project.

ਕਾਪੀਰਾਈਟ © 2025-2026 AISVS ਪ੍ਰੋਜੈਕਟ।

Released under the Creative Commons Attribution-ShareAlike 4.0 International License. For any reuse or distribution, you must clearly communicate the license terms of this work to others.

ਕਰੀਏਟਿਵ ਕਾਮਨਜ਼ ਐਟਰੀਬਿਊਸ਼ਨ-ਸ਼ੇਅਰਅਲਾਈਕ 4.0 ਅੰਤਰਰਾਸ਼ਟਰੀ ਲਾਇਸੈਂਸ ਅਧੀਨ ਜਾਰੀ ਕੀਤਾ ਗਿਆ। ਕਸਿ ਵੀ ਮੁੜ-ਵਰਤੋਂ ਜਾਂ ਵੰਡ ਲਈ, ਤੁਹਾਨੂੰ ਇਸ ਰਚਨਾ (work) ਦੀਆਂ ਲਾਇਸੈਂਸ ਸ਼ਰਤਾਂ ਨੂੰ ਦੂਜਿਆਂ ਨੂੰ ਸਪੱਸ਼ਟ ਰੂਪ ਵਿੱਚ ਦੱਸਣਾ ਲਾਜ਼ਮੀ ਹੈ।

Acknowledgments

ਧੰਨਵਾਦ

AISVS v1.0 is the result of a collaborative effort by its project leads, working group members, and community contributors. We thank everyone who has contributed requirements, reviews, and feedback to make this standard possible.

AISVS v1.0 ਇਸਦੇ ਪ੍ਰੋਜੈਕਟ ਮੁਖੀਆਂ, ਕਾਰਜ ਸਮੂਹ ਦੇ ਮੈਂਬਰਾਂ, ਅਤੇ ਭਾਈਚਾਰਕ ਯੋਗਦਾਨੀਆਂ ਦੇ ਸਾਂਝੇ ਯਤਨ ਦਾ ਨਤੀਜਾ ਹੈ। ਅਸੀਂ ਹਰ ਉਸ ਵਿਅਕਤੀ ਦਾ ਧੰਨਵਾਦ ਕਰਦੇ ਹਾਂ ਜਿਸਨੇ ਇਸ ਮਿਆਰ ਨੂੰ ਸੰਭਵ ਬਣਾਉਣ ਲਈ ਲੋੜਾਂ, ਸਮੀਖਿਆਵਾਂ, ਅਤੇ ਫੀਡਬੈਕ¹⁰ ਦਾ ਯੋਗਦਾਨ ਪਾਇਆ।

Project Leads

ਪ੍ਰੋਜੈਕਟ ਮੁਖੀ

- Jim Manico (jmanico)
- Otto Sulin (ottosulin)
- Rico Komenda (RicoKomenda)
- Russ Memisyazici (vtknighmare)

Contributors and Reviewers

ਯੋਗਦਾਨੀ ਅਤੇ ਸਮੀਖਿਅਕ

The list below reflects authored and edited content. It does not fully capture contributors whose impact came mainly through reviews and issue discussion, and we thank them as well.

ਹੇਠਲੀ ਸੂਚੀ ਲਿਖੀ ਅਤੇ ਸੰਪਾਦਿਤ ਕੀਤੀ ਸਮੱਗਰੀ ਨੂੰ ਦਰਸਾਉਂਦੀ ਹੈ। ਇਹ ਉਹਨਾਂ ਯੋਗਦਾਨੀਆਂ ਨੂੰ ਪੂਰੀ ਤਰ੍ਹਾਂ ਨਹੀਂ ਦਰਸਾਉਂਦੀ ਜਿਨ੍ਹਾਂ ਦਾ ਪ੍ਰਭਾਵ ਮੁੱਖ ਤੌਰ 'ਤੇ ਸਮੀਖਿਆਵਾਂ ਅਤੇ ਮੁੱਦਿਆਂ ਦੀ ਚਰਚਾ ਰਾਹੀਂ ਪਿਆ, ਅਤੇ ਅਸੀਂ ਉਹਨਾਂ ਦਾ ਵੀ ਧੰਨਵਾਦ ਕਰਦੇ ਹਾਂ।

- b100 (b100)
- Jim Schwoebel (jim-schwoebel)
- Vineeth Sai Narajala (vineethsai)
- RL Thornton (thornshadow99)
- Almog Langleben (almogbhl)
- Khalid Al-Amri (khalidwalidalamri)
- Barno Kaharova (BarnoKa)
- Joshua Beck (Josh-Beck)

¹⁰**feedback** (EN) -> ਫੀਡਬੈਕ — spelled with nukta (ਫ) for English /f/, per the corpus-wide orthographic normalisation that corrected a nukta/bare-ਫ split found across five loanwords including this one. Full discussion: OPEN-QUESTIONS.md Q86.

- Vishal Jindal (vishaljindal1990)
- Stefan Aeschbacher (imix)
- DotDotSlash (DotDotSlash)
- Tetsuo Seto (tetsuoseto)
- Tametomo (Tametomo)
- Martin Bjerke (kattn)
- Deepak Pandey (deepakrpandey12)
- RogueValley (RogueValley)
- emmanuelgjr (emmanuelgjr)
- Cyril Mathew (cy10101)
- mattijs moens (mattijsmoens)
- Jerry Hoff (jerryhoff)
- Ronald Robertson (Treyrob3)
- Vatsal Gupta (vatsalgupta)
- Zoe Braiterman (zbaiterman)
- Ralph Andalis (csfreak92)
- Uncle Joe (sydseter)
- Stuart Small (stusmall)
- Boone Carlson (KeystoneSmartQuotes)
- Joe-B-Security (Joe-B-Security)
- hackwither (hackwither)
- Mayur Agnihotri (Mayur021)
- Mohamad Khalil Yossif (MohamadKhalilYossif)
- William Jawad (wiljav)
- Hari Mukundhan (harimukundhan)
- Sandhya (sandhya13r)
- Starr Brown (mamicidal)

Panjabi Translation

ਪੰਜਾਬੀ ਅਨੁਵਾਦ

This bilingual translation is maintained by GeeksikhSecurity as part of the OWASP community effort to make AI security knowledge accessible to Panjabi speakers worldwide.

ਇਹ ਦੋਭਾਸ਼ੀ ਅਨੁਵਾਦ GeeksikhSecurity ਦੁਆਰਾ ਸੰਭਾਲਿਆ ਜਾਂਦਾ ਹੈ, ਜੋ ਦੁਨੀਆ ਭਰ ਦੇ ਪੰਜਾਬੀ ਬੋਲਣ ਵਾਲਿਆਂ ਲਈ AI ਸੁਰੱਖਿਆ ਗਿਆਨ ਨੂੰ ਪਹੁੰਚਯੋਗ ਬਣਾਉਣ ਦੇ OWASP ਭਾਈਚਾਰਕ ਯਤਨ ਦਾ ਹਿੱਸਾ ਹੈ।

Preface

ਮੁਖਬੰਧ

Welcome to the **Artificial Intelligence Security Verification Standard (AISVS) version 1.0**.

ਬਣਾਉਟੀ ਬੁੱਧੀ ਸੁਰੱਖਿਆ ਤਸਦੀਕ ਮਿਆਰ (Artificial Intelligence Security Verification Standard, AISVS) ਸੰਸਕਰਣ 1.0 ਵੱਖੋ ਵੱਖਰੇ ਆਇਆਂ ਨੂੰ।

By adopting AISVS, organizations can systematically evaluate and strengthen the security posture of their AI systems, building a foundation of secure AI engineering practices that evolves alongside the technology itself.

AISVS ਨੂੰ ਅਪਣਾ ਕੇ, ਸੰਸਥਾਵਾਂ ਆਪਣੇ AI ਸਿਸਟਮਾਂ ਦੀ ਸੁਰੱਖਿਆ ਸਥਿਤੀ ਦਾ ਵਿਵਸਥਿਤ ਢੰਗ ਨਾਲ ਮੁਲਾਂਕਣ ਕਰ ਸਕਦੀਆਂ ਹਨ ਅਤੇ ਉਸ ਨੂੰ ਮਜ਼ਬੂਤ ਬਣਾ ਸਕਦੀਆਂ ਹਨ, ਅਤੇ ਸੁਰੱਖਿਅਤ AI ਇੰਜੀਨੀਅਰਿੰਗ ਅਭਿਆਸਾਂ¹¹ ਦੀ ਇੱਕ ਅਜਿਹੀ ਨੀਂਹ ਉਸਾਰ ਸਕਦੀਆਂ ਹਨ ਜੋ ਤਕਨਾਲੋਜੀ ਦੇ ਨਾਲ-ਨਾਲ ਹੀ ਵਿਕਸਿਤ ਹੁੰਦੀ ਰਹੇ।

Why AISVS Exists

AISVS ਕੀਉਂ ਮੌਜੂਦ ਹੈ

AI systems introduce security risks that traditional application security standards were not designed to address. Prompt injection allows attackers to override model instructions through crafted inputs, turning a language model into a tool for data exfiltration, unauthorized actions, or bypassing safety controls. Training data can be poisoned to install backdoors or degrade model behavior. Models can be extracted, inverted, or manipulated through adversarial inputs. Autonomous agents can take actions with real-world consequences, acting on prompt-injected instructions they cannot tell apart from legitimate ones. Retrieval pipelines can be exploited to leak sensitive information or to inject malicious content into model context. The supply chain for models, datasets, and frameworks presents novel integrity challenges that existing software composition analysis alone cannot solve.

AI ਸਿਸਟਮ ਅਜਿਹੀ ਸੁਰੱਖਿਆ ਜੋਖਮ ਪੇਸ਼ ਕਰਦੇ ਹਨ ਜਨ੍ਹਾਂ ਨੂੰ ਸੰਬੋਧਿਤ ਕਰਨ ਲਈ ਰਵਾਇਤੀ ਐਪਲੀਕੇਸ਼ਨ ਸੁਰੱਖਿਆ ਮਿਆਰ ਤਿਆਰ ਹੀ ਨਹੀਂ ਕੀਤੇ ਗਏ ਸਨ। prompt ਇੰਜੈਕਸ਼ਨ (prompt injection) ਹਮਲਾਵਰਾਂ ਨੂੰ ਘੜੇ ਹੋਏ ਇਨਪੁੱਟਾਂ ਰਾਹੀਂ ਮਾਡਲ ਦੀਆਂ ਹਦਾਇਤਾਂ ਨੂੰ ਓਵਰਰਾਈਡ ਕਰਨ ਦਿੰਦਾ ਹੈ, ਜਿਸ ਨਾਲ ਇੱਕ ਭਾਸ਼ਾ ਮਾਡਲ ਡਾਟਾ ਬਾਹਰ ਕੱਢਣ (data exfiltration), ਅਣਅਧਿਕਾਰਤ ਕਾਰਵਾਈਆਂ, ਜਾਂ ਸਲਾਮਤੀ (safety) ਨਿਯੰਤਰਣਾਂ ਨੂੰ ਬਾਈਪਾਸ ਕਰਨ ਦਾ ਸੰਦ ਬਣ ਜਾਂਦਾ ਹੈ। ਸਿਖਲਾਈ ਡਾਟੇ (training data) ਨੂੰ ਬੈਕਡੋਰ ਸਥਾਪਤ ਕਰਨ ਜਾਂ ਮਾਡਲ ਦੇ ਵਿਵਹਾਰ ਨੂੰ ਵਿਗਾੜਨ ਲਈ data poisoning (ਡਾਟਾ ਜਹਰੀਕਰਨ) ਦਾ ਨਸ਼ਿਆ ਬਣਾਇਆ ਜਾ ਸਕਦਾ ਹੈ। ਮਾਡਲਾਂ ਨੂੰ ਵਿਰੋਧੀ ਇਨਪੁੱਟਾਂ (adversarial inputs) ਰਾਹੀਂ ਕੱਢਿਆ (model extraction), ਉਲਟਾਇਆ (model inversion)¹², ਜਾਂ ਤੋੜ-ਮਰੋੜ ਕੇ ਵਰਤਿਆ ਜਾ ਸਕਦਾ ਹੈ। ਖੁਦਮੁਖਤਾਰ ਏਜੰਟ (autonomous agents)¹³ ਅਸਲ-ਸੰਸਾਰ ਨਤੀਜਿਆਂ ਵਾਲੀਆਂ ਕਾਰਵਾਈਆਂ ਕਰ ਸਕਦੇ ਹਨ, ਅਤੇ ਉਹਨਾਂ prompt-ਇੰਜੈਕਟ ਕੀਤੀਆਂ ਹਦਾਇਤਾਂ ਉੱਤੇ ਅਮਲ ਕਰ ਸਕਦੇ ਹਨ ਜਨ੍ਹਾਂ ਨੂੰ ਉਹ ਜਾਣਦੇ ਹਦਾਇਤਾਂ ਤੋਂ ਵੱਖ ਨਹੀਂ ਕਰ ਸਕਦੇ। ਪ੍ਰਾਪਤੀ ਪਾਈਪਲਾਈਨਾਂ (retrieval pipelines) ਦਾ ਸ਼ੋਸ਼ਣ ਸੰਵੇਦਨਸ਼ੀਲ ਜਾਣਕਾਰੀ ਲੀਕ ਕਰਨ ਜਾਂ ਮਾਡਲ ਸੰਦਰਭ ਵਿੱਚ ਖ਼ਤਰਨਾਕ ਸਮੱਗਰੀ ਦਾਖ਼ਲ ਕਰਨ ਲਈ ਕੀਤਾ ਜਾ ਸਕਦਾ ਹੈ। ਮਾਡਲਾਂ, ਡਾਟਾਸੈੱਟਾਂ, ਅਤੇ ਫ੍ਰੇਮਵਰਕਾਂ ਦੀ ਸਪਲਾਈ ਚੇਨ (supply chain) ਅਖੰਡਤਾ (integrity) ਦੀਆਂ ਨਵੀਆਂ ਚੁਣੌਤੀਆਂ ਪੇਸ਼ ਕਰਦੀ ਹੈ ਜਨ੍ਹਾਂ ਨੂੰ ਮੌਜੂਦਾ ਸਾਫਟਵੇਅਰ ਕੰਪੋਜ਼ੀਸ਼ਨ ਵਿਸ਼ਲੇਸ਼ਣ (software composition analysis) ਇਕੱਲਾ ਹੱਲ ਨਹੀਂ ਕਰ ਸਕਦਾ।

AISVS was created to give organizations a structured, testable set of security controls purpose-built for these risks. It does not replace existing standards; it fills the gap that none of them cover.

¹¹**practices** (EN, “secure AI engineering practices”) -> ਅਭਿਆਸਾਂ — renders the professional-practice sense of “practice(s),” a different English word from training (ਸਿਖਲਾਈ); flagged because ਅਭਿਆਸ is elsewhere rejected on Gurmat grounds for training data, so a reviewer should confirm this is a deliberate, separate pick rather than an inconsistency. Full discussion: OPEN-QUESTIONS.md Q37.

¹²**model inversion** (EN) -> ਉਲਟਾਇਆ (prose verb) + retained English gloss — the named attack technique stays in English per the retained-attack-name rule, while the surrounding explanatory prose verb is translated because this sentence is explanatory prose rather than a normative requirement. Full discussion: OPEN-QUESTIONS.md Q82.

¹³**autonomous agents** (EN) -> ਖੁਦਮੁਖਤਾਰ ਏਜੰਟ — ਖੁਦਮੁਖਤਾਰ (“self-governing”) was chosen over ਸਵੈ-ਚਾਲਤਿ (“self-driven/automatic”) to capture delegated decision authority rather than mere unattended automation. Full discussion: OPEN-QUESTIONS.md Q81.

AISVS ਇਸ ਲਈ ਬਣਾਇਆ ਗਿਆ ਸੀ ਤਾਂ ਜੋ ਸੰਸਥਾਵਾਂ ਨੂੰ ਇਹਨਾਂ ਜੋਖਮਾਂ ਲਈ ਉਚੇਚੇ ਤੌਰ 'ਤੇ ਬਣਾਏ ਗਏ ਸੁਰੱਖਿਆ ਨਿਯੰਤਰਣਾਂ ਦਾ ਇੱਕ ਵਿਸ਼ਲੇਸ਼ਣ, ਪਰਖਣਯੋਗ ਸੈੱਟ ਦਿੱਤਾ ਜਾ ਸਕੇ। ਇਹ ਮੌਜੂਦਾ ਮਿਆਰਾਂ ਦੀ ਥਾਂ ਨਹੀਂ ਲੈਂਦਾ; ਇਹ ਉਸ ਪਾੜੇ ਨੂੰ ਭਰਦਾ ਹੈ ਜਿਸ ਨੂੰ ਉਹਨਾਂ ਵਿੱਚੋਂ ਕੋਈ ਵੀ ਨਹੀਂ ਢੱਕਦਾ।

Design Principles

ਡਿਜ਼ਾਈਨ ਸਧਿਾਂਤ

AISVS is organized into 12 control families. Each control family is divided into focused sections that support its control objective. Each section contains verification requirements. AISVS defines three verification levels, defined under Using the AISVS; sections need not include requirements at every level.

AISVS ਨੂੰ 12 ਨਿਯੰਤਰਣ ਪਰਿਵਾਰਾਂ¹⁴ (control families) ਵਿੱਚ ਵਿਸ਼ਲੇਸ਼ਣ ਕੀਤਾ ਗਿਆ ਹੈ। ਹਰ ਨਿਯੰਤਰਣ ਪਰਿਵਾਰ ਨੂੰ ਕੇਂਦਰਿਤ ਭਾਗਾਂ ਵਿੱਚ ਵੰਡਿਆ ਗਿਆ ਹੈ ਜੋ ਉਸ ਦੇ ਨਿਯੰਤਰਣ ਉਦੇਸ਼ ਦਾ ਸਮਰਥਨ ਕਰਦੇ ਹਨ। ਹਰ ਭਾਗ ਵਿੱਚ ਤਸਦੀਕ ਲੋੜਾਂ ਸ਼ਾਮਲ ਹਨ। AISVS ਤਿੰਨ ਤਸਦੀਕ ਪੱਧਰ ਪਰਿਭਾਸ਼ਿਤ ਕਰਦਾ ਹੈ, ਜੋ AISVS ਦੀ ਵਰਤੋਂ (Using the AISVS) ਹੇਠ ਪਰਿਭਾਸ਼ਿਤ ਕੀਤੇ ਗਏ ਹਨ; ਹਰ ਭਾਗ ਵਿੱਚ ਹਰ ਪੱਧਰ ਦੀਆਂ ਲੋੜਾਂ ਦਾ ਹੋਣਾ ਜ਼ਰੂਰੀ ਨਹੀਂ ਹੈ।

Each requirement must address a single concern that can ordinarily be implemented and verified as one technical mechanism. Requirements must not duplicate controls defined elsewhere in AISVS. Higher assurance levels may introduce stricter criteria, but those criteria must be stated as separate requirements. Requirements should use clear, technology-neutral language, referencing specific technologies only as examples where they improve clarity.

ਹਰ ਲੋੜ ਲਈ ਇੱਕੋ ਸਰੋਕਾਰ ਨੂੰ ਸੰਬੋਧਿਤ ਕਰਨਾ ਲਾਜ਼ਮੀ ਹੈ, ਜਿਸ ਨੂੰ ਆਮ ਤੌਰ 'ਤੇ ਇੱਕ ਤਕਨੀਕੀ ਵਿਧੀ ਵਜੋਂ ਲਾਗੂ ਅਤੇ ਤਸਦੀਕ ਕੀਤਾ ਜਾ ਸਕੇ। ਲੋੜਾਂ ਲਈ AISVS ਵਿੱਚ ਹੋਰ ਕੋਈ ਪਰਿਭਾਸ਼ਿਤ ਨਿਯੰਤਰਣਾਂ ਨੂੰ ਨਾ ਦੁਹਰਾਉਣਾ ਲਾਜ਼ਮੀ ਹੈ। ਉਦੋਂ ਭਰੋਸਾ ਪੱਧਰ ਸਖ਼ਤ ਮਾਪਦੰਡ ਪੇਸ਼ ਕਰ ਸਕਦੇ ਹਨ, ਪਰ ਉਹਨਾਂ ਮਾਪਦੰਡਾਂ ਨੂੰ ਵੱਖਰੀਆਂ ਲੋੜਾਂ ਵਜੋਂ ਦੱਸਣਾ ਲਾਜ਼ਮੀ ਹੈ। ਲੋੜਾਂ ਨੂੰ ਸਪੱਸ਼ਟ, ਤਕਨਾਲੋਜੀ-ਨਿਰਪੱਖ ਭਾਸ਼ਾ ਵਰਤਣੀ ਚਾਹੀਦੀ ਹੈ, ਅਤੇ ਖਾਸ ਤਕਨਾਲੋਜੀਆਂ ਦਾ ਹਵਾਲਾ ਸਿਰਫ਼ ਉਦਾਹਰਨਾਂ ਵਜੋਂ ਉਥੇ ਦੇਣਾ ਚਾਹੀਦਾ ਹੈ ਜਿਥੇ ਉਹ ਸਪੱਸ਼ਟਤਾ ਵਧਾਉਂਦੀਆਂ ਹਨ।

Every AISVS requirement follows four design principles derived from the standard's name:

ਹਰ AISVS ਲੋੜ ਮਿਆਰ ਦੇ ਨਾਮ ਤੋਂ ਲਏ ਗਏ ਚਾਰ ਡਿਜ਼ਾਈਨ ਸਧਿਾਂਤਾਂ ਦੀ ਪਾਲਣਾ ਕਰਦੀ ਹੈ:

- **Artificial Intelligence.** Requirements must address AI/ML-specific assets, workflows, or runtime behavior, including datasets, models, training and evaluation pipelines, retrieval systems, agents, tools, memory, and inference-time operation. AISVS does not duplicate general application security controls from standards such as ASVS unless the control has AI-specific implementation or verification concerns.
- **ਬਣਾਉਣੀ ਬੁੱਧੀ (Artificial Intelligence)**। ਲੋੜਾਂ ਲਈ AI/ML-ਵਿਸ਼ੇਸ਼ ਸੰਪਤੀਆਂ, ਵਰਕਫਲੋਜ਼, ਜਾਂ ਰਨਟਾਈਮ ਵਿਵਹਾਰ ਨੂੰ ਸੰਬੋਧਿਤ ਕਰਨਾ ਲਾਜ਼ਮੀ ਹੈ, ਜਿਸ ਵਿੱਚ ਡਾਟਾਸੈੱਟ, ਮਾਡਲ, ਸਿਖਲਾਈ ਅਤੇ ਮੁਲਾਂਕਣ ਪਾਈਪਲਾਈਨਾਂ, ਪ੍ਰਾਪਤੀ ਸਿਸਟਮ, ਏਜੰਟ, ਟੂਲ, ਮੈਮੋਰੀ¹⁵, ਅਤੇ ਇਨਫਰੈਂਸ-ਸਮੇਂ ਦਾ ਸੰਚਾਲਨ ਸ਼ਾਮਲ ਹਨ। AISVS, ASVS ਵਰਗੇ ਮਿਆਰਾਂ ਤੋਂ ਆਮ ਐਪਲੀਕੇਸ਼ਨ ਸੁਰੱਖਿਆ ਨਿਯੰਤਰਣਾਂ ਨੂੰ ਨਹੀਂ ਦੁਹਰਾਉਂਦਾ, ਜਦੋਂ ਤੱਕ ਉਸ ਨਿਯੰਤਰਣ ਦੇ AI-ਵਿਸ਼ੇਸ਼ ਅਮਲ ਜਾਂ ਤਸਦੀਕ ਸਰੋਕਾਰ ਨਾ ਹੋਣ।
- **Security.** Requirements must mitigate an identifiable security, privacy, or safety risk. Controls that serve only operational, governance, compliance, or business objectives are out of scope.
- **ਸੁਰੱਖਿਆ (Security)**। ਲੋੜਾਂ ਲਈ ਕੋਈ ਪਛਾਣਯੋਗ ਸੁਰੱਖਿਆ, ਨਿੱਜਤਾ, ਜਾਂ ਸਲਾਮਤੀ (safety) ਜੋਖਮ ਨੂੰ ਘਟਾਉਣਾ ਲਾਜ਼ਮੀ ਹੈ। ਉਹ ਨਿਯੰਤਰਣ ਜੋ ਸਿਰਫ਼ ਸੰਚਾਲਨ, ਸ਼ਾਸਨ (governance), ਪਾਲਣਾ, ਜਾਂ ਕਾਰੋਬਾਰੀ ਉਦੇਸ਼ਾਂ ਦੀ ਪੂਰਤੀ ਕਰਦੇ ਹਨ, ਘੇਰੇ ਤੋਂ ਬਾਹਰ ਹਨ।
- **Verification.** Requirements must be objectively verifiable through testing, inspection, or audit. Sufficient implementation guidance or tooling must exist to support both implementation and verification. Purely theoretical, subjective, or aspirational guidance is excluded.

¹⁴ **control family** (EN) -> ਨਿਯੰਤਰਣ ਪਰਿਵਾਰ — ਪਰਿਵਾਰ mirrors the English “family” metaphor and matches how NIST SP 800-53 control families are discussed in Panjabi security writing; ਸਮੂਹ was rejected for its statistics-collision risk. Full discussion: OPEN-QUESTIONS.md Q80.

¹⁵ **memory** (EN, AI-system-component sense) -> ਮੈਮੋਰੀ — the loan avoids ਸਮਿਰਤੀ (a Gurmat-devotional root) and ਯਾਦਦਾਸਤ, which would anthropomorphise a stored-state component as human recollection. Full discussion: OPEN-QUESTIONS.md Q79.

- **ਤਸਦੀਕ (Verification)**। ਲੋੜਾਂ ਲਈ ਟੈਸਟਿੰਗ, ਨਰੀਖਣ, ਜਾਂ ਆਡਿਟ ਰਾਹੀਂ ਵਸਤੂਪਰਕ ਤੌਰ 'ਤੇ ਤਸਦੀਕਯੋਗ ਹੋਣਾ ਲਾਜ਼ਮੀ ਹੈ। ਅਮਲ ਅਤੇ ਤਸਦੀਕ ਦੋਵਾਂ ਦਾ ਸਮਰਥਨ ਕਰਨ ਲਈ ਲੋੜੀਂਦਾ ਅਮਲ ਮਾਰਗਦਰਸ਼ਨ ਜਾਂ ਟੂਲਗਿ ਮੌਜੂਦ ਹੋਣਾ ਲਾਜ਼ਮੀ ਹੈ। ਪੂਰੀ ਤਰ੍ਹਾਂ ਸਧਿਾਂਤਕ, ਵਾਕਤੀਪਰਕ, ਜਾਂ ਇੱਛਾ-ਆਧਾਰਤ¹⁶ ਮਾਰਗਦਰਸ਼ਨ ਨੂੰ ਬਾਹਰ ਰੱਖਿਆ ਗਿਆ ਹੈ।
- **Standard.** Requirements must use consistent structure, terminology, and assurance-level semantics so AISVS remains coherent, navigable, and suitable for repeatable assessment.
- **ਮਿਆਰ (Standard)**। ਲੋੜਾਂ ਲਈ ਇਕਸਾਰ ਬਣਤਰ, ਸ਼ਬਦਾਵਲੀ, ਅਤੇ ਭਰੋਸਾ-ਪੱਧਰ ਅਰਥ-ਵਿਗਿਆਨ ਵਰਤਣਾ ਲਾਜ਼ਮੀ ਹੈ ਤਾਂ ਜੋ AISVS ਸੁਸੰਗਤ, ਸੌਖਾ ਨੈਵੀਗੇਟ ਕਰਨਯੋਗ, ਅਤੇ ਦੁਹਰਾਉਣਯੋਗ ਮੁਲਾਂਕਣ ਲਈ ਢੁਕਵਾਂ ਰਹੇ।

¹⁶-based (EN, in “ਇੱਛਾ-ਆਧਾਰਤ” = aspirational) -> ਆਧਾਰਤ — normalised to the long-vowel ਆਧਾਰਤ corpus-wide (never the short ਆਧਾਰਤ) after a cross-file audit found this compounding root split 3-3 between the two spellings. Full discussion: OPEN-QUESTIONS.md Q71.

Using the AISVS

AISVS ਦੀ ਵਰਤੋਂ

The Artificial Intelligence Security Verification Standard (AISVS) defines security requirements for modern AI applications and services, focusing on aspects within the control of application developers.

ਬਣਾਉਣੀ ਬੁੱਧੀ ਸੁਰੱਖਿਆ ਤਸਦੀਕ ਮਿਆਰ (Artificial Intelligence Security Verification Standard, AISVS) ਆਧੁਨਿਕ AI ਐਪਲੀਕੇਸ਼ਨਾਂ ਅਤੇ ਸੇਵਾਵਾਂ ਲਈ ਸੁਰੱਖਿਆ ਲੋੜਾਂ ਪਰਭਾਸ਼ਿਤ ਕਰਦਾ ਹੈ, ਅਤੇ ਉਹਨਾਂ ਪਹਲੂਆਂ 'ਤੇ ਕੇਂਦਰਿਤ ਹੈ ਜੋ ਐਪਲੀਕੇਸ਼ਨ ਵਿਕਾਸਕਾਰਾਂ ਦੇ ਨਿਯੰਤਰਣ ਵਿੱਚ ਹਨ।

The AISVS is intended for anyone developing or evaluating the security of AI applications, including developers, architects, security engineers, and auditors. This chapter introduces the structure and use of the AISVS, including its verification levels, intended use cases, and how it is positioned alongside other security standards.

AISVS ਉਹਨਾਂ ਸਾਰਿਆਂ ਲਈ ਹੈ ਜੋ AI ਐਪਲੀਕੇਸ਼ਨਾਂ ਦੀ ਸੁਰੱਖਿਆ ਨੂੰ ਵਕਿਸਤ ਕਰ ਰਹੇ ਹਨ ਜਾਂ ਉਸਦਾ ਮੁਲਾਂਕਣ ਕਰ ਰਹੇ ਹਨ, ਜਿਸ ਵਿੱਚ ਵਿਕਾਸਕਾਰ, ਆਰਕੀਟੈਕਟ, ਸੁਰੱਖਿਆ ਇੰਜੀਨੀਅਰ, ਅਤੇ ਆਡੀਟਰ ਸ਼ਾਮਲ ਹਨ। ਇਹ ਅਧਿਆਇ AISVS ਦੇ ਢਾਂਚੇ ਅਤੇ ਵਰਤੋਂ ਨੂੰ ਪੇਸ਼ ਕਰਦਾ ਹੈ, ਜਿਸ ਵਿੱਚ ਇਸਦੇ ਤਸਦੀਕ ਪੱਧਰ, ਇੱਛਤ ਵਰਤੋਂ-ਮਾਮਲੇ, ਅਤੇ ਇਹ ਹੋਰ ਸੁਰੱਖਿਆ ਮਿਆਰਾਂ ਦੇ ਨਾਲ ਕਵਿ ਸਥਿਤਿ ਹੈ, ਸ਼ਾਮਲ ਹਨ।

How to Read This Standard

ਇਸ ਮਿਆਰ ਨੂੰ ਕਵਿ ਪੜ੍ਹਨਾ ਹੈ

Chapter Structure

ਅਧਿਆਇ ਢਾਂਚਾ

Each of the 12 requirement chapters follows the same format:

- **Control Objective.** A brief statement of the security goal for the chapter.
- **Sections.** Requirements are grouped into related sections, each with a short description of the defense goal.
- **Requirement Tables.** Individual requirements are presented in tables with the following columns:

12 ਲੋੜ ਅਧਿਆਇ ਵੱਲੋਂ ਹਰ ਇੱਕ ਇੱਕੋ ਫਾਰਮੈਟ¹⁷ ਦੀ ਪਾਲਣਾ ਕਰਦਾ ਹੈ:

- **ਨਿਯੰਤਰਣ ਉਦੇਸ਼।** ਅਧਿਆਇ ਲਈ ਸੁਰੱਖਿਆ ਟੀਚੇ ਦਾ ਸੰਖੇਪ ਬਿਆਨ।
- **ਭਾਗ।** ਲੋੜਾਂ ਨੂੰ ਸੰਬੰਧਿਤ ਭਾਗਾਂ ਵਿੱਚ ਵੰਡਿਆ ਗਿਆ ਹੈ, ਹਰ ਭਾਗ ਦੇ ਨਾਲ ਬਚਾਅ ਟੀਚੇ ਦਾ ਸੰਖੇਪ ਵੇਰਵਾ ਦਿੱਤਾ ਗਿਆ ਹੈ।
- **ਲੋੜ ਸਾਰਣੀਆਂ।** ਵਿਅਕਤੀਗਤ ਲੋੜਾਂ ਹੇਠ ਲਿਖੇ ਕਾਲਮਾਂ ਵਾਲੀਆਂ ਸਾਰਣੀਆਂ ਵਿੱਚ ਪੇਸ਼ ਕੀਤੀਆਂ ਗਈਆਂ ਹਨ:

Column	Meaning
#	Unique requirement identifier (e.g., 1.1.1, 9.3.2).
Description	The requirement text, always beginning with “Verify that” to emphasize testability.
Level	The verification level (1, 2, or 3) indicating the depth of assurance required; see the verification levels below.

ਕਾਲਮ	ਅਰਥ
#	ਵਲਿੱਖਣ ਲੋੜ ਪਛਾਣਕਰਤਾ (ਜਵਿ, 1.1.1, 9.3.2)।

¹⁷ **format** (EN) -> ਫਾਰਮੈਟ — spelled with nukta (ਛ) for English /f/, correcting a corpus-wide split where “format” and “platform” appeared both with and without the nukta in different chapters. Full discussion: OPEN-QUESTIONS.md Q86.

ਕਾਲਮ	ਅਰਥ
ਵੇਰਵਾ	ਲੋੜ ਦਾ ਪਾਠ, ਜੋ ਪਰਖਯੋਗਤਾ 'ਤੇ ਜ਼ੋਰ ਦੇਣ ਲਈ ਹਮੇਸ਼ਾ “ਤਸਦੀਕ ਕਰੋ ਕੀ” ਨਾਲ ਸ਼ੁਰੂ ਹੁੰਦਾ ਹੈ।
ਪੱਧਰ	ਤਸਦੀਕ ਪੱਧਰ (1, 2, ਜਾਂ 3) ਜੋ ਲੋੜੀਂਦੇ ਭਰੋਸੇ (assurance) ਦੀ ਡੂੰਘਾਈ ਦਰਸਾਉਂਦਾ ਹੈ; ਹੇਠਾਂ ਦਿੱਤੇ ਤਸਦੀਕ ਪੱਧਰ ਵੇਖੋ।

Appendices

ਅੰਤਰਿਕਾਵਾਂ

Three appendices support the core requirements:

- **Appendix A (Glossary)** defines key terms and acronyms used throughout the standard.
- **Appendix B (AI Security Controls Inventory)** is a cross-reference of every defense technique in AISVS, organized by security control category (authentication, authorization, encryption, input validation, and so on) with mappings back to specific requirement identifiers.
- **Appendix C (AI-Assisted Secure Coding)** provides controls for the safe use of AI coding tools during software development.

ਤਿੰਨ ਅੰਤਰਿਕਾਵਾਂ¹⁸ ਮੁੱਖ ਲੋੜਾਂ ਦਾ ਸਮਰਥਨ ਕਰਦੀਆਂ ਹਨ:

- **ਅੰਤਰਿਕਾ A (ਸ਼ਬਦਾਵਲੀ)** ਪੂਰੇ ਮਿਆਰ ਵਿੱਚ ਵਰਤੇ ਗਏ ਮੁੱਖ ਸ਼ਬਦਾਂ ਅਤੇ ਸੰਖੇਪ-ਰੂਪਾਂ ਨੂੰ ਪਰਭਾਸ਼ਿਤ ਕਰਦੀ ਹੈ।
- **ਅੰਤਰਿਕਾ B (AI ਸੁਰੱਖਿਆ ਨਿਯੰਤਰਣ ਇਨਵੈਂਟਰੀ)** AISVS ਵਿੱਚ ਹਰ ਬਚਾਅ ਤਕਨੀਕ ਦਾ ਅੰਤਰ-ਹਵਾਲਾ ਹੈ, ਜੋ ਸੁਰੱਖਿਆ ਨਿਯੰਤਰਣ ਸ਼੍ਰੇਣੀ (ਪ੍ਰਮਾਣੀਕਰਨ, ਅਧਿਕਾਰੀਕਰਨ, ਏਨਕ੍ਰਿਪਸ਼ਨ, ਇਨਪੁੱਟ ਪ੍ਰਮਾਣਿਕਤਾ, ਆਦਿ) ਅਨੁਸਾਰ ਵਵਿਸਥਿਤ ਹੈ ਅਤੇ ਖਾਸ ਲੋੜ ਪਛਾਣਕਰਤਾਵਾਂ ਨਾਲ ਵਾਪਸ ਮੈਪਿੰਗ ਦਿੰਦਾ ਹੈ।
- **ਅੰਤਰਿਕਾ C (AI-ਸਹਾਇਤ ਪ੍ਰਾਪਤ ਸੁਰੱਖਿਅਤ ਕੋਡਿੰਗ)** ਸਾਫਟਵੇਅਰ ਵਿਕਾਸ ਦੌਰਾਨ AI ਕੋਡਿੰਗ ਟੂਲਾਂ ਦੀ ਸੁਰੱਖਿਅਤ ਵਰਤੋਂ ਲਈ ਨਿਯੰਤਰਣ ਪ੍ਰਦਾਨ ਕਰਦੀ ਹੈ।

Artificial Intelligence Security Verification Levels

ਬਣਾਉਣੀ ਬੁੱਧੀ ਸੁਰੱਖਿਆ ਤਸਦੀਕ ਪੱਧਰ

The AISVS defines three ascending levels of security verification. Each level adds depth and complexity, enabling organizations to tailor their security posture to the risk level of their AI systems.

AISVS ਸੁਰੱਖਿਆ ਤਸਦੀਕ ਦੇ ਤਿੰਨ ਵਧਦੇ ਕ੍ਰਮ ਵਾਲੇ ਪੱਧਰ ਪਰਭਾਸ਼ਿਤ ਕਰਦਾ ਹੈ। ਹਰ ਪੱਧਰ ਡੂੰਘਾਈ ਅਤੇ ਜਟਿਲਤਾ ਜੋੜਦਾ ਹੈ, ਜਿਸ ਨਾਲ ਸੰਸਥਾਵਾਂ ਆਪਣੀ ਸੁਰੱਖਿਆ ਸਥਿਤੀ ਨੂੰ ਆਪਣੇ AI ਸਿਸਟਮਾਂ ਦੇ ਜੋਖਮ ਪੱਧਰ ਅਨੁਸਾਰ ਢਾਲ ਸਕਦੀਆਂ ਹਨ।

Organizations may begin at Level 1 and progressively adopt higher levels as security maturity and threat exposure increase. AISVS levels are aligned with ASVS levels and are intended to be applied at the matching ASVS level (see Alignment with ASVS Levels below).

ਸੰਸਥਾਵਾਂ ਪੱਧਰ 1 ਤੋਂ ਸ਼ੁਰੂ ਕਰ ਸਕਦੀਆਂ ਹਨ ਅਤੇ ਸੁਰੱਖਿਆ ਪਰਿਪੱਕਤਾ ਅਤੇ ਖ਼ਤਰੇ ਦੇ ਸਾਹਮਣੇ ਆਉਣ ਵਿੱਚ ਵਾਧੇ ਦੇ ਨਾਲ-ਨਾਲ ਹੌਲੀ-ਹੌਲੀ ਉੱਚੇ ਪੱਧਰ ਅਪਣਾ ਸਕਦੀਆਂ ਹਨ। AISVS ਪੱਧਰ ASVS ਪੱਧਰਾਂ ਨਾਲ ਇਕਸਾਰ ਹਨ ਅਤੇ ਇਹਨਾਂ ਨੂੰ ਮੇਲ ਖਾਂਦੇ ASVS ਪੱਧਰ 'ਤੇ ਲਾਗੂ ਕਰਨ ਦਾ ਇਰਾਦਾ ਹੈ (ਹੇਠਾਂ “ASVS ਪੱਧਰਾਂ ਨਾਲ ਇਕਸਾਰਤਾ” ਵੇਖੋ)।

¹⁸ **Appendix** (EN) -> ਅੰਤਰਿਕਾ — the settled Panjabi term for a document appendix; the division letter (A/B/C) stays Latin as a cross-reference target, matching how requirement IDs are kept unconverted. Full discussion: OPEN-QUESTIONS.md Q121.

Definition of the Levels

ਪੱਧਰਾਂ ਦੀ ਪਰਭਾਸ਼ਾ

Each requirement in AISVS v1.0 is assigned to one of the following levels:

AISVS v1.0 ਵਿੱਚ ਹਰ ਲੋੜ ਨੂੰ ਹੇਠ ਲਿਖੇ ਪੱਧਰਾਂ ਵਿੱਚੋਂ ਇੱਕ ਸੌਂਪਿਆ ਗਿਆ ਹੈ:

Level 1 requirements

ਪੱਧਰ 1 ਦੀਆਂ ਲੋੜਾਂ Level 1 includes the most critical and foundational security requirements. These focus on preventing common attacks that do not rely on other preconditions or vulnerabilities. Most Level 1 controls are either straightforward to implement or essential enough to justify the effort.

ਪੱਧਰ 1 ਵਿੱਚ ਸਭ ਤੋਂ ਨਾਜ਼ੁਕ ਅਤੇ ਬੁਨਿਆਦੀ ਸੁਰੱਖਿਆ ਲੋੜਾਂ ਸ਼ਾਮਲ ਹਨ। ਇਹ ਉਹਨਾਂ ਆਮ ਹਮਲਿਆਂ ਨੂੰ ਰੋਕਣ 'ਤੇ ਕੇਂਦਰਿਤ ਹਨ ਜੋ ਹੋਰ ਪੂਰਵ-ਸ਼ਰਤਾਂ ਜਾਂ ਕਮਜ਼ੋਰੀਆਂ 'ਤੇ ਨਿਰਭਰ ਨਹੀਂ ਕਰਦੇ। ਜ਼ਿਆਦਾਤਰ ਪੱਧਰ 1 ਨਿਯੰਤਰਣ ਜਾਂ ਤਾਂ ਲਾਗੂ ਕਰਨ ਵਿੱਚ ਸਥਿ-ਸਾਧੇ ਹਨ ਜਾਂ ਇੰਨੇ ਜ਼ਰੂਰੀ ਹਨ ਕਿ ਉਹ ਲੱਗਣ ਵਾਲੀ ਮਹਿਨਤ ਨੂੰ ਜਾਇਜ਼ ਠਹਿਰਾਉਂਦੇ ਹਨ।

Level 2 requirements

ਪੱਧਰ 2 ਦੀਆਂ ਲੋੜਾਂ Level 2 addresses more advanced or less common attacks, as well as layered defenses against widespread threats. These requirements may involve more complex logic or target specific attack prerequisites.

ਪੱਧਰ 2 ਵਧੇਰੇ ਉੱਨਤ ਜਾਂ ਘੱਟ ਆਮ ਹਮਲਿਆਂ ਨੂੰ, ਨਾਲ ਹੀ ਵਿਆਪਕ ਖ਼ਤਰਿਆਂ ਵਿਰੁੱਧ ਪਰਤਦਾਰ ਬਚਾਵਾਂ ਨੂੰ ਸੰਬੋਧਿਤ ਕਰਦਾ ਹੈ। ਇਹਨਾਂ ਲੋੜਾਂ ਵਿੱਚ ਵਧੇਰੇ ਗੁੰਝਲਦਾਰ ਤਰਕ ਸ਼ਾਮਲ ਹੋ ਸਕਦਾ ਹੈ ਜਾਂ ਇਹ ਖ਼ਾਸ ਹਮਲਾ ਪੂਰਵ-ਲੋੜਾਂ ਨੂੰ ਨਿਸ਼ਾਨਾ ਬਣਾ ਸਕਦੀਆਂ ਹਨ।

Level 3 requirements

ਪੱਧਰ 3 ਦੀਆਂ ਲੋੜਾਂ Level 3 includes controls that are typically harder to implement or situational in applicability. These often represent defense-in-depth mechanisms or mitigations against niche, targeted, or high-complexity attacks.

ਪੱਧਰ 3 ਵਿੱਚ ਉਹ ਨਿਯੰਤਰਣ ਸ਼ਾਮਲ ਹਨ ਜੋ ਆਮ ਤੌਰ 'ਤੇ ਲਾਗੂ ਕਰਨੇ ਔਖੇ ਹੁੰਦੇ ਹਨ ਜਾਂ ਜਿਨ੍ਹਾਂ ਦੀ ਲਾਗੂ ਹੋਣ ਦੀ ਯੋਗਤਾ ਹਾਲਾਤ 'ਤੇ ਨਿਰਭਰ ਕਰਦੀ ਹੈ। ਇਹ ਅਕਸਰ ਡੂੰਘਾਈ ਵਿੱਚ ਬਚਾਅ (defense-in-depth)¹⁹ ਵਿਧੀਆਂ ਜਾਂ ਸੀਮਤ-ਦਾਇਰੇ, ਨਿਸ਼ਾਨਾਬੱਧ, ਜਾਂ ਉੱਚ-ਜਟਿਲਤਾ ਵਾਲੇ ਹਮਲਿਆਂ ਵਿਰੁੱਧ ਘਟਾਉਣ ਦੇ ਉਪਾਅ ਦਰਸਾਉਂਦੇ ਹਨ।

Alignment with ASVS Levels

ASVS ਪੱਧਰਾਂ ਨਾਲ ਇਕਸਾਰਤਾ

AISVS levels are aligned with ASVS levels. Verifying an AI application against AISVS Level N assumes the application has also been, or is being, verified against ASVS Level N. The two standards are designed to be applied together at matching levels:

AISVS ਪੱਧਰ ASVS ਪੱਧਰਾਂ ਨਾਲ ਇਕਸਾਰ ਹਨ। ਕਸਿ AI ਐਪਲੀਕੇਸ਼ਨ ਦੀ AISVS ਪੱਧਰ N ਵਿਰੁੱਧ ਤਸਦੀਕ ਇਹ ਮੰਨ ਕੇ ਚੱਲਦੀ ਹੈ ਕਿ ਉਸ ਐਪਲੀਕੇਸ਼ਨ ਦੀ ASVS ਪੱਧਰ N ਵਿਰੁੱਧ ਵੀ ਤਸਦੀਕ ਹੋ ਚੁੱਕੀ ਹੈ ਜਾਂ ਹੋ ਰਹੀ ਹੈ। ਦੋਵੇਂ ਮਿਆਰ ਮੇਲ ਖਾਂਦੇ ਪੱਧਰਾਂ 'ਤੇ ਇਕੱਠੇ ਲਾਗੂ ਕਰਨ ਲਈ ਤਿਆਰ ਕੀਤੇ ਗਏ ਹਨ:

¹⁹ **Defense-in-Depth** (EN, retained) -> ਡੂੰਘਾਈ ਵਿੱਚ ਬਚਾਅ — the named security doctrine keeps its fixed English name, as auditors and the NIST/CIS literature use it, with a literal Panjabi gloss; this file's hyphenation was normalised to match Appendix A after a corpus audit found it diverging. Full discussion: OPEN-QUESTIONS.md Q141.

AISVS Level	Corresponding ASVS Level	Typical use
1	1	Baseline security for any AI application that handles untrusted input or operates on data of any sensitivity.
2	2	AI applications handling sensitive business data, regulated data, or operating in adversarial contexts.
3	3	High-assurance AI applications such as those handling life-safety decisions, critical infrastructure, or highly sensitive personal data.

AISVS ਪੱਧਰ	ਸੰਬੰਧਿਤ ASVS ਪੱਧਰ	ਆਮ ਵਰਤੋਂ
1	1	ਕਸਿ ਵੀ ਅਜਹੀ AI ਐਪਲੀਕੇਸ਼ਨ ਲਈ ਬੁਨਿਆਦੀ ਸੁਰੱਖਿਆ ਜੋ ਗੈਰ-ਭਰੋਸੇਯੋਗ ਇਨਪੁਟ ਸੰਭਾਲਦੀ ਹੈ ਜਾਂ ਕਸਿ ਵੀ ਸੰਵੇਦਨਸ਼ੀਲਤਾ ਵਾਲੇ ਡਾਟੇ 'ਤੇ ਕੰਮ ਕਰਦੀ ਹੈ।
2	2	ਸੰਵੇਦਨਸ਼ੀਲ ਕਾਰੋਬਾਰੀ ਡਾਟਾ ਜਾਂ ਨਿਯੰਤਰਿਤ ਡਾਟਾ ਸੰਭਾਲਣ ਵਾਲੀਆਂ, ਜਾਂ ਵਰਿਧੀ ਸੰਦਰਭਾਂ ਵੱਲੋਂ ਕੰਮ ਕਰਨ ਵਾਲੀਆਂ AI ਐਪਲੀਕੇਸ਼ਨਾਂ।
3	3	ਉੱਚ-ਭਰੋਸੇ ਵਾਲੀਆਂ AI ਐਪਲੀਕੇਸ਼ਨਾਂ, ਜਿਵੇਂ ਕਿ ਜੀਵਨ-ਸਲਾਮਤੀ ਦੇ ਫੈਸਲੇ, ਨਾਜ਼ੁਕ ਬੁਨਿਆਦੀ ਢਾਂਚਾ, ਜਾਂ ਬਹੁਤ ਸੰਵੇਦਨਸ਼ੀਲ ਨਿੱਜੀ ਡਾਟਾ ਸੰਭਾਲਣ ਵਾਲੀਆਂ ਐਪਲੀਕੇਸ਼ਨਾਂ।

If an AISVS requirement appears to overlap with an ASVS requirement, the AISVS version is restated only because it has AI-specific implementation details, attack surface, or evidence that an auditor needs to evaluate differently.

ਜੇ ਕੋਈ AISVS ਲੋੜ ਕਸਿ ASVS ਲੋੜ ਨਾਲ ਓਵਰਲੈਪ ਹੁੰਦੀ ਜਾਪਦੀ ਹੈ, ਤਾਂ AISVS ਵਾਲਾ ਰੂਪ ਸਰਿਫ਼ ਇਸ ਲਈ ਦੁਬਾਰਾ ਦੱਸਿਆ ਗਿਆ ਹੈ ਕਿਉਂਕਿ ਉਸ ਵੱਲੋਂ AI-ਵਸਿਸ਼ ਲਾਗੂਕਰਨ ਵੇਰਵੇ, ਹਮਲਾ ਸਤ੍ਹਾ (attack surface), ਜਾਂ ਸਬੂਤ ਹਨ ਜਨਿਹਾਂ ਦਾ ਮੁਲਾਂਕਣ ਆਡੀਟਰ ਨੂੰ ਵੱਖਰੇ ਢੰਗ ਨਾਲ ਕਰਨਾ ਪੈਂਦਾ ਹੈ।

Scope of the AISVS

AISVS ਦਾ ਦਾਇਰਾ

AISVS is intentionally narrow. It only defines security requirements that are specific to AI and ML systems, or where general security controls have AI-specific nuances that warrant restating. It is not a self-contained security program for an AI application. AISVS assumes that the underlying application, infrastructure, and organizational practices are already verified against established general-purpose standards, and adds the AI-specific layer.

AISVS ਜਾਣ-ਬੁੱਝ ਕੇ ਸੀਮਤ ਦਾਇਰੇ ਵਾਲਾ ਹੈ। ਇਹ ਸਰਿਫ਼ ਉਹ ਸੁਰੱਖਿਆ ਲੋੜਾਂ ਪਰਭਾਸ਼ਿਤ ਕਰਦਾ ਹੈ ਜੋ AI ਅਤੇ ML ਸਸਿਟਮਾਂ ਲਈ ਵਸ਼ਿਸ਼ ਹਨ, ਜਾਂ ਜਿਥੇ ਆਮ ਸੁਰੱਖਿਆ ਨਿਯੰਤਰਣਾਂ ਵਿੱਚ AI-ਵਸ਼ਿਸ਼ ਬਾਰੀਕੀਆਂ ਹਨ ਜੋ ਦੁਬਾਰਾ ਦੱਸਣ ਯੋਗ ਹਨ। ਇਹ ਕਸਿ AI ਐਪਲੀਕੇਸ਼ਨ ਲਈ ਸਵੈ-ਨਰਿਭਰ ਸੁਰੱਖਿਆ ਪਰੋਗਰਾਮ ਨਹੀਂ ਹੈ। AISVS ਇਹ ਮੰਨ ਕੇ ਚੱਲਦਾ ਹੈ ਕਿ ਹੇਠਲੀ ਐਪਲੀਕੇਸ਼ਨ, ਬੁਨਿਆਦੀ ਢਾਂਚਾ, ਅਤੇ ਸੰਸਥਾਗਤ ਅਭਿਆਸ ਪਹਿਲਾਂ ਹੀ ਸਥਾਪਤ ਆਮ-ਮਕਸਦ ਮਿਆਰਾਂ ਵਰ੍ਹਿਧ ਤਸਦੀਕ ਕੀਤੇ ਜਾ ਚੁੱਕੇ ਹਨ, ਅਤੇ ਇਹ ਉਹਨਾਂ ਉੱਤੇ AI-ਵਸ਼ਿਸ਼ ਪਰਤ ਜੋੜਦਾ ਹੈ।

The following are intentionally out of scope and are not duplicated in AISVS chapters:

- **General application security.** Authentication, session management, authorization, transport security, input and output handling for non-AI surfaces, secrets management, file upload handling, error handling, and similar controls are defined by the OWASP Application Security Verification Standard (ASVS).
- **General software supply chain security.** Dependency scanning, version pinning, lockfile enforcement, build provenance, reproducible builds, generic SBOM generation, and CI/CD pipeline integrity are defined by the OWASP Software Component Verification Standard (SCVS), SLSA, and the CIS Controls.
- **General infrastructure and platform hardening.** Container, host, network, cloud, and Kubernetes baseline hardening are defined by the CIS Benchmarks, NIST SP 800-53, NIST SP 800-190, and the NIST Cybersecurity Framework (CSF).
- **General data protection and privacy operations.** Data classification, encryption at rest and in transit, retention scheduling, secure deletion of conventional storage, audit log immutability, and consent management platform operation are defined by ASVS, ISO/IEC 27001, and applicable privacy regulations such as the GDPR.
- **General logging and monitoring.** Log storage access control, retention, backup, encryption, redaction, tamper protection, SIEM integration, and operational telemetry are defined by ASVS and standard observability practice.
- **AI governance and risk management.** Organizational AI governance, AI impact assessments, fairness and ethics documentation, model cards, public transparency reports, and risk-management process design are defined by ISO/IEC 42001, ISO/IEC 23894, and the NIST AI RMF.
- **Vendor-specific guidance.** AISVS is vendor-neutral. It specifies what to verify, not which product to use.

ਹੇਠ ਲਿਖੀਆਂ ਗੱਲਾਂ ਜਾਣ-ਬੁੱਝ ਕੇ ਦਾਇਰੇ ਤੋਂ ਬਾਹਰ ਹਨ ਅਤੇ AISVS ਅਧਿਆਵਾਂ ਵਿੱਚ ਦੁਹਰਾਈਆਂ ਨਹੀਂ ਗਈਆਂ:

- **ਆਮ ਐਪਲੀਕੇਸ਼ਨ ਸੁਰੱਖਿਆ।** ਪ੍ਰਮਾਣੀਕਰਨ, ਸੈਸ਼ਨ ਪ੍ਰਬੰਧਨ, ਅਧਿਕਾਰੀਕਰਨ, ਟ੍ਰਾਂਸਪੋਰਟ ਸੁਰੱਖਿਆ²⁰, ਗੈਰ-AI ਸਤ੍ਹਾਵਾਂ ਲਈ ਇਨਪੁੱਟ ਅਤੇ ਆਊਟਪੁੱਟ ਪ੍ਰਬੰਧਨ, ਗੁਪਤ ਭੇਦ ਪ੍ਰਬੰਧਨ, ਫਾਈਲ ਅਪਲੋਡ ਪ੍ਰਬੰਧਨ, ਗਲਤੀ ਪ੍ਰਬੰਧਨ, ਅਤੇ ਇਸੇ ਤਰ੍ਹਾਂ ਦੇ ਨਿਯੰਤਰਣ OWASP Application Security Verification Standard (ASVS) ਦੁਆਰਾ ਪਰਭਾਸ਼ਿਤ ਕੀਤੇ ਗਏ ਹਨ।
- **ਆਮ ਸਾਫ਼ਟਵੇਅਰ ਸਪਲਾਈ ਚੇਨ ਸੁਰੱਖਿਆ।** ਡਿਪੈਂਡੈਂਸੀ ਸਕੈਨਿੰਗ, ਵਰਜ਼ਨ ਪਨਿੰਗ, ਲੌਕਫਾਈਲ ਲਾਗੂਕਰਨ, ਬਲਿਡ ਮੂਲ-ਸਰੋਤ (build provenance)²¹, ਦੁਹਰਾਉਣਯੋਗ ਬਲਿਡ, ਆਮ SBOM ਤਿਆਰੀ, ਅਤੇ CI/CD ਪਾਈਪਲਾਈਨ ਅਖੰਡਤਾ OWASP Software Component Verification Standard (SCVS), SLSA, ਅਤੇ CIS Controls ਦੁਆਰਾ ਪਰਭਾਸ਼ਿਤ ਕੀਤੇ ਗਏ ਹਨ।
- **ਆਮ ਬੁਨਿਆਦੀ ਢਾਂਚਾ ਅਤੇ ਪਲੇਟਫਾਰਮ ਸਖ਼ਤੀਕਰਨ।** ਕੰਟੇਨਰ, ਹੋਸਟ, ਨੈੱਟਵਰਕ, ਕਲਾਉਡ, ਅਤੇ Kubernetes ਦਾ ਬੁਨਿਆਦੀ ਸਖ਼ਤੀਕਰਨ CIS Benchmarks, NIST SP 800-53, NIST SP 800-190, ਅਤੇ NIST Cybersecurity Framework (CSF) ਦੁਆਰਾ ਪਰਭਾਸ਼ਿਤ ਕੀਤਾ ਗਿਆ ਹੈ।

²⁰**transport security** (EN) -> ਟ੍ਰਾਂਸਪੋਰਟ ਸੁਰੱਖਿਆ — ਟ੍ਰਾਂਸਪੋਰਟ is kept a loan rather than translated (e.g. ਢੋਆ-ਢੁਆਈ, “freight,” would be absurd for a protocol channel); this compound is the conformance anchor the C10 (MCP transport) chapter matches later. Full discussion: OPEN-QUESTIONS.md Q90.

²¹**provenance** (EN, in “build provenance”) -> ਮੂਲ-ਸਰੋਤ (“root-source”) — states “documented chain of origin” plainly, avoiding ਉਤਪਤੀ’s creation-narrative/devotional overtone. Full discussion: OPEN-QUESTIONS.md Q73.

- **ਆਮ ਡਾਟਾ ਸੁਰੱਖਿਆ ਅਤੇ ਨਜ਼ਿਤਾ ਸੰਚਾਲਨ।** ਡਾਟਾ ਵਰਗੀਕਰਨ, ਭੰਡਾਰਨ ਅਤੇ ਪ੍ਰਸਾਰਣ ਵਿੱਚ ਏਨਕ੍ਰਿਪਸ਼ਨ, ਧਾਰਨ ਸਮਾਂ-ਸੂਚੀ, ਰਵਾਇਤੀ ਭੰਡਾਰਨ ਦੀ ਸੁਰੱਖਿਅਤ ਮਟਾਈ, ਆਡਿਟ ਲੌਗ ਦੀ ਅਪਰਵਿਰਤਨਸ਼ੀਲਤਾ²², ਅਤੇ ਸਹਿਮਤੀ ਪ੍ਰਬੰਧਨ²³ ਪਲੇਟਫਾਰਮ ਦਾ ਸੰਚਾਲਨ ASVS, ISO/IEC 27001, ਅਤੇ ਲਾਗੂ ਹੋਣ ਵਾਲੇ ਨਜ਼ਿਤਾ ਨਯਮਾਂ ਜਿਵੇਂ ਕਿ GDPR ਦੁਆਰਾ ਪਰਭਾਸ਼ਿਤ ਕੀਤੇ ਗਏ ਹਨ।
- **ਆਮ ਲੌਗਿੰਗ ਅਤੇ ਨਗਿਰਾਨੀ।** ਲੌਗ ਭੰਡਾਰਨ ਦਾ ਪਹੁੰਚ ਕੰਟਰੋਲ, ਧਾਰਨ, ਬੈਕਅੱਪ, ਏਨਕ੍ਰਿਪਸ਼ਨ, ਰਡਿਕਸ਼ਨ, ਛੇੜਛਾੜ ਸੁਰੱਖਿਆ, SIEM ਏਕੀਕਰਨ, ਅਤੇ ਸੰਚਾਲਨ ਟੈਲੀਮੈਟਰੀ ASVS ਅਤੇ ਮਿਆਰੀ ਨਰਿਖਣਯੋਗਤਾ (observability) ਅਭਿਆਸ ਦੁਆਰਾ ਪਰਭਾਸ਼ਿਤ ਕੀਤੇ ਗਏ ਹਨ।
- **AI ਸ਼ਾਸਨ ਅਤੇ ਜੋਖਮ ਪ੍ਰਬੰਧਨ।** ਸੰਸਥਾਗਤ AI ਸ਼ਾਸਨ, AI ਪ੍ਰਭਾਵ ਮੁਲਾਂਕਣ, ਨਰਿਪੱਖਤਾ ਅਤੇ ਨੈਤਿਕਤਾ ਦਸਤਾਵੇਜ਼ੀਕਰਨ, ਮਾਡਲ ਕਾਰਡ²⁴, ਜਨਤਕ ਪਾਰਦਰਸ਼ਤਾ²⁵ ਰਿਪੋਰਟਾਂ, ਅਤੇ ਜੋਖਮ-ਪ੍ਰਬੰਧਨ ਪ੍ਰਕਿਰਿਆ ਦਾ ਡਿਜ਼ਾਈਨ ISO/IEC 42001, ISO/IEC 23894, ਅਤੇ NIST AI RMF ਦੁਆਰਾ ਪਰਭਾਸ਼ਿਤ ਕੀਤੇ ਗਏ ਹਨ।
- **ਵਕਿਰੇਤਾ-ਵਸ਼ਿਸ਼ ਮਾਰਗਦਰਸ਼ਨ।** AISVS ਵਕਿਰੇਤਾ-ਨਰਿਪੱਖ ਹੈ। ਇਹ ਦੱਸਦਾ ਹੈ ਕਿ ਕੀ ਤਸਦੀਕ ਕਰਨਾ ਹੈ, ਨਾ ਕਿ ਕਿਹੜਾ ਉਤਪਾਦ ਵਰਤਣਾ ਹੈ।

When verifying an AI application against AISVS, the equivalent level of those underlying standards should be verified in parallel.

ਕਿਸੇ AI ਐਪਲੀਕੇਸ਼ਨ ਦੀ AISVS ਵਿਰੁੱਧ ਤਸਦੀਕ ਕਰਦੇ ਸਮੇਂ, ਉਹਨਾਂ ਹੇਠਲੇ ਮਿਆਰਾਂ ਦੇ ਬਰਾਬਰ ਪੱਧਰ ਦੀ ਤਸਦੀਕ ਨਾਲੇ-ਨਾਲ ਕੀਤੀ ਜਾਣੀ ਚਾਹੀਦੀ ਹੈ।

Cross-References Inside AISVS

AISVS ਦੇ ਅੰਦਰ ਅੰਤਰ-ਹਵਾਲੇ

AISVS chapters are organized by control family rather than by attack or component. As a result, defending against a given AI threat usually requires applying requirements from several chapters together. For example, defending against prompt injection in an agentic application combines requirements from C2 (input validation), C7 (model behavior), C9 (orchestration and agentic security), C10 (MCP-specific controls), C11 (adversarial robustness), and C12 (detection and logging).

AISVS ਅਧਿਆਇ ਹਮਲੇ ਜਾਂ ਹਮਿਸ਼ੇ²⁶ ਦੀ ਬਜਾਏ ਨਜ਼ਿਤਰਣ ਪਰਵਿਰ²⁷ ਅਨੁਸਾਰ ਵਰਿਸਥਿਤ ਹਨ। ਨਤੀਜੇ ਵਜੋਂ, ਕਿਸੇ ਦਿੱਤੇ AI ਖ਼ਤਰੇ ਵਿਰੁੱਧ ਬਚਾਅ ਲਈ ਆਮ ਤੌਰ 'ਤੇ ਕਈ ਅਧਿਆਇਆਂ ਦੀਆਂ ਲੋੜਾਂ ਨੂੰ ਇਕੱਠੇ ਲਾਗੂ ਕਰਨਾ ਪੈਂਦਾ ਹੈ। ਉਦਾਹਰਨ ਲਈ, ਕਿਸੇ ਏਜੰਟ-ਆਧਾਰਿਤ (agentic)²⁸ ਐਪਲੀਕੇਸ਼ਨ ਵਿੱਚ prompt ਇੰਜੈਕਸ਼ਨ ਵਿਰੁੱਧ ਬਚਾਅ C2 (ਇਨਪੁੱਟ ਪ੍ਰਮਾਣਿਕਤਾ), C7 (ਮਾਡਲ ਵਰਿਹਾਰ), C9 (ਆਰਕੈਸਟ੍ਰੇਸ਼ਨ²⁹ ਅਤੇ ਏਜੰਟ-ਆਧਾਰਿਤ ਸੁਰੱਖਿਆ), C10 (MCP-ਵਸ਼ਿਸ਼ ਨਜ਼ਿਤਰਣ), C11 (ਵਰਿਧੀ ਮਜ਼ਬੂਤੀ³⁰), ਅਤੇ C12 (ਪਛਾਣ ਅਤੇ ਲੌਗਿੰਗ) ਦੀਆਂ ਲੋੜਾਂ ਨੂੰ ਜੋੜਦਾ ਹੈ।

When applying AISVS, treat the standard as a whole and consult Appendix B (AI Security Controls Inventory) for a cross-cutting view of where each defense technique appears.

²²**immutability** (EN, “audit log immutability”) -> ਅਪਰਵਿਰਤਨਸ਼ੀਲਤਾ — the settled adjective/noun form, kept consistent with C12 and Appendix C rather than paraphrased as “cannot be changed,” so the term stays searchable across the corpus. Full discussion: OPEN-QUESTIONS.md Q112.

²³**consent** (EN, “consent management platform”) -> ਸਹਿਮਤੀ — fixes ਸਹਿਮਤੀ to consent corpus-wide, deliberately keeping ਮਨਜ਼ੂਰੀ free for approval so the two obligations do not collapse into one word in C10. Full discussion: OPEN-QUESTIONS.md Q93.

²⁴**model card** (EN) -> ਮਾਡਲ ਕਾਰਡ — kept as a loan pair rather than a descriptive phrase (e.g. “documentation”) because a model card is a named artifact type with a fixed evidentiary meaning; a vaguer rendering would soften what an auditor can accept as proof. Full discussion: OPEN-QUESTIONS.md Q85.

²⁵**transparency** (EN, “public transparency reports”) -> ਪਾਰਦਰਸ਼ਤਾ — reserved for transparency specifically so Appendix C can use a different word (ਵਿਆਖਿਆਯੋਗਤਾ) for the separate governance concept of explainability. Full discussion: OPEN-QUESTIONS.md Q120.

²⁶**component** (EN, “attack or component”) -> ਹਮਿਸ਼ੇ — correct here because the source means a generic part, not a named system component; other chapters split between ਹਮਿਸ਼ੇ and the loan ਕੰਪੋਨੈਂਟ for the term-of-art sense, a corpus-wide split that is logged but not yet resolved. Full discussion: OPEN-QUESTIONS.md Q95.

²⁷**control family** (EN) -> ਨਜ਼ਿਤਰਣ ਪਰਵਿਰ — ਪਰਵਿਰ mirrors the English “family” metaphor and matches how NIST SP 800-53 control families are discussed in Panjabi security writing; recorded again here because the term recurs in every control chapter and must not drift. Full discussion: OPEN-QUESTIONS.md Q80.

²⁸**agentic / agent-based** (EN) -> ਏਜੰਟ-ਆਧਾਰਿਤ — normalised to the long-vowel ਆਧਾਰਿਤ (never the short ਅਧਾਰਿਤ) after a cross-file audit found this file internally split between the two spellings for the same compound. Full discussion: OPEN-QUESTIONS.md Q71.

²⁹**orchestration** (EN, C09 title) -> ਆਰਕੈਸਟ੍ਰੇਸ਼ਨ — kept as a loan because the nearest native word, ਤਾਲਮੇਲ (“coordination”), loses the specific sense of a control plane driving multi-step model/tool/agent execution. Full discussion: OPEN-QUESTIONS.md Q83.

³⁰**adversarial robustness** (EN, C11 title) -> ਵਰਿਧੀ ਮਜ਼ਬੂਤੀ — ਮਜ਼ਬੂਤੀ (“sturdiness”) was chosen over ਦ੍ਰੜਿਹਤਾ (“steadfastness/resolve”), which would ascribe an inner quality to a model. Full discussion: OPEN-QUESTIONS.md Q84.

AISVS ਲਾਗੂ ਕਰਦੇ ਸਮੇਂ, ਮਿਆਰ ਨੂੰ ਸਮੁੱਚੇ ਰੂਪ ਵਿੱਚ ਲਵੋ ਅਤੇ ਹਰ ਬਚਾਅ ਤਕਨੀਕ ਕਬਿ-ਕਬਿ ਆਉਂਦੀ ਹੈ, ਇਸਦੇ ਅੰਤਰ-ਵਿਆਪੀ ਦ੍ਰਸ਼ ਲਈ ਅੰਤਰਿਕ B (AI ਸੁਰੱਖਿਆ ਨਿਯੰਤਰਣ ਇਨਵੈਂਟਰੀ) ਵੇਖੋ।

AISVS Requirements and Scope in Assessments

ਮੁਲਾਂਕਣਾਂ ਵਿੱਚ AISVS ਲੋੜਾਂ ਅਤੇ ਦਾਇਰਾ

Requirements can often be assessed using a combination of technical testing and vendor documentation, such as model cards for AI models. Another option is to mark requirements outside the organization's control as out of scope.

ਲੋੜਾਂ ਦਾ ਮੁਲਾਂਕਣ ਅਕਸਰ ਤਕਨੀਕੀ ਪਰਖ ਅਤੇ ਵਕਿਰੇਤਾ ਦਸਤਾਵੇਜ਼ੀਕਰਨ — ਜਿਵੇਂ ਕਿ AI ਮਾਡਲਾਂ ਲਈ ਮਾਡਲ ਕਾਰਡ — ਦੇ ਸੁਮੇਲ ਨਾਲ ਕੀਤਾ ਜਾ ਸਕਦਾ ਹੈ। ਇੱਕ ਹੋਰ ਵਕਿਲਪ ਇਹ ਹੈ ਕਿ ਸੰਸਥਾ ਦੇ ਨਿਯੰਤਰਣ ਤੋਂ ਬਾਹਰ ਦੀਆਂ ਲੋੜਾਂ ਨੂੰ ਦਾਇਰੇ ਤੋਂ ਬਾਹਰ ਵਜੋਂ ਚਿੰਨ੍ਹਿਤ ਕੀਤਾ ਜਾਵੇ।

C1 Training Data Integrity & Traceability

C1 ਸਖਿਲਾਈ ਡਾਟਾ³¹ ਅਖੰਡਤਾ ਅਤੇ ਟਰੇਸਯੋਗਤਾ³²

Control Objective

ਨਿਯੰਤਰਣ ਉਦੇਸ਼

This chapter addresses protecting the integrity and traceability of training data as it is sourced, handled, and maintained.

ਇਹ ਅਧਿਆਇ ਸਖਿਲਾਈ ਡਾਟਾ (training data) ਦੀ ਅਖੰਡਤਾ (integrity) ਅਤੇ ਟਰੇਸਯੋਗਤਾ (traceability) ਦੀ ਰਾਖੀ ਨੂੰ ਸੰਬੋਧਿਤ ਕਰਦਾ ਹੈ, ਜਿਵੇਂ ਕਿ ਇਹ ਡਾਟਾ ਪ੍ਰਾਪਤ ਕੀਤਾ, ਸੰਭਾਲਿਆ, ਅਤੇ ਬਰਕਰਾਰ ਰੱਖਿਆ ਜਾਂਦਾ ਹੈ।

C1.1 Training Data Origin & Data Security

C1.1 ਸਖਿਲਾਈ ਡਾਟਾ ਦਾ ਮੂਲ ਅਤੇ ਡਾਟਾ ਸੁਰੱਖਿਆ

Training data origin and security are critical to the trustworthiness of any AI system. Datasets must be sourced from verifiable origins, tracked across their full lifecycle, and protected against tampering, corruption, and poisoning so that unauthorized modification can be detected.

ਸਖਿਲਾਈ ਡਾਟਾ ਦਾ ਮੂਲ ਅਤੇ ਸੁਰੱਖਿਆ ਕਿਸੇ ਵੀ AI ਸਿਸਟਮ ਦੀ ਭਰੋਸੇਯੋਗਤਾ ਲਈ ਨਾਜ਼ੁਕ ਹਨ। ਡਾਟਾਸੈਟ ਤਸਦੀਕਯੋਗ ਮੂਲਾਂ ਤੋਂ ਪ੍ਰਾਪਤ ਕੀਤੇ ਜਾਣੇ ਲਾਜ਼ਮੀ ਹਨ, ਆਪਣੇ ਪੂਰੇ ਜੀਵਨ-ਚੱਕਰ ਦੌਰਾਨ ਟਰੈਕ ਕੀਤੇ ਜਾਣੇ ਲਾਜ਼ਮੀ ਹਨ, ਅਤੇ ਛੇੜਛਾੜ, ਵਗਿਰਾੜ³³, ਅਤੇ poisoning³⁴ ਤੋਂ ਸੁਰੱਖਿਅਤ ਰੱਖੇ ਜਾਣੇ ਲਾਜ਼ਮੀ ਹਨ ਤਾਂ ਜੋ ਅਣਅਧਿਕਾਰਤ ਸੋਧ ਦਾ ਪਤਾ ਲਗਾਇਆ ਜਾ ਸਕੇ।

#	Description	Level
1.1.1	Verify that training data includes only features, attributes, and fields required for the model's stated purpose.	1
1.1.2	Verify that an up-to-date inventory is kept of every training-data source, including its origin, responsible party, license, collection method, intended use constraints, and processing history.	2
1.1.3	Verify that data integrity is provided when training data is stored and transferred.	2
1.1.4	Verify that integrity monitoring is applied to guard against unauthorized modifications or corruption of training data.	2
1.1.5	Verify that datasets are watermarked so their use can be attributed and any unauthorized use detected.	3

³¹**training data** (EN) -> ਸਖਿਲਾਈ ਡਾਟਾ — ਸਖਿਲਾਈ is the neutral, non-devotional Panjabi word for training, chosen over ਅਭਿਆਸ, which carries a Gurmat devotional-practice connotation. Full discussion: OPEN-QUESTIONS.md Q37.

³²**traceability** (EN) -> ਟਰੇਸਯੋਗਤਾ — a hybrid of the English root “trace” with the productive Panjabi suffix “-ਯੋਗਤਾ”, chosen because native alternatives either read clumsily or collide with “discoverability”. Full discussion: OPEN-QUESTIONS.md Q38.

³³**corruption** (EN) -> ਵਗਿਰਾੜ — chosen over ਕੁਰਸ਼ਿਟਾਚਾਰ, the standard Panjabi word for bribery/moral corruption, which would misread a data-integrity event as an accusation of human misconduct. Full discussion: OPEN-QUESTIONS.md Q40.

³⁴**data poisoning** (EN) -> retained as poisoning / data poisoning, glossed once as ਡਾਟਾ ਜਹਗੀਕਰਨ — kept in English on first mention so the reader can match it to the MITRE ATLAS AML.T0020 reference this chapter cites. Full discussion: OPEN-QUESTIONS.md Q39.

#	ਵੇਰਵਾ	ਪੱਧਰ
1.1.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਥਿਲਾਈ ਡਾਟਾ ਵੱਧ ਸਰਿਫ਼ ਉਹੀ ਫੀਚਰ ³⁵ (features), ਗੁਣ, ਅਤੇ ਖੇਤਰ ਸ਼ਾਮਲ ਹਨ ਜੋ ਮਾਡਲ ਦੇ ਦੱਸੇ ਗਏ ਮਕਸਦ ਲਈ ਲੋੜੀਂਦੇ ਹਨ।	1
1.1.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਹਰ ਸਥਿਲਾਈ-ਡਾਟਾ ਸਰੋਤ ਦੀ ਇੱਕ ਆਪ-ਟੂ-ਡੇਟ ਇਨਵੈਂਟਰੀ ਰੱਖੀ ਜਾਂਦੀ ਹੈ, ਜਿਸ ਵਿੱਚ ਉਸਦਾ ਮੂਲ, ਜ਼ਮਿੰਨਵਾਰ ਧਰਿ, ਲਾਇਸੰਸ, ਇਕੱਤਰੀਕਰਨ ਵਧੀ, ਇੱਛਤ ਵਰਤੋਂ ਦੀਆਂ ਪਾਬੰਦੀਆਂ, ਅਤੇ ਪ੍ਰਕਿਰਿਆ ਇਤਿਹਾਸ ਸ਼ਾਮਲ ਹਨ।	2
1.1.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਜਦੋਂ ਸਥਿਲਾਈ ਡਾਟਾ ਦਾ ਭੰਡਾਰਨ ਅਤੇ ਪ੍ਰਸਾਰਣ ਕੀਤਾ ਜਾਂਦਾ ਹੈ ਤਾਂ ਡਾਟਾ ਅਖੰਡਤਾ ਪ੍ਰਦਾਨ ਕੀਤੀ ਜਾਂਦੀ ਹੈ।	2
1.1.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਥਿਲਾਈ ਡਾਟਾ ਦੀਆਂ ਅਣਅਧਿਕਾਰਤ ਸੋਧਾਂ ਜਾਂ ਵਗਿਰਾੜ ਤੋਂ ਬਚਾਅ ਲਈ ਅਖੰਡਤਾ ਨਗਿਰਾਨੀ ਲਾਗੂ ਕੀਤੀ ਜਾਂਦੀ ਹੈ।	2
1.1.5	ਤਸਦੀਕ ਕਰੋ ਕਿ ਡਾਟਾਸੈਟਾਂ ਨੂੰ ਵਾਟਰਮਾਰਕ ³⁶ ਕੀਤਾ ਜਾਂਦਾ ਹੈ ਤਾਂ ਜੋ ਉਹਨਾਂ ਦੀ ਵਰਤੋਂ ਦਾ ਸਰੋਤ-ਨਗਿਰਾਨੀ ³⁷ (attribution) ਕੀਤਾ ਜਾ ਸਕੇ ਅਤੇ ਕਸਿ ਵੀ ਅਣਅਧਿਕਾਰਤ ਵਰਤੋਂ ਦਾ ਪਤਾ ਲਗਾਇਆ ਜਾ ਸਕੇ।	3

C1.2 Data Labeling and Annotation Security

C1.2 ਡਾਟਾ ਲੇਬਲਿੰਗ³⁸ ਅਤੇ ਐਨੋਟੇਸ਼ਨ ਸੁਰੱਖਿਆ

Labeling and annotation processes must be protected against unauthorized modification, data leakage, and integrity compromise. Annotation platforms should enforce access control, preserve auditability, and protect labeling artifacts and sensitive label content throughout the training pipeline.

ਲੇਬਲਿੰਗ ਅਤੇ ਐਨੋਟੇਸ਼ਨ ਪ੍ਰਕਿਰਿਆਵਾਂ ਨੂੰ ਅਣਅਧਿਕਾਰਤ ਸੋਧ, ਡਾਟਾ ਲੀਕੇਜ਼, ਅਤੇ ਅਖੰਡਤਾ ਦੇ ਸਮਝੌਤੇ (compromise) ਤੋਂ ਸੁਰੱਖਿਅਤ ਰੱਖਿਆ ਜਾਣਾ ਲਾਜ਼ਮੀ ਹੈ। ਐਨੋਟੇਸ਼ਨ ਪਲੇਟਫਾਰਮਾਂ ਨੂੰ ਪਹੁੰਚ ਕੰਟਰੋਲ ਲਾਗੂ ਕਰਨਾ ਚਾਹੀਦਾ ਹੈ, ਆਡਿਟਯੋਗਤਾ ਬਰਕਰਾਰ ਰੱਖਣੀ ਚਾਹੀਦੀ ਹੈ, ਅਤੇ ਪੂਰੀ ਸਥਿਲਾਈ ਪਾਈਪਲਾਈਨ ਦੌਰਾਨ ਲੇਬਲਿੰਗ ਆਰਟੀਫੈਕਟਾਂ ਅਤੇ ਸੰਵੇਦਨਸ਼ੀਲ ਲੇਬਲ ਸਮੱਗਰੀ ਦੀ ਰਾਖੀ ਕਰਨੀ ਚਾਹੀਦੀ ਹੈ।

#	Description	Level
1.2.1	Verify that labeling platforms enforce access controls that restrict who can create, modify, or approve annotations.	1
1.2.2	Verify that cryptographic integrity is applied to labeling artifacts.	2
1.2.3	Verify that sensitive information in labels is redacted, anonymized, or encrypted before being used in any labeling artifact.	2

#	ਵੇਰਵਾ	ਪੱਧਰ
1.2.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਲੇਬਲਿੰਗ ਪਲੇਟਫਾਰਮ ਅਜਹੀ ਪਹੁੰਚ ਕੰਟਰੋਲ ਲਾਗੂ ਕਰਦੇ ਹਨ ਜੋ ਇਹ ਸੀਮਤ ਕਰਦੇ ਹਨ ਕਿ ਕੌਣ ਐਨੋਟੇਸ਼ਨਾਂ ਬਣਾ, ਸੋਧ, ਜਾਂ ਮਨਜ਼ੂਰ ਕਰ ਸਕਦਾ ਹੈ।	1
1.2.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਲੇਬਲਿੰਗ ਆਰਟੀਫੈਕਟਾਂ ਉੱਤੇ ਕ੍ਰਿਪਟੋਗ੍ਰਾਫਿਕ ਅਖੰਡਤਾ ਲਾਗੂ ਕੀਤੀ ਜਾਂਦੀ ਹੈ।	2
1.2.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਲੇਬਲਾਂ ਵਿੱਚ ਮੌਜੂਦ ਸੰਵੇਦਨਸ਼ੀਲ ਜਾਣਕਾਰੀ ਨੂੰ ਕਸਿ ਵੀ ਲੇਬਲਿੰਗ ਆਰਟੀਫੈਕਟ ਵਿੱਚ ਵਰਤੇ ਜਾਣ ਤੋਂ ਪਹਿਲਾਂ ਰਡਿਕਟ (redacted), ਗੁਮਨਾਮ, ਜਾਂ ਏਨਕ੍ਰਿਪਟ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	2

³⁵ **features** (EN) -> ਫੀਚਰ — a loan glossed in English because rendering it as ਵਸ਼ਿਸ਼ਤਾ would collapse it into the adjacent, deliberately distinct term “attributes” (ਗੁਣ) in the same requirement. Full discussion: OPEN-QUESTIONS.md Q46.

³⁶ **watermarked** (EN) -> ਵਾਟਰਮਾਰਕ — kept as a loan because the literal calque ਜਲ-ਚੰਨਿਹ (paper watermark) conveys nothing about the ML provenance-attribution technique meant here. Full discussion: OPEN-QUESTIONS.md Q43.

³⁷ **attribution** (EN) -> ਸਰੋਤ-ਨਗਿਰਾਨੀ — chosen over ਸਹਿਰਾ (“credit”, a congratulatory register) because 1.1.5 means tracing use back to a source dataset, not crediting an author. Full discussion: OPEN-QUESTIONS.md Q45.

³⁸ **labeling, annotation** (EN) -> ਲੇਬਲਿੰਗ, ਐਨੋਟੇਸ਼ਨ — kept as two distinct loans because AISVS treats labeling and annotation as separate terms of art for one workflow, and a single native word would collapse that distinction. Full discussion: OPEN-QUESTIONS.md Q41.

C1.3 Training Data Quality and Security Assurance

C1.3 ਸਖਿਲਾਈ ਡਾਟਾ ਗੁਣਵੱਤਾ ਅਤੇ ਸੁਰੱਖਿਆ ਭਰੋਸਾ³⁹

Quality and security assurance controls help detect corruption, poisoning, labeling errors, and exploitable dataset patterns before they affect model behavior. Pipelines should combine automated validation, poisoning detection, label quality checks, and bias analysis.

ਗੁਣਵੱਤਾ ਅਤੇ ਸੁਰੱਖਿਆ ਭਰੋਸਾ ਨਿਯੰਤਰਣ ਵਰਗੇ, poisoning, ਲੇਬਲਿੰਗ ਗਲਤੀਆਂ, ਅਤੇ ਸੋਸ਼ਣਯੋਗ ਡਾਟਾਸੈਟ ਪੈਟਰਨਾਂ ਦਾ ਪਤਾ ਲਗਾਉਣ ਵੱਲੋਂ ਮਦਦ ਕਰਦੇ ਹਨ, ਇਸ ਤੋਂ ਪਹਿਲਾਂ ਕਿ ਉਹ ਮਾਡਲ ਦੇ ਵਿਹਾਰ ਨੂੰ ਪ੍ਰਭਾਵਤਿ ਕਰਨ। ਪਾਈਪਲਾਈਨਾਂ ਨੂੰ ਸਵੈਚਾਲਿਤ ਪ੍ਰਮਾਣਿਕਤਾ, poisoning ਪਛਾਣ, ਲੇਬਲ ਗੁਣਵੱਤਾ ਜਾਂਚਾਂ, ਅਤੇ ਪੱਖਪਾਤ (bias) ਵਿਸ਼ਲੇਸ਼ਣ ਨੂੰ ਜੋੜਨਾ ਚਾਹੀਦਾ ਹੈ।

#	Description	Level
1.3.1	Verify that training and fine-tuning pipelines implement poisoning detection techniques to identify potential data poisoning or unintentional corruption in training data.	2
1.3.2	Verify that automatically generated labels are subject to confidence thresholds and consistency checks to detect misleading or low-confidence labels.	2
1.3.3	Verify that models used in security-relevant decisions are evaluated for bias patterns.	2
1.3.4	Verify that disallowed content is detected and removed before training.	2
1.3.5	Verify that defenses against clean-label poisoning attacks are implemented.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
1.3.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਖਿਲਾਈ ਅਤੇ ਫਾਈਨ-ਟਿਊਨਿੰਗ (fine-tuning) ਪਾਈਪਲਾਈਨਾਂ ਸਖਿਲਾਈ ਡਾਟਾ ਵੱਲੋਂ ਸੰਭਾਵੀ data poisoning (ਡਾਟਾ ਜਹਰੀਕਰਨ) ਜਾਂ ਅਣਇੱਛਤ ਵਰਗਾਂ ਦੀ ਪਛਾਣ ਕਰਨ ਲਈ poisoning ਪਛਾਣ ਤਕਨੀਕਾਂ ਲਾਗੂ ਕਰਦੀਆਂ ਹਨ।	2
1.3.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਵੈਚਾਲਿਤ ਢੰਗ ਨਾਲ ਪੈਦਾ ਕੀਤੇ ਲੇਬਲ ਗੁੰਮਰਾਹਕੁੰਨ ਜਾਂ ਘੱਟ-ਭਰੋਸੇ ⁴⁰ ਵਾਲੇ ਲੇਬਲਾਂ ਦਾ ਪਤਾ ਲਗਾਉਣ ਲਈ ਭਰੋਸਾ ਥਰੈਸ਼ਹੋਲਡਾਂ ਅਤੇ ਇਕਸਾਰਤਾ ਜਾਂਚਾਂ ਦੇ ਅਧੀਨ ਹਨ।	2
1.3.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸੁਰੱਖਿਆ-ਸੰਬੰਧਿਤ ਫ਼ੈਸਲਿਆਂ ਵੱਲੋਂ ਵਰਤੇ ਜਾਣ ਵਾਲੇ ਮਾਡਲਾਂ ਦਾ ਪੱਖਪਾਤ (bias) ਪੈਟਰਨਾਂ ਲਈ ਮੁਲਾਂਕਣ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	2
1.3.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਖਿਲਾਈ ਤੋਂ ਪਹਿਲਾਂ ਮਨਾਹੀ ਵਾਲੀ ਸਮੱਗਰੀ ਦਾ ਪਤਾ ਲਗਾਇਆ ਜਾਂਦਾ ਹੈ ਅਤੇ ਉਸਨੂੰ ਹਟਾਇਆ ਜਾਂਦਾ ਹੈ।	2
1.3.5	ਤਸਦੀਕ ਕਰੋ ਕਿ clean-label poisoning ਹਮਲਿਆਂ ਵਿਰੁੱਧ ਬਚਾਅ ਲਾਗੂ ਕੀਤੇ ਜਾਂਦੇ ਹਨ।	3

References

ਹਵਾਲੇ

- NIST AI Risk Management Framework
- EU AI Act: Article 10: Data & Data Governance

³⁹**assurance** (EN) -> ਭਰੋਸਾ — chosen over ਯਕੀਨ-ਦਹਾਨੀ, which names the act of one party reassuring another rather than the grounded confidence a verification standard means. Full discussion: OPEN-QUESTIONS.md Q44.

⁴⁰**confidence threshold, low-confidence** (EN) -> ਭਰੋਸਾ ਥਰੈਸ਼ਹੋਲਡ, ਘੱਟ-ਭਰੋਸੇ — ਭਰੋਸਾ was preferred over ਆਤਮ-ਵਿਸ਼ਵਾਸ, which is human self-confidence and would anthropomorphise the model. Full discussion: OPEN-QUESTIONS.md Q42.

- CISA Advisory: Securing Data for AI Systems
- MITRE ATLAS: Poison Training Data (AML.T0020)
- ISO/IEC 42001:2023 Artificial Intelligence Management System

C2 Input Validation

C2 ਇਨਪੁੱਟ ਪ੍ਰਮਾਣਿਕਤਾ

Control Objective

ਨਿਯੰਤਰਣ ਉਦੇਸ਼

This chapter addresses validation of all inputs as a first-line defense against prompt injection, one of the most damaging attacks on AI systems.

ਇਹ ਅਧਿਆਇ prompt ਇੰਜੈਕਸ਼ਨ⁴¹ — AI ਸਿਸਟਮਾਂ ਉੱਤੇ ਸਭ ਤੋਂ ਵੱਧ ਨੁਕਸਾਨਦੇਹ ਹਮਲਿਆਂ ਵਿੱਚੋਂ ਇੱਕ — ਦੇ ਵਿਰੁੱਧ ਪਹਿਲੀ-ਕਤਾਰ ਬਚਾਅ ਵਜੋਂ ਸਾਰੇ ਇਨਪੁੱਟਾਂ ਦੀ ਪ੍ਰਮਾਣਿਕਤਾ (validation) ਨੂੰ ਸੰਬੋਧਿਤ ਕਰਦਾ ਹੈ।

C2.1 Prompt Injection Defenses

C2.1 Prompt ਇੰਜੈਕਸ਼ਨ ਬਚਾਅ

Prompt injection is one of the top risks for AI systems, and defending against it requires a combination of pattern filters, data classifiers, and instruction hierarchy enforcement.

Prompt ਇੰਜੈਕਸ਼ਨ AI ਸਿਸਟਮਾਂ ਲਈ ਸਭ ਤੋਂ ਵੱਡੇ ਜੋਖਮਾਂ ਵਿੱਚੋਂ ਇੱਕ ਹੈ, ਅਤੇ ਇਸ ਦੇ ਵਿਰੁੱਧ ਬਚਾਅ ਲਈ ਪੈਟਰਨ ਫ਼ਲਿਟਰਾਂ, ਡਾਟਾ ਵਰਗੀਕਾਰਾਂ (classifiers), ਅਤੇ ਹਦਾਇਤ ਲੜੀ-ਕ੍ਰਮ (instruction hierarchy) ਨੂੰ ਲਾਗੂ ਕਰਨ ਦੇ ਸੁਮੇਲ ਦੀ ਲੋੜ ਹੁੰਦੀ ਹੈ।

#	Description	Level
2.1.1	Verify that input normalization is applied before tokenization or embedding.	1
2.1.2	Verify that encoding and representation smuggling in inputs is detected and mitigated. Approved mitigations include canonicalization, strict schema validation, policy-based rejection, or explicit marking.	1
2.1.3	Verify that all inputs that could steer model behavior are treated as untrusted and screened by a prompt injection detection ruleset or classifier, with flagged inputs blocked.	1
2.1.4	Verify that input length controls prevent content from exceeding the context window. The controls must reject inputs that exceed token limits rather than truncating them.	1
2.1.5	Verify that the system implements a character set restriction for all inputs. The restriction must use an allow-list approach that permits only characters that are explicitly required.	1
2.1.6	Verify that the system enforces an instruction hierarchy in which system and developer messages override user instructions and other untrusted inputs, even after user instructions have been processed.	2
2.1.7	Verify that reserved special tokens are encoded as literal characters and cannot be injected into the model context.	2
2.1.8	Verify that the system can detect many-shot jailbreaking patterns.	3

⁴¹**prompt injection** (EN) -> prompt ਇੰਜੈਕਸ਼ਨ — “prompt” is kept in Latin script per the corpus’s canonical hybrid, matching the sibling ASVS corpus’s “SQL ਇੰਜੈਕਸ਼ਨ” and preserving searchability against OWASP LLM01:2025. Full discussion: OPEN-QUESTIONS.md Q26.

#	ਵੇਰਵਾ	ਪੱਧਰ
2.1.1	ਤਸਦੀਕ ਕਰੋ ਕੀ ਟੋਕਨਾਈਜ਼ੇਸ਼ਨ ⁴² (tokenization) ਜਾਂ embedding ਤੋਂ ਪਹਿਲਾਂ ਇਨਪੁੱਟ ਸਧਾਰਨੀਕਰਨ ⁴³ (normalization) ਲਾਗੂ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	1
2.1.2	ਤਸਦੀਕ ਕਰੋ ਕੀ ਇਨਪੁੱਟਾਂ ਵਿੱਚ ਏਨਕੋਡਿੰਗ ਅਤੇ ਪ੍ਰਤੀਨਿਧਤਾ ਤਸਕਰੀ ⁴⁴ (representation smuggling) ਦਾ ਪਤਾ ਲਗਾਇਆ ਜਾਂਦਾ ਹੈ ਅਤੇ ਇਸ ਨੂੰ ਘਟਾਇਆ ਜਾਂਦਾ ਹੈ। ਪ੍ਰਵਾਨਤ ਉਪਾਵਾਂ ਵਿੱਚ ਕੈਨੋਨੀਕਲਾਈਜ਼ੇਸ਼ਨ ⁴⁵ (canonicalization), ਸਖ਼ਤ ਸਕੀਮਾ ਪ੍ਰਮਾਣਿਕਤਾ, ਨੀਤੀ-ਆਧਾਰਤ ਰੱਦਗੀ, ਜਾਂ ਸਪੱਸ਼ਟ ਨਸ਼ਿਅਤਦੇਹੀ ਸ਼ਾਮਲ ਹਨ।	1
2.1.3	ਤਸਦੀਕ ਕਰੋ ਕੀ ਉਹ ਸਾਰੇ ਇਨਪੁੱਟ ਜੋ ਮਾਡਲ ਦੇ ਵਿਵਹਾਰ ਨੂੰ ਦਸ਼ਾ ਦੇ ਸਕਦੇ ਹਨ, ਗ਼ੈਰ-ਭਰੋਸੇਯੋਗ ਮੰਨੇ ਜਾਂਦੇ ਹਨ ਅਤੇ ਇੱਕ prompt ਇੰਜੈਕਸ਼ਨ ਪਛਾਣ ਨਿਯਮ-ਸਮੂਹ ਜਾਂ ਵਰਗੀਕਾਰ ⁴⁶ ਦੁਆਰਾ ਛਾਣੇ ਜਾਂਦੇ ਹਨ, ਅਤੇ ਨਸ਼ਿਅਤਬੱਧ ਕੀਤੇ ਇਨਪੁੱਟ ਰੋਕ ਦਿੱਤੇ ਜਾਂਦੇ ਹਨ।	1
2.1.4	ਤਸਦੀਕ ਕਰੋ ਕੀ ਇਨਪੁੱਟ ਲੰਬਾਈ ਨਿਯੰਤਰਣ ਸਮੱਗਰੀ ਨੂੰ ਸੰਦਰਭ ਵੰਡ ⁴⁷ (context window) ਤੋਂ ਵੱਧ ਜਾਣ ਤੋਂ ਰੋਕਦੇ ਹਨ। ਇਹਨਾਂ ਨਿਯੰਤਰਣਾਂ ਲਈ ਟੋਕਨ ਸੀਮਾਵਾਂ ਤੋਂ ਵੱਧ ਜਾਣ ਵਾਲੇ ਇਨਪੁੱਟਾਂ ਨੂੰ ਕੱਟਣ (truncate) ਦੀ ਬਜਾਏ ਰੱਦ ਕਰਨਾ ਲਾਜ਼ਮੀ ਹੈ।	1
2.1.5	ਤਸਦੀਕ ਕਰੋ ਕੀ ਸਿਸਟਮ ਸਾਰੇ ਇਨਪੁੱਟਾਂ ਲਈ ਇੱਕ ਅੱਖਰ-ਸਮੂਹ (character set) ਪਾਬੰਦੀ ਲਾਗੂ ਕਰਦਾ ਹੈ। ਇਸ ਪਾਬੰਦੀ ਲਈ allow-list ਤਰੀਕਾ ਵਰਤਣਾ ਲਾਜ਼ਮੀ ਹੈ ਜੋ ਸਰਿਫ਼ ਉਹਨਾਂ ਅੱਖਰਾਂ ਦੀ ਆਗਿਆ ਦਿੰਦਾ ਹੈ ਜੋ ਸਪੱਸ਼ਟ ਤੌਰ 'ਤੇ ਲੋੜੀਂਦੇ ਹਨ।	1
2.1.6	ਤਸਦੀਕ ਕਰੋ ਕੀ ਸਿਸਟਮ ਇੱਕ ਹਦਾਇਤ ਲੜੀ-ਕ੍ਰਮ ⁴⁸ (instruction hierarchy) ਲਾਗੂ ਕਰਦਾ ਹੈ ਜਿਸ ਵਿੱਚ ਸਿਸਟਮ ਅਤੇ ਡਿਵੈਲਪਰ ਸੁਨੇਹੇ ਉਪਭੋਗਤਾ ਹਦਾਇਤਾਂ ਅਤੇ ਹੋਰ ਗ਼ੈਰ-ਭਰੋਸੇਯੋਗ ਇਨਪੁੱਟਾਂ ਉੱਤੇ ਭਾਰੂ ਰਹਿੰਦੇ ਹਨ, ਭਾਵੇਂ ਉਪਭੋਗਤਾ ਹਦਾਇਤਾਂ ਦੀ ਪ੍ਰਕਿਰਿਆ ਹੋ ਚੁੱਕੀ ਹੋਵੇ।	2
2.1.7	ਤਸਦੀਕ ਕਰੋ ਕੀ ਰਾਖਵੇਂ ਵਸ਼ਿਸ਼ ਟੋਕਨ ਸ਼ਾਬਦਕਿ ਅੱਖਰਾਂ ਵਜੋਂ ਏਨਕੋਡ ਕੀਤੇ ਜਾਂਦੇ ਹਨ ਅਤੇ ਮਾਡਲ ਸੰਦਰਭ ਵਿੱਚ ਇੰਜੈਕਟ ਨਹੀਂ ਕੀਤੇ ਜਾ ਸਕਦੇ।	2
2.1.8	ਤਸਦੀਕ ਕਰੋ ਕੀ ਸਿਸਟਮ many-shot jailbreaking ⁴⁹ ਪੈਟਰਨਾਂ ਦਾ ਪਤਾ ਲਗਾ ਸਕਦਾ ਹੈ।	3

C2.2 Content & Policy Screening

C2.2 ਸਮੱਗਰੀ ਅਤੇ ਨੀਤੀ ਛਾਣਬੀਣ

Syntactically valid prompts may still request disallowed content such as policy-violating instructions, harmful material, or restricted information. Input-side content screening prevents such prompts from reaching the model.

ਵਾਕ-ਬਣਤਰ ਪੱਖੋਂ ਜਾਇਜ਼ prompt ਵੀ ਮਨਾਹੀ ਵਾਲੀ ਸਮੱਗਰੀ ਦੀ ਮੰਗ ਕਰ ਸਕਦੇ ਹਨ, ਜਿਵੇਂ ਕਿ ਨੀਤੀ ਦੀ ਉਲੰਘਣਾ ਕਰਨ ਵਾਲੀਆਂ ਹਦਾਇਤਾਂ, ਨੁਕਸਾਨਦੇਹ ਸਮੱਗਰੀ, ਜਾਂ ਪਾਬੰਦੀਸ਼ੁਦਾ ਜਾਣਕਾਰੀ। ਇਨਪੁੱਟ-ਪਾਸੇ ਦੀ ਸਮੱਗਰੀ ਛਾਣਬੀਣ ਅਜਿਹੀ prompt ਨੂੰ ਮਾਡਲ ਤੱਕ ਪਹੁੰਚਣ ਤੋਂ ਰੋਕਦੀ ਹੈ।

⁴²**tokenization** (EN) -> ਟੋਕਨਾਈਜ਼ੇਸ਼ਨ — extends the corpus's locked loan ਟੋਕਨ to the process; this is the ML tokenizer sense, distinct from the session/security-token sense used in the ASVS corpus. Full discussion: OPEN-QUESTIONS.md Q29.

⁴³**input normalization** (EN) -> ਸਧਾਰਨੀਕਰਨ — kept deliberately distinct from ਕੈਨੋਨੀਕਲਾਈਜ਼ੇਸ਼ਨ (canonicalization) so the two operations named separately in 2.1.1 and 2.1.2 do not collapse into one Panjabi word. Full discussion: OPEN-QUESTIONS.md Q27.

⁴⁴**representation smuggling** (EN) -> ਪ੍ਰਤੀਨਿਧਤਾ ਤਸਕਰੀ — ਤਸਕਰੀ (smuggling) carries the sense of moving something illicitly past a control, which the rejected alternative ਰੂਪ-ਲੁਕਾਈ (“concealment”) does not. Full discussion: OPEN-QUESTIONS.md Q34.

⁴⁵**canonicalization** (EN) -> ਕੈਨੋਨੀਕਲਾਈਜ਼ੇਸ਼ਨ — kept as a loan because the descriptive alternative ਪ੍ਰਮਾਣਿਕ ਰੂਪੀਕਰਨ would reuse a root already load-bearing for authentication and validation elsewhere in the corpus. Full discussion: OPEN-QUESTIONS.md Q28.

⁴⁶**classifier** (EN) -> ਵਰਗੀਕਾਰ — the agent noun derived regularly from ਵਰਗੀਕਰਨ (classification), preferred over the loan ਕਲਾਸੀਫਾਇਰ because classification is an established technique, not a coined product name. Full discussion: OPEN-QUESTIONS.md Q33.

⁴⁷**context window** (EN) -> ਸੰਦਰਭ ਵੰਡ — ਵੰਡ is the settled computing loan in Panjabi technical prose, preferred over the architectural-sounding ਖੜਕੀ. Full discussion: OPEN-QUESTIONS.md Q30.

⁴⁸**instruction hierarchy** (EN) -> ਹਦਾਇਤ ਲੜੀ-ਕ੍ਰਮ — ਹਦਾਇਤ (directive) was chosen over ਨਿਰਦੇਸ਼, which drifts toward mere “guidance” and would weaken a hard override requirement. Full discussion: OPEN-QUESTIONS.md Q31.

⁴⁹**many-shot jailbreaking** (EN) -> retained verbatim in Latin script — follows the corpus precedent of retaining named attacks and techniques so the term stays recognisable to a practitioner reading MITRE ATLAS. Full discussion: OPEN-QUESTIONS.md Q32.

#	Description	Level
2.2.1	Verify that every prompt is scored by a content classifier for violence, self-harm, hate, and sexual content against configurable thresholds. Prompts that exceed those thresholds are rejected or sanitized before reaching the model context.	1
2.2.2	Verify that prompt content classification is evaluated for unsupported languages.	1
2.2.3	Verify that non-text inputs (image/video/audio) are checked for adversarial perturbations, steganographic payloads, hidden or embedded content, or known attack patterns.	2
2.2.4	Verify that coordinated attacks spanning multiple input types (e.g., steganographic payloads in images combined with prompt injection in text) are detected and blocked.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
2.2.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਹਰ prompt ਨੂੰ ਹਸਿੰ, ਸਵੈ-ਨੁਕਸਾਨ, ਨਫ਼ਰਤ, ਅਤੇ ਜਨਿਸੀ ਸਮੱਗਰੀ ਲਈ ਇੱਕ ਸਮੱਗਰੀ ਵਰਗੀਕਾਰ ਦੁਆਰਾ ਸੰਚਨਾਯੋਗ ਥਰੇਸ਼ਹੋਲਡਾਂ (thresholds) ਦੇ ਵਰਿਧਿ ਅੰਕ ਦਿੱਤੇ ਜਾਂਦੇ ਹਨ। ਜਿਹੜੇ prompt ਇਹਨਾਂ ਥਰੇਸ਼ਹੋਲਡਾਂ ਤੋਂ ਵੱਧ ਜਾਂਦੇ ਹਨ, ਉਹਨਾਂ ਨੂੰ ਮਾਡਲ ਸੰਦਰਭ ਤੱਕ ਪਹੁੰਚਣ ਤੋਂ ਪਹਿਲਾਂ ਰੱਦ ਜਾਂ ਸੈਨੀਟਾਈਜ਼ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	1
2.2.2	ਤਸਦੀਕ ਕਰੋ ਕਿ prompt ਸਮੱਗਰੀ ਵਰਗੀਕਰਨ ਦਾ ਗੈਰ-ਸਮਰਥਤ ਭਾਸ਼ਾਵਾਂ ਲਈ ਮੁਲਾਂਕਣ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	1
2.2.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਗੈਰ-ਲਿਖਤੀ ਇਨਪੁਟਾਂ (ਚਤਿਰ/ਵੀਡੀਓ/ਆਡੀਓ) ਦੀ ਵਰਿਧੀ ਵਰਿਧਾਂ ⁵⁰ (adversarial perturbations), ਸਟੈਗਨੋਗ੍ਰਾਫਿਕ ਪੇਲੋਡਾਂ ⁵¹ , ਲੁਕਵੀਂ ਜਾਂ ਜੜੀ ਹੋਈ ਸਮੱਗਰੀ, ਜਾਂ ਜਾਣੇ-ਪਛਾਣੇ ਹਮਲਾ ਪੈਟਰਨਾਂ ਲਈ ਜਾਂਚ ਕੀਤੀ ਜਾਂਦੀ ਹੈ।	2
2.2.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਕਈ ਇਨਪੁਟ ਕਸਿਮਾਂ ਵੱਲੋਂ ਫੈਲੇ ਤਾਲਮੇਲ ਵਾਲੇ ਹਮਲਿਆਂ (ਜਵਿੰ, ਚਤਿਰਾਂ ਵੱਲੋਂ ਸਟੈਗਨੋਗ੍ਰਾਫਿਕ ਪੇਲੋਡ ਜੋ ਲਿਖਤ ਵੱਲੋਂ prompt ਇੰਜੈਕਸ਼ਨ ਨਾਲ ਜੋੜੇ ਗਏ ਹੋਣ) ਦਾ ਪਤਾ ਲਗਾਇਆ ਜਾਂਦਾ ਹੈ ਅਤੇ ਉਹਨਾਂ ਨੂੰ ਰੋਕਿਆ ਜਾਂਦਾ ਹੈ।	3

References

ਹਵਾਲੇ

- OWASP LLM01:2025 Prompt Injection
- LLM Prompt Injection Prevention Cheat Sheet
- MITRE ATLAS: Adversarial Input Detection
- MITRE ATLAS: LLM Prompt Injection (AML.T0051)

⁵⁰**adversarial perturbations** (EN) -> ਵਰਿਧੀ ਵਰਿਧਾਂ — ਵਰਿਧੀ (opposing) avoids the personal-enmity charge of ਦੁਸ਼ਮਣ, and ਵਰਿਧਾਂ denotes a crafted distortion rather than the accidental malfunction ਗੜਬੜੀ would imply. Full discussion: OPEN-QUESTIONS.md Q35.

⁵¹**steganographic payloads** (EN) -> ਸਟੈਗਨੋਗ੍ਰਾਫਿਕ ਪੇਲੋਡ — kept as a loan because the calque ਗੁਪਤ-ਲਿਖਤ would collide conceptually with encryption, blurring the hidden-channel threat this control targets. Full discussion: OPEN-QUESTIONS.md Q36.

C3 Model Lifecycle Management & Change Control

C3 ਮਾਡਲ ਜੀਵਨ-ਚੱਕਰ ਪ੍ਰਬੰਧਨ ਅਤੇ ਤਬਦੀਲੀ ਨਿਯੰਤਰਣ

Control Objective

ਨਿਯੰਤਰਣ ਉਦੇਸ਼

This chapter addresses control of model changes so that unauthorized or unsafe modifications cannot reach production.

ਇਹ ਅਧਿਆਇ ਮਾਡਲ ਤਬਦੀਲੀਆਂ ਦੇ ਨਿਯੰਤਰਣ ਨੂੰ ਸੰਬੰਧਿਤ ਕਰਦਾ ਹੈ ਤਾਂ ਜੋ ਅਣਅਧਿਕਾਰਤ ਜਾਂ ਗੈਰ-ਸਲਾਮਤ (unsafe) ਸੋਧਾਂ ਉਤਪਾਦਨ (production) ਤੱਕ ਨਾ ਪਹੁੰਚ ਸਕਣ।

C3.1 Model Authorization & Integrity

C3.1 ਮਾਡਲ ਅਧਿਕਾਰੀਕਰਨ ਅਤੇ ਅਖੰਡਤਾ

Only authorized models with verified integrity should reach production environments.

ਸਿਰਫ਼ ਉਹੀ ਅਧਿਕਾਰਤ ਮਾਡਲ ਉਤਪਾਦਨ ਵਾਤਾਵਰਣਾਂ ਤੱਕ ਪਹੁੰਚਣੇ ਚਾਹੀਦੇ ਹਨ ਜਿਨ੍ਹਾਂ ਦੀ ਅਖੰਡਤਾ (integrity) ਤਸਦੀਕ ਕੀਤੀ ਗਈ ਹੋਵੇ।

#	Description	Level
3.1.1	Verify that a model registry maintains an inventory of all deployed model artifacts and their origin.	1
3.1.2	Verify that all model artifacts (weights, configurations, tokenizers, base models, fine-tunes, adapters, and safety/policy models) are cryptographically signed by authorized entities.	2
3.1.3	Verify that model cryptographic signatures are verified at deployment admission and on load.	2

#	ਵੇਰਵਾ	ਪੱਧਰ
3.1.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਇੱਕ ਮਾਡਲ ਰਜਿਸਟਰੀ ⁵² ਸਾਰੇ ਤੈਨਾਤ ਕੀਤੇ ਮਾਡਲ ਆਰਟੀਫੈਕਟਾਂ ਅਤੇ ਉਹਨਾਂ ਦੇ ਮੂਲ ਦੀ ਇਨਵੈਂਟਰੀ ਰੱਖਦੀ ਹੈ।	1
3.1.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਾਰੇ ਮਾਡਲ ਆਰਟੀਫੈਕਟ (ਵੇਟਸ (weights), ਸੰਰਚਨਾਵਾਂ, ਟੋਕਨਾਈਜ਼ਰ ⁵³ , ਬੇਸ ਮਾਡਲ, ਫਾਈਨ-ਟਿਊਨ, ਅਡੈਪਟਰ, ਅਤੇ ਸਲਾਮਤੀ (safety)/ਨੀਤੀ ਮਾਡਲ) ਅਧਿਕਾਰਤ ਇਕਾਈਆਂ ਦੁਆਰਾ ਕ੍ਰਿਪਟੋਗ੍ਰਾਫਿਕ ਤੌਰ 'ਤੇ ਦਸਤਖਤ ਕੀਤੇ ਗਏ ਹਨ।	2
3.1.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਾਡਲ ਦੇ ਕ੍ਰਿਪਟੋਗ੍ਰਾਫਿਕ ਦਸਤਖਤ ਤੈਨਾਤੀ ਦਾਖਲੇ ਸਮੇਂ ਅਤੇ ਲੋਡ ਹੋਣ ਸਮੇਂ ਤਸਦੀਕ ਕੀਤੇ ਜਾਂਦੇ ਹਨ।	2

⁵²**model registry** (EN) -> ਮਾਡਲ ਰਜਿਸਟਰੀ — a loan for a named piece of MLOps infrastructure, parallel to the already-settled loan ਇਨਵੈਂਟਰੀ for what it holds. Full discussion: OPEN-QUESTIONS.md Q61.

⁵³**tokenizer** (EN) -> ਟੋਕਨਾਈਜ਼ਰ — a straight transliteration, since a tokenizer is a shipped, signable model artifact and a reviewer must be able to match the term to the file in their own registry. Full discussion: OPEN-QUESTIONS.md Q55.

C3.2 Model Validation & Testing

C3.2 ਮਾਡਲ ਪ੍ਰਮਾਣਿਕਤਾ ਅਤੇ ਟੈਸਟਿੰਗ

Models must pass defined security and safety validations before deployment.

ਮਾਡਲਾਂ ਲਈ ਤੈਨਾਤੀ ਤੋਂ ਪਹਿਲਾਂ ਪਰਭਾਸ਼ਤ ਸੁਰੱਖਿਆ (security) ਅਤੇ ਸਲਾਮਤੀ (safety) ਪ੍ਰਮਾਣਿਕਤਾਵਾਂ ਪਾਸ ਕਰਨੀਆਂ ਲਾਜ਼ਮੀ ਹਨ।

#	Description	Level
3.2.1	Verify that models undergo automated input validation testing, safety evaluation testing, and output sanitization testing before deployment.	1
3.2.2	Verify that models subjected to post-training quantization are re-evaluated against the same safety and alignment test suite on the compressed artifact before deployment.	2
3.2.3	Verify that provider model, version, or routing changes trigger security re-evaluation before continued use.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
3.2.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਾਡਲ ਤੈਨਾਤੀ ਤੋਂ ਪਹਿਲਾਂ ਸਵੈਚਲਤਿ ਇਨਪੁਟ ਪ੍ਰਮਾਣਿਕਤਾ ਟੈਸਟਿੰਗ, ਸਲਾਮਤੀ ਮੁਲਾਂਕਣ ਟੈਸਟਿੰਗ, ਅਤੇ ਆਉਟਪੁੱਟ ਸੈਨੀਟਾਈਜ਼ੇਸ਼ਨ ਟੈਸਟਿੰਗ ਵਰਤੋਂ ਲੰਘਦੇ ਹਨ।	1
3.2.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਥਿਲਾਈ-ਉਪਰੰਤ ਕੁਆਂਟਾਈਜ਼ੇਸ਼ਨ ⁵⁴ (post-training quantization) ਵਰਤੋਂ ਲੰਘੇ ਮਾਡਲਾਂ ਦਾ, ਤੈਨਾਤੀ ਤੋਂ ਪਹਿਲਾਂ, ਸੰਕੁਚਤਿ ਆਰਟੀਫੈਕਟ ਉੱਤੇ ਉਸੇ ਸਲਾਮਤੀ ਅਤੇ ਅਲਾਈਨਮੈਂਟ ⁵⁵ (alignment) ਟੈਸਟ ਸੂਟ ਦੇ ਵਰਤੋਂ ਮੁੜ-ਮੁਲਾਂਕਣ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	2
3.2.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਪ੍ਰਦਾਤਾ ਦੇ ਮਾਡਲ, ਵਰਜਨ, ਜਾਂ ਰੂਟਿੰਗ ਵਰਤੋਂ ਤਬਦੀਲੀਆਂ ਵਰਤੋਂ ਜਾਰੀ ਰੱਖਣ ਤੋਂ ਪਹਿਲਾਂ ਸੁਰੱਖਿਆ ਮੁੜ-ਮੁਲਾਂਕਣ ਨੂੰ ਸ਼ੁਰੂ ਕਰਦੀਆਂ ਹਨ।	3

C3.3 Controlled Deployment & Rollback

C3.3 ਨਿਯੰਤਰਤਿ ਤੈਨਾਤੀ ਅਤੇ ਰੋਲਬੈਕ

Model deployments must be controlled, monitored, and reversible to support lifecycle management.

ਜੀਵਨ-ਚੱਕਰ ਪ੍ਰਬੰਧਨ ਦਾ ਸਮਰਥਨ ਕਰਨ ਲਈ ਮਾਡਲ ਤੈਨਾਤੀਆਂ ਦਾ ਨਿਯੰਤਰਤਿ, ਨਗਿਰਾਨੀ ਅਧੀਨ, ਅਤੇ ਉਲਟਾਉਣਯੋਗ ਹੋਣਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
3.3.1	Verify that production deployments implement rollout mechanisms with automated rollback triggers.	2
3.3.2	Verify that rollback capabilities restore the complete model state.	2
3.3.3	Verify that model versions running in parallel use isolated runtime state so that AI-specific shared resources are not shared across deployments.	2

⁵⁴**post-training quantization** (EN) -> ਸਥਿਲਾਈ-ਉਪਰੰਤ ਕੁਆਂਟਾਈਜ਼ੇਸ਼ਨ — the loan avoids colliding with ਮਾਤਰਾ, the Gurmukhi vowel-sign term, which the literal calque ਮਾਤਰਾਕਰਨ would silently reuse. Full discussion: OPEN-QUESTIONS.md Q57.

⁵⁵**alignment** (EN) -> ਅਲਾਈਨਮੈਂਟ — kept as a neutral loan because every native candidate (ਇਕਸੁਰਤਾ, ਸੁਮੇਲ, ਤਾਲਮੇਲ) carries a musical or devotional harmony sense unsuitable for this high-risk AI-safety term. Full discussion: OPEN-QUESTIONS.md Q56.

#	ਵੇਰਵਾ	ਪੱਧਰ
3.3.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਉਤਪਾਦਨ ਤੈਨਾਤੀਆਂ ਸਵੈਚਲਤਿ ਰੋਲਬੈਕ ⁵⁶ ਟ੍ਰੀਗਰਾਂ ਦੇ ਨਾਲ ਰੋਲਆਊਟ ਵਧੀਆਂ ਲਾਗੂ ਕਰਦੀਆਂ ਹਨ।	2
3.3.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਰੋਲਬੈਕ ਸਮਰੱਥਾਵਾਂ ਮਾਡਲ ਦੀ ਸੰਪੂਰਨ ਸਥਿਤੀ ਨੂੰ ਬਹਾਲ ਕਰਦੀਆਂ ਹਨ।	2
3.3.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਮਾਨਾਂਤਰ ਚੱਲ ਰਹੇ ਮਾਡਲ ਵਰਜਨ ਅਲੱਗ-ਥਲੱਗ ਕੀਤੀ ਰਨਟਾਈਮ ਸਥਿਤੀ ਵਰਤਦੇ ਹਨ ਤਾਂ ਜੋ AI-ਵਸ਼ਿਸ਼ ਸਾਂਝੇ ਸਰੋਤ ਵੱਖ-ਵੱਖ ਤੈਨਾਤੀਆਂ ਵਚਿਕਾਰ ਸਾਂਝੇ ਨਾ ਕੀਤੇ ਜਾਣ।	2

C3.4 Secure Development Practices

C3.4 ਸੁਰੱਖਿਅਤ ਵਕਾਸ ਅਮਲ

Model development environments must be separated from production environments.

ਮਾਡਲ ਵਕਾਸ ਵਾਤਾਵਰਣਾਂ ਨੂੰ ਉਤਪਾਦਨ ਵਾਤਾਵਰਣਾਂ ਤੋਂ ਵੱਖ ਕੀਤਾ ਜਾਣਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
3.4.1	Verify that AI-specific runtime components are not shared across environment boundaries (e.g., development, staging, production).	1
3.4.2	Verify that model training and fine-tuning environments are isolated from production environments.	2

#	ਵੇਰਵਾ	ਪੱਧਰ
3.4.1	ਤਸਦੀਕ ਕਰੋ ਕਿ AI-ਵਸ਼ਿਸ਼ ਰਨਟਾਈਮ ਹਸਿੰ ⁵⁷ ਵਾਤਾਵਰਣ ਸੀਮਾਵਾਂ (ਜਵਿੰ, ਵਕਾਸ, ਸਟੇਜਿੰਗ, ਉਤਪਾਦਨ) ਦੇ ਆਰ-ਪਾਰ ਸਾਂਝੇ ਨਹੀਂ ਕੀਤੇ ਜਾਂਦੇ।	1
3.4.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਾਡਲ ਸਖਿਲਾਈ ਅਤੇ ਫ਼ਾਈਨ-ਟਿਊਨਿੰਗ ਵਾਤਾਵਰਣ ਉਤਪਾਦਨ ਵਾਤਾਵਰਣਾਂ ਤੋਂ ਅਲੱਗ-ਥਲੱਗ ਕੀਤੇ ਗਏ ਹਨ।	2

C3.5 Pipeline Fine-Tuning

C3.5 ਪਾਈਪਲਾਈਨ ਫ਼ਾਈਨ-ਟਿਊਨਿੰਗ

Fine-tuning pipelines are high-privilege operations that can alter deployed model behavior at scale. Multi-stage pipelines compound this risk because a compromise at any intermediate stage produces a subtly altered artifact that subsequent stages accept.

ਫ਼ਾਈਨ-ਟਿਊਨਿੰਗ ਪਾਈਪਲਾਈਨਾਂ ਉੱਚ-ਵਸ਼ਿਸ਼ ਅਧਿਕਾਰ ਵਾਲੀਆਂ ਕਾਰਵਾਈਆਂ ਹਨ ਜੋ ਤੈਨਾਤ ਕੀਤੇ ਮਾਡਲ ਦੇ ਵਵਿਹਾਰ ਨੂੰ ਵੱਡੇ ਪੱਧਰ 'ਤੇ ਬਦਲ ਸਕਦੀਆਂ ਹਨ। ਬਹੁ-ਪੜਾਵੀ ਪਾਈਪਲਾਈਨਾਂ ਇਸ ਜੋਖਮ ਨੂੰ ਹੋਰ ਵਧਾ ਦਿੰਦੀਆਂ ਹਨ ਕਿਉਂਕਿ ਕਸਿ ਵੀ ਵਚਿਕਾਰਲੇ ਪੜਾਅ 'ਤੇ ਹੋਇਆ ਸਮਝੌਤਾ (compromise) ਇੱਕ ਸੂਖਮ ਢੰਗ ਨਾਲ ਬਦਲਿਆ ਹੋਇਆ ਆਰਟੀਫ਼ੈਕਟ ਪੈਦਾ ਕਰਦਾ ਹੈ ਜਿਸਨੂੰ ਅਗਲੇ ਪੜਾਅ ਸਵੀਕਾਰ ਕਰ ਲੈਂਦੇ ਹਨ।

⁵⁶ **rollout mechanisms, rollback triggers/capabilities** (EN) -> ਰੋਲਆਊਟ, ਰੋਲਬੈਕ — kept as loans because these name configured deployment-pipeline mechanisms a reviewer inspects, not described actions, so the noun sense must survive translation. Full discussion: OPEN-QUESTIONS.md Q58.

⁵⁷ **components** (EN) -> ਹਸਿੰ — this chapter uses the native ਹਸਿੰ for “runtime components,” while other AISVS chapters use the loan ਕੰਪੋਨੈਂਟ for the same term of art; the corpus audit flagged the split as unresolved rather than silently normalising it. Full discussion: OPEN-QUESTIONS.md Q95.

#	Description	Level
3.5.1	Verify that models used in RLHF fine-tuning are versioned and integrity-verified before use in a training run.	2
3.5.2	Verify that RLHF training stages include automated detection of reward hacking or reward model over-optimization.	3
3.5.3	Verify that in multi-stage fine-tuning pipelines, each stage's output is integrity-verified before it is consumed by the next stage.	3
3.5.4	Verify that fine-tuning checkpoints are registered as distinct artifacts.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
3.5.1	ਤਸਦੀਕ ਕਰੋ ਕਿ RLHF ਫ਼ਾਈਨ-ਟਿਊਨਿੰਗ ਵਿੱਚ ਵਰਤੇ ਜਾਂਦੇ ਮਾਡਲ ਕਸਿ ਸਖਿਲਾਈ ਦੌਰ (training run) ਵਿੱਚ ਵਰਤੋਂ ਤੋਂ ਪਹਿਲਾਂ ਵਰਜਨਬੱਧ ਕੀਤੇ ਜਾਂਦੇ ਹਨ ਅਤੇ ਉਹਨਾਂ ਦੀ ਅਖੰਡਤਾ ਤਸਦੀਕ ਕੀਤੀ ਜਾਂਦੀ ਹੈ।	2
3.5.2	ਤਸਦੀਕ ਕਰੋ ਕਿ RLHF ਸਖਿਲਾਈ ਪੜਾਵਾਂ ਵਿੱਚ reward hacking ⁵⁸ (ਇਨਾਮ ਦੀ ਦੁਰਵਰਤੋਂ) ਜਾਂ reward model (ਇਨਾਮ ਮਾਡਲ) ਦੇ ਹੱਦੋਂ ਵੱਧ ਅਨੁਕੂਲਨ (over-optimization) ਦੀ ਸਵੈਚਲਤਿ ਪਛਾਣ ਸ਼ਾਮਲ ਹੈ।	3
3.5.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਬਹੁ-ਪੜਾਵੀ ਫ਼ਾਈਨ-ਟਿਊਨਿੰਗ ਪਾਈਪਲਾਈਨਾਂ ਵਿੱਚ, ਹਰ ਪੜਾਅ ਦੇ ਆਊਟਪੁੱਟ ਦੀ ਅਖੰਡਤਾ, ਅਗਲੇ ਪੜਾਅ ਦੁਆਰਾ ਵਰਤੇ ਜਾਣ ਤੋਂ ਪਹਿਲਾਂ, ਤਸਦੀਕ ਕੀਤੀ ਜਾਂਦੀ ਹੈ।	3
3.5.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਫ਼ਾਈਨ-ਟਿਊਨਿੰਗ ਚੈਕਪੁਆਇੰਟ ⁵⁹ ਵੱਖਰੇ ਆਰਟੀਫੈਕਟਾਂ ਵਜੋਂ ਰਜਿਸਟਰ ਕੀਤੇ ਜਾਂਦੇ ਹਨ।	3

References

ਹਵਾਲੇ

- MITRE ATLAS
- OWASP AI Testing Guide
- NIST SP 800-218A: Secure Software Development Practices for Generative AI
- ISO/IEC 42001:2023 Artificial Intelligence Management System
- NIST AI Risk Management Framework

⁵⁸**reward hacking** (EN) -> retained, glossed ਇਨਾਮ ਦੀ ਦੁਰਵਰਤੋਂ — ਦੁਰਵਰਤੋਂ (“misuse”) was chosen over a literal “hacking” calque because the concept is a gamed reward signal, not a system intrusion. Full discussion: OPEN-QUESTIONS.md Q59.

⁵⁹**checkpoint** (EN) -> ਚੈਕਪੁਆਇੰਟ — kept as a loan because the literal calques ਜਾਂਚ-ਬੰਦੂ and ਸੰਭਾਲ-ਬੰਦੂ both collide with senses of “check” and “handling” already reserved elsewhere in the corpus. Full discussion: OPEN-QUESTIONS.md Q60.

C4 Infrastructure, Configuration & Deployment Security

C4 ਬੁਨਿਆਦੀ ਢਾਂਚਾ, ਸੰਰਚਨਾ ਅਤੇ ਤੈਨਾਤੀ ਸੁਰੱਖਿਆ

Control Objective

ਨਿਯੰਤਰਣ ਉਦੇਸ਼

This chapter addresses hardening AI-specific infrastructure components against model theft, data leakage, and cross-tenant contamination.

ਇਹ ਅਧਿਆਇ ਮਾਡਲ ਚੋਰੀ⁶⁰ (model theft), ਡਾਟਾ ਲੀਕੇਜ਼, ਅਤੇ ਟੈਨੈਂਟਾਂ ਵਿਚਕਾਰ ਦੂਸ਼ਣ⁶¹ (cross-tenant contamination) ਦੇ ਵਿਰੁੱਧ AI-ਵਸ਼ਿਸ਼ ਬੁਨਿਆਦੀ ਢਾਂਚੇ ਦੇ ਹੱਸਿਆ⁶² ਨੂੰ ਸੁਖਤ ਕਰਨ ਨੂੰ ਸੰਬੋਧਤ ਕਰਦਾ ਹੈ।

C4.1 AI Workload Sandboxing & Validation

C4.1 AI ਵਰਕਲੋਡ ਸੈਂਡਬਾਕਸਿੰਗ ਅਤੇ ਪ੍ਰਮਾਣਿਕਤਾ

Untrusted AI models must be isolated in secure sandboxes, and sensitive AI workloads protected using trusted execution environments (TEEs) and confidential computing technologies.

ਗ਼ੈਰ-ਭਰੋਸੇਯੋਗ AI ਮਾਡਲਾਂ ਨੂੰ ਸੁਰੱਖਿਅਤ ਸੈਂਡਬਾਕਸਾਂ⁶³ (sandboxes) ਵਿੱਚ ਅਲੱਗ-ਥਲੱਗ ਕਰਨਾ ਲਾਜ਼ਮੀ ਹੈ, ਅਤੇ ਸੰਵੇਦਨਸ਼ੀਲ AI ਵਰਕਲੋਡਾਂ⁶⁴ ਨੂੰ ਭਰੋਸੇਯੋਗ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਵਾਤਾਵਰਣਾਂ⁶⁵ (trusted execution environments, TEEs) ਅਤੇ ਗੁਪਤ ਕੰਪਿਊਟਿੰਗ (confidential computing) ਤਕਨਾਲੋਜੀਆਂ ਦੀ ਵਰਤੋਂ ਕਰਕੇ ਸੁਰੱਖਿਅਤ ਕਰਨਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
4.1.1	Verify that AI models execute in isolated sandboxes.	1
4.1.2	Verify that model artifact loading enforces an explicit allow-list of serialization formats that do not permit arbitrary code execution during deserialization.	1
4.1.3	Verify that workload attestation is performed before model loading to provide proof that the execution environment has not been tampered with.	3
4.1.4	Verify that confidential inference services protect model weights during runtime through isolated execution environments.	3

⁶⁰**model theft** (EN) -> ਮਾਡਲ ਚੋਰੀ — ਚੋਰੀ (theft) renders the source's plain harm/outcome sense directly, kept distinct from the named C11 technique "model extraction", which stays in English. Full discussion: OPEN-QUESTIONS.md Q54.

⁶¹**cross-tenant contamination** (EN) -> ਟੈਨੈਂਟਾਂ ਵਿਚਕਾਰ ਦੂਸ਼ਣ — ਦੂਸ਼ਣ carries the neutral "one thing tainting another" sense used in scientific Panjabi, avoiding the moral shading of alternatives like ਮਲਿਵਟ. Full discussion: OPEN-QUESTIONS.md Q53.

⁶²**components** (EN) -> ਹੱਸਿਆ — this chapter uses the native ਹੱਸਿਆ for "infrastructure/hardware components," while other AISVS chapters use the loan ਕੰਪੋਨੈਂਟ for the same term of art; the corpus audit flagged the split as unresolved rather than silently normalising it. Full discussion: OPEN-QUESTIONS.md Q95.

⁶³**sandbox, sandboxing** (EN) -> ਸੈਂਡਬਾਕਸ — kept as a loan because a sandbox is a named technical primitive (kernel-enforced process confinement), and a descriptive Panjabi rendering would leave the reader guessing at scope. Full discussion: OPEN-QUESTIONS.md Q47.

⁶⁴**workload, accelerator, edge** (EN) -> ਵਰਕਲੋਡ, ਐਕਸਲੇਰੇਟਰ, ਐਜ — kept as loans because these are deployment-topology terms of art a Panjabi-reading practitioner meets in vendor documentation; a native rendering of "edge" (ਕਨਿਨਾਰ) is purely spatial and would make the section unintelligible. Full discussion: OPEN-QUESTIONS.md Q51.

⁶⁵**trusted execution environment (TEE), confidential computing** (EN) -> ਭਰੋਸੇਯੋਗ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਵਾਤਾਵਰਣ (TEE retained), ਗੁਪਤ ਕੰਪਿਊਟਿੰਗ — the adjectives ਭਰੋਸੇਯੋਗ/ਸੁਰੱਖਿਅਤ/ਗੁਪਤ are translated and kept visibly distinct because the source contrasts a trusted runtime with a secure enclave within one sentence elsewhere in the corpus. Full discussion: OPEN-QUESTIONS.md Q50.

#	ਵੇਰਵਾ	ਪੱਧਰ
4.1.1	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਮਾਡਲ ਅਲੌਗ-ਥਲੌਗ ਕੀਤੇ ਸੈਡਬਾਕਸਾਂ ਵਿੱਚ ਚੱਲਦੇ ਹਨ।	1
4.1.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਾਡਲ ਆਰਟੀਫਿਕਟ ਲੋਡਿੰਗ ਸੀਰੀਅਲਾਈਜ਼ੇਸ਼ਨ ਫਾਰਮੇਟਾਂ ਦੀ ਇੱਕ ਸਪਸ਼ਟ allow-list ਲਾਗੂ ਕਰਦੀ ਹੈ ਜੋ ਡੀਸੀਰੀਅਲਾਈਜ਼ੇਸ਼ਨ ਦੌਰਾਨ ਮਨਮਰਜ਼ੀ ਕੋਡ ਐਗਜ਼ੀਕਿਊਸ਼ਨ (arbitrary code execution) ਦੀ ਆਗਿਆ ਨਹੀਂ ਦਿੰਦੀ।	1
4.1.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਾਡਲ ਲੋਡ ਕਰਨ ਤੋਂ ਪਹਿਲਾਂ ਵਰਕਲੋਡ ਅਟੈਸਟੇਸ਼ਨ ⁶⁶ (workload attestation) ਕੀਤੀ ਜਾਂਦੀ ਹੈ ਤਾਂ ਜੋ ਇਹ ਸਬੂਤ ਮਿਲੇ ਕਿ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਵਾਤਾਵਰਣ ਨਾਲ ਫੇੜਛਾੜ ਨਹੀਂ ਕੀਤੀ ਗਈ।	3
4.1.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਗੁਪਤ ਇਨਫਰੈਸ ਸੇਵਾਵਾਂ ਅਲੌਗ-ਥਲੌਗ ਕੀਤੇ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਵਾਤਾਵਰਣਾਂ ਰਾਹੀਂ ਰਨਟਾਈਮ ਦੌਰਾਨ ਮਾਡਲ ਵੇਟਸ (model weights) ਦੀ ਸੁਰੱਖਿਆ ਕਰਦੀਆਂ ਹਨ।	3

C4.2 AI Hardware Security

C4.2 AI ਹਾਰਡਵੇਅਰ ਸੁਰੱਖਿਆ

AI-specific hardware components, including GPUs, TPUs, and specialized AI accelerators, must be secured.

AI-ਵਿਸ਼ੇਸ਼ ਹਾਰਡਵੇਅਰ ਹੱਸਿਆਂ ਨੂੰ, ਜਿਨ੍ਹਾਂ ਵਿੱਚ GPU, TPU, ਅਤੇ ਵਿਸ਼ੇਸ਼ AI ਐਕਸਲੇਰੇਟਰ (accelerators) ਸ਼ਾਮਲ ਹਨ, ਸੁਰੱਖਿਅਤ ਕਰਨਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
4.2.1	Verify that AI accelerator (GPU) firmware is version-pinned, signed, and attested at boot.	2
4.2.2	Verify that execution within a trusted execution environment (TEE) provides hardware-enforced isolation, memory encryption, and integrity protection.	3
4.2.3	Verify that AI accelerator (GPU) integrity is validated using hardware-based attestation mechanisms before each workload executes.	3
4.2.4	Verify that accelerator (GPU) memory is isolated between workloads through partitioning mechanisms with memory sanitization between jobs.	3
4.2.5	Verify that accelerator interconnects are restricted to approved topologies and authenticated endpoints.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
4.2.1	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਐਕਸਲੇਰੇਟਰ (GPU) ਫਰਮਵੇਅਰ ਵਰਜ਼ਨ-ਪਿਨਿੰਗ ਕੀਤਾ, ਦਸਤਖਤ ਕੀਤਾ, ਅਤੇ ਬੂਟ ਵੇਲੇ ਅਟੈਸਟ ਕੀਤਾ ਗਿਆ ਹੈ।	2
4.2.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਭਰੋਸੇਯੋਗ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਵਾਤਾਵਰਣ (trusted execution environment, TEE) ਦੇ ਅੰਦਰ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਹਾਰਡਵੇਅਰ ਦੁਆਰਾ ਲਾਗੂ ਕੀਤੀ ਅਲੌਗ-ਥਲੌਗਤਾ, ਮੈਮੋਰੀ ⁶⁷ ਏਨਕ੍ਰਿਪਸ਼ਨ, ਅਤੇ ਅਖੰਡਤਾ (integrity) ਸੁਰੱਖਿਆ ਪ੍ਰਦਾਨ ਕਰਦਾ ਹੈ।	3
4.2.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਹਰ ਵਰਕਲੋਡ ਦੇ ਚੱਲਣ ਤੋਂ ਪਹਿਲਾਂ AI ਐਕਸਲੇਰੇਟਰ (GPU) ਦੀ ਅਖੰਡਤਾ ਨੂੰ ਹਾਰਡਵੇਅਰ-ਆਧਾਰਤ ਅਟੈਸਟੇਸ਼ਨ ਵਿਧੀਆਂ ਦੀ ਵਰਤੋਂ ਕਰਕੇ ਪ੍ਰਮਾਣਿਤ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	3

⁶⁶ **attestation** (EN) -> ਅਟੈਸਟੇਸ਼ਨ — kept as a loan because the four adjacent verbs verify/validate/authenticate/certify are already locked to four distinct Panjabi words elsewhere in the corpus, leaving no native candidate free for this fifth, distinct concept. Full discussion: OPEN-QUESTIONS.md Q48.

⁶⁷ **memory** (EN) -> ਮੈਮੋਰੀ — kept as a neutral loan for hardware memory (GPU VRAM, process address space); the native candidates ਯਾਦਦਾਸ਼ਤ and ਸਮਿਰਨ were rejected for anthropomorphising hardware and for devotional-remembrance connotations respectively. Full discussion: OPEN-QUESTIONS.md Q49.

#	ਵੇਰਵਾ	ਪੱਧਰ
4.2.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਐਕਸਲੇਰੇਟਰ (GPU) ਮੈਮੋਰੀ ਨੂੰ ਵਰਕਲੋਡ ਦੇ ਵਚਿਕਾਰ ਵਭਾਜਨ ਵਧੀਆਂ ਰਾਹੀਂ ਅਲੱਗ-ਥਲੱਗ ਕੀਤਾ ਜਾਂਦਾ ਹੈ, ਜਿਸ ਵਿੱਚ ਕੰਮਾਂ ਦੇ ਵਚਿਕਾਰ ਮੈਮੋਰੀ ਸੈਨੀਟਾਈਜ਼ੇਸ਼ਨ ਸ਼ਾਮਲ ਹੈ।	3
4.2.5	ਤਸਦੀਕ ਕਰੋ ਕਿ ਐਕਸਲੇਰੇਟਰ ਇੰਟਰਕਨੈਕਟ ਪ੍ਰਵਾਨਾਤਿ ਟੋਪੋਲੋਜੀਆਂ ਅਤੇ ਪ੍ਰਮਾਣੀਕਰਨ ਕੀਤੇ ਐਂਡਪੋਇੰਟਾਂ ਤੱਕ ਸੀਮਤਿ ਹਨ।	3

C4.3 Edge & Distributed AI Security

C4.3 ਐਜ ਅਤੇ ਵੰਡੇ ਹੋਏ AI ਦੀ ਸੁਰੱਖਿਆ

Distributed AI deployments, including edge computing, federated learning, and multi-site architectures, must be secured.

ਵੰਡੀਆਂ ਹੋਈਆਂ AI ਤੈਨਾਤੀਆਂ ਨੂੰ, ਜਿਨ੍ਹਾਂ ਵਿੱਚ ਐਜ ਕੰਪਿਊਟਿੰਗ (edge computing), ਫੈਡਰੇਟਡ ਲਰਨਿੰਗ⁶⁸ (federated learning), ਅਤੇ ਬਹੁ-ਸਾਈਟ ਆਰਕੀਟੈਕਚਰ ਸ਼ਾਮਲ ਹਨ, ਸੁਰੱਖਿਅਤ ਕਰਨਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
4.3.1	Verify that edge AI devices authenticate to central infrastructure using strong authentication mechanisms.	1
4.3.2	Verify that models deployed to edge or mobile devices are cryptographically signed during packaging, and that the on-device runtime validates these signatures or checksums before loading or inference.	2
4.3.3	Verify that inference runtimes enforce process, memory, and file access isolation.	3
4.3.4	Verify that model weights and sensitive parameters stored locally are encrypted using hardware-backed key stores or secure enclaves.	3
4.3.5	Verify that models packaged within mobile, IoT, or embedded applications are encrypted at rest, and decrypted only inside a trusted runtime or secure enclave, preventing direct extraction from the app package or filesystem.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
4.3.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਐਜ AI ਡਵਾਈਸ ਮਜ਼ਬੂਤ ਪ੍ਰਮਾਣੀਕਰਨ ਵਧੀਆਂ ਦੀ ਵਰਤੋਂ ਕਰਕੇ ਕੇਂਦਰੀ ਬੁਨਿਆਦੀ ਢਾਂਚੇ ਨਾਲ ਪ੍ਰਮਾਣੀਕਰਨ ਕਰਦੇ ਹਨ।	1
4.3.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਐਜ ਜਾਂ ਮੋਬਾਈਲ ਡਵਾਈਸਾਂ 'ਤੇ ਤੈਨਾਤ ਕੀਤੇ ਮਾਡਲ ਪੈਕੇਜਿੰਗ ਦੌਰਾਨ ਕ੍ਰਿਪਟੋਗ੍ਰਾਫਿਕ ਤੌਰ 'ਤੇ ਦਸਤਖਤ ਕੀਤੇ ਜਾਂਦੇ ਹਨ, ਅਤੇ ਇਹ ਕਿ ਡਵਾਈਸ 'ਤੇ ਮੌਜੂਦ ਰਨਟਾਈਮ ਲੋਡਿੰਗ ਜਾਂ ਇਨਫ਼ਰੈਂਸ ਤੋਂ ਪਹਿਲਾਂ ਇਹਨਾਂ ਦਸਤਖਤਾਂ ਜਾਂ ਚੈਕਸਮਾਂ ਨੂੰ ਪ੍ਰਮਾਣਿਤ ਕਰਦਾ ਹੈ।	2
4.3.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਇਨਫ਼ਰੈਂਸ ਰਨਟਾਈਮ ਪ੍ਰਕਿਰਿਆ, ਮੈਮੋਰੀ, ਅਤੇ ਫ਼ਾਈਲ ਪਹੁੰਚ ਦੀ ਅਲੱਗ-ਥਲੱਗਤਾ ਲਾਗੂ ਕਰਦੇ ਹਨ।	3
4.3.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਥਾਨਕ ਤੌਰ 'ਤੇ ਸੰਭਾਲੇ ਮਾਡਲ ਵੇਟਸ ਅਤੇ ਸੰਵੇਦਨਸ਼ੀਲ ਪੈਰਾਮੀਟਰ ਹਾਰਡਵੇਅਰ-ਸਮਰਥਤ ਕੁੰਜੀ ਸਟੋਰਾਂ ਜਾਂ ਸੁਰੱਖਿਅਤ ਐਨਕਲੇਵਾਂ (secure enclaves) ਦੀ ਵਰਤੋਂ ਕਰਕੇ ਏਨਕ੍ਰਿਪਟ ਕੀਤੇ ਜਾਂਦੇ ਹਨ।	3
4.3.5	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮੋਬਾਈਲ, IoT, ਜਾਂ ਏਮਬੈਡਡ ਐਪਲੀਕੇਸ਼ਨਾਂ ਦੇ ਅੰਦਰ ਪੈਕ ਕੀਤੇ ਮਾਡਲ ਸਥਿਤੀ ਵਿੱਚ (at rest) ਏਨਕ੍ਰਿਪਟ ਕੀਤੇ ਜਾਂਦੇ ਹਨ, ਅਤੇ ਸਰਿਫ਼ ਇੱਕ ਭਰੋਸੇਯੋਗ ਰਨਟਾਈਮ ਜਾਂ ਸੁਰੱਖਿਅਤ ਐਨਕਲੇਵ ਦੇ ਅੰਦਰ ਹੀ ਡੀਕ੍ਰਿਪਟ ਕੀਤੇ ਜਾਂਦੇ ਹਨ, ਜਿਸ ਨਾਲ ਐਪ ਪੈਕੇਜ ਜਾਂ ਫ਼ਾਈਲਸਿਸਟਮ ਤੋਂ ਸਥਿਤ ਕੱਢਣ ਨੂੰ ਰੋਕਿਆ ਜਾਂਦਾ ਹੈ।	3

⁶⁸**federated learning** (EN) -> ਫੈਡਰੇਟਡ ਲਰਨਿੰਗ — kept as a loan/named technique because ਸੰਘੀ ਸਥਿਲਾਈ misleads toward political federation, and the source sentence needs “federated” to stay visibly distinct from “distributed” in the same list. Full discussion: OPEN-QUESTIONS.md Q52.

References

ਹਵਾਲੇ

- NIST AI Risk Management Framework
- NIST SP 800-190: Application Container Security Guide
- NSA/CISA Kubernetes Hardening Guidance
- Confidential Computing Consortium

C5 Access Control & Identity for AI Components & Users

C5 AI ਕੰਪੋਨੈਂਟਾਂ⁶⁹ ਅਤੇ ਉਪਭੋਗਤਾਵਾਂ ਲਈ ਪਹੁੰਚ ਕੰਟਰੋਲ ਅਤੇ ਪਛਾਣ

Control Objective

ਨਿਯੰਤਰਣ ਉਦੇਸ਼

This chapter addresses access control challenges that AI systems introduce beyond traditional application security. ਇਹ ਅਧਿਆਇ ਉਹਨਾਂ ਪਹੁੰਚ ਕੰਟਰੋਲ ਚੁਣੌਤੀਆਂ ਨੂੰ ਸੰਬੋਧਿਤ ਕਰਦਾ ਹੈ ਜੋ AI ਸਿਸਟਮ ਰਵਾਇਤੀ ਐਪਲੀਕੇਸ਼ਨ ਸੁਰੱਖਿਆ ਤੋਂ ਪਰੇ ਪੇਸ਼ ਕਰਦੇ ਹਨ।

C5.1 Authentication

C5.1 ਪ੍ਰਮਾਣੀਕਰਨ

AI agents and human users accessing resources must be properly authenticated and authorized for their level of access.

ਸਰੋਤਾਂ ਤੱਕ ਪਹੁੰਚ ਕਰਨ ਵਾਲੇ AI ਏਜੰਟਾਂ⁷⁰ ਅਤੇ ਮਨੁੱਖੀ ਉਪਭੋਗਤਾਵਾਂ ਦਾ ਉਹਨਾਂ ਦੀ ਪਹੁੰਚ ਦੇ ਪੱਧਰ ਲਈ ਸਹੀ ਢੰਗ ਨਾਲ ਪ੍ਰਮਾਣੀਕਰਨ (authentication) ਅਤੇ ਅਧਿਕਾਰੀਕਰਨ (authorization) ਹੋਣਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
5.1.1	Verify that high-risk AI operations (model deployment, weight export, training data access, production configuration changes) require step-up authentication.	3
5.1.2	Verify that AI agents in federated or multi-system deployments authenticate using short-lived, minimal-scoped, cryptographically signed tokens.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
5.1.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਉੱਚ-ਜੋਖਮ ਵਾਲੀਆਂ AI ਕਾਰਵਾਈਆਂ (ਮਾਡਲ ਤੈਨਾਤੀ, ਮਾਡਲ ਵੇਟਸ ਨਰਿਯਾਤ, ਸਖਿਲਾਈ ਡਾਟਾ ਪਹੁੰਚ, ਪ੍ਰੋਡਕਸ਼ਨ ਸੰਰਚਨਾ ਤਬਦੀਲੀਆਂ) ਲਈ ਸਟੈਪ-ਅੱਪ ਪ੍ਰਮਾਣੀਕਰਨ ⁷¹ (step-up authentication) ਲੋੜੀਂਦਾ ਹੈ।	3
5.1.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਫੈਡਰੇਟਿਡ ⁷² ਜਾਂ ਬਹੁ-ਸਿਸਟਮ ਤੈਨਾਤੀਆਂ ਵੱਲੋਂ AI ਏਜੰਟ ਥੋੜ੍ਹੇ ਸਮੇਂ ਵਾਲੇ, ਘੱਟੋ-ਘੱਟ ਸਕੋਪ ਵਾਲੇ, ਕ੍ਰਿਪਟੋਗ੍ਰਾਫਿਕ ਤੌਰ 'ਤੇ ਦਸਤਖਤ ਕੀਤੇ ਟੋਕਨਾਂ ਦੀ ਵਰਤੋਂ ਕਰਕੇ ਪ੍ਰਮਾਣੀਕਰਨ ਕਰਦੇ ਹਨ।	3

⁶⁹ **component** (EN) -> ਕੰਪੋਨੈਂਟ — kept as the established loan (this chapter title is one of the sites that fixes it) rather than the native ਹਸਿੰ used for generic parts elsewhere in the corpus; a full-corpus audit found the two forms split by usage and recommended normalising the minority native sites toward this one. Full discussion: OPEN-QUESTIONS.md Q95.

⁷⁰ **AI agent** (EN) -> AI ਏਜੰਟ — rendered as a transliterated loan because “agent” is flagged as a high-risk anthropomorphising term, and every native alternative (ਦੂਤ “messenger”, ਪ੍ਰਤੀਨਿਧਿ “representative”) either carries devotional colour or loses the software sense. Full discussion: OPEN-QUESTIONS.md Q17.

⁷¹ **step-up authentication** (EN) -> ਸਟੈਪ-ਅੱਪ ਪ੍ਰਮਾਣੀਕਰਨ — the modifier is kept as a retained loan rather than translated because “step-up” names a specific industry pattern (NIST SP 800-63-3) distinct from plain re-authentication, and a descriptive Panjabi modifier would flatten that distinction. Full discussion: OPEN-QUESTIONS.md Q23.

⁷² **federated** (EN, as in federated deployments) -> ਫੈਡਰੇਟਿਡ — spelled with the nukta ਫ਼ per the corpus-wide rule that English /f/ takes the nukta; this chapter was one of the sites normalised to match. Full discussion: OPEN-QUESTIONS.md Q52 (spelling rule recorded at Q86).

C5.2 AI Resource Authorization & Classification

C5.2 AI ਸਰੋਤ ਅਧਿਕਾਰੀਕਰਨ ਅਤੇ ਵਰਗੀਕਰਨ

The caller's authorization context must be enforced through AI-specific query pipelines (RAG retrieval, embedding lookups, inference chains) so the system does not return data the caller is not entitled to access.

ਕਾਲਰ ਦੇ ਅਧਿਕਾਰੀਕਰਨ ਸੰਦਰਭ ਨੂੰ AI-ਵਸ਼ਿਸ਼ ਕਰਦੀ ਪਾਈਪਲਾਈਨਾਂ (RAG ਪ੍ਰਾਪਤੀ⁷³, embedding⁷⁴ ਖੋਜਾਂ, ਇਨਫਰੈਂਸ⁷⁵ ਲੜੀਆਂ) ਰਾਹੀਂ ਲਾਗੂ ਕਰਨਾ ਲਾਜ਼ਮੀ ਹੈ ਤਾਂ ਜੋ ਸਸਿਟਮ ਅਜਹਿ ਡਾਟਾ ਵਾਪਸ ਨਾ ਕਰੇ ਜਿਸ ਤੱਕ ਪਹੁੰਚ ਦਾ ਕਾਲਰ ਨੂੰ ਹੱਕ ਨਹੀਂ ਹੈ।

#	Description	Level
5.2.1	Verify that every AI resource (datasets, endpoints, vector collections, embedding indices, compute instances) enforces access controls with explicit allow-lists and default-deny policies.	2
5.2.2	Verify that retrieval pipelines (e.g., RAG queries, embedding lookups) enforce the end-user's authorization context at each retrieval and assembly stage, rather than relying solely on the service account's permissions.	2
5.2.3	Verify that sensitive data is retrieved via retrieval pipelines (e.g., RAG queries, embedding lookups) to prevent permanent storage in models.	2
5.2.4	Verify that post-inference filtering mechanisms prevent responses from including data that the requester is not authorized to receive.	2
5.2.5	Verify that the policy decision point for agent authorization is isolated from the agent's execution environment.	2
5.2.6	Verify that privileged access to model weights, training pipelines, and production AI configuration is granted just in time, with a defined maximum session duration and automatic expiry. Zero Standing Privilege (ZSP) to these resources is encouraged.	3
5.2.7	Verify that data classification labels propagate to downstream resources (embeddings, prompt caches, model outputs).	3

#	ਵੇਰਵਾ	ਪੱਧਰ
5.2.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਹਰ AI ਸਰੋਤ (ਡਾਟਾਸੈੱਟ, ਐਂਡਪੁਆਇੰਟ, ਵੈਕਟਰ ਸੰਗ੍ਰਹ, embedding ਇੰਡੈਕਸ, ਕੰਪਿਊਟ ਇੰਸਟਾਂਸ) ਸਪੱਸ਼ਟ allow-list ਅਤੇ ਡਿਫਾਲਟ-ਇਨਕਾਰ ਨੀਤੀਆਂ ਨਾਲ ਪਹੁੰਚ ਕੰਟਰੋਲ ਲਾਗੂ ਕਰਦਾ ਹੈ।	2
5.2.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਪ੍ਰਾਪਤੀ ਪਾਈਪਲਾਈਨਾਂ (ਜਿਵੇਂ, RAG ਕਰਿਊਰੀਆਂ, embedding ਖੋਜਾਂ) ਸਰਿਫ਼ ਸੇਵਾ ਖਾਤੇ ਦੀਆਂ ਇਜਾਜ਼ਤਾਂ 'ਤੇ ਨਿਰਭਰ ਰਹਿਣ ਦੀ ਬਜਾਏ, ਹਰ ਪ੍ਰਾਪਤੀ ਅਤੇ ਅਸੈਂਬਲੀ ਪੜਾਅ 'ਤੇ ਅੰਤਮ-ਉਪਭੋਗਤਾ ਦੇ ਅਧਿਕਾਰੀਕਰਨ ਸੰਦਰਭ ਨੂੰ ਲਾਗੂ ਕਰਦੀਆਂ ਹਨ।	2
5.2.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸੰਵੇਦਨਸ਼ੀਲ ਡਾਟਾ ਮਾਡਲਾਂ ਵਿੱਚ ਸਥਾਈ ਭੰਡਾਰਨ ਨੂੰ ਰੋਕਣ ਲਈ ਪ੍ਰਾਪਤੀ ਪਾਈਪਲਾਈਨਾਂ (ਜਿਵੇਂ, RAG ਕਰਿਊਰੀਆਂ, embedding ਖੋਜਾਂ) ਰਾਹੀਂ ਪ੍ਰਾਪਤ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	2
5.2.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਇਨਫਰੈਂਸ-ਉਪਰੰਤ ਫ਼ਲਿਟਰਿੰਗ ਵਧੀਆਂ ਜਵਾਬਾਂ ਵਿੱਚ ਅਜਹਿ ਡਾਟਾ ਸ਼ਾਮਲ ਹੋਣ ਤੋਂ ਰੋਕਦੀਆਂ ਹਨ ਜਿਸਨੂੰ ਪ੍ਰਾਪਤ ਕਰਨ ਲਈ ਬੇਨਤੀਕਰਤਾ ਅਧਿਕਾਰਤ ਨਹੀਂ ਹੈ।	2

⁷³**retrieval** (EN, as in RAG retrieval) -> ਪ੍ਰਾਪਤੀ — chosen because it is cognate with the verb ਪ੍ਰਾਪਤ ਕੀਤਾ ਜਾਂਦਾ ਹੈ used elsewhere in this chapter, while ਖੋਜ is deliberately reserved for “lookup/search” so the two RAG pipeline stages stay distinguishable. Full discussion: OPEN-QUESTIONS.md Q20.

⁷⁴**embedding** (EN) -> embedding (retained in Latin script) — kept as a retained Latin head rather than transliterated to ਏਮਬੈਡਿੰਗ because that is already the canonical hybrid pattern fixed corpus-wide (embedding ਸਟੋਰ, embedding ਇੰਡੈਕਸ). Full discussion: OPEN-QUESTIONS.md Q19.

⁷⁵**inference** (EN) -> ਇਨਫਰੈਂਸ — kept as a loan rather than ਅਨੁਮਾਨ, because that word is already used elsewhere in the corpus for “expected/anticipated” and would misread inference as an estimated value rather than the act of running the model. Full discussion: OPEN-QUESTIONS.md Q18.

#	ਵੇਰਵਾ	ਪੱਧਰ
5.2.5	ਤਸਦੀਕ ਕਰੋ ਕੀ ਏਜੰਟ ਅਧਿਕਾਰੀਕਰਨ ਲਈ ਨੀਤੀ ਫ਼ੈਸਲਾ ਬਿੰਦੂ ⁷⁶ (policy decision point) ਏਜੰਟ ਦੇ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਵਾਤਾਵਰਣ ਤੋਂ ਅਲੱਗ-ਥਲੱਗ ਹੈ।	2
5.2.6	ਤਸਦੀਕ ਕਰੋ ਕੀ ਮਾਡਲ ਵੇਟਸ (model weights), ਸਥਿਰਤਾ ਪਾਈਪਲਾਈਨਾਂ, ਅਤੇ ਪ੍ਰੋਡਕਸ਼ਨ AI ਸੰਰਚਨਾ ਤੱਕ ਵਸ਼ਿਸ਼-ਅਧਿਕਾਰ ਪ੍ਰਾਪਤ ਪਹੁੰਚ ਇੱਕ ਪਰਭਿਯੋਜਿਤ ਵੱਧ ਤੋਂ ਵੱਧ ਸੈਸ਼ਨ ਮਿਆਦ ਅਤੇ ਆਪਣੇ-ਆਪ ਸਮਾਪਤੀ ਦੇ ਨਾਲ, ਸਰਿਫ਼ ਲੋੜ ਪੈਣ 'ਤੇ ਹੀ (just in time) ਦਿੱਤੀ ਜਾਂਦੀ ਹੈ। ਇਹਨਾਂ ਸਰੋਤਾਂ ਲਈ Zero Standing Privilege (ZSP) ⁷⁷ ਨੂੰ ਉਤਸ਼ਾਹਿਤ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	3
5.2.7	ਤਸਦੀਕ ਕਰੋ ਕੀ ਡਾਟਾ ਵਰਗੀਕਰਨ ਲੇਬਲ ਡਾਊਨਸਟ੍ਰੀਮ ਸਰੋਤਾਂ (embeddings, prompt ਕੈਸ਼ ⁷⁸ , ਮਾਡਲ ਆਊਟਪੁੱਟ) ਤੱਕ ਅੱਗੇ ਸੰਚਾਰਿਤ ਹੁੰਦੇ ਹਨ।	3

C5.3 Multi-Tenant Isolation

C5.3 ਬਹੁ-ਟੈਨੈਂਟ⁷⁹ ਅਲੱਗ-ਥਲੱਗਤਾ

Cross-tenant information leakage through AI-specific shared infrastructure, such as inference caches and shared model state, must be prevented.

AI-ਵਸ਼ਿਸ਼ ਸਾਂਝੇ ਬੁਨਿਆਦੀ ਢਾਂਚੇ, ਜਿਵੇਂ ਕਿ ਇਨਫ਼ਰੈਂਸ ਕੈਸ਼ ਅਤੇ ਸਾਂਝੀ ਮਾਡਲ ਸਥਿਤੀ, ਰਾਹੀਂ ਟੈਨੈਂਟਾਂ ਵਿਚਕਾਰ ਜਾਣਕਾਰੀ ਲੀਕ ਹੋਣ ਨੂੰ ਰੋਕਣਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
5.3.1	Verify that shared model serving infrastructure prevents one tenant's fine-tuning, inference, or embedding operations from influencing or observing another tenant's operations.	2
5.3.2	Verify that one tenant cannot influence or observe another tenant's operations through shared compute resources. Satisfying this requirement typically requires hardware partitioning, confidential computing, or dedicated per-tenant compute allocation.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
5.3.1	ਤਸਦੀਕ ਕਰੋ ਕੀ ਸਾਂਝਾ ਮਾਡਲ ਸਰਵਿਸ ਬੁਨਿਆਦੀ ਢਾਂਚਾ ਇੱਕ ਟੈਨੈਂਟ ਦੀਆਂ ਫ਼ਾਈਨ-ਟਿਊਨਿੰਗ, ਇਨਫ਼ਰੈਂਸ, ਜਾਂ embedding ਕਾਰਵਾਈਆਂ ਨੂੰ ਕਮਿ ਹੋਰ ਟੈਨੈਂਟ ਦੀਆਂ ਕਾਰਵਾਈਆਂ ਨੂੰ ਪ੍ਰਭਾਵਿਤ ਕਰਨ ਜਾਂ ਵੇਖਣ ਤੋਂ ਰੋਕਦਾ ਹੈ।	2
5.3.2	ਤਸਦੀਕ ਕਰੋ ਕੀ ਇੱਕ ਟੈਨੈਂਟ ਸਾਂਝੇ ਕੰਪਿਊਟ ਸਰੋਤਾਂ ਰਾਹੀਂ ਕਮਿ ਹੋਰ ਟੈਨੈਂਟ ਦੀਆਂ ਕਾਰਵਾਈਆਂ ਨੂੰ ਪ੍ਰਭਾਵਿਤ ਨਹੀਂ ਕਰ ਸਕਦਾ ਜਾਂ ਵੇਖ ਨਹੀਂ ਸਕਦਾ। ਇਸ ਲੋੜ ਨੂੰ ਪੂਰਾ ਕਰਨ ਲਈ ਆਮ ਤੌਰ 'ਤੇ ਹਾਰਡਵੇਅਰ ਵਭਿਜਨ, ਗੁਪਤ ਕੰਪਿਊਟਿੰਗ ⁸⁰ (confidential computing), ਜਾਂ ਪ੍ਰਤੀ-ਟੈਨੈਂਟ ਰਾਖਵੀਂ (dedicated) ਕੰਪਿਊਟ ਵੰਡ ਦੀ ਲੋੜ ਹੁੰਦੀ ਹੈ।	3

⁷⁶**policy decision point** (EN) -> ਨੀਤੀ ਫ਼ੈਸਲਾ ਬਿੰਦੂ — translated rather than retained because all three parts already have settled Panjabi equivalents, and the term is glossed in English on first use so it stays matchable to the NIST SP 800-207 reference this chapter cites. Full discussion: OPEN-QUESTIONS.md Q24.

⁷⁷**Zero Standing Privilege (ZSP)** (EN) -> Zero Standing Privilege (ZSP) (retained verbatim) — kept in English as a named security model, the same treatment Zero Trust Architecture gets in the reference this chapter cites, while the surrounding “privileged access” prose is translated normally. Full discussion: OPEN-QUESTIONS.md Q25.

⁷⁸**prompt cache** (EN) -> prompt ਕੈਸ਼ — the head noun prompt stays in Latin script per the corpus-wide hybrid pattern already fixed for prompt ਇੰਜੈਕਸ਼ਨ, extended here to cache. Full discussion: OPEN-QUESTIONS.md Q21.

⁷⁹**tenant / multi-tenant** (EN) -> ਟੈਨੈਂਟ / ਬਹੁ-ਟੈਨੈਂਟ — kept as a loan rather than ਕਰਿਏਦਾਰ (“renter”), because the literal dictionary word denotes a person renting property and would obscure the isolation boundary this section is about. Full discussion: OPEN-QUESTIONS.md Q22.

⁸⁰**confidential computing** (EN) -> ਗੁਪਤ ਕੰਪਿਊਟਿੰਗ — normalised from an earlier loan rendering (ਕਾਨਫ਼ੀਡੈਂਸ਼ੀਅਲ ਕੰਪਿਊਟਿੰਗ) that was the corpus's only instance of that form and read two ways against the same requirement indexed in Appendix B; the fix also protects the three-way ਭਰੋਸੇਯੋਗ / ਸੁਰੱਖਿਅਤ / ਗੁਪਤ (trusted/secure/confidential) contrast the C4 sibling chapter depends on. Full discussion: OPEN-QUESTIONS.md Q50.

References

ਹਵਾਲੇ

- NIST SP 800-207: Zero Trust Architecture
- NIST SP 800-63-3: Digital Identity Guidelines
- OAuth 2.1 (IETF Draft)
- OpenID Connect Core 1.0
- I Know What You Asked: Prompt Leakage via KV-Cache Sharing in Multi-Tenant LLM Serving (NDSS 2025)

C6 Supply Chain Security for Models

C6 ਮਾਡਲਾਂ ਲਈ ਸਪਲਾਈ ਚੇਨ⁸¹ ਸੁਰੱਖਿਆ

Control Objective

ਨਿਯੰਤਰਣ ਉਦੇਸ਼

This chapter addresses defending against AI supply chain attacks that exploit third-party models, frameworks, or datasets to embed backdoors, bias, or exploitable code.

ਇਹ ਅਧਿਆਇ AI ਸਪਲਾਈ ਚੇਨ (supply chain) ਹਮਲਿਆਂ ਤੋਂ ਬਚਾਅ ਨੂੰ ਸੰਬੰਧਿਤ ਕਰਦਾ ਹੈ, ਜੋ ਬੈਕਡੋਰ, ਪੱਖਪਾਤ⁸² (bias), ਜਾਂ ਸ਼ੋਸ਼ਣਯੋਗ ਕੋਡ ਨੂੰ ਅੰਦਰ ਬਠਾਉਣ ਲਈ ਤੀਜੀ-ਧਰ ਦੇ ਮਾਡਲਾਂ, ਫਰੇਮਵਰਕਾਂ, ਜਾਂ ਡਾਟਾਸੈਟਾਂ ਦਾ ਸ਼ੋਸ਼ਣ ਕਰਦੇ ਹਨ।

C6.1 Model Artifact Integrity

C6.1 ਮਾਡਲ ਆਰਟੀਫੈਕਟ ਅਖੰਡਤਾ

Third-party model origins must be authenticated and checked for hidden behavior before fine-tuning or deployment, and AI artifacts should be downloaded only from approved sources.

ਤੀਜੀ-ਧਰ ਦੇ ਮਾਡਲਾਂ ਦੇ ਮੂਲ ਦਾ ਫਾਈਨ-ਟਿਊਨਿੰਗ (fine-tuning) ਜਾਂ ਤੈਨਾਤੀ ਤੋਂ ਪਹਿਲਾਂ ਪ੍ਰਮਾਣੀਕਰਨ (authentication) ਕੀਤਾ ਜਾਣਾ ਅਤੇ ਲੁਕਵੇਂ ਵਹਿਰਾਂ⁸³ ਲਈ ਜਾਂਚ ਕੀਤੀ ਜਾਣੀ ਲਾਜ਼ਮੀ ਹੈ, ਅਤੇ AI ਆਰਟੀਫੈਕਟ ਸਰਿਫ਼ ਪ੍ਰਵਾਨਤਿ ਸਰੋਤਾਂ ਤੋਂ ਹੀ ਡਾਊਨਲੋਡ ਕੀਤੇ ਜਾਣੇ ਚਾਹੀਦੇ ਹਨ।

#	Description	Level
6.1.1	Verify that models are scanned for malicious code before import.	1
6.1.2	Verify that model weights, datasets, and fine-tuning adapters are downloaded only from approved sources.	1
6.1.3	Verify that every third-party model artifact can be integrity-verified.	2
6.1.4	Verify that models pass a behavioral acceptance test suite before being promoted to any non-development environment.	2

#	ਵੇਰਵਾ	ਪੱਧਰ
6.1.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਾਡਲਾਂ ਨੂੰ ਆਯਾਤ (import) ਤੋਂ ਪਹਿਲਾਂ ਖ਼ਤਰਨਾਕ ਕੋਡ ਲਈ ਸਕੈਨ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	1

⁸¹**supply chain** (EN) -> ਸਪਲਾਈ ਚੇਨ — kept as a loan rather than a coined native compound (ਪੂਰਤੀ ਲੜੀ, “provision chain”) because the ASVS sibling corpus resolves modern infrastructure compounds toward the loan, and “supply chain” is already the circulating form in Panjabi business/technology press. Full discussion: OPEN-QUESTIONS.md Q1.

⁸²**bias** (EN, AI/model bias) -> ਪੱਖਪਾਤ — chosen over ਪੂਰਵ-ਧਾਰਨਾ (“preconception”) because that word would ascribe a mental state to the model, whereas ਪੱਖਪਾਤ names the output property (systematically unfair outcomes) without anthropomorphising. Full discussion: OPEN-QUESTIONS.md Q6.

⁸³**behavior** (EN) -> ਵਹਿਰ — a consistency carry-over from the ASVS sibling corpus’s use of ਵਹਿਰ for system behavior, chosen over ਆਚਰਣ (“conduct”) because that word carries a moral register unsuitable for a machine. Full discussion: OPEN-QUESTIONS.md Q7.

#	ਵੇਰਵਾ	ਪੱਧਰ
6.1.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਾਡਲ ਵੇਟਸ ⁸⁴ (model weights), ਡਾਟਾਸੈੱਟ ⁸⁵ , ਅਤੇ ਫਾਈਨ-ਟਿਊਨਿੰਗ ਅਡੈਪਟਰ ⁸⁶ ਸਹਿਫ਼ ਪ੍ਰਵਾਨਤਿ ਸਰੋਤਾਂ ਤੋਂ ਹੀ ਡਾਊਨਲੋਡ ਕੀਤੇ ਜਾਂਦੇ ਹਨ।	1
6.1.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਹਰ ਤੀਜੀ-ਧਰਿ ਮਾਡਲ ਆਰਟੀਫੈਕਟ ਦੀ ਅਖੰਡਤਾ (integrity) ਦੀ ਤਸਦੀਕ ਕੀਤੀ ਜਾ ਸਕਦੀ ਹੈ।	2
6.1.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਾਡਲ ਕਸਿ ਵੀ ਗੈਰ-ਵਕਾਸ ਵਾਤਾਵਰਣ ਵਿੱਚ ਤਰੱਕੀ ਦਿੱਤੀ ਜਾਣ ਤੋਂ ਪਹਿਲਾਂ ਇੱਕ ਵਿਵਹਾਰਕ ਸਵੀਕ੍ਰਤੀ ਟੈਸਟ ਸੂਟ ਪਾਸ ਕਰਦੇ ਹਨ।	2

C6.2 AI BOM & Supply Chain Monitoring

C6.2 AI BOM⁸⁷ ਅਤੇ ਸਪਲਾਈ ਚੇਨ ਨਗਿਰਾਨੀ

Detailed AI-specific bills of materials must be generated and signed, with readiness to respond to supply chain compromise events.

ਵਸਿਤਰਤਿ AI-ਵਸ਼ਿਸ਼ ਬਲਿ ਆਫ਼ ਮਟੀਰੀਅਲਜ਼ (bills of materials) ਤਿਆਰ ਅਤੇ ਦਸਤਖ਼ਤ ਕੀਤੇ ਜਾਣੇ ਲਾਜ਼ਮੀ ਹਨ, ਨਾਲ ਹੀ ਸਪਲਾਈ ਚੇਨ ਦੇ ਸਮਝੌਤੇ (compromise) ਦੀਆਂ ਘਟਨਾਵਾਂ ਦਾ ਜਵਾਬ ਦੇਣ ਦੀ ਤਿਆਰੀ ਸਮੇਤ।

#	Description	Level
6.2.1	Verify that every model artifact publishes a version-controlled, machine-readable AI BOM listing datasets, weights, licenses, and data-origin statements.	1
6.2.2	Verify that AI BOMs are cryptographically signed before deployment.	2
6.2.3	Verify that AI BOM completeness checks fail the build if any component metadata is missing.	2

#	ਵੇਰਵਾ	ਪੱਧਰ
6.2.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਹਰ ਮਾਡਲ ਆਰਟੀਫੈਕਟ ਇੱਕ ਵਰਜਨ-ਨਯੰਤਰਤਿ, ਮਸ਼ੀਨ-ਪੜ੍ਹਨਯੋਗ AI BOM ਪ੍ਰਕਾਸ਼ਤਿ ਕਰਦਾ ਹੈ ਜਿਸ ਵਿੱਚ ਡਾਟਾਸੈੱਟ, ਵੇਟਸ, ਲਾਇਸੈਂਸ, ਅਤੇ ਡਾਟਾ-ਮੂਲ ਬਿਆਨ ਸੂਚੀਬੱਧ ਹੁੰਦੇ ਹਨ।	1
6.2.2	ਤਸਦੀਕ ਕਰੋ ਕਿ AI BOM ਨੂੰ ਤੈਨਾਤੀ ਤੋਂ ਪਹਿਲਾਂ ਕ੍ਰਿਪਟੋਗ੍ਰਾਫ਼ਿਕ ਤੌਰ 'ਤੇ ਦਸਤਖ਼ਤ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	2
6.2.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਜੇ ਕਸਿ ਕੰਪੋਨੈਂਟ ⁸⁸ ਦਾ ਮੈਟਾਡਾਟਾ ਗੈਰ-ਮੌਜੂਦ ਹੋਵੇ ਤਾਂ AI BOM ਸੰਪੂਰਨਤਾ ਜਾਂਚਾਂ ਬਲਿਡ ਨੂੰ ਫੇਲ੍ਹ ਕਰ ਦਿੰਦੀਆਂ ਹਨ।	2

⁸⁴ **model weights** (EN) -> ਮਾਡਲ ਵੇਟਸ — kept as a loan because the native candidates (ਭਾਰ, ਵਜ਼ਨ) carry only the physical-mass sense and would mislead a reader, whereas a weight here is a learned numeric parameter and a distributable artifact name in practice. Full discussion: OPEN-QUESTIONS.md Q2.

⁸⁵ **dataset** (EN) -> ਡਾਟਾਸੈੱਟ — kept as a loan rather than ਅੰਕੜਾ-ਸਮੂਹ (“statistics group”), which would actively mislead for text/image corpora, since a dataset here is a named, versioned, downloadable artifact rather than a generic collection. Full discussion: OPEN-QUESTIONS.md Q5.

⁸⁶ **fine-tuning adapter** (EN) -> ਫਾਈਨ-ਟਿਊਨਿੰਗ ਅਡੈਪਟਰ — “fine-tuning” is retained as a loan because it names a specific training operation distinct from pre-training, retraining, and prompt-tuning, and a descriptive native rendering would lose that specificity. Full discussion: OPEN-QUESTIONS.md Q3.

⁸⁷ **AI BOM** (EN) -> AI BOM (retained) — the acronym stays in Latin script per the corpus's always-retained rule for acronyms, matching how SBOM/CycloneDX appear in this chapter's own reference list. Full discussion: OPEN-QUESTIONS.md Q4.

⁸⁸ **component** (EN) -> ਕੰਪੋਨੈਂਟ — kept as the established loan rather than the native ਹੱਸਿਾ used for generic parts elsewhere in the corpus; a full-corpus audit found the two forms split by usage and recommended normalising the minority native sites toward this one. Full discussion: OPEN-QUESTIONS.md Q95.

References

ਹਵਾਲੇ

- OWASP LLM03:2025 Supply Chain
- MITRE ATLAS: Supply Chain Compromise
- SBOM Overview: CISA
- CycloneDX: Machine Learning Bill of Materials
- OWASP AIBOM

C7 Model Behavior, Output Control & Safety Assurance

C7 ਮਾਡਲ ਵਵਿਹਾਰ⁸⁹, ਆਉਟਪੁੱਟ⁹⁰ ਨਿਯੰਤਰਣ ਅਤੇ ਸਲਾਮਤੀ ਭਰੋਸਾ⁹¹

Control Objective

ਨਿਯੰਤਰਣ ਉਦੇਸ਼

This chapter addresses constraining, validating, and monitoring model outputs so that unsafe, malformed, or high-risk responses cannot reach users or downstream systems.

ਇਹ ਅਧਿਆਇ ਮਾਡਲ ਆਉਟਪੁੱਟ ਨੂੰ ਸੀਮਤ ਕਰਨ, ਪ੍ਰਮਾਣਿਤ ਕਰਨ ਅਤੇ ਉਸ ਦੀ ਨਿਗਰਾਨੀ ਕਰਨ ਨੂੰ ਸੰਬੋਧਿਤ ਕਰਦਾ ਹੈ ਤਾਂ ਜੋ ਗੈਰ-ਸਲਾਮਤ⁹² (unsafe), ਵਗਿੜੇ⁹³ ਹੋਏ, ਜਾਂ ਉੱਚ-ਜੋਖਮ ਵਾਲੇ ਜਵਾਬ ਉਪਭੋਗਤਾਵਾਂ ਜਾਂ ਡਾਊਨਸਟ੍ਰੀਮ⁹⁴ ਸਿਸਟਮਾਂ ਤੱਕ ਨਾ ਪਹੁੰਚ ਸਕਣ।

C7.1 Output Format Enforcement

C7.1 ਆਉਟਪੁੱਟ ਫਾਰਮੈਟ ਲਾਗੂਕਰਨ

Model outputs must be structured and validated to reduce downstream injection risk.

ਡਾਊਨਸਟ੍ਰੀਮ ਇੰਜੈਕਸ਼ਨ ਜੋਖਮ ਨੂੰ ਘਟਾਉਣ ਲਈ ਮਾਡਲ ਆਉਟਪੁੱਟ ਦਾ ਢਾਂਚਾਗਤ ਅਤੇ ਪ੍ਰਮਾਣਿਤ ਹੋਣਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
7.1.1	Verify that the application validates all model outputs against a defined schema and rejects any output that does not match.	1
7.1.2	Verify that model-generated output is bounded by length limits and termination controls.	1

#	ਵੇਰਵਾ	ਪੱਧਰ
7.1.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਐਪਲੀਕੇਸ਼ਨ ਸਾਰੇ ਮਾਡਲ ਆਉਟਪੁੱਟ ਨੂੰ ਇੱਕ ਪਰਭਾਸ਼ਿਤ ਸਕੀਮਾ ਦੇ ਵਰਿਥ ਪ੍ਰਮਾਣਿਤ ਕਰਦੀ ਹੈ ਅਤੇ ਕਸਿ ਵੀ ਅਜਹੇ ਆਉਟਪੁੱਟ ਨੂੰ ਰੱਦ ਕਰਦੀ ਹੈ ਜੋ ਮੇਲ ਨਹੀਂ ਖਾਂਦਾ।	1

⁸⁹**behavior** (EN) -> ਵਵਿਹਾਰ — carried over from the ASVS sibling corpus's use of ਵਵਿਹਾਰ for system behavior, chosen over ਆਚਰਣ (“conduct”) because that word carries a moral/ethical register that would wrongly ascribe agency to a model. Full discussion: OPEN-QUESTIONS.md Q7.

⁹⁰**output** (EN, model output) -> ਆਉਟਪੁੱਟ — kept as a loan to mirror the ASVS corpus's ਇਨਪੁੱਟ (input), so the input/output pair reads symmetrically across both standards; ਨਤੀਜਾ (“result”) was rejected because it would collide with a different sense. Full discussion: OPEN-QUESTIONS.md Q78.

⁹¹**Safety Assurance** (EN, chapter title) -> ਸਲਾਮਤੀ ਭਰੋਸਾ — conforms to the corpus's standing pick of ਭਰੋਸਾ for assurance, even though the same word also carries confidence elsewhere in this chapter; the overload does not create ambiguity in any single sentence, so this chapter conforms rather than splitting the term. Full discussion: OPEN-QUESTIONS.md Q67.

⁹²**unsafe** (EN) -> ਗੈਰ-ਸਲਾਮਤ — derived from ਸਲਾਮਤ (safety) rather than ਸੁਰੱਖਿਅਤ (which derives from ਸੁਰੱਖਿਆ, reserved for security), so this chapter's requirement text does not contradict its own title two paragraphs later. Full discussion: OPEN-QUESTIONS.md Q66.

⁹³**malformed** (EN) -> ਵਗਿੜੇ (ਹੋਏ) — uses the same root ਵਗਿੜ already applied elsewhere in the corpus to adversarial perturbation and corruption; flagged as an unresolved three-way overload rather than corrected, since no single sentence here is ambiguous. Full discussion: OPEN-QUESTIONS.md Q35.

⁹⁴**downstream** (EN, downstream systems/risk) -> ਡਾਊਨਸਟ੍ਰੀਮ — kept as a loan because “downstream” is pipeline vocabulary with no settled Panjabi equivalent, and a literal water-flow rendering would mislead a reader into a physical-flow reading. Full discussion: OPEN-QUESTIONS.md Q77.

#	ਵੇਰਵਾ	ਪੱਧਰ
7.1.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਾਡਲ ਦੁਆਰਾ ਤਿਆਰ ਕੀਤਾ ਆਉਟਪੁੱਟ ਲੰਬਾਈ ਸੀਮਾਵਾਂ ਅਤੇ ਸਮਾਪਤੀ ਨਿਯੰਤਰਣ ⁹⁵ ਦੁਆਰਾ ਸੀਮਤ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	1

C7.2 Hallucination Detection & Mitigation

C7.2 Hallucination⁹⁶ ਦੀ ਪਛਾਣ ਅਤੇ ਘਟਾਉਣਾ

Potentially inaccurate or fabricated content must be detected so unreliable outputs do not reach users or downstream systems.

ਸੰਭਾਵੀ ਤੌਰ 'ਤੇ ਗ਼ਲਤ ਜਾਂ ਮਨਘੜਤ ਸਮੱਗਰੀ (hallucination) ਦੀ ਪਛਾਣ ਕਰਨਾ ਲਾਜ਼ਮੀ ਹੈ ਤਾਂ ਜੋ ਗ਼ੈਰ-ਭਰੋਸੇਯੋਗ ਆਉਟਪੁੱਟ ਉਪਭੋਗਤਾਵਾਂ ਜਾਂ ਡਾਊਨਸਟ੍ਰੀਮ ਸਿਸਟਮਾਂ ਤੱਕ ਨਾ ਪਹੁੰਚੇ।

#	Description	Level
7.2.1	Verify that the system assesses the reliability of generated answers using a confidence estimation method.	2
7.2.2	Verify that the application automatically blocks answers or switches to a fallback message if the confidence score drops below a defined threshold.	2
7.2.3	Verify that for responses classified as high-risk by policy, the system performs an additional verification step.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
7.2.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਿਸਟਮ ਇੱਕ ਭਰੋਸਾ ਅਨੁਮਾਨ ਵਧੀ ⁹⁷ (confidence estimation) ਦੀ ਵਰਤੋਂ ਕਰਕੇ ਤਿਆਰ ਕੀਤੇ ਜਵਾਬਾਂ ਦੀ ਭਰੋਸੇਯੋਗਤਾ ਦਾ ਮੁਲਾਂਕਣ ਕਰਦਾ ਹੈ।	2
7.2.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਜੇ ਭਰੋਸਾ ਸਕੋਰ ਇੱਕ ਪਰਭਿਸ਼ਤਿ ਥਰੈਸ਼ਹੋਲਡ ⁹⁸ ਤੋਂ ਹੇਠਾਂ ਡਿੱਗ ਜਾਂਦਾ ਹੈ ਤਾਂ ਐਪਲੀਕੇਸ਼ਨ ਆਪਣੇ ਆਪ ਜਵਾਬਾਂ ਨੂੰ ਰੋਕ ਦਿੰਦੀ ਹੈ ਜਾਂ ਇੱਕ ਫਾਲਬੈਕ ਸੁਨੇਹੇ ⁹⁹ 'ਤੇ ਬਦਲ ਜਾਂਦੀ ਹੈ।	2
7.2.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਨੀਤੀ ਦੁਆਰਾ ਉੱਚ-ਜੋਖਮ ਵਜੋਂ ਵਰਗੀਕ੍ਰਿਤ ¹⁰⁰ ਕੀਤੇ ਜਵਾਬਾਂ ਲਈ, ਸਿਸਟਮ ਇੱਕ ਵਾਧੂ ਤਸਦੀਕ ਪੜਾਅ ਕਰਦਾ ਹੈ।	3

⁹⁵ **controls** (EN, termination controls) -> ਨਿਯੰਤਰਣ — normalised from an earlier inconsistency where the same underlying word appeared as the loan ਕੰਟਰੋਲ in one chapter's requirement text; standalone control(s) stays ਨਿਯੰਤਰਣ corpus-wide, with the loan ਕੰਟਰੋਲ reserved only for the fixed compound ਪਹੁੰਚ ਕੰਟਰੋਲ (access control). Full discussion: OPEN-QUESTIONS.md Q80.

⁹⁶ **hallucination** (EN) -> hallucination (retained, glossed ਮਨਘੜਤ ਸਮੱਗਰੀ) — kept in Latin script because ਭਰਮ, ਭੁਲੇਖਾ, and ਵਹਿਮ all carry Gurbani-specific spiritual weight (delusion, doubt) that this term must not borrow; treated as a named AI failure mode with a neutral descriptive gloss instead. Full discussion: OPEN-QUESTIONS.md Q65.

⁹⁷ **confidence estimation method** (EN) -> ਭਰੋਸਾ ਅਨੁਮਾਨ ਵਧੀ — built on ਭਰੋਸਾ rather than ਵਸ਼ਿਵਾਸ, which leans toward faith/belief and was excluded as too devotionally coloured for an ML confidence score. Full discussion: OPEN-QUESTIONS.md Q68.

⁹⁸ **threshold** (EN) -> ਥਰੈਸ਼ਹੋਲਡ — kept as a loan rather than ਸੀਮਾ, which is already bound to limit elsewhere in this same chapter (output length limits), so the limit/threshold contrast stays visible within one requirement set. Full discussion: OPEN-QUESTIONS.md Q69.

⁹⁹ **fallback message** (EN) -> ਫਾਲਬੈਕ ਸੁਨੇਹਾ — “fallback” kept as a loan because it is settled software-engineering vocabulary with no Panjabi equivalent, and ਬਦਲਵਾਂ (“alternative”) was rejected for understating that a fallback is specifically the safe response. Full discussion: OPEN-QUESTIONS.md Q70.

¹⁰⁰ **classified (as high-risk)** (EN) -> ਵਰਗੀਕ੍ਰਿਤ — shares the ਵਰਗੀਕਰਨ root already settled for classifier elsewhere in the corpus, kept deliberately mechanical since a classifier here is a model acting as a filter, not a reasoning agent. Full discussion: OPEN-QUESTIONS.md Q76.

C7.3 Output Safety

C7.3 ਆਉਟਪੁੱਟ ਸਲਾਮਤੀ

Technical controls must detect and remove unsafe content before it is shown to the user.

ਤਕਨੀਕੀ ਨਿਯੰਤਰਣਾਂ ਲਈ ਉਪਭੋਗਤਾ ਨੂੰ ਦੱਖਾਏ ਜਾਣ ਤੋਂ ਪਹਿਲਾਂ ਗ਼ੈਰ-ਸਲਾਮਤ ਸਮੱਗਰੀ ਦੀ ਪਛਾਣ ਕਰਨਾ ਅਤੇ ਉਸ ਨੂੰ ਹਟਾਉਣਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
7.3.1	Verify that automated classifiers scan every response and block content that matches defined harmful content categories.	1
7.3.2	Verify that output filters detect and block responses that disclose system prompt content or backend data.	2
7.3.3	Verify that model-generated output is prevented from triggering outbound requests.	2
7.3.4	Verify that model outputs are checked for hidden, encoded, or misleading content created through homoglyphs, formatting, metadata, or structured fields.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
7.3.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਵੈਚਾਲਤ ਵਰਗੀਕਾਰ (classifiers) ਹਰ ਜਵਾਬ ਨੂੰ ਸਕੈਨ ਕਰਦੇ ਹਨ ਅਤੇ ਉਸ ਸਮੱਗਰੀ ਨੂੰ ਰੋਕਦੇ ਹਨ ਜੋ ਪਰਭਿਾਸ਼ਤ ਨੁਕਸਾਨਦੇਹ ਸਮੱਗਰੀ ਸ਼੍ਰੇਣੀਆਂ ਨਾਲ ਮੇਲ ਖਾਂਦੀ ਹੈ।	1
7.3.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਆਉਟਪੁੱਟ ਫ਼ਿਲਟਰ ਉਹਨਾਂ ਜਵਾਬਾਂ ਦੀ ਪਛਾਣ ਕਰਦੇ ਹਨ ਅਤੇ ਉਹਨਾਂ ਨੂੰ ਰੋਕਦੇ ਹਨ ਜੋ system prompt ਦੀ ਸਮੱਗਰੀ ਜਾਂ ਬੈਕਐਂਡ ਡਾਟਾ ਦਾ ਖੁਲਾਸਾ ਕਰਦੇ ਹਨ।	2
7.3.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਾਡਲ ਦੁਆਰਾ ਤਿਆਰ ਕੀਤੇ ਆਉਟਪੁੱਟ ਨੂੰ ਬਾਹਰ ਜਾਣ ਵਾਲੀਆਂ ਬੇਨਤੀਆਂ ਸ਼ੁਰੂ ਕਰਨ ਤੋਂ ਰੋਕਿਆ ਜਾਂਦਾ ਹੈ।	2
7.3.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਾਡਲ ਆਉਟਪੁੱਟ ਦੀ ਲੁਕੀ ਹੋਈ, ਏਨਕੋਡ ਕੀਤੀ, ਜਾਂ ਗੁਮਰਾਹਕੁਨ ਸਮੱਗਰੀ ਲਈ ਜਾਂਚ ਕੀਤੀ ਜਾਂਦੀ ਹੈ ਜੋ homoglyph ¹⁰¹ (ਸਮਰੂਪ ਅੱਖਰ), ਫ਼ਾਰਮੈਟਿੰਗ, ਮੈਟਾਡਾਟਾ, ਜਾਂ ਢਾਂਚਾਗਤ ਖੇਤਰਾਂ ਰਾਹੀਂ ਬਣਾਈ ਗਈ ਹੋਵੇ।	3

C7.4 Source Attribution & Citation Integrity

C7.4 ਸਰੋਤ-ਨਰਿਧਾਰਨ¹⁰² ਅਤੇ ਹਵਾਲਾ ਅਖੰਡਤਾ

RAG-grounded outputs must be traceable to their source documents, with cited claims verifiably supported by retrieved content.

RAG-ਆਧਾਰਤ¹⁰³ ਆਉਟਪੁੱਟ ਦਾ ਆਪਣੇ ਸਰੋਤ ਦਸਤਾਵੇਜ਼ਾਂ ਤੱਕ ਟਰੇਸ ਕਰਨਯੋਗ ਹੋਣਾ ਲਾਜ਼ਮੀ ਹੈ, ਅਤੇ ਹਵਾਲਾ ਦਿੱਤੇ ਗਏ ਦਾਅਵੇ ਪ੍ਰਾਪਤ ਕੀਤੀ ਸਮੱਗਰੀ ਦੁਆਰਾ ਤਸਦੀਕਯੋਗ ਢੰਗ ਨਾਲ ਸਮਰਥਤ ਹੋਣੇ ਲਾਜ਼ਮੀ ਹਨ।

¹⁰¹**homoglyph** (EN) -> homoglyph (retained, glossed ਸਮਰੂਪ ਅੱਖਰ) — follows the corpus's pattern of retaining named attack/technique terms in English (as with prompt injection, jailbreak) with a native gloss for readability, since this is what an implementer would search for in Unicode security literature. Full discussion: OPEN-QUESTIONS.md Q75.

¹⁰²**source attribution** (EN) -> ਸਰੋਤ-ਨਰਿਧਾਰਨ — reuses the rendering already fixed for dataset-use attribution, kept distinct from ਹਵਾਲਾ (citation) because 7.4.2 depends on that difference: attributions must come from retrieval metadata, not the model, while a citation is what the reader sees. Full discussion: OPEN-QUESTIONS.md Q72.

¹⁰³**RAG-grounded** (EN) -> RAG-ਆਧਾਰਤ — “grounding” is a high-risk metaphor term, so the neutral technical sense (“anchored in retrieved evidence”) is rendered as ਆਧਾਰਤ (based on) rather than any literal earth/ground calque that would import imagery the source does not intend. Full discussion: OPEN-QUESTIONS.md Q71.

#	Description	Level
7.4.1	Verify that responses generated using retrieval-augmented generation (RAG) include attribution to the source documents.	1
7.4.2	Verify that RAG attributions are derived from retrieval metadata and are not generated by the model, so provenance cannot be fabricated.	1
7.4.3	Verify that claims in a RAG response can be traced to the retrieved chunk.	2
7.4.4	Verify that generated media is watermarked to prove it was AI-generated.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
7.4.1	ਤਸਦੀਕ ਕਰੋ ਕਿ retrieval-augmented generation (RAG) ਦੀ ਵਰਤੋਂ ਕਰਕੇ ਤਿਆਰ ਕੀਤੇ ਜਵਾਬਾਂ ਵਿੱਚ ਸਰੋਤ ਦਸਤਾਵੇਜ਼ਾਂ ਦਾ ਸਰੋਤ-ਨਰਿਧਾਰਨ (attribution) ਸ਼ਾਮਲ ਹੁੰਦਾ ਹੈ।	1
7.4.2	ਤਸਦੀਕ ਕਰੋ ਕਿ RAG ਸਰੋਤ-ਨਰਿਧਾਰਨ ਪ੍ਰਾਪਤੀ ਮੈਟਾਡਾਟਾ ਤੋਂ ਲਏ ਜਾਂਦੇ ਹਨ ਅਤੇ ਮਾਡਲ ਦੁਆਰਾ ਤਿਆਰ ਨਹੀਂ ਕੀਤੇ ਜਾਂਦੇ, ਤਾਂ ਜੋ ਮੂਲ-ਸਰੋਤ ¹⁰⁴ (provenance) ਘੜਿਆ ਨਾ ਜਾ ਸਕੇ।	1
7.4.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਇੱਕ RAG ਜਵਾਬ ਵਿਚਲੇ ਦਾਅਵਿਆਂ ਨੂੰ ਪ੍ਰਾਪਤ ਕੀਤੇ ਚੰਕ ¹⁰⁵ (chunk) ਤੱਕ ਟਰੇਸ ਕੀਤਾ ਜਾ ਸਕਦਾ ਹੈ।	2
7.4.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਤਿਆਰ ਕੀਤੇ ਮੀਡੀਆ ਨੂੰ ਵਾਟਰਮਾਰਕ ਕੀਤਾ ਜਾਂਦਾ ਹੈ ਤਾਂ ਜੋ ਇਹ ਸਾਬਤ ਹੋ ਸਕੇ ਕਿ ਇਹ AI ਦੁਆਰਾ ਤਿਆਰ ਕੀਤਾ ਗਿਆ ਸੀ।	3

References

ਹਵਾਲੇ

- OWASP LLM05:2025 Improper Output Handling
- OWASP LLM06:2025 Excessive Agency
- OWASP LLM09:2025 Misinformation
- NIST AI 600-1: Generative AI Profile (AI RMF Companion)
- MITRE ATLAS

¹⁰⁴**provenance** (EN) -> ਮੂਲ-ਸਰੋਤ (“root-source”) — states the “documented chain of origin” sense plainly, avoiding ਉਤਪਤੀ (“origination”), which carries creation-narrative overtones in Panjabi religious register. Full discussion: OPEN-QUESTIONS.md Q73.

¹⁰⁵**chunk** (EN, retrieved chunk) -> ਚੰਕ — kept as a loan because a chunk is a specific RAG-pipeline retrieval unit, not a generic piece of text; ਖੰਡ (“segment”) was additionally excluded for its near-collision with ਅਖੰਡਤਾ (integrity), the locked term appearing in this same chapter’s C7.4 title. Full discussion: OPEN-QUESTIONS.md Q74.

C8 Memory, Embeddings & Vector Database Security

C8 ਮੈਮੋਰੀ¹⁰⁶, Embeddings ਅਤੇ ਵੈਕਟਰ ਡਾਟਾਬੇਸ ਸੁਰੱਖਿਆ

Control Objective

ਨਿਯੰਤਰਣ ਉਦੇਸ਼

This chapter addresses securing the embeddings and vector stores that act as semi-persistent and persistent “memory” for AI systems through Retrieval-Augmented Generation (RAG).

ਇਹ ਅਧਿਆਇ ਉਹਨਾਂ embeddings ਅਤੇ ਵੈਕਟਰ ਸਟੋਰਾਂ ਨੂੰ ਸੁਰੱਖਿਅਤ ਕਰਨ ਨੂੰ ਸੰਬੋਧਿਤ ਕਰਦਾ ਹੈ ਜੋ Retrieval-Augmented Generation (RAG) ਰਾਹੀਂ AI ਸਿਸਟਮਾਂ ਲਈ ਅਰਧ-ਸਥਾਈ ਅਤੇ ਸਥਾਈ “ਮੈਮੋਰੀ” (memory) ਵਜੋਂ ਕੰਮ ਕਰਦੇ ਹਨ।

C8.1 Access Controls on Memory & RAG Indices

C8.1 ਮੈਮੋਰੀ ਅਤੇ RAG ਇੰਡੈਕਸਾਂ ਉੱਤੇ ਪਹੁੰਚ ਕੰਟਰੋਲ

Fine-grained access controls and query-time scope enforcement must be applied to every vector collection.

ਹਰ ਵੈਕਟਰ ਸੰਗ੍ਰਹਾਂ ਉੱਤੇ ਬਾਰੀਕ-ਪੱਧਰੀ ਪਹੁੰਚ ਕੰਟਰੋਲ ਅਤੇ ਕਵਿਰੀ-ਸਮੇਂ ਸਕੋਪ ਪਾਬੰਦੀਆਂ ਲਾਗੂ ਕਰਨਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
8.1.1	Verify that vector identifiers and namespaces enforce uniqueness per tenant and prevent cross-tenant collisions.	1
8.1.2	Verify that document metadata tags are immutable after the initial write.	2
8.1.3	Verify that retrieval operations enforce scope constraints.	2

¹⁰⁶**memory** (EN, AI/agent system memory) -> ਮੈਮੋਰੀ — kept as a loan rather than ਯਾਦਦਾਸਤ (human recollection) or ਸਮਿਰਤੀ (a Hindu scriptural category, categorically excluded), since both native candidates either anthropomorphise a vector index or carry devotional weight; also matches the hardware-memory loan already used in this standard’s infrastructure chapter, letting one word serve one concept across chapters. Full discussion: OPEN-QUESTIONS.md Q62.

#	ਵੇਰਵਾ	ਪੱਧਰ
8.1.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਵੈਕਟਰ ਪਛਾਣਕਰਤਾ ਅਤੇ ਨੇਮਸਪੇਸ ਪ੍ਰਤੀ ਟੈਨੋਟ ਵਲਿੱਖਣਤਾ ਲਾਗੂ ਕਰਦੇ ਹਨ ਅਤੇ ਅੰਤਰ-ਟੈਨੋਟ ਟਕਰਾਵਾਂ (collisions) ਨੂੰ ਰੋਕਦੇ ਹਨ।	1
8.1.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਦਸਤਾਵੇਜ਼ ਮੈਟਾਡਾਟਾ ਟੈਗ ਸ਼ੁਰੂਆਤੀ ਲਿਖਤ ਤੋਂ ਬਾਅਦ ਅਪਰਿਵਰਤਨਸ਼ੀਲ ¹⁰⁷ (immutable) ਹਨ।	2
8.1.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਪ੍ਰਾਪਤੀ ਕਾਰਵਾਈਆਂ ਸਕੋਪ ਪਾਬੰਦੀਆਂ ਲਾਗੂ ਕਰਦੀਆਂ ਹਨ।	2

C8.2 Embedding Sanitization & Validation

C8.2 Embedding ਸੈਨੀਟਾਈਜ਼ੇਸ਼ਨ ਅਤੇ ਪ੍ਰਮਾਣਿਕਤਾ

Content must be pre-screened before vectorization, and memory writes treated as untrusted input, to prevent ingestion of unsafe payloads.

ਗ਼ੈਰ-ਸਲਾਮਤ¹⁰⁸ (unsafe) ਪੇਲੋਡਾਂ ਦੇ ਦਾਖਲੇ ਨੂੰ ਰੋਕਣ ਲਈ, ਵੈਕਟਰਾਈਜ਼ੇਸ਼ਨ (vectorization) ਤੋਂ ਪਹਿਲਾਂ ਸਮੱਗਰੀ ਦੀ ਪਹਿਲਾਂ ਹੀ ਛਾਣਬੀਣ ਕਰਨਾ, ਅਤੇ ਮੈਮੋਰੀ ਵਿੱਚ ਲਿਖੀ ਜਾਣ ਵਾਲੀ ਹਰ ਚੀਜ਼ ਨੂੰ ਗ਼ੈਰ-ਭਰੋਸੇਯੋਗ ਇਨਪੁੱਟ ਮੰਨਣਾ, ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
8.2.1	Verify that sensitive fields are detected before embedding and are masked, tokenized, or dropped.	1
8.2.2	Verify that vectors that fall outside normal clustering patterns are flagged and quarantined before entering production indices.	2

¹⁰⁷ **immutable** (EN) -> ਅਪਰਿਵਰਤਨਸ਼ੀਲ — normalised from an earlier paraphrase (“cannot be changed”) to the standing adjective used elsewhere in the corpus for this same requirement, so the term stays searchable and consistent with its own cross-reference in the controls-inventory appendix. Full discussion: OPEN-QUESTIONS.md Q112.

¹⁰⁸ **unsafe** (EN) -> ਗ਼ੈਰ-ਸਲਾਮਤ — normalised from an earlier rendering (ਅਸੁਰੱਖਿਅਤ) that silently re-collapsed the corpus’s ਸਲਾਮਤੀ/ਸੁਰੱਖਿਆ (safety/security) split; derived from ਸਲਾਮਤ, not ਸੁਰੱਖਿਅਤ. Full discussion: OPEN-QUESTIONS.md Q66.

#	Description	Level
8.2.3	Verify that agent outputs and tool outputs are not automatically written to trusted agent memory without explicit source validation.	2
8.2.4	Verify that content crafted to manipulate retrieval results is detected and rejected or quarantined before vectorization.	3
8.2.5	Verify that new content written to memory is checked for contradictions with what is already stored and that conflicts trigger alerts.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
8.2.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸੰਵੇਦਨਸ਼ੀਲ ਖੇਤਰਾਂ ਦਾ embedding ਤੋਂ ਪਹਿਲਾਂ ਪਤਾ ਲਗਾਇਆ ਜਾਂਦਾ ਹੈ ਅਤੇ ਉਹਨਾਂ ਨੂੰ ਮਾਸਕ, ਟੋਕਨਾਈਜ਼, ਜਾਂ ਹਟਾ ਦਿੱਤਾ ਜਾਂਦਾ ਹੈ।	1
8.2.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਜਿਹੜੇ ਵੈਕਟਰ ਸਧਾਰਨ ਕਲੱਸਟਰਿੰਗ ¹⁰⁹ (clustering) ਪੈਟਰਨਾਂ ਤੋਂ ਬਾਹਰ ਪੈਂਦੇ ਹਨ, ਉਹਨਾਂ ਨੂੰ ਉਤਪਾਦਨ ਇੰਡੈਕਸਾਂ ਵਿੱਚ ਦਾਖ਼ਲ ਹੋਣ ਤੋਂ ਪਹਿਲਾਂ ਨਸ਼ਿਅਤਬੱਧ ਅਤੇ ਕੁਆਰੰਟੀਨ ¹¹⁰ (quarantine) ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	2
8.2.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਏਜੰਟ ਆਊਟਪੁੱਟ ਅਤੇ ਟੂਲ ਆਊਟਪੁੱਟ ਸਪਸ਼ਟ ਸਰੋਤ ਪ੍ਰਮਾਣਿਕਤਾ ਤੋਂ ਬਿਨਾਂ ਆਪਣੇ ਆਪ ਭਰੋਸੇਯੋਗ ਏਜੰਟ ਮੈਮੋਰੀ ਵਿੱਚ ਨਹੀਂ ਲਿਖੇ ਜਾਂਦੇ।	2

¹⁰⁹ **clustering** (EN, normal clustering patterns) -> ਕਲੱਸਟਰਿੰਗ — kept as a loan because this is a named unsupervised-learning technique, and a generic native rendering (ਸਮੂਹਬੰਦੀ, “grouping”) would let a reader take it as any ad-hoc grouping rather than the specific distribution an anomaly detector compares against. Full discussion: OPEN-QUESTIONS.md Q64.

¹¹⁰ **quarantine / quarantined** (EN) -> ਕੁਆਰੰਟੀਨ — kept as a loan because quarantine here names a precise third state (content is retained but excluded from retrieval), distinct from both ਅਲੱਗ-ਥਲੱਗ (isolation, already load-bearing for infrastructure elsewhere in the corpus) and outright removal. Full discussion: OPEN-QUESTIONS.md Q63.

#	ਵੇਰਵਾ	ਪੱਧਰ
8.2.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਪ੍ਰਾਪਤੀ ਨਤੀਜਿਆਂ ਨਾਲ ਹੋਰਾਫੇਰੀ ਕਰਨ ਲਈ ਘੜੀ ਗਈ ਸਮੱਗਰੀ ਦਾ ਪਤਾ ਲਗਾਇਆ ਜਾਂਦਾ ਹੈ ਅਤੇ ਉਸ ਨੂੰ ਵੈਕਟਰਾਈਜ਼ੇਸ਼ਨ ¹¹¹ ਤੋਂ ਪਹਿਲਾਂ ਰੱਦ ਜਾਂ ਕੁਆਰੰਟੀਨ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	3
8.2.5	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮੈਮੋਰੀ ਵੱਲੋਂ ਲਿਖੀ ਜਾਣ ਵਾਲੀ ਨਵੀਂ ਸਮੱਗਰੀ ਦੀ ਪਹਿਲਾਂ ਤੋਂ ਸੰਭਾਲੀ ਹੋਈ ਸਮੱਗਰੀ ਨਾਲ ਵਰਿਥਾਭਾਸਾਂ ਲਈ ਜਾਂਚ ਕੀਤੀ ਜਾਂਦੀ ਹੈ, ਅਤੇ ਟਕਰਾਅ ਹੋਣ 'ਤੇ ਚੇਤਾਵਨੀਆਂ ਪੈਦਾ ਹੁੰਦੀਆਂ ਹਨ।	3

C8.3 Memory Expiry & Revocation

C8.3 ਮੈਮੋਰੀ ਦੀ ਮਿਆਦ ਪੁੱਗਣਾ ਅਤੇ ਰੱਦਗੀ

Retention and revocation must be explicit and enforceable for memory and RAG indices.

ਮੈਮੋਰੀ ਅਤੇ RAG ਇੰਡੈਕਸਾਂ ਲਈ ਧਾਰਨ (retention) ਅਤੇ ਰੱਦਗੀ (revocation) ਦਾ ਸਪਸ਼ਟ ਅਤੇ ਲਾਗੂ ਕਰਨਯੋਗ ਹੋਣਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
8.3.1	Verify that expired vectors are excluded from retrieval results.	2
8.3.2	Verify that memory can be reset.	2
8.3.3	Verify that quarantined content is retained but excluded from all retrieval results.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
8.3.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਿਆਦ ਪੁੱਗ ਚੁੱਕੇ ਵੈਕਟਰ ਪ੍ਰਾਪਤੀ ਨਤੀਜਿਆਂ ਵੱਲੋਂ ਬਾਹਰ ਰੱਖੇ ਜਾਂਦੇ ਹਨ।	2
8.3.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮੈਮੋਰੀ ਨੂੰ ਰੀਸੈਟ ਕੀਤਾ ਜਾ ਸਕਦਾ ਹੈ।	2

¹¹¹**vectorization** (EN) -> ਵੈਕਟਰਾਈਜ਼ੇਸ਼ਨ — built on the already-locked loan ਵੈਕਟਰ, kept as a loan alongside ਕਲੱਸਟਰਿੰਗ as a named machine-learning operation rather than a fresh coinage. Full discussion: OPEN-QUESTIONS.md Q64.

#	ਵੇਰਵਾ	ਪੱਧਰ
8.3.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਕੁਆਰੰਟੀਨ ਕੀਤੀ ਸਮੱਗਰੀ ਦਾ ਧਾਰਨ ਕੀਤਾ ਜਾਂਦਾ ਹੈ ਪਰ ਉਸ ਨੂੰ ਸਾਰੇ ਪ੍ਰਾਪਤੀ ਨਤੀਜਿਆਂ ਵੱਲੋਂ ਬਾਹਰ ਰੱਖਿਆ ਜਾਂਦਾ ਹੈ।	3

References

ਹਵਾਲੇ

- OWASP LLM08:2025 Vector and Embedding Weaknesses
- OWASP LLM04:2025 Data and Model Poisoning
- OWASP LLM02:2025 Sensitive Information Disclosure
- MITRE ATLAS: RAG Poisoning
- MITRE ATLAS: Infer Training Data Membership

C9 Orchestration & Agentic Security

C9 ਆਰਕੈਸਟ੍ਰੇਸ਼ਨ¹¹² (orchestration) ਅਤੇ ਏਜੰਟ-ਆਧਾਰਿਤ¹¹³ ਸੁਰੱਖਿਆ

Control Objective

ਨਿਯੰਤਰਣ ਉਦੇਸ਼

This chapter addresses ensuring autonomous and multi-agent systems execute only authorized, intended, and bounded actions.

ਇਹ ਅਧਿਆਇ ਇਹ ਯਕੀਨੀ ਬਣਾਉਣ ਨੂੰ ਸੰਬੋਧਿਤ ਕਰਦਾ ਹੈ ਕਿ ਖੁਦਮੁਖਤਾਰ¹¹⁴ (autonomous) ਅਤੇ ਬਹੁ-ਏਜੰਟ ਸਿਸਟਮ ਸਰਿਫ਼ ਅਧਿਕਾਰਤ, ਇੱਛਤ, ਅਤੇ ਸੀਮਾਬੱਧ ਕਾਰਵਾਈਆਂ ਹੀ ਚਲਾਉਂਦੇ ਹਨ।

C9.1 Execution Budgets, Loop Control, and Circuit Breakers

C9.1 ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਬਜਟ, ਲੂਪ ਨਿਯੰਤਰਣ, ਅਤੇ ਸਰਕਟ ਬ੍ਰੇਕਰ

Runtime expansion (recursion, concurrency, cost) must be bounded, with safe halting on runaway behavior.

ਰਨਟਾਈਮ ਫੈਲਾਅ (ਰੀਕਰਸ਼ਨ, ਸਮਕਾਲੀਨਤਾ, ਲਾਗਤ) ਦਾ ਸੀਮਾਬੱਧ ਹੋਣਾ ਲਾਜ਼ਮੀ ਹੈ, ਅਤੇ ਬੇਕਾਬੂ ਵਰਤਵਾਂ ਹੋਣ 'ਤੇ ਸਲਾਮਤ (safe) ਢੰਗ ਨਾਲ ਰੁਕਣਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
9.1.1	Verify that per-tool quotas and timeouts (e.g., CPU, memory, disk, egress, and execution time) are enforced.	1
9.1.2	Verify that per-execution budgets (e.g., max recursion depth, token use, and monetary spend) are configured and enforced by the runtime.	1
9.1.3	Verify that a swarm-level kill-switch exists that can halt all active agent instances.	2

¹¹²**orchestration** (EN) -> ਆਰਕੈਸਟ੍ਰੇਸ਼ਨ — kept as a loan because the closer native words (ਤਾਲਮੇਲ, ਪ੍ਰਬੰਧ, ਸੰਚਾਲਨ) are all already reserved for other senses elsewhere in the corpus. Full discussion: OPEN-QUESTIONS.md Q83.

¹¹³**agent** (EN) -> ਏਜੰਟ — transliterated rather than translated because the native candidates (ਦੂਤ, ਪ੍ਰਤੀਨਿਧਿ, ਕਾਰਕ) either carry devotional colour or lose the software-agent sense; C09 is the deciding chapter for this pick. Full discussion: OPEN-QUESTIONS.md Q17.

¹¹⁴**autonomous** (EN) -> ਖੁਦਮੁਖਤਾਰ — chosen over ਸਵੈ-ਚਾਲਤਿ (“automatic/unattended”) because it captures deciding-and-acting without a human in the loop rather than merely running unattended. Full discussion: OPEN-QUESTIONS.md Q81.

#	ਵੇਰਵਾ	ਪੱਧਰ
9.1.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਪ੍ਰਤੀ-ਟੂਲ ਕੋਟੇ ਅਤੇ ਟਾਈਮਆਊਟ (ਜਵਿੰ, CPU, ਮੈਮੋਰੀ, ਡਿਸਕ, ਬਾਹਰ ਜਾਣ ਵਾਲਾ ਟਰੈਫਿਕ (egress), ਅਤੇ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਸਮਾਂ) ਲਾਗੂ ਕੀਤੇ ਜਾਂਦੇ ਹਨ।	1
9.1.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਪ੍ਰਤੀ-ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਬਜਟ (ਜਵਿੰ, ਵੱਧ ਤੋਂ ਵੱਧ ਰੀਕਰਸ਼ਨ ਡੂੰਘਾਈ, ਟੋਕਨ ਵਰਤੋਂ, ਅਤੇ ਵਤੀਤੀ ਖਰਚ) ਰਨਟਾਈਮ ਦੁਆਰਾ ਸੰਰਚਤਿ ਅਤੇ ਲਾਗੂ ਕੀਤੇ ਜਾਂਦੇ ਹਨ।	1
9.1.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਇੱਕ ਸਵਾਰਮ-ਪੱਧਰੀ (swarm-level) kill-switch (ਤੁਰੰਤ-ਬੰਦ ਸਵਿੱਚ) ਮੌਜੂਦ ਹੈ ਜੋ ਸਾਰੇ ਸਰਗਰਮ ਏਜੰਟ ਇੰਸਟਾਂਸਾਂ ਨੂੰ ਰੋਕ ਸਕਦਾ ਹੈ।	2

C9.2 High-Impact Action Approval and Irreversibility Controls

C9.2 ਉੱਚ-ਪ੍ਰਭਾਵ ਕਾਰਵਾਈ ਮਨਜ਼ੂਰੀ ਅਤੇ ਰੀਰ-ਉਲਟਾਉਣਯੋਗਤਾ ਨਿਯੰਤਰਣ

Privileged, high-impact, or hard-to-reverse agent actions must require trusted approval checkpoints.

ਵਸ਼ਿਸ਼-ਅਧਿਕਾਰ ਪ੍ਰਾਪਤ, ਉੱਚ-ਪ੍ਰਭਾਵ ਵਾਲੀਆਂ, ਜਾਂ ਔਖਿਆਈ ਨਾਲ ਉਲਟਾਈਆਂ ਜਾਣ ਵਾਲੀਆਂ ਏਜੰਟ ਕਾਰਵਾਈਆਂ ਲਈ ਭਰੋਸੇਯੋਗ ਮਨਜ਼ੂਰੀ ਚੈਕਪੁਆਇੰਟਾਂ ਦੀ ਲੋੜ ਹੋਣਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
9.2.1	Verify that the agent runtime blocks execution of privileged, high-impact, or irreversible actions until explicit human approval is received and verified.	1
9.2.2	Verify that approval requests display canonicalized and complete action parameters, such as diffs, commands, recipients, amounts, resources, and scopes, without truncation or unsafe transformation.	2

#	Description	Level
9.2.3	Verify that each high-impact action has a trusted reversibility classification, such as read-only, reversible, externally reversible, or irreversible.	2
9.2.4	Verify that the agent runtime enforces reversibility classifications by blocking, requiring approval, or restricting actions based on their impact and ability to be reversed.	2
9.2.5	Verify that any self-modification capability (e.g., prompt rewriting, tool-list changes, parameter updates) is restricted by enforceable boundaries.	2
9.2.6	Verify that agentic systems include an AI-augmented review of planned high-risk actions before execution that adds to, and does not replace, the deterministic policy gate.	2
9.2.7	Verify that the AI-augmented review mechanism is protected against manipulation by adversarial inputs, and cannot be overridden or bypassed through prompt injection.	2
9.2.8	Verify that approvals are cryptographically bound to action parameters, requester identity, execution context, and a unique single-use nonce.	3

#	Description	Level
9.2.9	Verify that cryptographic key material or credentials used to issue approvals are isolated from the agent runtime.	3
9.2.10	Verify that approval gates for multi-step or multi-agent action chains enforce the highest-impact reversibility classification present anywhere in the chain.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
9.2.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਏਜੰਟ ਰਨਟਾਈਮ ਵਸਿਸ਼-ਅਧਿਕਾਰ ਪ੍ਰਾਪਤ, ਉੱਚ-ਪ੍ਰਭਾਵ ਵਾਲੀਆਂ, ਜਾਂ ਗੈਰ-ਉਲਟਾਉਣਯੋਗ ਕਾਰਵਾਈਆਂ ਦੇ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਨੂੰ ਉਦੋਂ ਤੱਕ ਰੋਕਦਾ ਹੈ ਜਦੋਂ ਤੱਕ ਸਪੱਸ਼ਟ ਮਨੁੱਖੀ ਮਨਜ਼ੂਰੀ ਪ੍ਰਾਪਤ ਅਤੇ ਤਸਦੀਕ ਨਹੀਂ ਹੋ ਜਾਂਦੀ।	1
9.2.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਨਜ਼ੂਰੀ ਬੇਨਤੀਆਂ ਕਾਰਵਾਈ ਦੇ ਕੈਨੋਨੀਕਲਾਈਜ਼ ਕੀਤੇ ਅਤੇ ਸੰਪੂਰਨ ਪੈਰਾਮੀਟਰ — ਜਿਵੇਂ diff, ਕਮਾਂਡਾਂ, ਪ੍ਰਾਪਤਕਰਤਾ, ਰਕਮਾਂ, ਸਰੋਤ, ਅਤੇ ਸਕੇਪ — ਬਿਨਾਂ ਕਸ਼ਿ ਕਟੌਤੀ (truncation) ਜਾਂ ਗੈਰ-ਸਲਾਮਤ ਤਬਦੀਲੀ ਦੇ ਦਿਖਾਉਂਦੀਆਂ ਹਨ।	2
9.2.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਹਰ ਉੱਚ-ਪ੍ਰਭਾਵ ਵਾਲੀ ਕਾਰਵਾਈ ਦਾ ਇੱਕ ਭਰੋਸੇਯੋਗ ਉਲਟਾਉਣਯੋਗਤਾ ਵਰਗੀਕਰਨ (reversibility classification) ਹੈ, ਜਿਵੇਂ ਸਰਿਫ਼-ਪੜ੍ਹਨਯੋਗ, ਉਲਟਾਉਣਯੋਗ, ਬਾਹਰੀ ਤੌਰ 'ਤੇ ਉਲਟਾਉਣਯੋਗ, ਜਾਂ ਗੈਰ-ਉਲਟਾਉਣਯੋਗ।	2
9.2.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਏਜੰਟ ਰਨਟਾਈਮ ਕਾਰਵਾਈਆਂ ਦੇ ਪ੍ਰਭਾਵ ਅਤੇ ਉਹਨਾਂ ਦੇ ਉਲਟਾਏ ਜਾ ਸਕਣ ਦੀ ਸਮਰੱਥਾ ਦੇ ਆਧਾਰ 'ਤੇ ਉਹਨਾਂ ਨੂੰ ਰੋਕ ਕੇ, ਮਨਜ਼ੂਰੀ ਦੀ ਲੋੜ ਪਾ ਕੇ, ਜਾਂ ਸੀਮਤ ਕਰਕੇ ਉਲਟਾਉਣਯੋਗਤਾ ਵਰਗੀਕਰਨਾਂ ਨੂੰ ਲਾਗੂ ਕਰਦਾ ਹੈ।	2

#	ਵੇਰਵਾ	ਪੱਧਰ
9.2.5	ਤਸਦੀਕ ਕਰੋ ਕਿ ਕੋਈ ਵੀ ਸਵੈ-ਸੋਧ ਸਮਰੱਥਾ (ਜਿਵੇਂ, prompt ਨੂੰ ਮੁੜ-ਲਿਖਣਾ, ਟੂਲ-ਸੂਚੀ ਤਬਦੀਲੀਆਂ, ਪੈਰਾਮੀਟਰ ਅੱਪਡੇਟ) ਲਾਗੂਕਰਨਯੋਗ ਸੀਮਾਵਾਂ ਦੁਆਰਾ ਸੀਮਤ ਕੀਤੀ ਜਾਂਦੀ ਹੈ।	2
9.2.6	ਤਸਦੀਕ ਕਰੋ ਕਿ ਏਜੰਟ-ਆਧਾਰਤ ਸਸਿਟਮਾਂ ਵੱਲੋਂ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਤੋਂ ਪਹਿਲਾਂ ਯੋਜਨਾਬੱਧ ਉੱਚ-ਜੋਖਮ ਕਾਰਵਾਈਆਂ ਦੀ ਇੱਕ AI-ਸਹਾਇਤ ਪ੍ਰਾਪਤ ਸਮੀਖਿਆ (AI-augmented review) ਸ਼ਾਮਲ ਹੁੰਦੀ ਹੈ, ਜੋ ਨਿਸ਼ਚਿਤ (deterministic) ਨੀਤੀ ਗੇਟ ਵੱਲੋਂ ਵਾਧਾ ਕਰਦੀ ਹੈ, ਉਸ ਦੀ ਥਾਂ ਨਹੀਂ ਲੈਂਦੀ।	2
9.2.7	ਤਸਦੀਕ ਕਰੋ ਕਿ AI-ਸਹਾਇਤ ਪ੍ਰਾਪਤ ਸਮੀਖਿਆ ਵਧੀ ਵਰਿਧੀ ਇਨਪੁੱਟਾਂ ਦੁਆਰਾ ਹੇਰਾਫੇਰੀ ਤੋਂ ਸੁਰੱਖਿਅਤ ਹੈ, ਅਤੇ prompt ਇੰਜੈਕਸ਼ਨ ਰਾਹੀਂ ਇਸ ਨੂੰ ਓਵਰਰਾਈਡ ਜਾਂ ਬਾਈਪਾਸ ਨਹੀਂ ਕੀਤਾ ਜਾ ਸਕਦਾ।	2
9.2.8	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਨਜ਼ੂਰੀਆਂ ਕ੍ਰੈਪਿਟੋਗ੍ਰਾਫ਼ਿਕ ਤੌਰ 'ਤੇ ਕਾਰਵਾਈ ਦੇ ਪੈਰਾਮੀਟਰਾਂ, ਬੇਨਤੀਕਰਤਾ ਦੀ ਪਛਾਣ, ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਸੰਦਰਭ, ਅਤੇ ਇੱਕ ਵਲਿੱਖਣ ਇੱਕ-ਵਾਰੀ-ਵਰਤੋਂ ਵਾਲੇ ਨੌਸ (nonce) ਨਾਲ ਬੰਨ੍ਹੀਆਂ ਜਾਂਦੀਆਂ ਹਨ।	3
9.2.9	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਨਜ਼ੂਰੀਆਂ ਜਾਰੀ ਕਰਨ ਲਈ ਵਰਤੀ ਜਾਂਦੀ ਕ੍ਰੈਪਿਟੋਗ੍ਰਾਫ਼ਿਕ ਕੁੰਜੀ ਸਮੱਗਰੀ ਜਾਂ ਕ੍ਰੈਡੈਂਸ਼ੀਅਲ ਏਜੰਟ ਰਨਟਾਈਮ ਤੋਂ ਅਲੱਗ-ਥਲੱਗ ਹਨ।	3
9.2.10	ਤਸਦੀਕ ਕਰੋ ਕਿ ਬਹੁ-ਪੜਾਵੀ ਜਾਂ ਬਹੁ-ਏਜੰਟ ਕਾਰਵਾਈ ਲੜੀਆਂ ਲਈ ਮਨਜ਼ੂਰੀ ਗੇਟ ਲੜੀ ਵੱਲੋਂ ਕਤਿ ਵੀ ਮੌਜੂਦ ਸਭ ਤੋਂ ਉੱਚ-ਪ੍ਰਭਾਵ ਵਾਲਾ ਉਲਟਾਉਣਯੋਗਤਾ ਵਰਗੀਕਰਨ ਲਾਗੂ ਕਰਦੇ ਹਨ।	3

C9.3 Component Isolation and Tool Authorization

C9.3 ਕੰਪੋਨੈਂਟ¹¹⁵ ਅਲੱਗ-ਥਲੱਗਤਾ ਅਤੇ ਟੂਲ ਅਧਿਕਾਰੀਕਰਨ

Tool and plugin execution, loading, and outputs must be constrained to prevent unauthorized system access and unsafe side effects.

ਅਣਅਧਿਕਾਰਤ ਸਸਿਟਮ ਪਹੁੰਚ ਅਤੇ ਰੋਰ-ਸਲਾਮਤ ਸਹ-ਪ੍ਰਭਾਵਾਂ (side effects) ਨੂੰ ਰੋਕਣ ਲਈ ਟੂਲ ਅਤੇ ਪਲੱਗਇਨ ਦੇ ਐਗਜ਼ੀਕਿਊਸ਼ਨ, ਲੋਡਿੰਗ, ਅਤੇ ਆਊਟਪੁੱਟ¹¹⁶ ਨੂੰ ਸੀਮਤ ਕਰਨਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
9.3.1	Verify that each tool/plugin executes in a least-privilege sandbox or is otherwise isolated from model operations.	1
9.3.2	Verify that tool outputs are validated against schemas.	1
9.3.3	Verify that tool manifests declare required privileges, resource limits, and output validation requirements.	2
9.3.4	Verify that the runtime enforces the privileges, resource limits, and output-validation requirements declared in tool manifests.	2
9.3.5	Verify that components processing untrusted data are isolated from tool-calling capabilities, ensuring that compromised data processing cannot trigger unauthorized tool invocations.	2
9.3.6	Verify that there is architectural separation between processing of untrusted tool outputs and agent operations.	2

¹¹⁵ **component** (EN) -> ਕੰਪੋਨੈਂਟ — logged as an open corpus split: C09 and C10 use the loan ਕੰਪੋਨੈਂਟ while C03/C04/C12 use the native ਹਸਿ for the identical term-of-art sense. Full discussion: OPEN-QUESTIONS.md Q95.

¹¹⁶ **output** (EN) -> ਆਊਟਪੁੱਟ — kept as a loan to mirror the ASVS corpus's ਇਨਪੁੱਟ/ਆਊਟਪੁੱਟ pairing rather than ਨਤੀਜਾ (“result”), which would collide with a different sense. Full discussion: OPEN-QUESTIONS.md Q78.

#	Description	Level
9.3.7	Verify that external resources named in model output are verified against an approved allow-list or registry before the agent installs or invokes them.	2
9.3.8	Verify that policy violations trigger automated tool containment.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
9.3.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਹਰ ਟੂਲ/ਪਲੱਗਇਨ ਘੱਟੋ-ਘੱਟ-ਵਸ਼ਿਸਤ-ਅਧਿਕਾਰ (least-privilege) ਸੈੱਡਬਾਕਸ ਵਿੱਚ ਚੱਲਦਾ ਹੈ ਜਾਂ ਕਸਿ ਹੋਰ ਢੰਗ ਨਾਲ ਮਾਡਲ ਕਾਰਵਾਈਆਂ ਤੋਂ ਅਲੱਗ-ਥਲੱਗ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	1
9.3.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਟੂਲ ਆਊਟਪੁੱਟ ਨੂੰ ਸਕੀਮਾਵਾਂ ਦੇ ਵਿਰੁੱਧ ਪ੍ਰਮਾਣਿਤ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	1
9.3.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਟੂਲ ਮੈਨੀਫੈਸਟ (tool manifests) ਲੋੜੀਂਦੇ ਵਸ਼ਿਸਤ-ਅਧਿਕਾਰਾਂ, ਸਰੋਤ ਸੀਮਾਵਾਂ, ਅਤੇ ਆਊਟਪੁੱਟ ਪ੍ਰਮਾਣਿਕਤਾ ਲੋੜਾਂ ਦੀ ਘੋਸ਼ਣਾ ਕਰਦੇ ਹਨ।	2
9.3.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਰਨਟਾਈਮ ਟੂਲ ਮੈਨੀਫੈਸਟਾਂ ਵਿੱਚ ਘੋਸ਼ਿਤ ਵਸ਼ਿਸਤ-ਅਧਿਕਾਰਾਂ, ਸਰੋਤ ਸੀਮਾਵਾਂ, ਅਤੇ ਆਊਟਪੁੱਟ-ਪ੍ਰਮਾਣਿਕਤਾ ਲੋੜਾਂ ਨੂੰ ਲਾਗੂ ਕਰਦਾ ਹੈ।	2
9.3.5	ਤਸਦੀਕ ਕਰੋ ਕਿ ਗੈਰ-ਭਰੋਸੇਯੋਗ ਡਾਟਾ ਦੀ ਪ੍ਰਕਿਰਿਆ ਕਰਨ ਵਾਲੇ ਕੰਪੋਨੈਂਟ ਟੂਲ-ਕਾਲ ਕਰਨ ਦੀਆਂ ਸਮਰੱਥਾਵਾਂ ਤੋਂ ਅਲੱਗ-ਥਲੱਗ ਹਨ, ਜਿਸ ਨਾਲ ਇਹ ਯਕੀਨੀ ਬਣਦਾ ਹੈ ਕਿ ਸਮਝੌਤਾ ਹੋਈ ਡਾਟਾ ਪ੍ਰਕਿਰਿਆ ਅਣਅਧਿਕਾਰਤ ਟੂਲ ਸੱਦੇ (tool invocations) ਸ਼ੁਰੂ ਨਹੀਂ ਕਰ ਸਕਦੀ।	2
9.3.6	ਤਸਦੀਕ ਕਰੋ ਕਿ ਗੈਰ-ਭਰੋਸੇਯੋਗ ਟੂਲ ਆਊਟਪੁੱਟ ਦੀ ਪ੍ਰਕਿਰਿਆ ਅਤੇ ਏਜੰਟ ਕਾਰਵਾਈਆਂ ਵਿਚਕਾਰ ਆਰਕੀਟੈਕਚਰਲ ਵਡਿਆਨ ਮੌਜੂਦ ਹੈ।	2

#	ਵੇਰਵਾ	ਪੱਧਰ
9.3.7	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਾਡਲ ਆਊਟਪੁੱਟ ਵੱਲੋਂ ਨਾਮਜ਼ਦ ਬਾਹਰੀ ਸਰੋਤਾਂ ਦੀ, ਏਜੰਟ ਦੁਆਰਾ ਉਹਨਾਂ ਨੂੰ ਸਥਾਪਤ ਕਰਨ ਜਾਂ ਸੱਦਣ ਤੋਂ ਪਹਿਲਾਂ, ਇੱਕ ਪ੍ਰਵਾਨਤਿ allow-list ਜਾਂ ਰਜਿਸਟਰੀ ਦੇ ਵਰਿਥ ਤਸਦੀਕ ਕੀਤੀ ਜਾਂਦੀ ਹੈ।	2
9.3.8	ਤਸਦੀਕ ਕਰੋ ਕਿ ਨੀਤੀ ਉਲੰਘਣਾਵਾਂ ਸਵੈਚਾਲਤਿ ਟੂਲ ਘੇਰਾਬੰਦੀ (tool containment) ਸ਼ੁਰੂ ਕਰਦੀਆਂ ਹਨ।	3

C9.4 Agent and Orchestrator Identity

C9.4 ਏਜੰਟ ਅਤੇ ਆਰਕੈਸਟ੍ਰੇਟਰ (orchestrator) ਪਛਾਣ

Every action must be attributable and every mutation detectable.

ਹਰ ਕਾਰਵਾਈ ਦਾ ਸਰੋਤ-ਨਰਿਧਾਰਨਯੋਗ ਹੋਣਾ ਅਤੇ ਹਰ ਪਰਵਿਰਤਨ (mutation) ਦਾ ਪਤਾ ਲਗਾਉਣਯੋਗ ਹੋਣਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
9.4.1	Verify that each agent instance has a unique cryptographic identity and authenticates as a first-class principal to downstream systems.	2
9.4.2	Verify that agent-initiated actions are cryptographically bound to each step of the execution chain for non-repudiation.	2
9.4.3	Verify that agent identity credentials rotate on a defined schedule.	3
9.4.4	Verify that agent state persisted between invocations is integrity-protected.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
9.4.1	ਤਸਦੀਕ ਕਰੋ ਕੀ ਹਰ ਏਜੰਟ ਇੰਸਟਾਂਸ ਦੀ ਇੱਕ ਵਲਿੱਖਣ ਕ੍ਰਪਿਟੋਗ੍ਰਾਫਿਕ ਪਛਾਣ ਹੈ ਅਤੇ ਉਹ ਡਾਊਨਸਟ੍ਰੀਮ ¹¹⁷ ਸਿਸਟਮਾਂ ਲਈ ਇੱਕ ਪਹਲਿ-ਦਰਜੇ ਦੀ ਪਛਾਣ-ਇਕਾਈ ¹¹⁸ (first-class principal) ਵਜੋਂ ਪ੍ਰਮਾਣੀਕਰਨ ਕਰਦਾ ਹੈ।	2
9.4.2	ਤਸਦੀਕ ਕਰੋ ਕੀ ਏਜੰਟ ਦੁਆਰਾ ਸ਼ੁਰੂ ਕੀਤੀਆਂ ਕਾਰਵਾਈਆਂ ਗੈਰ-ਇਨਕਾਰਯੋਗਤਾ (non-repudiation) ਲਈ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਲੜੀ ਦੇ ਹਰ ਪੜਾਅ ਨਾਲ ਕ੍ਰਪਿਟੋਗ੍ਰਾਫਿਕ ਤੌਰ 'ਤੇ ਬੰਨ੍ਹੀਆਂ ਜਾਂਦੀਆਂ ਹਨ।	2
9.4.3	ਤਸਦੀਕ ਕਰੋ ਕੀ ਏਜੰਟ ਪਛਾਣ ਕ੍ਰੈਡੈਂਸ਼ੀਅਲ ਇੱਕ ਪਰਭਾਸ਼ਿਤ ਸਮਾਂ-ਸਾਰਣੀ ਅਨੁਸਾਰ ਬਦਲੇ (rotate) ਜਾਂਦੇ ਹਨ।	3
9.4.4	ਤਸਦੀਕ ਕਰੋ ਕੀ ਸੱਦਿਆਂ ਵੇਚਕਾਰ ਸਥਾਈ ਰੱਖੀ ਗਈ ਏਜੰਟ ਸਥਿਤੀ ਅਖੰਡਤਾ-ਸੁਰੱਖਿਅਤ ਹੈ।	3

C9.5 Agent Authorization, Delegation, and Continuous Enforcement

C9.5 ਏਜੰਟ ਅਧਿਕਾਰੀਕਰਨ, ਸੌਂਪਣੀ, ਅਤੇ ਨਰਿੰਤਰ ਲਾਗੂਕਰਨ

Every action must be authorized at execution time and constrained by scope.

ਹਰ ਕਾਰਵਾਈ ਦਾ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਦੇ ਸਮੇਂ ਅਧਿਕਾਰੀਕਰਨ ਹੋਣਾ ਅਤੇ ਸਕੋਪ ਦੁਆਰਾ ਸੀਮਤਿ ਹੋਣਾ ਲਾਜ਼ਮੀ ਹੈ।

¹¹⁷**downstream** (EN) -> ਡਾਊਨਸਟ੍ਰੀਮ — kept as a loan because a literal water-flow rendering would mislead a reader into a physical-flow reading of pipeline data direction. Full discussion: OPEN-QUESTIONS.md Q77.

¹¹⁸**principal** (EN) -> ਪਛਾਣ-ਇਕਾਈ — coined from ਪਛਾਣ (identity) rather than ਕਰਤਾ, which is rejected as load-bearing Sikh devotional vocabulary (ਕਰਤਾ ਪੁਰਖ); note C11.2.2 still uses the loan ਪ੍ਰਸਿੱਧਲ for the same concept, an open split. Full discussion: OPEN-QUESTIONS.md Q124.

#	Description	Level
9.5.1	Verify that agent actions are authorized against fine-grained policies enforced by the runtime that restrict which tools an agent may invoke, and which parameter values it may supply.	2
9.5.2	Verify that when an agent acts on a user's behalf, the runtime propagates an integrity-protected, scope-limited token that carries the user's authorization context and is enforced at every downstream call.	2
9.5.3	Verify that all access control decisions are enforced by application logic or a policy engine, never by the AI model itself.	2
9.5.4	Verify that secrets and credentials required by an agent at runtime are not exposed within the model's observable context, including the context window, system prompts, or tool call parameters.	2
9.5.5	Verify that inter-agent task delegation is restricted by an explicit authorization policy.	2
9.5.6	Verify that long-running agent sessions re-evaluate current backend authorization policy on every privileged action.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
9.5.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਏਜੰਟ ਕਾਰਵਾਈਆਂ ਦਾ ਰਨਟਾਈਮ ਦੁਆਰਾ ਲਾਗੂ ਕੀਤੀਆਂ ਬਾਰੀਕ-ਪੱਧਰੀ ਨੀਤੀਆਂ ਦੇ ਵਰਿਊਥ ਅਧਿਕਾਰੀਕਰਨ ਕੀਤਾ ਜਾਂਦਾ ਹੈ, ਜੋ ਇਹ ਸੀਮਤ ਕਰਦੀਆਂ ਹਨ ਕਿ ਇੱਕ ਏਜੰਟ ਕਹਿੰਦੇ ਟੂਲ ਸੱਦ ਸਕਦਾ ਹੈ, ਅਤੇ ਕਹਿੰਦੇ ਪੈਰਾਮੀਟਰ ਮੁੱਲ ਦੇ ਸਕਦਾ ਹੈ।	2
9.5.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਜਦੋਂ ਕੋਈ ਏਜੰਟ ਕਮਿ ਉਪਭੋਗਤਾ ਵੱਲੋਂ ਕਾਰਵਾਈ ਕਰਦਾ ਹੈ, ਤਾਂ ਰਨਟਾਈਮ ਇੱਕ ਅਖੰਡਤਾ-ਸੁਰੱਖਿਅਤ, ਸਕੋਪ-ਸੀਮਤਿ ਟੈਕਨ ਅੱਗੇ ਸੰਚਾਰਤਿ ਕਰਦਾ ਹੈ ਜੋ ਉਪਭੋਗਤਾ ਦਾ ਅਧਿਕਾਰੀਕਰਨ ਸੰਦਰਭ ਲੈ ਕੇ ਜਾਂਦਾ ਹੈ ਅਤੇ ਹਰ ਡਾਊਨਸਟਰੀਮ ਕਾਲ 'ਤੇ ਲਾਗੂ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	2
9.5.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਾਰੇ ਪਹੁੰਚ ਕੰਟਰੋਲ ਫ੍ਰੈਸਲੇ ਐਪਲੀਕੇਸ਼ਨ ਤਰਕ ਜਾਂ ਇੱਕ ਨੀਤੀ ਇੰਜਣ ਦੁਆਰਾ ਲਾਗੂ ਕੀਤੇ ਜਾਂਦੇ ਹਨ, ਕਦੇ ਵੀ AI ਮਾਡਲ ਦੁਆਰਾ ਖੁਦ ਨਹੀਂ।	2
9.5.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਰਨਟਾਈਮ 'ਤੇ ਕਮਿ ਏਜੰਟ ਨੂੰ ਲੋੜੀਂਦੇ ਗੁਪਤ ਭੇਦ ਅਤੇ ਕਰੈਡੈਂਸ਼ੀਅਲ ਮਾਡਲ ਦੇ ਦੇਖਣਯੋਗ ਸੰਦਰਭ ਵੱਲੋਂ ਜਾਹਰ ਨਹੀਂ ਹੁੰਦੇ, ਜਿਸ ਵੱਲੋਂ ਸੰਦਰਭ ਵੱਡੇ, system prompt, ਜਾਂ ਟੂਲ ਕਾਲ ਪੈਰਾਮੀਟਰ ਸ਼ਾਮਲ ਹਨ।	2
9.5.5	ਤਸਦੀਕ ਕਰੋ ਕਿ ਏਜੰਟਾਂ ਵਿਚਕਾਰ ਕਾਰਜ ਸੌਪਣੀ (task delegation) ਇੱਕ ਸਪੱਸ਼ਟ ਅਧਿਕਾਰੀਕਰਨ ਨੀਤੀ ਦੁਆਰਾ ਸੀਮਤ ਕੀਤੀ ਜਾਂਦੀ ਹੈ।	2
9.5.6	ਤਸਦੀਕ ਕਰੋ ਕਿ ਲੰਬੇ ਸਮੇਂ ਤੱਕ ਚੱਲਣ ਵਾਲੇ ਏਜੰਟ ਸੈਸ਼ਨ ਹਰ ਵਸ਼ਿਸ਼-ਅਧਿਕਾਰ ਪ੍ਰਾਪਤ ਕਾਰਵਾਈ 'ਤੇ ਮੌਜੂਦਾ ਬੈਕਐਂਡ ਅਧਿਕਾਰੀਕਰਨ ਨੀਤੀ ਦਾ ਮੁੜ-ਮੁਲਾਂਕਣ ਕਰਦੇ ਹਨ।	3

C9.6 Shutdown and Graceful Degradation

C9.6 ਬੰਦ ਕਰਨਾ ਅਤੇ ਸੁਚੱਜੀ ਗਰਿਏਟ

Shutdown and graceful degradation paths must remain under human control, with mechanisms that stay reliable and are exercised over time.

ਬੰਦ ਕਰਨ ਅਤੇ ਸੁਚੱਜੀ ਗਰਿਥਾਵਟ (graceful degradation) ਦੇ ਰਾਹਾਂ ਦਾ ਮਨੁੱਖੀ ਨਿਯੰਤਰਣ ਹੇਠ ਰਹਿਣਾ ਲਾਜ਼ਮੀ ਹੈ, ਅਤੇ ਇਹਨਾਂ ਦੀਆਂ ਵਧੀਆਂ ਦਾ ਭਰੋਸੇਯੋਗ ਬਣੇ ਰਹਿਣਾ ਅਤੇ ਸਮੇਂ ਦੇ ਨਾਲ-ਨਾਲ ਪਰਖੇ ਜਾਣਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
9.6.1	Verify that a manual kill-switch mechanism exists to immediately halt AI model inference and outputs.	1
9.6.2	Verify that when a human-approval gate is not satisfied within the defined approval time, the system blocks the pending action.	2
9.6.3	Verify that kill-switch commands are implemented through an out-of-band channel that is isolated from the agent runtime.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
9.6.1	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਮਾਡਲ ਦੇ ਇਨਫਰੈਂਸ ਅਤੇ ਆਊਟਪੁੱਟ ਨੂੰ ਤੁਰੰਤ ਰੋਕਣ ਲਈ ਇੱਕ ਹੱਥੀ ਚਲਾਈ ਜਾਣ ਵਾਲੀ kill-switch ਵਧੀ ਮੌਜੂਦ ਹੈ।	1
9.6.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਜਦੋਂ ਪਰਭਿਾਸ਼ਤਿ ਮਨਜ਼ੂਰੀ ਸਮੇਂ ਦੇ ਅੰਦਰ ਮਨੁੱਖੀ-ਮਨਜ਼ੂਰੀ ਗੇਟ ਪੂਰਾ ਨਹੀਂ ਹੁੰਦਾ, ਤਾਂ ਸਸਿਟਮ ਬਕਾਇਆ ਕਾਰਵਾਈ ਨੂੰ ਰੋਕ ਦਿੰਦਾ ਹੈ।	2
9.6.3	ਤਸਦੀਕ ਕਰੋ ਕਿ kill-switch ਕਮਾਂਡਾਂ ਇੱਕ ਆਊਟ-ਆਫ-ਬੈਂਡ (out-of-band) ਚੈਨਲ ਰਾਹੀਂ ਲਾਗੂ ਕੀਤੀਆਂ ਜਾਂਦੀਆਂ ਹਨ ਜੋ ਏਜੰਟ ਰਨਟਾਈਮ ਤੋਂ ਅਲੱਗ-ਥਲੱਗ ਹੈ।	3

References

ਹਵਾਲੇ

- OWASP Agentic AI Threats and Mitigations
- OWASP Top 10 for Agentic Applications 2026

- OWASP LLM06:2025 Excessive Agency
- NIST AI 100-1: AI Risk Management Framework (AI RMF 1.0)
- Regulation (EU) 2024/1689 (EU AI Act), Article 14: Human Oversight

C10 Model Context Protocol (MCP) Security

C10 Model Context Protocol (MCP)¹¹⁹ ਸੁਰੱਖਿਆ

Control Objective

ਨਿਯੰਤਰਣ ਉਦੇਸ਼

This chapter addresses secure discovery, authentication, authorization, transport, and use of MCP-based tool and resource integrations.

ਇਹ ਅਧਿਆਇ MCP-ਆਧਾਰਿਤ ਟੂਲ ਅਤੇ ਸਰੋਤ ਏਕੀਕਰਨਾਂ (integrations) ਦੀ ਸੁਰੱਖਿਅਤ ਖੋਜ¹²⁰ (discovery), ਪ੍ਰਮਾਣੀਕਰਨ, ਅਧਿਕਾਰੀਕਰਨ, ਟ੍ਰਾਂਸਪੋਰਟ¹²¹, ਅਤੇ ਵਰਤੋਂ ਨੂੰ ਸੰਬੋਧਿਤ ਕਰਦਾ ਹੈ।

C10.1 Component Integrity

C10.1 ਕੰਪੋਨੈਂਟ¹²² ਅਖੰਡਤਾ

Only trusted MCP components must be used, and locally launched servers must be secured.

ਸਿਰਫ਼ ਭਰੋਸੇਯੋਗ MCP ਕੰਪੋਨੈਂਟਾਂ ਦੀ ਹੀ ਵਰਤੋਂ ਕਰਨਾ ਲਾਜ਼ਮੀ ਹੈ, ਅਤੇ ਸਥਾਨਕ ਤੌਰ 'ਤੇ ਚਾਲੂ ਕੀਤੇ ਗਏ ਸਰਵਰਾਂ¹²³ ਨੂੰ ਸੁਰੱਖਿਅਤ ਕਰਨਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
10.1.1	Verify that MCP components are obtained only from trusted sources and cryptographically verified.	1
10.1.2	Verify that only allow-listed MCP servers are permitted.	2
10.1.3	Verify that locally launched MCP servers run in a least-privilege sandbox with restricted file system, network, and system access.	2

¹¹⁹ **Model Context Protocol (MCP)** (EN) -> retained verbatim — kept in English/Latin because it is the wire protocol's proper name and a reader must be able to match it against the specification this chapter cites. Full discussion: OPEN-QUESTIONS.md Q87.

¹²⁰ **discovery** (EN) -> ਖੋਜ — reuses a word already carrying lookup/search elsewhere in the corpus; flagged as a known overload rather than a fresh coinage. Full discussion: OPEN-QUESTIONS.md Q94.

¹²¹ **transport** (EN) -> ਟ੍ਰਾਂਸਪੋਰਟ — kept as a loan over literal “haulage” renderings, which would suggest physical goods rather than a protocol channel. Full discussion: OPEN-QUESTIONS.md Q90.

¹²² **component** (EN) -> ਕੰਪੋਨੈਂਟ — logged as an open corpus split: C09/C10 use this loan while C03/C04/C12 use the native ਹਿੱਸਾ for the identical term-of-art sense. Full discussion: OPEN-QUESTIONS.md Q95.

¹²³ **server / client** (EN) -> ਸਰਵਰ / ਕਲਾਇੰਟ — the devotional-toned ਸੇਵਾਦਾਰ (“one who serves”) was excluded because ਸੇਵਾ is load-bearing Gurmat vocabulary for selfless service. Full discussion: OPEN-QUESTIONS.md Q88.

#	ਵੇਰਵਾ	ਪੱਧਰ
10.1.1	ਤਸਦੀਕ ਕਰੋ ਕਿ MCP ਕੰਪੋਨੈਂਟ ਸਰਿਫ਼ ਭਰੋਸੇਯੋਗ ਸਰੋਤਾਂ ਤੋਂ ਹੀ ਪ੍ਰਾਪਤ ਕੀਤੇ ਜਾਂਦੇ ਹਨ ਅਤੇ ਕਰਪਿਟੇਗਰਾਫ਼ਿਕ ਤੌਰ 'ਤੇ ਤਸਦੀਕ ਕੀਤੇ ਜਾਂਦੇ ਹਨ।	1
10.1.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਰਿਫ਼ allow-list ਵਿੱਚ ਸ਼ਾਮਲ MCP ਸਰਵਰਾਂ ਦੀ ਹੀ ਆਗਿਆ ਹੈ।	2
10.1.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਥਾਨਕ ਤੌਰ 'ਤੇ ਚਾਲੂ ਕੀਤੇ ਗਏ MCP ਸਰਵਰ ਸੀਮਤ ਫ਼ਾਈਲ ਸਿਸਟਮ, ਨੈੱਟਵਰਕ, ਅਤੇ ਸਿਸਟਮ ਪਹੁੰਚ ਵਾਲੇ ਘੱਟੋ-ਘੱਟ-ਵਿਸ਼ੇਸ਼-ਅਧਿਕਾਰ (least-privilege) ਸੈੱਡਬਾਕਸ ਵਿੱਚ ਚੱਲਦੇ ਹਨ।	2

C10.2 Authentication & Authorization

C10.2 ਪ੍ਰਮਾਣੀਕਰਨ ਅਤੇ ਅਧਿਕਾਰੀਕਰਨ

Callers must be authenticated and access to MCP servers authorized, following protocol best practices.

ਪ੍ਰੋਟੋਕੋਲ ਦੇ ਬਹਿਤਰੀਨ ਅਮਲਾਂ ਦੀ ਪਾਲਣਾ ਕਰਦਿਆਂ, ਸੱਦਣ ਵਾਲਿਆਂ (callers) ਦਾ ਪ੍ਰਮਾਣੀਕਰਨ ਹੋਣਾ ਅਤੇ MCP ਸਰਵਰਾਂ ਤੱਕ ਪਹੁੰਚ ਦਾ ਅਧਿਕਾਰੀਕਰਨ ਹੋਣਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
10.2.1	Verify that MCP servers validate access tokens for each request and do not rely on transport security alone.	1
10.2.2	Verify that MCP servers validate the presented access token's issuer, audience, expiration, and scope claims in accordance with OAuth 2.1.	1
10.2.3	Verify that MCP servers acting as OAuth 2.1 resource servers do not store or persist access tokens or user credentials.	1

#	Description	Level
10.2.4	Verify that MCP tools/list returns only tools permitted by resource owners' authorized scopes.	2
10.2.5	Verify that MCP servers enforce access control on every tool invocation, validating that the user's access token authorizes both the requested tool and the specific argument values supplied.	2
10.2.6	Verify that MCP servers ensure all session artifacts are removed when a session terminates.	2
10.2.7	Verify that MCP servers do not pass through access tokens received from clients to downstream APIs.	2

#	ਵੇਰਵਾ	ਪੱਧਰ
10.2.1	ਤਸਦੀਕ ਕਰੋ ਕਿ MCP ਸਰਵਰ ਹਰ ਬੇਨਤੀ ਲਈ ਪਹੁੰਚ ਟੋਕਨ ਪ੍ਰਮਾਣਿਤ ਕਰਦੇ ਹਨ ਅਤੇ ਇਕੱਲੀ ਟ੍ਰਾਂਸਪੋਰਟ ਸੁਰੱਖਿਆ 'ਤੇ ਨਿਰਭਰ ਨਹੀਂ ਕਰਦੇ।	1
10.2.2	ਤਸਦੀਕ ਕਰੋ ਕਿ MCP ਸਰਵਰ ਪੇਸ਼ ਕੀਤੇ ਗਏ ਪਹੁੰਚ ਟੋਕਨ ਦੇ ਜਾਰੀਕਰਤਾ (issuer), ਉਦੇਸ਼ਿਤ ਪ੍ਰਾਪਤਕਰਤਾ ¹²⁴ (audience), ਮਿਆਦ ਸਮਾਪਤੀ (expiration), ਅਤੇ ਸਕੋਪ ਦੇ ਦਾਅਵਿਆਂ (claims) ਨੂੰ OAuth 2.1 ਦੇ ਅਨੁਸਾਰ ਪ੍ਰਮਾਣਿਤ ਕਰਦੇ ਹਨ।	1
10.2.3	ਤਸਦੀਕ ਕਰੋ ਕਿ OAuth 2.1 ਸਰੋਤ ਸਰਵਰਾਂ (resource servers) ਵੱਲੋਂ ਕੰਮ ਕਰਨ ਵਾਲੇ MCP ਸਰਵਰ ਪਹੁੰਚ ਟੋਕਨ ਜਾਂ ਉਪਭੋਗਤਾ ਕ੍ਰੈਡੈਂਸ਼ੀਅਲ ਨਾ ਤਾਂ ਭੰਡਾਰ ਕਰਦੇ ਹਨ ਅਤੇ ਨਾ ਹੀ ਸਥਾਈ ਤੌਰ 'ਤੇ ਰੱਖਦੇ ਹਨ।	1

¹²⁴ **audience** (token claim) (EN) -> ਉਦੇਸ਼ਿਤ ਪ੍ਰਾਪਤਕਰਤਾ ("intended recipient") — chosen over ਸਰੋਤੇ/ਦਰਸ਼ਕ ("listening/viewing public"), which would invert the OAuth meaning of a single intended token recipient. Full discussion: OPEN-QUESTIONS.md Q89.

#	ਵੇਰਵਾ	ਪੱਧਰ
10.2.4	ਤਸਦੀਕ ਕਰੋ ਕਿ MCP tools/list ਸਰਿਫ਼ ਉਹੀ ਟੂਲ ਵਾਪਸ ਕਰਦਾ ਹੈ ਜਿਨ੍ਹਾਂ ਦੀ ਸਰੋਤ ਮਾਲਕਾਂ (resource owners) ਦੇ ਅਧਿਕਾਰਤ ਸਕੋਪਾਂ ਦੁਆਰਾ ਆਗਿਆ ਹੈ।	2
10.2.5	ਤਸਦੀਕ ਕਰੋ ਕਿ MCP ਸਰਵਰ ਹਰ ਟੂਲ ਸੱਦੇ (tool invocation) 'ਤੇ ਪਹੁੰਚ ਕੰਟਰੋਲ ਲਾਗੂ ਕਰਦੇ ਹਨ, ਅਤੇ ਇਹ ਪ੍ਰਮਾਣਿਤ ਕਰਦੇ ਹਨ ਕਿ ਉਪਭੋਗਤਾ ਦਾ ਪਹੁੰਚ ਟੋਕਨ ਬੇਨਤੀ ਕੀਤੇ ਟੂਲ ਅਤੇ ਦੱਤੇ ਗਏ ਖਾਸ ਆਰਗੂਮੈਂਟ ਮੁੱਲਾਂ, ਦੋਵਾਂ ਦਾ ਅਧਿਕਾਰੀਕਰਨ ਕਰਦਾ ਹੈ।	2
10.2.6	ਤਸਦੀਕ ਕਰੋ ਕਿ MCP ਸਰਵਰ ਇਹ ਯਕੀਨੀ ਬਣਾਉਂਦੇ ਹਨ ਕਿ ਜਦੋਂ ਕੋਈ ਸੈਸ਼ਨ ਸਮਾਪਤ ਹੁੰਦਾ ਹੈ ਤਾਂ ਸਾਰੇ ਸੈਸ਼ਨ ਆਰਟੀਫੈਕਟ ਹਟਾ ਦਿੱਤੇ ਜਾਂਦੇ ਹਨ।	2
10.2.7	ਤਸਦੀਕ ਕਰੋ ਕਿ MCP ਸਰਵਰ ਕਲਾਇੰਟਾਂ ਤੋਂ ਪ੍ਰਾਪਤ ਹੋਏ ਪਹੁੰਚ ਟੋਕਨ ਡਾਊਨਸਟ੍ਰੀਮ ¹²⁵ API ਨੂੰ ਅੱਗੇ ਨਹੀਂ ਲੰਘਾਉਂਦੇ ¹²⁶ (pass through)।	2

C10.3 Secure Transport

C10.3 ਸੁਰੱਖਿਅਤ ਟ੍ਰਾਂਸਪੋਰਟ

MCP communications must be secured following protocol best practices.

ਪ੍ਰੋਟੋਕੋਲ ਦੇ ਬਹਿਤਰੀਨ ਅਮਲਾਂ ਦੀ ਪਾਲਣਾ ਕਰਦਿਆਂ MCP ਸੰਚਾਰਾਂ ਨੂੰ ਸੁਰੱਖਿਅਤ ਕਰਨਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
10.3.1	Verify that authenticated, encrypted streamable HTTP is used for MCP transport for remote services.	1

¹²⁵ **downstream** (EN) -> ਡਾਊਨਸਟ੍ਰੀਮ — kept as a loan, consistent with the corpus's other pipeline/infrastructure loans, rather than a literal water-flow rendering. Full discussion: OPEN-QUESTIONS.md Q77.

¹²⁶ **pass through** (EN) -> ਅੱਗੇ ਲੰਘਾਉਣਾ — deliberately kept distinct from 'ਅੱਗੇ ਸੰਚਾਰਿਤ ਕਰਨਾ' (C09's approved delegation-token propagation) so a prohibition and an obligation don't read as the same act. Full discussion: OPEN-QUESTIONS.md Q101.

#	Description	Level
10.3.2	Verify that stdio transport is permitted only in controlled local environments.	1
10.3.3	Verify that MCP servers validate both the Origin header and the Host header independently on all HTTP-based transports to prevent DNS rebinding attacks.	2
10.3.4	Verify that MCP clients enforce a minimum acceptable protocol version and reject initialize responses that propose a version below that minimum.	2
10.3.5	Verify that access tokens between the MCP client and server are sender-constrained using mTLS or DPoP.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
10.3.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਰਮਿਟ ਸੇਵਾਵਾਂ ਲਈ MCP ਟ੍ਰਾਂਸਪੋਰਟ ਵਾਸਤੇ ਪ੍ਰਮਾਣੀਕਰਨ ਕੀਤਾ ਗਿਆ, ਏਨਕ੍ਰਿਪਟ ਕੀਤਾ ਗਿਆ streamable HTTP ਵਰਤਿਆ ਜਾਂਦਾ ਹੈ।	1
10.3.2	ਤਸਦੀਕ ਕਰੋ ਕਿ stdio ਟ੍ਰਾਂਸਪੋਰਟ ਦੀ ਆਗਿਆ ਸਹਿਫ਼ ਨਿਯੰਤਰਿਤ ਸਥਾਨਕ ਵਾਤਾਵਰਣਾਂ ਵਿੱਚ ਹੀ ਹੈ।	1
10.3.3	ਤਸਦੀਕ ਕਰੋ ਕਿ MCP ਸਰਵਰ DNS rebinding ¹²⁷ ਹਮਲਿਆਂ ਨੂੰ ਰੋਕਣ ਲਈ ਸਾਰੇ HTTP-ਆਧਾਰਿਤ ਟ੍ਰਾਂਸਪੋਰਟਾਂ ਉੱਤੇ Origin ਹੈੱਡਰ ਅਤੇ Host ਹੈੱਡਰ ਦੋਵਾਂ ਨੂੰ ਵੱਖਰੇ ਤੌਰ 'ਤੇ ਪ੍ਰਮਾਣਿਤ ਕਰਦੇ ਹਨ।	2

¹²⁷**DNS rebinding / replay** (EN) -> DNS rebinding retained verbatim; replay retained with a ਦੁਹਰਾਓ (“repetition”) gloss — both are named attack classes kept searchable against the cited OWASP MCP Security Cheat Sheet. Full discussion: OPEN-QUESTIONS.md Q92.

#	ਵੇਰਵਾ	ਪੱਧਰ
10.3.4	ਤਸਦੀਕ ਕਰੋ ਕਿ MCP ਕਲਾਇੰਟ ਇੱਕ ਘੱਟੋ-ਘੱਟ ਸਵੀਕਾਰਯੋਗ ਪਰੋਟੋਕੋਲ ਸੰਸਕਰਣ ਲਾਗੂ ਕਰਦੇ ਹਨ ਅਤੇ ਉਹਨਾਂ initialize ਜਵਾਬਾਂ ਨੂੰ ਰੱਦ ਕਰਦੇ ਹਨ ਜੋ ਉਸ ਘੱਟੋ-ਘੱਟ ਤੋਂ ਹੇਠਲਾ ਸੰਸਕਰਣ ਪ੍ਰਸਤਾਵਿਤ ਕਰਦੇ ਹਨ।	2
10.3.5	ਤਸਦੀਕ ਕਰੋ ਕਿ MCP ਕਲਾਇੰਟ ਅਤੇ ਸਰਵਰ ਵਚਿਕਾਰਲੇ ਪਹੁੰਚ ਟੋਕਨ mTLS ਜਾਂ DPoP ਦੀ ਵਰਤੋਂ ਕਰਕੇ ਭੇਜਣ ਵਾਲੇ ਨਾਲ ਬੰਨ੍ਹੇ ਹੋਏ ¹²⁸ (sender-constrained) ਹਨ।	3

C10.4 Schema, Message, and Input Validation

C10.4 ਸਕੀਮਾ, ਸੁਨੇਹਾ, ਅਤੇ ਇਨਪੁੱਟ ਪ੍ਰਮਾਣਿਕਤਾ

Schema, message, and input validation must be enforced in both MCP servers and clients.

MCP ਸਰਵਰਾਂ ਅਤੇ ਕਲਾਇੰਟਾਂ, ਦੋਵਾਂ ਵੱਲੋਂ ਸਕੀਮਾ, ਸੁਨੇਹਾ, ਅਤੇ ਇਨਪੁੱਟ ਪ੍ਰਮਾਣਿਕਤਾ ਲਾਗੂ ਕਰਨਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
10.4.1	Verify that MCP tools/list and tools/call responses are validated against their declared schemas before being injected into the model context.	1
10.4.2	Verify that MCP tools/list and tools/call responses are screened for indirect prompt injection before being injected into the model context.	1
10.4.3	Verify that MCP servers reject unrecognized or oversized parameters in function calls.	1
10.4.4	Verify that all MCP servers enforce strict schema validation.	2

¹²⁸**sender-constrained** (EN) -> ਭੇਜਣ ਵਾਲੇ ਨਾਲ ਬੰਨ੍ਹੇ ਹੋਏ — reuses the corpus's existing verb for cryptographic binding (ਬੰਨ੍ਹਣਾ) rather than ਸੀਮਤਿ, which would suggest scope-restriction, a different control. Full discussion: OPEN-QUESTIONS.md Q91.

#	Description	Level
10.4.5	Verify that all MCP transports enforce maximum payload size limits.	2
10.4.6	Verify that MCP servers sign tool responses with a unique nonce and timestamp so MCP clients can detect replay attempts.	2
10.4.7	Verify that MCP clients present users with explicit consent dialogue and cancellation options upon installation of a local MCP server.	2
10.4.8	Verify that MCP clients maintain a snapshot of tool definitions and that any change to a tool definition triggers re-approval before the modified tool can be invoked.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
10.4.1	ਤਸਦੀਕ ਕਰੋ ਕਿ MCP tools/list ਅਤੇ tools/call ਜਵਾਬਾਂ ਨੂੰ ਮਾਡਲ ਸੰਦਰਭ ਵੱਲੋਂ ਇੰਜੈਕਟ ਕੀਤੇ ਜਾਣ ਤੋਂ ਪਹਿਲਾਂ ਉਹਨਾਂ ਦੀਆਂ ਪ੍ਰਮਾਣਿਤ ਸਕੀਮਾਵਾਂ ਦੇ ਵਰਿਥ ਪ੍ਰਮਾਣਿਤ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	1
10.4.2	ਤਸਦੀਕ ਕਰੋ ਕਿ MCP tools/list ਅਤੇ tools/call ਜਵਾਬਾਂ ਦੀ, ਮਾਡਲ ਸੰਦਰਭ ਵੱਲੋਂ ਇੰਜੈਕਟ ਕੀਤੇ ਜਾਣ ਤੋਂ ਪਹਿਲਾਂ, ਅਸਧਿੱ prompt ਇੰਜੈਕਸ਼ਨ (indirect prompt injection) ਲਈ ਛਾਣਬੀਣ ਕੀਤੀ ਜਾਂਦੀ ਹੈ।	1
10.4.3	ਤਸਦੀਕ ਕਰੋ ਕਿ MCP ਸਰਵਰ ਫ੍ਰੰਟੈਂਡ ਕਾਲਾਂ ਵੱਲੋਂ ਅਣਪਛਾਤੇ ਜਾਂ ਲੋੜੇ ਵੱਡੇ ਪੈਰਾਮੀਟਰਾਂ ਨੂੰ ਰੱਦ ਕਰਦੇ ਹਨ।	1

#	ਵੇਰਵਾ	ਪੱਧਰ
10.4.4	ਤਸਦੀਕ ਕਰੋ ਕੀ ਸਾਰੇ MCP ਸਰਵਰ ਸ਼ਖ਼ਤ ਸਕੀਮਾ ਪ੍ਰਮਾਣਿਕਤਾ ਲਾਗੂ ਕਰਦੇ ਹਨ।	2
10.4.5	ਤਸਦੀਕ ਕਰੋ ਕੀ ਸਾਰੇ MCP ਟ੍ਰਾਂਸਪੋਰਟ ਵੱਧ ਤੋਂ ਵੱਧ ਪੈਲੋਡ ਆਕਾਰ ਸੀਮਾਵਾਂ ਲਾਗੂ ਕਰਦੇ ਹਨ।	2
10.4.6	ਤਸਦੀਕ ਕਰੋ ਕੀ MCP ਸਰਵਰ ਟੂਲ ਜਵਾਬਾਂ ਉੱਤੇ ਇੱਕ ਵਲਿੱਖਣ ਨੋਨਸ (nonce) ਅਤੇ ਟਾਈਮਸਟੈਂਪ ਨਾਲ ਦਸਤਖ਼ਤ ਕਰਦੇ ਹਨ ਤਾਂ ਜੋ MCP ਕਲਾਇੰਟ replay ¹²⁹ (ਦੁਹਰਾਓ) ਕੋਸ਼ਿਸ਼ਾਂ ਦਾ ਪਤਾ ਲਗਾ ਸਕਣ।	2
10.4.7	ਤਸਦੀਕ ਕਰੋ ਕੀ MCP ਕਲਾਇੰਟ ਕਸਿ ਸਥਾਨਕ MCP ਸਰਵਰ ਦੀ ਸਥਾਪਨਾ ਵੇਲੇ ਉਪਭੋਗਤਾਵਾਂ ਸਾਹਮਣੇ ਸਪੱਸ਼ਟ ਸਹਿਮਤੀ ਸੰਵਾਦ ¹³⁰ (consent dialogue) ਅਤੇ ਰੱਦ ਕਰਨ ਦੇ ਵਕਿਲਪ ਪੇਸ਼ ਕਰਦੇ ਹਨ।	2
10.4.8	ਤਸਦੀਕ ਕਰੋ ਕੀ MCP ਕਲਾਇੰਟ ਟੂਲ ਪਰਭਿਾਸ਼ਾਵਾਂ ਦਾ ਇੱਕ ਸਨੈਪਸ਼ਾਟ ਬਰਕਰਾਰ ਰੱਖਦੇ ਹਨ, ਅਤੇ ਕਸਿ ਟੂਲ ਪਰਭਿਾਸ਼ਾ ਵੱਚਿ ਕੋਈ ਵੀ ਤਬਦੀਲੀ ਹੋਣ 'ਤੇ, ਸੋਧਿਆ ਹੋਇਆ ਟੂਲ ਸੱਦੇ ਜਾਣ ਤੋਂ ਪਹਿਲਾਂ ਮੁੜ-ਮਨਜ਼ੂਰੀ ਸ਼ੁਰੂ ਹੁੰਦੀ ਹੈ।	3

References

ਹਵਾਲੇ

- Model Context Protocol (MCP) Specification
- OWASP MCP Security Cheat Sheet
- NIST SP 800-207: Zero Trust Architecture
- OAuth 2.1 (IETF Draft)
- OWASP Top 10 for Agentic Applications 2026

¹²⁹**DNS rebinding / replay** (EN) -> DNS rebinding retained verbatim; replay retained with a ਦੁਹਰਾਓ (“repetition”) gloss — both are named attack classes kept searchable against the cited OWASP MCP Security Cheat Sheet. Full discussion: OPEN-QUESTIONS.md Q92.

¹³⁰**consent dialogue** (EN) -> ਸਪੱਸ਼ਟ ਸਹਿਮਤੀ ਸੰਵਾਦ — ਮਨਜ਼ੂਰੀ (“approval”) was deliberately avoided because 10.4.8 already locks it to re-approval, and consent and re-approval are two separate obligations in this same section. Full discussion: OPEN-QUESTIONS.md Q93.

C11 Adversarial Robustness

C11 ਵਰਿਧੀ ਮਜ਼ਬੂਤੀ¹³¹

Control Objective

ਨਿਯੰਤਰਣ ਉਦੇਸ਼

This chapter addresses keeping AI systems reliable and abuse-resistant when facing evasion, inference, extraction, or poisoning attacks.

ਇਹ ਅਧਿਆਇ evasion (ਪਛਾਣ ਤੋਂ ਬਚ ਨਕਿਲਣਾ), inference, extraction, ਜਾਂ poisoning ਹਮਲਿਆਂ ਦੇ ਸਾਹਮਣੇ AI ਸਿਸਟਮਾਂ ਨੂੰ ਭਰੋਸੇਯੋਗ ਅਤੇ ਦੁਰਵਰਤੋਂ-ਰੋਧਕ ਬਣਾਈ ਰੱਖਣ ਨੂੰ ਸੰਬੋਧਿਤ ਕਰਦਾ ਹੈ।

C11.1 Model Alignment, Safety, and Robustness Testing and Training

C11.1 ਮਾਡਲ ਅਲਾਈਨਮੈਂਟ¹³², ਸਲਾਮਤੀ, ਅਤੇ ਮਜ਼ਬੂਤੀ ਟੈਸਟਿੰਗ ਅਤੇ ਸਖਿਲਾਈ

Model resilience to manipulated inputs designed to cause misclassification or policy bypass must be increased, primarily through adversarial testing and robustness benchmarking.

ਗ਼ਲਤ ਵਰਗੀਕਰਨ ਜਾਂ ਨੀਤੀ ਬਾਈਪਾਸ ਕਰਵਾਉਣ ਲਈ ਘੜੇ ਗਏ, ਹੇਰਾਫੇਰੀ ਕੀਤੇ ਇਨਪੁੱਟਾਂ ਪ੍ਰਤੀ ਮਾਡਲ ਦੇ ਲਚਕੀਲੇਪਣ (resilience) ਨੂੰ ਵਧਾਉਣਾ ਲਾਜ਼ਮੀ ਹੈ, ਮੁੱਖ ਤੌਰ 'ਤੇ ਵਰਿਧੀ ਟੈਸਟਿੰਗ (adversarial testing) ਅਤੇ ਮਜ਼ਬੂਤੀ ਬੈਂਚਮਾਰਕਿੰਗ (robustness benchmarking) ਰਾਹੀਂ।

#	Description	Level
11.1.1	Verify that the model has undergone alignment and safety training or fine-tuning to prevent the model from generating disallowed content categories.	1
11.1.2	Verify that a version-controlled alignment test suite is run on every model update or release.	1
11.1.3	Verify that models are evaluated against known adversarial attack techniques relevant to their modality.	1
11.1.4	Verify that models are hardened against adversarial inputs.	2
11.1.5	Verify that an automated evaluator measures harmful-content rate and flags regressions beyond a defined threshold.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
11.1.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਾਡਲ ਨੇ ਅਲਾਈਨਮੈਂਟ (alignment) ਅਤੇ ਸਲਾਮਤੀ ਸਖਿਲਾਈ ਜਾਂ ਫ਼ਾਈਨ-ਟਿਊਨਿੰਗ ਕਰਵਾਈ ਹੈ ਤਾਂ ਜੋ ਮਾਡਲ ਨੂੰ ਮਨਾਹੀ ਵਾਲੀਆਂ ਸਮੱਗਰੀ ਸ਼੍ਰੇਣੀਆਂ ਤਿਆਰ ਕਰਨ ਤੋਂ ਰੋਕਿਆ ਜਾ ਸਕੇ।	1
11.1.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਹਰ ਮਾਡਲ ਅੱਪਡੇਟ ਜਾਂ ਰਲੀਜ਼ ਉੱਤੇ ਇੱਕ ਵਰਜ਼ਨ-ਨਿਯੰਤਰਤਿ ਅਲਾਈਨਮੈਂਟ ਟੈਸਟ ਸੂਟ ਚਲਾਇਆ ਜਾਂਦਾ ਹੈ।	1
11.1.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਾਡਲਾਂ ਦਾ ਉਹਨਾਂ ਦੀ ਮਾਡੈਲਿਟੀ (modality) ਨਾਲ ਸੰਬੰਧਿਤ ਜਾਣੀਆਂ-ਪਛਾਣੀਆਂ ਵਰਿਧੀ ਹਮਲਾ ਤਕਨੀਕਾਂ ਦੇ ਵਿਰੁੱਧ ਮੁਲਾਂਕਣ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	1
11.1.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਾਡਲਾਂ ਨੂੰ ਵਰਿਧੀ ਇਨਪੁੱਟਾਂ ਵਿਰੁੱਧ ਸਖ਼ਤ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	2

¹³¹ **adversarial robustness** (EN) -> ਵਰਿਧੀ ਮਜ਼ਬੂਤੀ — ਮਜ਼ਬੂਤੀ (“sturdiness”) was chosen over ਦ੍ਰੜ੍ਹਤਾ (“steadfastness/resolve”), which would anthropomorphise the model with an inner quality. Full discussion: OPEN-QUESTIONS.md Q84.

¹³² **alignment** (EN) -> ਅਲਾਈਨਮੈਂਟ — kept as a loan because every native candidate (ਇਕਸੁਰਤਾ, ਸੁਮੇਲ, ਤਾਲਮੇਲ) runs through a harmony/attunement root with devotional colour. Full discussion: OPEN-QUESTIONS.md Q56.

#	ਵੇਰਵਾ	ਪੱਧਰ
11.1.5	ਤਸਦੀਕ ਕਰੋ ਕਿ ਇੱਕ ਸਵੈਚਾਲਤ ਮੁਲਾਂਕਣਕਾਰ (evaluator) ਨੁਕਸਾਨਦੇਹ-ਸਮੱਗਰੀ ਦਰ ਨੂੰ ਮਾਪਦਾ ਹੈ ਅਤੇ ਇੱਕ ਪਰਭਾਸ਼ਤ ਥਰੈਸ਼ਹੋਲਡ ਤੋਂ ਪਰੇ ਦੇ ਰਿਗਰੈਸ਼ਨਾਂ (regressions) ਨੂੰ ਨਸ਼ਿਆਨਬੱਧ ਕਰਦਾ ਹੈ।	3

C11.2 Membership-Inference and Model-Inversion Mitigation

C11.2 Membership-Inference ਅਤੇ Model-Inversion¹³³ ਨੂੰ ਘਟਾਉਣਾ

The ability to determine whether a specific record was in the training data must be limited, and reconstruction of private training data or sensitive attributes from model outputs prevented.

ਇਹ ਪਤਾ ਲਗਾਉਣ ਦੀ ਸਮਰੱਥਾ ਕਿ ਕੋਈ ਖਾਸ ਰਕਿਅਤ ਸਖਿਲਾਈ ਡਾਟਾ ਵੱਲੋਂ ਸੀ ਜਾਂ ਨਹੀਂ, ਸੀਮਤ ਕੀਤੀ ਜਾਣੀ ਲਾਜ਼ਮੀ ਹੈ, ਅਤੇ ਮਾਡਲ ਆਉਟਪੁੱਟ¹³⁴ ਤੋਂ ਨਜ਼ੀ ਸਖਿਲਾਈ ਡਾਟਾ ਜਾਂ ਸੰਵੇਦਨਸ਼ੀਲ ਗੁਣਾਂ ਦੇ ਪੁਨਰ-ਨਿਰਮਾਣ ਨੂੰ ਰੋਕਿਆ ਜਾਣਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
11.2.1	Verify that model-inferred sensitive attributes are not directly returned in outputs.	1
11.2.2	Verify that inference endpoints enforce per-principal and global rate limits sized to the extraction threat model, and not solely as a generic API throttle.	1
11.2.3	Verify that model outputs are calibrated to reduce overconfident predictions.	2
11.2.4	Verify that training on sensitive datasets employs differentially-private optimization.	2
11.2.5	Verify that membership-inference attack simulations demonstrate that attack accuracy does not exceed random guessing on evaluated data.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
11.2.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਾਡਲ ਦੁਆਰਾ ਅਨੁਮਾਨਤ ਸੰਵੇਦਨਸ਼ੀਲ ਗੁਣ ਸਧਿ ਤੌਰ 'ਤੇ ਆਉਟਪੁੱਟ ਵੱਲੋਂ ਵਾਪਸ ਨਹੀਂ ਕੀਤੇ ਜਾਂਦੇ।	1
11.2.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਇਨਫ਼ਰੈਂਸ ¹³⁵ ਐਂਡਪੁਆਇੰਟ ਪ੍ਰਤੀ-ਪ੍ਰਿੰਸੀਪਲ ¹³⁶ (per-principal) ਅਤੇ ਸਮੁੱਚੀਆਂ ਦਰ ਸੀਮਾਵਾਂ ਲਾਗੂ ਕਰਦੇ ਹਨ ਜੋ extraction ਖ਼ਤਰਾ ਮਾਡਲ ਦੇ ਅਨੁਸਾਰ ਮਥਿਅੀਆਂ ਗਈਆਂ ਹੋਣ, ਨਾ ਕਿ ਸਰਿਫ਼ ਇੱਕ ਆਮ API ਥਰੋਟਲ (throttle) ਵਜੋਂ।	1
11.2.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਹੱਦੋਂ ਵੱਧ ਭਰੋਸੇ ਵਾਲੇ ਪੂਰਵ-ਅਨੁਮਾਨਾਂ (overconfident predictions) ਨੂੰ ਘਟਾਉਣ ਲਈ ਮਾਡਲ ਆਉਟਪੁੱਟ ਨੂੰ ਕੈਲੀਬਰੇਟ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	2
11.2.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸੰਵੇਦਨਸ਼ੀਲ ਡਾਟਾਸੈੱਟਾਂ ਉੱਤੇ ਸਖਿਲਾਈ differential privacy-ਆਧਾਰਤ ਅਨੁਕੂਲਨ (differentially-private optimization) ਵਰਤਦੀ ਹੈ।	2
11.2.5	ਤਸਦੀਕ ਕਰੋ ਕਿ membership-inference ਹਮਲੇ ਦੇ ਸਮੂਲੇਸ਼ਨ ਇਹ ਦਰਸਾਉਂਦੇ ਹਨ ਕਿ ਮੁਲਾਂਕਣ ਕੀਤੇ ਡਾਟੇ ਉੱਤੇ ਹਮਲੇ ਦੀ ਸਟੀਕਤਾ (accuracy) ਬੇਤਰਤੀਬ ਅੰਦਾਜ਼ੇ ਤੋਂ ਵੱਧ ਨਹੀਂ ਜਾਂਦੀ।	3

¹³³**model inversion** (EN) -> Model-Inversion retained verbatim — a named attack technique kept in English so it stays searchable against the cited threat-intel literature, matching the treatment given to model extraction. Full discussion: OPEN-QUESTIONS.md Q82.

¹³⁴**output** (EN) -> ਆਉਟਪੁੱਟ — kept as a loan to mirror the ASVS corpus's ਇਨਪੁੱਟ/ਆਉਟਪੁੱਟ pairing rather than ਨਤੀਜਾ ("result"). Full discussion: OPEN-QUESTIONS.md Q78.

¹³⁵**inference** (EN) -> ਇਨਫ਼ਰੈਂਸ — kept as a loan because the native ਅਨੁਮਾਨ is already load-bearing elsewhere for “expected/anticipated,” which would read as an estimate rather than model execution. Full discussion: OPEN-QUESTIONS.md Q18.

¹³⁶**principal** (per-principal) (EN) -> ਪ੍ਰਿੰਸੀਪਲ — an open corpus split: this loan form is used here while C09 9.4.1 uses the coined ਪਛਾਣ-ਇਕਾਈ for the identical concept; both should move together. Full discussion: OPEN-QUESTIONS.md Q124.

C11.3 Model-Extraction Defense

C11.3 Model-Extraction¹³⁷ ਵਰਿੱਧ ਬਚਾਅ

Unauthorized model cloning through API abuse must be detected and deterred using rate limiting, query-pattern analysis, and watermarking.

API ਦੀ ਦੁਰਵਰਤੋਂ ਰਾਹੀਂ ਅਣਅਧਿਕਾਰਤ ਮਾਡਲ ਕਲੋਨਿੰਗ (cloning) ਦਾ ਦਰ ਸੀਮਾ, ਕਊਰੀ-ਪੈਟਰਨ ਵਸ਼ਿਲੇਸ਼ਣ, ਅਤੇ ਵਾਟਰਮਾਰਕਿੰਗ ਦੀ ਵਰਤੋਂ ਕਰਕੇ ਪਤਾ ਲਗਾਇਆ ਜਾਣਾ ਅਤੇ ਉਸ ਨੂੰ ਰੋਕਿਆ ਜਾਣਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
11.3.1	Verify that query-pattern analysis feeds an extraction-attempt detector.	1
11.3.2	Verify that raw model outputs are not directly exposed beyond the application backend, and that externally visible responses are calibrated to the extraction risk level.	2
11.3.3	Verify that model watermarking or fingerprinting techniques are applied so that unauthorized copies can be identified.	3
11.3.4	Verify that detection of suspected extraction triggers response measures.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
11.3.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਕਊਰੀ-ਪੈਟਰਨ ਵਸ਼ਿਲੇਸ਼ਣ ਇੱਕ extraction-ਕੋਸ਼ਿਸ਼ ਡਟੈਕਟਰ (detector) ਨੂੰ ਇਨਪੁੱਟ ਦਿੰਦਾ ਹੈ।	1
11.3.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਕੱਚੇ ਮਾਡਲ ਆਉਟਪੁੱਟ ਐਪਲੀਕੇਸ਼ਨ ਬੈਕਐਂਡ ਤੋਂ ਪਰੇ ਸਥਿਤ ਤੌਰ 'ਤੇ ਜਾਹਰ ਨਹੀਂ ਕੀਤੇ ਜਾਂਦੇ, ਅਤੇ ਇਹ ਕੰਬਾਹਰੋਂ ਦਖਿਅਤੀ ਦੇਣ ਵਾਲੇ ਜਵਾਬ extraction ਜੋਖਮ ਪੱਧਰ ਦੇ ਅਨੁਸਾਰ ਕੈਲੀਬਰੇਟ ਕੀਤੇ ਜਾਂਦੇ ਹਨ।	2
11.3.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਾਡਲ ਵਾਟਰਮਾਰਕਿੰਗ ਜਾਂ ਫ੍ਰਿੰਗਰਪ੍ਰਿੰਟਿੰਗ ਤਕਨੀਕਾਂ ਲਾਗੂ ਕੀਤੀਆਂ ਜਾਂਦੀਆਂ ਹਨ ਤਾਂ ਜੋ ਅਣਅਧਿਕਾਰਤ ਨਕਲਾਂ ਦੀ ਪਛਾਣ ਕੀਤੀ ਜਾ ਸਕੇ।	3
11.3.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸ਼ੱਕੀ extraction ਦੀ ਪਛਾਣ ਜਵਾਬੀ ਉਪਾਵਾਂ ਨੂੰ ਸ਼ੁਰੂ ਕਰਦੀ ਹੈ।	3

C11.4 Model Runtime Anomaly Detection

C11.4 ਮਾਡਲ ਰਨਟਾਈਮ ਅਸਧਾਰਨਤਾ ਪਛਾਣ

Manipulated, backdoored, or adversarial data entering the model context at inference time via external sources must be identified and neutralized.

ਇਨਫਰੈਂਸ ਵੇਲੇ ਬਾਹਰੀ ਸਰੋਤਾਂ ਰਾਹੀਂ ਮਾਡਲ ਸੰਦਰਭ ਵਿੱਚ ਦਾਖਲ ਹੋਣ ਵਾਲੇ ਹੇਰਾਫੇਰੀ ਕੀਤੇ, ਬੈਕਡੋਰ ਵਾਲੇ, ਜਾਂ ਵਰਿਧੀ ਡਾਟੇ ਦੀ ਪਛਾਣ ਕਰਨਾ ਅਤੇ ਉਸ ਨੂੰ ਬੇਅਸਰ ਕਰਨਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
11.4.1	Verify that inputs from external or untrusted sources pass through anomaly detection before model inference.	2
11.4.2	Verify that inputs flagged as anomalous trigger gating actions.	2
11.4.3	Verify that the safety violation feedback pipeline includes poisoning detection and human review gates to prevent adversarial manipulation of the improvement mechanism.	3

¹³⁷ **model extraction** (EN) -> Model-Extraction retained verbatim — the technique name stays English while ਚੋਰੀ (“theft”) is reserved elsewhere for the harm/outcome sense, a boundary this chapter must not blur. Full discussion: OPEN-QUESTIONS.md Q54.

#	ਵੇਰਵਾ	ਪੱਧਰ
11.4.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਬਾਹਰੀ ਜਾਂ ਗੈਰ-ਭਰੋਸੇਯੋਗ ਸਰੋਤਾਂ ਤੋਂ ਆਏ ਇਨਪੁੱਟ ਮਾਡਲ ਇਨਫ਼ਰੈਂਸ ਤੋਂ ਪਹਿਲਾਂ ਅਸਧਾਰਨਤਾ ਪਛਾਣ (anomaly detection) ਵੱਲੋਂ ਲੰਘਦੇ ਹਨ।	2
11.4.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਅਸਧਾਰਨ ਵਜੋਂ ਨਿਸ਼ਾਨਬੱਧ ਕੀਤੇ ਇਨਪੁੱਟ ਗੇਟਿੰਗ ਕਾਰਵਾਈਆਂ (gating actions) ਸ਼ੁਰੂ ਕਰਦੇ ਹਨ।	2
11.4.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਲਾਮਤੀ ਉਲੰਘਣਾ ਫ਼ੀਡਬੈਕ ਪਾਈਪਲਾਈਨ ਵੱਲੋਂ poisoning ¹³⁸ ਪਛਾਣ ਅਤੇ ਮਨੁੱਖੀ ਸਮੀਖਿਆ ਗੇਟ ਸ਼ਾਮਲ ਹਨ ਤਾਂ ਜੋ ਸੁਧਾਰ ਵਧੀ ਨਾਲ ਵਰਿਫੀ ਹੋਰਾਫੇਰੀ ਨੂੰ ਰੋਕਿਆ ਜਾ ਸਕੇ।	3

References

ਹਵਾਲੇ

- NIST AI 100-2e2023 Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations
- OWASP LLM04:2025 Data and Model Poisoning
- MITRE ATLAS: Evade ML Model (AML.T0015)
- MITRE ATLAS: Backdoor ML Model
- MITRE ATLAS: Extract ML Model

¹³⁸**poisoning** (detection) (EN) -> retained as poisoning, hybridised as poisoning ਪਛਾਣ — kept in English after the corpus's first gloss so the term stays traceable to MITRE ATLAS AML.T0020. Full discussion: OPEN-QUESTIONS.md Q39.

C12 Monitoring, Logging & Anomaly Detection

C12 ਨਗਿਰਾਨੀ, ਲੌਗਿੰਗ ਅਤੇ ਅਸਧਾਰਨਤਾ ਪਛਾਣ

Control Objective

ਨਿਯੰਤਰਣ ਉਦੇਸ਼

This chapter addresses real-time and forensic visibility into what the model and other AI components see, do, and return, so that AI-specific threats can be detected and triaged.

ਇਹ ਅਧਿਆਇ ਇਸ ਗੱਲ ਵੱਲ ਰੀਅਲ-ਟਾਈਮ ਅਤੇ ਫੋਰੈਂਸਿਕ ਦੱਖਿ ਨੂੰ ਸੰਬੰਧਿਤ ਕਰਦਾ ਹੈ ਕਿ ਮਾਡਲ ਅਤੇ ਹੋਰ AI ਹੱਸਿ¹³⁹ ਕੀ ਦੇਖਦੇ ਹਨ, ਕੀ ਕਰਦੇ ਹਨ, ਅਤੇ ਕੀ ਵਾਪਸ ਦਿੰਦੇ ਹਨ, ਤਾਂ ਜੋ AI-ਵੱਸ਼ਿਸ਼ ਖ਼ਤਰਿਆਂ ਦਾ ਪਤਾ ਲਗਾਇਆ ਜਾ ਸਕੇ ਅਤੇ ਉਹਨਾਂ ਨੂੰ ਤਰਜੀਹ-ਕ੍ਰਮ (triage) ਦਿੱਤਾ ਜਾ ਸਕੇ।

C12.1 Request & Response Logging

C12.1 ਬੇਨਤੀ ਅਤੇ ਜਵਾਬ ਲੌਗਿੰਗ

AI requests and responses must be logged to create an audit trail and support incident response.

AI ਬੇਨਤੀਆਂ ਅਤੇ ਜਵਾਬਾਂ ਦਾ ਲੌਗ ਕੀਤਾ ਜਾਣਾ ਲਾਜ਼ਮੀ ਹੈ ਤਾਂ ਜੋ ਇੱਕ ਆਡਿਟ ਟ੍ਰੇਲ (audit trail) ਬਣਾਈ ਜਾ ਸਕੇ ਅਤੇ ਘਟਨਾ ਜਵਾਬ (incident response) ਦਾ ਸਮਰਥਨ ਕੀਤਾ ਜਾ ਸਕੇ।

#	Description	Level
12.1.1	Verify that AI interactions are logged with session context and AI-specific telemetry.	1
12.1.2	Verify that safety filtering and policy decisions are logged with sufficient detail to support audit, debugging, and forensic analysis of content moderation systems.	2
12.1.3	Verify that log entries for AI inference events follow a structured, interoperable schema that includes at least the model identifier, token usage (input and output), provider name, and operation type.	2
12.1.4	Verify that RAG pipeline retrieval events are logged, including the query, documents retrieved, and knowledge source.	2

#	ਵੇਰਵਾ	ਪੱਧਰ
12.1.1	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਪਰਸਪਰ-ਕਰਿਆਵਾਂ ਨੂੰ ਸੈਸ਼ਨ ਸੰਦਰਭ ਅਤੇ AI-ਵੱਸ਼ਿਸ਼ ਟੈਲੀਮੈਟਰੀ ਸਮੇਤ ਲੌਗ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	1
12.1.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਲਾਮਤੀ ਫ਼ਲਿਟਰਿੰਗ ਅਤੇ ਨੀਤੀ ਫ਼ੈਸਲਿਆਂ ਨੂੰ ਇੰਨੇ ਵੇਰਵੇ ਨਾਲ ਲੌਗ ਕੀਤਾ ਜਾਂਦਾ ਹੈ ਕਿ ਸਮੱਗਰੀ ਮਾਡਰੇਸ਼ਨ (content moderation) ਸਿਸਟਮਾਂ ਦੇ ਆਡਿਟ, ਡੀਬੱਗਿੰਗ, ਅਤੇ ਫੋਰੈਂਸਿਕ ਵਿਸ਼ਲੇਸ਼ਣ ਦਾ ਸਮਰਥਨ ਕੀਤਾ ਜਾ ਸਕੇ।	2
12.1.3	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਇਨਫ਼ਰੈਂਸ ਘਟਨਾਵਾਂ ਲਈ ਲੌਗ ਐਂਟਰੀਆਂ ਇੱਕ ਢਾਂਚਾਗਤ, ਅੰਤਰ-ਕਾਰਜਸ਼ੀਲ ਸਕੀਮਾ ਦੀ ਪਾਲਣਾ ਕਰਦੀਆਂ ਹਨ ਜਿਸ ਵਿੱਚ ਟੋਕਨ-ਘੱਟ ਮਾਡਲ ਪਛਾਣਕਰਤਾ, ਟੋਕਨ ਵਰਤੋਂ (ਇਨਪੁਟ ਅਤੇ ਆਊਟਪੁਟ), ਪ੍ਰਦਾਤਾ ਦਾ ਨਾਮ, ਅਤੇ ਸੰਚਾਲਨ ਕਸਿਮ ਸ਼ਾਮਲ ਹਨ।	2
12.1.4	ਤਸਦੀਕ ਕਰੋ ਕਿ RAG ਪਾਈਪਲਾਈਨ ਦੀਆਂ ਪ੍ਰਾਪਤੀ ਘਟਨਾਵਾਂ ਨੂੰ ਲੌਗ ਕੀਤਾ ਜਾਂਦਾ ਹੈ, ਜਿਸ ਵਿੱਚ ਕਵਿਰੀ (query), ਪ੍ਰਾਪਤ ਕੀਤੇ ਦਸਤਾਵੇਜ਼, ਅਤੇ ਗਿਆਨ ਸਰੋਤ ਸ਼ਾਮਲ ਹਨ।	2

¹³⁹ **component** (EN) -> ਹੱਸਿ — logged as an open corpus split: C12 uses the native ਹੱਸਿ here while C09/C10 use the loan ਕੰਪੋਨੈਂਟ for the identical term-of-art sense. Full discussion: OPEN-QUESTIONS.md Q95.

C12.2 Detection and Alerting

C12.2 ਪਛਾਣ ਅਤੇ ਚੇਤਾਵਨੀ

AI-specific attack patterns (jailbreak, prompt injection, model extraction, multi-turn trajectory attacks, covert channels over LLM endpoints) must be detected, and security events enriched with AI-specific context so downstream detection and response systems can act on them.

AI-ਵਸ਼ਿਸ਼ਟ ਹਮਲਾ ਪੈਟਰਨਾਂ (jailbreak, prompt ਇੰਜੈਕਸ਼ਨ, model extraction, ਬਹੁ-ਵਾਰੀ trajectory ਹਮਲੇ, LLM ਐਂਡਪੁਆਇੰਟਾਂ ਉੱਤੇ ਲੁਕਵੇਂ ਚੈਨਲ¹⁴⁰) ਦਾ ਪਤਾ ਲਗਾਇਆ ਜਾਣਾ ਲਾਜ਼ਮੀ ਹੈ, ਅਤੇ ਸੁਰੱਖਿਆ ਘਟਨਾਵਾਂ ਨੂੰ AI-ਵਸ਼ਿਸ਼ਟ ਸੰਦਰਭ ਨਾਲ ਸੰਪੰਨ ਕੀਤਾ ਜਾਣਾ ਲਾਜ਼ਮੀ ਹੈ ਤਾਂ ਜੋ ਡਾਊਨਸਟ੍ਰੀਮ ਪਛਾਣ ਅਤੇ ਜਵਾਬ ਸਿਸਟਮ ਉਹਨਾਂ ਉੱਤੇ ਕਾਰਵਾਈ ਕਰ ਸਕਣ।

#	Description	Level
12.2.1	Verify that the system detects and alerts on known jailbreak patterns, prompt injection attempts, and adversarial inputs.	1
12.2.2	Verify that behavioral anomaly detection identifies unusual conversation patterns, excessive retry attempts, or probing behaviors.	2
12.2.3	Verify that custom rules detect AI-specific threat patterns for coordinated jailbreak attempts, prompt injection, and system prompt extraction attempts.	2
12.2.4	Verify that extraction-alert events include offending query metadata to support investigation.	2
12.2.5	Verify that token usage is tracked at granular attribution levels including per user, per session, per feature endpoint, and per team or workspace.	2
12.2.6	Verify that LLM API traffic is monitored for covert-channel indicators and communication signatures to identify malware and command-and-control (C2) activity.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
12.2.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਿਸਟਮ ਜਾਣੇ-ਪਛਾਣੇ jailbreak ਪੈਟਰਨਾਂ, prompt ਇੰਜੈਕਸ਼ਨ ਦੀਆਂ ਕੋਸ਼ਿਸ਼ਾਂ, ਅਤੇ ਵਰਿਧੀ ਇਨਪੁਟਾਂ ਦਾ ਪਤਾ ਲਗਾਉਂਦਾ ਹੈ ਅਤੇ ਉਹਨਾਂ ਬਾਰੇ ਚੇਤਾਵਨੀ ਦਿੰਦਾ ਹੈ।	1
12.2.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਵਿਵਹਾਰਕ ਅਸਧਾਰਨਤਾ ਪਛਾਣ (anomaly detection) ਅਸਧਾਰਨ ਗੱਲਬਾਤ ਪੈਟਰਨਾਂ, ਹੱਦੋਂ ਵੱਧ ਮੁੜ-ਕੋਸ਼ਿਸ਼ਾਂ, ਜਾਂ ਟੋਹ ਲੈਣ ਵਾਲੇ ਵਿਵਹਾਰਾਂ ਦੀ ਪਛਾਣ ਕਰਦੀ ਹੈ।	2
12.2.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਕਸਟਮ ਨਿਯਮ ਤਾਲਮੇਲ ਵਾਲੀਆਂ jailbreak ਕੋਸ਼ਿਸ਼ਾਂ, prompt ਇੰਜੈਕਸ਼ਨ, ਅਤੇ system prompt ਕੱਢਣ (extraction) ਦੀਆਂ ਕੋਸ਼ਿਸ਼ਾਂ ਲਈ AI-ਵਸ਼ਿਸ਼ਟ ਖ਼ਤਰਾ ਪੈਟਰਨਾਂ ਦਾ ਪਤਾ ਲਗਾਉਂਦੇ ਹਨ।	2
12.2.4	ਤਸਦੀਕ ਕਰੋ ਕਿ extraction (ਕੱਢਣ) ਦੀਆਂ ਚੇਤਾਵਨੀ ਘਟਨਾਵਾਂ ਵਿੱਚ ਤਫ਼ਤੀਸ਼ ਦਾ ਸਮਰਥਨ ਕਰਨ ਲਈ ਦੇਸ਼ੀ ਕਠਿੂਰੀ ਦਾ ਸੇਟਾਡਾਟਾ ਸ਼ਾਮਲ ਹੁੰਦਾ ਹੈ।	2
12.2.5	ਤਸਦੀਕ ਕਰੋ ਕਿ ਟੋਕਨ ਵਰਤੋਂ ਨੂੰ ਬਾਰੀਕ ਨਰਿਧਾਰਨ ਪੱਧਰਾਂ (attribution levels) ਉੱਤੇ ਟਰੈਕ ਕੀਤਾ ਜਾਂਦਾ ਹੈ, ਜਿਸ ਵਿੱਚ ਪ੍ਰਤੀ ਉਪਭੋਗਤਾ, ਪ੍ਰਤੀ ਸੈਸ਼ਨ, ਪ੍ਰਤੀ ਫ਼ੀਚਰ ਐਂਡਪੁਆਇੰਟ, ਅਤੇ ਪ੍ਰਤੀ ਟੀਮ ਜਾਂ ਵਰਕਸਪੇਸ ਸ਼ਾਮਲ ਹਨ।	2
12.2.6	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮਾਲਵੇਅਰ ਅਤੇ command-and-control (C2) ਗਤੀਵਿਧੀ ਦੀ ਪਛਾਣ ਕਰਨ ਲਈ LLM API ਟ੍ਰੈਫ਼ਿਕ ਦੀ ਲੁਕਵੇਂ-ਚੈਨਲ ਸੰਕੇਤਾਂ ਅਤੇ ਸੰਚਾਰ ਸਹਿਨੇਚਰਾਂ (signatures) ਲਈ ਨਰਿਗਰਾਨੀ ਕੀਤੀ ਜਾਂਦੀ ਹੈ।	3

¹⁴⁰ **covert channel** (EN) -> ਲੁਕਵੇਂ ਚੈਨਲ — ਗੁਪਤ (“confidential”) was deliberately avoided because it is already locked elsewhere for confidential computing, and reusing it here would merge the protective and adversarial senses of one adjective. Full discussion: OPEN-QUESTIONS.md Q128.

C12.3 Model, Data, and Performance Drift Detection

C12.3 ਮਾਡਲ, ਡਾਟਾ, ਅਤੇ ਕਾਰਗੁਜ਼ਾਰੀ ਡਰਿਫਟ ਪਛਾਣ

Drift and degradation across model outputs, input distributions, and data schemas must be monitored to identify quality regressions and security-relevant behavioral shifts.

ਗੁਣਵੱਤਾ ਦੇ ਰਗਿਰੈਸ਼ਨਾਂ (regressions) ਅਤੇ ਸੁਰੱਖਿਆ-ਸੰਬੰਧਤ ਵਿਵਹਾਰਕ ਤਬਦੀਲੀਆਂ ਦੀ ਪਛਾਣ ਕਰਨ ਲਈ ਮਾਡਲ ਆਊਟਪੁੱਟ, ਇਨਪੁੱਟ ਵੰਡਾਂ, ਅਤੇ ਡਾਟਾ ਸਕੀਮਾਂ ਵਿੱਚ ਡਰਿਫਟ (drift) ਅਤੇ ਨਿਪਿਰ ਦੀ ਨਿਗਰਾਨੀ ਕੀਤੀ ਜਾਣੀ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
12.3.1	Verify that data drift detection monitors input distribution changes that may impact model performance, using statistically validated methods matched to the input data type (e.g., KS test or PSI for tabular numeric features, embedding-distance metrics for text or image).	1
12.3.2	Verify that hallucination detection monitors identify and flag model outputs that contain factually incorrect, inconsistent, or fabricated information.	2
12.3.3	Verify that hallucination rates are tracked as continuous time-series metrics to enable trend analysis and detection of sustained model degradation.	2
12.3.4	Verify that unexplained behavioral shifts are distinguished from gradual, expected operational drift.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
12.3.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਡਾਟਾ ਡਰਿਫਟ ਪਛਾਣ ਇਨਪੁੱਟ ਵੰਡ ਵਿੱਚ ਹੋਣ ਵਾਲੀਆਂ ਉਹਨਾਂ ਤਬਦੀਲੀਆਂ ਦੀ ਨਿਗਰਾਨੀ ਕਰਦੀ ਹੈ ਜੋ ਮਾਡਲ ਦੀ ਕਾਰਗੁਜ਼ਾਰੀ ਨੂੰ ਪ੍ਰਭਾਵਤਿ ਕਰ ਸਕਦੀਆਂ ਹਨ, ਅਤੇ ਇਸ ਲਈ ਇਨਪੁੱਟ ਡਾਟਾ ਦੀ ਕਸਿਮ ਨਾਲ ਮੇਲ ਖਾਂਦੀਆਂ ਅੰਕੜਾ-ਪੱਖੋਂ ਪ੍ਰਮਾਣਤਿ ਵਧੀਆਂ ਵਰਤਦੀ ਹੈ (ਜਵਿ, ਸਾਰਣੀਬੱਧ ਸੰਖਿਆਤਮਕ ਫੀਚਰਾਂ ਲਈ KS test ਜਾਂ PSI, ਟੈਕਸਟ ਜਾਂ ਚਿੱਤਰ ਲਈ embedding-ਦੂਰੀ ਮੈਟ੍ਰਿਕ)।	1
12.3.2	ਤਸਦੀਕ ਕਰੋ ਕਿ hallucination ¹⁴¹ ਪਛਾਣ ਨਿਗਰਾਨ ਉਹਨਾਂ ਮਾਡਲ ਆਊਟਪੁੱਟਾਂ ਦੀ ਪਛਾਣ ਕਰਦੇ ਹਨ ਅਤੇ ਉਹਨਾਂ ਨੂੰ ਨਸ਼ਿਨਬੱਧ ਕਰਦੇ ਹਨ ਜਨਿਹਾਂ ਵਿੱਚ ਤੱਥਾਂ ਪੱਖੋਂ ਗ਼ਲਤ, ਅਸੰਗਤ, ਜਾਂ ਮਨਘੜਤ ਜਾਣਕਾਰੀ ਹੁੰਦੀ ਹੈ।	2
12.3.3	ਤਸਦੀਕ ਕਰੋ ਕਿ hallucination ਦਰਾਂ ਨੂੰ ਲਗਾਤਾਰ ਸਮਾਂ-ਲੜੀ ਮੈਟ੍ਰਿਕਾਂ ਵਜੋਂ ਟਰੈਕ ਕੀਤਾ ਜਾਂਦਾ ਹੈ ਤਾਂ ਜੋ ਰੁਝਾਨ ਵਿਸ਼ਲੇਸ਼ਣ ਅਤੇ ਲਗਾਤਾਰ ਬਣੇ ਰਹਿਣ ਵਾਲੇ ਮਾਡਲ ਨਿਪਿਰ ਦੀ ਪਛਾਣ ਸੰਭਵ ਹੋ ਸਕੇ।	2
12.3.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਅਣ-ਵਿਆਖਿਆਤ ਵਿਵਹਾਰਕ ਤਬਦੀਲੀਆਂ ਨੂੰ ਹੌਲੀ-ਹੌਲੀ ਹੋਣ ਵਾਲੇ, ਅਨੁਮਾਨਤਿ ਸੰਚਾਲਨ ਡਰਿਫਟ ਤੋਂ ਵੱਖਰਾ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	3

C12.4 Proactive Security Behavior Monitoring

C12.4 ਪੂਰਵ-ਸਰਗਰਮ ਸੁਰੱਖਿਆ ਵਿਵਹਾਰ ਨਿਗਰਾਨੀ

Security threats arising from proactive (agent-initiated) behavior must be detected and prevented, including pre-execution validation, behavior pattern analysis, and audit trails for approval of security-critical actions.

ਪੂਰਵ-ਸਰਗਰਮ (proactive — ਭਾਵ ਏਜੰਟ ਵੱਲੋਂ ਸ਼ੁਰੂ ਕੀਤੇ) ਵਿਵਹਾਰ ਤੋਂ ਪੈਦਾ ਹੋਣ ਵਾਲੇ ਸੁਰੱਖਿਆ ਖ਼ਤਰਿਆਂ ਦਾ ਪਤਾ ਲਗਾਇਆ ਅਤੇ ਉਹਨਾਂ ਨੂੰ ਰੋਕਿਆ ਜਾਣਾ ਲਾਜ਼ਮੀ ਹੈ, ਜਿਸ ਵਿੱਚ ਐਗਜ਼ੀਕਿਊਸ਼ਨ-ਪੂਰਵ ਪ੍ਰਮਾਣਕਿਤਾ, ਵਿਵਹਾਰ ਪੈਟਰਨ ਵਿਸ਼ਲੇਸ਼ਣ, ਅਤੇ ਸੁਰੱਖਿਆ-ਨਾਜ਼ਕ ਕਾਰਵਾਈਆਂ ਦੀ ਮਨਜ਼ੂਰੀ ਲਈ ਆਡਿਟ ਟ੍ਰੇਲ ਸ਼ਾਮਲ ਹਨ।

¹⁴¹hallucination (EN) -> retained in Latin script, glossed ਮਨਘੜਤ ਸਮੱਗਰੀ ("fabricated content") — the native candidates (ਭਰਮ, ਭੁਲੇਖਾ, ਵਹਿਮ) all carry Gurbani-specific spiritual weight and were rejected on Gurmat-safety grounds. Full discussion: OPEN-QUESTIONS.md Q65.

#	Description	Level
12.4.1	Verify that autonomous action triggers include proactive behavior-pattern analysis, security evaluation, and threat-landscape assessment.	2
12.4.2	Verify that audit logs capture security-critical proactive actions, including approver identity, timestamp, action parameters, and decision outcomes.	2
12.4.3	Verify that kill-switch activations and override commands are logged.	2

#	ਵੇਰਵਾ	ਪੱਧਰ
12.4.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਖੁਦਮੁਖਤਾਰ ਕਾਰਵਾਈ ਦੇ ਟ੍ਰਿਗਰਾਂ ਵਿੱਚ ਪੂਰਵ-ਸਰਗਰਮ ਵਿਵਹਾਰ-ਪੈਟਰਨ ਵਸ਼ਿਲੇਸ਼ਣ, ਸੁਰੱਖਿਆ ਮੁਲਾਂਕਣ, ਅਤੇ ਖ਼ਤਰਾ-ਪਰਦ੍ਰਿਸ਼ ਮੁਲਾਂਕਣ ਸ਼ਾਮਲ ਹਨ।	2
12.4.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਆਡਿਟ ਲੌਗ ਸੁਰੱਖਿਆ-ਨਾਜ਼ੁਕ ਪੂਰਵ-ਸਰਗਰਮ ਕਾਰਵਾਈਆਂ ਨੂੰ ਦਰਜ ਕਰਦੇ ਹਨ, ਜਿਸ ਵਿੱਚ ਮਨਜ਼ੂਰੀ ਦੇਣ ਵਾਲੇ ਦੀ ਪਛਾਣ, ਟਾਈਮਸਟੈਂਪ, ਕਾਰਵਾਈ ਦੇ ਪੈਰਾਮੀਟਰ, ਅਤੇ ਫ਼ੈਸਲੇ ਦੇ ਨਤੀਜੇ ਸ਼ਾਮਲ ਹਨ।	2
12.4.3	ਤਸਦੀਕ ਕਰੋ ਕਿ kill-switch (ਤੁਰੰਤ-ਬੰਦ ਸਵਿੱਚ) ਦੀਆਂ ਸਰਗਰਮੀਆਂ ਅਤੇ ਓਵਰਰਾਈਡ ਕਮਾਂਡਾਂ ਨੂੰ ਲੌਗ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	2

C12.5 Training Data & Model Lifecycle Audit

C12.5 ਸਖਿਲਾਈ ਡਾਟਾ ਅਤੇ ਮਾਡਲ ਜੀਵਨ-ਚੱਕਰ ਆਡਿਟ

The provenance and change history of training data, model artifacts, and knowledge sources must be auditable throughout the AI development lifecycle.

ਸਖਿਲਾਈ ਡਾਟਾ, ਮਾਡਲ ਆਰਟੀਫੈਕਟਾਂ, ਅਤੇ ਗਿਆਨ ਸਰੋਤਾਂ ਦੇ ਮੂਲ-ਸਰੋਤ (provenance) ਅਤੇ ਤਬਦੀਲੀ ਇਤਹਾਸ ਦਾ AI ਵਿਕਾਸ ਜੀਵਨ-ਚੱਕਰ ਦੌਰਾਨ ਆਡਿਟਯੋਗ ਹੋਣਾ ਲਾਜ਼ਮੀ ਹੈ।

#	Description	Level
12.5.1	Verify that dataset lineage records each dataset and its components, including all transformations, augmentations, and merges.	1
12.5.2	Verify that all labeling activities are recorded in logs.	1
12.5.3	Verify that all model changes generate immutable audit records.	2
12.5.4	Verify that every ingested document is tagged at write time with source, writer identity, and timestamp.	2

#	ਵੇਰਵਾ	ਪੱਧਰ
12.5.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਡਾਟਾਸੈੱਟ ਵੰਸ਼ਾਵਲੀ (lineage) ਹਰ ਡਾਟਾਸੈੱਟ ਅਤੇ ਉਸ ਦੇ ਹਿੱਸਿਆਂ ਨੂੰ ਦਰਜ ਕਰਦੀ ਹੈ, ਜਿਸ ਵਿੱਚ ਸਾਰੇ ਪਰਵਰਤਨ, ਅੱਗਮੈਂਟੇਸ਼ਨ (augmentations), ਅਤੇ ਮਰਜ਼ ਸ਼ਾਮਲ ਹਨ।	1
12.5.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਾਰੀਆਂ ਲੇਬਲਿੰਗ ਗਤੀਵਿਧੀਆਂ ਲੌਗਾਂ ਵਿੱਚ ਦਰਜ ਕੀਤੀਆਂ ਜਾਂਦੀਆਂ ਹਨ।	1
12.5.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਾਰੀਆਂ ਮਾਡਲ ਤਬਦੀਲੀਆਂ ਅਪਰਵਰਤਨਸ਼ੀਲ ¹⁴² (immutable) ਆਡਿਟ ਰਕਾਰਡ ਪੈਦਾ ਕਰਦੀਆਂ ਹਨ।	2
12.5.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਹਰ ਦਾਖ਼ਲ ਕੀਤੇ ਦਸਤਾਵੇਜ਼ ਨੂੰ ਲਿਖਣ ਦੇ ਸਮੇਂ ਸਰੋਤ, ਲਿਖਣ ਵਾਲੇ ਦੀ ਪਛਾਣ, ਅਤੇ ਟਾਈਮਸਟੈਂਪ ਨਾਲ ਟੈਗ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	2

¹⁴²immutable (EN) -> ਅਪਰਵਰਤਨਸ਼ੀਲ — this requirement (12.5.3) is the corpus's cited precedent for the adjective form, later reused to correct a paraphrase found elsewhere in the corpus. Full discussion: OPEN-QUESTIONS.md Q112.

References

ਹਵਾਲੇ

- OWASP Top 10 for LLM Applications 2025
- MITRE ATLAS - Adversarial Threat Landscape for AI Systems
- NIST AI Risk Management Framework (AI RMF 1.0)
- OWASP Agentic AI Threats and Mitigations
- Microsoft Agent Governance Toolkit
- NIST SP 800-207 Zero Trust Architecture

Appendix A: Glossary

ਅੰਤਰਿਕਾ¹⁴³ A: ਸ਼ਬਦਾਵਲੀ

This glossary defines key AI, ML, and security terms used throughout the AISVS to ensure clarity and common understanding.

ਇਹ ਸ਼ਬਦਾਵਲੀ AISVS ਵਿੱਚ ਵਰਤੇ ਗਏ ਮੁੱਖ AI, ML, ਅਤੇ ਸੁਰੱਖਿਆ ਸ਼ਬਦਾਂ ਨੂੰ ਪਰਭਾਸ਼ਿਤ ਕਰਦੀ ਹੈ ਤਾਂ ਜੋ ਸਪੱਸ਼ਟਤਾ ਅਤੇ ਸਾਂਝੀ ਸਮਝ ਯਕੀਨੀ ਬਣਾਈ ਜਾ ਸਕੇ।

- **Adapter** – A lightweight module (e.g., LoRA, QLoRA) added to a pre-trained model to specialize its behavior on a specific task without modifying the original weights.
- **ਅਡੈਪਟਰ (Adapter)** – ਇੱਕ ਹਲਕਾ ਮਾਡਲਿੰਗ (ਜਵਿੰ, LoRA, QLoRA) ਜੋ ਕਸਿ ਪਹਲਿ-ਸਖਿਲਾਈ-ਪ੍ਰਾਪਤ ਮਾਡਲ ਵਿੱਚ ਜੋੜਿਆ ਜਾਂਦਾ ਹੈ ਤਾਂ ਜੋ ਮੂਲ ਵੇਟਸ (weights) ਨੂੰ ਸੋਧੇ ਬਨਿੰ ਕਸਿ ਖ਼ਾਸ ਕਾਰਜ ਲਈ ਉਸ ਦੇ ਵਿਹਾਰ ਨੂੰ ਵਸ਼ਿਸ਼ ਬਣਾਇਆ ਜਾ ਸਕੇ।
- **Adversarial Example** – An input deliberately crafted to cause an AI model to make a mistake, often by adding subtle perturbations imperceptible to humans.
- **ਵਰਿਧੀ ਉਦਾਹਰਨ (Adversarial Example)** – ਇੱਕ ਅਜਹਿ ਇਨਪੁੱਟ ਜੋ ਜਾਣ-ਬੁੱਝ ਕੇ ਇਸ ਢੰਗ ਨਾਲ ਘੜਿਆ ਗਿਆ ਹੋਵੇ ਕਿ AI ਮਾਡਲ ਗਲਤੀ ਕਰੇ, ਅਕਸਰ ਅਜਹਿ ਸੂਖਮ ਵਿਗਾੜ (perturbations) ਜੋੜ ਕੇ ਜੋ ਮਨੁੱਖਾਂ ਨੂੰ ਮਹਸੂਸ ਹੀ ਨਹੀਂ ਹੁੰਦੇ।
- **Adversarial Robustness** – A model's ability to maintain its performance and resist being fooled or manipulated by intentionally crafted, malicious inputs designed to cause errors.
- **ਵਰਿਧੀ ਮਜ਼ਬੂਤੀ (Adversarial Robustness)** – ਮਾਡਲ ਦੀ ਉਹ ਸਮਰੱਥਾ ਜਸਿ ਨਾਲ ਉਹ ਆਪਣੀ ਕਾਰਗੁਜ਼ਾਰੀ ਬਰਕਰਾਰ ਰੱਖਦਾ ਹੈ ਅਤੇ ਗਲਤੀਆਂ ਕਰਵਾਉਣ ਲਈ ਜਾਣ-ਬੁੱਝ ਕੇ ਘੜੇ ਗਏ ਖ਼ਤਰਨਾਕ ਇਨਪੁੱਟਾਂ ਦੁਆਰਾ ਧੋਖਾ ਖਾਣ ਜਾਂ ਹੇਰਾਫੇਰੀ ਦਾ ਸ਼ਕਾਰ ਹੋਣ ਦਾ ਵਿਰੋਧ ਕਰਦਾ ਹੈ।
- **Adversarial Training** – A training technique that augments training data with adversarial examples to improve model robustness against perturbation attacks.
- **ਵਰਿਧੀ ਸਖਿਲਾਈ (Adversarial Training)** – ਇੱਕ ਸਖਿਲਾਈ ਤਕਨੀਕ ਜੋ ਵਿਗਾੜ ਹਮਲਿਆਂ ਵਿਰੁੱਧ ਮਾਡਲ ਦੀ ਮਜ਼ਬੂਤੀ ਸੁਧਾਰਨ ਲਈ ਸਖਿਲਾਈ ਡਾਟਾ ਵਿੱਚ ਵਰਿਧੀ ਉਦਾਹਰਨਾਂ ਸ਼ਾਮਲ ਕਰਦੀ ਹੈ।
- **Agent** – An AI software system that uses reasoning, planning, and memory to pursue goals and complete tasks on behalf of users, with a degree of autonomy to make decisions, learn, and adapt. Also referred to as Agentic AI.
- **ਏਜੰਟ (Agent)** – ਇੱਕ AI ਸਾਫਟਵੇਅਰ ਸਸਿਟਮ ਜੋ ਉਪਭੋਗਤਾਵਾਂ ਵੱਲੋਂ ਟੀਚੇ ਪੂਰੇ ਕਰਨ ਅਤੇ ਕਾਰਜ ਨੇਪਰੇ ਚਾੜ੍ਹਨ ਲਈ ਤਰਕ, ਯੋਜਨਾਬੰਦੀ, ਅਤੇ ਮੈਮੋਰੀ (memory) ਦੀ ਵਰਤੋਂ ਕਰਦਾ ਹੈ, ਅਤੇ ਜਸਿ ਕੋਲ ਫ਼ੈਸਲੇ ਲੈਣ, ਸਖਿਣ, ਅਤੇ ਢਲਣ ਲਈ ਕੁਝ ਪੱਧਰ ਦੀ ਖੁਦਮੁਖ਼ਤਾਰੀ (autonomy) ਹੁੰਦੀ ਹੈ। ਇਸ ਨੂੰ ਏਜੰਟ-ਆਧਾਰਤ AI (Agentic AI) ਵੀ ਕਹਿਾ ਜਾਂਦਾ ਹੈ।
- **AI BOM (AI Bill of Materials)** – A structured record of all components in an AI system, including models, datasets, weights, hyperparameters, frameworks, and licenses. May follow SPDX or CycloneDX formats. Distinct from a traditional SBOM in that it covers model-specific artifacts beyond software dependencies. Also referred to as AIBOM or MBOM (Model Bill of Materials).
- **AI BOM (AI ਬਲਿ ਆਫ਼ ਮਟੀਰੀਅਲਜ਼)** – ਕਸਿ AI ਸਸਿਟਮ ਦੇ ਸਾਰੇ ਹਸਿੰਆਂ ਦਾ ਇੱਕ ਢਾਂਚਾਗਤ ਰਕਿਾਰਡ, ਜਸਿ ਵਿੱਚ ਮਾਡਲ, ਡਾਟਾਸੈੱਟ, ਵੇਟਸ, ਹਾਈਪਰਪੈਰਾਮੀਟਰ, ਫ੍ਰੇਮਵਰਕ, ਅਤੇ ਲਾਇਸੰਸ ਸ਼ਾਮਲ ਹਨ। ਇਹ SPDX ਜਾਂ CycloneDX ਫ਼ਾਰਮੈਟਾਂ ਦੀ ਪਾਲਣਾ ਕਰ ਸਕਦਾ ਹੈ। ਇਹ ਰਵਾਇਤੀ SBOM ਤੋਂ ਇਸ ਪੱਖੋਂ ਵੱਖਰਾ ਹੈ ਕਿ ਇਹ ਸਾਫਟਵੇਅਰ ਡਿਪੈਂਡੈਂਸੀਆਂ ਤੋਂ ਔਰੇ ਜਾ ਕੇ ਮਾਡਲ-ਵਸ਼ਿਸ਼ ਆਰਟੀਫੈਕਟਾਂ ਨੂੰ ਵੀ ਸਮੇਟਦਾ ਹੈ। ਇਸ ਨੂੰ AIBOM ਜਾਂ MBOM (Model Bill of Materials) ਵੀ ਕਹਿਾ ਜਾਂਦਾ ਹੈ।

¹⁴³ **Appendix** (EN) -> ਅੰਤਰਿਕਾ — ਅੰਤਰਿਕਾ is the settled Panjabi term for a document appendix in academic/government publishing, so the division letter stays Latin (a cross-reference target) while the noun is translated. Full discussion: OPEN-QUESTIONS.md Q121.

- **Alignment** – The degree to which a model’s behavior and outputs match human intentions, values, and safety requirements. Alignment is shaped during training through techniques such as RLHF and Constitutional AI, and is the property that adversarial attacks such as jailbreaks attempt to subvert.
- **ਅਲਾਈਨਮੈਂਟ (Alignment)** – ਉਹ ਪੱਧਰ ਜਿਸ ਤੱਕ ਕਸਿ ਮਾਡਲ ਦਾ ਵਿਵਹਾਰ ਅਤੇ ਆਉਟਪੁੱਟ ਮਨੁੱਖੀ ਇਰਾਦਿਆਂ, ਕਦਰਾਂ-ਕੀਮਤਾਂ, ਅਤੇ ਸਲਾਮਤੀ (safety) ਲੋੜਾਂ ਨਾਲ ਮੇਲ ਖਾਂਦੇ ਹਨ। ਅਲਾਈਨਮੈਂਟ ਸਥਿਲਾਈ ਦੌਰਾਨ RLHF ਅਤੇ Constitutional AI ਵਰਗੀਆਂ ਤਕਨੀਕਾਂ ਰਾਹੀਂ ਘੜੀ ਜਾਂਦੀ ਹੈ, ਅਤੇ ਇਹ ਉਹੀ ਗੁਣ ਹੈ ਜਿਸ ਨੂੰ jailbreak ਵਰਗੇ ਵਿਰੋਧੀ ਹਮਲੇ ਭੰਗ ਕਰਨ ਦੀ ਕੋਸ਼ਿਸ਼ ਕਰਦੇ ਹਨ।
- **AppArmor** – A Linux kernel security module that restricts program capabilities through per-program security profiles, used to sandbox AI workloads.
- **AppArmor** – ਇੱਕ Linux ਕਰਨਲ ਸੁਰੱਖਿਆ ਮਾਡਿਊਲ ਜੋ ਪ੍ਰੋਗਰਾਮ-ਪ੍ਰੋਫਾਈਲਾਂ ਰਾਹੀਂ ਪ੍ਰੋਗਰਾਮ ਦੀਆਂ ਸਮਰੱਥਾਵਾਂ ਨੂੰ ਸੀਮਤ ਕਰਦਾ ਹੈ, ਅਤੇ AI ਵਰਕਲੋਡਾਂ ਨੂੰ ਸੈਂਡਬਾਕਸ ਕਰਨ ਲਈ ਵਰਤਿਆ ਜਾਂਦਾ ਹੈ।
- **Attention Map** – A visualization of which parts of an input a transformer model attends to when producing an output, used as an interpretability tool.
- **ਅਟੈਂਸ਼ਨ ਮੈਪ¹⁴⁴ (Attention Map)** – ਇੱਕ ਦਰਸ਼ਿ ਪੇਸ਼ਕਾਰੀ¹⁴⁵ (visualization) ਜੋ ਦਰਸਾਉਂਦੀ ਹੈ ਕਿ ਆਉਟਪੁੱਟ ਤਿਆਰ ਕਰਦੇ ਸਮੇਂ ਕੋਈ transformer ਮਾਡਲ ਇਨਪੁੱਟ ਦੇ ਕਿਹੜੇ ਹਿੱਸਿਆਂ ਨੂੰ ਭਾਰ ਦਿੰਦਾ ਹੈ; ਇਹ ਵਿਆਖਿਆਯੋਗਤਾ¹⁴⁶ (interpretability) ਦੇ ਟੂਲ ਵਜੋਂ ਵਰਤੀ ਜਾਂਦੀ ਹੈ।
- **Attribute-Based Access Control (ABAC)** – An access control paradigm where authorization decisions are based on attributes of the user, resource, action, and environment, evaluated at query time.
- **ਗੁਣ-ਆਧਾਰਤ ਪਹੁੰਚ ਕੰਟਰੋਲ¹⁴⁷ (Attribute-Based Access Control, ABAC)** – ਪਹੁੰਚ ਕੰਟਰੋਲ ਦਾ ਇੱਕ ਮਾਡਲ ਜਿਸ ਵਿੱਚ ਅਧਿਕਾਰੀਕਰਨ ਦੇ ਫ਼ੈਸਲੇ ਉਪਭੋਗਤਾ, ਸਰੋਤ, ਕਾਰਵਾਈ, ਅਤੇ ਵਾਤਾਵਰਣ ਦੇ ਗੁਣਾਂ ਉੱਤੇ ਆਧਾਰਤ ਹੁੰਦੇ ਹਨ ਅਤੇ ਕਾਊਂਟਰੀ ਵੇਲੇ ਪਰਖੇ ਜਾਂਦੇ ਹਨ।
- **Backdoor Attack** – A type of data poisoning attack where the model is trained to respond in a specific way to certain triggers while behaving normally otherwise.
- **ਬੈਕਡੋਰ ਹਮਲਾ (Backdoor Attack)** – data poisoning ਹਮਲੇ ਦੀ ਇੱਕ ਕਸਿਮ ਜਿਸ ਵਿੱਚ ਮਾਡਲ ਨੂੰ ਇਸ ਤਰ੍ਹਾਂ ਸਥਿਲਾਈ ਦਿੱਤੀ ਜਾਂਦੀ ਹੈ ਕਿ ਉਹ ਕੁਝ ਖ਼ਾਸ ਟਰਿਗਰਾਂ ਪ੍ਰਤੀ ਇੱਕ ਨਿਸ਼ਚਿਤ ਢੰਗ ਨਾਲ ਜਵਾਬ ਦੇਵੇ ਜਦਕਿ ਬਾਕੀ ਹਾਲਾਤਾਂ ਵਿੱਚ ਆਮ ਵਾਂਗ ਵਿਵਹਾਰ ਕਰੇ।
- **Bias** – Systematic errors in AI model outputs that can lead to unfair or discriminatory outcomes for certain groups or in specific contexts.
- **ਪੱਖਪਾਤ (Bias)** – AI ਮਾਡਲ ਦੇ ਆਉਟਪੁੱਟ ਵਿੱਚ ਪ੍ਰਣਾਲੀਗਤ ਗਲਤੀਆਂ ਜੋ ਕੁਝ ਸਮੂਹਾਂ ਲਈ ਜਾਂ ਖ਼ਾਸ ਸੰਦਰਭਾਂ ਵਿੱਚ ਨਾ-ਇਨਸਾਫ਼ੀ ਵਾਲੇ ਜਾਂ ਵਿਤਕਰੇ ਭਰੇ ਨਤੀਜੇ ਪੈਦਾ ਕਰ ਸਕਦੀਆਂ ਹਨ।
- **Bias Exploitation** – An attack technique that takes advantage of known biases in AI models to manipulate outputs or outcomes.
- **ਪੱਖਪਾਤ ਦਾ ਸ਼ੋਸ਼ਣ (Bias Exploitation)** – ਇੱਕ ਹਮਲਾ ਤਕਨੀਕ ਜੋ ਆਉਟਪੁੱਟ ਜਾਂ ਨਤੀਜਿਆਂ ਨਾਲ ਹੇਰਾਫੇਰੀ ਕਰਨ ਲਈ AI ਮਾਡਲਾਂ ਦੇ ਜਾਣੇ-ਪਛਾਣੇ ਪੱਖਪਾਤਾਂ ਦਾ ਲਾਹਾ ਲੈਂਦੀ ਹੈ।
- **Blue-Green Deployment** – A deployment strategy that runs two identical production environments (blue and green), allowing instant rollback by switching traffic between them.

¹⁴⁴ **attention map** (EN) -> ਅਟੈਂਸ਼ਨ ਮੈਪ — kept as a loan rather than a literal ਧਿਆਨ (“focused remembrance”) calque because that word is load-bearing Gurbani/devotional vocabulary and a transformer computes a weighting, not an act of attending. Full discussion: OPEN-QUESTIONS.md Q126.

¹⁴⁵ **visualization** (EN) -> ਦਰਸ਼ਿ ਪੇਸ਼ਕਾਰੀ — corrected from an earlier draft’s ਦਰਸ਼ਿਣਾਤ, which names an illustrative parable/example in commentarial exegesis and was the wrong word twice over in the entry with the most Gurmat scrutiny in the appendix. Full discussion: OPEN-QUESTIONS.md Q144.

¹⁴⁶ **interpretability** (EN) -> ਵਿਆਖਿਆਯੋਗਤਾ — reuses the explainability rendering rather than coining a second word, because the appendix uses the two English terms near-synonymously and a second Panjabi word would assert a distinction the source does not make. Full discussion: OPEN-QUESTIONS.md Q127.

¹⁴⁷ **Role-/Attribute-Based Access Control** (EN) -> ਭੂਮਿਕਾ-/ਗੁਣ-ਆਧਾਰਤ ਪਹੁੰਚ ਕੰਟਰੋਲ — attribute takes ਗੁਣ (not ਵਸ਼ਿਸ਼ਤਾ) specifically so it stays clear of features, which both words appear alongside in this appendix. Full discussion: OPEN-QUESTIONS.md Q131.

- **ਬਲੂ-ਗਰੀਨ ਤੈਨਾਤੀ (Blue-Green Deployment)** – ਤੈਨਾਤੀ ਦੀ ਇੱਕ ਰਣਨੀਤੀ ਜਿਸ ਵਿੱਚ ਦੋ ਇੱਕੋ ਜਿਹੇ ਉਤਪਾਦਨ ਵਾਤਾਵਰਣ (ਬਲੂ ਅਤੇ ਗਰੀਨ) ਚਲਾਏ ਜਾਂਦੇ ਹਨ, ਜਿਸ ਨਾਲ ਟਰੈਫਿਕ ਨੂੰ ਇੱਕ ਤੋਂ ਦੂਜੇ ਵੱਲ ਮੋੜ ਕੇ ਤੁਰੰਤ ਰੋਲਬੈਕ ਸੰਭਵ ਹੋ ਜਾਂਦਾ ਹੈ।
- **Byzantine Fault Tolerance** – The ability of a distributed system to reach consensus and continue operating correctly even when some nodes fail or act maliciously.
- **Byzantine Fault Tolerance (ਬਾਈਜੈਂਟਾਈਨ ਫਾਲਟ ਸਹਣਸ਼ੀਲਤਾ)**¹⁴⁸ – ਕਮਿ ਵੰਡੇ ਹੋਏ ਸਸਿਟਮ ਦੀ ਉਹ ਸਮਰੱਥਾ ਜਿਸ ਨਾਲ ਉਹ ਸਰਬ-ਸਹਮਿਤੀ¹⁴⁹ (consensus) ਉੱਤੇ ਪਹੁੰਚ ਸਕਦਾ ਹੈ ਅਤੇ ਸਹੀ ਢੰਗ ਨਾਲ ਚੱਲਦਾ ਰਹਿ ਸਕਦਾ ਹੈ, ਭਾਵੇਂ ਕੁਝ ਨੋਡ ਫ਼ੇਲ੍ਹ ਹੋ ਜਾਣ ਜਾਂ ਖ਼ਤਰਨਾਕ ਢੰਗ ਨਾਲ ਵਰਤਿਆਰ ਕਰਨ।
- **Canary Deployment** – A deployment strategy that gradually routes a small percentage of traffic to a new model version to detect issues before full rollout.
- **ਕੈਨਰੀ ਤੈਨਾਤੀ (Canary Deployment)** – ਤੈਨਾਤੀ ਦੀ ਇੱਕ ਰਣਨੀਤੀ ਜਿਸ ਵਿੱਚ ਪੂਰੇ ਰੋਲਆਊਟ ਤੋਂ ਪਹਿਲਾਂ ਸਮੱਸਿਆਵਾਂ ਦਾ ਪਤਾ ਲਗਾਉਣ ਲਈ ਟਰੈਫਿਕ ਦਾ ਇੱਕ ਛੋਟਾ ਹਿੱਸਾ ਹੌਲੀ-ਹੌਲੀ ਨਵੇਂ ਮਾਡਲ ਵਰਜ਼ਨ ਵੱਲ ਭੇਜਿਆ ਜਾਂਦਾ ਹੈ।
- **Cedar** – An open-source policy language and evaluation engine for fine-grained permissions, originally created by Amazon. Used in implementing ABAC for AI systems.
- **Cedar** – ਬਾਰੀਕ-ਪੱਧਰੀ ਇਜਾਜ਼ਤਾਂ ਲਈ ਇੱਕ ਓਪਨ-ਸੋਰਸ ਨੀਤੀ ਭਾਸ਼ਾ ਅਤੇ ਮੁਲਾਂਕਣ ਇੰਜਣ, ਜੋ ਮੂਲ ਰੂਪ ਵਿੱਚ Amazon ਦੁਆਰਾ ਬਣਾਇਆ ਗਿਆ। ਇਹ AI ਸਸਿਟਮਾਂ ਲਈ ABAC ਲਾਗੂ ਕਰਨ ਵਿੱਚ ਵਰਤਿਆ ਜਾਂਦਾ ਹੈ।
- **Certified Robustness** – A formal mathematical guarantee that a model's prediction will not change within a specified perturbation bound around an input, verified through techniques such as interval-bound propagation.
- **ਸਰਟੀਫਾਈਡ ਮਜ਼ਬੂਤੀ**¹⁵⁰ (**Certified Robustness**) – ਇੱਕ ਰਸਮੀ ਗਣਿਤਿਕ ਗਾਰੰਟੀ ਕਿ ਕਿਸੇ ਇਨਪੁੱਟ ਦੇ ਦੁਆਲੇ ਨਰਿਧਾਰਤਿ ਵਰਗਿਤ ਸੀਮਾ ਦੇ ਅੰਦਰ ਮਾਡਲ ਦਾ ਪੂਰਵ-ਅਨੁਮਾਨ ਨਹੀਂ ਬਦਲੇਗਾ; ਇਸ ਦੀ ਤਸਦੀਕ interval-bound propagation ਵਰਗੀਆਂ ਤਕਨੀਕਾਂ ਰਾਹੀਂ ਕੀਤੀ ਜਾਂਦੀ ਹੈ।
- **Chain of Thought** – A technique for improving reasoning in language models by generating intermediate reasoning steps before producing a final answer.
- **Chain of Thought (ਸੋਚ ਦੀ ਲੜੀ)**¹⁵¹ – ਭਾਸ਼ਾ ਮਾਡਲਾਂ ਵਿੱਚ ਤਰਕ ਸੁਧਾਰਨ ਦੀ ਇੱਕ ਤਕਨੀਕ, ਜਿਸ ਵਿੱਚ ਅੰਤਿਮ ਜਵਾਬ ਦੇਣ ਤੋਂ ਪਹਿਲਾਂ ਵਿਚਕਾਰਲੇ ਤਰਕ ਪੜਾਅ ਤਿਆਰ ਕੀਤੇ ਜਾਂਦੇ ਹਨ।
- **CI/CD (Continuous Integration / Continuous Deployment)** – A software engineering practice that automates building, testing, and deploying code changes, used in AI systems for model and pipeline deployment.
- **CI/CD (Continuous Integration / Continuous Deployment)** – ਇੱਕ ਸਾਫ਼ਟਵੇਅਰ ਇੰਜੀਨੀਅਰਿੰਗ ਅਭਿਆਸ ਜੋ ਕੋਡ ਤਬਦੀਲੀਆਂ ਦੇ ਬਲਿਡ, ਟੈਸਟਿੰਗ, ਅਤੇ ਤੈਨਾਤੀ ਨੂੰ ਸਵੈਚਲਤਿ ਕਰਦਾ ਹੈ; AI ਸਸਿਟਮਾਂ ਵਿੱਚ ਇਹ ਮਾਡਲ ਅਤੇ ਪਾਈਪਲਾਈਨ ਦੀ ਤੈਨਾਤੀ ਲਈ ਵਰਤਿਆ ਜਾਂਦਾ ਹੈ।
- **Circuit Breaker** – A mechanism that automatically halts AI system operations when specific risk thresholds are exceeded, such as runaway agent loops or budget exhaustion.
- **ਸਰਕਟ ਬਰੇਕਰ (Circuit Breaker)** – ਇੱਕ ਵਧੀ ਜੋ ਖ਼ਾਸ ਜੋਖਮ ਥਰੈਸ਼ਹੋਲਡਾਂ ਦੇ ਪਾਰ ਹੋਣ 'ਤੇ AI ਸਸਿਟਮ ਦੇ ਕੰਮਕਾਜ ਨੂੰ ਆਪਣੇ-ਆਪ ਰੋਕ ਦਿੰਦੀ ਹੈ, ਜਿਵੇਂ ਬੇਕਾਬੂ ਏਜੰਟ ਲੂਪ ਜਾਂ ਬਜਟ ਦਾ ਮੁੱਕ ਜਾਣਾ।

¹⁴⁸**Byzantine Fault Tolerance** (EN) -> retained, glossed ਬਾਈਜੈਂਟਾਈਨ ਫਾਲਟ ਸਹਣਸ਼ੀਲਤਾ — spends ਸਹਣਸ਼ੀਲਤਾ (“tolerance”), a word kept deliberately free of resilience (ਲਚਕੀਲਾਪਣ) and robustness (ਮਜ਼ਬੂਤੀ) so all three distributed-systems properties stay distinguishable. Full discussion: OPEN-QUESTIONS.md Q137.

¹⁴⁹**consensus** (EN) -> ਸਰਬ-ਸਹਮਿਤੀ — corrected from an earlier draft's bare ਸਹਮਿਤੀ, which is fixed corpus-wide to consent and appears in that sense elsewhere in this same file. Full discussion: OPEN-QUESTIONS.md Q144.

¹⁵⁰**Certified Robustness** (EN) -> ਸਰਟੀਫਾਈਡ ਮਜ਼ਬੂਤੀ — the adjective derives from the loan ਸਰਟੀਫ਼ਿਕੇਸ਼ਨ because ਪ੍ਰਮਾਣਤਿ (validate) and ਤਸਦੀਕਸ਼ੁਦਾ (verify) are both already locked to different verbs in this corpus. Full discussion: OPEN-QUESTIONS.md Q136.

¹⁵¹**Chain of Thought** (EN) -> retained, glossed ਸੋਚ ਦੀ ਲੜੀ — the gloss deliberately uses the plain word ਸੋਚ for “thought” rather than ਵਿਚਾਰ, which carries devotional-contemplative weight in Gurbani usage. Full discussion: OPEN-QUESTIONS.md Q139.

- **CMP (Consent Management Platform)** – A system that tracks user consent preferences including opt-in status, purpose, and retention period, and enforces consent decisions across data processing pipelines.
- **CMP (ਸਹਿਮਤੀ ਪ੍ਰਬੰਧਨ ਪਲੇਟਫਾਰਮ)** – ਇੱਕ ਸਸਿਟਮ ਜੋ ਉਪਭੋਗਤਾ ਦੀਆਂ ਸਹਿਮਤੀ ਤਰਜੀਹਾਂ — ਜਿਸ ਵਿੱਚ opt-in ਸਥਿਤੀ, ਮਕਸਦ, ਅਤੇ ਧਾਰਨ ਮਿਆਦ ਸ਼ਾਮਲ ਹਨ — ਨੂੰ ਟਰੈਕ ਕਰਦਾ ਹੈ ਅਤੇ ਸਾਰੀਆਂ ਡਾਟਾ ਪ੍ਰਕਿਰਿਆ ਪਾਈਪਲਾਈਨਾਂ ਵਿੱਚ ਸਹਿਮਤੀ ਦੇ ਫ਼ੈਸਲੇ ਲਾਗੂ ਕਰਦਾ ਹੈ।
- **Concept Drift** – A change in the statistical relationship between model inputs and outputs over time, causing model predictions to become less accurate even if input distributions remain stable.
- **ਕਾਨਸੈਪਟ ਡ੍ਰਿਫਟ¹⁵² (Concept Drift)** – ਸਮੇਂ ਦੇ ਨਾਲ ਮਾਡਲ ਦੇ ਇਨਪੁੱਟ ਅਤੇ ਆਉਟਪੁੱਟ ਵਿਚਕਾਰ ਅੰਕੜਾ-ਸੰਬੰਧ ਵਿੱਚ ਆਈ ਤਬਦੀਲੀ, ਜਿਸ ਕਾਰਨ ਮਾਡਲ ਦੇ ਪੂਰਵ-ਅਨੁਮਾਨ ਘੱਟ ਸਟੀਕ ਹੋ ਜਾਂਦੇ ਹਨ, ਭਾਵੇਂ ਇਨਪੁੱਟ ਵੰਡਾਂ ਸਥਿਰ ਹੀ ਰਹਿਣ।
- **Confidential Computing** – A security paradigm that protects data in use by performing computation within hardware-enforced trusted execution environments, ensuring code and data remain encrypted and isolated from the host.
- **ਗੁਪਤ ਕੰਪਿਊਟਿੰਗ (Confidential Computing)** – ਇੱਕ ਸੁਰੱਖਿਆ ਪਹੁੰਚ-ਵਿਧੀ ਜੋ ਹਾਰਡਵੇਅਰ ਦੁਆਰਾ ਲਾਗੂ ਕੀਤੇ ਭਰੋਸੇਯੋਗ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਵਾਤਾਵਰਣਾਂ ਦੇ ਅੰਦਰ ਗਣਨਾ ਕਰਕੇ ਵਰਤੋਂ ਅਧੀਨ ਡਾਟੇ ਦੀ ਰਾਖੀ ਕਰਦੀ ਹੈ, ਅਤੇ ਇਹ ਯਕੀਨੀ ਬਣਾਉਂਦੀ ਹੈ ਕਿ ਕੋਡ ਅਤੇ ਡਾਟਾ ਏਨਕ੍ਰਿਪਟ ਰਹਿਣ ਅਤੇ ਹੋਸਟ ਤੋਂ ਅਲੱਗ-ਥਲੱਗ ਰਹਿਣ।
- **Confidential Inference** – An inference service that runs AI models inside a trusted execution environment (TEE), ensuring model weights and inference data remain encrypted, sealed, and protected from unauthorized access or tampering.
- **ਗੁਪਤ ਇਨਫ਼ਰੈਂਸ (Confidential Inference)** – ਇੱਕ ਇਨਫ਼ਰੈਂਸ ਸੇਵਾ ਜੋ AI ਮਾਡਲਾਂ ਨੂੰ ਭਰੋਸੇਯੋਗ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਵਾਤਾਵਰਣ (TEE) ਦੇ ਅੰਦਰ ਚਲਾਉਂਦੀ ਹੈ, ਅਤੇ ਇਹ ਯਕੀਨੀ ਬਣਾਉਂਦੀ ਹੈ ਕਿ ਮਾਡਲ ਵੇਟਸ ਅਤੇ ਇਨਫ਼ਰੈਂਸ ਡਾਟਾ ਏਨਕ੍ਰਿਪਟ, ਸੀਲਬੰਦ, ਅਤੇ ਅਣਅਧਿਕਾਰਤ ਪਹੁੰਚ ਜਾਂ ਛੇੜਛਾੜ ਤੋਂ ਸੁਰੱਖਿਅਤ ਰਹਿਣ।
- **Constitutional AI** – A training approach in which a model is guided by a set of written principles (a “constitution”) and trained to critique and revise its own outputs for policy compliance, using a self-critique process as an alternative or supplement to human feedback. See also: RLHF.
- **Constitutional AI** – ਇੱਕ ਸਖਿਲਾਈ ਪਹੁੰਚ-ਵਿਧੀ ਜਿਸ ਵਿੱਚ ਮਾਡਲ ਨੂੰ ਲਿਖਤੀ ਅਸੂਲਾਂ ਦੇ ਇੱਕ ਸਮੂਹ (ਇੱਕ “ਸੰਵਿਧਾਨ”) ਦੁਆਰਾ ਸੇਧ ਦਿੱਤੀ ਜਾਂਦੀ ਹੈ ਅਤੇ ਇਸ ਤਰ੍ਹਾਂ ਸਖਿਲਾਈ ਦਿੱਤੀ ਜਾਂਦੀ ਹੈ ਕਿ ਉਹ ਨੀਤੀ-ਪਾਲਣਾ ਲਈ ਆਪਣੇ ਹੀ ਆਉਟਪੁੱਟ ਦੀ ਸਮੀਖਿਆ ਅਤੇ ਸੋਧ ਕਰੇ; ਇਹ ਸਵੈ-ਸਮੀਖਿਆ ਪ੍ਰਕਿਰਿਆ ਮਨੁੱਖੀ ਫ਼ੀਡਬੈਕ ਦਾ ਬਦਲ ਜਾਂ ਪੂਰਕ ਹੁੰਦੀ ਹੈ। ਇਹ ਵੀ ਵੇਖੋ: RLHF।
- **Context Window** – The maximum amount of text (measured in tokens) that a language model can process in a single inference call, encompassing the system prompt, conversation history, retrieved documents, and tool outputs. The context window defines what information is available to the model at inference time and is a finite resource that can be exhausted or manipulated by adversarial inputs.
- **ਸੰਦਰਭ ਵੰਡ (Context Window)** – ਲਿਖਤ ਦੀ ਉਹ ਵੱਧ ਤੋਂ ਵੱਧ ਮਾਤਰਾ (ਟੋਕਨਾਂ ਵਿੱਚ ਮਾਪੀ ਗਈ) ਜਿਸ ਨੂੰ ਕੋਈ ਭਾਸ਼ਾ ਮਾਡਲ ਇੱਕੋ ਇਨਫ਼ਰੈਂਸ ਕਾਲ ਵਿੱਚ ਪ੍ਰਕਿਰਿਆ ਕਰ ਸਕਦਾ ਹੈ, ਜਿਸ ਵਿੱਚ system prompt, ਗੱਲਬਾਤ ਦਾ ਇਤਿਹਾਸ, ਪ੍ਰਾਪਤ ਕੀਤੇ ਦਸਤਾਵੇਜ਼, ਅਤੇ ਟੂਲ ਆਉਟਪੁੱਟ ਸ਼ਾਮਲ ਹਨ। ਸੰਦਰਭ ਵੰਡ ਇਹ ਤੈਅ ਕਰਦੀ ਹੈ ਕਿ ਇਨਫ਼ਰੈਂਸ ਵੇਲੇ ਮਾਡਲ ਕੋਲ ਕਹਿੜੀ ਜਾਣਕਾਰੀ ਉਪਲਬਧ ਹੈ, ਅਤੇ ਇਹ ਇੱਕ ਸੀਮਤ ਸਰੋਤ ਹੈ ਜਿਸ ਨੂੰ ਵਰਿਧੀ ਇਨਪੁੱਟਾਂ ਦੁਆਰਾ ਮੁਕਾਇਆ ਜਾਂ ਹੇਰਾਫੇਰੀ ਦਾ ਸ਼ਕਾਰ ਬਣਾਇਆ ਜਾ ਸਕਦਾ ਹੈ।
- **Counterfactual Explanation** – An interpretability technique that explains a model decision by describing the minimal changes to input features that would change the prediction outcome.
- **ਵਿਪਰੀਤ-ਤੱਥ ਵਿਆਖਿਆ (Counterfactual Explanation)** – ਇੱਕ ਵਿਆਖਿਆਯੋਗਤਾ ਤਕਨੀਕ ਜੋ ਮਾਡਲ ਦੇ ਫ਼ੈਸਲੇ ਦੀ ਵਿਆਖਿਆ ਇਹ ਦੱਸ ਕੇ ਕਰਦੀ ਹੈ ਕਿ ਇਨਪੁੱਟ ਫ਼ੀਚਰਾਂ ਵਿੱਚ ਘੱਟੋ-ਘੱਟ ਕਹਿੜੀਆਂ ਤਬਦੀਲੀਆਂ ਪੂਰਵ-ਅਨੁਮਾਨ ਦਾ ਨਤੀਜਾ ਬਦਲ ਦੇਣਗੀਆਂ।

¹⁵² **Concept Drift** (EN) -> ਕਾਨਸੈਪਟ ਡ੍ਰਿਫਟ — kept as a loan rather than ਧਾਰਨਾ ਡ੍ਰਿਫਟ, since ਧਾਰਨਾ was already set aside elsewhere for anthropomorphising a model as holding notions. Full discussion: OPEN-QUESTIONS.md Q138.

- **Covert Channel** – An unintended communication path that can be exploited to transfer information in violation of security policy, such as through timing or resource usage patterns in shared AI infrastructure.
- **ਲੁਕਵਾਂ ਚੈਨਲ**¹⁵³ (**Covert Channel**) – ਇੱਕ ਅਣਇੱਛਤ ਸੰਚਾਰ ਰਾਹ ਜਿਸ ਦਾ ਸ਼ੋਸ਼ਣ ਕਰਕੇ ਸੁਰੱਖਿਆ ਨੀਤੀ ਦੀ ਉਲੰਘਣਾ ਕਰਦਿਆਂ ਜਾਣਕਾਰੀ ਭੇਜੀ ਜਾ ਸਕਦੀ ਹੈ, ਜਿਵੇਂ ਸਾਂਝੇ AI ਬੁਨਿਆਦੀ ਢਾਂਚੇ ਵਿੱਚ ਸਮਾਂ-ਵਹਿਾਰ ਜਾਂ ਸਰੋਤ-ਵਰਤੋਂ ਦੇ ਪੈਟਰਨਾਂ ਰਾਹੀਂ।
- **CycloneDX** – An open standard for software and AI bill of materials, supporting component inventory, vulnerability tracking, and license compliance.
- **CycloneDX** – ਸਾਫਟਵੇਅਰ ਅਤੇ AI ਬਲਿ ਆਫ ਮਟੀਰੀਅਲਜ਼ ਲਈ ਇੱਕ ਖੁੱਲ੍ਹਾ ਮਿਆਰ, ਜੋ ਕੰਪੋਨੈਂਟ ਇਨਵੈਂਟਰੀ, ਕਮਜ਼ੋਰੀ ਟਰੈਕਿੰਗ, ਅਤੇ ਲਾਈਸੰਸ ਪਾਲਣਾ ਦਾ ਸਮਰਥਨ ਕਰਦਾ ਹੈ।
- **DAG (Directed Acyclic Graph)** – A graph structure with directed edges and no cycles, used in AI systems to represent agent decision paths, reasoning traces, and workflow dependencies.
- **DAG (Directed Acyclic Graph — ਦਸ਼ਾ-ਨਰਿਦੇਸ਼ਤਿ ਅਚੱਕਰੀ ਗਰਾਫ਼)** – ਇੱਕ ਗਰਾਫ਼ ਢਾਂਚਾ ਜਿਸ ਵਿੱਚ ਕਨਿਏਰੇ ਦਸ਼ਾ-ਨਰਿਦੇਸ਼ਤਿ ਹੁੰਦੇ ਹਨ ਅਤੇ ਕੋਈ ਚੱਕਰ ਨਹੀਂ ਹੁੰਦਾ; AI ਸਸਿਟਮਾਂ ਵਿੱਚ ਇਹ ਏਜੰਟ ਦੇ ਫ਼ੈਸਲਾ-ਰਾਹਾਂ, ਤਰਕ ਦੇ ਨਸ਼ਿਆਨਾਂ, ਅਤੇ ਵਰਕਫਲੋ ਡਿਪੈਂਡੈਂਸੀਆਂ ਨੂੰ ਦਰਸਾਉਣ ਲਈ ਵਰਤਿਆ ਜਾਂਦਾ ਹੈ।
- **Data Augmentation** – A technique that creates modified copies of training data (e.g., through rotation, noise addition, or paraphrasing) to increase dataset diversity and improve model robustness.
- **ਡਾਟਾ ਔਗਮੈਂਟੇਸ਼ਨ**¹⁵⁴ (**Data Augmentation**) – ਇੱਕ ਤਕਨੀਕ ਜੋ ਡਾਟਾਸੈੱਟ ਦੀ ਵੰਨ-ਸੁਵੰਨਤਾ ਵਧਾਉਣ ਅਤੇ ਮਾਡਲ ਦੀ ਮਜ਼ਬੂਤੀ ਸੁਧਾਰਨ ਲਈ ਸਥਿਲਾਈ ਡਾਟਾ ਦੀਆਂ ਸੋਧੀਆਂ ਹੋਈਆਂ ਨਕਲਾਂ ਬਣਾਉਂਦੀ ਹੈ (ਜਿਵੇਂ, ਘੁਮਾਅ, ਰੋਲਾ ਜੋੜਨ, ਜਾਂ ਦੁਬਾਰਾ-ਸ਼ਬਦਬੰਦੀ ਰਾਹੀਂ)।
- **Data Drift** – A change in the statistical distribution of model input data over time compared to the data the model was trained on, potentially degrading prediction quality.
- **ਡਾਟਾ ਡਰਿਫਟ (Data Drift)** – ਸਮੇਂ ਦੇ ਨਾਲ ਮਾਡਲ ਦੇ ਇਨਪੁੱਟ ਡਾਟੇ ਦੀ ਅੰਕੜਾ-ਵੰਡ ਵਿੱਚ ਉਸ ਡਾਟੇ ਦੇ ਮੁਕਾਬਲੇ ਆਈ ਤਬਦੀਲੀ ਜਿਸ ਉੱਤੇ ਮਾਡਲ ਨੂੰ ਸਥਿਲਾਈ ਦਿੱਤੀ ਗਈ ਸੀ, ਜੋ ਪੂਰਵ-ਅਨੁਮਾਨ ਦੀ ਗੁਣਵੱਤਾ ਘਟਾ ਸਕਦੀ ਹੈ।
- **Data Leakage** – Unintended exposure of sensitive information through AI model outputs or behavior.
- **ਡਾਟਾ ਲੀਕੇਜ਼ (Data Leakage)** – AI ਮਾਡਲ ਦੇ ਆਉਟਪੁੱਟ ਜਾਂ ਵਿਵਹਾਰ ਰਾਹੀਂ ਸੰਵੇਦਨਸ਼ੀਲ ਜਾਣਕਾਰੀ ਦਾ ਅਣਇੱਛਤ ਖੁਲਾਸਾ।
- **Data Lineage** – The documented chain of origin, transformation, and movement of data through an AI system's lifecycle, from collection through preprocessing, training, fine-tuning, embedding, and inference. Lineage records capture source identity, transformation operations, timestamps, and responsible parties, enabling auditability and the removal of data whose provenance cannot be verified.
- **ਡਾਟਾ ਵੰਸ਼ਾਵਲੀ (Data Lineage)** – ਕਸਿ AI ਸਸਿਟਮ ਦੇ ਜੀਵਨ-ਚੱਕਰ ਦੌਰਾਨ ਡਾਟੇ ਦੇ ਮੂਲ, ਪਰਵਿਰਤਨ, ਅਤੇ ਹਲਿਜ਼ਲ ਦੀ ਦਸਤਾਵੇਜ਼ੀ ਲੜੀ — ਇਕੱਤਰੀਕਰਨ ਤੋਂ ਲੈ ਕੇ ਪੂਰਵ-ਪ੍ਰਕਰਿਆ, ਸਥਿਲਾਈ, ਫ਼ਾਈਨ-ਟਿਊਨਿੰਗ, embedding, ਅਤੇ ਇਨਫ਼ਰੈਂਸ ਤੱਕ। ਵੰਸ਼ਾਵਲੀ ਰਕਿਾਰਡ ਸਰੋਤ ਦੀ ਪਛਾਣ, ਪਰਵਿਰਤਨ ਕਾਰਵਾਈਆਂ, ਸਮਾਂ-ਮੋਹਰਾਂ, ਅਤੇ ਜ਼ਿੰਮੇਵਾਰ ਧਰਿੰ ਦਰਜ ਕਰਦੇ ਹਨ, ਜਿਸ ਨਾਲ ਆਡਿਟਯੋਗਤਾ ਅਤੇ ਉਸ ਡਾਟੇ ਨੂੰ ਹਟਾਉਣਾ ਸੰਭਵ ਹੁੰਦਾ ਹੈ ਜਿਸ ਦੇ ਮੂਲ-ਸਰੋਤ (provenance) ਦੀ ਤਸਦੀਕ ਨਹੀਂ ਹੋ ਸਕਦੀ।
- **Data Minimization** – The principle of collecting, processing, and retaining only the minimum data necessary for a defined and documented purpose. In AI systems this extends to training data selection, feature engineering, context window construction, retrieval chunk inclusion, and memory and embedding retention policies.

¹⁵³ **Covert Channel / Side-Channel Attack** (EN) -> ਲੁਕਵਾਂ ਚੈਨਲ / ਸਾਈਡ-ਚੈਨਲ ਹਮਲਾ — covert is translated (ਲੁਕਵਾਂ, “hidden”) but not rendered ਗੁਪਤ, which this same glossary already fixes to confidential in ਗੁਪਤ ਕੰਪਿਊਟਿੰਗ; side-channel stays a loan because it names a specific hardware-security attack class. Full discussion: OPEN-QUESTIONS.md Q128.

¹⁵⁴ **Transfer Learning / Temperature Scaling / Defensive Distillation / Data Augmentation** etc. (EN) -> carried as loans (ਟ੍ਰਾਂਸਫਰ ਲਰਨਿੰਗ, ਟੈਂਪਰੇਚਰ ਸਕੇਲਿੰਗ, ਬਚਾਅ-ਪੱਖੀ ਡਿਸਟਿਲੇਸ਼ਨ, ਡਾਟਾ ਔਗਮੈਂਟੇਸ਼ਨ) — named ML operations with no settled Panjabi word route to a loan per corpus rule; temperature scaling is the clearest case where a literal calque (ਤਾਪਮਾਨ = heat) would actively mislead. Full discussion: OPEN-QUESTIONS.md Q140.

- **ਡਾਟਾ ਘੱਟੋ-ਘੱਟਕਰਨ¹⁵⁵ (Data Minimization)** – ਉਹ ਅਸੂਲ ਕੀ ਸਰਿਫ਼ ਓਨਾ ਹੀ ਡਾਟਾ ਇਕੱਤਰ, ਪ੍ਰਕਰਿਆ, ਅਤੇ ਧਾਰਨ ਕੀਤਾ ਜਾਵੇ ਜਿੰਨਾ ਕਸਿ ਪਰਭਾਸ਼ਤਿ ਅਤੇ ਦਸਤਾਵੇਜ਼ੀ ਮਕਸਦ ਲਈ ਘੱਟੋ-ਘੱਟ ਲੋੜੀਂਦਾ ਹੈ। AI ਸਸਿਟਮਾਂ ਵਿਚਿ ਇਹ ਸਖਿਲਾਈ ਡਾਟੇ ਦੀ ਚੋਣ, ਫ਼ੀਚਰ ਇੰਜੀਨੀਅਰਿੰਗ, ਸੰਦਰਭ ਵਡਿ ਦੀ ਉਸਾਰੀ, ਪ੍ਰਾਪਤੀ ਚੰਕਾਂ ਦੇ ਸ਼ਾਮਲ ਕੀਤੇ ਜਾਣ, ਅਤੇ ਮੈਮੋਰੀ ਤੇ embedding ਧਾਰਨ ਨੀਤੀਆਂ ਤੱਕ ਫੈਲਦਾ ਹੈ।
- **Data Poisoning** – The deliberate corruption of training data to compromise model integrity, often to install backdoors or degrade performance.
- **data poisoning (ਡਾਟਾ ਜਹਰੀਕਰਨ)** – ਮਾਡਲ ਦੀ ਅਖੰਡਤਾ ਭੰਗ ਕਰਨ ਲਈ ਸਖਿਲਾਈ ਡਾਟੇ ਦਾ ਜਾਣ-ਬੁੱਝ ਕੇ ਕੀਤਾ ਗਿਆ ਵਗਿਰਾੜ, ਅਕਸਰ ਬੈਕਡੋਰ ਸਥਾਪਤ ਕਰਨ ਜਾਂ ਕਾਰਗੁਜ਼ਾਰੀ ਘਟਾਉਣ ਲਈ।
- **Defense-in-Depth** – A security strategy that layers multiple independent defensive controls so that if one layer fails, others continue to provide protection.
- **Defense-in-Depth (ਡੂੰਘਾਈ ਵਿਚਿ ਬਚਾਅ)¹⁵⁶** – ਇੱਕ ਸੁਰੱਖਿਆ ਰਣਨੀਤੀ ਜੋ ਕਈ ਸੁਤੰਤਰ ਬਚਾਅ ਨਿਯੰਤਰਣਾਂ ਨੂੰ ਪਰਤਾਂ ਵਿਚਿ ਲਗਾਉਂਦੀ ਹੈ ਤਾਂ ਜੋ ਇੱਕ ਪਰਤ ਦੇ ਫ਼ੇਲ੍ਹ ਹੋਣ 'ਤੇ ਬਾਕੀ ਪਰਤਾਂ ਰਾਖੀ ਦਿੰਦੀਆਂ ਰਹਣ।
- **Defensive Distillation** – A training technique where a model is trained on the soft probability outputs of another model to smooth decision boundaries and reduce susceptibility to adversarial perturbation.
- **ਬਚਾਅ-ਪੱਖੀ ਡਿਸਟਿਲੇਸ਼ਨ (Defensive Distillation)** – ਇੱਕ ਸਖਿਲਾਈ ਤਕਨੀਕ ਜਸਿ ਵਿਚਿ ਇੱਕ ਮਾਡਲ ਨੂੰ ਕਸਿ ਦੂਜੇ ਮਾਡਲ ਦੇ ਨਰਮ ਸੰਭਾਵਨਾ ਆਉਟਪੁੱਟ ਉਤੇ ਸਖਿਲਾਈ ਦਿੱਤੀ ਜਾਂਦੀ ਹੈ ਤਾਂ ਜੋ ਫ਼ੈਸਲਾ-ਸੀਮਾਵਾਂ ਨਿਰਵਿਘਨ ਹੋਣ ਅਤੇ ਵਰਿਧੀ ਵਗਿਰਾੜ ਪ੍ਰਤੀ ਸੰਵੇਦਨਸ਼ੀਲਤਾ ਘਟੇ।
- **Differential Privacy** – A mathematically rigorous framework for releasing statistical information about datasets while protecting the privacy of individual data subjects, quantified by an epsilon privacy budget.
- **differential privacy** – ਡਾਟਾਸੈੱਟਾਂ ਬਾਰੇ ਅੰਕੜਾ ਜਾਣਕਾਰੀ ਜਾਰੀ ਕਰਨ ਲਈ ਇੱਕ ਗਣਤਿਕ ਤੌਰ 'ਤੇ ਸਖ਼ਤ ਫ਼ਰੇਮਵਰਕ, ਜੋ ਨਾਲੇ-ਨਾਲ ਵੱਖ-ਵੱਖ ਡਾਟਾ ਵਸ਼ਿਆਂ ਦੀ ਨਜ਼ਤਾ (privacy) ਦੀ ਰਾਖੀ ਕਰਦਾ ਹੈ; ਇਸ ਨੂੰ ਇੱਕ epsilon ਨਜ਼ਤਾ ਬਜਟ ਦੁਆਰਾ ਮਾਪਿਆ ਜਾਂਦਾ ਹੈ।
- **DoS (Denial of Service)** – An attack that attempts to make a system unavailable by overwhelming it with requests or exhausting its resources.
- **DoS (ਸੇਵਾ-ਇਨਕਾਰ)** – ਇੱਕ ਹਮਲਾ ਜੋ ਕਸਿ ਸਸਿਟਮ ਨੂੰ ਬੇਨਤੀਆਂ ਨਾਲ ਭਰ ਕੇ ਜਾਂ ਉਸ ਦੇ ਸਰੋਤ ਮੁਕਾ ਕੇ ਉਸ ਨੂੰ ਅਣਉਪਲਬਧ ਕਰਨ ਦੀ ਕੋਸ਼ਿਸ਼ ਕਰਦਾ ਹੈ।
- **Downgrade (response)** – Returning a model response that is less specific, less personalized, or otherwise reduced in scope when full processing would exceed an authorization or consent boundary. Examples include filtering out retrieval chunks sourced from non-consenting data subjects, suppressing personalized fields, or returning a generic answer instead of one that materially relies on restricted data. Refusal is always a valid downgrade. Acceptable downgrade behaviors should be documented per inference path.
- **ਡਾਊਨਗਰੇਡ¹⁵⁷ (Downgrade — ਜਵਾਬ ਦਾ)** – ਅਜਹਿਾ ਮਾਡਲ ਜਵਾਬ ਵਾਪਸ ਕਰਨਾ ਜੋ ਘੱਟ ਵਸ਼ਿਸ਼, ਘੱਟ ਨਜ਼ਿਕਰਤਿ, ਜਾਂ ਹੋਰ ਪੱਖੋਂ ਸੀਮਤ ਦਾਇਰੇ ਵਾਲਾ ਹੋਵੇ, ਜਦੋਂ ਪੂਰੀ ਪ੍ਰਕਰਿਆ ਕਸਿ ਅਧਿਕਾਰੀਕਰਨ ਜਾਂ ਸਹਿਮਤੀ ਸੀਮਾ ਨੂੰ ਪਾਰ ਕਰ ਜਾਂਦੀ ਹੋਵੇ। ਉਦਾਹਰਨਾਂ ਵਿਚਿ ਗੈਰ-ਸਹਿਮਤ ਡਾਟਾ ਵਸ਼ਿਆਂ ਤੋਂ ਆਏ ਪ੍ਰਾਪਤੀ ਚੰਕਾਂ ਨੂੰ ਫ਼ਲਿਟਰ ਕਰਨਾ, ਨਜ਼ਿਕਰਤਿ ਖੇਤਰਾਂ ਨੂੰ ਦਬਾਉਣਾ, ਜਾਂ ਪਾਬੰਦੀਸ਼ੁਦਾ ਡਾਟੇ ਉਤੇ ਠੋਸ ਤੌਰ 'ਤੇ ਨਿਰਭਰ ਜਵਾਬ ਦੀ ਥਾਂ ਇੱਕ ਆਮ ਜਵਾਬ ਦੇਣਾ ਸ਼ਾਮਲ ਹੈ। ਇਨਕਾਰ ਹਮੇਸ਼ਾ ਇੱਕ ਜਾਇਜ਼ ਡਾਊਨਗਰੇਡ ਹੁੰਦਾ ਹੈ। ਪ੍ਰਵਾਨਯੋਗ ਡਾਊਨਗਰੇਡ ਵਿਵਹਾਰ ਹਰ ਇਨਫ਼ਰੈਸ ਰਾਹ ਲਈ ਦਸਤਾਵੇਜ਼ੀ ਕੀਤੇ ਜਾਣੇ ਚਾਹੀਦੇ ਹਨ।
- **DPIA (Data Protection Impact Assessment)** – A formal assessment required under regulations such as GDPR to evaluate and mitigate risks to personal data before processing begins.

¹⁵⁵ **Data Minimization (EN)** -> ਡਾਟਾ ਘੱਟੋ-ਘੱਟਕਰਨ — built on the corpus's settled ਘੱਟੋ-ਘੱਟ ("minimum/least"), not ਸੀਮਤਕਰਨ ("limiting"), because minimization is a floor obligation and "limiting" would soften it. Full discussion: OPEN-QUESTIONS.md Q130.

¹⁵⁶ **Defense-in-Depth (EN)** -> retained, glossed ਡੂੰਘਾਈ ਵਿਚਿ ਬਚਾਅ — a named security doctrine (treated like Zero Trust), so the English string is kept for auditors and reference lists; normalised to un-hyphenated Panjabi for corpus consistency with the one other site that uses it. Full discussion: OPEN-QUESTIONS.md Q141.

¹⁵⁷ **Downgrade (response) (EN)** -> ਡਾਊਨਗਰੇਡ — kept as a loan and not ਨਿਘਾਰ, which this corpus already uses for degradation in the drift-monitoring sense; AISVS gives downgrade a precise, enumerated meaning that a narrower native word would soften. Full discussion: OPEN-QUESTIONS.md Q134.

- **DPIA (Data Protection Impact Assessment — ਡਾਟਾ ਸੁਰੱਖਿਆ ਪਰਭਾਵ ਮੁਲਾਂਕਣ)** – ਇੱਕ ਰਸਮੀ ਮੁਲਾਂਕਣ ਜੋ GDPR ਵਰਗੇ ਨਿਯਮਾਂ ਅਧੀਨ ਲੋੜੀਂਦਾ ਹੈ, ਤਾਂ ਜੋ ਪ੍ਰਕਿਰਿਆ ਸ਼ੁਰੂ ਹੋਣ ਤੋਂ ਪਹਿਲਾਂ ਨਿੱਜੀ ਡਾਟੇ ਨੂੰ ਦਰਪੇਸ਼ ਜੋਖਮਾਂ ਦਾ ਮੁਲਾਂਕਣ ਅਤੇ ਉਹਨਾਂ ਦਾ ਨਿਵਾਰਨ ਕੀਤਾ ਜਾ ਸਕੇ।
- **DPOP (Demonstrating Proof-of-Possession)** – An OAuth 2.0 mechanism (RFC 9449) that binds an access token to a cryptographic key held by the client, so a stolen token cannot be replayed by another party. Used alongside or instead of mTLS to sender-constrain tokens between MCP clients and servers. See also: Sender-Constrained Token, mTLS.
- **DPOP (Demonstrating Proof-of-Possession)** – ਇੱਕ OAuth 2.0 ਵਧੀ (RFC 9449) ਜੋ ਪਹੁੰਚ ਟੋਕਨ ਨੂੰ ਕਲਾਇੰਟ ਕੋਲ ਮੌਜੂਦ ਕ੍ਰਿਪਟੋਗ੍ਰਾਫਿਕ ਕੁੰਜੀ ਨਾਲ ਬੰਨ੍ਹ ਦਿੰਦੀ ਹੈ, ਤਾਂ ਜੋ ਚੋਰੀ ਹੋਏ ਟੋਕਨ ਨੂੰ ਕੋਈ ਹੋਰ ਧਰਿਰ replay (ਦੁਹਰਾਓ)¹⁵⁸ ਨਾ ਕਰ ਸਕੇ। ਇਹ MCP ਕਲਾਇੰਟਾਂ ਅਤੇ ਸਰਵਰਾਂ ਵਿਚਕਾਰ ਟੋਕਨਾਂ ਨੂੰ ਭੇਜਣ ਵਾਲੇ ਨਾਲ ਬੰਨ੍ਹਣ ਲਈ mTLS ਦੇ ਨਾਲ ਜਾਂ ਉਸ ਦੀ ਥਾਂ ਵਰਤੀ ਜਾਂਦੀ ਹੈ। ਇਹ ਵੀ ਵੇਖੋ: Sender-Constrained Token, mTLS।
- **DP-SGD (Differentially Private Stochastic Gradient Descent)** – A training algorithm that adds calibrated noise to gradient updates during model training to provide formal differential privacy guarantees.
- **DP-SGD (Differentially Private Stochastic Gradient Descent)** – ਇੱਕ ਸਖਿਲਾਈ ਐਲਗੋਰਿਦਮ ਜੋ ਰਸਮੀ differential privacy ਗਾਰੰਟੀਆਂ ਦੇਣ ਲਈ ਮਾਡਲ ਸਖਿਲਾਈ ਦੌਰਾਨ gradient ਅੱਪਡੇਟਾਂ ਵਿੱਚ ਮਣਿਆ-ਤੋਲਿਆ ਰੌਲਾ ਜੋੜਦਾ ਹੈ।
- **DRTM (Dynamic Root of Trust for Measurement)** – A hardware mechanism that establishes a trusted execution starting point at runtime, enabling integrity verification of AI accelerator workloads.
- **DRTM (Dynamic Root of Trust for Measurement)** – ਇੱਕ ਹਾਰਡਵੇਅਰ ਵਧੀ ਜੋ ਰਨਟਾਈਮ 'ਤੇ ਭਰੋਸੇਯੋਗ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਦਾ ਸ਼ੁਰੂਆਤੀ ਬਿੰਦੂ ਕਾਇਮ ਕਰਦੀ ਹੈ, ਜਿਸ ਨਾਲ AI ਐਕਸਲੇਰੇਟਰ ਵਰਕਲੋਡਾਂ ਦੀ ਅਖੰਡਤਾ ਤਸਦੀਕ ਸੰਭਵ ਹੁੰਦੀ ਹੈ।
- **Embedding Inversion** – An attack technique that reconstructs approximate plaintext content from vector embeddings, potentially exposing sensitive information that was assumed to be protected by the embedding transformation. Related: MITRE ATLAS AML.T0024.001. See also: Model Inversion.
- **Embedding Inversion** – ਇੱਕ ਹਮਲਾ ਤਕਨੀਕ ਜੋ ਵੈਕਟਰ embedding ਤੋਂ ਲਗਭਗ ਅਸਲ ਲਿਖਤੀ ਸਮੱਗਰੀ ਦਾ ਪੁਨਰ-ਨਰਮਾਣ ਕਰ ਲੈਂਦੀ ਹੈ, ਅਤੇ ਇਸ ਤਰ੍ਹਾਂ ਉਹ ਸੰਵੇਦਨਸ਼ੀਲ ਜਾਣਕਾਰੀ ਜਾਹਰ ਕਰ ਸਕਦੀ ਹੈ ਜਿਸ ਨੂੰ embedding ਪਰਵਿਰਤਨ ਦੁਆਰਾ ਸੁਰੱਖਿਅਤ ਮੰਨ ਲਿਆ ਗਿਆ ਸੀ। ਸੰਬੰਧਿਤ: MITRE ATLAS AML.T0024.001। ਇਹ ਵੀ ਵੇਖੋ: Model Inversion।
- **Embeddings** – Dense vector representations of data (text, images, etc.) that capture semantic meaning in a high-dimensional space.
- **Embeddings** – ਡਾਟੇ (ਲਿਖਤ, ਚਿੱਤਰ, ਆਦਿ) ਦੀਆਂ ਸੰਘਣੀਆਂ ਵੈਕਟਰ ਪ੍ਰਤੀਨਿਧਤਾਵਾਂ ਜੋ ਅਰਥ ਨੂੰ ਇੱਕ ਬਹੁ-ਆਯਾਮੀ ਥਾਂ ਵਿੱਚ ਸਾਂਭ ਲੈਂਦੀਆਂ ਹਨ।
- **Excessive Agency** – A vulnerability class in which an AI agent is granted more capability, permission, or autonomy than its task requires, allowing benign or manipulated behavior to cause disproportionate harm. Mitigated by least privilege, scoped tools, and human-in-the-loop approval for high-impact actions.
- **Excessive Agency (ਹੱਦੋਂ ਵੱਧ ਏਜੰਟ-ਸਮਰੱਥਾ)**¹⁵⁹ – ਕਮਜ਼ੋਰੀ ਦੀ ਇੱਕ ਸ਼੍ਰੇਣੀ ਜਿਸ ਵਿੱਚ ਕਸਿ AI ਏਜੰਟ ਨੂੰ ਉਸ ਦੇ ਕਾਰਜ ਦੀ ਲੋੜ ਤੋਂ ਵੱਧ ਸਮਰੱਥਾ, ਇਜਾਜ਼ਤ, ਜਾਂ ਖੁਦਮੁਖਤਾਰੀ ਦਿੱਤੀ ਜਾਂਦੀ ਹੈ, ਜਿਸ ਨਾਲ ਨਰਿਦੇਸ਼ ਜਾਂ ਹੇਰਾਫੇਰੀ ਕੀਤਾ ਵਿਵਹਾਰ ਵੀ ਬੇਤਹਾਸ਼ਾ ਨੁਕਸਾਨ ਕਰ ਸਕਦਾ ਹੈ। ਇਸ ਦਾ ਨਿਵਾਰਨ ਘੱਟੋ-ਘੱਟ-ਵਸ਼ਿਸ਼-ਅਧਿਕਾਰ, ਦਾਇਰਾ-ਬੱਧ ਟੂਲਾਂ, ਅਤੇ ਉੱਚ-ਪ੍ਰਭਾਵ ਵਾਲੀਆਂ ਕਾਰਵਾਈਆਂ ਲਈ ਮਨੁੱਖੀ ਮਨਜ਼ੂਰੀ ਰਾਹੀਂ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।
- **Exfiltration** – The unauthorized transfer of data outside a system or security boundary. In AI systems, exfiltration paths include model outputs, covert channels in generated content, tool side effects, and memory or embedding leakage.

¹⁵⁸ **replay** (EN) -> retained in Latin, glossed (ਦੁਹਰਾਓ) — corrected from an earlier draft's ਮੁੜ-ਵਰਤੋਂ, which collides with reuse elsewhere in the corpus; conforms to the C10 chapter's decision to keep replay searchable as a named attack class. Full discussion: OPEN-QUESTIONS.md Q144.

¹⁵⁹ **Excessive Agency** (EN) -> retained, glossed ਹੱਦੋਂ ਵੱਧ ਏਜੰਟ-ਸਮਰੱਥਾ — a named OWASP LLM06:2025 vulnerability class, so the English survives for catalogue cross-reference; the gloss avoids ਅਧਿਕਾਰ (already bound to authorization) and does not collapse to autonomy alone, since the source names three separate things that can be excessive. Full discussion: OPEN-QUESTIONS.md Q135.

- **ਬਾਹਰ ਕੱਢਣਾ (Exfiltration)** – ਕਸਿ ਸਸਿਟਮ ਜਾਂ ਸੁਰੱਖਿਆ ਸੀਮਾ ਤੋਂ ਬਾਹਰ ਡਾਟੇ ਦਾ ਅਣਅਧਿਕਾਰਤ ਤਬਾਦਲਾ। AI ਸਸਿਟਮਾਂ ਵਿੱਚ ਇਸ ਦੇ ਰਾਹਾਂ ਵਿੱਚ ਮਾਡਲ ਆਉਟਪੁੱਟ, ਤਿਆਰ ਕੀਤੀ ਸਮੱਗਰੀ ਵਿਚਲੇ ਲੁਕਵੇਂ ਚੈਨਲ, ਟੂਲਾਂ ਦੇ ਸਹ-ਪ੍ਰਭਾਵ¹⁶⁰ (side effects), ਅਤੇ ਮੈਮੋਰੀ ਜਾਂ embedding ਲੀਕੇਜ਼ ਸ਼ਾਮਲ ਹਨ।
- **Explainability** – The ability of an AI system to provide human-understandable reasons for its decisions and predictions, through techniques such as SHAP, LIME, attention maps, and counterfactual explanations. Also referred to as Explainable AI (XAI).
- **ਵਿਆਖਿਆਯੋਗਤਾ¹⁶¹ (Explainability)** – ਕਸਿ AI ਸਸਿਟਮ ਦੀ ਉਹ ਸਮਰੱਥਾ ਜਿਸ ਨਾਲ ਉਹ ਆਪਣੇ ਫੈਸਲਿਆਂ ਅਤੇ ਪੂਰਵ-ਅਨੁਮਾਨਾਂ ਦੇ ਮਨੁੱਖ-ਸਮਝਯੋਗ ਕਾਰਨ ਦੇ ਸਕਦਾ ਹੈ, ਜਿਵੇਂ SHAP, LIME, ਅਟੈਂਸ਼ਨ ਮੈਪ, ਅਤੇ ਵਿਪਰੀਤ-ਤੱਥ ਵਿਆਖਿਆਵਾਂ ਵਰਗੀਆਂ ਤਕਨੀਕਾਂ ਰਾਹੀਂ। ਇਸ ਨੂੰ Explainable AI (XAI) ਵੀ ਕਹਿ ਜਾਂਦਾ ਹੈ।
- **Fail-Closed / Fail-Open** – Fail-closed describes a system that defaults to a secure, blocked state when it encounters an error or component failure, preventing uncontrolled operation. Fail-open describes the inverse: operation continues unrestricted on failure. AISVS requires AI components with safety or authorization responsibilities to fail closed.
- **ਨਾਕਾਮੀ-‘ਤੇ-ਬੰਦ / ਨਾਕਾਮੀ-‘ਤੇ-ਖੁੱਲ੍ਹਾ (Fail-Closed / Fail-Open)¹⁶²** – ਨਾਕਾਮੀ-‘ਤੇ-ਬੰਦ ਉਸ ਸਸਿਟਮ ਨੂੰ ਕਹਿੰਦੇ ਹਨ ਜੋ ਗਲਤੀ ਜਾਂ ਕੰਪੋਨੈਂਟ ਦੀ ਨਾਕਾਮੀ ਹੋਣ ‘ਤੇ ਮੂਲ ਰੂਪ ਵਿੱਚ ਸੁਰੱਖਿਅਤ, ਰੋਕੀ ਹੋਈ ਸਥਿਤੀ ਵਿੱਚ ਚਲਾ ਜਾਂਦਾ ਹੈ ਅਤੇ ਬੇਕਾਬੂ ਕੰਮਕਾਜ ਨਹੀਂ ਹੋਣ ਦਿੰਦਾ। ਨਾਕਾਮੀ-‘ਤੇ-ਖੁੱਲ੍ਹਾ ਇਸ ਦਾ ਉਲਟ ਹੈ: ਨਾਕਾਮੀ ਹੋਣ ‘ਤੇ ਕੰਮਕਾਜ ਬਿਨਾਂ ਪਾਬੰਦੀ ਜਾਰੀ ਰਹਿੰਦਾ ਹੈ। AISVS ਦੀ ਲੋੜ ਹੈ ਕਿ ਸਲਾਮਤੀ ਜਾਂ ਅਧਿਕਾਰੀਕਰਨ ਦੀ ਜ਼ਿੰਮੇਵਾਰੀ ਵਾਲੇ AI ਕੰਪੋਨੈਂਟ ਨਾਕਾਮੀ-‘ਤੇ-ਬੰਦ ਹੋਣ।
- **Feature Attribution** – An interpretability method that assigns importance scores to individual input features indicating their contribution to a specific model prediction.
- **ਫੀਚਰ ਮਹੱਤਵ-ਨਿਰਧਾਰਨ (Feature Attribution)** – ਇੱਕ ਵਿਆਖਿਆਯੋਗਤਾ ਵਿਧੀ ਜੋ ਵੱਖ-ਵੱਖ ਇਨਪੁੱਟ ਫੀਚਰਾਂ ਨੂੰ ਮਹੱਤਵ ਸਕੋਰ ਦਿੰਦੀ ਹੈ, ਜੋ ਕਸਿ ਖ਼ਾਸ ਮਾਡਲ ਪੂਰਵ-ਅਨੁਮਾਨ ਵਿੱਚ ਉਹਨਾਂ ਦੇ ਯੋਗਦਾਨ ਨੂੰ ਦਰਸਾਉਂਦੇ ਹਨ।
- **Federated Learning** – A machine learning approach where models are trained across multiple decentralized devices holding local data samples, without exchanging the data itself.
- **ਫੈਡਰੇਟਡ ਲਰਨਿੰਗ (Federated Learning)** – ਮਸ਼ੀਨ ਲਰਨਿੰਗ ਦੀ ਇੱਕ ਪਹੁੰਚ-ਵਿਧੀ ਜਿਸ ਵਿੱਚ ਮਾਡਲਾਂ ਨੂੰ ਸਥਾਨਕ ਡਾਟਾ ਨਮੂਨੇ ਰੱਖਣ ਵਾਲੇ ਕਈ ਗੈਰ-ਕੇਂਦਰੀਕਰਤ ਯੰਤਰਾਂ ਉੱਤੇ ਸਥਿਲਾਈ ਦਿੱਤੀ ਜਾਂਦੀ ਹੈ, ਬਿਨਾਂ ਡਾਟੇ ਦਾ ਆਪਸੀ ਵਟਾਂਦਰਾ ਕੀਤੇ।
- **Fine-tuning** – The process of continuing to train a pre-trained model on a smaller, task-specific dataset to adapt it for a particular use case.
- **ਫਾਈਨ-ਟਿਊਨਿੰਗ (Fine-tuning)** – ਕਸਿ ਪਹਿਲਾਂ-ਸਥਿਲਾਈ-ਪਰਾਪਤ ਮਾਡਲ ਨੂੰ ਕਸਿ ਖ਼ਾਸ ਵਰਤੋਂ-ਹਾਲਤ ਲਈ ਢਾਲਣ ਵਾਸਤੇ ਉਸ ਨੂੰ ਇੱਕ ਛੋਟੇ, ਕਾਰਜ-ਵਿਸ਼ੇਸ਼ ਡਾਟਾਸੈੱਟ ਉੱਤੇ ਅੱਗੇ ਸਥਿਲਾਈ ਦਿੱਤੀ ਰਹਿਣ ਦੀ ਪ੍ਰਕਿਰਿਆ।
- **FIPS 140-3** – A U.S. government standard that defines security requirements for cryptographic modules, with Level 3 requiring physical tamper-resistance and identity-based authentication.
- **FIPS 140-3** – ਇੱਕ ਅਮਰੀਕੀ ਸਰਕਾਰੀ ਮਿਆਰ ਜੋ ਕ੍ਰਿਪਟੋਗ੍ਰਾਫਿਕ ਮਾਡਿਊਲਾਂ ਲਈ ਸੁਰੱਖਿਆ ਲੋੜਾਂ ਪਰਭਾਸ਼ਿਤ ਕਰਦਾ ਹੈ; ਇਸ ਦੇ Level 3 ਲਈ ਭੌਤਿਕ ਛੇੜਛਾੜ-ਰੋਧਕਤਾ ਅਤੇ ਪਛਾਣ-ਆਧਾਰਤ ਪ੍ਰਮਾਣੀਕਰਨ ਲਾਜ਼ਮੀ ਹੈ।
- **Guardrails** – Constraints implemented to prevent AI systems from producing harmful, biased, or otherwise undesirable outputs.

¹⁶⁰ **side effects** (EN) -> ਸਹ-ਪ੍ਰਭਾਵ — corrected from an earlier draft’s ਮਾੜੇ ਪ੍ਰਭਾਵ (“adverse effects”), a value judgement the source does not make; matches the gloss already used elsewhere in the corpus for the same English term. Full discussion: OPEN-QUESTIONS.md Q144.

¹⁶¹ **Explainability** (EN) -> ਵਿਆਖਿਆਯੋਗਤਾ — built with the -ਯੋਗਤਾ property-noun suffix, matching how the corpus already forms ਟਰੇਸਯੋਗਤਾ (traceability); kept distinct from ਪਾਰਦਰਸ਼ਤਾ (transparency), a separate governance concept elsewhere in the corpus. Full discussion: OPEN-QUESTIONS.md Q120.

¹⁶² **Fail-Closed / Fail-Open** (EN) -> ਨਾਕਾਮੀ-‘ਤੇ-ਬੰਦ / ਨਾਕਾਮੀ-‘ਤੇ-ਖੁੱਲ੍ਹਾ — the literal compound pair was chosen over the shorter transliterated loan because the source states the control as one and names its opposite as the corresponding pitfall, and only the literal compound inverts cleanly for both. Full discussion: OPEN-QUESTIONS.md Q104.

- **ਗਾਰਡਰੇਲ**¹⁶³ (**Guardrails**) – ਉਹ ਪਾਬੰਦੀਆਂ ਜੋ AI ਸਸਿਟਮਾਂ ਨੂੰ ਨੁਕਸਾਨਦੇਹ, ਪੱਖਪਾਤੀ, ਜਾਂ ਹੋਰ ਪੱਖੋਂ ਅਣਚਾਹੇ ਆਉਟਪੁੱਟ ਪੈਦਾ ਕਰਨ ਤੋਂ ਰੋਕਣ ਲਈ ਲਾਗੂ ਕੀਤੀਆਂ ਜਾਂਦੀਆਂ ਹਨ।
- **Hallucination** – A phenomenon where an AI model generates incorrect or misleading information that is not grounded in its training data, retrieved context, or factual reality.
- **hallucination (ਮਨਘੜਤ ਸਮੱਗਰੀ)** – ਇੱਕ ਵਰਤਾਰਾ ਜਿਸ ਵਿੱਚ ਕੋਈ AI ਮਾਡਲ ਗਲਤ ਜਾਂ ਗੁੰਮਰਾਹਕੁੰਨ ਜਾਣਕਾਰੀ ਤਿਆਰ ਕਰਦਾ ਹੈ ਜੋ ਉਸ ਦੇ ਸਖਿਲਾਈ ਡਾਟੇ, ਪ੍ਰਾਪਤ ਕੀਤੇ ਸੰਦਰਭ, ਜਾਂ ਤੱਥਾਂ ਦੀ ਅਸਲੀਅਤ ਉੱਤੇ ਆਧਾਰਿਤ ਨਹੀਂ ਹੁੰਦੀ।
- **Homoglyph** – A character that visually resembles another character from a different script or encoding (e.g., Cyrillic “a” U+0430 vs. Latin “a” U+0061), exploited in attacks to bypass text-based input validation.
- **homoglyph (ਸਮਰੂਪ ਅੱਖਰ)** – ਅਜਿਹਾ ਅੱਖਰ ਜੋ ਕਿਸੇ ਵੱਖਰੀ ਲਿਪੀ ਜਾਂ ਏਨਕੋਡਿੰਗ ਦੇ ਕਿਸੇ ਹੋਰ ਅੱਖਰ ਵਰਗਾ ਦਿਸਦਾ ਹੈ (ਜਵਿ, ਸਰਿਲਿਕਿ “a” U+0430 ਬਨਾਮ ਲਾਤੀਨੀ “a” U+0061), ਅਤੇ ਲਖਿਤ-ਆਧਾਰਿਤ ਇਨਪੁੱਟ ਪ੍ਰਮਾਣਿਕਤਾ ਨੂੰ ਬਾਈਪਾਸ ਕਰਨ ਵਾਲੇ ਹਮਲਿਆਂ ਵਿੱਚ ਵਰਤਿਆ ਜਾਂਦਾ ਹੈ।
- **HSM (Hardware Security Module)** – A dedicated physical device that manages, processes, and stores cryptographic keys in a tamper-resistant environment.
- **HSM (Hardware Security Module — ਹਾਰਡਵੇਅਰ ਸੁਰੱਖਿਆ ਮਾਡਿਊਲ)** – ਇੱਕ ਸਮਰਪਤ ਭੌਤਿਕ ਯੰਤਰ ਜੋ ਛੇੜਛਾੜ-ਰੋਧਕ ਵਾਤਾਵਰਣ ਵਿੱਚ ਕ੍ਰਿਪਟੋਗ੍ਰਾਫਿਕ ਕੁੰਜੀਆਂ ਦਾ ਪ੍ਰਬੰਧਨ, ਪ੍ਰਕਰਿਆ, ਅਤੇ ਭੰਡਾਰਨ ਕਰਦਾ ਹੈ।
- **Human-in-the-Loop (HITL)** – Systems designed to require human oversight, verification, or intervention at crucial decision points.
- **Human-in-the-Loop (HITL — ਮਨੁੱਖੀ ਦਖਲ ਸਮੇਤ)** – ਅਜਿਹੇ ਸਸਿਟਮ ਜੋ ਇਸ ਤਰ੍ਹਾਂ ਡਿਜ਼ਾਈਨ ਕੀਤੇ ਗਏ ਹੋਣ ਕੀ ਅਹਮਿ ਫ਼ੈਸਲਾ-ਬਣਦਿਆਂ ਉੱਤੇ ਮਨੁੱਖੀ ਨਿਗਰਾਨੀ, ਤਸਦੀਕ, ਜਾਂ ਦਖਲ ਲਾਜ਼ਮੀ ਹੋਵੇ।
- **Indirect Prompt Injection** – A prompt injection attack where the malicious instructions are not supplied directly by the user but are embedded in external content the model later consumes, such as a retrieved document, web page, email, or tool output. Because the agent treats that content as trusted context, the injected instructions can hijack its behavior. See also: Prompt Injection.
- **ਅਸਧਿੱ ਪ੍ਰਮਪਟ ਇੰਜੈਕਸ਼ਨ (Indirect Prompt Injection)** – ਪ੍ਰਮਪਟ ਇੰਜੈਕਸ਼ਨ ਦਾ ਅਜਿਹਾ ਹਮਲਾ ਜਿਸ ਵਿੱਚ ਖ਼ਤਰਨਾਕ ਹਦਾਇਤਾਂ ਉਪਭੋਗਤਾ ਸਧਿ ਤੋਂ ਨਹੀਂ ਦਿੰਦੀ, ਸਗੋਂ ਉਹ ਬਾਹਰੀ ਸਮੱਗਰੀ ਵਿੱਚ ਜੜੀਆਂ ਹੁੰਦੀਆਂ ਹਨ ਜਿਸ ਨੂੰ ਮਾਡਲ ਬਾਅਦ ਵਿੱਚ ਵਰਤਦਾ ਹੈ, ਜਵਿ ਕੋਈ ਪ੍ਰਾਪਤ ਕੀਤਾ ਦਸਤਾਵੇਜ਼, ਵੈੱਬ ਪੰਨਾ, ਈਮੇਲ, ਜਾਂ ਟੂਲ ਆਉਟਪੁੱਟ। ਕਉਂਕਿ ਏਜੰਟ ਉਸ ਸਮੱਗਰੀ ਨੂੰ ਭਰੋਸੇਯੋਗ ਸੰਦਰਭ ਮੰਨ ਲੈਂਦਾ ਹੈ, ਇਸ ਲਈ ਜੜੀਆਂ ਹੋਈਆਂ ਹਦਾਇਤਾਂ ਉਸ ਦੇ ਵਿਵਹਾਰ ਨੂੰ ਹਾਈਜੈਕ ਕਰ ਸਕਦੀਆਂ ਹਨ। ਇਹ ਵੀ ਵੇਖੋ: Prompt Injection।
- **Inference** – The process of running a trained model on new input to produce an output, as distinct from training. Inference time is when the system prompt, user input, retrieved context, and tool outputs are combined and processed, and is the point at which many runtime controls apply.
- **ਇਨਫ਼ਰੈਂਸ (Inference)** – ਆਉਟਪੁੱਟ ਪੈਦਾ ਕਰਨ ਲਈ ਸਖਿਲਾਈ-ਪ੍ਰਾਪਤ ਮਾਡਲ ਨੂੰ ਨਵੇਂ ਇਨਪੁੱਟ ਉੱਤੇ ਚਲਾਉਣ ਦੀ ਪ੍ਰਕਰਿਆ, ਜੋ ਸਖਿਲਾਈ ਤੋਂ ਵੱਖਰੀ ਹੈ। ਇਨਫ਼ਰੈਂਸ ਦਾ ਸਮਾਂ ਉਹ ਹੁੰਦਾ ਹੈ ਜਦੋਂ system prompt, ਉਪਭੋਗਤਾ ਇਨਪੁੱਟ, ਪ੍ਰਾਪਤ ਕੀਤਾ ਸੰਦਰਭ, ਅਤੇ ਟੂਲ ਆਉਟਪੁੱਟ ਜੋੜ ਕੇ ਪ੍ਰਕਰਿਆ ਕੀਤੇ ਜਾਂਦੇ ਹਨ, ਅਤੇ ਇਹੀ ਉਹ ਬਿੰਦੂ ਹੈ ਜਥਿ ਕਈ ਰਨਟਾਈਮ ਨਿਯੰਤਰਣ ਲਾਗੂ ਹੁੰਦੇ ਹਨ।
- **Infrastructure as Code (IaC)** – Managing and provisioning infrastructure through code instead of manual processes, enabling security scanning and consistent deployments.
- **Infrastructure as Code (IaC — ਕੋਡ ਵਜੋਂ ਬੁਨਿਆਦੀ ਢਾਂਚਾ)** – ਹੱਥੀਂ ਕੀਤੀਆਂ ਪ੍ਰਕਰਿਆਵਾਂ ਦੀ ਥਾਂ ਕੋਡ ਰਾਹੀਂ ਬੁਨਿਆਦੀ ਢਾਂਚੇ ਦਾ ਪ੍ਰਬੰਧਨ ਅਤੇ ਪ੍ਰਵਾਧਾਨ ਕਰਨਾ, ਜਿਸ ਨਾਲ ਸੁਰੱਖਿਆ ਸਕੈਨਿੰਗ ਅਤੇ ਇਕਸਾਰ ਤੈਨਾਤੀਆਂ ਸੰਭਵ ਹੁੰਦੀਆਂ ਹਨ।
- **Interval-Bound Propagation** – A formal verification technique that propagates bounds through neural network layers to certify that model predictions are robust within specified input perturbation ranges.

¹⁶³ **guardrail** (EN) -> ਗਾਰਡਰੇਲ — kept as a neutral loan after excluding ਮਰਿਆਦਾ, which names the Sikh code of conduct and would be a Gurmatsafety violation if applied to a machine constraint. Full discussion: OPEN-QUESTIONS.md Q105.

- **Interval-Bound Propagation** – ਇੱਕ ਰਸਮੀ ਤਸਦੀਕ ਤਕਨੀਕ ਜੋ ਨਿਊਰਲ ਨੈੱਟਵਰਕ ਦੀਆਂ ਪਰਤਾਂ ਵਿੱਚ ਸੀਮਾਵਾਂ ਨੂੰ ਅੱਗੇ ਵਧਾਉਂਦੀ ਹੈ ਤਾਂ ਜੋ ਇਹ ਸਰਟੀਫਾਈ ਕੀਤਾ ਜਾ ਸਕੇ ਕਿ ਨਿਰਧਾਰਤ ਇਨਪੁੱਟ ਵਰਗੇ ਦਾਇਰਿਆਂ ਦੇ ਅੰਦਰ ਮਾਡਲ ਦੇ ਪੂਰਵ-ਅਨੁਮਾਨ ਮਜ਼ਬੂਤ ਰਹਦੇ ਹਨ।
- **Jailbreak** – Techniques used to circumvent safety guardrails in AI systems, particularly in large language models, to produce prohibited content.
- **jailbreak** – AI ਸਿਸਟਮਾਂ ਵਿੱਚ, ਖਾਸ ਕਰਕੇ ਵੱਡੇ ਭਾਸ਼ਾ ਮਾਡਲਾਂ ਵਿੱਚ, ਮਨਾਹੀ ਵਾਲੀ ਸਮੱਗਰੀ ਤਿਆਰ ਕਰਵਾਉਣ ਲਈ ਸਲਾਮਤੀ ਗਾਰਡਰੇਲਾਂ ਤੋਂ ਬਚ ਨਿਕਲਣ ਵਾਸਤੇ ਵਰਤੀਆਂ ਜਾਂਦੀਆਂ ਤਕਨੀਕਾਂ।
- **JIT (Just-in-Time) Privileged Access** – A security practice where elevated permissions are granted only for a short, defined window when needed for a specific task and automatically revoked afterward, minimizing standing privilege exposure.
- **JIT (Just-in-Time) ਵਸ਼ਿਸ਼-ਅਧਿਕਾਰ ਪ੍ਰਾਪਤ ਪਹੁੰਚ** – ਇੱਕ ਸੁਰੱਖਿਆ ਅਭਿਆਸ ਜਿਸ ਵਿੱਚ ਉੱਚੀਆਂ ਇਜਾਜ਼ਤਾਂ ਕਸ਼ਿ ਖਾਸ ਕਾਰਜ ਦੀ ਲੋੜ ਪੈਣ 'ਤੇ ਸਰਿਫ਼ ਇੱਕ ਥੋੜ੍ਹੀ, ਪਰਭਿਸ਼ਤਿ ਮਿਆਦ ਲਈ ਦੱਤੀਆਂ ਜਾਂਦੀਆਂ ਹਨ ਅਤੇ ਬਾਅਦ ਵਿੱਚ ਆਪਣੇ-ਆਪ ਵਾਪਸ ਲੈ ਲਈਆਂ ਜਾਂਦੀਆਂ ਹਨ, ਜਿਸ ਨਾਲ ਸਥਾਈ ਵਸ਼ਿਸ਼-ਅਧਿਕਾਰ ਦਾ ਖ਼ਤਰਾ ਘੱਟੋ-ਘੱਟ ਰਹਿੰਦਾ ਹੈ।
- **JWT (JSON Web Token)** – A compact, self-contained token format for securely transmitting identity and authorization claims between parties, signed to ensure integrity.
- **JWT (JSON Web Token)** – ਇੱਕ ਸੰਖੇਪ, ਸਵੈ-ਨਰਿਭਰ ਟੋਕਨ ਫ਼ਾਰਮੈਟ ਜੋ ਧਰੀਂ ਵਿਚਕਾਰ ਪਛਾਣ ਅਤੇ ਅਧਿਕਾਰੀਕਰਨ ਦੇ ਦਾਅਵੇ ਸੁਰੱਖਿਅਤ ਢੰਗ ਨਾਲ ਭੇਜਣ ਲਈ ਵਰਤਿਆ ਜਾਂਦਾ ਹੈ, ਅਤੇ ਅਖੰਡਤਾ ਯਕੀਨੀ ਬਣਾਉਣ ਲਈ ਦਸਤਖ਼ਤ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।
- **k-anonymity** – A privacy property where each record in a dataset is indistinguishable from at least k-1 other records with respect to certain identifying attributes.
- **k-anonymity** – ਇੱਕ ਨਜ਼ਿਤਾ ਗੁਣ ਜਿਸ ਵਿੱਚ ਡਾਟਾਸੈੱਟ ਦਾ ਹਰ ਰਕਿਾਰਡ ਕੁਝ ਖਾਸ ਪਛਾਣ-ਗੁਣਾਂ ਦੇ ਪੱਖੋਂ ਘੱਟੋ-ਘੱਟ k-1 ਹੋਰ ਰਕਿਾਰਡਾਂ ਤੋਂ ਵੱਖਰਾ ਨਹੀਂ ਕੀਤਾ ਜਾ ਸਕਦਾ।
- **Kill-Switch** – A mechanism to immediately halt AI model inference, agent execution, or system outputs on command or in response to a safety trigger. Kill-switches for autonomous agents must be delivered through a channel the agent runtime cannot access or suppress, so that a compromised agent cannot block its own shutdown.
- **kill-switch (ਤੁਰੰਤ-ਬੰਦ ਸਵਿੱਚ)** – ਇੱਕ ਵਧੀ ਜੋ ਹੁਕਮ ਮਲਿਣ 'ਤੇ ਜਾਂ ਕਸ਼ਿ ਸਲਾਮਤੀ ਟ੍ਰਗਿਰ ਦੇ ਜਵਾਬ ਵਿੱਚ AI ਮਾਡਲ ਦੇ ਇਨਫ਼ਰੈਂਸ, ਏਜੰਟ ਦੇ ਐਗਜ਼ੀਕਿਊਸ਼ਨ, ਜਾਂ ਸਿਸਟਮ ਦੇ ਆਉਟਪੁੱਟ ਨੂੰ ਤੁਰੰਤ ਰੋਕ ਦਿੰਦੀ ਹੈ। ਖ਼ੁਦਮੁਖ਼ਤਾਰ ਏਜੰਟਾਂ ਲਈ kill-switch ਅਜਹਿ ਚੈਨਲ ਰਾਹੀਂ ਪਹੁੰਚਾਇਆ ਜਾਣਾ ਲਾਜ਼ਮੀ ਹੈ ਜਿਸ ਤੱਕ ਏਜੰਟ ਰਨਟਾਈਮ ਦੀ ਨਾ ਪਹੁੰਚ ਹੋਵੇ ਅਤੇ ਨਾ ਹੀ ਉਸ ਨੂੰ ਦਬਾ ਸਕੇ, ਤਾਂ ਜੋ ਭੰਗ ਹੋ ਚੁੱਕਾ ਏਜੰਟ ਆਪਣੇ ਹੀ ਬੰਦ ਹੋਣ ਨੂੰ ਨਾ ਰੋਕ ਸਕੇ।
- **KMS (Key Management Service)** – A managed service for creating, storing, rotating, and controlling access to cryptographic keys used to protect data and artifacts.
- **KMS (Key Management Service)** – ਇੱਕ ਪ੍ਰਬੰਧਤਿ ਸੇਵਾ ਜੋ ਡਾਟੇ ਅਤੇ ਆਰਟੀਫ਼ੈਕਟਾਂ ਦੀ ਰਾਖੀ ਲਈ ਵਰਤੀਆਂ ਜਾਂਦੀਆਂ ਕ੍ਰਿਪਟੋਗ੍ਰਾਫ਼ਿਕ ਕੁੰਜੀਆਂ ਬਣਾਉਣ, ਸਾਂਭਣ, ਬਦਲਣ, ਅਤੇ ਉਹਨਾਂ ਤੱਕ ਪਹੁੰਚ ਨੂੰ ਨਿਯੰਤਰਤਿ ਕਰਨ ਦਾ ਕੰਮ ਕਰਦੀ ਹੈ।
- **Labeling** – The process of assigning classification tags, annotations, or ground-truth values to training data records or fields, performed by human annotators, automated systems, or a combination of both. Labeling encompasses the full annotation pipeline including annotator identity tracking, label integrity verification, and preference data collection for RLHF.
- **ਲੇਬਲਿੰਗ (Labeling)** – ਸਖਿਲਾਈ ਡਾਟੇ ਦੇ ਰਕਿਾਰਡਾਂ ਜਾਂ ਖੇਤਰਾਂ ਨੂੰ ਵਰਗੀਕਰਨ ਟੈਗ, ਐਨੋਟੇਸ਼ਨਾਂ, ਜਾਂ ground-truth ਮੁੱਲ¹⁶⁴ ਦੇਣ ਦੀ ਪ੍ਰਕ੍ਰਿਅਿਆ, ਜੋ ਮਨੁੱਖੀ ਐਨੋਟੇਟਰਾਂ, ਸਵੈਚਲਤਿ ਸਿਸਟਮਾਂ, ਜਾਂ ਦੋਵਾਂ ਦੇ ਸੁਮੇਲ ਦੁਆਰਾ ਕੀਤੀ ਜਾਂਦੀ ਹੈ। ਲੇਬਲਿੰਗ ਪੂਰੀ ਐਨੋਟੇਸ਼ਨ ਪਾਈਪਲਾਈਨ ਨੂੰ ਸਮੇਟਦੀ ਹੈ, ਜਿਸ ਵਿੱਚ ਐਨੋਟੇਟਰ ਦੀ ਪਛਾਣ ਦੀ ਟਰੈਕਿੰਗ, ਲੇਬਲ ਅਖੰਡਤਾ ਦੀ ਤਸਦੀਕ, ਅਤੇ RLHF ਲਈ ਤਰਜੀਹ ਡਾਟੇ ਦਾ ਇਕੱਤਰੀਕਰਨ ਸ਼ਾਮਲ ਹੈ।

¹⁶⁴ **ground-truth values** (EN) -> ground-truth ਮੁੱਲ — corrected from an earlier draft's ਮੂਲ-ਸੱਚ ਮੁੱਲ; ਸੱਚ/ਸਤੀ is load-bearing devotional vocabulary for Divine Truth in Gurbani and is rejected corpus-wide for this reason, so the retained Latin head plus ਮੁੱਲ was substituted instead. Full discussion: OPEN-QUESTIONS.md Q144.

- **l-diversity** – A privacy property extending k-anonymity that requires each equivalence class to contain at least l distinct values for sensitive attributes, preventing attribute disclosure.
- **l-diversity** – k-anonymity ਨੂੰ ਅੱਗੇ ਵਧਾਉਣ ਵਾਲਾ ਇੱਕ ਨਜ਼ਰੀਆ ਗੁਣ, ਜਿਸ ਅਨੁਸਾਰ ਹਰ ਸਮਾਨਤਾ-ਸ਼੍ਰੇਣੀ ਵਿੱਚ ਸੰਵੇਦਨਸ਼ੀਲ ਗੁਣਾਂ ਲਈ ਘੱਟੋ-ਘੱਟ l ਵੱਖਰੇ ਮੁੱਲ ਹੋਣੇ ਲਾਜ਼ਮੀ ਹਨ, ਤਾਂ ਜੋ ਗੁਣਾਂ ਦਾ ਖੁਲਾਸਾ ਰੋਕਿਆ ਜਾ ਸਕੇ।
- **Least Privilege** – The security principle of granting only the minimum necessary access rights for users and processes.
- **ਘੱਟੋ-ਘੱਟ-ਵਸ਼ਿਸਤ-ਅਧਿਕਾਰ (Least Privilege)** – ਉਹ ਸੁਰੱਖਿਆ ਅਸੂਲ ਕਿ ਉਪਭੋਗਤਾਵਾਂ ਅਤੇ ਪ੍ਰਕਿਰਿਆਵਾਂ ਨੂੰ ਸਰਿਫ਼ ਘੱਟੋ-ਘੱਟ ਲੋੜੀਂਦੇ ਪਹੁੰਚ ਹੱਕ ਹੀ ਦਿੱਤੇ ਜਾਣ।
- **LIME (Local Interpretable Model-agnostic Explanations)** – A technique to explain the predictions of any machine learning classifier by approximating it locally with an interpretable model.
- **LIME (Local Interpretable Model-agnostic Explanations)** – ਕਸਿ ਵੀ ਮਸ਼ੀਨ ਲਰਨਿੰਗ ਵਰਗੀਕਾਰ ਦੇ ਪੂਰਵ-ਅਨੁਮਾਨਾਂ ਦੀ ਵਿਆਖਿਆ ਕਰਨ ਦੀ ਇੱਕ ਤਕਨੀਕ, ਜਿਸ ਵਿੱਚ ਉਸ ਨੂੰ ਸਥਾਨਕ ਤੌਰ 'ਤੇ ਇੱਕ ਵਿਆਖਿਆਯੋਗ ਮਾਡਲ ਨਾਲ ਲਗਭਗ ਦਰਸਾਇਆ ਜਾਂਦਾ ਹੈ।
- **Linkage Attack** – An attack that combines quasi-identifiers across multiple datasets to re-identify individuals whose data was supposedly anonymized.
- **Linkage Attack (ਜੋੜ-ਮੇਲ ਹਮਲਾ)** – ਇੱਕ ਅਜਿਹਾ ਹਮਲਾ ਜੋ ਕਈ ਡਾਟਾਸੈੱਟਾਂ ਵਿਚਲੇ ਅਰਧ-ਪਛਾਣਕਰਤਾਵਾਂ ਨੂੰ ਜੋੜ ਕੇ ਉਹਨਾਂ ਵਿਅਕਤੀਆਂ ਦੀ ਮੁੜ-ਪਛਾਣ ਕਰ ਲੈਂਦਾ ਹੈ ਜਿਨ੍ਹਾਂ ਦਾ ਡਾਟਾ ਕਥਿਤ ਤੌਰ 'ਤੇ ਗੁਪਤਮਾਨ ਕੀਤਾ ਗਿਆ ਸੀ।
- **LLM (Large Language Model)** – A neural network, typically transformer-based, trained on large text corpora to predict and generate language; the core model type behind most generative AI applications, assistants, and agents.
- **LLM (Large Language Model)** – ਇੱਕ ਨਿਊਰਲ ਨੈੱਟਵਰਕ, ਆਮ ਤੌਰ 'ਤੇ transformer-ਆਧਾਰਿਤ, ਜਿਸ ਨੂੰ ਭਾਸ਼ਾ ਦਾ ਪੂਰਵ-ਅਨੁਮਾਨ ਲਾਉਣ ਅਤੇ ਭਾਸ਼ਾ ਤਿਆਰ ਕਰਨ ਲਈ ਵੱਡੇ ਲਿਖਤੀ ਭੰਡਾਰਾਂ ਉੱਤੇ ਸਿਖਲਾਈ ਦਿੱਤੀ ਜਾਂਦੀ ਹੈ; ਇਹ ਬਹੁਤੀਆਂ ਜਨਰੇਟਿਵ AI ਐਪਲੀਕੇਸ਼ਨਾਂ, ਸਹਾਇਕਾਂ, ਅਤੇ ਏਜੰਟਾਂ ਪਿੱਛੇ ਦੀ ਮੂਲ ਮਾਡਲ ਕਸਿਮ ਹੈ।
- **Machine Unlearning** – Techniques to remove the influence of specific training data from a trained model, supporting data subject deletion requests and regulatory compliance.
- **ਮਸ਼ੀਨ ਅਨਲਰਨਿੰਗ¹⁶⁵ (Machine Unlearning)** – ਉਹ ਤਕਨੀਕਾਂ ਜੋ ਕਸਿ ਸਿਖਲਾਈ-ਪ੍ਰਰਾਪਤ ਮਾਡਲ ਵਿੱਚੋਂ ਖ਼ਾਸ ਸਿਖਲਾਈ ਡਾਟੇ ਦਾ ਅਸਰ ਹਟਾ ਦਿੰਦੀਆਂ ਹਨ, ਜਿਸ ਨਾਲ ਡਾਟਾ ਵਸ਼ਿਸ਼ਟੀ ਦੀਆਂ ਮਹਿਮਤਾਵਾਂ ਦੀਆਂ ਬੇਨਤੀਆਂ ਅਤੇ ਨਿਯਮਕ ਪਾਲਣਾ ਦਾ ਸਮਰਥਨ ਹੁੰਦਾ ਹੈ।
- **Many-Shot Jailbreaking** – An attack technique that embeds a large number of fabricated user-model exchange pairs in the context window to shift the model's apparent behavioral pattern and override its safety guardrails through accumulated in-context examples.
- **many-shot jailbreaking** – ਇੱਕ ਹਮਲਾ ਤਕਨੀਕ ਜੋ ਸੰਦਰਭ ਵਿੱਚ ਉਪਭੋਗਤਾ-ਮਾਡਲ ਵਟਾਂਦਰੇ ਦੇ ਵੱਡੀ ਗਣਿਤੀ ਵਿੱਚ ਘੜੇ ਹੋਏ ਜੋੜੇ ਜੜ ਦਿੰਦੀ ਹੈ, ਤਾਂ ਜੋ ਮਾਡਲ ਦਾ ਪ੍ਰਤੱਖ ਵਿਵਹਾਰਕ ਪੈਟਰਨ ਬਦਲਿਆ ਜਾ ਸਕੇ ਅਤੇ ਸੰਦਰਭ ਵਿੱਚ ਇਕੱਠੀਆਂ ਹੋਈਆਂ ਉਦਾਹਰਨਾਂ ਰਾਹੀਂ ਉਸ ਦੀਆਂ ਸਲਾਮਤੀ ਗਾਰੰਟੀਆਂ ਓਵਰਰਾਈਡ ਹੋ ਜਾਣ।
- **MCP (Model Context Protocol)** – A protocol that enables AI models and agents to access external tools, data sources, and resources by exchanging structured, typed requests and responses over a defined transport.
- **MCP (Model Context Protocol)** – ਇੱਕ ਪ੍ਰੋਟੋਕੋਲ ਜੋ AI ਮਾਡਲਾਂ ਅਤੇ ਏਜੰਟਾਂ ਨੂੰ ਬਾਹਰੀ ਟੂਲਾਂ, ਡਾਟਾ ਸਰੋਤਾਂ, ਅਤੇ ਸਰੋਤਾਂ ਤੱਕ ਪਹੁੰਚ ਦਿੰਦਾ ਹੈ, ਇੱਕ ਪਰਿਭਾਸ਼ਿਤ ਟ੍ਰਾਂਸਪੋਰਟ ਉੱਤੇ ਢਾਂਚਾਗਤ, ਕਸਿਮ-ਬੱਧ ਬੇਨਤੀਆਂ ਅਤੇ ਜਵਾਬਾਂ ਦੇ ਵਟਾਂਦਰੇ ਰਾਹੀਂ।

¹⁶⁵ **Machine Unlearning** (EN) -> ਮਸ਼ੀਨ ਅਨਲਰਨਿੰਗ — kept as a loan because every native candidate for “unlearning” runs through a verb of forgetting, and Panjabi’s formal register for that reaches into ਸਮਿਰਨ-adjacent devotional vocabulary. Full discussion: OPEN-QUESTIONS.md Q132.

- **Membership Inference Attack** – An attack that aims to determine whether a specific data point was used to train a machine learning model.
- **membership inference ਹਮਲਾ** – ਇੱਕ ਅਜਿਹਾ ਹਮਲਾ ਜਿਸ ਦਾ ਮਕਸਦ ਇਹ ਪਤਾ ਲਗਾਉਣਾ ਹੁੰਦਾ ਹੈ ਕਿ ਕੋਈ ਖਾਸ ਡਾਟਾ ਬਿੰਦੂ ਕੀਸੇ ਮਸ਼ੀਨ ਲਰਨਿੰਗ ਮਾਡਲ ਦੀ ਸਿਖਲਾਈ ਵਿੱਚ ਵਰਤਿਆ ਗਿਆ ਸੀ ਜਾਂ ਨਹੀਂ।
- **MIG (Multi-Instance GPU)** – An NVIDIA technology that partitions a single GPU into multiple isolated instances, each with dedicated memory and compute resources for secure multi-tenant workloads.
- **MIG (Multi-Instance GPU)** – ਇੱਕ NVIDIA ਤਕਨਾਲੋਜੀ ਜੋ ਇੱਕੋ GPU ਨੂੰ ਕਈ ਅਲੱਗ-ਥਲੱਗ ਇੰਸਟਾਂਸਾਂ ਵਿੱਚ ਵੰਡ ਦਿੰਦੀ ਹੈ, ਜਿਨ੍ਹਾਂ ਵਿੱਚੋਂ ਹਰ ਇੱਕ ਕੋਲ ਸੁਰੱਖਿਅਤ ਬਹੁ-ਟੈਨੈਂਟ ਵਰਕਲੋਡਾਂ ਲਈ ਸਮਰਪਤਿ ਮੈਮੋਰੀ ਅਤੇ ਗਣਨਾ ਸਰੋਤ ਹੁੰਦੇ ਹਨ।
- **MITRE ATLAS** – Adversarial Threat Landscape for Artificial-Intelligence Systems; a knowledge base of adversarial tactics and techniques against AI systems.
- **MITRE ATLAS** – Adversarial Threat Landscape for Artificial-Intelligence Systems; AI ਸਿਸਟਮਾਂ ਵਿਰੁੱਧ ਵਰਤੋਂਯੋਗ ਦਾਅ-ਪੇਚਾਂ ਅਤੇ ਤਕਨੀਕਾਂ ਦਾ ਇੱਕ ਗਿਆਨ-ਭੰਡਾਰ।
- **Model Card** – A document that provides standardized information about an AI model's performance, limitations, intended uses, and ethical considerations to promote transparency and responsible AI development.
- **ਮਾਡਲ ਕਾਰਡ (Model Card)** – ਇੱਕ ਦਸਤਾਵੇਜ਼ ਜੋ ਕਿਸੇ AI ਮਾਡਲ ਦੀ ਕਾਰਗੁਜ਼ਾਰੀ, ਸੀਮਾਵਾਂ, ਇੱਛਤ ਵਰਤੋਂ, ਅਤੇ ਨੈਤਿਕ ਪੱਖਾਂ ਬਾਰੇ ਮਿਆਰੀ ਜਾਣਕਾਰੀ ਦਿੰਦਾ ਹੈ, ਤਾਂ ਜੋ ਪਾਰਦਰਸ਼ਤਾ ਅਤੇ ਜ਼ਿੰਮੇਵਾਰ AI ਵਿਕਾਸ ਨੂੰ ਉਤਸ਼ਾਹ ਮਿਲੇ।
- **Model Extraction** – An attack where an adversary repeatedly queries a target model to create a functionally similar copy without authorization. Also referred to as model stealing or model theft.
- **model extraction (ਮਾਡਲ ਚੋਰੀ)** – ਇੱਕ ਅਜਿਹਾ ਹਮਲਾ ਜਿਸ ਵਿੱਚ ਹਮਲਾਵਰ ਕਿਸੇ ਨਸ਼ਿਆਂ ਮਾਡਲ ਨੂੰ ਵਾਰ-ਵਾਰ ਕੀਊਰੀ ਕਰਕੇ, ਬਿਨਾਂ ਅਧਿਕਾਰ ਦੇ, ਕਾਰਜ-ਪੱਖੋਂ ਮਲਿਦੀ-ਜੁਲਦੀ ਨਕਲ ਬਣਾ ਲੈਂਦਾ ਹੈ। ਇਸ ਨੂੰ model stealing ਜਾਂ model theft ਵੀ ਕਹਿ ਜਾਂਦਾ ਹੈ।
- **Model Inversion** – An attack that attempts to reconstruct training data by analyzing model outputs.
- **model inversion** – ਇੱਕ ਅਜਿਹਾ ਹਮਲਾ ਜੋ ਮਾਡਲ ਦੇ ਆਉਟਪੁੱਟ ਦਾ ਵਿਸ਼ਲੇਸ਼ਣ ਕਰਕੇ ਸਿਖਲਾਈ ਡਾਟੇ ਦਾ ਪੁਨਰ-ਨਿਰਮਾਣ ਕਰਨ ਦੀ ਕੋਸ਼ਿਸ਼ ਕਰਦਾ ਹੈ।
- **Model Lifecycle Management** – The process of overseeing all stages of an AI model's existence, including design, development, deployment, monitoring, maintenance, and eventual retirement.
- **ਮਾਡਲ ਜੀਵਨ-ਚੱਕਰ ਪ੍ਰਬੰਧਨ (Model Lifecycle Management)** – ਕਿਸੇ AI ਮਾਡਲ ਦੀ ਹੋਂਦ ਦੇ ਸਾਰੇ ਪੜਾਵਾਂ ਦੀ ਦੇਖ-ਰੇਖ ਦੀ ਪ੍ਰਕਿਰਿਆ, ਜਿਸ ਵਿੱਚ ਡਿਜ਼ਾਈਨ, ਵਿਕਾਸ, ਤੈਨਾਤੀ, ਨਿਗਰਾਨੀ, ਰੱਖ-ਰਖਾਅ, ਅਤੇ ਅਖੀਰ ਸੇਵਾ-ਮੁਕਤੀ ਸ਼ਾਮਲ ਹਨ।
- **Model Poisoning** – Introducing vulnerabilities or backdoors directly into a model during the training process.
- **model poisoning (ਮਾਡਲ ਜਹਰੀਕਰਨ)** – ਸਿਖਲਾਈ ਪ੍ਰਕਿਰਿਆ ਦੌਰਾਨ ਸਹਿ ਤੌਰ 'ਤੇ ਮਾਡਲ ਵਿੱਚ ਕਮਜ਼ੋਰੀਆਂ ਜਾਂ ਬੈਕਡੋਰ ਦਾਖਲ ਕਰਨਾ।
- **mTLS (Mutual TLS)** – A TLS configuration where both client and server authenticate each other using certificates, ensuring bidirectional identity verification for service-to-service communication.
- **mTLS (Mutual TLS)** – TLS ਦੀ ਇੱਕ ਸੰਰਚਨਾ ਜਿਸ ਵਿੱਚ ਕਲਾਇੰਟ ਅਤੇ ਸਰਵਰ ਦੋਵੇਂ ਸਰਟੀਫਿਕੇਟਾਂ ਦੀ ਵਰਤੋਂ ਕਰਕੇ ਇੱਕ-ਦੂਜੇ ਦਾ ਪ੍ਰਮਾਣੀਕਰਨ ਕਰਦੇ ਹਨ, ਜਿਸ ਨਾਲ ਸੇਵਾ-ਤੋ-ਸੇਵਾ ਸੰਚਾਰ ਲਈ ਦੋ-ਪਾਸੀ ਪਛਾਣ ਤਸਦੀਕ ਯਕੀਨੀ ਬਣਦੀ ਹੈ।
- **Multi-agent System** – A system composed of multiple interacting AI agents, each with potentially different capabilities and goals.
- **ਬਹੁ-ਏਜੰਟ ਸਿਸਟਮ (Multi-agent System)** – ਇੱਕ ਅਜਿਹਾ ਸਿਸਟਮ ਜੋ ਆਪਸ ਵਿੱਚ ਕੰਮ ਕਰਦੇ ਕਈ AI ਏਜੰਟਾਂ ਤੋਂ ਬਣਿਆ ਹੋਵੇ, ਜਿਨ੍ਹਾਂ ਵਿੱਚੋਂ ਹਰ ਇੱਕ ਦੀਆਂ ਸਮਰੱਥਾਵਾਂ ਅਤੇ ਟੀਚੇ ਵੱਖਰੇ ਹੋ ਸਕਦੇ ਹਨ।

- **NFC (Normal Form Composed)** – A Unicode normalization form that decomposes characters and then re-composes them into a canonical representation, used to prevent encoding-based bypass attacks.
- **NFC (Normal Form Composed)** – ਇੱਕ Unicode ਸਧਾਰਨੀਕਰਨ ਰੂਪ ਜੋ ਅੱਖਰਾਂ ਨੂੰ ਪਹਿਲਾਂ ਤੋੜਦਾ ਹੈ ਅਤੇ ਫਿਰ ਉਹਨਾਂ ਨੂੰ ਇੱਕ ਕੈਨੋਨੀਕਲ ਪ੍ਰਤੀਨਿਧਤਾ ਵਿੱਚ ਮੁੜ ਜੋੜਦਾ ਹੈ; ਇਹ ਏਨਕੋਡਿੰਗ-ਆਧਾਰਤ ਬਾਈਪਾਸ ਹਮਲਿਆਂ ਨੂੰ ਰੋਕਣ ਲਈ ਵਰਤਿਆ ਜਾਂਦਾ ਹੈ।
- **Non-repudiation** – A security property ensuring that a party cannot credibly deny having performed an action. In AI systems, achieved through cryptographic signing of agent actions and audit log entries, enabling attribution of decisions to specific principals.
- **ਗੈਰ-ਇਨਕਾਰਯੋਗਤਾ (Non-repudiation)** – ਇੱਕ ਸੁਰੱਖਿਆ ਗੁਣ ਜੋ ਇਹ ਯਕੀਨੀ ਬਣਾਉਂਦਾ ਹੈ ਕਿ ਕੋਈ ਧਰਿ ਕਸਿ ਕਾਰਵਾਈ ਨੂੰ ਕਰਨ ਤੋਂ ਭਰੋਸੇਯੋਗ ਢੰਗ ਨਾਲ ਮੁੱਕਰ ਨਾ ਸਕੇ। AI ਸਸਿਟਮਾਂ ਵਿੱਚ ਇਹ ਏਜੰਟ ਦੀਆਂ ਕਾਰਵਾਈਆਂ ਅਤੇ ਆਡਿਟ ਲੌਗ ਇੰਦਰਾਜਾਂ ਉੱਤੇ ਕ੍ਰਪਿਟੋਗ੍ਰਾਫਿਕ ਦਸਤਖਤ ਰਾਹੀਂ ਹਾਸਲ ਕੀਤਾ ਜਾਂਦਾ ਹੈ, ਜਸਿ ਨਾਲ ਫ਼ੈਸਲਿਆਂ ਦਾ ਖ਼ਾਸ ਪਛਾਣ-ਇਕਾਈਆਂ¹⁶⁶ (principals) ਨਾਲ ਸਰੋਤ-ਨਰਿਧਾਰਨ (attribution) ਸੰਭਵ ਹੁੰਦਾ ਹੈ।
- **NVLink** – A high-bandwidth interconnect technology for GPU-to-GPU communication, requiring authentication and encryption in multi-tenant AI environments.
- **NVLink** – GPU-ਤੋਂ-GPU ਸੰਚਾਰ ਲਈ ਇੱਕ ਉੱਚ-ਬੈਂਡਵਿਡਥ ਅੰਤਰ-ਸੰਪਰਕ ਤਕਨਾਲੋਜੀ, ਜਸਿ ਲਈ ਬਹੁ-ਟੈਨੈਂਟ AI ਵਾਤਾਵਰਣਾਂ ਵਿੱਚ ਪ੍ਰਮਾਣੀਕਰਨ ਅਤੇ ਏਨਕ੍ਰਪਿਸ਼ਨ ਲਾਜ਼ਮੀ ਹੈ।
- **OAuth 2.1** – An authorization framework that consolidates OAuth 2.0 best practices into a single specification, used in AISVS as the required authentication mechanism for MCP clients and servers.
- **OAuth 2.1** – ਇੱਕ ਅਧਿਕਾਰੀਕਰਨ ਫ੍ਰੇਮਵਰਕ ਜੋ OAuth 2.0 ਦੇ ਸਭ ਤੋਂ ਵਧੀਆ ਅਭਿਆਸਾਂ ਨੂੰ ਇੱਕੋ ਸਪੈਸੀਫਿਕੇਸ਼ਨ¹⁶⁷ (specification) ਵਿੱਚ ਇਕੱਠਾ ਕਰਦਾ ਹੈ; AISVS ਵਿੱਚ ਇਹ MCP ਕਲਾਇੰਟਾਂ ਅਤੇ ਸਰਵਰਾਂ ਲਈ ਲੋੜੀਂਦੀ ਪ੍ਰਮਾਣੀਕਰਨ ਵਧੀ ਵਜੋਂ ਵਰਤਿਆ ਜਾਂਦਾ ਹੈ।
- **OIDC (OpenID Connect)** – An identity layer built on OAuth 2.0 that enables clients to verify user identity based on authentication performed by an authorization server.
- **OIDC (OpenID Connect)** – OAuth 2.0 ਉੱਤੇ ਬਣੀ ਇੱਕ ਪਛਾਣ ਪਰਤ ਜੋ ਕਲਾਇੰਟਾਂ ਨੂੰ ਕਸਿ ਅਧਿਕਾਰੀਕਰਨ ਸਰਵਰ ਦੁਆਰਾ ਕੀਤੇ ਪ੍ਰਮਾਣੀਕਰਨ ਦੇ ਆਧਾਰ ਉੱਤੇ ਉਪਭੋਗਤਾ ਦੀ ਪਛਾਣ ਤਸਦੀਕ ਕਰਨ ਦਿੰਦੀ ਹੈ।
- **OPA (Open Policy Agent)** – An open-source, general-purpose policy engine that evaluates authorization and admission control policies written in Rego, enabling unified policy enforcement across applications, APIs, and infrastructure.
- **OPA (Open Policy Agent)** – ਇੱਕ ਓਪਨ-ਸੋਰਸ, ਆਮ-ਮਕਸਦੀ ਨੀਤੀ ਇੰਜਣ ਜੋ Rego ਵਿੱਚ ਲਿਖੀਆਂ ਅਧਿਕਾਰੀਕਰਨ ਅਤੇ ਦਾਖ਼ਲਾ-ਨਿਯੰਤਰਣ ਨੀਤੀਆਂ ਦਾ ਮੁਲਾਂਕਣ ਕਰਦਾ ਹੈ, ਜਸਿ ਨਾਲ ਐਪਲੀਕੇਸ਼ਨਾਂ, API, ਅਤੇ ਬੁਨਿਆਦੀ ਢਾਂਚੇ ਵਿੱਚ ਇੱਕਸਾਰ ਨੀਤੀ-ਲਾਗੂਕਰਨ ਸੰਭਵ ਹੁੰਦਾ ਹੈ।
- **PDP (Policy Decision Point)** – A component in a policy enforcement architecture that evaluates authorization requests against defined policies and returns an allow or deny decision. In agentic AI systems, the PDP is isolated from the agent's execution environment to prevent a compromised agent from influencing its own authorization decisions.
- **PDP (ਨੀਤੀ ਫ਼ੈਸਲਾ ਬਿੰਦੂ)** – ਨੀਤੀ-ਲਾਗੂਕਰਨ ਆਰਕੀਟੈਕਚਰ ਦਾ ਇੱਕ ਹਸਿ ਜੋ ਅਧਿਕਾਰੀਕਰਨ ਦੀਆਂ ਬੇਨਤੀਆਂ ਦਾ ਪਰਭਾਸ਼ਿਤ ਨੀਤੀਆਂ ਦੇ ਵਿਰੁੱਧ ਮੁਲਾਂਕਣ ਕਰਦਾ ਹੈ ਅਤੇ ਇਜਾਜ਼ਤ ਜਾਂ ਇਨਕਾਰ ਦਾ ਫ਼ੈਸਲਾ ਵਾਪਸ ਕਰਦਾ ਹੈ। ਏਜੰਟ-ਆਧਾਰਤ AI ਸਸਿਟਮਾਂ ਵਿੱਚ PDP ਨੂੰ ਏਜੰਟ ਦੇ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਵਾਤਾਵਰਣ ਤੋਂ ਅਲੱਗ-ਥਲੱਗ ਰੱਖਿਆ ਜਾਂਦਾ ਹੈ, ਤਾਂ ਜੋ ਭੰਗ ਹੋ ਚੁੱਕਾ ਏਜੰਟ ਆਪਣੇ ਹੀ ਅਧਿਕਾਰੀਕਰਨ ਫ਼ੈਸਲਿਆਂ ਨੂੰ ਪ੍ਰਭਾਵਤਿ ਨਾ ਕਰ ਸਕੇ।
- **PII (Personally Identifiable Information)** – Any information that can be used to identify, contact, or locate a specific individual, either alone or combined with other data.

¹⁶⁶**principal** (security principal) (EN) -> ਪਛਾਣ-ਇਕਾਈ — built on the already-settled ਪਛਾਣ (“identity”) rather than ਕਰਤਾ, which is rejected on Gurmat grounds as load-bearing devotional vocabulary (ਕਰਤਾ ਪੁਰਖ, ਕਰਤਾਰ) for a divine doer. Full discussion: OPEN-QUESTIONS.md Q124.

¹⁶⁷**specification** (EN) -> ਸਪੈਸੀਫਿਕੇਸ਼ਨ — corrected from an earlier draft’s coinage ਵਸਿਸ਼-ਵੇਰਵਾ, which double-collided with the requirement tables’ Description column and with ਵਸਿਸ਼-ਅਧਿਕਾਰ (privilege); routed to a loan instead. Full discussion: OPEN-QUESTIONS.md Q144.

- **PII (ਨਜ਼ੀ ਪਛਾਣਯੋਗ ਜਾਣਕਾਰੀ)** – ਕੋਈ ਵੀ ਅਜਿਹੀ ਜਾਣਕਾਰੀ ਜਿਸ ਦੀ ਵਰਤੋਂ, ਇਕੱਲਿਆਂ ਜਾਂ ਹੋਰ ਡਾਟੇ ਨਾਲ ਜੋੜ ਕੇ, ਕਸਿ ਖਾਸ ਵਿਅਕਤੀ ਦੀ ਪਛਾਣ ਕਰਨ, ਉਸ ਨਾਲ ਸੰਪਰਕ ਕਰਨ, ਜਾਂ ਉਸ ਦਾ ਟਕਿਣਾ ਲੱਭਣ ਲਈ ਕੀਤੀ ਜਾ ਸਕਦੀ ਹੈ।
- **Policy-as-Code** – The practice of defining security and compliance policies in machine-readable code that can be version-controlled, tested, and automatically enforced in CI/CD pipelines.
- **ਕੋਡ-ਵਜੋ-ਨੀਤੀ¹⁶⁸ (Policy-as-Code)** – ਸੁਰੱਖਿਆ ਅਤੇ ਪਾਲਣਾ ਨੀਤੀਆਂ ਨੂੰ ਮਸ਼ੀਨ-ਪੜ੍ਹਨਯੋਗ ਕੋਡ ਵਿੱਚ ਪਰਭਾਸ਼ਿਤ ਕਰਨ ਦਾ ਅਭਿਆਸ, ਤਾਂ ਜੋ ਉਹਨਾਂ ਨੂੰ ਵਰਜਨ-ਨਿਯੰਤਰਿਤ, ਟੈਸਟ, ਅਤੇ CI/CD ਪਾਈਪਲਾਈਨਾਂ ਵਿੱਚ ਆਪਣੇ-ਆਪ ਲਾਗੂ ਕੀਤਾ ਜਾ ਸਕੇ।
- **Privacy-Preserving Machine Learning (PPML)** – Techniques and methods to train and deploy ML models while protecting the privacy of the training data.
- **Privacy-Preserving Machine Learning (PPML — ਨਜ਼ਤਾ-ਰੱਖਿਅਕ ਮਸ਼ੀਨ ਲਰਨਿੰਗ)** – ਸਖਿਲਾਈ ਡਾਟੇ ਦੀ ਨਜ਼ਤਾ ਦੀ ਰਾਖੀ ਕਰਦੇ ਹੋਏ ML ਮਾਡਲਾਂ ਨੂੰ ਸਖਿਲਾਈ ਦੇਣ ਅਤੇ ਤੈਨਾਤ ਕਰਨ ਦੀਆਂ ਤਕਨੀਕਾਂ ਅਤੇ ਵਿਧੀਆਂ।
- **Prompt Injection** – An attack where malicious instructions are embedded in inputs to override a model's intended behavior.
- **prompt ਇੰਜੈਕਸ਼ਨ (Prompt Injection)** – ਇੱਕ ਅਜਿਹਾ ਹਮਲਾ ਜਿਸ ਵਿੱਚ ਮਾਡਲ ਦੇ ਇੱਛਤ ਵਿਵਹਾਰ ਨੂੰ ਓਵਰਰਾਈਡ ਕਰਨ ਲਈ ਇਨਪੁਟਾਂ ਵਿੱਚ ਖ਼ਤਰਨਾਕ ਹਦਾਇਤਾਂ ਜੜ ਦਿੱਤੀਆਂ ਜਾਂਦੀਆਂ ਹਨ।
- **Prompt Template** – A structured text pattern used to construct prompts submitted to an AI model, containing fixed instructions, variable placeholders for user inputs, and formatting directives. Prompt templates are AI-specific configuration artifacts that require version control, integrity protection, and access controls equivalent to source code.
- **prompt ਟੈਪਲੇਟ (Prompt Template)** – ਇੱਕ ਢਾਂਚਾਗਤ ਲਿਖਤੀ ਪੈਟਰਨ ਜੋ AI ਮਾਡਲ ਨੂੰ ਭੇਜੇ ਜਾਣ ਵਾਲੇ prompt ਬਣਾਉਣ ਲਈ ਵਰਤਿਆ ਜਾਂਦਾ ਹੈ, ਅਤੇ ਜਿਸ ਵਿੱਚ ਸਥਿਰ ਹਦਾਇਤਾਂ, ਉਪਭੋਗਤਾ ਇਨਪੁਟਾਂ ਲਈ ਪਰਵਿਰਤਨਸ਼ੀਲ ਥਾਂ-ਧਾਰਕ, ਅਤੇ ਫਾਰਮੈਟਿੰਗ ਨਿਰਦੇਸ਼ ਹੁੰਦੇ ਹਨ। prompt ਟੈਪਲੇਟ AI-ਵਸ਼ਿਸ਼ ਸੰਰਚਨਾ ਆਰਟੀਫੈਕਟ ਹਨ ਜਿਨ੍ਹਾਂ ਲਈ ਸਰੋਤ ਕੋਡ ਦੇ ਬਰਾਬਰ ਵਰਜਨ ਨਿਯੰਤਰਣ, ਅਖੰਡਤਾ ਸੁਰੱਖਿਆ, ਅਤੇ ਪਹੁੰਚ ਕੰਟਰੋਲ ਦੀ ਲੋੜ ਹੁੰਦੀ ਹੈ।
- **Quantization** – A post-training compression technique that reduces model weight precision (e.g., from 32-bit to 8-bit or 4-bit integers) to decrease memory footprint and inference latency. Quantization can alter model behavior, requiring safety and robustness properties to be re-evaluated after application.
- **ਕੁਆਂਟਾਈਜ਼ੇਸ਼ਨ (Quantization)** – ਸਖਿਲਾਈ-ਉਪਰੰਤ ਸੰਕੁਚਨ ਦੀ ਇੱਕ ਤਕਨੀਕ ਜੋ ਸੈਮੋਰੀ ਦੀ ਖਪਤ ਅਤੇ ਇਨਫਰੈਂਸ ਦੀ ਦੇਰੀ ਘਟਾਉਣ ਲਈ ਮਾਡਲ ਵੇਟਸ ਦੀ ਸ਼ੁੱਧਤਾ ਘਟਾ ਦਿੰਦੀ ਹੈ (ਜਿਵੇਂ, 32-ਬਿਟ ਤੋਂ 8-ਬਿਟ ਜਾਂ 4-ਬਿਟ ਪੂਰਨ ਅੰਕਾਂ ਤੱਕ)। ਕੁਆਂਟਾਈਜ਼ੇਸ਼ਨ ਮਾਡਲ ਦਾ ਵਿਵਹਾਰ ਬਦਲ ਸਕਦੀ ਹੈ, ਇਸ ਲਈ ਇਸ ਨੂੰ ਲਾਗੂ ਕਰਨ ਤੋਂ ਬਾਅਦ ਸਲਾਮਤੀ ਅਤੇ ਮਜ਼ਬੂਤੀ ਦੇ ਗੁਣਾਂ ਦਾ ਮੁੜ-ਮੁਲਾਂਕਣ ਲਾਜ਼ਮੀ ਹੈ।
- **RAG (Retrieval-Augmented Generation)** – A technique that enhances large language models by retrieving relevant information from external knowledge sources before generating a response.
- **RAG (Retrieval-Augmented Generation)** – ਇੱਕ ਤਕਨੀਕ ਜੋ ਜਵਾਬ ਤਿਆਰ ਕਰਨ ਤੋਂ ਪਹਿਲਾਂ ਬਾਹਰੀ ਗਿਆਨ-ਸਰੋਤਾਂ ਤੋਂ ਸੰਬੰਧਿਤ ਜਾਣਕਾਰੀ ਦੀ ਪ੍ਰਾਪਤੀ ਕਰਕੇ ਵੱਡੇ ਭਾਸ਼ਾ ਮਾਡਲਾਂ ਨੂੰ ਬਹਿਤਰ ਬਣਾਉਂਦੀ ਹੈ।
- **RBAC (Role-Based Access Control)** – An access control model where permissions are assigned to roles rather than individual users, and users are granted access by being assigned to appropriate roles.
- **RBAC (ਭੂਮਿਕਾ-ਆਧਾਰਿਤ ਪਹੁੰਚ ਕੰਟਰੋਲ)** – ਪਹੁੰਚ ਕੰਟਰੋਲ ਦਾ ਇੱਕ ਮਾਡਲ ਜਿਸ ਵਿੱਚ ਇਜਾਜ਼ਤਾਂ ਵੱਖ-ਵੱਖ ਉਪਭੋਗਤਾਵਾਂ ਦੀ ਥਾਂ ਭੂਮਿਕਾਵਾਂ ਨੂੰ ਦਿੱਤੀਆਂ ਜਾਂਦੀਆਂ ਹਨ, ਅਤੇ ਉਪਭੋਗਤਾਵਾਂ ਨੂੰ ਢੁਕਵੀਆਂ ਭੂਮਿਕਾਵਾਂ ਸੌਂਪ ਕੇ ਪਹੁੰਚ ਦਿੱਤੀ ਜਾਂਦੀ ਹੈ।
- **Red-Teaming** – The practice of actively testing AI systems by simulating adversarial attacks to identify vulnerabilities.

¹⁶⁸ **Policy-as-Code (EN)** -> ਕੋਡ-ਵਜੋ-ਨੀਤੀ — a transparent compound (not a branded product name) built from already-settled ਨੀਤੀ (policy) and the ordinary loan ਕੋਡ, with word order following the Panjabi head-final pattern rather than transliterating the English order. Full discussion: OPEN-QUESTIONS.md Q113.

- **ਰੈਡ-ਟੀਮਿੰਗ¹⁶⁹ (Red-Teaming)** – ਕਮਜ਼ੋਰੀਆਂ ਦੀ ਪਛਾਣ ਕਰਨ ਲਈ ਵਰਤੀ ਗਈ ਹਮਲਿਆਂ ਦਾ ਸਮੂਹਿਕ ਕਾਰਨਾਮਾ ਜੋ AI ਸਿਸਟਮਾਂ ਦੀ ਸਰਗਰਮ ਪਰਖ ਕਰਨ ਦਾ ਅਭਿਆਸ।
- **Re-identification Risk** – The probability that an individual can be identified from a supposedly anonymized dataset, measured against defined thresholds.
- **ਮੁੜ-ਪਛਾਣ ਜੋਖਮ (Re-identification Risk)** – ਉਹ ਸੰਭਾਵਨਾ ਕਿ ਕੋਈ ਭਰੋਸੇਯੋਗ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਵਾਤਾਵਰਣ ਕੋਲੋਂ ਕੁਝ ਵਿਅਕਤੀ ਦੀ ਪਛਾਣ ਕੀਤੀ ਜਾ ਸਕਦੀ ਹੈ; ਇਸ ਨੂੰ ਪਰਭਾਸ਼ਤ ਥਰੈਸ਼ਹੋਲਡਾਂ ਦੇ ਵਿਰੁੱਧ ਮਾਪਿਆ ਜਾਂਦਾ ਹੈ।
- **Remote Attestation** – A mechanism by which a trusted execution environment provides cryptographic proof to a remote party that specific code is running in a genuine, unmodified TEE.
- **ਰਿਮੋਟ ਅਟੈਸਟੇਸ਼ਨ (Remote Attestation)** – ਇੱਕ ਵਿਧੀ ਜਿਸ ਰਾਹੀਂ ਕੋਈ ਭਰੋਸੇਯੋਗ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਵਾਤਾਵਰਣ ਕੋਲੋਂ ਦੂਰ-ਦੁਰਾਡੇ ਧਰਿ ਨੂੰ ਕ੍ਰਿਪਟੋਗ੍ਰਾਫਿਕ ਸਬੂਤ ਦਿੰਦਾ ਹੈ ਕਿ ਖਾਸ ਕੋਡ ਇੱਕ ਅਸਲੀ, ਅਣ-ਸੋਧੇ TEE ਵਿੱਚ ਚੱਲ ਰਿਹਾ ਹੈ।
- **Reward Model** – A machine learning model trained to predict human preference scores for AI outputs, used as a proxy reward signal in RLHF training pipelines. Because reward models are ML artifacts, they are subject to data poisoning attacks that can subvert alignment training outcomes.
- **reward model (ਇਨਾਮ ਮਾਡਲ)** – ਇੱਕ ਮਸ਼ੀਨ ਲਰਨਿੰਗ ਮਾਡਲ ਜਿਸ ਨੂੰ AI ਆਊਟਪੁੱਟ ਲਈ ਮਨੁੱਖੀ ਤਰਜੀਹ ਸਕੋਰਾਂ ਦਾ ਪੂਰਵ-ਅਨੁਮਾਨ ਲਾਉਣ ਦੀ ਸਖਿਲਾਈ ਦਿੱਤੀ ਜਾਂਦੀ ਹੈ, ਅਤੇ ਜੋ RLHF ਸਖਿਲਾਈ ਪਾਈਪਲਾਈਨਾਂ ਵਿੱਚ ਬਦਲਵੇਂ ਇਨਾਮ ਸੰਕੇਤ ਵਜੋਂ ਵਰਤਿਆ ਜਾਂਦਾ ਹੈ। ਕਿਉਂਕਿ ਇਨਾਮ ਮਾਡਲ ਵੀ ML ਆਰਟੀਫੈਕਟ ਹਨ, ਇਸ ਲਈ ਉਹ data poisoning ਹਮਲਿਆਂ ਦੀ ਮਾਰ ਹੇਠ ਆਉਂਦੇ ਹਨ, ਜੋ ਅਲਾਈਨਮੈਂਟ ਸਖਿਲਾਈ ਦੇ ਨਤੀਜਿਆਂ ਨੂੰ ਭੰਗ ਕਰ ਸਕਦੇ ਹਨ।
- **RLHF (Reinforcement Learning from Human Feedback)** – A training technique where a model is fine-tuned using human preference judgments as a reward signal to improve alignment with human values and safety requirements.
- **RLHF (Reinforcement Learning from Human Feedback)** – ਇੱਕ ਸਖਿਲਾਈ ਤਕਨੀਕ ਜਿਸ ਵਿੱਚ ਮਨੁੱਖੀ ਕਦਰਾਂ-ਕੀਮਤਾਂ ਅਤੇ ਸਲਾਮਤੀ ਲੋੜਾਂ ਨਾਲ ਅਲਾਈਨਮੈਂਟ ਸੁਧਾਰਨ ਲਈ ਮਨੁੱਖੀ ਤਰਜੀਹ ਦੇ ਨਿਰਣਿਆਂ ਨੂੰ ਇਨਾਮ ਸੰਕੇਤ ਵਜੋਂ ਵਰਤ ਕੇ ਮਾਡਲ ਦੀ ਫਾਈਨ-ਟਿਊਨਿੰਗ ਕੀਤੀ ਜਾਂਦੀ ਹੈ।
- **SAML (Security Assertion Markup Language)** – An XML-based standard for exchanging authentication and authorization data between identity providers and service providers.
- **SAML (Security Assertion Markup Language)** – ਪਛਾਣ ਪ੍ਰਦਾਤਾਵਾਂ ਅਤੇ ਸੇਵਾ ਪ੍ਰਦਾਤਾਵਾਂ ਵਿਚਕਾਰ ਪ੍ਰਮਾਣੀਕਰਨ ਅਤੇ ਅਧਿਕਾਰੀਕਰਨ ਡਾਟੇ ਦੇ ਵਟਾਂਦਰੇ ਲਈ ਇੱਕ XML-ਆਧਾਰਤ ਮਿਆਰ।
- **Sandboxing** – An isolation technique that confines a process or component to a controlled environment with restricted filesystem access, network egress, and system call permissions. In AI systems, sandboxing is used to contain tool and plugin execution, AI workloads, and third-party model inference to prevent unauthorized host access or cross-tenant contamination.
- **ਸੈਂਡਬਾਕਸਿੰਗ (Sandboxing)** – ਅਲੱਗ-ਥਲੱਗ ਕਰਨ ਦੀ ਇੱਕ ਤਕਨੀਕ ਜੋ ਕੋਈ ਪ੍ਰਕਿਰਿਆ ਜਾਂ ਕੰਪੋਨੈਂਟ ਨੂੰ ਸੀਮਤ ਫਾਈਲਸਿਸਟਮ ਪਹੁੰਚ, ਨੈੱਟਵਰਕ ਨਿਕਾਸ, ਅਤੇ ਸਿਸਟਮ ਕਾਲ ਇਜਾਜ਼ਤਾਂ ਵਾਲੇ ਇੱਕ ਨਿਯੰਤਰਤ ਵਾਤਾਵਰਣ ਤੱਕ ਸੀਮਤ ਰੱਖਦੀ ਹੈ। AI ਸਿਸਟਮਾਂ ਵਿੱਚ ਸੈਂਡਬਾਕਸਿੰਗ ਟੂਲ ਅਤੇ ਪਲੱਗਇਨ ਦੇ ਐਗਜ਼ੀਕਿਊਸ਼ਨ, AI ਵਰਕਲੋਡਾਂ, ਅਤੇ ਤੀਜੀ-ਧਰਿ ਦੇ ਮਾਡਲ ਇਨਫਰੈਂਸ ਨੂੰ ਘੇਰ ਕੇ ਰੱਖਣ ਲਈ ਵਰਤੀ ਜਾਂਦੀ ਹੈ, ਤਾਂ ਜੋ ਅਣਅਧਿਕਾਰਤ ਹੋਸਟ ਪਹੁੰਚ ਜਾਂ ਟੈਨੈਂਟਾਂ ਵਿਚਕਾਰ ਦੂਸ਼ਣ ਰੋਕਿਆ ਜਾ ਸਕੇ।
- **SBOM (Software Bill of Materials)** – A formal record containing the details and supply chain relationships of software components used in building an application. See also AI BOM for model-specific artifacts.
- **SBOM (Software Bill of Materials)** – ਇੱਕ ਰਸਮੀ ਰਕਾਰਡ ਜਿਸ ਵਿੱਚ ਕੋਈ ਐਪਲੀਕੇਸ਼ਨ ਦੀ ਉਸਾਰੀ ਵਿੱਚ ਵਰਤੇ ਗਏ ਸਾਫਟਵੇਅਰ ਕੰਪੋਨੈਂਟਾਂ ਦੇ ਵੇਰਵੇ ਅਤੇ ਸਪਲਾਈ ਚੇਨ ਸੰਬੰਧ ਦਰਜ ਹੁੰਦੇ ਹਨ। ਮਾਡਲ-ਵਿਸ਼ੇਸ਼ ਆਰਟੀਫੈਕਟਾਂ ਲਈ AI BOM ਵੀ ਵੇਖੋ।

¹⁶⁹**Red-Teaming (EN)** -> ਰੈਡ-ਟੀਮਿੰਗ — kept as a loan because the colour term is a naming convention for a security discipline, not a description, so translating it (ਲਾਲ ਟੀਮ) would leave a reader with an unexplained colour. Full discussion: OPEN-QUESTIONS.md Q108.

- **Scanned** – Subjected to automated security analysis by a tool, integrated into a pipeline or controlled process (as opposed to an ad-hoc or manual check).
- **ਸਕੈਨ ਕੀਤਾ (Scanned)** – ਕਸਿ ਟੂਲ ਦੁਆਰਾ ਸਵੈਚਲਤਿ ਸੁਰੱਖਿਆ ਵਸਿਲੇਸ਼ਣ ਦੇ ਅਧੀਨ ਲਿਆਂਦਾ ਗਿਆ, ਜੋ ਕਸਿ ਪਾਈਪਲਾਈਨ ਜਾਂ ਨਿਯੰਤਰਤਿ ਪ੍ਰਕਰਿਆ ਵੱਚਿ ਏਕੀਕ੍ਰਤਿ ਹੋਵੇ (ਨਾ ਕੀ ਕੋਈ ਗੈਰ-ਰਸਮੀ ਜਾਂ ਹੱਥੀਂ ਕੀਤੀ ਜਾਂਚ)।
- **SCVS (Software Component Verification Standard)** – An OWASP framework for verifying the security properties of software components, referenced by AISVS for supply chain integrity controls applicable to AI frameworks, libraries, and model dependencies.
- **SCVS (Software Component Verification Standard)** – ਸਾਫਟਵੇਅਰ ਕੰਪੋਨੈਂਟਾਂ ਦੇ ਸੁਰੱਖਿਆ ਗੁਣਾਂ ਦੀ ਤਸਦੀਕ ਲਈ ਇੱਕ OWASP ਫ੍ਰੇਮਵਰਕ, ਜਸਿ ਦਾ ਹਵਾਲਾ AISVS AI ਫ੍ਰੇਮਵਰਕਾਂ, ਲਾਇਬ੍ਰੇਰੀਆਂ, ਅਤੇ ਮਾਡਲ ਡਿਪੈਂਡੈਂਸੀਆਂ ਉੱਤੇ ਲਾਗੂ ਹੋਣ ਵਾਲੇ ਸਪਲਾਈ ਚੇਨ ਅਖੰਡਤਾ ਨਿਯੰਤਰਣਾਂ ਲਈ ਦਿੰਦਾ ਹੈ।
- **seccomp (Secure Computing Mode)** – A Linux kernel feature that restricts the system calls a process can make, used to sandbox AI workloads and reduce attack surface.
- **seccomp (Secure Computing Mode)** – ਇੱਕ Linux ਕਰਨਲ ਵਸਿਸ਼ਤਾ ਜੋ ਕਸਿ ਪ੍ਰਕਰਿਆ ਦੁਆਰਾ ਕੀਤੀਆਂ ਜਾ ਸਕਣ ਵਾਲੀਆਂ ਸਿਸਟਮ ਕਾਲਾਂ ਨੂੰ ਸੀਮਤ ਕਰਦੀ ਹੈ; ਇਹ AI ਵਰਕਲੋਡਾਂ ਨੂੰ ਸੈਂਡਬਾਕਸ ਕਰਨ ਅਤੇ ਹਮਲਾ ਸਤ੍ਹਾ ਘਟਾਉਣ ਲਈ ਵਰਤੀ ਜਾਂਦੀ ਹੈ।
- **Secure Boot** – A firmware security feature that verifies the cryptographic signature of each component in the boot chain before execution, preventing unauthorized or tampered software from loading.
- **ਸੁਰੱਖਿਅਤ ਬੂਟ (Secure Boot)** – ਇੱਕ ਫਰਮਵੇਅਰ ਸੁਰੱਖਿਆ ਵਸਿਸ਼ਤਾ ਜੋ ਬੂਟ ਲੜੀ ਦੇ ਹਰ ਕੰਪੋਨੈਂਟ ਦੇ ਕ੍ਰਪਟੋਗ੍ਰਾਫਿਕ ਦਸਤਖਤ ਦੀ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਤੋਂ ਪਹਿਲਾਂ ਤਸਦੀਕ ਕਰਦੀ ਹੈ, ਅਤੇ ਅਣਅਧਿਕਾਰਤ ਜਾਂ ਛੇੜਛਾੜ ਕੀਤੇ ਸਾਫਟਵੇਅਰ ਨੂੰ ਲੋਡ ਹੋਣ ਤੋਂ ਰੋਕਦੀ ਹੈ।
- **Secure Multi-Party Computation (SMPC)** – A cryptographic technique that enables multiple parties to jointly compute a function over their private inputs without revealing those inputs to each other.
- **Secure Multi-Party Computation (SMPC — ਸੁਰੱਖਿਅਤ ਬਹੁ-ਧਰਿ ਗਣਨਾ)** – ਇੱਕ ਕ੍ਰਪਟੋਗ੍ਰਾਫਿਕ ਤਕਨੀਕ ਜੋ ਕਈ ਧਰਿਾਂ ਨੂੰ ਆਪਣੇ ਨਿੱਜੀ ਇਨਪੁੱਟਾਂ ਉੱਤੇ ਸਾਂਝੇ ਤੌਰ 'ਤੇ ਕੋਈ ਫੰਕਸ਼ਨ ਗਣਨਾ ਦਿੰਦੀ ਹੈ, ਬਿਨਾਂ ਉਹ ਇਨਪੁੱਟ ਇੱਕ-ਦੂਜੇ ਸਾਹਮਣੇ ਜਾਹਰ ਕੀਤੇ।
- **SELinux (Security-Enhanced Linux)** – A Linux kernel security module that provides mandatory access controls using security policies, used to enforce fine-grained process isolation for AI workloads.
- **SELinux (Security-Enhanced Linux)** – ਇੱਕ Linux ਕਰਨਲ ਸੁਰੱਖਿਆ ਮਾਡਿਊਲ ਜੋ ਸੁਰੱਖਿਆ ਨੀਤੀਆਂ ਦੀ ਵਰਤੋਂ ਕਰਕੇ ਲਾਜ਼ਮੀ ਪਹੁੰਚ ਕੰਟਰੋਲ ਦਿੰਦਾ ਹੈ; ਇਹ AI ਵਰਕਲੋਡਾਂ ਲਈ ਬਾਰੀਕ-ਪੱਧਰੀ ਪ੍ਰਕਰਿਆ ਅਲੋਗ-ਬਲੱਗਤਾ ਲਾਗੂ ਕਰਨ ਵਾਸਤੇ ਵਰਤਿਆ ਜਾਂਦਾ ਹੈ।
- **Sender-Constrained Token** – An access token cryptographically bound to the legitimate client so it cannot be used by another party if stolen, through mechanisms such as mTLS or DPoP. AISVS requires sender-constrained tokens between MCP clients and servers. See also: DPoP, mTLS.
- **Sender-Constrained Token (ਭੇਜਣ ਵਾਲੇ ਨਾਲ ਬੰਨ੍ਹਿਆ ਟੋਕਨ)** – ਇੱਕ ਪਹੁੰਚ ਟੋਕਨ ਜੋ mTLS ਜਾਂ DPoP ਵਰਗੀਆਂ ਵਧੀਆਂ ਰਾਹੀਂ ਕ੍ਰਪਟੋਗ੍ਰਾਫਿਕ ਤੌਰ 'ਤੇ ਜਾਇਜ਼ ਕਲਾਇੰਟ ਨਾਲ ਬੰਨ੍ਹਿਆ ਹੁੰਦਾ ਹੈ, ਤਾਂ ਜੋ ਚੋਰੀ ਹੋਣ 'ਤੇ ਵੀ ਕੋਈ ਹੋਰ ਧਰਿ ਉਸ ਨੂੰ ਨਾ ਵਰਤ ਸਕੇ। AISVS ਦੀ ਲੋੜ ਹੈ ਕਿ MCP ਕਲਾਇੰਟਾਂ ਅਤੇ ਸਰਵਰਾਂ ਵਿਚਕਾਰ ਭੇਜਣ ਵਾਲੇ ਨਾਲ ਬੰਨ੍ਹੇ ਟੋਕਨ ਵਰਤੇ ਜਾਣ। ਇਹ ਵੀ ਵੇਖੋ: DPoP, mTLS।
- **Sensitive Fields** – Individual data attributes, columns, or record elements within a dataset that contain personal, regulated, or otherwise protected information (e.g., names, identifiers, health data, financial data, or biometric data). Sensitive fields require access controls, minimization, redaction, or encryption. In AI systems, sensitive field detection is required before data is used for training, embedding, or inference to prevent unintentional leakage or memorization.
- **ਸੰਵੇਦਨਸ਼ੀਲ ਖੇਤਰ (Sensitive Fields)** – ਕਸਿ ਡਾਟਾਸੈੱਟ ਦੇ ਅੰਦਰਲੇ ਵੱਖ-ਵੱਖ ਡਾਟਾ ਗੁਣ, ਕਾਲਮ, ਜਾਂ ਰਕਿਾਰਡ ਤੱਤ ਜਨਿਹਾਂ ਵਿੱਚ ਨਿੱਜੀ, ਨਿਯਮਤਿ, ਜਾਂ ਹੋਰ ਪੱਖੋਂ ਸੁਰੱਖਿਅਤ ਜਾਣਕਾਰੀ ਹੁੰਦੀ ਹੈ (ਜਵਿੱ, ਨਾਮ, ਪਛਾਣਕਰਤਾ, ਸਹਿਤ ਡਾਟਾ, ਵਤੀ ਡਾਟਾ, ਜਾਂ ਬਾਇਓਮੈਟ੍ਰਿਕ ਡਾਟਾ)। ਸੰਵੇਦਨਸ਼ੀਲ ਖੇਤਰਾਂ ਲਈ ਪਹੁੰਚ ਕੰਟਰੋਲ, ਘੱਟੋ-ਘੱਟਕਰਨ, ਰਡਿਕਸ਼ਨ, ਜਾਂ ਏਨਕ੍ਰਿਪਸ਼ਨ ਦੀ ਲੋੜ ਹੁੰਦੀ ਹੈ। AI ਸਿਸਟਮਾਂ ਵਿੱਚ, ਅਣਇੱਛਤ ਲੀਕੇਜ਼ ਜਾਂ ਯਾਦ ਰਹਿ ਜਾਣ ਨੂੰ ਰੋਕਣ ਲਈ ਸਖਿਲਾਈ, embedding, ਜਾਂ ਇਨਫਰੈਸ ਵਾਸਤੇ ਡਾਟਾ ਵਰਤਣ ਤੋਂ ਪਹਿਲਾਂ ਸੰਵੇਦਨਸ਼ੀਲ ਖੇਤਰਾਂ ਦੀ ਪਛਾਣ ਲਾਜ਼ਮੀ ਹੈ।

- **Shadow Deployment** – A deployment pattern in which a new model version receives a copy of live production traffic alongside the current version without serving responses to end users, enabling behavioral comparison and safety validation before promotion.
- **ਸ਼ੈਡੋ ਡੈਪਲਾਈ (Shadow Deployment)** – ਡੈਪਲਾਈ ਦਾ ਇੱਕ ਪੈਟਰਨ ਜਿਸ ਵਿੱਚ ਨਵਾਂ ਮਾਡਲ ਵਰਜ਼ਨ ਮੌਜੂਦਾ ਵਰਜ਼ਨ ਦੇ ਨਾਲ-ਨਾਲ ਜੀਊਏ ਉਤਪਾਦਨ ਟਰੈਫਿਕ ਦੀ ਇੱਕ ਨਕਲ ਹਾਸਲ ਕਰਦਾ ਹੈ ਪਰ ਅੰਤਿਮ ਉਪਭੋਗਤਾਵਾਂ ਨੂੰ ਜਵਾਬ ਨਹੀਂ ਦਿੰਦਾ, ਜਿਸ ਨਾਲ ਤਰੱਕੀ ਤੋਂ ਪਹਿਲਾਂ ਵਿਵਹਾਰਕ ਤੁਲਨਾ ਅਤੇ ਸਲਾਮਤੀ ਪ੍ਰਮਾਣਿਕਤਾ ਸੰਭਵ ਹੁੰਦੀ ਹੈ।
- **Shadow Model** – A model trained by an attacker to mimic a target model's behavior, used in membership inference attacks and as a baseline for evaluating machine unlearning effectiveness.
- **ਸ਼ੈਡੋ ਮਾਡਲ (Shadow Model)** – ਇੱਕ ਮਾਡਲ ਜਿਸ ਨੂੰ ਹਮਲਾਵਰ ਕਸਿ ਨਸ਼ਿਆਨਾ ਮਾਡਲ ਦੇ ਵਿਵਹਾਰ ਦੀ ਨਕਲ ਕਰਨ ਲਈ ਸਿਖਲਾਈ ਦਿੰਦਾ ਹੈ; ਇਹ membership inference ਹਮਲਿਆਂ ਵਿੱਚ ਅਤੇ ਮਸ਼ੀਨ ਅਨਲਰਨਿੰਗ ਦੀ ਕਾਰਗਰਤਾ ਦੇ ਮੁਲਾਂਕਣ ਲਈ ਬੇਸਲਾਈਨ¹⁷⁰ ਵਜੋਂ ਵਰਤਿਆ ਜਾਂਦਾ ਹੈ।
- **SHAP (SHapley Additive exPlanations)** – A game theoretic approach to explain the output of any machine learning model by computing the contribution of each feature to the prediction.
- **SHAP (SHapley Additive exPlanations)** – ਕਸਿ ਵੀ ਮਸ਼ੀਨ ਲਰਨਿੰਗ ਮਾਡਲ ਦੇ ਆਊਟਪੁੱਟ ਦੀ ਵਿਆਖਿਆ ਕਰਨ ਦੀ ਇੱਕ ਖੇਡ-ਸਥਿਤਕ ਪਹੁੰਚ-ਵਿਧੀ, ਜਿਸ ਵਿੱਚ ਪੂਰਵ-ਅਨੁਮਾਨ ਵਿੱਚ ਹਰ ਫੀਚਰ ਦੇ ਯੋਗਦਾਨ ਦੀ ਗਣਨਾ ਕੀਤੀ ਜਾਂਦੀ ਹੈ।
- **Side-Channel Attack** – An attack that extracts information from a system through indirect observation of physical characteristics such as timing, power consumption, electromagnetic emissions, or cache behavior, rather than exploiting software vulnerabilities.
- **ਸਾਈਡ-ਚੈਨਲ ਹਮਲਾ (Side-Channel Attack)** – ਇੱਕ ਅਜਿਹਾ ਹਮਲਾ ਜੋ ਸਾਫਟਵੇਅਰ ਕਮਜ਼ੋਰੀਆਂ ਦਾ ਸ਼ੋਸ਼ਣ ਕਰਨ ਦੀ ਬਜਾਏ ਭੌਤਿਕ ਲੱਛਣਾਂ — ਜਿਵੇਂ ਸਮਾਂ-ਵਿਹਾਰ, ਬਜਿਲੀ ਦੀ ਖਪਤ, ਬਜਿਲ-ਚੁੰਬਕੀ ਨਕਿਸ਼, ਜਾਂ ਕੈਸ਼ ਵਿਵਹਾਰ — ਦੇ ਅਸਥਿਰ ਨਿਰੀਖਣ ਰਾਹੀਂ ਸਮਿਟਮ ਵਿੱਚ ਜਾਣਕਾਰੀ ਕੱਢ ਲੈਂਦਾ ਹੈ।
- **SIEM (Security Information and Event Management)** – A platform that aggregates, correlates, and analyzes security event data from multiple sources to detect threats, support incident response, and satisfy compliance requirements.
- **SIEM (Security Information and Event Management)** – ਇੱਕ ਪਲੇਟਫਾਰਮ ਜੋ ਕਈ ਸਰੋਤਾਂ ਤੋਂ ਸੁਰੱਖਿਆ ਘਟਨਾ ਡਾਟੇ ਨੂੰ ਇਕੱਠਾ ਕਰਦਾ, ਉਸ ਦਾ ਸਹਿ-ਸੰਬੰਧ ਜੋੜਦਾ, ਅਤੇ ਵਿਸ਼ਲੇਸ਼ਣ ਕਰਦਾ ਹੈ, ਤਾਂ ਜੋ ਖ਼ਤਰਿਆਂ ਦਾ ਪਤਾ ਲਗਾਇਆ ਜਾ ਸਕੇ, ਘਟਨਾ ਪ੍ਰਤੀਕਰਮ ਦਾ ਸਮਰਥਨ ਹੋ ਸਕੇ, ਅਤੇ ਪਾਲਣਾ ਲੋੜਾਂ ਪੂਰੀਆਂ ਹੋ ਸਕਣ।
- **SLSA (Supply-chain Levels for Software Artifacts)** – A security framework defining incremental levels of supply chain integrity guarantees, from basic build-process documentation to fully reproducible, hermetically sealed builds with authenticated artifact provenance. Referenced by AISVS for AI model and artifact supply chain controls.
- **SLSA (Supply-chain Levels for Software Artifacts)** – ਇੱਕ ਸੁਰੱਖਿਆ ਫ੍ਰੇਮਵਰਕ ਜੋ ਸਪਲਾਈ ਚੇਨ ਅਖੰਡਤਾ ਦੀਆਂ ਗਾਰੰਟੀਆਂ ਦੇ ਵਧਦੇ ਪੱਧਰ ਪਰਭਾਸ਼ਿਤ ਕਰਦਾ ਹੈ — ਮੁੱਢਲੇ ਬਲਿਡ-ਪ੍ਰਕਿਰਿਆ ਦਸਤਾਵੇਜ਼ੀਕਰਨ ਤੋਂ ਲੈ ਕੇ ਪ੍ਰਮਾਣੀਕ੍ਰਿਤ ਆਰਟੀਫੈਕਟ ਮੂਲ-ਸਰੋਤ ਵਾਲੇ ਪੂਰੀ ਤਰ੍ਹਾਂ ਦੁਹਰਾਉਣਯੋਗ, ਪੂਰੀ ਤਰ੍ਹਾਂ ਸੀਲਬੰਦ ਬਲਿਡਾਂ ਤੱਕ। AISVS ਇਸ ਦਾ ਹਵਾਲਾ AI ਮਾਡਲ ਅਤੇ ਆਰਟੀਫੈਕਟ ਸਪਲਾਈ ਚੇਨ ਨਿਯੰਤਰਣਾਂ ਲਈ ਦਿੰਦਾ ਹੈ।
- **SOC (Security Operations Center)** – A team or facility responsible for monitoring, detecting, analyzing, and responding to security incidents. In AISVS, SOC teams consume AI security event logs for correlation, triage, and incident response.
- **SOC (Security Operations Center)** – ਇੱਕ ਟੀਮ ਜਾਂ ਸਹੂਲਤ ਜੋ ਸੁਰੱਖਿਆ ਘਟਨਾਵਾਂ ਦੀ ਨਿਗਰਾਨੀ, ਪਛਾਣ, ਵਿਸ਼ਲੇਸ਼ਣ, ਅਤੇ ਉਹਨਾਂ ਪ੍ਰਤੀ ਪ੍ਰਤੀਕਰਮ ਲਈ ਜ਼ਿੰਮੇਵਾਰ ਹੁੰਦੀ ਹੈ। AISVS ਵਿੱਚ SOC ਟੀਮਾਂ ਸਹਿ-ਸੰਬੰਧ, ਛਾਂਟੀ, ਅਤੇ ਘਟਨਾ ਪ੍ਰਤੀਕਰਮ ਲਈ AI ਸੁਰੱਖਿਆ ਘਟਨਾ ਲੋਗ ਵਰਤਦੀਆਂ ਹਨ।

¹⁷⁰ **baseline** (EN) -> ਬੇਸਲਾਈਨ — kept as a loan (not ਆਧਾਰ-ਰੇਖਾ) because ਆਧਾਰ is already load-bearing corpus-wide as the pinned -ਆਧਾਰਤਿ (“-based”) suffix, and the two would collide when adjacent. Full discussion: OPEN-QUESTIONS.md Q118.

- **SPDX (Software Package Data Exchange)** – An open standard for communicating software and AI component bill of materials information, including component origin, licensing, and security references.
- **SPDX (Software Package Data Exchange)** – ਸਾਫਟਵੇਅਰ ਅਤੇ AI ਕੰਪੋਨੈਂਟ ਬਲਿ ਆਫ ਮਟੀਰੀਅਲਜ਼ ਦੀ ਜਾਣਕਾਰੀ ਸੰਚਾਰਤਿ ਕਰਨ ਲਈ ਇੱਕ ਖੁੱਲ੍ਹਾ ਮਿਆਰ, ਜਿਸ ਵਿੱਚ ਕੰਪੋਨੈਂਟ ਦਾ ਮੂਲ, ਲਾਇਸੰਸਿੰਗ, ਅਤੇ ਸੁਰੱਖਿਆ ਹਵਾਲੇ ਸ਼ਾਮਲ ਹਨ।
- **SSE (Server-Sent Events)** – A web technology that enables a server to push real-time updates to a client over an HTTP connection, used as a transport mechanism in MCP.
- **SSE (Server-Sent Events)** – ਇੱਕ ਵੈੱਬ ਤਕਨਾਲੋਜੀ ਜੋ ਸਰਵਰ ਨੂੰ HTTP ਕਨੈਕਸ਼ਨ ਉੱਤੇ ਕਲਾਇੰਟ ਵੱਲ ਤਤਕਾਲ ਅੱਪਡੇਟ ਭੇਜਣ ਦੀ ਇਜਾਜ਼ਤ ਦਿੰਦੀ ਹੈ; ਇਹ MCP ਵਿੱਚ ਟ੍ਰਾਂਸਪੋਰਟ ਵਧੀ ਵਜੋਂ ਵਰਤੀ ਜਾਂਦੀ ਹੈ।
- **stdio (Standard Input/Output)** – A process communication mechanism using standard input, output, and error streams, used in MCP as a local-only transport restricted to single-process, same-machine communication.
- **stdio (Standard Input/Output)** – ਮਿਆਰੀ ਇਨਪੁੱਟ, ਆਊਟਪੁੱਟ, ਅਤੇ ਗਲਤੀ ਧਾਰਾਵਾਂ ਵਰਤਣ ਵਾਲੀ ਇੱਕ ਪ੍ਰਕਿਰਿਆ-ਸੰਚਾਰ ਵਧੀ, ਜੋ MCP ਵਿੱਚ ਸਰੀਰ-ਸਥਾਨਕ ਟ੍ਰਾਂਸਪੋਰਟ ਵਜੋਂ ਵਰਤੀ ਜਾਂਦੀ ਹੈ ਅਤੇ ਇੱਕੋ-ਪ੍ਰਕਿਰਿਆ, ਇੱਕੋ-ਮਸ਼ੀਨ ਸੰਚਾਰ ਤੱਕ ਸੀਮਤ ਹੈ।
- **Steganography** – The practice of hiding data within other media (images, audio, video) in a way that is not apparent to observers, used as an attack vector to smuggle payloads past content filters.
- **ਸਟੈਗਨੋਗ੍ਰਾਫੀ (Steganography)** – ਡਾਟੇ ਨੂੰ ਹੋਰ ਮੀਡੀਆ (ਚਿੱਤਰ, ਆਡੀਓ, ਵੀਡੀਓ) ਦੇ ਅੰਦਰ ਇਸ ਢੰਗ ਨਾਲ ਲੁਕਾਉਣ ਦਾ ਅਭਿਆਸ ਕਿਵੇਖਣ ਵਾਲਿਆਂ ਨੂੰ ਪਤਾ ਨਾ ਲੱਗੇ; ਇਸ ਨੂੰ ਸਮੱਗਰੀ ਫਲਟਰਾਂ ਤੋਂ ਪਾਰ ਪੇਲੋਡ ਤਸਕਰੀ ਕਰਨ ਦੇ ਹਮਲਾ-ਰਾਹ ਵਜੋਂ ਵਰਤਿਆ ਜਾਂਦਾ ਹੈ।
- **Strong Authentication** – Authentication that resists credential theft and replay by requiring at least two factors (knowledge, possession, inherence) and phishing-resistant mechanisms such as FIDO2/WebAuthn, certificate-based service auth, or short-lived tokens.
- **ਮਜ਼ਬੂਤ ਪ੍ਰਮਾਣੀਕਰਨ (Strong Authentication)** – ਅਜਿਹਾ ਪ੍ਰਮਾਣੀਕਰਨ ਜੋ ਘੱਟੋ-ਘੱਟ ਦੋ ਕਾਰਕਾਂ (ਗਿਆਨ, ਕਬਜ਼ਾ, ਅੰਤਰ-ਨਹਿਤਿ ਗੁਣ) ਅਤੇ phishing-ਰੋਧਕ ਵਧੀਆਂ — ਜਿਵੇਂ FIDO2/WebAuthn, ਸਰਟੀਫਿਕੇਟ-ਆਧਾਰਤ ਸੇਵਾ ਪ੍ਰਮਾਣੀਕਰਨ, ਜਾਂ ਬੇੜ੍ਹੇ ਸਮੇਂ ਵਾਲੇ ਟੋਕਨ — ਦੀ ਲੋੜ ਰੱਖ ਕੇ ਕ੍ਰੈਡੈਂਸ਼ੀਅਲ ਚੋਰੀ ਅਤੇ replay ਦਾ ਵਿਰੋਧ ਕਰਦਾ ਹੈ।
- **Supply Chain Attack** – Compromising a system by targeting less-secure elements in its supply chain, such as third-party libraries, datasets, or pre-trained models.
- **ਸਪਲਾਈ ਚੇਨ ਹਮਲਾ (Supply Chain Attack)** – ਕਸਿ ਸਸਿਟਮ ਦੀ ਸਪਲਾਈ ਚੇਨ ਦੇ ਘੱਟ ਸੁਰੱਖਿਅਤ ਹਿੱਸਿਆਂ — ਜਿਵੇਂ ਤੀਜੀ-ਧਰਿ ਦੀਆਂ ਲਾਇਬ੍ਰੇਰੀਆਂ, ਡਾਟਾਸੈੱਟ, ਜਾਂ ਪਹਿਲਾਂ-ਸਥਿਰਾਈ-ਪ੍ਰਾਪਤ ਮਾਡਲ — ਨੂੰ ਨਸ਼ਿਆਂ ਬਣਾ ਕੇ ਉਸ ਸਸਿਟਮ ਨੂੰ ਭੰਗ ਕਰਨਾ।
- **Synthetic Data** – Artificially generated data that preserves the statistical properties of real data while containing no actual individual records, used to protect privacy during model training and testing.
- **ਸਥਿਟਿਕ ਡਾਟਾ¹⁷¹ (Synthetic Data)** – ਬਣਾਉਣੀ ਢੰਗ ਨਾਲ ਤਿਆਰ ਕੀਤਾ ਡਾਟਾ ਜੋ ਅਸਲ ਡਾਟੇ ਦੇ ਅੰਕੜਾ-ਗੁਣ ਬਰਕਰਾਰ ਰੱਖਦਾ ਹੈ ਪਰ ਜਿਸ ਵਿੱਚ ਕੋਈ ਅਸਲੀ ਵਿਅਕਤੀਗਤ ਰਕਿਰਡ ਨਹੀਂ ਹੁੰਦਾ; ਇਹ ਮਾਡਲ ਸਥਿਰਾਈ ਅਤੇ ਟੈਸਟਿੰਗ ਦੌਰਾਨ ਨਜ਼ਾਤ ਦੀ ਰਾਖੀ ਲਈ ਵਰਤਿਆ ਜਾਂਦਾ ਹੈ।
- **System Prompt** – Instructions supplied to a model by the application or developer that establish its role, constraints, and policies, separate from user input. System prompt content is sensitive: disclosure can reveal guardrails and aid evasion, so AISVS requires output filters to block its leakage. See also: Prompt Template, Context Window.
- **system prompt** – ਉਹ ਹਦਾਇਤਾਂ ਜੋ ਐਪਲੀਕੇਸ਼ਨ ਜਾਂ ਵਿਕਾਸਕਾਰ ਵੱਲੋਂ ਮਾਡਲ ਨੂੰ ਦੱਸੀਆਂ ਜਾਂਦੀਆਂ ਹਨ ਅਤੇ ਜੋ ਉਸ ਦੀ ਭੂਮਿਕਾ, ਪਾਬੰਦੀਆਂ, ਅਤੇ ਨੀਤੀਆਂ ਤੈਅ ਕਰਦੀਆਂ ਹਨ; ਇਹ ਉਪਭੋਗਤਾ ਇਨਪੁੱਟ ਤੋਂ ਵੱਖਰੀਆਂ ਹੁੰਦੀਆਂ ਹਨ। system prompt ਦੀ ਸਮੱਗਰੀ ਸੰਵੇਦਨਸ਼ੀਲ ਹੁੰਦੀ ਹੈ: ਇਸ ਦਾ ਖੁਲਾਸਾ ਗਾਰਡਰੇਲਾਂ ਨੂੰ ਜਾਹਰ ਕਰ ਸਕਦਾ ਹੈ ਅਤੇ ਬਚ ਨਕਿਲਣ ਵਿੱਚ ਮਦਦ ਕਰ ਸਕਦਾ ਹੈ, ਇਸ ਲਈ AISVS ਦੀ ਲੋੜ ਹੈ ਕਿ ਆਊਟਪੁੱਟ ਫਲਟਰ ਇਸ ਦੀ ਲੀਕੇਜ਼ ਰੋਕਣ। ਇਹ ਵੀ ਵੇਖੋ: Prompt Template, Context Window।

¹⁷¹**Synthetic Data** (EN) -> ਸਥਿਟਿਕ ਡਾਟਾ — kept as a loan rather than ਬਣਾਉਣੀ ਡਾਟਾ, since ਬਣਾਉਣੀ is already load-bearing for artificial in ਬਣਾਉਣੀ ਬੁੱਧੀ (artificial intelligence) and reuse here would blur “synthetic data” with “AI data.” Full discussion: OPEN-QUESTIONS.md Q133.

- **TEE (Trusted Execution Environment)** – A hardware-isolated processing environment that provides confidentiality and integrity guarantees for code and data, protecting them from the host operating system and other tenants.
- **TEE (ਭਰੋਸੇਯੋਗ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਵਾਤਾਵਰਣ)** – ਇੱਕ ਹਾਰਡਵੇਅਰ-ਪੱਧਰ 'ਤੇ ਅਲੱਗ-ਥਲੱਗ ਕੀਤਾ ਪ੍ਰਕਰਿਆ ਵਾਤਾਵਰਣ ਜੋ ਕੋਡ ਅਤੇ ਡਾਟੇ ਲਈ ਗੁਪਤਤਾ ਅਤੇ ਅਖੰਡਤਾ ਦੀਆਂ ਗਾਰੰਟੀਆਂ ਦਿੰਦਾ ਹੈ, ਅਤੇ ਉਹਨਾਂ ਨੂੰ ਹੋਸਟ ਓਪਰੇਟਿੰਗ ਸਸਟਮ ਅਤੇ ਹੋਰ ਟੈਨੈਂਟਾਂ ਤੋਂ ਸੁਰੱਖਿਅਤ ਰੱਖਦਾ ਹੈ।
- **Temperature Scaling** – A post-hoc calibration technique that adjusts model output confidence scores to better reflect true prediction probabilities.
- **ਟੈਂਪਰੇਚਰ ਸਕੇਲਿੰਗ (Temperature Scaling)** – ਇੱਕ ਉਪਰੰਤ-ਲਾਗੂ¹⁷² (post-hoc) ਕੈਲੀਬਰੇਸ਼ਨ ਤਕਨੀਕ ਜੋ ਮਾਡਲ ਦੇ ਆਊਟਪੁੱਟ ਭਰੋਸਾ ਸਕੋਰਾਂ ਨੂੰ ਇਸ ਤਰ੍ਹਾਂ ਵਸਤੂਬੱਧ ਕਰਦੀ ਹੈ ਕਿ ਉਹ ਅਸਲ ਪੂਰਵ-ਅਨੁਮਾਨ ਸੰਭਾਵਨਾਵਾਂ ਨੂੰ ਬਹਿਤਰ ਢੰਗ ਨਾਲ ਦਰਸਾਉਣ।
- **TLS (Transport Layer Security)** – A cryptographic protocol that provides end-to-end encryption, authentication, and integrity for data transmitted over a network. AISVS requires TLS 1.3 or later.
- **TLS (Transport Layer Security)** – ਇੱਕ ਕ੍ਰਿਪਟੋਗ੍ਰਾਫਿਕ ਪ੍ਰੋਟੋਕੋਲ ਜੋ ਨੈੱਟਵਰਕ ਉੱਤੇ ਭੇਜੇ ਜਾਂਦੇ ਡਾਟੇ ਲਈ ਸਰੋਤ-ਤੋਂ-ਸਰੋਤ ਏਨਕ੍ਰਿਪਸ਼ਨ, ਪ੍ਰਮਾਣੀਕਰਨ, ਅਤੇ ਅਖੰਡਤਾ ਦਿੰਦਾ ਹੈ। AISVS ਦੀ ਲੋੜ ਹੈ ਕਿ TLS 1.3 ਜਾਂ ਉਸ ਤੋਂ ਬਾਅਦ ਵਾਲਾ ਵਰਜਨ ਵਰਤਿਆ ਜਾਵੇ।
- **Tokenizer** – A component that converts raw text into a sequence of tokens (subwords, words, or characters) that a language model can process as input.
- **ਟੋਕਨਾਈਜ਼ਰ (Tokenizer)** – ਇੱਕ ਕੰਪੋਨੈਂਟ ਜੋ ਕੱਚੀ ਲਿਖਤ ਨੂੰ ਟੋਕਨਾਂ (ਉਪ-ਸ਼ਬਦ, ਸ਼ਬਦ, ਜਾਂ ਅੱਖਰ) ਦੀ ਲੜੀ ਵਿੱਚ ਬਦਲ ਦਿੰਦਾ ਹੈ, ਜਿਸ ਨੂੰ ਕੋਈ ਭਾਸ਼ਾ ਮਾਡਲ ਇਨਪੁੱਟ ਵਜੋਂ ਪ੍ਰਕਰਿਆ ਕਰ ਸਕਦਾ ਹੈ।
- **TPM (Trusted Platform Module)** – A dedicated hardware chip that provides cryptographic functions including secure key generation, storage, and platform integrity measurement.
- **TPM (Trusted Platform Module)** – ਇੱਕ ਸਮਰਪਤ ਹਾਰਡਵੇਅਰ ਚਿੱਪ ਜੋ ਕ੍ਰਿਪਟੋਗ੍ਰਾਫਿਕ ਫੰਕਸ਼ਨ ਦਿੰਦੀ ਹੈ, ਜਿਸ ਵਿੱਚ ਸੁਰੱਖਿਅਤ ਕੁੰਜੀ ਤਿਆਰੀ, ਭੰਡਾਰਨ, ਅਤੇ ਪਲੇਟਫਾਰਮ ਅਖੰਡਤਾ ਮਾਪ ਸ਼ਾਮਲ ਹਨ।
- **Transfer Learning** – A technique where a model developed for one task is reused as the starting point for a model on a second task.
- **ਟ੍ਰਾਂਸਫਰ ਲਰਨਿੰਗ (Transfer Learning)** – ਇੱਕ ਤਕਨੀਕ ਜਿਸ ਵਿੱਚ ਕੋਈ ਇੱਕ ਕਾਰਜ ਲਈ ਵਿਕਸਤ ਕੀਤਾ ਮਾਡਲ ਕੋਈ ਦੂਜੇ ਕਾਰਜ ਦੇ ਮਾਡਲ ਦੇ ਸ਼ੁਰੂਆਤੀ ਬਿੰਦੂ ਵਜੋਂ ਮੁੜ ਵਰਤਿਆ ਜਾਂਦਾ ਹੈ।
- **Trust Boundary** – A point where data or control passes between zones that hold different levels of trust, such as from untrusted external input to a more privileged internal component. Flows crossing a trust boundary should be validated, authorized, and monitored, and content entering a higher-trust zone should be treated as untrusted until checked.
- **ਭਰੋਸਾ ਸੀਮਾ¹⁷³ (Trust Boundary)** – ਉਹ ਬਿੰਦੂ ਜਿਥੇ ਡਾਟਾ ਜਾਂ ਨਿਯੰਤਰਣ ਵੱਖ-ਵੱਖ ਭਰੋਸਾ ਪੱਧਰਾਂ ਵਾਲੇ ਖੇਤਰਾਂ ਵਿਚਕਾਰ ਲੰਘਦਾ ਹੈ, ਜਿਵੇਂ ਗੈਰ-ਭਰੋਸੇਯੋਗ ਬਾਹਰੀ ਇਨਪੁੱਟ ਤੋਂ ਕੋਈ ਵਧੇਰੇ ਵਸ਼ਿਸ਼-ਅਧਿਕਾਰ ਪ੍ਰਾਪਤ ਅੰਦਰੂਨੀ ਕੰਪੋਨੈਂਟ ਵੱਲ। ਭਰੋਸਾ ਸੀਮਾ ਪਾਰ ਕਰਨ ਵਾਲੇ ਵਹਾਵਾਂ ਨੂੰ ਪ੍ਰਮਾਣਿਤ, ਅਧਿਕਾਰਤ, ਅਤੇ ਨਿਗਰਾਨੀ ਅਧੀਨ ਕੀਤਾ ਜਾਣਾ ਚਾਹੀਦਾ ਹੈ, ਅਤੇ ਉੱਚ-ਭਰੋਸਾ ਖੇਤਰ ਵਿੱਚ ਦਾਖਲ ਹੋਣ ਵਾਲੀ ਸਮੱਗਰੀ ਨੂੰ ਜਾਂਚ ਹੋਣ ਤੱਕ ਗੈਰ-ਭਰੋਸੇਯੋਗ ਹੀ ਮੰਨਿਆ ਜਾਣਾ ਚਾਹੀਦਾ ਹੈ।
- **Vector Database** – A specialized database designed to store high-dimensional vectors (embeddings) and perform efficient similarity searches.

¹⁷² **post-hoc** (EN) -> ਉਪਰੰਤ-ਲਾਗੂ — corrected from an earlier draft's ਪਛਿਲਖੁਰੀ, which means “retrograde / walking backwards” and reads as regression rather than “applied afterwards”; matches the corpus's settled -ਉਪਰੰਤ pattern elsewhere. Full discussion: OPEN-QUESTIONS.md Q144.

¹⁷³ **Trust Boundary** (EN) -> ਭਰੋਸਾ ਸੀਮਾ — ਸੀਮਾ is the standing rendering for boundary/bound across the appendix (ਸੁਰੱਖਿਆ ਸੀਮਾ, ਸਹਮਿਤੀ ਸੀਮਾ, ਵਰਿਗਤ ਸੀਮਾ), deliberately not ਸਰਹੱਦ (“border”), which reads as a territorial boundary and is lint-blocked. Full discussion: OPEN-QUESTIONS.md Q129.

- **ਵੈਕਟਰ ਡਾਟਾਬੇਸ (Vector Database)** – ਇੱਕ ਵੈਕਟਰ ਡਾਟਾਬੇਸ ਜੋ ਬਹੁ-ਆਯਾਮੀ ਵੈਕਟਰਾਂ (embeddings) ਨੂੰ ਸਾਂਭਣ ਅਤੇ ਕਾਰਗਰ ਸਮਾਨਤਾ ਖੋਜਾਂ ਕਰਨ ਲਈ ਬਣਾਇਆ ਗਿਆ ਹੈ।
- **VRAM (Video Random Access Memory)** – Memory on a GPU used to store model weights, activations, and intermediate computations during AI inference and training, requiring zeroing out between tenant workloads.
- **VRAM (Video Random Access Memory)** – GPU ਉੱਤੇ ਮੌਜੂਦ ਮੈਮੋਰੀ ਜੋ AI ਇਨਫਰੈਂਸ ਅਤੇ ਸਥਿਰਤਾ ਦੌਰਾਨ ਮਾਡਲ ਵੇਟਸ, ਐਕਟੀਵੇਸ਼ਨਾਂ, ਅਤੇ ਵਰਤਮਾਨਕੀਆਂ ਗਣਨਾਵਾਂ ਸਾਂਭਣ ਲਈ ਵਰਤੀ ਜਾਂਦੀ ਹੈ; ਟੈਨੈਂਟ ਵਰਕਲੋਡਾਂ ਵਰਤਮਾਨਕੀ ਇਸ ਨੂੰ ਜ਼ੀਰੋ ਕਰਨਾ ਲਾਜ਼ਮੀ ਹੈ।
- **Vulnerability Scanning** – Automated tools that identify known security vulnerabilities in software components, including AI frameworks and dependencies.
- **ਕਮਜ਼ੋਰੀ ਸਕੈਨਿੰਗ (Vulnerability Scanning)** – ਸਵੈਚਲਿਤ ਟੂਲ ਜੋ ਸਾਫਟਵੇਅਰ ਕੰਪੋਨੈਂਟਾਂ ਵਿੱਚ, AI ਫਰੇਮਵਰਕਾਂ ਅਤੇ ਡੈਪੈਂਡੈਂਸੀਆਂ ਸਮੇਤ, ਜਾਣੀਆਂ-ਪਛਾਣੀਆਂ ਸੁਰੱਖਿਆ ਕਮਜ਼ੋਰੀਆਂ ਦੀ ਪਛਾਣ ਕਰਦੇ ਹਨ।
- **WASM (WebAssembly)** – A portable binary instruction format that enables sandboxed execution of code, used as an isolation mechanism for AI tools and plugins.
- **WASM (WebAssembly)** – ਇੱਕ ਪੋਰਟੇਬਲ ਬਾਈਨਰੀ ਹਦਾਇਤ ਫਾਰਮੈਟ ਜੋ ਕੋਡ ਦਾ ਸੈਂਡਬਾਕਸ ਕੀਤਾ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਸੰਭਵ ਬਣਾਉਂਦਾ ਹੈ; ਇਹ AI ਟੂਲਾਂ ਅਤੇ ਪਲੱਗਿਨਾਂ ਲਈ ਅਲੋਗ-ਥਲੋਗ ਕਰਨ ਦੀ ਵਰਤੋਂ ਵਜੋਂ ਵਰਤਿਆ ਜਾਂਦਾ ਹੈ।
- **Watermarking** – Techniques to embed imperceptible markers in AI-generated content or model weights to track origin, detect unauthorized copies, or identify AI-generated media.
- **ਵਾਟਰਮਾਰਕਿੰਗ (Watermarking)** – ਉਹ ਤਕਨੀਕਾਂ ਜੋ AI ਦੁਆਰਾ ਤਿਆਰ ਸਮੱਗਰੀ ਜਾਂ ਮਾਡਲ ਵੇਟਸ ਵਿੱਚ ਅਣਦਿਸ਼ੇ ਨਸ਼ਾਨ ਜੜ੍ਹ ਦਿੰਦੀਆਂ ਹਨ, ਤਾਂ ਜੋ ਮੂਲ ਦੀ ਟਰੈਕਿੰਗ ਹੋ ਸਕੇ, ਅਣਅਧਿਕਾਰਤ ਨਕਲਾਂ ਦਾ ਪਤਾ ਲੱਗ ਸਕੇ, ਜਾਂ AI ਦੁਆਰਾ ਤਿਆਰ ਮੀਡੀਆ ਦੀ ਪਛਾਣ ਹੋ ਸਕੇ।
- **WORM (Write-Once-Read-Many)** – A storage technology that prevents modification or deletion of data after it is written, used for tamper-evident audit logs and backup protection.
- **WORM (Write-Once-Read-Many)** – ਇੱਕ ਭੰਡਾਰਨ ਤਕਨਾਲੋਜੀ ਜੋ ਡਾਟਾ ਲਿਖਿ ਜਾਣ ਤੋਂ ਬਾਅਦ ਉਸ ਦੀ ਸੋਧ ਜਾਂ ਮਟਿਆਈ ਨੂੰ ਰੋਕਦੀ ਹੈ; ਇਹ ਛੇੜਛਾੜ-ਪ੍ਰਗਟ ਆਡਿਟ ਲੌਗਾਂ ਅਤੇ ਬੈਕਅੱਪ ਸੁਰੱਖਿਆ ਲਈ ਵਰਤੀ ਜਾਂਦੀ ਹੈ।
- **Zero-Day Vulnerability** – A previously unknown vulnerability that attackers can exploit before developers create and deploy a patch.
- **ਜ਼ੀਰੋ-ਡੇ ਕਮਜ਼ੋਰੀ (Zero-Day Vulnerability)** – ਇੱਕ ਪਹਿਲਾਂ ਤੋਂ ਅਣਜਾਣ ਕਮਜ਼ੋਰੀ ਜਿਸ ਦਾ ਹਮਲਾਵਰ ਉਦੋਂ ਸ਼ੋਸ਼ਣ ਕਰ ਸਕਦੇ ਹਨ ਜਦੋਂ ਤੱਕ ਵਕਾਸਕਾਰ ਪੈਚ ਬਣਾ ਕੇ ਤੈਨਾਤ ਨਹੀਂ ਕਰ ਦਿੰਦੇ।
- **Zero Standing Privilege (ZSP)** – A security principle requiring that no user, service account, or agent holds persistent elevated permissions. All privileged access is granted just in time for a specific task, scoped to the minimum necessary rights, and automatically revoked after a defined maximum session duration or upon task completion.
- **Zero Standing Privilege (ZSP)** – ਇੱਕ ਸੁਰੱਖਿਆ ਅਸੂਲ ਜਿਸ ਅਨੁਸਾਰ ਕਸਿ ਵੀ ਉਪਭੋਗਤਾ, ਸੇਵਾ ਖਾਤੇ, ਜਾਂ ਏਜੰਟ ਕੋਲ ਸਥਾਈ ਉੱਚੀਆਂ ਇਜਾਜ਼ਤਾਂ ਨਹੀਂ ਹੋਣੀਆਂ ਚਾਹੀਦੀਆਂ। ਸਾਰੀ ਵੈਸ਼ਿਸ਼-ਅਧਿਕਾਰ ਪ੍ਰਾਪਤ ਪਹੁੰਚ ਕਸਿ ਖ਼ਾਸ ਕਾਰਜ ਲਈ ਸਰਿਫ਼ ਲੇੜ ਪੈਣ 'ਤੇ ਹੀ (just in time) ਦਿੱਤੀ ਜਾਂਦੀ ਹੈ, ਘੱਟੋ-ਘੱਟ ਲੇੜੀਏ ਹੱਕਾਂ ਤੱਕ ਦਾਇਰਾ-ਬੱਧ ਰੱਖੀ ਜਾਂਦੀ ਹੈ, ਅਤੇ ਇੱਕ ਪਰਭਾਸ਼ਿਤ ਵੱਧ ਤੋਂ ਵੱਧ ਸੈਸ਼ਨ ਮਿਆਦ ਪਛਿ ਜਾਂ ਕਾਰਜ ਪੂਰਾ ਹੋਣ 'ਤੇ ਆਪਣੇ-ਆਪ ਵਾਪਸ ਲੈ ਲਈ ਜਾਂਦੀ ਹੈ।
- **Zero-Trust** – A security model that assumes no implicit trust for any user, device, or network, requiring continuous verification of identity and authorization for every access request.
- **Zero-Trust** – ਇੱਕ ਸੁਰੱਖਿਆ ਮਾਡਲ ਜੋ ਕਸਿ ਵੀ ਉਪਭੋਗਤਾ, ਯੰਤਰ, ਜਾਂ ਨੈੱਟਵਰਕ ਲਈ ਕੋਈ ਅਪ੍ਰਤੱਖ ਭਰੋਸਾ ਨਹੀਂ ਮੰਨਦਾ, ਅਤੇ ਹਰ ਪਹੁੰਚ ਬੇਨਤੀ ਲਈ ਪਛਾਣ ਅਤੇ ਅਧਿਕਾਰੀਕਰਨ ਦੀ ਲਗਾਤਾਰ ਤਸਦੀਕ ਲਾਜ਼ਮੀ ਕਰਦਾ ਹੈ।

Appendix B: AI Security Controls Inventory

ਅੰਤਿਕਾ¹⁷⁴ B: AI ਸੁਰੱਖਿਆ ਨਿਯੰਤਰਣ ਇਨਵੈਂਟਰੀ

Objective

ਉਦੇਸ਼

This appendix is a consolidated, developer-facing inventory of the security controls mandated across the AISVS requirements. Controls are grouped by control family so an implementer can find all related defenses in one place, regardless of which chapter defines them, and each control links back to the AISVS requirement IDs that mandate it.

ਇਹ ਅੰਤਿਕਾ AISVS ਦੀਆਂ ਲੋੜਾਂ ਵੱਲੋਂ ਲਾਜ਼ਮੀ ਕੀਤੇ ਗਏ ਸੁਰੱਖਿਆ ਨਿਯੰਤਰਣਾਂ ਦੀ ਇੱਕ ਇਕੱਠੀ ਕੀਤੀ ਹੋਈ, ਡਵੈਲਪਰ-ਮੁਖੀ ਇਨਵੈਂਟਰੀ ਹੈ। ਨਿਯੰਤਰਣਾਂ ਨੂੰ ਨਿਯੰਤਰਣ ਪਰਿਵਾਰ (control family) ਅਨੁਸਾਰ ਸਮੂਹਬੱਧ ਕੀਤਾ ਗਿਆ ਹੈ ਤਾਂ ਜੋ ਲਾਗੂ ਕਰਨ ਵਾਲਾ ਸਾਰੇ ਸੰਬੰਧਿਤ ਬਚਾਅ ਇੱਕੋ ਥਾਂ ਲੱਭ ਸਕੇ, ਭਾਵੇਂ ਉਹਨਾਂ ਨੂੰ ਕੋਈ ਵੀ ਅਧਿਆਇ ਪਰਿਭਾਸ਼ਿਤ ਕਰਦਾ ਹੋਵੇ, ਅਤੇ ਹਰ ਨਿਯੰਤਰਣ ਉਹਨਾਂ AISVS ਲੋੜ ID ਨਾਲ ਵਾਪਸ ਜੁੜਦਾ ਹੈ ਜੋ ਉਸ ਨੂੰ ਲਾਜ਼ਮੀ ਕਰਦੇ ਹਨ।

This inventory is non-normative. It reorganizes existing requirements for ease of implementation and does not add, remove, or change any requirement. The requirement chapters (C1 through C12) remain the source of truth. Requirement IDs are written in canonical C{chapter}·{section}·{requirement} form (for example, C5.1.1). Every numbered requirement in the standard appears in exactly one control family below, so the inventory can be checked for completeness against the chapters.

ਇਹ ਇਨਵੈਂਟਰੀ ਗੈਰ-ਨਿਯਮਬੱਧ¹⁷⁵ (non-normative) ਹੈ। ਇਹ ਮੌਜੂਦਾ ਲੋੜਾਂ ਨੂੰ ਲਾਗੂ ਕਰਨ ਦੀ ਸੌਖ ਲਈ ਮੁੜ-ਵਿਸਥਾਪਿਤ ਕਰਦੀ ਹੈ ਅਤੇ ਕਸਿ ਵੀ ਲੋੜ ਨੂੰ ਜੋੜਦੀ, ਹਟਾਉਂਦੀ, ਜਾਂ ਬਦਲਦੀ ਨਹੀਂ। ਲੋੜ ਅਧਿਆਇ (C1 ਤੋਂ C12) ਹੀ ਫ਼ੈਸਲਾਕੁੰਨ ਸਰੋਤ¹⁷⁶ (source of truth) ਬਣੇ ਰਹਿੰਦੇ ਹਨ। ਲੋੜ ID ਕੈਨੋਨੀਕਲ C{chapter}·{section}·{requirement} ਰੂਪ ਵੱਲੋਂ ਲਿਖੇ ਜਾਂਦੇ ਹਨ (ਉਦਾਹਰਨ ਲਈ, C5.1.1)। ਮਿਆਰ ਵੱਲੋਂ ਹਰ ਨੰਬਰ ਵਾਲੀ ਲੋੜ ਹੇਠਾਂ ਦਿੱਤੇ ਬਲਿਕੁਲ ਇੱਕ ਨਿਯੰਤਰਣ ਪਰਿਵਾਰ ਵੱਲੋਂ ਆਉਂਦੀ ਹੈ, ਇਸ ਲਈ ਇਨਵੈਂਟਰੀ ਦੀ ਸੰਪੂਰਨਤਾ ਨੂੰ ਅਧਿਆਇਆਂ ਦੇ ਵਰਿਧਿ ਜਾਂਚਿਆ ਜਾ ਸਕਦਾ ਹੈ।

AD.1 Authentication & Identity

AD.1 ਪ੍ਰਮਾਣੀਕਰਨ ਅਤੇ ਪਛਾਣ

Verify the identity of users, agents, services, edge devices, and MCP clients/servers before granting access.

ਪਹੁੰਚ ਦੇਣ ਤੋਂ ਪਹਿਲਾਂ ਉਪਭੋਗਤਾਵਾਂ, ਏਜੰਟਾਂ, ਸੇਵਾਵਾਂ, ਐਜ ਡਵਾਈਸਾਂ, ਅਤੇ MCP ਕਲਾਇੰਟਾਂ/ਸਰਵਰਾਂ ਦੀ ਪਛਾਣ ਦੀ ਤਸਦੀਕ ਕਰੋ।

Control / Technique	Requirement IDs
Step-up authentication for high-risk AI operations (model deployment, weight export, training-data access, production configuration changes)	C5.1.1
Short-lived, minimal-scoped, cryptographically signed tokens for federated or multi-system agent authentication	C5.1.2

¹⁷⁴ **Appendix** (EN) -> ਅੰਤਿਕਾ — the settled Panjabi term for a document appendix in academic/government publishing; the division letter stays Latin as a cross-reference target, matching Appendix A and Appendix C. Full discussion: OPEN-QUESTIONS.md Q121.

¹⁷⁵ **non-normative** (EN) -> ਗੈਰ-ਨਿਯਮਬੱਧ — built on ਨਿਯਮ (“rule”), not ਲਾਜ਼ਮੀ (bound corpus-wide to the hard “must” of requirement text), so the negation reads as a statement about document status rather than obligation strength. Full discussion: OPEN-QUESTIONS.md Q96.

¹⁷⁶ **source of truth** (EN) -> ਫ਼ੈਸਲਾਕੁੰਨ ਸਰੋਤ — “decisive, settling the matter,” built on the already-settled ਫ਼ੈਸਲਾ (ਨੀਤੀ ਫ਼ੈਸਲਾ ਬਾਧੂ); ਸੱਚ ਦਾ ਸਰੋਤ was rejected on Gurmat grounds since ਸੱਚ/ਸਤੀ is load-bearing devotional vocabulary for Divine Truth. Full discussion: OPEN-QUESTIONS.md Q97.

Control / Technique	Requirement IDs
Strong authentication of edge AI devices to central infrastructure	C4.3.1
Unique cryptographic identity per agent instance, authenticating as a first-class principal to downstream systems	C9.4.1
Scheduled rotation of agent identity credentials	C9.4.3
MCP per-request access-token validation (not transport security alone)	C10.2.1
MCP access-token claim validation (issuer, audience, expiration, scope) per OAuth 2.1	C10.2.2
MCP resource servers do not store or persist access tokens or user credentials	C10.2.3
Removal of all MCP session artifacts on session termination	C10.2.6
No pass-through of client access tokens to downstream APIs	C10.2.7
Sender-constrained MCP access tokens (mTLS or DPOp)	C10.3.5

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਉੱਚ-ਜੋਖਮ ਵਾਲੀਆਂ AI ਕਾਰਵਾਈਆਂ (ਮਾਡਲ ਤੈਨਾਤੀ, ਵੋਟਸ ਨਰਿਯਾਤ, ਸਖਿਲਾਈ-ਡਾਟਾ ਪਹੁੰਚ, ਪ੍ਰੋਡਕਸ਼ਨ ਸੰਰਚਨਾ ਤਬਦੀਲੀਆਂ) ਲਈ ਸਟੈਂਪ-ਔਫ ਪ੍ਰਮਾਣੀਕਰਨ	C5.1.1
ਫ੍ਰੈਡਰੇਟਿਡ ਜਾਂ ਬਹੁ-ਸਿਸਟਮ ਏਜੰਟ ਪ੍ਰਮਾਣੀਕਰਨ ਲਈ ਥੋੜ੍ਹੇ ਸਮੇਂ ਵਾਲੇ, ਘੱਟੋ-ਘੱਟ ਸਕੋਪ ਵਾਲੇ, ਕ੍ਰਪਟੋਗ੍ਰਾਫਿਕ ਤੌਰ 'ਤੇ ਦਸਤਖਤ ਕੀਤੇ ਟੋਕਨ	C5.1.2
ਕੇਂਦਰੀ ਬੁਨਿਆਦੀ ਢਾਂਚੇ ਨਾਲ ਐਜੰਟ AI ਡਵਾਈਸਾਂ ਦਾ ਮਜ਼ਬੂਤ ਪ੍ਰਮਾਣੀਕਰਨ	C4.3.1
ਪ੍ਰਤੀ ਏਜੰਟ ਇੰਸਟਾਂਸ ਵਲੋਂ ਕ੍ਰਪਟੋਗ੍ਰਾਫਿਕ ਪਛਾਣ, ਜੋ ਡਾਊਨਸਟ੍ਰੀਮ ਸਿਸਟਮਾਂ ਲਈ ਪਹਿਲੀ-ਦਰਜੇ ਦੀ ਪਛਾਣ-ਇਕਾਈ ¹⁷⁷ (first-class principal) ਵਜੋਂ ਪ੍ਰਮਾਣੀਕਰਨ ਕਰਦੀ ਹੈ	C9.4.1
ਏਜੰਟ ਪਛਾਣ ਕ੍ਰੈਡੈਂਸ਼ੀਅਲਾਂ ਦੀ ਸਮਾਂ-ਸਾਰਣੀ ਅਨੁਸਾਰ ਅਦਲਾ-ਬਦਲੀ (rotation)	C9.4.3
MCP ਪ੍ਰਤੀ-ਬੇਨਤੀ ਪਹੁੰਚ-ਟੋਕਨ ਪ੍ਰਮਾਣਕਤਾ (ਸਰਿਫ਼ ਟ੍ਰਾਂਸਪੋਰਟ ਸੁਰੱਖਿਆ ਨਹੀਂ)	C10.2.1
OAuth 2.1 ਅਨੁਸਾਰ MCP ਪਹੁੰਚ-ਟੋਕਨ ਦੇ ਦਾਅਵਿਆਂ (claims) — ਜਾਰੀਕਰਤਾ, ਉਦੇਸ਼ਤਿ ਪ੍ਰਾਪਤਕਰਤਾ (audience), ਮਿਆਦ ਸਮਾਪਤੀ, ਸਕੋਪ — ਦੀ ਪ੍ਰਮਾਣਕਤਾ	C10.2.2
MCP ਸਰੋਤ ਸਰਵਰ ਪਹੁੰਚ ਟੋਕਨ ਜਾਂ ਉਪਭੋਗਤਾ ਕ੍ਰੈਡੈਂਸ਼ੀਅਲ ਨਾ ਤਾਂ ਭੰਡਾਰ ਕਰਦੇ ਹਨ ਅਤੇ ਨਾ ਹੀ ਸਥਾਈ ਤੌਰ 'ਤੇ ਰੱਖਦੇ ਹਨ	C10.2.3
ਸੈਸ਼ਨ ਸਮਾਪਤੀ 'ਤੇ ਸਾਰੇ MCP ਸੈਸ਼ਨ ਆਰਟੀਫੈਕਟਾਂ ਨੂੰ ਹਟਾਉਣਾ	C10.2.6
ਕਲਾਇੰਟ ਪਹੁੰਚ ਟੋਕਨਾਂ ਨੂੰ ਡਾਊਨਸਟ੍ਰੀਮ API ਤੱਕ ਅੱਗੇ ਨਾ ਲੰਘਾਉਣਾ ¹⁷⁸ (pass-through)	C10.2.7

¹⁷⁷ **principal** (security principal) (EN) -> ਪਛਾਣ-ਇਕਾਈ — built on the already-settled ਪਛਾਣ (“identity”) rather than ਕਰਤਾ, which is rejected on Gurmat grounds as load-bearing devotional vocabulary for a divine doer. Full discussion: OPEN-QUESTIONS.md Q124.

¹⁷⁸ **pass-through** (of client access tokens) (EN) -> ਅੱਗੇ ਲੰਘਾਉਣਾ — states the mechanism the control forbids (relaying a client's token unchanged downstream), deliberately kept distinct from ਅੱਗੇ ਸੰਚਾਰਤਿ ਕਰਨਾ, which names the approved propagation of a scope-limited delegation token elsewhere in this file. Full discussion: OPEN-QUESTIONS.md Q101.

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਭੇਜਣ ਵਾਲੇ ਨਾਲ ਬੰਨ੍ਹੇ ਹੋਏ (sender-constrained) MCP ਪਹੁੰਚ ਟੋਕਨ (mTLS ਜਾਂ DPOP)	C10.3.5

Common pitfalls: reusing end-user credentials for agent-to-agent calls; not rotating agent credentials on suspected compromise; treating transport security as a substitute for per-request token validation.

ਆਮ ਗਲਤੀਆਂ¹⁷⁹ (common pitfalls): ਏਜੰਟ-ਤੋ-ਏਜੰਟ ਕਾਲਾਂ ਲਈ ਅੰਤਮ-ਉਪਭੋਗਤਾ ਦੇ ਕ੍ਰੈਡੈਂਸ਼ੀਅਲ ਮੁੜ-ਵਰਤਣਾ; ਸੱਕੀ ਸਮਝੌਤੇ (compromise) 'ਤੇ ਏਜੰਟ ਕ੍ਰੈਡੈਂਸ਼ੀਅਲ ਨਾ ਬਦਲਣਾ; ਟ੍ਰਾਂਸਪੋਰਟ ਸੁਰੱਖਿਆ ਨੂੰ ਪ੍ਰਤੀ-ਬੇਨਤੀ ਟੋਕਨ ਪ੍ਰਮਾਣਿਕਤਾ ਦੇ ਬਦਲ ਵਜੋਂ ਲੈਣਾ।

AD.2 Authorization & Access Control

AD.2 ਅਧਿਕਾਰੀਕਰਨ ਅਤੇ ਪਹੁੰਚ ਕੰਟਰੋਲ

Enforce access decisions across users, agents, tools, and resources using policy that the model cannot override.

ਉਪਭੋਗਤਾਵਾਂ, ਏਜੰਟਾਂ, ਟੂਲਾਂ, ਅਤੇ ਸਰੋਤਾਂ ਦੇ ਆਰ-ਪਾਰ ਪਹੁੰਚ ਫੈਸਲੇ ਅਜਿਹੀ ਨੀਤੀ ਦੀ ਵਰਤੋਂ ਕਰਕੇ ਲਾਗੂ ਕਰੋ ਜਿਸ ਨੂੰ ਮਾਡਲ ਓਵਰਰਾਈਡ ਨਾ ਕਰ ਸਕੇ।

Control / Technique	Requirement IDs
Access controls on every AI resource (datasets, endpoints, vector collections, embedding indices, compute) with explicit allow-lists and default-deny	C5.2.1
End-user authorization context enforced at each retrieval and assembly stage, not the service account alone	C5.2.2
Post-inference filtering so responses exclude data the requester is not entitled to receive	C5.2.4
Policy decision point isolated from the agent execution environment	C5.2.5
Just-in-time privileged access to model weights, training pipelines, and production configuration with automatic expiry	C5.2.6
Fine-grained, runtime-enforced authorization of agent actions (which tools, which parameter values)	C9.5.1
Integrity-protected, scope-limited delegation token propagated to every downstream call	C9.5.2
Access-control decisions enforced by application logic or a policy engine, never by the model	C9.5.3
Inter-agent task delegation restricted by an explicit authorization policy	C9.5.5
Re-evaluation of backend authorization on every privileged action in long-running sessions	C9.5.6

¹⁷⁹ **Common pitfalls** (EN) -> ਆਮ ਗਲਤੀਆਂ — a recurring implementation mistake, not a vulnerability class or an attacker's trap, so the plain word (spelled without nukta, matching the corpus's existing ਗਲਤੀ ਪ੍ਰਬੰਧਨ) is the honest one; ਫੰਦਾ and ਭੁਲੇਖਾ were rejected as devotionally loaded or already spoken for. Full discussion: OPEN-QUESTIONS.md Q98.

Control / Technique	Requirement IDs
Scope-filtered MCP tool discovery (tools/list returns only authorized tools)	C10.2.4
Per-invocation MCP access control validating both the tool and the supplied argument values	C10.2.5

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਹਰ AI ਸਰੋਤ (ਡਾਟਾਸੈੱਟ, ਐਂਡਪੁਆਇੰਟ, ਵੈਕਟਰ ਸੰਗ੍ਰਹ, embedding ਇੰਡੈਕਸ, ਕੰਪਿਊਟ) ਉੱਤੇ ਸਪੱਸ਼ਟ allow-list ਅਤੇ ਡਿਨਾਇਲ-ਇਨਕਾਰ ਨਾਲ ਪਹੁੰਚ ਕੰਟਰੋਲ	C5.2.1
ਸਰਿਫ਼ ਸੇਵਾ ਖਾਤੇ ਦੀ ਬਜਾਏ, ਹਰ ਪ੍ਰਾਪਤੀ ਅਤੇ ਅਸੈਂਬਲੀ ਪੜਾਅ 'ਤੇ ਲਾਗੂ ਕੀਤਾ ਗਿਆ ਅੰਤਮ-ਉਪਭੋਗਤਾ ਅਧਿਕਾਰੀਕਰਨ ਸੰਦਰਭ	C5.2.2
ਇਨਫਰੈਂਸ-ਉਪਰੰਤ ਫ਼ਲਿਟਰਿੰਗ, ਤਾਂ ਜੋ ਜਵਾਬਾਂ ਵਿੱਚ ਉਹ ਡਾਟਾ ਸ਼ਾਮਲ ਨਾ ਹੋਵੇ ਜਿਸ ਨੂੰ ਪ੍ਰਾਪਤ ਕਰਨ ਦਾ ਬੇਨਤੀਕਰਤਾ ਹੱਕਦਾਰ ਨਹੀਂ	C5.2.4
ਏਜੰਟ ਦੇ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਵਾਤਾਵਰਣ ਤੋਂ ਅਲੱਗ-ਥਲੱਗ ਕੀਤਾ ਨੀਤੀ ਫ਼ੈਸਲਾ ਬਿੰਦੂ (policy decision point)	C5.2.5
ਮਾਡਲ ਵੇਟਸ, ਸਥਿਰਤਾਈ ਪਾਈਪਲਾਈਨਾਂ, ਅਤੇ ਪ੍ਰੋਡਕਸ਼ਨ ਸੰਰਚਨਾ ਤੱਕ ਆਪਣੇ-ਆਪ ਸਮਾਪਤੀ ਵਾਲੀ, ਸਰਿਫ਼ ਲੋੜ ਪੈਣ 'ਤੇ (just-in-time) ਵਸ਼ਿਸ਼-ਅਧਿਕਾਰ ਪ੍ਰਾਪਤ ਪਹੁੰਚ	C5.2.6
ਏਜੰਟ ਕਾਰਵਾਈਆਂ ਦਾ ਬਾਰੀਕ-ਪੱਧਰੀ, ਰਨਟਾਈਮ ਦੁਆਰਾ ਲਾਗੂ ਕੀਤਾ ਅਧਿਕਾਰੀਕਰਨ (ਕਹਿੜੇ ਟੂਲ, ਕਹਿੜੇ ਪੈਰਾਮੀਟਰ ਮੁੱਲ)	C9.5.1
ਹਰ ਡਾਊਨਸਟਰੀਮ ਕਾਲ ਤੱਕ ਅੱਗੇ ਸੰਚਾਰਿਤ ਕੀਤਾ ਅਖੰਡਤਾ-ਸੁਰੱਖਿਅਤ, ਸਕੋਪ-ਸੀਮਤਿ ਸੌਂਪਣੀ (delegation) ਟੋਕਨ	C9.5.2
ਐਪਲੀਕੇਸ਼ਨ ਤਰਕ ਜਾਂ ਨੀਤੀ ਇੰਜਣ ਦੁਆਰਾ ਲਾਗੂ ਕੀਤੇ ਪਹੁੰਚ ਕੰਟਰੋਲ ਫ਼ੈਸਲੇ, ਕਦੇ ਵੀ ਮਾਡਲ ਦੁਆਰਾ ਨਹੀਂ	C9.5.3
ਸਪੱਸ਼ਟ ਅਧਿਕਾਰੀਕਰਨ ਨੀਤੀ ਦੁਆਰਾ ਸੀਮਤ ਕੀਤੀ ਏਜੰਟਾਂ ਵਿਚਕਾਰ ਕਾਰਜ ਸੌਂਪਣੀ	C9.5.5
ਲੰਬੇ ਸਮੇਂ ਤੱਕ ਚੱਲਣ ਵਾਲੇ ਸੈਸ਼ਨਾਂ ਵਿੱਚ ਹਰ ਵਸ਼ਿਸ਼-ਅਧਿਕਾਰ ਪ੍ਰਾਪਤ ਕਾਰਵਾਈ 'ਤੇ ਬੈਕਐਂਡ ਅਧਿਕਾਰੀਕਰਨ ਦਾ ਮੁੜ-ਮੁਲਾਂਕਣ	C9.5.6
ਸਕੋਪ-ਫ਼ਲਿਟਰ ਕੀਤੀ MCP ਟੂਲ ਖੋਜ (tools/list ਸਰਿਫ਼ ਅਧਿਕਾਰਤ ਟੂਲ ਵਾਪਸ ਕਰਦਾ ਹੈ)	C10.2.4
ਪ੍ਰਤੀ-ਸੱਦਾ MCP ਪਹੁੰਚ ਕੰਟਰੋਲ ਜੋ ਟੂਲ ਅਤੇ ਦਿੱਤੇ ਗਏ ਆਰਗੂਮੈਂਟ ਮੁੱਲ ਦੇਵਾਂ ਨੂੰ ਪ੍ਰਮਾਣਿਤ ਕਰਦਾ ਹੈ	C10.2.5

Common pitfalls: relying on the service account's permissions instead of the caller's; letting model-generated output drive authorization; not re-checking authorization when context changes mid-session.

ਆਮ ਗਲਤੀਆਂ: ਕਾਲ ਕਰਨ ਵਾਲੇ ਦੀਆਂ ਇਜਾਜ਼ਤਾਂ ਦੀ ਬਜਾਏ ਸੇਵਾ ਖਾਤੇ ਦੀਆਂ ਇਜਾਜ਼ਤਾਂ 'ਤੇ ਨਰਿਭਰ ਰਹਿਣਾ; ਮਾਡਲ ਦੁਆਰਾ ਤਿਆਰ ਕੀਤੇ ਆਊਟਪੁੱਟ ਨੂੰ ਅਧਿਕਾਰੀਕਰਨ ਚਲਾਉਣ ਦੇਣਾ; ਸੈਸ਼ਨ ਦੇ ਵਿਚਕਾਰ ਸੰਦਰਭ ਬਦਲਣ 'ਤੇ ਅਧਿਕਾਰੀਕਰਨ ਦੀ ਮੁੜ-ਜਾਂਚ ਨਾ ਕਰਨਾ।

AD.3 Data Classification & Tenant Isolation

AD.3 ਡਾਟਾ ਵਰਗੀਕਰਨ ਅਤੇ ਟੈਨੈਂਟ ਅਲੱਗ-ਥਲੱਗਤਾ

Keep data within its authorization and tenancy boundaries as it flows through AI-specific transformations and shared infrastructure.

ਡਾਟੇ ਨੂੰ AI-ਵਸ਼ਿਸ਼ ਪਰਵਿਰਤਨਾਂ ਅਤੇ ਸਾਂਝੇ ਬੁਨਿਆਦੀ ਢਾਂਚੇ ਵਿੱਚ ਲੰਘਦੇ ਸਮੇਂ ਉਸ ਦੇ ਅਧਿਕਾਰੀਕਰਨ ਅਤੇ ਟੈਨੈਂਸੀ ਦੀਆਂ ਸੀਮਾਵਾਂ ਦੇ ਅੰਦਰ ਰੱਖੋ।

Control / Technique	Requirement IDs
Sensitive data served through retrieval pipelines rather than persisted into model weights	C5.2.3
Classification labels propagated to downstream resources (embeddings, prompt caches, model outputs)	C5.2.7
Cross-tenant isolation in shared model serving (fine-tuning, inference, embedding operations)	C5.3.1
Cross-tenant isolation across shared compute (hardware partitioning, confidential computing, or dedicated allocation)	C5.3.2

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਸੰਵੇਦਨਸ਼ੀਲ ਡਾਟਾ ਮਾਡਲ ਵੇਟਸ ਵਿੱਚ ਸਥਾਈ ਰੱਖਣ ਦੀ ਬਜਾਏ ਪ੍ਰਾਪਤੀ ਪਾਈਪਲਾਈਨਾਂ ਰਾਹੀਂ ਦੱਤਾ ਜਾਣਾ	C5.2.3
ਵਰਗੀਕਰਨ ਲੇਬਲਾਂ ਦਾ ਡਾਊਨਸਟ੍ਰੀਮ ਸਰੋਤਾਂ (embeddings, prompt ਕੈਸ਼, ਮਾਡਲ ਆਊਟਪੁੱਟ) ਤੱਕ ਅੱਗੇ ਸੰਚਾਰ	C5.2.7
ਸਾਂਝੇ ਮਾਡਲ ਸਰਵਿਸ ਵਿੱਚ ਟੈਨੈਂਟਾਂ ਵਿਚਕਾਰ ਅਲੱਗ-ਥਲੱਗਤਾ (ਫ੍ਰਾਈਨ-ਟਿਊਨਿੰਗ, ਇਨਫਰੈਂਸ, embedding ਕਾਰਵਾਈਆਂ)	C5.3.1
ਸਾਂਝੇ ਕੰਪਿਊਟ ਦੇ ਆਰ-ਪਾਰ ਟੈਨੈਂਟਾਂ ਵਿਚਕਾਰ ਅਲੱਗ-ਥਲੱਗਤਾ (ਹਾਰਡਵੇਅਰ ਵੰਡ, ਗੁਪਤ ਕੰਪਿਊਟਿੰਗ, ਜਾਂ ਰਾਖਵੀਂ ਵੰਡ)	C5.3.2

Common pitfalls: dropping classification labels when data is embedded or cached; assuming logical multi-tenancy is sufficient against side channels in shared inference caches.

ਆਮ ਗਲਤੀਆਂ: ਡਾਟਾ embed ਜਾਂ ਕੈਸ਼ ਹੋਣ ਵੇਲੇ ਵਰਗੀਕਰਨ ਲੇਬਲ ਗੁਆ ਦੇਣਾ; ਇਹ ਮੰਨ ਲੈਣਾ ਕਿ ਸਾਂਝੇ ਇਨਫਰੈਂਸ ਕੈਸ਼ਾਂ ਵਿਚਲੇ ਸਾਈਡ-ਚੈਨਲਾਂ ਵਿਰੁੱਧ ਤਾਰਕਿਕ ਬਹੁ-ਟੈਨੈਂਸੀ ਹੀ ਕਾਫ਼ੀ ਹੈ।

AD.4 Encryption & Data Protection

AD.4 ਏਨਕ੍ਰਿਪਸ਼ਨ ਅਤੇ ਡਾਟਾ ਸੁਰੱਖਿਆ

Protect data and secrets at rest, in transit, and in the model's observable context.

ਡਾਟਾ ਅਤੇ ਗੁਪਤ ਭੇਦਾਂ ਦੀ ਸਥਿਤੀ ਸਥਿਤੀ ਵਿੱਚ (at rest), ਪ੍ਰਸਾਰਣ ਦੌਰਾਨ, ਅਤੇ ਮਾਡਲ ਦੇ ਦੇਖਣਯੋਗ ਸੰਦਰਭ ਵਿੱਚ ਸੁਰੱਖਿਆ ਕਰੋ।

Control / Technique	Requirement IDs
Integrity protection of training data while stored and transferred	C1.1.3
Redaction, anonymization, or encryption of sensitive information in labels before use in any labeling artifact	C1.2.3
Encryption of locally stored model weights and sensitive parameters using hardware-backed key stores or secure enclaves	C4.3.4
Encryption at rest of models packaged in mobile, IoT, or embedded apps, decrypted only inside a trusted runtime or secure enclave	C4.3.5
Secrets and credentials kept out of the model's observable context (context window, system prompts, tool-call parameters)	C9.5.4

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਸਥਿਰਤਾ ਡਾਟੇ ਦੇ ਭੰਡਾਰਨ ਅਤੇ ਪ੍ਰਸਾਰਣ ਦੌਰਾਨ ਉਸ ਦੀ ਅਖੰਡਤਾ ਦੀ ਸੁਰੱਖਿਆ	C1.1.3
ਕਿਸੇ ਵੀ ਲੇਬਲਿੰਗ ਆਰਟੀਫੈਕਟ ਵਿੱਚ ਵਰਤੋਂ ਤੋਂ ਪਹਿਲਾਂ ਲੇਬਲਾਂ ਵਿਚਲੀ ਸੰਵੇਦਨਸ਼ੀਲ ਜਾਣਕਾਰੀ ਦੀ ਰਡਿਕਸ਼ਨ, ਗੁਪਤਮਾਨੀਕਰਨ, ਜਾਂ ਏਨਕਰਪਿਸ਼ਨ	C1.2.3
ਹਾਰਡਵੇਅਰ-ਸਮਰਥਿਤ ਕੁੰਜੀ ਸਟੋਰਾਂ ਜਾਂ ਸੁਰੱਖਿਅਤ ਐਨਕਲੇਵਾਂ ਦੀ ਵਰਤੋਂ ਕਰਕੇ ਸਥਾਨਕ ਤੌਰ 'ਤੇ ਸੰਭਾਲੇ ਮਾਡਲ ਵੇਟਸ ਅਤੇ ਸੰਵੇਦਨਸ਼ੀਲ ਪੈਰਾਮੀਟਰਾਂ ਦੀ ਏਨਕਰਪਿਸ਼ਨ	C4.3.4
ਮੋਬਾਈਲ, IoT, ਜਾਂ ਏਮਬੈਡਡ ਐਪਾਂ ਵਿੱਚ ਪੈਕ ਕੀਤੇ ਮਾਡਲਾਂ ਦੀ ਸਥਿਰਤਾ ਸਥਿਤੀ ਵਿੱਚ ਏਨਕਰਪਿਸ਼ਨ, ਜੋ ਸਰਿਫ਼ ਭਰੋਸੇਯੋਗ ਰਨਟਾਈਮ ਜਾਂ ਸੁਰੱਖਿਅਤ ਐਨਕਲੇਵ ਦੇ ਅੰਦਰ ਹੀ ਡੀਕਰਪਿਟ ਹੁੰਦੇ ਹਨ	C4.3.5
ਗੁਪਤ ਭੇਦਾਂ ਅਤੇ ਕ੍ਰੈਡੈਂਸ਼ੀਅਲਾਂ ਨੂੰ ਮਾਡਲ ਦੇ ਦੇਖਣਯੋਗ ਸੰਦਰਭ (ਸੰਦਰਭ ਵਡਿ, system prompt, ਟੂਲ-ਕਾਲ ਪੈਰਾਮੀਟਰ) ਤੋਂ ਬਾਹਰ ਰੱਖਣਾ	C9.5.4

Common pitfalls: encrypting the database but not model checkpoints or embeddings; leaving model weights extractable from an app package; exposing API keys inside tool-call parameters.

ਆਮ ਗਲਤੀਆਂ: ਡਾਟਾਬੇਸ ਨੂੰ ਏਨਕਰਪਿਟ ਕਰਨਾ ਪਰ ਮਾਡਲ ਚੈਕਪੁਆਇੰਟਾਂ ਜਾਂ embeddings ਨੂੰ ਨਹੀਂ; ਮਾਡਲ ਵੇਟਸ ਨੂੰ ਐਪ ਪੈਕੇਜ ਵਿੱਚੋਂ ਕੱਢਣਯੋਗ ਛੱਡ ਦੇਣਾ; ਟੂਲ-ਕਾਲ ਪੈਰਾਮੀਟਰਾਂ ਦੇ ਅੰਦਰ API ਕੁੰਜੀਆਂ ਜਾਹਰ ਕਰਨਾ।

AD.5 Integrity, Signing & Provenance

AD.5 ਅਖੰਡਤਾ, ਦਸਤਖਤ, ਅਤੇ ਮੂਲ-ਸਰੋਤ

Verify authenticity and detect tampering of models, artifacts, messages, tool definitions, and generated media.

ਮਾਡਲਾਂ, ਆਰਟੀਫੈਕਟਾਂ, ਸੁਨੇਹਿਆਂ, ਟੂਲ ਪਰਭਿਾਸ਼ਾਵਾਂ, ਅਤੇ ਤਿਆਰ ਕੀਤੇ ਮੀਡੀਆ ਦੀ ਅਸਲੀਅਤ¹⁸⁰ (authenticity) ਦੀ ਤਸਦੀਕ ਕਰੋ ਅਤੇ ਛੇੜਛਾੜ ਦਾ ਪਤਾ

¹⁸⁰ **authenticity** (EN) -> ਅਸਲੀਅਤ — a sixth distinct verb-precision term alongside the already-locked verify/validate/authenticate/certify/attest cluster; kept clear of ਪਰਮਾਣਿਕਤਾ, which renders validation throughout the corpus including elsewhere in this same appendix. Full discussion: OPEN-QUESTIONS.md Q99.

ਲਗਾਓ।

Control / Technique	Requirement IDs
Integrity monitoring of training data against unauthorized modification or corruption	C1.1.4
Cryptographic integrity for labeling artifacts	C1.2.2
Cryptographic signing of all model artifacts (weights, configs, tokenizers, base models, fine-tunes, adapters, safety/policy models)	C3.1.2
Signature verification at deployment admission and on load	C3.1.3
Signed edge/mobile model packages with on-device signature or checksum validation before load	C4.3.2
Cryptographic binding of agent-initiated actions to each step of the execution chain for non-repudiation	C9.4.2
Integrity protection of agent state persisted between invocations	C9.4.4
Signed MCP tool responses with a unique nonce and timestamp for replay defense	C10.4.6
Tool-definition snapshotting with re-approval required on any change before invocation	C10.4.8
Watermarking of AI-generated media to prove it was AI-generated	C7.4.4

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਅਣਅਧਿਕਾਰਤ ਸੋਧ ਜਾਂ ਵਗਿਰਾਝ ਵਰਿਧਿ ਸਖਿਲਾਈ ਡਾਟੇ ਦੀ ਅਖੰਡਤਾ ਨਗਿਰਾਨੀ	C1.1.4
ਲੇਬਲਿੰਗ ਆਰਟੀਫੈਕਟਾਂ ਲਈ ਕ੍ਰਪਿਟੋਗ੍ਰਾਫ਼ਿਕ ਅਖੰਡਤਾ	C1.2.2
ਸਾਰੇ ਮਾਡਲ ਆਰਟੀਫੈਕਟਾਂ (ਵੇਟਸ, ਸੰਰਚਨਾਵਾਂ, ਟੋਕਨਾਈਜ਼ਰ, ਬੇਸ ਮਾਡਲ, ਫ਼ਾਈਨ-ਟਿਊਨ, ਅਡੈਪਟਰ, ਸਲਾਮਤੀ/ਨੀਤੀ ਮਾਡਲ) ਦੇ ਕ੍ਰਪਿਟੋਗ੍ਰਾਫ਼ਿਕ ਦਸਤਖਤ	C3.1.2
ਤੈਨਾਤੀ ਦਾਖ਼ਲੇ ਸਮੇਂ ਅਤੇ ਲੋਡ ਹੋਣ ਸਮੇਂ ਦਸਤਖਤਾਂ ਦੀ ਤਸਦੀਕ	C3.1.3
ਦਸਤਖਤ ਕੀਤੇ ਐਜੰਟ/ਮੋਬਾਈਲ ਮਾਡਲ ਪੈਕੇਜ, ਜਨਿਹਾਂ ਦੇ ਦਸਤਖਤ ਜਾਂ ਚੈਕਸਮ	C4.3.2
ਲੋਡ ਤੋਂ ਪਹਿਲਾਂ ਡਿਵਾਈਸ ਉੱਤੇ ਹੀ ਪ੍ਰਮਾਣਿਤ ਹੁੰਦੇ ਹਨ	
ਗ਼ੈਰ-ਇਨਕਾਰਯੋਗਤਾ (non-repudiation) ਲਈ ਏਜੰਟ ਦੁਆਰਾ ਸ਼ੁਰੂ ਕੀਤੀਆਂ ਕਾਰਵਾਈਆਂ ਦਾ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਲੜੀ ਦੇ ਹਰ ਪੜਾਅ ਨਾਲ ਕ੍ਰਪਿਟੋਗ੍ਰਾਫ਼ਿਕ ਬੰਧਨ	C9.4.2
ਸੱਦਿਆਂ ਵਿਚਕਾਰ ਸਥਾਈ ਰੱਖੀ ਗਈ ਏਜੰਟ ਸਥਿਤੀ ਦੀ ਅਖੰਡਤਾ ਸੁਰੱਖਿਆ	C9.4.4
replay (ਦੁਹਰਾਓ) ¹⁸¹ ਵਰਿਧਿ ਬਚਾਅ ਲਈ ਵਲਿੱਖਣ ਨੌਸ (nonce) ਅਤੇ	C10.4.6
ਟਾਈਮਸਟੈਂਪ ਸਮੇਤ ਦਸਤਖਤ ਕੀਤੇ MCP ਟੂਲ ਜਵਾਬ	
ਟੂਲ ਪਰਭਿਾਸ਼ਾਵਾਂ ਦੀ ਸਨੈਪਸ਼ਾਟਿੰਗ, ਜਿਸ ਵਿਚਿ ਕਸਿ ਵੀ ਤਬਦੀਲੀ 'ਤੇ ਸੱਦੇ ਤੋਂ ਪਹਿਲਾਂ ਮੁੜ-ਮਨਜ਼ੂਰੀ ਲਾਜ਼ਮੀ ਹੈ	C10.4.8
AI ਦੁਆਰਾ ਤਿਆਰ ਕੀਤੇ ਮੀਡੀਆ ਦੀ ਵਾਟਰਮਾਰਕਿੰਗ ਤਾਂ ਜੋ ਇਹ ਸਾਬਤ ਹੋ ਸਕੇ ਕਿ ਇਹ AI ਦੁਆਰਾ ਤਿਆਰ ਕੀਤਾ ਗਿਆ ਸੀ	C7.4.4

¹⁸¹ **replay** (EN) -> retained in Latin, glossed (ਦੁਹਰਾਓ) — conforms to the C10 chapter's decision so the named attack class stays searchable across the corpus; an earlier draft's transliterated ਰੀਪਲੇ was normalised away. Full discussion: OPEN-QUESTIONS.md Q102.

Common pitfalls: using mutable tags instead of immutable digests; not re-verifying tool definitions between MCP invocations; missing replay protection on tool responses.

ਆਮ ਗਲਤੀਆਂ: ਅਪਰਵਿਰਤਨਸ਼ੀਲ ਡਾਈਜੈਸਟਾਂ ਦੀ ਬਜਾਏ ਬਦਲਣਯੋਗ ਟੈਗ ਵਰਤਣੇ; MCP ਸੱਦਿਆਂ ਵਚਿਕਾਰ ਟੂਲ ਪਰਭਾਸ਼ਾਵਾਂ ਦੀ ਮੁੜ-ਤਸਦੀਕ ਨਾ ਕਰਨੀ; ਟੂਲ ਜਵਾਬਾਂ ਉੱਤੇ replay ਵਰਿਧ ਸੁਰੱਖਿਆ ਦਾ ਗੈਰ-ਮੌਜੂਦ ਹੋਣਾ।

AD.6 Input Validation & Sanitization

AD.6 ਇਨਪੁੱਟ ਪਰਮਾਣਕਤਾ ਅਤੇ ਸੈਨੀਟਾਈਜ਼ੇਸ਼ਨ

Validate, normalize, and constrain all inputs (including tool, MCP, and retrieved content) before they reach the model or downstream systems.

ਸਾਰੇ ਇਨਪੁੱਟਾਂ (ਟੂਲ, MCP, ਅਤੇ ਪ੍ਰਾਪਤ ਕੀਤੀ ਸਮੱਗਰੀ ਸਮੇਤ) ਨੂੰ ਮਾਡਲ ਜਾਂ ਡਾਊਨਸਟ੍ਰੀਮ ਸਿਸਟਮਾਂ ਤੱਕ ਪਹੁੰਚਣ ਤੋਂ ਪਹਿਲਾਂ ਪਰਮਾਣਤਿ ਕਰੋ, ਸਧਾਰਨ ਬਣਾਓ, ਅਤੇ ਸੀਮਤਿ ਕਰੋ।

Control / Technique	Requirement IDs
Input normalization applied before tokenization or embedding	C2.1.1
Encoding and representation-smuggling detection and mitigation (canonicalization, strict schema validation, policy-based rejection, or explicit marking)	C2.1.2
Untrusted-input screening by a prompt-injection detection ruleset or classifier, with blocking	C2.1.3
Input length controls that reject (not truncate) content exceeding the context window	C2.1.4
Allow-list character-set restriction on all inputs	C2.1.5
Instruction hierarchy enforcement (system and developer messages override user and untrusted input)	C2.1.6
Reserved special tokens encoded as literal characters and not injectable into context	C2.1.7
Many-shot jailbreaking pattern detection	C2.1.8
Adversarial-perturbation, steganography, and hidden-content checks on non-text inputs (image, video, audio)	C2.2.3
Cross-modal coordinated attack detection	C2.2.4
Schema validation of tool outputs	C9.3.2
Verification of external resources named in model output against an approved allow-list or registry before install or invocation	C9.3.7
MCP response schema validation before injection into model context	C10.4.1
Indirect-prompt-injection screening of MCP responses before injection into model context	C10.4.2
Rejection of unrecognized or oversized MCP function-call parameters	C10.4.3

Control / Technique	Requirement IDs
Strict MCP schema validation	C10.4.4
Maximum MCP payload size limits	C10.4.5
Anomaly detection on external or untrusted inputs before inference	C11.4.1
Gating actions on inputs flagged as anomalous	C11.4.2

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਟੋਕਨਾਈਜ਼ੇਸ਼ਨ ਜਾਂ embedding ਤੋਂ ਪਹਿਲਾਂ ਲਾਗੂ ਕੀਤਾ ਇਨਪੁੱਟ ਸਧਾਰਨੀਕਰਨ	C2.1.1
ਏਨਕੋਡਿੰਗ ਅਤੇ ਪ੍ਰਤੀਨਿਧਤਾ ਤਸਕਰੀ ਦੀ ਪਛਾਣ ਅਤੇ ਉਸ ਨੂੰ ਘਟਾਉਣਾ (ਕੈਨੋਨੀਕਲਾਈਜ਼ੇਸ਼ਨ, ਸਖ਼ਤ ਸਕੀਮਾ ਪ੍ਰਮਾਣਿਕਤਾ, ਨੀਤੀ-ਆਧਾਰਤ ਰੱਦਗੀ, ਜਾਂ ਸਪੱਸ਼ਟ ਨਿਸ਼ਾਨਦੇਹੀ)	C2.1.2
ਗ਼ੈਰ-ਭਰੋਸੇਯੋਗ ਇਨਪੁੱਟ ਦੀ prompt ਇੰਜੈਕਸ਼ਨ ਪਛਾਣ ਨਿਯਮ-ਸਮੂਹ ਜਾਂ ਵਰਗੀਕਾਰ ਦੁਆਰਾ ਛਾਣਬੀਣ, ਅਤੇ ਰੋਕ	C2.1.3
ਇਨਪੁੱਟ ਲੰਬਾਈ ਨਿਯੰਤਰਣ ਜੋ ਸੰਦਰਭ ਵੱਡੇ ਵੱਧ ਸਮੱਗਰੀ ਨੂੰ ਕੱਟਣ ਦੀ ਬਜਾਏ ਰੱਦ ਕਰਦੇ ਹਨ	C2.1.4
ਸਾਰੇ ਇਨਪੁੱਟਾਂ ਉੱਤੇ allow-list ਅੱਖਰ-ਸਮੂਹ ਪਾਬੰਦੀ	C2.1.5
ਹਦਾਇਤ ਲੜੀ-ਕਰਮ ਦਾ ਲਾਗੂਕਰਨ (ਸਮਿਟਮ ਅਤੇ ਡਵਿਲਪਰ ਸੁਨੇਹੇ ਉਪਭੋਗਤਾ ਅਤੇ ਗ਼ੈਰ-ਭਰੋਸੇਯੋਗ ਇਨਪੁੱਟ ਉੱਤੇ ਭਾਰੂ ਰਹਿੰਦੇ ਹਨ)	C2.1.6
ਰਾਖਵੇਂ ਵਸ਼ਿਸ਼ਟ ਟੋਕਨ ਸ਼ਾਬਦਿਕ ਅੱਖਰਾਂ ਵਜੋਂ ਏਨਕੋਡ ਕੀਤੇ ਜਾਣ ਅਤੇ ਸੰਦਰਭ ਵੱਲੋਂ ਇੰਜੈਕਟ ਨਾ ਕੀਤੇ ਜਾ ਸਕਣ	C2.1.7
many-shot jailbreaking ਪੈਟਰਨਾਂ ਦੀ ਪਛਾਣ	C2.1.8
ਗ਼ੈਰ-ਲਿਖਤੀ ਇਨਪੁੱਟਾਂ (ਚਿੱਤਰ, ਵੀਡੀਓ, ਆਡੀਓ) ਉੱਤੇ ਵਰਿਧੀ ਵਰਿਗਾੜ, ਸਟੈਗਨੋਗ੍ਰਾਫੀ, ਅਤੇ ਲੁਕਵੀਂ ਸਮੱਗਰੀ ਦੀਆਂ ਜਾਂਚਾਂ	C2.2.3
ਕਈ ਇਨਪੁੱਟ ਕਸਿਮਾਂ ਵੱਲੋਂ ਫੈਲੇ ਤਾਲਮੇਲ ਵਾਲੇ ਹਮਲਿਆਂ ਦੀ ਪਛਾਣ	C2.2.4
ਟੂਲ ਆਉਟਪੁੱਟ ਦੀ ਸਕੀਮਾ ਪ੍ਰਮਾਣਿਕਤਾ	C9.3.2
ਮਾਡਲ ਆਉਟਪੁੱਟ ਵੱਲੋਂ ਨਾਮਜ਼ਦ ਬਾਹਰੀ ਸਰੋਤਾਂ ਦੀ, ਸਥਾਪਨਾ ਜਾਂ ਸੱਦੇ ਤੋਂ ਪਹਿਲਾਂ, ਪ੍ਰਵਾਨਾਤਿ allow-list ਜਾਂ ਰਜਿਸਟਰੀ ਦੇ ਵਰਿਧਿ ਤਸਦੀਕ	C9.3.7
ਮਾਡਲ ਸੰਦਰਭ ਵੱਲੋਂ ਦਾਖ਼ਲ ਕਰਨ ਤੋਂ ਪਹਿਲਾਂ MCP ਜਵਾਬਾਂ ਦੀ ਸਕੀਮਾ ਪ੍ਰਮਾਣਿਕਤਾ	C10.4.1
ਮਾਡਲ ਸੰਦਰਭ ਵੱਲੋਂ ਦਾਖ਼ਲ ਕਰਨ ਤੋਂ ਪਹਿਲਾਂ MCP ਜਵਾਬਾਂ ਦੀ ਅਸਧਿੱਖੀ prompt ਇੰਜੈਕਸ਼ਨ ਲਈ ਛਾਣਬੀਣ	C10.4.2
ਅਣਪਛਾਤੇ ਜਾਂ ਹੱਦੋਂ ਵੱਧ ਵੱਡੇ MCP function-call ਪੈਰਾਮੀਟਰਾਂ ਦੀ ਰੱਦਗੀ	C10.4.3
ਸਖ਼ਤ MCP ਸਕੀਮਾ ਪ੍ਰਮਾਣਿਕਤਾ	C10.4.4
ਵੱਧ ਤੋਂ ਵੱਧ MCP ਪੋਲੋਡ ਆਕਾਰ ਸੀਮਾਵਾਂ	C10.4.5
ਇਨਫ਼ਰੈਂਸ ਤੋਂ ਪਹਿਲਾਂ ਬਾਹਰੀ ਜਾਂ ਗ਼ੈਰ-ਭਰੋਸੇਯੋਗ ਇਨਪੁੱਟਾਂ ਉੱਤੇ ਅਸਧਾਰਨਤਾ ਪਛਾਣ	C11.4.1
ਅਸਧਾਰਨ ਵਜੋਂ ਨਿਸ਼ਾਨਬੱਧ ਇਨਪੁੱਟਾਂ ਉੱਤੇ ਗੇਟਿੰਗ ਕਾਰਵਾਈਆਂ	C11.4.2

Common pitfalls: validating only the text modality while ignoring image/audio channels; relying on regex alone without semantic detection; not validating tool and MCP outputs before they re-enter agent context.

ਆਮ ਗਲਤੀਆਂ: ਸਰਿਫ਼ ਲਿਖਤੀ ਮਾਡੈਲਟੀ ਨੂੰ ਪ੍ਰਮਾਣਿਤ ਕਰਨਾ ਅਤੇ ਚਿੱਤਰ/ਆਡੀਓ ਚੈਨਲਾਂ ਨੂੰ ਅਣਗੌਲਿਆਂ ਛੱਡਣਾ; ਅਰਥ-ਪੱਖੀ ਪਛਾਣ ਤੋਂ ਬਿਨਾਂ ਸਰਿਫ਼ regex 'ਤੇ ਨਿਰਭਰ ਰਹਿਣਾ; ਟੂਲ ਅਤੇ MCP ਆਉਟਪੁੱਟ ਦੇ ਏਜੰਟ ਸੰਦਰਭ ਵੱਲੋਂ ਮੁੜ-ਦਾਖ਼ਲ ਹੋਣ ਤੋਂ ਪਹਿਲਾਂ ਉਹਨਾਂ ਨੂੰ ਪ੍ਰਮਾਣਿਤ ਨਾ ਕਰਨਾ।

AD.7 Inbound Content & Policy Screening

AD.7 ਆਉਣ ਵਾਲੀ ਸਮੱਗਰੀ ਅਤੇ ਨੀਤੀ ਛਾਣਬੀਣ

Screen prompts and training content against policy before they reach the model or the training pipeline.

prompt ਅਤੇ ਸਖਿਲਾਈ ਸਮੱਗਰੀ ਨੂੰ ਮਾਡਲ ਜਾਂ ਸਖਿਲਾਈ ਪਾਈਪਲਾਈਨ ਤੱਕ ਪਹੁੰਚਣ ਤੋਂ ਪਹਿਲਾਂ ਨੀਤੀ ਦੇ ਵਿਰੁੱਧ ਛਾਣੋ।

Control / Technique	Requirement IDs
Inbound content classification (violence, self-harm, hate, sexual) against configurable thresholds, with rejection or sanitization before model context	C2.2.1
Evaluation of content classification for unsupported languages	C2.2.2
Detection and removal of disallowed content before training	C1.3.4

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਸੰਰਚਨਾਯੋਗ ਥਰੈਸ਼ਹੋਲਡਾਂ ਦੇ ਵਿਰੁੱਧ ਆਉਣ ਵਾਲੀ ਸਮੱਗਰੀ ਦਾ ਵਰਗੀਕਰਨ (ਹਸਿਆ, ਸਵੈ-ਨੁਕਸਾਨ, ਨਫ਼ਰਤ, ਜਨਿਸੀ), ਅਤੇ ਮਾਡਲ ਸੰਦਰਭ ਤੋਂ ਪਹਿਲਾਂ ਰੱਦਗੀ ਜਾਂ ਸੈਨੀਟਾਈਜ਼ੇਸ਼ਨ	C2.2.1
ਗੈਰ-ਸਮਰਥਤ ਭਾਸ਼ਾਵਾਂ ਲਈ ਸਮੱਗਰੀ ਵਰਗੀਕਰਨ ਦਾ ਮੁਲਾਂਕਣ	C2.2.2
ਸਖਿਲਾਈ ਤੋਂ ਪਹਿਲਾਂ ਮਨਾਹੀ ਵਾਲੀ ਸਮੱਗਰੀ ਦੀ ਪਛਾਣ ਅਤੇ ਉਸ ਨੂੰ ਹਟਾਉਣਾ	C1.3.4

Common pitfalls: deploying classifiers tuned only for one language; screening prompts but not the training corpus.

ਆਮ ਗਲਤੀਆਂ: ਸਰਿਫ਼ ਇੱਕ ਭਾਸ਼ਾ ਲਈ ਟ੍ਰੇਨਿੰਗ ਕੀਤੇ ਵਰਗੀਕਾਰ ਤੈਨਾਤ ਕਰਨੇ; prompt ਦੀ ਛਾਣਬੀਣ ਕਰਨੀ ਪਰ ਸਖਿਲਾਈ ਭੰਡਾਰ (corpus) ਦੀ ਨਹੀਂ।

AD.8 Output Handling & Safety

AD.8 ਆਉਟਪੁੱਟ ਪ੍ਰਬੰਧਨ ਅਤੇ ਸਲਾਮਤੀ

Constrain, filter, and validate model outputs before they reach users or downstream systems.

ਮਾਡਲ ਆਉਟਪੁੱਟ ਨੂੰ ਉਪਭੋਗਤਾਵਾਂ ਜਾਂ ਡਾਊਨਸਟ੍ਰੀਮ ਸਿਸਟਮਾਂ ਤੱਕ ਪਹੁੰਚਣ ਤੋਂ ਪਹਿਲਾਂ ਸੀਮਤ ਕਰੋ, ਫ਼ਿਲਟਰ ਕਰੋ, ਅਤੇ ਪ੍ਰਮਾਣਿਤ ਕਰੋ।

Control / Technique	Requirement IDs
Schema validation of model outputs with rejection on mismatch	C7.1.1
Length limits and termination controls on generated output	C7.1.2
Confidence or uncertainty estimation for generated answers	C7.2.1

Control / Technique	Requirement IDs
Automatic blocking or fallback when confidence drops below a defined threshold	C7.2.2
Additional verification step for responses classified as high-risk by policy	C7.2.3
Automated classifiers that scan responses and block defined harmful-content categories	C7.3.1
Detection and blocking of responses that disclose system prompt content or backend data	C7.3.2
Prevention of model-generated output triggering outbound requests	C7.3.3
Detection of hidden, encoded, or misleading output (homoglyphs, formatting, metadata, structured fields)	C7.3.4

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਮਾਡਲ ਆਊਟਪੁੱਟ ਦੀ ਸਕੀਮਾ ਪ੍ਰਮਾਣਿਕਤਾ, ਅਤੇ ਮੇਲ ਨਾ ਖਾਣ 'ਤੇ ਰੱਦਗੀ	C7.1.1
ਤਿਆਰ ਕੀਤੇ ਆਊਟਪੁੱਟ ਉੱਤੇ ਲੰਬਾਈ ਸੀਮਾਵਾਂ ਅਤੇ ਸਮਾਪਤੀ ਨਿਯੰਤਰਣ	C7.1.2
ਤਿਆਰ ਕੀਤੇ ਜਵਾਬਾਂ ਲਈ ਭਰੋਸਾ ਜਾਂ ਅਨੁਸ਼ਚਿਤਤਾ ਦਾ ਅਨੁਮਾਨ	C7.2.1
ਭਰੋਸਾ ਇੱਕ ਪਰਭਾਸ਼ਿਤ ਥ੍ਰੈਸ਼ਹੋਲਡ ਤੋਂ ਹੇਠਾਂ ਡਿਗਣ 'ਤੇ ਆਪਣੇ-ਆਪ ਰੋਕ ਜਾਂ ਫਾਲਬੈਕ	C7.2.2
ਨੀਤੀ ਦੁਆਰਾ ਉੱਚ-ਜੋਖਮ ਵਜੋਂ ਵਰਗੀਕ੍ਰਿਤ ਜਵਾਬਾਂ ਲਈ ਵਾਧੂ ਤਸਦੀਕ ਪੜਾਅ	C7.2.3
ਸਵੈਚਾਲਿਤ ਵਰਗੀਕਾਰ ਜੋ ਜਵਾਬਾਂ ਨੂੰ ਸਕੈਨ ਕਰਦੇ ਹਨ ਅਤੇ ਪਰਭਾਸ਼ਿਤ ਨੁਕਸਾਨਦੇਹ-ਸਮੱਗਰੀ ਸ਼੍ਰੇਣੀਆਂ ਨੂੰ ਰੋਕਦੇ ਹਨ	C7.3.1
system prompt ਦੀ ਸਮੱਗਰੀ ਜਾਂ ਬੈਕਐਂਡ ਡਾਟੇ ਦਾ ਖੁਲਾਸਾ ਕਰਨ ਵਾਲੇ ਜਵਾਬਾਂ ਦੀ ਪਛਾਣ ਅਤੇ ਰੋਕ	C7.3.2
ਮਾਡਲ ਦੁਆਰਾ ਤਿਆਰ ਕੀਤੇ ਆਊਟਪੁੱਟ ਦੁਆਰਾ ਬਾਹਰ ਜਾਣ ਵਾਲੀਆਂ ਬੇਨਤੀਆਂ ਸ਼ੁਰੂ ਕਰਨ ਦੀ ਰੋਕਥਾਮ	C7.3.3
ਲੁਕੇ ਹੋਏ, ਏਨਕੋਡ ਕੀਤੇ, ਜਾਂ ਗੁਮਰਾਹਕੁਨ ਆਊਟਪੁੱਟ ਦੀ ਪਛਾਣ (homoglyph, ਫਾਰਮੈਟਿੰਗ, ਮੈਟਾਡਾਟਾ, ਢਾਂਚਾਗਤ ਖੇਤਰ)	C7.3.4

Common pitfalls: enforcing stop sequences in batch mode but not on streaming output; leaking the system prompt through paraphrase; treating a confidence score as available when the provider does not expose one.

ਆਮ ਗਲਤੀਆਂ: ਬੈਚ ਮੋਡ ਵਿੱਚ stop sequence ਲਾਗੂ ਕਰਨੇ ਪਰ ਸਟ੍ਰੀਮਿੰਗ ਆਊਟਪੁੱਟ ਉੱਤੇ ਨਹੀਂ; ਪੈਰਾਫ੍ਰੇਜ ਰਾਹੀਂ system prompt ਲੀਕ ਕਰ ਦੇਣਾ; ਭਰੋਸਾ ਸਕੋਰ ਨੂੰ ਉਪਲਬਧ ਮੰਨ ਲੈਣਾ ਜਦੋਂ ਪ੍ਰਦਾਤਾ ਉਹ ਦਿੰਦਾ ਹੀ ਨਹੀਂ।

AD.9 Rate Limiting, Budgets & Resource Control

AD.9 ਦਰ ਸੀਮਾ, ਬਜਟ, ਅਤੇ ਸਰੋਤ ਨਿਯੰਤਰਣ

Bound consumption to prevent abuse, runaway execution, denial of service, and model extraction.

ਦੁਰਵਰਤੋਂ, ਬੇਕਾਬੂ ਐਗਜ਼ੀਕਿਊਸ਼ਨ, ਸੇਵਾ-ਇਨਕਾਰ, ਅਤੇ model extraction ਨੂੰ ਰੋਕਣ ਲਈ ਖਪਤ ਨੂੰ ਸੀਮਾਬੱਧ ਕਰੋ।

Control / Technique	Requirement IDs
Per-tool quotas and timeouts (CPU, memory, disk, egress, execution time)	C9.1.1
Per-execution budgets (maximum recursion depth, token use, monetary spend) enforced by the runtime	C9.1.2
Per-principal and global inference rate limits sized to the extraction threat model, not a generic API throttle	C11.2.2

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਪ੍ਰਤੀ-ਟੂਲ ਕੋਟੇ ਅਤੇ ਟਾਈਮਆਊਟ (CPU, ਮੈਮੋਰੀ, ਡਿਸਕ, ਬਾਹਰ ਜਾਣ ਵਾਲਾ ਟਰੈਫਿਕ, ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਸਮਾਂ)	C9.1.1
ਰਨਟਾਈਮ ਦੁਆਰਾ ਲਾਗੂ ਕੀਤੇ ਪ੍ਰਤੀ-ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਬਜਟ (ਵੱਧ ਤੋਂ ਵੱਧ ਰੀਕਰਸ਼ਨ ਡੂੰਘਾਈ, ਟੋਕਨ ਵਰਤੋਂ, ਵੱਡੀ ਖਰਚ)	C9.1.2
ਪ੍ਰਤੀ-ਪ੍ਰਿੰਸੀਪਲ ¹⁸² ਅਤੇ ਸਮੁੱਚੀਆਂ ਇਨਫਰੈਂਸ ਦਰ ਸੀਮਾਵਾਂ, ਜੋ ਆਮ API ਥਰੋਟਲ ਦੀ ਬਜਾਏ extraction ਖਤਰਾ ਮਾਡਲ ਦੇ ਅਨੁਸਾਰ ਮਿਥੀਆਂ ਗਈਆਂ ਹੋਣ	C11.2.2

Common pitfalls: rate-limiting per endpoint but not per agent session; ignoring tool fan-out when sizing budgets; treating extraction defense as ordinary throttling.

ਆਮ ਗਲਤੀਆਂ: ਪ੍ਰਤੀ ਐਂਡਪੁਆਇੰਟ ਦਰ ਸੀਮਾ ਲਾਉਣੀ ਪਰ ਪ੍ਰਤੀ ਏਜੰਟ ਸੈਸ਼ਨ ਨਹੀਂ; ਬਜਟ ਮਿਥਦੇ ਸਮੇਂ ਟੂਲ ਫੈਨ-ਆਊਟ (fan-out) ਨੂੰ ਅਣਗੌਲਿਆਂ ਕਰਨਾ; extraction ਵਰਿਥ ਬਚਾਅ ਨੂੰ ਆਮ ਥਰੋਟਲਿੰਗ ਸਮਝ ਲੈਣਾ।

AD.10 Sandboxing & Workload Isolation

AD.10 ਸੈਂਡਬਾਕਸਿੰਗ ਅਤੇ ਵਰਕਲੋਡ ਅਲੱਗ-ਥਲੱਗਤਾ

Isolate models, tools, agents, and hardware workloads to contain failures and prevent lateral movement.

ਨਾਕਾਮੀਆਂ ਨੂੰ ਘੇਰਨ ਅਤੇ lateral movement (ਪਾਸੇ-ਵੱਲ ਫੈਲਾਅ)¹⁸³ ਨੂੰ ਰੋਕਣ ਲਈ ਮਾਡਲਾਂ, ਟੂਲਾਂ, ਏਜੰਟਾਂ, ਅਤੇ ਹਾਰਡਵੇਅਰ ਵਰਕਲੋਡਾਂ ਨੂੰ ਅਲੱਗ-ਥਲੱਗ ਕਰੋ।

Control / Technique	Requirement IDs
Execution of AI models in isolated sandboxes	C4.1.1
Allow-list of serialization formats that do not permit code execution during deserialization	C4.1.2
Workload attestation before model loading	C4.1.3
Confidential inference protecting model weights at runtime through isolated execution	C4.1.4

¹⁸² **per-principal** (EN) -> ਪ੍ਰਿੰਸੀਪਲ (loan) — a recorded, still-open corpus split: this site and C11.2.2 use the loan, while C9.4.1 and another site in this same file use ਪਛਾਣ-ਇਕਾਈ for the same underlying concept; flagged for a reviewer rather than silently resolved. Full discussion: OPEN-QUESTIONS.md Q124.

¹⁸³ **lateral movement** (EN) -> retained in Latin, glossed ਪਾਸੇ-ਵੱਲ ਫੈਲਾਅ (“spread sideways”) — a MITRE ATT&CK tactic name, so the English stays for cross-reference against the threat-intel literature while the gloss carries the descriptive sense. Full discussion: OPEN-QUESTIONS.md Q103.

Control / Technique	Requirement IDs
Trusted execution environment with hardware-enforced isolation, memory encryption, and integrity protection	C4.2.2
GPU integrity validation via hardware attestation before each workload	C4.2.3
GPU memory partitioning with sanitization between jobs	C4.2.4
Version-pinned, signed, boot-attested accelerator firmware	C4.2.1
Process, memory, and file-access isolation in edge inference runtimes	C4.3.3
Least-privilege sandbox or isolation for each tool or plugin	C9.3.1
Tool manifests declaring required privileges, resource limits, and output-validation requirements	C9.3.3
Runtime enforcement of declared tool-manifest privileges and limits	C9.3.4
Isolation of untrusted-data processing from tool-calling capability	C9.3.5
Architectural separation of untrusted tool-output processing from agent operations	C9.3.6
Least-privilege sandbox for locally launched MCP servers (restricted file system, network, system access)	C10.1.3
AI-specific runtime components not shared across environment boundaries (development, staging, production)	C3.4.1
Training and fine-tuning environments isolated from production	C3.4.2

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
AI ਮਾਡਲਾਂ ਦਾ ਅਲੌਗ-ਬਲੌਗ ਕੀਤੇ ਸੈਂਡਬਾਕਸਾਂ ਵਿੱਚ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਅਜਹੀ ਸੀਰੀਅਲਾਈਜ਼ੇਸ਼ਨ ਫਾਰਮੈਟਾਂ ਦੀ allow-list ਜੋ ਡੀਸੀਰੀਅਲਾਈਜ਼ੇਸ਼ਨ ਦੌਰਾਨ ਕੋਡ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਦੀ ਆਗਿਆ ਨਹੀਂ ਦਿੰਦੇ	C4.1.1
ਮਾਡਲ ਲੋਡ ਕਰਨ ਤੋਂ ਪਹਿਲਾਂ ਵਰਕਲੋਡ ਅਟੈਸਟੇਸ਼ਨ	C4.1.2
ਗੁਪਤ ਇਨਫਰੈਂਸ, ਜੋ ਅਲੌਗ-ਬਲੌਗ ਕੀਤੇ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਰਾਹੀਂ ਰਨਟਾਈਮ ਦੌਰਾਨ ਮਾਡਲ ਵੇਟਸ ਦੀ ਸੁਰੱਖਿਆ ਕਰਦਾ ਹੈ	C4.1.3
ਹਾਰਡਵੇਅਰ ਦੁਆਰਾ ਲਾਗੂ ਕੀਤੀ ਅਲੌਗ-ਬਲੌਗਤਾ, ਮੈਮੋਰੀ ਏਨਕ੍ਰਿਪਸ਼ਨ, ਅਤੇ ਅਖੰਡਤਾ ਸੁਰੱਖਿਆ ਵਾਲਾ ਭਰੋਸੇਯੋਗ ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਵਾਤਾਵਰਣ (TEE)	C4.1.4
ਹਰ ਵਰਕਲੋਡ ਤੋਂ ਪਹਿਲਾਂ ਹਾਰਡਵੇਅਰ ਅਟੈਸਟੇਸ਼ਨ ਰਾਹੀਂ GPU ਅਖੰਡਤਾ ਦੀ ਪੁਰਮਾਣਕਤਾ	C4.2.2
ਕੰਮਾਂ ਦੇ ਵਿਚਕਾਰ ਸੈਨੀਟਾਈਜ਼ੇਸ਼ਨ ਸਮੇਤ GPU ਮੈਮੋਰੀ ਦਾ ਵਭਿਜਨ	C4.2.3
ਵਰਜ਼ਨ-ਪਨਿ ਕੀਤਾ, ਦਸਤਖਤ ਕੀਤਾ, ਬੂਟ ਵੇਲੇ ਅਟੈਸਟ ਕੀਤਾ ਐਕਸਲੇਰੇਟਰ ਫਰਮਵੇਅਰ	C4.2.4
ਐਜ ਇਨਫਰੈਂਸ ਰਨਟਾਈਮਾਂ ਵਿੱਚ ਪ੍ਰਕਰਿਆ, ਮੈਮੋਰੀ, ਅਤੇ ਫਾਈਲ-ਪਹੁੰਚ ਦੀ ਅਲੌਗ-ਬਲੌਗਤਾ	C4.2.1
	C4.3.3

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਹਰ ਟੂਲ ਜਾਂ ਪਲੱਗਇਨ ਲਈ ਘੱਟੋ-ਘੱਟ-ਵਸ਼ਿਸ਼-ਅਧਿਕਾਰ ਸੈਂਡਬਾਕਸ ਜਾਂ ਅਲੌਗ-ਥਲੌਗਤਾ	C9.3.1
ਲੋੜੀਂਦੇ ਵਸ਼ਿਸ਼-ਅਧਿਕਾਰਾਂ, ਸਰੋਤ ਸੀਮਾਵਾਂ, ਅਤੇ ਆਊਟਪੁੱਟ-ਪ੍ਰਮਾਣਿਕਤਾ	C9.3.3
ਲੋੜਾਂ ਦੀ ਘੋਸ਼ਣਾ ਕਰਨ ਵਾਲੇ ਟੂਲ ਮੈਨੀਫੈਸਟ	
ਟੂਲ ਮੈਨੀਫੈਸਟਾਂ ਵਿੱਚ ਘੋਸ਼ਿਤ ਵਸ਼ਿਸ਼-ਅਧਿਕਾਰਾਂ ਅਤੇ ਸੀਮਾਵਾਂ ਦਾ ਰਨਟਾਈਮ ਲਾਗੂਕਰਨ	C9.3.4
ਗੈਰ-ਭਰੋਸੇਯੋਗ ਡਾਟਾ ਪ੍ਰਕਿਰਿਆ ਦੀ ਟੂਲ-ਕਾਲ ਕਰਨ ਦੀ ਸਮਰੱਥਾ ਤੋਂ ਅਲੌਗ-ਥਲੌਗਤਾ	C9.3.5
ਗੈਰ-ਭਰੋਸੇਯੋਗ ਟੂਲ-ਆਊਟਪੁੱਟ ਪ੍ਰਕਿਰਿਆ ਦਾ ਏਜੰਟ ਕਾਰਵਾਈਆਂ ਤੋਂ ਆਰਕੀਟੈਕਚਰਲ ਵਭਿਜਨ	C9.3.6
ਸਥਾਨਕ ਤੌਰ 'ਤੇ ਚਲਾਏ ਗਏ MCP ਸਰਵਰਾਂ ਲਈ ਘੱਟੋ-ਘੱਟ-ਵਸ਼ਿਸ਼-ਅਧਿਕਾਰ ਸੈਂਡਬਾਕਸ (ਸੀਮਿਤ ਫ਼ਾਈਲਸਿਸਟਮ, ਨੈੱਟਵਰਕ, ਸਿਸਟਮ ਪਹੁੰਚ)	C10.1.3
AI-ਵਸ਼ਿਸ਼ ਰਨਟਾਈਮ ਕੰਪੋਨੈਂਟ ਵਾਤਾਵਰਣ ਸੀਮਾਵਾਂ (ਵਕਿਸ, ਸਟੇਜਿੰਗ, ਪ੍ਰੋਡਕਸ਼ਨ) ਦੇ ਆਰ-ਪਾਰ ਸਾਂਝੇ ਨਾ ਕੀਤੇ ਜਾਣ	C3.4.1
ਸਥਿਰਤਾ ਅਤੇ ਫ਼ਾਈਨ-ਟਿਊਨਿੰਗ ਵਾਤਾਵਰਣਾਂ ਦਾ ਪ੍ਰੋਡਕਸ਼ਨ ਤੋਂ ਅਲੌਗ-ਥਲੌਗ ਹੋਣਾ	C3.4.2

Common pitfalls: sharing infrastructure between dev and prod; granting tool sandboxes more capability than needed; allowing untrusted data processing to reach tool-calling paths.

ਆਮ ਗਲਤੀਆਂ: ਵਕਿਸ ਅਤੇ ਪ੍ਰੋਡਕਸ਼ਨ ਵਰਤਕਾਰ ਬੁਨਿਆਦੀ ਢਾਂਚਾ ਸਾਂਝਾ ਕਰਨਾ; ਟੂਲ ਸੈਂਡਬਾਕਸਾਂ ਨੂੰ ਲੋੜ ਤੋਂ ਵੱਧ ਸਮਰੱਥਾ ਦੇਣੀ; ਗੈਰ-ਭਰੋਸੇਯੋਗ ਡਾਟਾ ਪ੍ਰਕਿਰਿਆ ਨੂੰ ਟੂਲ-ਕਾਲ ਦੇ ਰਾਹਾਂ ਤੱਕ ਪਹੁੰਚਣ ਦੇਣਾ।

AD.11 Network & Egress Control

AD.11 ਨੈੱਟਵਰਕ ਅਤੇ ਬਾਹਰ ਜਾਣ ਵਾਲੇ ਟਰੈਫ਼ਿਕ (egress) ਦਾ ਨਿਯੰਤਰਣ

Control network boundaries, transport security, and traffic flow for AI workloads and MCP integrations.

AI ਵਰਕਲੋਡਾਂ ਅਤੇ MCP ਏਕੀਕਰਨਾਂ ਲਈ ਨੈੱਟਵਰਕ ਸੀਮਾਵਾਂ, ਟ੍ਰਾਂਸਪੋਰਟ ਸੁਰੱਖਿਆ, ਅਤੇ ਟਰੈਫ਼ਿਕ ਦੇ ਵਹਾਅ ਨੂੰ ਨਿਯੰਤਰਿਤ ਕਰੋ।

Control / Technique	Requirement IDs
Authenticated, encrypted streamable HTTP for remote MCP transport	C10.3.1
stdio MCP transport restricted to controlled local environments	C10.3.2
Independent Origin and Host header validation on HTTP-based transports (DNS rebinding defense)	C10.3.3
MCP client minimum protocol-version enforcement (downgrade defense)	C10.3.4
Accelerator interconnects restricted to approved topologies and authenticated endpoints	C4.2.5

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਰਸਿਟ MCP ਟ੍ਰਾਂਸਪੋਰਟ ਲਈ ਪ੍ਰਮਾਣੀਕਰਨ ਕੀਤਾ, ਏਨਕ੍ਰਿਪਟ ਕੀਤਾ streamable HTTP	C10.3.1
stdio MCP ਟ੍ਰਾਂਸਪੋਰਟ ਸਰਿਫ਼ ਨਿਯੰਤਰਤਿ ਸਥਾਨਕ ਵਾਤਾਵਰਣਾਂ ਤੱਕ ਸੀਮਤਿ	C10.3.2
HTTP-ਆਧਾਰਤਿ ਟ੍ਰਾਂਸਪੋਰਟਾਂ ਉੱਤੇ Origin ਅਤੇ Host header ਦੀ ਸੁਤੰਤਰ ਪ੍ਰਮਾਣਿਕਤਾ (DNS rebinding ਵਰਿੱਧ ਬਚਾਅ)	C10.3.3
MCP ਕਲਾਇੰਟ ਦੁਆਰਾ ਘੱਟੋ-ਘੱਟ ਪ੍ਰੋਟੋਕੋਲ-ਵਰਜ਼ਨ ਦਾ ਲਾਗੂਕਰਨ (ਡਾਊਨਗ੍ਰੇਡ ¹⁸⁴ ਵਰਿੱਧ ਬਚਾਅ)	C10.3.4
ਐਕਸਲੇਰੇਟਰ ਇੰਟਰਕਨੈਕਟਾਂ ਦਾ ਪ੍ਰਵਾਨਤਿ ਟੋਪੋਲੋਜੀਆਂ ਅਤੇ ਪ੍ਰਮਾਣੀਕਰਨ ਕੀਤੇ ਐਡਪੁਆਇੰਟਾਂ ਤੱਕ ਸੀਮਤਿ ਹੋਣਾ	C4.2.5

Common pitfalls: exposing stdio or SSE transports beyond the local host; skipping Origin/Host validation and enabling DNS rebinding; accepting downgraded protocol versions.

ਆਮ ਗਲਤੀਆਂ: stdio ਜਾਂ SSE ਟ੍ਰਾਂਸਪੋਰਟਾਂ ਨੂੰ ਸਥਾਨਕ ਹੋਸਟ ਤੋਂ ਪਰੇ ਜਾਹਰ ਕਰਨਾ; Origin/Host ਪ੍ਰਮਾਣਿਕਤਾ ਛੱਡ ਦੇਣੀ ਅਤੇ DNS rebinding ਨੂੰ ਸੰਭਵ ਬਣਾ ਦੇਣਾ; ਡਾਊਨਗ੍ਰੇਡ ਕੀਤੇ ਪ੍ਰੋਟੋਕੋਲ ਵਰਜ਼ਨ ਸਵੀਕਾਰ ਕਰਨੇ।

AD.12 Supply Chain & Artifact Integrity

AD.12 ਸਪਲਾਈ ਚੇਨ ਅਤੇ ਆਰਟੀਫੈਕਟ ਅਖੰਡਤਾ

Verify origin and authenticity of models, datasets, frameworks, and MCP components, and maintain an AI bill of materials.

ਮਾਡਲਾਂ, ਡਾਟਾਸੈੱਟਾਂ, ਫ੍ਰੇਮਵਰਕਾਂ, ਅਤੇ MCP ਕੰਪੋਨੈਂਟਾਂ ਦੇ ਮੂਲ ਅਤੇ ਅਸਲੀਅਤ ਦੀ ਤਸਦੀਕ ਕਰੋ, ਅਤੇ ਇੱਕ AI ਬਲਿ ਆਫ ਮਟੀਰੀਅਲਜ਼ ਬਰਕਰਾਰ ਰੱਖੋ।

Control / Technique	Requirement IDs
Model registry inventory of all deployed model artifacts and their origin	C3.1.1
Malicious-code scanning of models before import	C6.1.1
Approved-source-only download of model weights, datasets, and fine-tuning adapters	C6.1.2
Integrity verification of every third-party model artifact	C6.1.3
Behavioral acceptance test suite passed before promotion beyond development	C6.1.4
Version-controlled, machine-readable AI BOM per model artifact (datasets, weights, licenses, data-origin statements)	C6.2.1
Cryptographic signing of AI BOMs before deployment	C6.2.2
Build-failing AI BOM completeness checks when component metadata is missing	C6.2.3

¹⁸⁴ **downgrade** (protocol) (EN) -> ਡਾਊਨਗ੍ਰੇਡ — the one term in this control row not already settled by the C10 chapter's transport vocabulary; kept as a loan since it names a forced protocol-version rollback, consistent with the corpus's treatment of protocol-layer terms. Full discussion: OPEN-QUESTIONS.md Q100.

Control / Technique	Requirement IDs
MCP components obtained only from trusted sources and cryptographically verified	C10.1.1
Allow-listed MCP servers only	C10.1.2

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਸਾਰੇ ਤੈਨਾਤ ਕੀਤੇ ਮਾਡਲ ਆਰਟੀਫੈਕਟਾਂ ਅਤੇ ਉਹਨਾਂ ਦੇ ਮੂਲ ਦੀ ਮਾਡਲ ਰਜਿਸਟਰੀ ਇਨਵੈਂਟਰੀ	C3.1.1
ਆਯਾਤ ਤੋਂ ਪਹਿਲਾਂ ਮਾਡਲਾਂ ਦੀ ਖਤਰਨਾਕ ਕੋਡ ਲਈ ਸਕੈਨਿੰਗ	C6.1.1
ਮਾਡਲ ਵੇਟਸ, ਡਾਟਾਸੈੱਟਾਂ, ਅਤੇ ਫਾਈਨ-ਟਿਊਨਿੰਗ ਅਡੈਪਟਰਾਂ ਦਾ ਸਰਿਫ਼ ਪ੍ਰਵਾਨਤਿ ਸਰੋਤਾਂ ਤੋਂ ਡਾਊਨਲੋਡ	C6.1.2
ਹਰ ਤੀਜੀ-ਧਰਿ ਮਾਡਲ ਆਰਟੀਫੈਕਟ ਦੀ ਅਖੰਡਤਾ ਦੀ ਤਸਦੀਕ	C6.1.3
ਵਿਕਾਸ ਤੋਂ ਪਰੇ ਤਰੱਕੀ ਤੋਂ ਪਹਿਲਾਂ ਵਿਵਹਾਰਕ ਸਵੀਕ੍ਰਿਤੀ ਟੈਸਟ ਸੂਟ ਦਾ ਪਾਸ ਹੋਣਾ	C6.1.4
ਪ੍ਰਤੀ ਮਾਡਲ ਆਰਟੀਫੈਕਟ ਵਰਜਨ-ਨਿਯੰਤਰਤਿ, ਮਸ਼ੀਨ-ਪੜ੍ਹਨਯੋਗ AI BOM (ਡਾਟਾਸੈੱਟ, ਵੇਟਸ, ਲਾਇਸੈਂਸ, ਡਾਟਾ-ਮੂਲ ਬਿਆਨ)	C6.2.1
ਤੈਨਾਤੀ ਤੋਂ ਪਹਿਲਾਂ AI BOM ਦੇ ਕ੍ਰਪਿਟੋਗ੍ਰਾਫ਼ਿਕ ਦਸਤਖ਼ਤ	C6.2.2
ਕੰਪੋਨੈਂਟ ਮੈਟਾਡਾਟਾ ਗੈਰ-ਮੌਜੂਦ ਹੋਣ 'ਤੇ ਬਲਿਡ ਨੂੰ ਫੇਲ੍ਹ ਕਰਨ ਵਾਲੀਆਂ AI BOM ਸੰਪੂਰਨਤਾ ਜਾਂਚਾਂ	C6.2.3
MCP ਕੰਪੋਨੈਂਟ ਸਰਿਫ਼ ਭਰੋਸੇਯੋਗ ਸਰੋਤਾਂ ਤੋਂ ਪ੍ਰਾਪਤ ਕੀਤੇ ਅਤੇ ਕ੍ਰਪਿਟੋਗ੍ਰਾਫ਼ਿਕ ਤੌਰ 'ਤੇ ਤਸਦੀਕ ਕੀਤੇ ਜਾਣ	C10.1.1
ਸਰਿਫ਼ allow-list ਕੀਤੇ MCP ਸਰਵਰ	C10.1.2

Common pitfalls: treating AI BOMs as static documents rather than signed, version-controlled artifacts; not scanning pretrained weights for backdoors; pulling models from unapproved registries.

ਆਮ ਗਲਤੀਆਂ: AI BOM ਨੂੰ ਦਸਤਖ਼ਤ ਕੀਤੇ, ਵਰਜਨ-ਨਿਯੰਤਰਤਿ ਆਰਟੀਫੈਕਟਾਂ ਦੀ ਬਜਾਏ ਸਥਰਿ ਦਸਤਾਵੇਜ਼ ਸਮਝਣਾ; ਪਹਿਲਾਂ ਤੋਂ ਸਖਿਲਾਈ ਪ੍ਰਾਪਤ ਵੇਟਸ ਦੀ backdoor ਲਈ ਸਕੈਨਿੰਗ ਨਾ ਕਰਨੀ; ਗੈਰ-ਪ੍ਰਵਾਨਤਿ ਰਜਿਸਟਰੀਆਂ ਤੋਂ ਮਾਡਲ ਲੈਣੇ।

AD.13 Model Lifecycle, Deployment & Rollback

AD.13 ਮਾਡਲ ਜੀਵਨ-ਚੱਕਰ, ਤੈਨਾਤੀ, ਅਤੇ ਰੋਲਬੈਕ

Manage model validation, deployment, rollback, and fine-tuning pipeline integrity.

ਮਾਡਲ ਪ੍ਰਮਾਣਿਕਤਾ, ਤੈਨਾਤੀ, ਰੋਲਬੈਕ, ਅਤੇ ਫਾਈਨ-ਟਿਊਨਿੰਗ ਪਾਈਪਲਾਈਨ ਦੀ ਅਖੰਡਤਾ ਦਾ ਪ੍ਰਬੰਧ ਕਰੋ।

Control / Technique	Requirement IDs
Pre-deployment automated input-validation, safety-evaluation, and output-sanitization testing	C3.2.1
Re-evaluation of models subjected to post-training quantization against the same safety and alignment test suite before deployment	C3.2.2

Control / Technique	Requirement IDs
Security re-evaluation triggered by provider model, version, or routing changes	C3.2.3
Rollout mechanisms with automated rollback triggers	C3.3.1
Complete model-state restoration on rollback	C3.3.2
Isolated runtime state for model versions running in parallel	C3.3.3
Versioned, integrity-verified RLHF reward models before a training run	C3.5.1
Detection of reward hacking or reward-model over-optimization in RLHF stages	C3.5.2
Stage-by-stage integrity verification in multi-stage fine-tuning pipelines	C3.5.3
Fine-tuning checkpoints registered as distinct artifacts	C3.5.4

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਤੈਨਾਤੀ ਤੋਂ ਪਹਿਲਾਂ ਸਵੈਚਲਤਿ ਇਨਪੁੱਟ-ਪ੍ਰਮਾਣਿਕਤਾ, ਸਲਾਮਤੀ-ਮੁਲਾਂਕਣ, ਅਤੇ ਆਊਟਪੁੱਟ-ਸੈਨੀਟਾਈਜ਼ੇਸ਼ਨ ਟੈਸਟਿੰਗ	C3.2.1
ਸਖਿਲਾਈ-ਉਪਰੰਤ ਕੁਆਂਟਾਈਜ਼ੇਸ਼ਨ ਵੱਲੋਂ ਲੰਘੇ ਮਾਡਲਾਂ ਦਾ, ਤੈਨਾਤੀ ਤੋਂ ਪਹਿਲਾਂ, ਉਸੇ ਸਲਾਮਤੀ ਅਤੇ ਅਲਾਈਨਮੈਂਟ ਟੈਸਟ ਸੂਟ ਦੇ ਵਰਿਥ ਮੁੜ-ਮੁਲਾਂਕਣ ਪ੍ਰਦਾਤਾ ਦੇ ਮਾਡਲ, ਵਰਜਨ, ਜਾਂ ਰੂਟਿੰਗ ਵੱਲੋਂ ਤਬਦੀਲੀਆਂ ਦੁਆਰਾ ਸ਼ੁਰੂ ਕੀਤਾ ਸੁਰੱਖਿਆ ਮੁੜ-ਮੁਲਾਂਕਣ	C3.2.2
ਸਵੈਚਲਤਿ ਰੋਲਬੈਕ ਟ੍ਰਿਗਰਾਂ ਸਮੇਤ ਰੋਲਆਊਟ ਵਧੀਆਂ ਰੋਲਬੈਕ 'ਤੇ ਮਾਡਲ ਦੀ ਸੰਪੂਰਨ ਸਥਿਤੀ ਦੀ ਬਹਾਲੀ	C3.2.3
ਸਮਾਨਾਂਤਰ ਚੱਲ ਰਹੇ ਮਾਡਲ ਵਰਜਨਾਂ ਲਈ ਅਲੱਗ-ਥਲੱਗ ਕੀਤੀ ਰਨਟਾਈਮ ਸਥਿਤੀ	C3.3.1
ਸਖਿਲਾਈ ਦੌਰ ਤੋਂ ਪਹਿਲਾਂ ਵਰਜਨਬੱਧ, ਅਖੰਡਤਾ-ਤਸਦੀਕਸ਼ੁਦਾ RLHF ਇਨਾਮ ਮਾਡਲ	C3.3.2
RLHF ਪੜਾਵਾਂ ਵੱਲੋਂ reward hacking ਜਾਂ ਇਨਾਮ ਮਾਡਲ ਦੇ ਹੱਦੋਂ ਵੱਧ ਅਨੁਕੂਲਨ ਦੀ ਪਛਾਣ	C3.3.3
ਬਹੁ-ਪੜਾਵੀ ਫ਼ਾਈਨ-ਟਿਊਨਿੰਗ ਪਾਈਪਲਾਈਨਾਂ ਵੱਲੋਂ ਪੜਾਅ-ਦਰ-ਪੜਾਅ ਅਖੰਡਤਾ ਤਸਦੀਕ	C3.5.1
ਫ਼ਾਈਨ-ਟਿਊਨਿੰਗ ਚੈਕਪੁਆਇੰਟਾਂ ਦਾ ਵੱਖਰੇ ਆਰਟੀਫੈਕਟਾਂ ਵਜੋਂ ਰਜਿਸਟਰ ਹੋਣਾ	C3.5.2
	C3.5.3
	C3.5.4

Common pitfalls: not testing rollback before it is needed; leaving retired model artifacts in serving caches; treating reward models as static infrastructure rather than versioned, validated artifacts.

ਆਮ ਗਲਤੀਆਂ: ਲੋੜ ਪੈਣ ਤੋਂ ਪਹਿਲਾਂ ਰੋਲਬੈਕ ਦੀ ਪਰਖ ਨਾ ਕਰਨੀ; ਸੇਵਾ-ਮੁਕਤ ਕੀਤੇ ਮਾਡਲ ਆਰਟੀਫੈਕਟਾਂ ਨੂੰ ਸਰਵਿਸ ਕੈਸ਼ਾਂ ਵੱਲੋਂ ਛੱਡ ਦੇਣਾ; ਇਨਾਮ ਮਾਡਲਾਂ ਨੂੰ ਵਰਜਨਬੱਧ, ਪ੍ਰਮਾਣਿਤ ਆਰਟੀਫੈਕਟਾਂ ਦੀ ਬਜਾਏ ਸਥਿਰ ਬੁਨਿਆਦੀ ਢਾਂਚਾ ਸਮਝਣਾ।

AD.14 Training Data Integrity & Governance

AD.14 ਸਖਿਲਾਈ ਡਾਟਾ ਅਖੰਡਤਾ ਅਤੇ ਸ਼ਾਸਨ

Source, vet, and document training data so tampering, poisoning, and corruption can be detected and traced.

ਸਖਿਲਾਈ ਡਾਟਾ ਨੂੰ ਇਸ ਤਰ੍ਹਾਂ ਪ੍ਰਾਪਤ ਕਰੋ, ਪਰਖੋ, ਅਤੇ ਦਸਤਾਵੇਜ਼ਬੱਧ ਕਰੋ ਕਿ ਛੇੜਛਾੜ, poisoning, ਅਤੇ ਵਗਿਰਾ ਦਾ ਪਤਾ ਲਗਾਇਆ ਅਤੇ ਟਰੇਸ ਕੀਤਾ ਜਾ ਸਕੇ।

Control / Technique	Requirement IDs
Data minimization to only the features, attributes, and fields required for the stated purpose	C1.1.1
Up-to-date inventory of every training-data source (origin, responsible party, license, collection method, use constraints, processing history)	C1.1.2
Dataset watermarking for usage attribution and detection of unauthorized use	C1.1.5
Labeling-platform access controls restricting who can create, modify, or approve annotations	C1.2.1
Poisoning detection in training and fine-tuning pipelines	C1.3.1
Confidence thresholds and consistency checks on automatically generated labels	C1.3.2
Bias evaluation for models used in security-relevant decisions	C1.3.3
Defenses against clean-label poisoning attacks	C1.3.5
Dataset lineage recording (transformations, augmentations, merges)	C12.5.1
Logging of all labeling activities	C12.5.2
Write-time tagging of every ingested document (source, writer identity, timestamp)	C12.5.4

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਡਾਟਾ ਨੂੰ ਸਰਿਫ਼ ਦੱਸੇ ਗਏ ਮਕਸਦ ਲਈ ਲੋੜੀਂਦੇ ਫੀਚਰਾਂ, ਗੁਣਾਂ, ਅਤੇ ਖੇਤਰਾਂ ਤੱਕ ਘਟਾਉਣਾ	C1.1.1
ਹਰ ਸਖਿਲਾਈ-ਡਾਟਾ ਸਰੋਤ ਦੀ ਅੱਪ-ਟੂ-ਡੇਟ ਇਨਵੈਂਟਰੀ (ਮੂਲ, ਜ਼ਿੰਮੇਵਾਰ ਧਰਿ, ਲਾਇਸੰਸ, ਇਕੱਤਰੀਕਰਨ ਵਧੀ, ਵਰਤੋਂ ਪਾਬੰਦੀਆਂ, ਪ੍ਰਕਿਰਿਆ ਇਤਿਹਾਸ)	C1.1.2
ਵਰਤੋਂ ਦੇ ਸਰੋਤ-ਨਰਿਧਾਰਨ ਅਤੇ ਅਣਅਧਿਕਾਰਤ ਵਰਤੋਂ ਦੀ ਪਛਾਣ ਲਈ ਡਾਟਾਸੈੱਟ ਵਾਟਰਮਾਰਕਿੰਗ	C1.1.5
ਲੇਬਲਿੰਗ-ਪਲੇਟਫਾਰਮ ਪਹੁੰਚ ਕੰਟਰੋਲ ਜੋ ਇਹ ਸੀਮਤ ਕਰਦੇ ਹਨ ਕਿ ਕੌਣ ਐਨੋਟੇਸ਼ਨਾਂ ਬਣਾ, ਸੋਧ, ਜਾਂ ਮਨਜ਼ੂਰ ਕਰ ਸਕਦਾ ਹੈ	C1.2.1
ਸਖਿਲਾਈ ਅਤੇ ਫਾਈਨ-ਟਿਊਨਿੰਗ ਪਾਈਪਲਾਈਨਾਂ ਵਿੱਚ poisoning ਪਛਾਣ	C1.3.1
ਸਵੈਚਾਲਤ ਢੰਗ ਨਾਲ ਪੈਦਾ ਕੀਤੇ ਲੇਬਲਾਂ ਉੱਤੇ ਭਰੋਸਾ ਥਰੈਸ਼ਹੋਲਡ ਅਤੇ ਇਕਸਾਰਤਾ ਜਾਂਚਾਂ	C1.3.2
ਸੁਰੱਖਿਆ-ਸੰਬੰਧਤ ਫ਼ੈਸਲਿਆਂ ਵਿੱਚ ਵਰਤੇ ਜਾਣ ਵਾਲੇ ਮਾਡਲਾਂ ਲਈ ਪੱਖਪਾਤ ਮੁਲਾਂਕਣ	C1.3.3
clean-label poisoning ਹਮਲਿਆਂ ਵਿਰੁੱਧ ਬਚਾਅ	C1.3.5

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਡਾਟਾਸੈੱਟ ਵੰਸ਼ਾਵਲੀ ਦਾ ਦਰਜ ਹੋਣਾ (ਪਰਵਿਰਤਨ, ਔਗਮੈਂਟੇਸ਼ਨ, ਮਰਜ)	C12.5.1
ਸਾਰੀਆਂ ਲੇਬਲਿੰਗ ਗਤੀਵਿਧੀਆਂ ਦੀ ਲੋੜ	C12.5.2
ਹਰ ਦਾਖਲ ਕੀਤੇ ਦਸਤਾਵੇਜ਼ ਦੀ ਲਿਖਣ-ਸਮੇਂ ਟੈਗਿੰਗ (ਸਰੋਤ, ਲਿਖਣ ਵਾਲੇ ਦੀ ਪਛਾਣ, ਟਾਈਮਸਟੈਂਪ)	C12.5.4

Common pitfalls: not scanning fine-tuning datasets for poisoning; collecting more attributes than the purpose requires; losing dataset lineage across transformations and merges.

ਆਮ ਗਲਤੀਆਂ: ਫ੍ਰਾਈਨ-ਟਿਊਨਿੰਗ ਡਾਟਾਸੈੱਟਾਂ ਦੀ poisoning ਲਈ ਸਕੈਨਿੰਗ ਨਾ ਕਰਨੀ; ਮਕਸਦ ਦੀ ਲੋੜ ਤੋਂ ਵੱਧ ਗੁਣ ਇਕੱਠੇ ਕਰਨੇ; ਪਰਵਿਰਤਨਾਂ ਅਤੇ ਮਰਜਾਂ ਦੇ ਆਰ-ਪਾਰ ਡਾਟਾਸੈੱਟ ਵੰਸ਼ਾਵਲੀ ਗੁਆ ਦੇਣੀ।

AD.15 Memory, Embeddings & RAG Security

AD.15 ਮੈਮੋਰੀ, embeddings, ਅਤੇ RAG ਸੁਰੱਖਿਆ

Harden vector stores, memory pipelines, and retrieval-augmented generation against leakage, poisoning, and fabricated provenance.

ਵੈਕਟਰ ਸਟੋਰਾਂ, ਮੈਮੋਰੀ ਪਾਈਪਲਾਈਨਾਂ, ਅਤੇ retrieval-augmented generation (RAG) ਨੂੰ ਲੀਕੇਜ਼, poisoning, ਅਤੇ ਘੜੇ ਹੋਏ ਮੂਲ-ਸਰੋਤ ਵਰ੍ਹਿਧ ਸਖ਼ਤ ਕਰੋ।

Control / Technique	Requirement IDs
Per-tenant uniqueness of vector identifiers and namespaces, preventing cross-tenant collisions	C8.1.1
Immutability of document metadata tags after the initial write	C8.1.2
Scope constraints enforced on retrieval operations	C8.1.3
Detection and masking, tokenization, or dropping of sensitive fields before embedding	C8.2.1
Detection, rejection, or quarantine of retrieval-manipulation content before vectorization	C8.2.4
Flagging and quarantine of outlier vectors before they enter production indices	C8.2.2
Source validation before agent or tool outputs are written to trusted memory	C8.2.3
Contradiction checks on new memory writes, with conflicts triggering alerts	C8.2.5
Exclusion of expired vectors from retrieval results	C8.3.1
Memory reset capability	C8.3.2
Retention of quarantined content while excluding it from all retrieval results	C8.3.3
Attribution of RAG responses to their source documents	C7.4.1
RAG attributions derived from retrieval metadata, not generated by the model	C7.4.2

Control / Technique	Requirement IDs
Traceability of RAG claims to the retrieved chunk	C7.4.3

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਵੈਕਟਰ ਪਛਾਣਕਰਤਾਵਾਂ ਅਤੇ ਨੇਮਸਪੇਸਾਂ ਦੀ ਪ੍ਰਤੀ-ਟੈਨੈਂਟ ਵਲਿੱਖਣਤਾ, ਜੋ ਟੈਨੈਂਟਾਂ ਵਚਿਕਾਰ ਟਕਰਾਵਾਂ ਨੂੰ ਰੋਕਦੀ ਹੈ	C8.1.1
ਸ਼ੁਰੂਆਤੀ ਲਿਖਤ ਤੋਂ ਬਾਅਦ ਦਸਤਾਵੇਜ਼ ਮੈਟਾਡਾਟਾ ਟੈਗਾਂ ਦੀ ਅਪਰਵਿਰਤਨਸ਼ੀਲਤਾ ¹⁸⁵	C8.1.2
ਪ੍ਰਾਪਤੀ ਕਾਰਵਾਈਆਂ ਉੱਤੇ ਲਾਗੂ ਕੀਤੀਆਂ ਸਕੋਪ ਪਾਬੰਦੀਆਂ	C8.1.3
embedding ਤੋਂ ਪਹਿਲਾਂ ਸੰਵੇਦਨਸ਼ੀਲ ਖੇਤਰਾਂ ਦੀ ਪਛਾਣ ਅਤੇ ਉਹਨਾਂ ਦੀ ਮਾਸਕਿੰਗ, ਟੈਕਨਾਈਜ਼ੇਸ਼ਨ, ਜਾਂ ਹਟਾਈ	C8.2.1
ਵੈਕਟਰਾਈਜ਼ੇਸ਼ਨ ਤੋਂ ਪਹਿਲਾਂ ਪ੍ਰਾਪਤੀ-ਹੇਰਾਫੇਰੀ ਵਾਲੀ ਸਮੱਗਰੀ ਦੀ ਪਛਾਣ, ਰੱਦਗੀ, ਜਾਂ ਕੁਆਰੰਟੀਨ	C8.2.4
ਬਾਹਰਲੇ (outlier) ਵੈਕਟਰਾਂ ਦਾ ਉਤਪਾਦਨ ਇੰਡੈਕਸਾਂ ਵਿੱਚ ਦਾਖਲ ਹੋਣ ਤੋਂ ਪਹਿਲਾਂ ਨਸ਼ਿਕਰਤਾ ਹੋਣਾ ਅਤੇ ਕੁਆਰੰਟੀਨ	C8.2.2
ਏਜੰਟ ਜਾਂ ਟੂਲ ਆਊਟਪੁੱਟ ਦੇ ਭਰੋਸੇਯੋਗ ਮੈਮੋਰੀ ਵਿੱਚ ਲਿਖਿ ਜਾਣ ਤੋਂ ਪਹਿਲਾਂ ਸਰੋਤ ਪ੍ਰਮਾਣਿਕਤਾ	C8.2.3
ਨਵੀਆਂ ਮੈਮੋਰੀ ਲਿਖਤਾਂ ਉੱਤੇ ਵਰਿਧਾਭਾਸ ਜਾਂਚਾਂ, ਅਤੇ ਟਕਰਾਅ 'ਤੇ ਚੇਤਾਵਨੀਆਂ	C8.2.5
ਮਿਆਦ ਪੁੱਗ ਚੁੱਕੇ ਵੈਕਟਰਾਂ ਨੂੰ ਪ੍ਰਾਪਤੀ ਨਤੀਜਿਆਂ ਵਿੱਚੋਂ ਬਾਹਰ ਰੱਖਣਾ	C8.3.1
ਮੈਮੋਰੀ ਰੀਸੈੱਟ ਦੀ ਸਮਰੱਥਾ	C8.3.2
ਕੁਆਰੰਟੀਨ ਕੀਤੀ ਸਮੱਗਰੀ ਦਾ ਧਾਰਨ, ਪਰ ਉਸ ਨੂੰ ਸਾਰੇ ਪ੍ਰਾਪਤੀ ਨਤੀਜਿਆਂ ਵਿੱਚੋਂ ਬਾਹਰ ਰੱਖਣਾ	C8.3.3
RAG ਜਵਾਬਾਂ ਦਾ ਉਹਨਾਂ ਦੇ ਸਰੋਤ ਦਸਤਾਵੇਜ਼ਾਂ ਤੱਕ ਸਰੋਤ-ਨਰਿਧਾਰਨ	C7.4.1
RAG ਸਰੋਤ-ਨਰਿਧਾਰਨ ਪ੍ਰਾਪਤੀ ਮੈਟਾਡਾਟਾ ਤੋਂ ਲੈਣ ਜਾਣ, ਮਾਡਲ ਦੁਆਰਾ ਤਿਆਰ ਨਾ ਕੀਤੇ ਜਾਣ	C7.4.2
RAG ਦਾਅਵਿਆਂ ਦੀ ਪ੍ਰਾਪਤ ਕੀਤੇ ਚੰਕ ਤੱਕ ਟਰੇਸਯੋਗਤਾ	C7.4.3

Common pitfalls: auto-writing tool output into trusted memory without validation; serving expired or quarantined vectors; letting the model fabricate citations instead of deriving them from retrieval metadata.

ਆਮ ਗਲਤੀਆਂ: ਟੂਲ ਆਊਟਪੁੱਟ ਨੂੰ ਪ੍ਰਮਾਣਿਕਤਾ ਤੋਂ ਬਿਨਾਂ ਆਪਣੇ-ਆਪ ਭਰੋਸੇਯੋਗ ਮੈਮੋਰੀ ਵਿੱਚ ਲਿਖਿ ਦੇਣਾ; ਮਿਆਦ ਪੁੱਗ ਚੁੱਕੇ ਜਾਂ ਕੁਆਰੰਟੀਨ ਕੀਤੇ ਵੈਕਟਰ ਪਰੋਸਣੇ; ਮਾਡਲ ਨੂੰ ਪ੍ਰਾਪਤੀ ਮੈਟਾਡਾਟਾ ਤੋਂ ਲੈਣ ਦੀ ਬਜਾਏ ਹਵਾਲੇ ਘੜਨ ਦੇਣਾ।

AD.16 Adversarial Robustness & Privacy Defense

AD.16 ਵਰਿਧੀ ਮਜ਼ਬੂਤੀ ਅਤੇ ਨਜ਼ਿਤਾ ਬਚਾਅ

Test for and defend against evasion, membership inference, model inversion, extraction, and poisoning of the improvement loop.

evasion (ਪਛਾਣ ਤੋਂ ਬਚ ਨਕਿਲਣਾ), membership inference, model inversion, extraction, ਅਤੇ ਸੁਧਾਰ ਲੂਪ ਦੇ poisoning ਲਈ ਪਰਖ ਕਰੋ ਅਤੇ ਉਹਨਾਂ ਵਿਰੁੱਧ ਬਚਾਅ ਕਰੋ।

¹⁸⁵ **immutable** (EN) -> ਅਪਰਵਿਰਤਨਸ਼ੀਲਤਾ — this exact requirement (C8.1.2) was found paraphrased elsewhere in the corpus as “cannot be changed,” which hid the term from a reader searching for it beside this file’s own index entry; this site is the corpus’s standing form. Full discussion: OPEN-QUESTIONS.md Q112.

Control / Technique	Requirement IDs
Alignment and safety training or fine-tuning to suppress disallowed content categories	C11.1.1
Version-controlled alignment test suite run on every model update or release	C11.1.2
Evaluation against known adversarial attack techniques relevant to the modality	C11.1.3
Hardening of models against adversarial inputs	C11.1.4
Automated evaluator that measures harmful-content rate and flags regressions beyond a threshold	C11.1.5
Suppression of directly returned model-inferred sensitive attributes	C11.2.1
Output calibration to reduce overconfident predictions exploitable by inference attacks	C11.2.3
Differentially-private optimization for training on sensitive datasets	C11.2.4
Membership-inference attack simulation demonstrating accuracy no better than random guessing	C11.2.5
Raw model outputs not exposed beyond the backend, with externally visible responses calibrated to extraction risk	C11.3.2
Model watermarking or fingerprinting so unauthorized copies can be identified	C11.3.3
Poisoning detection and human review gates protecting the safety-violation feedback pipeline	C11.4.3

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਮਨਾਹੀ ਵਾਲੀਆਂ ਸਮੱਗਰੀ ਸ਼੍ਰੇਣੀਆਂ ਨੂੰ ਦਬਾਉਣ ਲਈ ਅਲਾਈਨਮੈਂਟ ਅਤੇ ਸਲਾਮਤੀ ਸਖਿਲਾਈ ਜਾਂ ਫਾਈਨ-ਟਿਊਨਿੰਗ	C11.1.1
ਹਰ ਮਾਡਲ ਅੱਪਡੇਟ ਜਾਂ ਰਲੀਜ਼ ਉੱਤੇ ਚਲਾਇਆ ਜਾਣ ਵਾਲਾ ਵਰਜਨ-ਨਿਯੰਤਰਤਿ ਅਲਾਈਨਮੈਂਟ ਟੈਸਟ ਸੂਟ	C11.1.2
ਮਾਡੈਲਿਟੀ ਨਾਲ ਸੰਬੰਧਿਤ ਜਾਣੀਆਂ-ਪਛਾਣੀਆਂ ਵਰਿਧੀ ਹਮਲਾ ਤਕਨੀਕਾਂ ਦੇ ਵਰਿਧ ਮੁਲਾਂਕਣ	C11.1.3
ਵਰਿਧੀ ਇਨਪੁੱਟਾਂ ਵਰਿਧ ਮਾਡਲਾਂ ਨੂੰ ਸਖਤ ਕਰਨਾ	C11.1.4
ਸਵੈਚਾਲਤਿ ਮੁਲਾਂਕਣਕਾਰ ਜੋ ਨੁਕਸਾਨਦੇਹ-ਸਮੱਗਰੀ ਦਰ ਮਾਪਦਾ ਹੈ ਅਤੇ ਇੱਕ ਬਰੈਂਸਹੋਲਡ ਤੋਂ ਪਰੇ ਦੇ ਰਗਿਰੈਸ਼ਨਾਂ ਨੂੰ ਨਸ਼ਿਨਬੱਧ ਕਰਦਾ ਹੈ	C11.1.5
ਮਾਡਲ ਦੁਆਰਾ ਅਨੁਮਾਨਤਿ ਸੰਵੇਦਨਸ਼ੀਲ ਗੁਣਾਂ ਦੇ ਸਧਿ ਵਾਪਸ ਕੀਤੇ ਜਾਣ ਦੀ ਰੋਕਥਾਮ	C11.2.1
ਇਨਫਰੈਸ ਹਮਲਿਆਂ ਦੁਆਰਾ ਵਰਤੇ ਜਾ ਸਕਣ ਵਾਲੇ ਹੱਦੋਂ ਵੱਧ ਭਰੋਸੇ ਵਾਲੇ ਪੂਰਵ-ਅਨੁਮਾਨਾਂ ਨੂੰ ਘਟਾਉਣ ਲਈ ਆਉਟਪੁੱਟ ਕੈਲੀਬਰੇਸ਼ਨ	C11.2.3
ਸੰਵੇਦਨਸ਼ੀਲ ਡਾਟਾਸੈੱਟਾਂ ਉੱਤੇ ਸਖਿਲਾਈ ਲਈ differential privacy-ਆਧਾਰਤਿ ਅਨੁਕੂਲਨ	C11.2.4
membership-inference ਹਮਲੇ ਦਾ ਸਮੂਲੇਸ਼ਨ ਜੋ ਦਰਸਾਏ ਕੀ ਸਟੀਕਤਾ ਬੇਤਰਤੀਬ ਅੰਦਾਜ਼ੇ ਤੋਂ ਵੱਧ ਨਹੀਂ	C11.2.5

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਕੱਚੇ ਮਾਡਲ ਆਊਟਪੁੱਟ ਦਾ ਬੈਕਐਂਡ ਤੋਂ ਪਰੇ ਜਾਹਰ ਨਾ ਹੋਣਾ, ਅਤੇ ਬਾਹਰੋਂ ਦਿਖਾਈ ਦੇਣ ਵਾਲੇ ਜਵਾਬਾਂ ਦਾ extraction ਜੋਖਮ ਅਨੁਸਾਰ ਕੈਲੀਬਰੇਟ ਹੋਣਾ	C11.3.2
ਮਾਡਲ ਵਾਟਰਮਾਰਕਿੰਗ ਜਾਂ ਫ਼ਿਗਿਰਪਰਟਿੰਗ ਤਾਂ ਜੋ ਅਣਅਧਿਕਾਰਤ ਨਕਲਾਂ ਦੀ ਪਛਾਣ ਹੋ ਸਕੇ	C11.3.3
ਸਲਾਮਤੀ-ਉਲੰਘਣਾ ਫ਼ੀਡਬੈਕ ਪਾਈਪਲਾਈਨ ਦੀ ਰਾਖੀ ਕਰਨ ਵਾਲੇ poisoning ਪਛਾਣ ਅਤੇ ਮਨੁੱਖੀ ਸਮੀਖਿਆ ਗੇਟ	C11.4.3

Common pitfalls: testing only known jailbreak patterns without adaptive attacks; not re-running the alignment suite after model updates; exposing raw confidence vectors that accelerate extraction.

ਆਮ ਗਲਤੀਆਂ: ਅਨੁਕੂਲ ਹੋਣ ਵਾਲੇ ਹਮਲਿਆਂ ਤੋਂ ਬਿਨਾਂ ਸਰਿਫ਼ ਜਾਣੇ-ਪਛਾਣੇ jailbreak ਪੈਟਰਨਾਂ ਦੀ ਪਰਖ ਕਰਨੀ; ਮਾਡਲ ਅੱਪਡੇਟਾਂ ਤੋਂ ਬਾਅਦ ਅਲਾਈਨਮੈਂਟ ਸੂਟ ਮੁੜ ਨਾ ਚਲਾਉਣਾ; ਕੱਚੇ ਭਰੋਸਾ ਵੈਕਟਰ ਜਾਹਰ ਕਰਨੇ ਜੋ extraction ਨੂੰ ਤੇਜ਼ ਕਰਦੇ ਹਨ।

AD.17 Logging & Audit

AD.17 ਲੌਗਿੰਗ ਅਤੇ ਆਡਿਟ

Capture security-relevant events with sufficient context and integrity for forensic reconstruction and accountability.

ਸੁਰੱਖਿਆ-ਸੰਬੰਧਤ ਘਟਨਾਵਾਂ ਨੂੰ ਫ਼ੋਰੈਂਸਿਕ ਪੁਨਰ-ਨਿਰਮਾਣ ਅਤੇ ਜਵਾਬਦੇਹੀ ਲਈ ਲੋੜੀਂਦੇ ਸੰਦਰਭ ਅਤੇ ਅਖੰਡਤਾ ਨਾਲ ਦਰਜ ਕਰੋ।

Control / Technique	Requirement IDs
AI interaction logging with session context and AI-specific telemetry	C12.1.1
Logging of safety filtering and policy decisions in enough detail to audit content moderation	C12.1.2
Structured, interoperable log schema for inference events (model identifier, token usage, provider, operation type)	C12.1.3
Logging of RAG pipeline retrieval events (query, documents retrieved, knowledge source)	C12.1.4
Audit logs capturing the approval chain for security-critical proactive actions (approver identity, timestamp, parameters, outcome)	C12.4.2
Logging of kill-switch activations and override commands	C12.4.3
Immutable audit records for all model changes	C12.5.3

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਸੈਸ਼ਨ ਸੰਦਰਭ ਅਤੇ AI-ਵਸ਼ਿਸ਼ਟ ਟੈਲੀਮੈਟਰੀ ਸਮੇਤ AI ਪਰਸਪਰ-ਕਰਿਆਵਾਂ ਦੀ ਲੌਗਿੰਗ	C12.1.1

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਸਲਾਮਤੀ ਫ਼ਲਿਟਰਿੰਗ ਅਤੇ ਨੀਤੀ ਫ਼ੈਸਲਿਆਂ ਦੀ ਇੰਨੇ ਵੇਰਵੇ ਨਾਲ ਲੋਗਿੰਗ ਕੀ ਸਮੱਗਰੀ ਮਾਡਰੇਸ਼ਨ ਦਾ ਆਡਿਟ ਹੋ ਸਕੇ	C12.1.2
ਇਨਫ਼ਰੈਸ ਘਟਨਾਵਾਂ ਲਈ ਢਾਂਚਾਗਤ, ਅੰਤਰ-ਕਾਰਜਸ਼ੀਲ ਲੋਗ ਸਕੀਮਾ (ਮਾਡਲ ਪਛਾਣਕਰਤਾ, ਟੋਕਨ ਵਰਤੋਂ, ਪ੍ਰਦਾਤਾ, ਸੰਚਾਲਨ ਕਸਿਮ)	C12.1.3
RAG ਪਾਈਪਲਾਈਨ ਦੀਆਂ ਪ੍ਰਾਪਤੀ ਘਟਨਾਵਾਂ ਦੀ ਲੋਗਿੰਗ (ਕਊਰੀ, ਪ੍ਰਾਪਤ ਕੀਤੇ ਦਸਤਾਵੇਜ਼, ਗਿਆਨ ਸਰੋਤ)	C12.1.4
ਸੁਰੱਖਿਆ-ਨਾਜ਼ੁਕ ਪੂਰਵ-ਸਰਗਰਮ ਕਾਰਵਾਈਆਂ ਦੀ ਮਨਜ਼ੂਰੀ ਲੜੀ ਦਰਜ ਕਰਨ ਵਾਲੇ ਆਡਿਟ ਲੋਗ (ਮਨਜ਼ੂਰੀ ਦੇਣ ਵਾਲੇ ਦੀ ਪਛਾਣ, ਟਾਈਮਸਟੈਪ, ਪੈਰਾਮੀਟਰ, ਨਤੀਜਾ)	C12.4.2
kill-switch ਦੀਆਂ ਸਰਗਰਮੀਆਂ ਅਤੇ ਓਵਰਰਾਈਡ ਕਮਾਂਡਾਂ ਦੀ ਲੋਗਿੰਗ	C12.4.3
ਸਾਰੀਆਂ ਮਾਡਲ ਤਬਦੀਲੀਆਂ ਲਈ ਅਪਰੇਟਿੰਗ ਨਤੀਜੇ ਆਡਿਟ ਰਕਾਰਡ	C12.5.3

Common pitfalls: logging prompts without redaction; using mutable log storage without integrity protection; logging agent actions and approvals but not human-initiated overrides such as kill-switch activations.

ਆਮ ਗਲਤੀਆਂ: prompt ਨੂੰ ਰਡਿਕਸ਼ਨ ਤੋਂ ਬਨਿਾਂ ਲੋਗ ਕਰਨਾ; ਅਖੰਡਤਾ ਸੁਰੱਖਿਆ ਤੋਂ ਬਨਿਾਂ ਬਦਲਣਯੋਗ ਲੋਗ ਭੰਡਾਰਨ ਵਰਤਣਾ; ਏਜੰਟ ਕਾਰਵਾਈਆਂ ਅਤੇ ਮਨਜ਼ੂਰੀਆਂ ਨੂੰ ਲੋਗ ਕਰਨਾ ਪਰ kill-switch ਸਰਗਰਮੀਆਂ ਵਰਗੇ ਮਨੁੱਖੀ ਓਵਰਰਾਈਡਾਂ ਨੂੰ ਨਹੀਂ।

AD.18 Monitoring, Detection & Incident Response

AD.18 ਨਗਿਰਾਨੀ, ਪਛਾਣ, ਅਤੇ ਘਟਨਾ ਪ੍ਰਤੀਕਰਮ

Detect AI-specific abuse, drift, and anomalies, and respond to incidents.

AI-ਵਸ਼ਿਸ਼ ਦੁਰਵਰਤੋਂ, ਡ੍ਰਿਫਟ, ਅਤੇ ਅਸਧਾਰਨਤਾਵਾਂ ਦਾ ਪਤਾ ਲਗਾਓ, ਅਤੇ ਘਟਨਾਵਾਂ ਦਾ ਜਵਾਬ ਦਿਓ।

Control / Technique	Requirement IDs
Automated tool containment triggered by policy violations	C9.3.8
Extraction-attempt detector fed by query-pattern analysis	C11.3.1
Response measures triggered on detection of suspected model extraction	C11.3.4
Signature-based detection and alerting on jailbreak patterns, prompt injection, and adversarial inputs	C12.2.1
Behavioral anomaly detection (unusual conversation patterns, excessive retries, systematic probing)	C12.2.2
Custom detection rules for AI-specific threat patterns (coordinated jailbreak attempts, prompt injection, system prompt extraction)	C12.2.3
Extraction-alert events including offending query metadata	C12.2.4
Granular token-usage attribution (per user, session, feature endpoint, team or workspace)	C12.2.5

Control / Technique	Requirement IDs
Monitoring of LLM API traffic for covert-channel and command-and-control indicators	C12.2.6
Data drift detection using methods matched to the input type (KS test or PSI for tabular, embedding-distance for text/image)	C12.3.1
Hallucination detection monitoring of model outputs	C12.3.2
Hallucination rates tracked as continuous time-series metrics	C12.3.3
Distinction of unexplained behavioral shifts from gradual operational drift	C12.3.4
Security evaluation and threat-landscape assessment for autonomous action triggers	C12.4.1

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਨੀਤੀ ਉਲੰਘਣਾਵਾਂ ਦੁਆਰਾ ਸ਼ੁਰੂ ਕੀਤੀ ਸਵੈਚਾਲਤਿ ਟੂਲ ਘੇਰਾਬੰਦੀ	C9.3.8
ਕਊਰੀ-ਪੈਟਰਨ ਵਸਿਲੇਸ਼ਣ ਤੋਂ ਇਨਪੁੱਟ ਲੈਣ ਵਾਲਾ extraction-ਕੋਸ਼ਿਸ਼ ਡੈਟੈਕਟਰ	C11.3.1
ਸ਼ੱਕੀ model extraction ਦੀ ਪਛਾਣ ਹੋਣ 'ਤੇ ਸ਼ੁਰੂ ਹੋਣ ਵਾਲੇ ਜਵਾਬੀ ਉਪਾਅ	C11.3.4
jailbreak ਪੈਟਰਨਾਂ, prompt ਇੰਜੈਕਸ਼ਨ, ਅਤੇ ਵਰਿਧੀ ਇਨਪੁੱਟਾਂ ਉੱਤੇ	C12.2.1
ਸਹਿਨੇਚਰ-ਆਧਾਰਤਿ ਪਛਾਣ ਅਤੇ ਚੇਤਾਵਨੀ	
ਵਿਵਹਾਰਕ ਅਸਧਾਰਨਤਾ ਪਛਾਣ (ਅਸਧਾਰਨ ਗੱਲਬਾਤ ਪੈਟਰਨ, ਹੱਦੋ ਵੱਧ ਮੁੜ-ਕੋਸ਼ਿਸ਼ਾਂ, ਵਿਵਸਥਤਿ ਟੋਹ)	C12.2.2
AI-ਵਸਿਸ਼ ਖਤਰਾ ਪੈਟਰਨਾਂ ਲਈ ਕਸਟਮ ਪਛਾਣ ਨਯਮ (ਤਾਲਮੇਲ ਵਾਲੀਆਂ	C12.2.3
jailbreak ਕੋਸ਼ਿਸ਼ਾਂ, prompt ਇੰਜੈਕਸ਼ਨ, system prompt extraction)	
ਦੋਸ਼ੀ ਕਊਰੀ ਦਾ ਮੈਟਾਡਾਟਾ ਸ਼ਾਮਲ ਕਰਨ ਵਾਲੀਆਂ extraction-ਚੇਤਾਵਨੀ ਘਟਨਾਵਾਂ	C12.2.4
ਬਾਰੀਕ ਟੈਕਨ-ਵਰਤੋਂ ਨਰਿਧਾਰਨ (ਪਰਤੀ ਉਪਭੋਗਤਾ, ਸੈਸ਼ਨ, ਫ਼ੀਚਰ ਐਂਡਪੁਆਇੰਟ, ਟੀਮ ਜਾਂ ਵਰਕਸਪੇਸ)	C12.2.5
ਲੁਕਵੇ-ਚੈਨਲ ਅਤੇ command-and-control ਸੰਕੇਤਾਂ ਲਈ LLM API	C12.2.6
ਟਰੈਫ਼ਿਕ ਦੀ ਨਗਿਰਾਨੀ	
ਇਨਪੁੱਟ ਕਸਿਮ ਨਾਲ ਮੇਲ ਖਾਂਦੀਆਂ ਵਰਿਧੀਆਂ ਵਰਤ ਕੇ ਡਾਟਾ ਡਰਫ਼ਿਟ ਪਛਾਣ	C12.3.1
(ਸਾਰਣੀਬੱਧ ਲਈ KS test ਜਾਂ PSI, ਟੈਕਸਟ/ਚਤਿਰ ਲਈ embedding-ਦੂਰੀ)	
ਮਾਡਲ ਆਊਟਪੁੱਟ ਦੀ hallucination (ਮਨਘੜਤ ਸਮੱਗਰੀ) ਪਛਾਣ	C12.3.2
ਨਗਿਰਾਨੀ	
hallucination ਦਰਾਂ ਦਾ ਲਗਾਤਾਰ ਸਮਾਂ-ਲੜੀ ਮੈਟਰਿਕਾਂ ਵਜੋਂ ਟਰੈਕ ਹੋਣਾ	C12.3.3
ਅਣ-ਵਿਆਖਿਆਤ ਵਿਵਹਾਰਕ ਤਬਦੀਲੀਆਂ ਨੂੰ ਹੌਲੀ-ਹੌਲੀ ਹੋਣ ਵਾਲੇ ਸੰਚਾਲਨ	C12.3.4
ਡਰਫ਼ਿਟ ਤੋਂ ਵੱਖ ਕਰਨਾ	
ਖੁਦਮੁਖਤਾਰ ਕਾਰਵਾਈ ਦੇ ਟਰਿਗਰਾਂ ਲਈ ਸੁਰੱਖਿਆ ਮੁਲਾਂਕਣ ਅਤੇ	C12.4.1
ਖਤਰਾ-ਪਰਦਿਰਸ਼ਿ ਮੁਲਾਂਕਣ	

Common pitfalls: not correlating AI-specific events with broader SIEM alerts; treating drift as a scheduled check rather than continuous monitoring; lacking AI-specific forensic tooling during an incident.

ਆਮ ਗਲਤੀਆਂ: AI-ਵਸ਼ਿਸ਼ ਘਟਨਾਵਾਂ ਦਾ ਵਡੇਰੀਆਂ SIEM ਚੇਤਾਵਨੀਆਂ ਨਾਲ ਸਹਿ-ਸੰਬੰਧ ਨਾ ਬਣਾਉਣਾ; ਡਰਫ਼ਿਟ ਨੂੰ ਲਗਾਤਾਰ ਨਗਿਰਾਨੀ ਦੀ ਬਜਾਏ ਸਮਾਂ-ਸਾਰਣੀ ਵਾਲੀ ਜਾਂਚ ਸਮਝਣਾ; ਘਟਨਾ ਦੌਰਾਨ AI-ਵਸ਼ਿਸ਼ ਫ਼ੋਰੈਂਸਿਕ ਸੰਦਾਂ ਦਾ ਨਾ ਹੋਣਾ।

AD.19 Human Oversight & Shutdown Control

AD.19 ਮਨੁੱਖੀ ਨਗਿਰਾਨੀ ਅਤੇ ਬੰਦ ਕਰਨ ਦਾ ਨਿਯੰਤਰਣ

Require human approval for high-impact actions and provide reliable, exercised shutdown and graceful degradation paths under human control.

ਉੱਚ-ਪ੍ਰਭਾਵ ਵਾਲੀਆਂ ਕਾਰਵਾਈਆਂ ਲਈ ਮਨੁੱਖੀ ਮਨਜ਼ੂਰੀ ਦੀ ਲੋੜ ਰੱਖੋ, ਅਤੇ ਮਨੁੱਖੀ ਨਿਯੰਤਰਣ ਹੇਠ ਭਰੋਸੇਯੋਗ, ਪਰਖੇ ਹੋਏ ਬੰਦ ਕਰਨ ਅਤੇ ਸੁਚੱਜੀ ਗਰਿਫ਼ਟ (graceful degradation) ਦੇ ਰਾਹ ਪ੍ਰਦਾਨ ਕਰੋ।

Control / Technique	Requirement IDs
Swarm-level kill-switch that halts all active agent instances	C9.1.3
Runtime blocking of privileged, high-impact, or irreversible actions until explicit human approval is received and verified	C9.2.1
Approval requests displaying canonicalized, complete action parameters (diffs, commands, recipients, amounts, resources, scopes) without truncation	C9.2.2
Trusted reversibility classification for each high-impact action (read-only, reversible, externally reversible, irreversible)	C9.2.3
Runtime enforcement of reversibility classifications (block, require approval, or restrict)	C9.2.4
Restriction and bounding of any self-modification capability (prompt rewriting, tool-list changes, parameter updates)	C9.2.5
AI-augmented review of planned high-risk actions, adding to (not replacing) the deterministic policy gate	C9.2.6
Protection of the AI-augmented review mechanism against prompt-injection bypass	C9.2.7
Approvals cryptographically bound to parameters, requester identity, execution context, and a single-use nonce	C9.2.8
Isolation of approval-issuing key material or credentials from the agent runtime	C9.2.9
Multi-step or multi-agent chains enforcing the highest-impact reversibility classification in the chain	C9.2.10
Manual kill-switch to immediately halt model inference and outputs	C9.6.1
Fail-closed blocking of a pending action when a human-approval gate is not satisfied within the defined time	C9.6.2

Control / Technique	Requirement IDs
Kill-switch commands delivered through an out-of-band channel isolated from the agent runtime	C9.6.3
Explicit consent dialogue and cancellation option on installation of a local MCP server	C10.4.7

ਨਿਯੰਤਰਣ / ਤਕਨੀਕ	ਲੋੜ ID
ਸਵਾਰਮ-ਪੱਧਰੀ kill-switch ਜੋ ਸਾਰੇ ਸਰਗਰਮ ਏਜੰਟ ਇੰਸਟਾਂਸਾਂ ਨੂੰ ਰੋਕ ਦਿੰਦਾ ਹੈ	C9.1.3
ਵਸ਼ਿਸ਼-ਅਧਿਕਾਰ ਪ੍ਰਾਪਤ, ਉੱਚ-ਪ੍ਰਭਾਵ ਵਾਲੀਆਂ, ਜਾਂ ਗੈਰ-ਉਲਟਾਉਣਯੋਗ ਕਾਰਵਾਈਆਂ ਦੀ ਰਨਟਾਈਮ ਰੋਕ, ਜਦੋਂ ਤੱਕ ਸਪੱਸ਼ਟ ਮਨੁੱਖੀ ਮਨਜ਼ੂਰੀ ਪ੍ਰਾਪਤ ਅਤੇ ਤਸਦੀਕ ਨਾ ਹੋ ਜਾਵੇ	C9.2.1
ਮਨਜ਼ੂਰੀ ਬੇਨਤੀਆਂ ਜੋ ਕੈਨੋਨੀਕਲਾਈਜ਼ ਕੀਤੇ, ਸੰਪੂਰਨ ਕਾਰਵਾਈ ਪੈਰਾਮੀਟਰ (diff, ਕਮਾਂਡਾਂ, ਪ੍ਰਾਪਤਕਰਤਾ, ਰਕਮਾਂ, ਸਰੋਤ, ਸਕੋਪ) ਬਨਿਾਂ ਕਟੌਤੀ ਦੇ ਦਖਿਉਂਦੀਆਂ ਹਨ	C9.2.2
ਹਰ ਉੱਚ-ਪ੍ਰਭਾਵ ਵਾਲੀ ਕਾਰਵਾਈ ਲਈ ਭਰੋਸੇਯੋਗ ਉਲਟਾਉਣਯੋਗਤਾ ਵਰਗੀਕਰਨ (ਸਰਿਫ਼-ਪੜ੍ਹਨਯੋਗ, ਉਲਟਾਉਣਯੋਗ, ਬਾਹਰੀ ਤੌਰ 'ਤੇ ਉਲਟਾਉਣਯੋਗ, ਗੈਰ-ਉਲਟਾਉਣਯੋਗ)	C9.2.3
ਉਲਟਾਉਣਯੋਗਤਾ ਵਰਗੀਕਰਨਾਂ ਦਾ ਰਨਟਾਈਮ ਲਾਗੂਕਰਨ (ਰੋਕਣਾ, ਮਨਜ਼ੂਰੀ ਦੀ ਲੋੜ ਪਾਉਣੀ, ਜਾਂ ਸੀਮਤ ਕਰਨਾ)	C9.2.4
ਕਸਿ ਵੀ ਸਵੈ-ਸੋਧ ਸਮਰੱਥਾ (prompt ਮੁੜ-ਲਿਖਣਾ, ਟੂਲ-ਸੂਚੀ ਤਬਦੀਲੀਆਂ, ਪੈਰਾਮੀਟਰ ਅੱਪਡੇਟ) ਦੀ ਪਾਬੰਦੀ ਅਤੇ ਸੀਮਾਬੰਦੀ	C9.2.5
ਯੋਜਨਾਬੱਧ ਉੱਚ-ਜੋਖਮ ਕਾਰਵਾਈਆਂ ਦੀ AI-ਸਹਾਇਤ ਪ੍ਰਾਪਤ ਸਮੀਖਿਆ, ਜੋ ਨਸ਼ਿਚਤੀ ਨੀਤੀ ਗੇਟ ਵੱਲੋਂ ਵਾਧਾ ਕਰਦੀ ਹੈ (ਉਸ ਦੀ ਥਾਂ ਨਹੀਂ ਲੈਂਦੀ)	C9.2.6
AI-ਸਹਾਇਤ ਪ੍ਰਾਪਤ ਸਮੀਖਿਆ ਵਧੀ ਦੀ prompt ਇੰਜੈਕਸ਼ਨ ਰਾਹੀਂ ਬਾਈਪਾਸ ਵਰਿੱਧ ਸੁਰੱਖਿਆ	C9.2.7
ਮਨਜ਼ੂਰੀਆਂ ਦਾ ਪੈਰਾਮੀਟਰਾਂ, ਬੇਨਤੀਕਰਤਾ ਦੀ ਪਛਾਣ, ਐਗਜ਼ੀਕਿਊਸ਼ਨ ਸੰਦਰਭ, ਅਤੇ ਇੱਕ-ਵਾਰੀ-ਵਰਤੋਂ ਵਾਲੇ ਨੌਸ ਨਾਲ ਕਰਪਿਟੋਗਰਾਫ਼ਿਕ ਬੰਧਨ	C9.2.8
ਮਨਜ਼ੂਰੀ ਜਾਰੀ ਕਰਨ ਵਾਲੀ ਕੁੰਜੀ ਸਮੱਗਰੀ ਜਾਂ ਕ੍ਰੈਡੈਂਸ਼ੀਅਲਾਂ ਦੀ ਏਜੰਟ ਰਨਟਾਈਮ ਤੋਂ ਅਲੱਗ-ਥਲੱਗਤਾ	C9.2.9
ਬਹੁ-ਪੜਾਵੀ ਜਾਂ ਬਹੁ-ਏਜੰਟ ਲੜੀਆਂ ਵੱਲੋਂ ਲੜੀ ਦੇ ਸਭ ਤੋਂ ਉੱਚ-ਪ੍ਰਭਾਵ ਵਾਲੇ ਉਲਟਾਉਣਯੋਗਤਾ ਵਰਗੀਕਰਨ ਦਾ ਲਾਗੂਕਰਨ	C9.2.10
ਮਾਡਲ ਇਨਫ਼ਰੈਂਸ ਅਤੇ ਆਊਟਪੁੱਟ ਨੂੰ ਤੁਰੰਤ ਰੋਕਣ ਲਈ ਹੱਥੀਂ ਚਲਾਈ ਜਾਣ ਵਾਲੀ kill-switch	C9.6.1
ਪਰਭਿਾਸ਼ਤਿ ਸਮੇਂ ਦੇ ਅੰਦਰ ਮਨੁੱਖੀ-ਮਨਜ਼ੂਰੀ ਗੇਟ ਪੂਰਾ ਨਾ ਹੋਣ 'ਤੇ ਬਕਾਇਆ ਕਾਰਵਾਈ ਦੀ ਨਾਕਾਮੀ-‘ਤੇ-ਬੰਦ’ ¹⁸⁶ (fail-closed) ਰੋਕ	C9.6.2
ਏਜੰਟ ਰਨਟਾਈਮ ਤੋਂ ਅਲੱਗ-ਥਲੱਗ ਆਊਟ-ਆਫ਼-ਬੈਂਡ ਚੈਨਲ ਰਾਹੀਂ ਦੱਤੀਆਂ ਜਾਣ ਵਾਲੀਆਂ kill-switch ਕਮਾਂਡਾਂ	C9.6.3
ਸਥਾਨਕ MCP ਸਰਵਰ ਦੀ ਸਥਾਪਨਾ 'ਤੇ ਸਪੱਸ਼ਟ ਸਹਿਮਤੀ ਸੰਵਾਦ ਅਤੇ ਰੱਦ ਕਰਨ ਦਾ ਵਿਕਲਪ	C10.4.7

¹⁸⁶ **fail-closed** (EN) -> ਨਾਕਾਮੀ-‘ਤੇ-ਬੰਦ’ — the literal compound was chosen over the shorter transliterated loan because the control states fail-closed and names open as its pitfall in the same family, and only the literal compound inverts cleanly for both. Full discussion: OPEN-QUESTIONS.md Q104.

Common pitfalls: documenting a high-risk action policy never wired to a runtime gate; binding approval to parameters without binding to identity or context; defaulting to fail-open when the approver does not respond; assuming an in-band kill-switch will work against a compromised agent; implementing a kill-switch that is never exercised.

ਆਮ ਗਲਤੀਆਂ: ਉਚ-ਜੋਖਮ ਕਾਰਵਾਈ ਨੀਤੀ ਨੂੰ ਦਸਤਾਵੇਜ਼ਬੱਧ ਕਰਨਾ ਪਰ ਉਸ ਨੂੰ ਕਦੇ ਰਨਟਾਈਮ ਗੇਟ ਨਾਲ ਨਾ ਜੋੜਨਾ; ਮਨਜ਼ੂਰੀ ਨੂੰ ਪੈਰਾਮੀਟਰਾਂ ਨਾਲ ਬੰਨ੍ਹਣਾ ਪਰ ਪਛਾਣ ਜਾਂ ਸੰਦਰਭ ਨਾਲ ਨਹੀਂ; ਮਨਜ਼ੂਰੀ ਦੇਣ ਵਾਲੇ ਦੇ ਜਵਾਬ ਨਾ ਦੇਣ 'ਤੇ ਡਿਫਾਲਟ ਰੂਪ ਵਿੱਚ ਨਾਕਾਮੀ-‘ਤੇ-ਖੁੱਲ੍ਹਾ¹⁸⁷ (fail-open) ਰਹਿਣਾ; ਇਹ ਮੰਨ ਲੈਣਾ ਕਿ ਇਨ-ਬੈਂਡ kill-switch ਸਮਝੌਤਾ ਹੋਏ ਏਜੰਟ ਵਿਰੁੱਧ ਕੰਮ ਕਰੇਗਾ; ਅਜਿਹਾ kill-switch ਲਾਗੂ ਕਰਨਾ ਜਿਸ ਨੂੰ ਕਦੇ ਪਰਖਿਆ ਹੀ ਨਾ ਜਾਵੇ।

References

ਹਵਾਲੇ

- NIST AI Risk Management Framework 1.0
- ISO/IEC 42001:2023: AI Management Systems Requirements
- OWASP Top 10 for Large Language Model Applications
- OWASP Application Security Verification Standard (ASVS)
- NIST SP 800-218A: Secure Software Development Practices for Generative AI

¹⁸⁷ **fail-open** (EN) -> ਨਾਕਾਮੀ-‘ਤੇ-ਖੁੱਲ੍ਹਾ — the inverse of ਨਾਕਾਮੀ-‘ਤੇ-ਬੰਦ, deliberately not rendered as “safe failure,” which would name the desirable outcome rather than the mechanism and make this pitfall untranslatable as fail-closed’s opposite. Full discussion: OPEN-QUESTIONS.md Q104.

Appendix C: AI-Assisted Secure Coding

ਅੰਤਿਕਾ¹⁸⁸ C: AI-ਸਹਾਇਤ ਪ੍ਰਾਪਤ ਸੁਰੱਖਿਅਤ ਕੋਡਿੰਗ

Objective

ਉਦੇਸ਼

This appendix lists organizational controls for using AI coding tools safely. The range is baseline to advanced. Scope is coding, code review, and the rest of the SSDLC.

ਇਹ ਅੰਤਿਕਾ AI ਕੋਡਿੰਗ ਟੂਲਾਂ ਨੂੰ ਸਲਾਮਤ (safe) ਢੰਗ ਨਾਲ ਵਰਤਣ ਲਈ ਸੰਸਥਾਗਤ ਨਿਯੰਤਰਣ ਸੂਚੀਬੱਧ ਕਰਦੀ ਹੈ। ਇਹਨਾਂ ਦਾ ਘੇਰਾ ਬੇਸਲਾਈਨ¹⁸⁹ (baseline) ਤੋਂ ਲੈ ਕੇ ਉੱਨਤ ਤੱਕ ਹੈ। ਦਾਇਰੇ ਵਿੱਚ ਕੋਡਿੰਗ, ਕੋਡ ਸਮੀਖਿਆ, ਅਤੇ ਬਾਕੀ SSDLC ਸ਼ਾਮਲ ਹਨ।

AC.1 AI-Assisted Secure-Coding Workflow

AC.1 AI-ਸਹਾਇਤ ਪ੍ਰਾਪਤ ਸੁਰੱਖਿਅਤ-ਕੋਡਿੰਗ ਵਰਕਫਲੋ

AI tooling has to slot into the existing SSDLC without weakening any of the security gates already in place. Equally important: write down the adversarial-AI threat scenarios that justify each guardrail. Doing this up front is much easier than reconstructing it after the fact.

AI ਟੂਲਿੰਗ ਨੂੰ ਮੌਜੂਦਾ SSDLC ਵਿੱਚ ਇਸ ਤਰ੍ਹਾਂ ਸਮਾਉਣਾ ਪੈਂਦਾ ਹੈ ਕਿ ਪਹਿਲਾਂ ਤੋਂ ਲੱਗੇ ਕਸਿ ਵੀ ਸੁਰੱਖਿਆ ਗੇਟ ਕਮਜ਼ੋਰ ਨਾ ਪੈਣ। ਓਨਾ ਹੀ ਜ਼ਰੂਰੀ: ਉਹ ਵਰਿਥੀ-AI ਖ਼ਤਰਾ ਦ੍ਰਸ਼ਿ¹⁹⁰ (adversarial-AI threat scenarios) ਲਿਖਿਤੀ ਰੂਪ ਵਿੱਚ ਦਰਜ ਕਰੋ ਜੋ ਹਰ ਗਾਰਡਰੇਲ¹⁹¹ (guardrail) ਨੂੰ ਜਾਇਜ਼ ਠਹਿਰਾਉਂਦੇ ਹਨ। ਇਹ ਕੰਮ ਪਹਿਲਾਂ ਹੀ ਕਰ ਲੈਣਾ ਬਾਅਦ ਵਿੱਚ ਮੁੜ ਜੋੜਨ ਨਾਲੋਂ ਕੜੀ ਸੌਖਾ ਹੈ।

#	Description	Level
AC.1.1	Verify that a written workflow says when AI tools may generate, refactor, or review code. The workflow names the approved tools, the prohibited use cases, and the data classifications that are allowed as input.	1

¹⁸⁸ **Appendix** (EN) -> ਅੰਤਿਕਾ — the settled Panjabi term for a document appendix in academic/government publishing; the division letter stays Latin as a cross-reference target, matching Appendix A and Appendix B. Full discussion: OPEN-QUESTIONS.md Q121.

¹⁸⁹ **baseline** (EN) -> ਬੇਸਲਾਈਨ — kept as a loan rather than ਆਧਾਰ-ਰੇਖਾ, since ਆਧਾਰ is already load-bearing corpus-wide as the pinned -ਆਧਾਰਿਤ (“-based”) suffix and the two would collide when adjacent; one word has to cover a maturity floor, a comparison measurement, and a signed reference artifact. Full discussion: OPEN-QUESTIONS.md Q118.

¹⁹⁰ **threat scenario** (EN) -> ਖ਼ਤਰਾ ਦ੍ਰਸ਼ਿ — ਦ੍ਰਸ਼ਿ (“scene, depicted situation”) names a described hypothetical, kept visibly distinct from ਪਰਦ੍ਰਿਸ਼ਿ (threat landscape) the way “scene” and “panorama” are distinct in English. Full discussion: OPEN-QUESTIONS.md Q122.

¹⁹¹ **guardrail** (EN) -> ਗਾਰਡਰੇਲ — kept as a neutral loan after excluding ਮਰਿਆਦਾ, which names the Sikh code of conduct and would be a Gurmat-safety violation if applied to a machine constraint. Full discussion: OPEN-QUESTIONS.md Q105.

#	Description	Level
AC.1.2	Verify that the workflow covers every SSDLC phase from design and implementation through code review, testing, deployment, and post-deployment monitoring, and names the security gates that stay mandatory whether AI was involved or not.	2
AC.1.3	Verify that the workflow names the adversarial-AI threat scenarios it is built to mitigate. The list should cover prompt injection delivered through PR content, AI-generated supply-chain payloads, autonomous agents approving their own work, fork-PR secret exfiltration, and compromise of the model supply chain.	2
AC.1.4	Verify that metrics are collected on AI-produced and AI-mediated code, and that the results are compared against a human-only baseline. Vulnerability density, mean-time-to-detect, AI-attributable defect rate, prompt-injection detection rate, and fork-PR rejection rate are all useful.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.1.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਇੱਕ ਲਿਖਤੀ ਵਰਕਫਲੋ ¹⁹² (workflow) ਦੱਸਦਾ ਹੈ ਕਿ AI ਟੂਲ ਕਦੇ ਕੋਡ ਤਿਆਰ ਕਰ ਸਕਦੇ ਹਨ, ਮੁੜ-ਸੰਗਠਿਤ (refactor) ਕਰ ਸਕਦੇ ਹਨ, ਜਾਂ ਉਸ ਦੀ ਸਮੀਖਿਆ ਕਰ ਸਕਦੇ ਹਨ। ਵਰਕਫਲੋ ਪ੍ਰਵਾਨਗਿ ਟੂਲਾਂ, ਵਰਜਤਿ ਵਰਤੋ-ਮਾਮਲਿਆਂ, ਅਤੇ ਉਹਨਾਂ ਡਾਟਾ ਵਰਗੀਕਰਨਾਂ ਦੇ ਨਾਂ ਦੱਸਦਾ ਹੈ ਜਿਨ੍ਹਾਂ ਨੂੰ ਇਨਪੁੱਟ ਵਜੋਂ ਦੇਣ ਦੀ ਇਜਾਜ਼ਤ ਹੈ।	1

¹⁹² **workflow** (EN) -> ਵਰਕਫਲੋ — one loan covers both the written-process sense and the CI/CD-artifact sense, because the appendix uses the English word for both and two Panjabi words would suggest two unrelated concepts; deliberately kept distinct from ਪਾਈਪਲਾਈਨ (pipeline). Full discussion: OPEN-QUESTIONS.md Q110.

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.1.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਵਰਕਫਲੋ ਡਿਜ਼ਾਈਨ ਅਤੇ ਲਾਗੂਕਰਨ ਤੋਂ ਲੈ ਕੇ ਕੋਡ ਸਮੀਖਿਆ, ਟੈਸਟਿੰਗ, ਤੈਨਾਤੀ, ਅਤੇ ਤੈਨਾਤੀ-ਉਪਰੰਤ ਨਿਗਰਾਨੀ ਤੱਕ ਹਰ SSDLC ਪੜਾਅ ਨੂੰ ਢੱਕਦਾ ਹੈ, ਅਤੇ ਉਹਨਾਂ ਸੁਰੱਖਿਆ ਗੇਟਾਂ ਦੇ ਨਾਂ ਦੱਸਦਾ ਹੈ ਜੋ AI ਦੇ ਸ਼ਾਮਲ ਹੋਣ ਜਾਂ ਨਾ ਹੋਣ ਦੇ ਬਾਵਜੂਦ ਲਾਜ਼ਮੀ ਰਹਿੰਦੇ ਹਨ।	2
AC.1.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਵਰਕਫਲੋ ਉਹਨਾਂ ਵਰਿਥੀ-AI ਖ਼ਤਰਾ ਦਰਸ਼ਾਂ ਦੇ ਨਾਂ ਦੱਸਦਾ ਹੈ ਜਿਨ੍ਹਾਂ ਨੂੰ ਘਟਾਉਣ ਲਈ ਇਹ ਬਣਾਇਆ ਗਿਆ ਹੈ। ਇਸ ਸੂਚੀ ਵਿੱਚ PR ਸਮੱਗਰੀ ਰਾਹੀਂ ਪਹੁੰਚਾਇਆ ਗਿਆ prompt ਇੰਜੈਕਸ਼ਨ, AI ਦੁਆਰਾ ਤਿਆਰ ਸਪਲਾਈ ਚੇਨ ਪੋਲੋਡ, ਆਪਣੇ ਹੀ ਕੰਮ ਨੂੰ ਮਨਜ਼ੂਰੀ ਦਿੰਦੇ ਖ਼ੁਦਮੁਖ਼ਤਾਰ ਏਜੰਟ, ਫੋਰਕ-PR ¹⁹³ ਰਾਹੀਂ ਗੁਪਤ ਭੇਦ ਬਾਹਰ ਕੱਢਣਾ (exfiltration), ਅਤੇ ਮਾਡਲ ਸਪਲਾਈ ਚੇਨ ਦਾ ਸਮਝੌਤਾ (compromise) ਸ਼ਾਮਲ ਹੋਣੇ ਚਾਹੀਦੇ ਹਨ।	2
AC.1.4	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਦੁਆਰਾ ਤਿਆਰ ਕੀਤੇ ਅਤੇ AI-ਵਿਚਲਿਗੀ ਵਾਲੇ ਕੋਡ ਬਾਰੇ ਮੈਟ੍ਰਿਕਸ (metrics) ਇਕੱਠੇ ਕੀਤੇ ਜਾਂਦੇ ਹਨ, ਅਤੇ ਨਤੀਜਿਆਂ ਦੀ ਤੁਲਨਾ ਸਰਿਫ਼-ਮਨੁੱਖੀ ਬੇਸਲਾਈਨ ਨਾਲ ਕੀਤੀ ਜਾਂਦੀ ਹੈ। ਕਮਜ਼ੋਰੀ ਘਣਤਾ, ਐਂਸਤ-ਪਛਾਣ-ਸਮਾਂ, AI ਨੂੰ ਸਰੋਤ-ਨਰਿਧਾਰਤਿ ਕੀਤੀ ਜਾ ਸਕਣ ਵਾਲੀ ਨੁਕਸ ਦਰ, prompt ਇੰਜੈਕਸ਼ਨ ਪਛਾਣ ਦਰ, ਅਤੇ ਫੋਰਕ-PR ਰੱਦਗੀ ਦਰ — ਇਹ ਸਾਰੇ ਲਾਭਦਾਇਕ ਹਨ।	3

Mappings & References:

ਮੈਪਿੰਗ ਅਤੇ ਹਵਾਲੇ:

- **AC.1.1:** NIST SSDF PO.1 (Define Security Requirements for Software Development); ISO/IEC 42001 Clauses 6, 8; OWASP SAMM Strategy & Metrics (SM), Policy & Compliance (PC).
- **AC.1.2:** NIST SSDF PW.1, PW.7; OWASP SAMM Education & Guidance (EG); ISO/IEC 5338 Clause 6.
- **AC.1.3:** MITRE ATLAS (Reconnaissance & Initial Access tactics); NIST AI 600-1 GOVERN; OWASP LLM Top 10 (2025) LLM03; OWASP Agentic Top 10 (2026) ASI04.
- **AC.1.4:** NIST AI RMF MEASURE; ISO/IEC 42001 Clause 9; OWASP SAMM Strategy & Metrics (SM).

AC.2 AI Tool Qualification & Threat Modeling

AC.2 AI ਟੂਲ ਯੋਗਤਾ-ਨਰਿਧਾਰਨ ਅਤੇ ਖ਼ਤਰਾ ਮਾਡਲਿੰਗ

Do not adopt an AI coding tool until it has been evaluated. Three areas in particular: its security capabilities, its resistance to adversarial input, and the risk inherited from its supply chain.

¹⁹³ **fork** (EN) -> ਫੋਰਕ — kept as a loan because the security meaning here is a trust boundary (a fork PR originates outside the repository's permission domain), a sense that ਨਕਲ (“copy”) or ਵੰਡ (“split”) would lose and that ਸ਼ਾਖ਼ਾ would collide with branch. Full discussion: OPEN-QUESTIONS.md Q107.

ਕਸਿ AI ਕੋਡਿੰਗ ਟੂਲ ਨੂੰ ਉਦੋਂ ਤੱਕ ਨਾ ਅਪਣਾਓ ਜਦੋਂ ਤੱਕ ਉਸ ਦਾ ਮੁਲਾਂਕਣ ਨਾ ਹੋ ਜਾਵੇ। ਖਾਸ ਕਰਕੇ ਤਿੰਨ ਖੇਤਰ: ਉਸ ਦੀਆਂ ਸੁਰੱਖਿਆ ਸਮਰੱਥਾਵਾਂ, ਵਰਿਧੀ ਇਨਪੁੱਟ ਪ੍ਰਤੀ ਉਸ ਦਾ ਟਾਕਰਾ, ਅਤੇ ਉਸ ਦੀ ਸਪਲਾਈ ਚੇਨ ਤੋਂ ਵਰਿਸੇ ਵੱਧਿ ਮਲਿਆ ਜੋਖਮ।

#	Description	Level
AC.2.1	Verify that every AI tool, whether it is an assistant, a reviewer, an agent, or an MCP server, has a threat model. The threat model covers misuse, model inversion, training-data leakage, prompt injection from untrusted input, insecure output handling, excessive agency, and risk inherited from its dependency chain.	1
AC.2.2	Verify that the evaluation of each tool covers the local components (static and dynamic analysis), the SaaS endpoints (TLS, AuthN/AuthZ, logging, data residency), and the vendor's model supply chain (training-data provenance, fine-tune history, RAG sources). Each of these is reviewed and the review is written down.	2
AC.2.3	Verify that each tool goes through adversarial robustness testing before onboarding. The testing is repeated after any material change to the model or to the system prompts. Coverage includes automated prompt-injection probes, jailbreak suites, and indirect-injection corpora delivered through realistic PR and issue surfaces.	2
AC.2.4	Verify that evaluations follow a recognized framework such as NIST AI RMF, NIST AI 600-1 Generative AI Profile, or ISO/IEC 42001. Evaluations are repeated after a major version change, a vendor incident, or new threat intelligence relevant to the tool class.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.2.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਹਰ AI ਟੂਲ ਦਾ — ਭਾਵੇਂ ਉਹ ਸਹਾਇਕ ਹੋਵੇ, ਸਮੀਖਿਅਕ, ਏਜੰਟ, ਜਾਂ MCP ਸਰਵਰ — ਇੱਕ ਖ਼ਤਰਾ ਮਾਡਲ ਹੈ। ਇਹ ਖ਼ਤਰਾ ਮਾਡਲ ਦੁਰਵਰਤੋਂ, model inversion, ਸਖਿਲਾਈ-ਡਾਟਾ ਲੀਕੇਜ਼, ਗੈਰ-ਭਰੋਸੇਯੋਗ ਇਨਪੁੱਟ ਤੋਂ prompt ਇੰਜੈਕਸ਼ਨ, ਗੈਰ-ਸੁਰੱਖਿਅਤ ਆਊਟਪੁੱਟ ਪ੍ਰਬੰਧਨ, ਲੋੜ ਤੋਂ ਵੱਧ ਏਜੰਸੀ (excessive agency), ਅਤੇ ਉਸ ਦੀ ਡਿਪੈਂਡੈਂਸੀ ਲੜੀ ਤੋਂ ਵਰਿਸੇ ਵੱਲੋਂ ਮਲਿ ਜੋਖਮ ਨੂੰ ਢੱਕਦਾ ਹੈ।	1
AC.2.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਹਰ ਟੂਲ ਦਾ ਮੁਲਾਂਕਣ ਸਥਾਨਕ ਕੰਪੋਨੈਂਟਾਂ (ਸਥਿਰ ਅਤੇ ਗਤੀਸ਼ੀਲ ਵਸ਼ਿਲੇਸ਼ਣ), SaaS ਐਂਡਪੁਆਇੰਟਾਂ (TLS, AuthN/AuthZ, ਲੌਗਿੰਗ, ਡਾਟਾ ਨਵਿਸ਼ਾਸ), ਅਤੇ ਵਕਿਰੇਤਾ ਦੀ ਮਾਡਲ ਸਪਲਾਈ ਚੇਨ (ਸਖਿਲਾਈ-ਡਾਟਾ ਦਾ ਮੂਲ-ਸਰੋਤ, ਫ਼ਾਈਨ-ਟਿਊਨਿੰਗ ਇਤਹਾਸ, RAG ਸਰੋਤ) ਨੂੰ ਢੱਕਦਾ ਹੈ। ਇਹਨਾਂ ਵੱਲੋਂ ਹਰੇਕ ਦੀ ਸਮੀਖਿਆ ਕੀਤੀ ਜਾਂਦੀ ਹੈ ਅਤੇ ਸਮੀਖਿਆ ਲਿਖਤੀ ਰੂਪ ਵੱਲੋਂ ਦਰਜ ਕੀਤੀ ਜਾਂਦੀ ਹੈ।	2
AC.2.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਹਰ ਟੂਲ ਨੂੰ ਸ਼ਾਮਲ ਕਰਨ ਤੋਂ ਪਹਿਲਾਂ ਵਰਿਧੀ ਮਜ਼ਬੂਤੀ (adversarial robustness) ਟੈਸਟਿੰਗ ਵੱਲੋਂ ਲੰਘਾਇਆ ਜਾਂਦਾ ਹੈ। ਮਾਡਲ ਜਾਂ ਸਿਸਟਮ prompt ਵੱਲੋਂ ਕਸਿ ਵੀ ਮਹੱਤਵਪੂਰਨ ਤਬਦੀਲੀ ਤੋਂ ਬਾਅਦ ਇਹ ਟੈਸਟਿੰਗ ਦੁਹਰਾਈ ਜਾਂਦੀ ਹੈ। ਇਸ ਦੇ ਘੇਰੇ ਵੱਲੋਂ ਸਵੈਚਾਲਤ prompt ਇੰਜੈਕਸ਼ਨ ਪੜਤਾਲਾਂ, jailbreak ਸੂਟ, ਅਤੇ ਅਸਲੀਅਤ ਵਰਗੀਆਂ PR ਤੇ ਮੁੱਦਾ ਸਤ੍ਹਾਵਾਂ ਰਾਹੀਂ ਪਹੁੰਚਾਏ ਗਏ ਅਸਧਿ-ਇੰਜੈਕਸ਼ਨ ਕਾਰਪੋਰਾ ਸ਼ਾਮਲ ਹਨ।	2
AC.2.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮੁਲਾਂਕਣ ਕਸਿ ਮਾਨਤਾ-ਪ੍ਰਾਪਤ ਫ਼ਰੇਮਵਰਕ ਦੀ ਪਾਲਣਾ ਕਰਦੇ ਹਨ, ਜਿਵੇਂ NIST AI RMF, NIST AI 600-1 Generative AI Profile, ਜਾਂ ISO/IEC 42001। ਵੱਡੀ ਵਰਜਨ ਤਬਦੀਲੀ, ਵਕਿਰੇਤਾ ਦੀ ਕਸਿ ਘਟਨਾ, ਜਾਂ ਟੂਲ ਸ਼੍ਰੇਣੀ ਨਾਲ ਸੰਬੰਧਤ ਨਵੀਂ ਖ਼ਤਰਾ ਖੁਫ਼ੀਆ ਜਾਣਕਾਰੀ ਤੋਂ ਬਾਅਦ ਮੁਲਾਂਕਣ ਦੁਹਰਾਏ ਜਾਂਦੇ ਹਨ।	3

Mappings & References:

ਮੈਪਿੰਗ ਅਤੇ ਹਵਾਲੇ:

- **AC.2.1:** OWASP LLM Top 10 (2025) LLM01, LLM06; OWASP Agentic Top 10 (2026) ASI01, ASI02, ASI03; AISVS C9; MITRE ATLAS (Threat modeling).
- **AC.2.2:** OWASP LLM Top 10 (2025) LLM03; OWASP Agentic Top 10 (2026) ASI04; NIST SSDF PO.1, PO.5; ISO/IEC 42001 Clause 8.
- **AC.2.3:** MITRE ATLAS (Adversarial ML testing); AISVS C2.1, C11.1; NIST AI 600-1 MEASURE.
- **AC.2.4:** ISO/IEC 42001 Clause 9.2; NIST AI RMF GOVERN.

AC.3 Secure Prompt & Context Management

AC.3 ਸੁਰੱਖਿਅਤ prompt ਅਤੇ ਸੰਦਰਭ ਪ੍ਰਬੰਧਨ

Two goals in this family. First: stop secrets, proprietary code, and personal data from leaking into prompts. Second: treat any content sourced from the repository, a PR, or a third party as untrusted input. Any of it can carry a prompt-injection payload, and most of it usually does not, which is part of what makes the rare hostile case easy to miss.

ਇਸ ਪਰਿਵਾਰ ਵਿੱਚ ਦੋ ਟੀਚੇ ਹਨ। ਪਹਿਲਾਂ: ਗੁਪਤ ਭੇਦਾਂ, ਮਲਕੀਅਤੀ ਕੋਡ, ਅਤੇ ਨਜ਼ੀ ਡਾਟੇ ਨੂੰ prompt ਵਿੱਚ ਲੀਕ ਹੋਣ ਤੋਂ ਰੋਕਣਾ। ਦੂਜਾ: ਰਿਪੋਜ਼ਿਟਰੀ, ਕਮਿ PR, ਜਾਂ ਕਸਿ ਤੀਜੀ ਧਰਿ ਤੋਂ ਆਈ ਹਰ ਸਮੱਗਰੀ ਨੂੰ ਗ਼ੈਰ-ਭਰੋਸੇਯੋਗ ਇਨਪੁੱਟ ਵਜੋਂ ਲੈਣਾ। ਇਹਨਾਂ ਵਿੱਚੋਂ ਕੋਈ ਵੀ prompt ਇੰਜੈਕਸ਼ਨ ਪੇਲੋਡ ਲੈ ਕੇ ਆ ਸਕਦੀ ਹੈ, ਅਤੇ ਵਧੇਰੇ ਕਰਕੇ ਨਹੀਂ ਲਿਆਉਂਦੀ — ਇਹੀ ਗੱਲ ਵਰਿਲੇ ਦੁਸ਼ਮਣਾਨਾ ਮਾਮਲੇ ਨੂੰ ਨਜ਼ਰੋਂ ਖੁੰਝਾਉਣਾ ਸੌਖਾ ਬਣਾ ਦਿੰਦੀ ਹੈ।

Relationship to AISVS C2.1: AC.3.3, AC.3.4, and AC.3.5 apply AISVS C2.1 (Prompt Injection Defenses) to the secure-coding case. If a finding here is something that C2.1 verification did not already close, count it as an additional gap (specific to coding-tool prompt construction). If C2.1 already closed it, do not count it twice.

AISVS C2.1 ਨਾਲ ਸੰਬੰਧ: AC.3.3, AC.3.4, ਅਤੇ AC.3.5 AISVS C2.1 (Prompt Injection Defenses) ਨੂੰ ਸੁਰੱਖਿਅਤ-ਕੋਡਿੰਗ ਦੇ ਮਾਮਲੇ ਉੱਤੇ ਲਾਗੂ ਕਰਦੇ ਹਨ। ਜੇ ਇੱਥੋਂ ਦਾ ਕੋਈ ਖੋਜ-ਨਤੀਜਾ ਅਜਿਹਾ ਹੈ ਜਿਸ ਨੂੰ C2.1 ਦੀ ਤਸਦੀਕ ਨੇ ਪਹਿਲਾਂ ਹੀ ਬੰਦ ਨਹੀਂ ਕੀਤਾ ਸੀ, ਤਾਂ ਉਸ ਨੂੰ ਇੱਕ ਵਾਧੂ ਪਾੜੇ ਵਜੋਂ ਗਣਿ (ਜੇ ਕੋਡਿੰਗ-ਟੂਲ ਦੇ prompt ਨਰਿਮਾਣ ਲਈ ਵਸ਼ਿਸ਼ ਹੈ)। ਜੇ C2.1 ਨੇ ਉਸ ਨੂੰ ਪਹਿਲਾਂ ਹੀ ਬੰਦ ਕਰ ਦਿੱਤਾ ਸੀ, ਤਾਂ ਉਸ ਨੂੰ ਦੋ ਵਾਰ ਨਾ ਗਣਿ।

#	Description	Level
AC.3.1	Verify that written guidance forbids putting secrets, credentials, PII, or classified data in any prompt sent to an AI tool. The guidance is enforced in pre-commit hooks, IDE integrations, and CI.	1
AC.3.2	Verify that technical controls automatically strip sensitive material from any context window sent to an AI tool. Client-side redaction, approved context filters, and secret scanners with pre-prompt hooks all qualify.	1
AC.3.3	Verify that any externally sourced context being fed to an AI tool is treated as untrusted and screened for prompt injection before it reaches the prompt. Sources to cover: PR descriptions and comments, fork-supplied diffs, issue bodies, commit messages, third-party documentation, web search results, and MCP tool outputs.	1

#	Description	Level
AC.3.4	Verify that the AI tool enforces an instruction hierarchy, with system and developer messages taking precedence over untrusted repository content. This hierarchy has to hold across multi-turn conversations and tool-augmented workflows.	1
AC.3.5	Verify that input length controls stop untrusted PR or repository content from crowding system instructions or safety directives out of the effective context window. Oversized inputs are rejected outright. Silent truncation is not acceptable.	2
AC.3.6	Verify that prompts and AI responses are encrypted in transit and at rest, and retained per the data-classification policy. Tenants and projects are cryptographically separated from each other.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.3.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਲਿਖਤੀ ਮਾਰਗਦਰਸ਼ਨ AI ਟੂਲ ਨੂੰ ਭੇਜੇ ਜਾਂਦੇ ਕਸਿ ਵੀ prompt ਵਿੱਚ ਗੁਪਤ ਭੇਦ, ਕ੍ਰੈਡੈਂਸ਼ੀਅਲ, PII, ਜਾਂ ਵਰਗੀਕ੍ਰਿਤ ਡਾਟਾ ਪਾਉਣ ਤੋਂ ਵਰਜਦਾ ਹੈ। ਇਹ ਮਾਰਗਦਰਸ਼ਨ pre-commit ਹੁੱਕਾਂ, IDE ਏਕੀਕਰਨਾਂ, ਅਤੇ CI ਵਿੱਚ ਲਾਗੂ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	1
AC.3.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਤਕਨੀਕੀ ਨਿਯੰਤਰਣ AI ਟੂਲ ਨੂੰ ਭੇਜੀ ਜਾਂਦੀ ਕਸਿ ਵੀ ਸੰਦਰਭ ਵਡੇ (context window) ਵਿੱਚ ਸੰਵੇਦਨਸ਼ੀਲ ਸਮੱਗਰੀ ਆਪਣੇ-ਆਪ ਹਟਾ ਦਿੰਦੇ ਹਨ। ਕਲਾਇੰਟ-ਪਾਸੇ ਦੀ ਰਡਿਕਸ਼ਨ, ਪ੍ਰਵਾਨਤਿ ਸੰਦਰਭ ਫ਼ਲਿਟਰ, ਅਤੇ prompt-ਤੋਂ-ਪਹਿਲਾਂ ਵਾਲੀਆਂ ਹੁੱਕਾਂ ਵਾਲੇ ਗੁਪਤ-ਭੇਦ ਸਕੈਨਰ — ਇਹ ਸਾਰੇ ਯੋਗ ਹਨ।	1

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.3.3	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਟੂਲ ਨੂੰ ਦੱਤੀ ਜਾ ਰਹੇ ਕਸਿ ਵੀ ਬਾਹਰੀ ਸਰੋਤ ਵਾਲੇ ਸੰਦਰਭ ਨੂੰ ਗੈਰ-ਭਰੋਸੇਯੋਗ ਮੰਨਿਆ ਜਾਂਦਾ ਹੈ ਅਤੇ prompt ਤੱਕ ਪਹੁੰਚਣ ਤੋਂ ਪਹਿਲਾਂ prompt ਇੰਜੈਕਸ਼ਨ ਲਈ ਛਾਣਿਆ ਜਾਂਦਾ ਹੈ। ਢੱਕੇ ਜਾਣ ਵਾਲੇ ਸਰੋਤ: PR ਵੇਰਵੇ ਅਤੇ ਟਪਿੰਨੀਆਂ, ਫੋਰਕ ਤੋਂ ਦੱਤੀ diff, ਮੁੱਦਿਆਂ ਦਾ ਮਜ਼ਮੂਨ, ਕਮਿਟਿ ਸੁਨੇਹੇ, ਤੀਜੀ-ਧਰਿ ਦਸਤਾਵੇਜ਼ੀਕਰਨ, ਵੈੱਬ ਖੋਜ ਨਤੀਜੇ, ਅਤੇ MCP ਟੂਲ ਆਊਟਪੁੱਟ।	1
AC.3.4	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਟੂਲ ਇੱਕ ਹਦਾਇਤ ਲੜੀ-ਕਰਮ (instruction hierarchy) ਲਾਗੂ ਕਰਦਾ ਹੈ, ਜਿਸ ਵਿੱਚ ਸਸਿਟਮ ਅਤੇ ਡਵਿਲਪਰ ਸੁਨੇਹਿਆਂ ਨੂੰ ਗੈਰ-ਭਰੋਸੇਯੋਗ ਰਪਿੰਜਟਰੀ ਸਮੱਗਰੀ ਉੱਤੇ ਪਹਿਲ ਮਲਿਦੀ ਹੈ। ਇਹ ਲੜੀ-ਕਰਮ ਬਹੁ-ਵਾਰੀ ਗੱਲਬਾਤਾਂ ਅਤੇ ਟੂਲ-ਸਹਾਇਤ ਪ੍ਰਾਪਤ ਵਰਕਫਲੋ ਵਿੱਚ ਵੀ ਕਾਇਮ ਰਹਿਣਾ ਚਾਹੀਦਾ ਹੈ।	1
AC.3.5	ਤਸਦੀਕ ਕਰੋ ਕਿ ਇਨਪੁੱਟ ਲੰਬਾਈ ਨਯੰਤਰਣ ਗੈਰ-ਭਰੋਸੇਯੋਗ PR ਜਾਂ ਰਪਿੰਜਟਰੀ ਸਮੱਗਰੀ ਨੂੰ ਸਸਿਟਮ ਹਦਾਇਤਾਂ ਜਾਂ ਸਲਾਮਤੀ ਨਰਿਦੇਸ਼ਾਂ ਨੂੰ ਅਸਰਦਾਰ ਸੰਦਰਭ ਵਡਿ ਵਿੱਚੋਂ ਧੱਕ ਦੇਣ ਤੋਂ ਰੋਕਦੇ ਹਨ। ਲੋੜੇ ਵੱਡੇ ਇਨਪੁੱਟ ਸਥਿ ਰੱਦ ਕੀਤੇ ਜਾਂਦੇ ਹਨ। ਚੁੱਪ-ਚਾਪ ਕਟੌਤੀ (truncation) ਪ੍ਰਵਾਨ ਨਹੀਂ ਹੈ।	2
AC.3.6	ਤਸਦੀਕ ਕਰੋ ਕਿ prompt ਅਤੇ AI ਜਵਾਬ ਪ੍ਰਸਾਰਣ ਅਤੇ ਭੰਡਾਰਨ ਦੇਵਾਂ ਵਿੱਚ ਏਨਕ੍ਰਪਿਟ ਕੀਤੇ ਜਾਂਦੇ ਹਨ, ਅਤੇ ਡਾਟਾ-ਵਰਗੀਕਰਨ ਨੀਤੀ ਅਨੁਸਾਰ ਧਾਰਨ ਕੀਤੇ ਜਾਂਦੇ ਹਨ। ਟੈਨੈਟ ਅਤੇ ਪ੍ਰੋਜੈਕਟ ਇੱਕ-ਦੂਜੇ ਤੋਂ ਕ੍ਰਪਿਟੇਗਰਾਫ਼ਿਕ ਤੌਰ 'ਤੇ ਵੱਖ ਕੀਤੇ ਜਾਂਦੇ ਹਨ।	3

Mappings & References:

ਮੈਪਿੰਗ ਅਤੇ ਹਵਾਲੇ:

- **AC.3.1:** OWASP LLM Top 10 (2025) LLM02 (Sensitive Information Disclosure); OWASP ASVS v5 V14 (Data Protection); ISO/IEC 27001:2022 A.8.12 (Data Leakage Prevention).
- **AC.3.2:** AISVS C2.2; OWASP LLM Top 10 (2025) LLM02; NIST SSDF PW.3.
- **AC.3.3:** AISVS C2.1; OWASP LLM Top 10 (2025) LLM01; OWASP Agentic Top 10 (2026) ASI06; MITRE ATLAS (Indirect prompt injection).
- **AC.3.4:** AISVS C2.1.2; OWASP LLM Top 10 (2025) LLM01; CISA Secure by Design.
- **AC.3.5:** OWASP LLM Top 10 (2025) LLM10; AISVS C2.1.4.
- **AC.3.6:** OWASP ASVS v5 V6 (Cryptography), V14 (Data Protection); ISO/IEC 27001:2022 A.8.24 (Use of Cryptography).

AC.4 Validation of AI-Generated Code

AC.4 AI ਦੁਆਰਾ ਤਿਆਰ ਕੋਡ ਦੀ ਪ੍ਰਮਾਣਿਕਤਾ

Catch the vulnerabilities AI output introduces. Fix them before the code reaches a merge or a deployment.

AI ਆਊਟਪੁੱਟ ਵੱਲੋਂ ਪੇਸ਼ ਕੀਤੀਆਂ ਕਮਜ਼ੋਰੀਆਂ ਨੂੰ ਫੜੋ। ਕੋਡ ਦੇ ਮਰਜ਼ ਜਾਂ ਡੈਨਾਤੀ ਤੱਕ ਪਹੁੰਚਣ ਤੋਂ ਪਹਿਲਾਂ ਉਹਨਾਂ ਨੂੰ ਠੀਕ ਕਰੋ।

#	Description	Level
AC.4.1	Verify that AI-generated code always goes through code review by a qualified human engineer. The reviewer must not be the same identity that asked for the AI generation in the first place (separation of duties). And the AI agent itself does not count as the human reviewer.	1
AC.4.2	Verify that automated security testing runs on every pull request containing AI-generated code: SAST, IAST, DAST, secret scanning, IaC scanning, and SCA. Where the scanner supports them, AI-attribution-aware rules are turned on.	2
AC.4.3	Verify that pull requests containing AI-generated code are blocked from merging when an automated scan surfaces a critical security finding, defined as CVSS ≥ 9.0 or the equivalent threshold in the organization's vulnerability severity policy. Bypassing the block requires a written exception approved by an authorized human.	2
AC.4.4	Verify that security-critical files require an elevated review threshold when AI generated or modified them: two-person review, security-team sign-off, or stricter. Security-critical files here include authentication, authorization, and cryptography code; IAM policy; CI/CD workflow definitions; deployment manifests; and sandbox or network policy artifacts.	2

#	Description	Level
AC.4.5	Verify that differential fuzz testing or property-based tests cover the security-critical behaviors of AI-generated code: input validation, authorization logic, and deserialization safety.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.4.1	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਦੁਆਰਾ ਤਿਆਰ ਕੋਡ ਹਮੇਸ਼ਾ ਕਸਿ ਯੋਗ ਮਨੁੱਖੀ ਇੰਜੀਨੀਅਰ ਦੀ ਕੋਡ ਸਮੀਖਿਆ ਵਾਂਗੋ ਲੰਘਦਾ ਹੈ। ਸਮੀਖਿਅਕ ਉਹੀ ਪਛਾਣ ਨਹੀਂ ਹੋਣੀ ਚਾਹੀਦੀ ਜਿਸ ਨੇ ਪਹਿਲਾਂ AI ਤੋਂ ਕੋਡ ਤਿਆਰ ਕਰਵਾਇਆ ਸੀ (ਕਰਤੱਵਾਂ ਦੀ ਵੰਡ ¹⁹⁴ , separation of duties)। ਅਤੇ AI ਏਜੰਟ ਆਪ ਮਨੁੱਖੀ ਸਮੀਖਿਅਕ ਵਜੋਂ ਨਹੀਂ ਗਣਿਆ ਜਾਂਦਾ।	1
AC.4.2	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਦੁਆਰਾ ਤਿਆਰ ਕੋਡ ਵਾਲੀ ਹਰ ਪੁੱਲ ਰਕਿਐਸਟ ¹⁹⁵ (pull request) ਉੱਤੇ ਸਵੈਚਾਲਤ ਸੁਰੱਖਿਆ ਟੈਸਟਿੰਗ ਚੱਲਦੀ ਹੈ: SAST, IAST, DAST, ਗੁਪਤ-ਭੇਦ ਸਕੈਨਿੰਗ, IaC ਸਕੈਨਿੰਗ, ਅਤੇ SCA। ਜਿਥੇ ਸਕੈਨਰ ਸਮਰਥਨ ਕਰਦਾ ਹੈ, ਉਥੇ AI-ਸਰੋਤ-ਨਰਿਧਾਰਨ ਨੂੰ ਪਛਾਣਨ ਵਾਲੇ ਨਿਯਮ ਚਾਲੂ ਕੀਤੇ ਜਾਂਦੇ ਹਨ।	2
AC.4.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਜਦੋਂ ਕੋਈ ਸਵੈਚਾਲਤ ਸਕੈਨ ਕੋਈ ਨਾਜ਼ੁਕ ਸੁਰੱਖਿਆ ਖੋਜ-ਨਤੀਜਾ ਸਾਹਮਣੇ ਲਿਆਉਂਦਾ ਹੈ — ਜਿਸ ਦੀ ਪਰਭਾਸ਼ਾ CVSS >= 9.0 ਜਾਂ ਸੰਸਥਾ ਦੀ ਕਮਜ਼ੋਰੀ-ਗੰਭੀਰਤਾ ਨੀਤੀ ਵਿਚਲਾ ਬਰਾਬਰ ਦਾ ਥਰੈਸ਼ਹੋਲਡ ਹੈ — ਤਾਂ AI ਦੁਆਰਾ ਤਿਆਰ ਕੋਡ ਵਾਲੀਆਂ ਪੁੱਲ ਰਕਿਐਸਟਾਂ ਨੂੰ ਮਰਜ਼ ਹੋਣ ਤੋਂ ਰੋਕ ਦਿੱਤਾ ਜਾਂਦਾ ਹੈ। ਇਸ ਰੋਕ ਨੂੰ ਬਾਈਪਾਸ ਕਰਨ ਲਈ ਕਸਿ ਅਧਿਕਾਰਤ ਮਨੁੱਖ ਵੱਲੋਂ ਮਨਜ਼ੂਰ ਕੀਤੀ ਲਿਖਤੀ ਛੋਟ ਦੀ ਲੋੜ ਹੁੰਦੀ ਹੈ।	2

¹⁹⁴**separation of duties** (EN) -> ਕਰਤੱਵਾਂ ਦੀ ਵੰਡ — ਕਰਤੱਵ (“duty, assigned task”) reads as a named ISO/IEC 27001 control, where ਜ਼ਿੰਮੇਵਾਰੀ (“responsibility”) would drift to ordinary work allocation. Full discussion: OPEN-QUESTIONS.md Q109.

¹⁹⁵**pull request** (EN) -> ਪੁੱਲ ਰਕਿਐਸਟ, glossed on first use, then the retained acronym **PR** — a named platform object with an identity and an API (GitHub/GitLab), so a descriptive native rendering would break the mapping to the literal pull_request trigger name used in the same requirement set. Full discussion: OPEN-QUESTIONS.md Q106.

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.4.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਜਦੋਂ ਸੁਰੱਖਿਆ-ਨਾਜ਼ੁਕ ਫਾਈਲਾਂ AI ਨੇ ਤਿਆਰ ਜਾਂ ਸੋਧੀਆਂ ਹੋਣ, ਤਾਂ ਉਹਨਾਂ ਲਈ ਉੱਚਾ ਸਮੀਖਿਆ ਥਰੈਸ਼ਹੋਲਡ ਲਾਜ਼ਮੀ ਹੁੰਦਾ ਹੈ: ਦੇ-ਵਿਅਕਤੀ ਸਮੀਖਿਆ, ਸੁਰੱਖਿਆ-ਟੀਮ ਦੀ ਮਨਜ਼ੂਰੀ, ਜਾਂ ਇਸ ਤੋਂ ਵੀ ਸਖ਼ਤ। ਇੱਥੇ ਸੁਰੱਖਿਆ-ਨਾਜ਼ੁਕ ਫਾਈਲਾਂ ਵਿੱਚ ਪ੍ਰਮਾਣੀਕਰਨ, ਅਧਿਕਾਰੀਕਰਨ, ਅਤੇ ਕਰਪਿਟੋਗ੍ਰਾਫੀ ਕੋਡ; IAM ਨੀਤੀ; CI/CD ਵਰਕਫਲੋ ਪਰਭਿਾਸ਼ਾਵਾਂ; ਤੈਨਾਤੀ ਮੈਨੀਫੈਸਟ; ਅਤੇ ਸੈਂਡਬਾਕਸ ਜਾਂ ਨੈੱਟਵਰਕ ਨੀਤੀ ਆਰਟੀਫੈਕਟ ਸ਼ਾਮਲ ਹਨ।	2
AC.4.5	ਤਸਦੀਕ ਕਰੋ ਕਿ ਡਿਫਰੈਂਸ਼ੀਅਲ ਫਜ਼ ਟੈਸਟਿੰਗ (differential fuzz testing) ਜਾਂ ਵਸ਼ਿਸ਼ਤਾ-ਆਧਾਰਤਿ ਟੈਸਟ AI ਦੁਆਰਾ ਤਿਆਰ ਕੋਡ ਦੇ ਸੁਰੱਖਿਆ-ਨਾਜ਼ੁਕ ਵਿਵਹਾਰਾਂ ਨੂੰ ਢੱਕਦੇ ਹਨ: ਇਨਪੁੱਟ ਪ੍ਰਮਾਣਕਤਾ, ਅਧਿਕਾਰੀਕਰਨ ਤਰਕ, ਅਤੇ ਡੀਸੀਰੀਅਲਾਈਜ਼ੇਸ਼ਨ ਸਲਾਮਤੀ।	3

Mappings & References:

ਮੈਪਿੰਗ ਅਤੇ ਹਵਾਲੇ:

- **AC.4.1:** NIST SSDF PW.7; OWASP ASVS v5 V10 (Coding Quality); ISO/IEC 27001:2022 A.5.3 (Segregation of Duties).
- **AC.4.2:** NIST SP 800-204D (Pipeline scanning controls); SLSA v1.2 Build Track L2; OWASP SAMM Security Testing (ST).
- **AC.4.3:** OWASP CI/CD Top 10 CICD-SEC-04 (Poisoned Pipeline Execution); NIST SSDF PW.7, PW.8.
- **AC.4.4:** NIST SSDF PW.4, PW.7; OWASP CI/CD Top 10 CICD-SEC-01 (Insufficient Flow Control); ISO/IEC 27001:2022 A.8.32 (Change Management).
- **AC.4.5:** NIST SSDF PW.8; OWASP ASVS v5 V11 (Business Logic).

AC.5 Explainability & Traceability of Code Suggestions

AC.5 ਕੋਡ ਸੁਝਾਵਾਂ ਦੀ ਵਿਆਖਿਆਯੋਗਤਾ¹⁹⁶ ਅਤੇ ਟਰੇਸਯੋਗਤਾ

Auditors, defenders, and the developers themselves need to be able to see why a given AI suggestion was made, and how it ended up in a shipped artifact.

ਆਡੀਟਰਾਂ, ਬਚਾਅ ਕਰਨ ਵਾਲਿਆਂ, ਅਤੇ ਖੁਦ ਡਿਵੈਲਪਰਾਂ ਨੂੰ ਇਹ ਦੇਖ ਸਕਣਾ ਚਾਹੀਦਾ ਹੈ ਕਿ ਕੋਈ ਖਾਸ AI ਸੁਝਾਅ ਕਿਉਂ ਦਿੱਤਾ ਗਿਆ ਸੀ, ਅਤੇ ਉਹ ਭੇਜੇ ਗਏ ਆਰਟੀਫੈਕਟ ਵਿੱਚ ਕਿਵੇਂ ਪਹੁੰਚਿਆ।

¹⁹⁶ **Explainability** (EN) -> ਵਿਆਖਿਆਯੋਗਤਾ — built with the -ਯੋਗਤਾ property-noun suffix, matching how the corpus already forms ਟਰੇਸਯੋਗਤਾ (traceability), the very word paired with it in this chapter title; kept distinct from ਪਾਰਦਰਸ਼ਤਾ (transparency), a separate governance concept elsewhere in the corpus. Full discussion: OPEN-QUESTIONS.md Q120.

#	Description	Level
AC.5.1	Verify that prompt-and-response pairs are logged with stable correlation identifiers, so that an investigator can later replay the whole chain: prompt -> response -> commit -> build -> deployment.	1
AC.5.2	Verify that developers can pull up the citations (training snippets, retrieved documents, MCP tool outputs) that support a suggestion, and that the citation chain travels with the artifact.	3
AC.5.3	Verify that explainability reports, AI-event logs, and citation records are kept in tamper-evident storage (append-only, WORM, or an immutable log store) and are referenced during security reviews.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.5.1	ਤਸਦੀਕ ਕਰੋ ਕਿ prompt-ਅਤੇ-ਜਵਾਬ ਜੋੜੇ ਸਥਿਰ ਸਹਿ-ਸੰਬੰਧ ਪਛਾਣਕਰਤਾਵਾਂ ਨਾਲ ਲੌਗ ਕੀਤੇ ਜਾਂਦੇ ਹਨ, ਤਾਂ ਜੋ ਕੋਈ ਤਫ਼ਤੀਸ਼ਕਾਰ ਬਾਅਦ ਵੱਧ ਪੂਰੀ ਲੜੀ ਮੁੜ ਚਲਾ ਸਕੇ: prompt -> ਜਵਾਬ -> ਕਮਿਟ -> ਬਲਿਡ -> ਤੈਨਾਤੀ।	1
AC.5.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਡਵੈਲਪਰ ਉਹ ਹਵਾਲੇ (ਸਥਿਰਤਾ ਦੇ ਟੁਕੜੇ, ਪ੍ਰਾਪਤ ਕੀਤੇ ਦਸਤਾਵੇਜ਼, MCP ਟੂਲ ਆਊਟਪੁੱਟ) ਸਾਹਮਣੇ ਲਿਆ ਸਕਦੇ ਹਨ ਜੋ ਕਿਸੇ ਸੁਝਾਅ ਦਾ ਆਧਾਰ ਬਣਦੇ ਹਨ, ਅਤੇ ਇਹ ਹਵਾਲਾ ਲੜੀ ਆਰਟੀਫੈਕਟ ਦੇ ਨਾਲ-ਨਾਲ ਸਫ਼ਰ ਕਰਦੀ ਹੈ।	3
AC.5.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਵਿਆਖਿਆਯੋਗਤਾ ਰਿਪੋਰਟਾਂ, AI-ਘਟਨਾ ਲੌਗ, ਅਤੇ ਹਵਾਲਾ ਰਕਿਰਡ ਛੇੜਛਾੜ-ਪ੍ਰਗਟ ¹⁹⁷ (tamper-evident) ਭੰਡਾਰਨ ਵੱਧ ਰੱਖੇ ਜਾਂਦੇ ਹਨ (ਸਰਿਫ਼-ਜੋੜਨਯੋਗ, WORM, ਜਾਂ ਕੋਈ ਅਪਰਵਿਰਤਨਸ਼ੀਲ ਲੌਗ ਸਟੋਰ) ਅਤੇ ਸੁਰੱਖਿਆ ਸਮੀਖਿਆਵਾਂ ਦੌਰਾਨ ਉਹਨਾਂ ਦਾ ਹਵਾਲਾ ਦਿੱਤਾ ਜਾਂਦਾ ਹੈ।	3

Mappings & References:

ਮੈਪਿੰਗ ਅਤੇ ਹਵਾਲੇ:

¹⁹⁷ **tamper-evident** (EN) -> ਛੇੜਛਾੜ-ਪ੍ਰਗਟ — ਪ੍ਰਗਟ (“manifest, apparent”) keeps the detectability claim distinct from ਛੇੜਛਾੜ-ਰੋਧਕ (tamper-resistant, prevention), which is a different property than this control asks for. Full discussion: OPEN-QUESTIONS.md Q112.

- **AC.5.1:** ISO/IEC 42001 Clause 7.5 (Documented Information); OWASP ASVS v5 V8 (Logging); NIST SP 800-218A (Generative AI logging guidance).
- **AC.5.2:** NIST AI RMF MEASURE; OWASP LLM Top 10 (2025) LLM03.
- **AC.5.3:** ISO/IEC 27001:2022 A.8.15 (Logging); NIST AI 600-1 MEASURE; ISO/IEC 42001 (traceability).

AC.6 Continuous Feedback, Adversarial Testing & Model Fine-Tuning

AC.6 ਲਗਾਤਾਰ ਫੀਡਬੈਕ, ਵਰਿਧੀ ਟੈਸਟਿੰਗ, ਅਤੇ ਮਾਡਲ ਫ਼ਾਈਨ-ਟਊਨਿੰਗ

Improve model security over time. Watch for negative drift. Keep red-teaming the AI tooling. The red-team scope in this family is the AI tooling itself; the underlying systems and services the tooling depends on are handled by separate programs.

ਸਮੇਂ ਦੇ ਨਾਲ ਮਾਡਲ ਦੀ ਸੁਰੱਖਿਆ ਬਹਿਤਰ ਬਣਾਓ। ਨਾਂਹ-ਪੱਖੀ ਡਰਿਫਟ (drift) ਉੱਤੇ ਨਜ਼ਰ ਰੱਖੋ। AI ਟੂਲਿੰਗ ਦੀ ਰੈੱਡ-ਟੀਮਿੰਗ¹⁹⁸ (red-teaming) ਜਾਰੀ ਰੱਖੋ। ਇਸ ਪਰਿਵਾਰ ਵਿੱਚ ਰੈੱਡ-ਟੀਮ ਦਾ ਦਾਇਰਾ ਖੁਦ AI ਟੂਲਿੰਗ ਹੈ; ਜਨ੍ਹਾਂ ਹੇਠਲੇ ਸਸਿਟਮਾਂ ਅਤੇ ਸੇਵਾਵਾਂ ਉੱਤੇ ਇਹ ਟੂਲਿੰਗ ਨਰਿਭਰ ਕਰਦੀ ਹੈ, ਉਹਨਾਂ ਨੂੰ ਵੱਖਰੇ ਪਰੋਗਰਾਮ ਸੰਭਾਲਦੇ ਹਨ।

#	Description	Level
AC.6.1	Verify that developers and reviewers can flag insecure or non-compliant suggestions, and that each flag is tracked to closure with links back to the originating prompt and response and forward to any downstream artifacts.	1
AC.6.2	Verify that aggregated feedback feeds into periodic system-prompt updates or retrieval-augmented generation against vetted secure-coding corpora (OWASP Cheat Sheets, internal coding standards). Where the organization controls model training infrastructure, fine-tuning on the same feedback corpus is also required.	2

¹⁹⁸**Red-Teaming** (EN) -> ਰੈੱਡ-ਟੀਮਿੰਗ — kept as a loan because the colour term is a naming convention for a security discipline, not a description; translating it (ਲਾਲ ਟੀਮ) would leave a reader with an unexplained colour. Full discussion: OPEN-QUESTIONS.md Q108.

#	Description	Level
AC.6.3	Verify that scheduled red-team exercises target the AI tooling itself. The exercises include direct and indirect prompt-injection probes delivered through realistic PR, issue, and comment surfaces, jailbreak corpora, and supply-chain payload generation. Findings are remediated under tracked severity SLAs.	2
AC.6.4	Verify that a closed-loop evaluation harness runs regression tests after every fine-tune, system-prompt change, or model upgrade. Security metrics must meet or exceed the prior baseline before deployment.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.6.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਡਵੈਲਪਰ ਅਤੇ ਸਮੀਖਿਅਕ ਗੈਰ-ਸੁਰੱਖਿਅਤ ਜਾਂ ਗੈਰ-ਅਨੁਕੂਲ ਸੁਝਾਵਾਂ ਨੂੰ ਨਸ਼ਿਕਾਰ ਕਰ ਸਕਦੇ ਹਨ, ਅਤੇ ਹਰ ਨਸ਼ਿਕਾਰੀ ਨੂੰ ਬੰਦ ਹੋਣ ਤੱਕ ਟਰੈਕ ਕੀਤਾ ਜਾਂਦਾ ਹੈ, ਜਿਸ ਵਿੱਚ ਪਛਿ ਮੂਲ prompt ਤੇ ਜਵਾਬ ਅਤੇ ਅੱਗੇ ਕਸਿ ਵੀ ਡਾਊਨਸਟਰੀਮ ਆਰਟੀਫੈਕਟ ਤੱਕ ਦੇ ਲੜਿਕੇ ਹੁੰਦੇ ਹਨ।	1
AC.6.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਇਕੱਤਰ ਕੀਤਾ ਫੀਡਬੈਕ ਸਮੇਂ-ਸਮੇਂ ਸਰਿ ਸਸਿਟਮ-prompt ਅੱਪਡੇਟਾਂ ਵਿੱਚ, ਜਾਂ ਪਰਖੇ ਹੋਏ ਸੁਰੱਖਿਅਤ-ਕੋਡਿੰਗ ਕਾਰਪੋਰਾ (OWASP Cheat Sheets, ਅੰਦਰੂਨੀ ਕੋਡਿੰਗ ਮਿਆਰ) ਦੇ ਵਿਰੁੱਧ RAG (retrieval-augmented generation) ਵਿੱਚ ਪਾਇਆ ਜਾਂਦਾ ਹੈ। ਜਿਥੇ ਸੰਸਥਾ ਦਾ ਮਾਡਲ ਸਥਿਲਾਈ ਬੁਨਿਆਦੀ ਢਾਂਚੇ ਉੱਤੇ ਨਿਯੰਤਰਣ ਹੈ, ਉਥੇ ਉਸੇ ਫੀਡਬੈਕ ਕਾਰਪਸ ਉੱਤੇ ਫਾਈਨ-ਟਿਊਨਿੰਗ ਵੀ ਲਾਜ਼ਮੀ ਹੈ।	2
AC.6.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਮਾਂ-ਸਾਰਣੀ ਅਨੁਸਾਰ ਹੋਣ ਵਾਲੀਆਂ ਰੈਡ-ਟੀਮ ਮਸ਼ਕਾਂ ਦਾ ਨਸ਼ਿਕਾਰ ਖੁਦ AI ਟੂਲਿੰਗ ਹੁੰਦੀ ਹੈ। ਇਹਨਾਂ ਮਸ਼ਕਾਂ ਵਿੱਚ ਅਸਲੀਅਤ ਵਰਗੀਆਂ PR, ਮੁੱਦਾ, ਅਤੇ ਟਿੱਪਣੀ ਸਤ੍ਹਾਵਾਂ ਰਾਹੀਂ ਪਹੁੰਚਾਈਆਂ ਸਹਿਯੋਗਾਂ ਤੇ ਅਸਹਿਯੋਗਾਂ prompt ਇੰਜੈਕਸ਼ਨ ਪੜਤਾਲਾਂ, jailbreak ਕਾਰਪੋਰਾ, ਅਤੇ ਸਪਲਾਈ ਚੇਨ ਪੋਲੋਡ ਤਿਆਰੀ ਸ਼ਾਮਲ ਹਨ। ਖੋਜ-ਨਤੀਜਿਆਂ ਨੂੰ ਟਰੈਕ ਕੀਤੇ ਗੰਭੀਰਤਾ SLA ਦੇ ਅਧੀਨ ਦਰੁਸਤ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	2

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.6.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਹਰ ਫਾਈਨ-ਟਿਊਨ, ਸਿਸਟਮ-prompt ਤਬਦੀਲੀ, ਜਾਂ ਮਾਡਲ ਅੱਪਗ੍ਰੇਡ ਤੋਂ ਬਾਅਦ ਇੱਕ ਬੰਦ-ਲੂਪ ਮੁਲਾਂਕਣ ਹਾਰਨੈਸ (closed-loop evaluation harness) ਰਿਗਰੈਸ਼ਨ ਟੈਸਟ ਚਲਾਉਂਦਾ ਹੈ। ਤੈਨਾਤੀ ਤੋਂ ਪਹਿਲਾਂ ਸੁਰੱਖਿਆ ਮੈਟ੍ਰਿਕਸ ਦਾ ਪਛਿਲੀ ਬੇਸਲਾਈਨ ਦੇ ਬਰਾਬਰ ਜਾਂ ਉਸ ਤੋਂ ਉੱਤੇ ਹੋਣਾ ਲਾਜ਼ਮੀ ਹੈ।	3

Mappings & References:

ਮੈਪਿੰਗ ਅਤੇ ਹਵਾਲੇ:

- **AC.6.1:** NIST AI RMF MANAGE; ISO/IEC 42001 Clause 10; OWASP SAMM Defect Management (DM).
- **AC.6.2:** OWASP LLM Top 10 (2025) LLM03; NIST SSDF PO.3.
- **AC.6.3:** MITRE ATLAS (Adversarial ML lifecycle); NIST AI 600-1 MEASURE 2.7; OWASP SAMM Security Testing (ST).
- **AC.6.4:** ISO/IEC 42001 Clause 9.1; NIST AI RMF MEASURE.

AC.7 AI-Generated Infrastructure & Pipeline Artifacts

AC.7 AI ਦੁਆਰਾ ਤਿਆਰ ਬੁਨਿਆਦੀ ਢਾਂਚਾ ਅਤੇ ਪਾਈਪਲਾਈਨ ਆਰਟੀਫੈਕਟ

Infrastructure code, CI/CD workflow files, deployment manifests, and security policy artifacts each have outsized impact when they are wrong. When AI has generated them, the validation needs to be correspondingly stricter than for ordinary application code.

ਬੁਨਿਆਦੀ ਢਾਂਚਾ ਕੋਡ, CI/CD ਵਰਕਫਲੋ ਫਾਈਲਾਂ, ਤੈਨਾਤੀ ਮੈਨੀਫੈਸਟ, ਅਤੇ ਸੁਰੱਖਿਆ ਨੀਤੀ ਆਰਟੀਫੈਕਟ — ਇਹਨਾਂ ਵਿੱਚੋਂ ਹਰੇਕ ਦੇ ਗਲਤ ਹੋਣ ਦਾ ਪ੍ਰਭਾਵ ਹੱਦੋਂ ਵੱਧ ਹੁੰਦਾ ਹੈ। ਜਦੋਂ ਇਹ AI ਨੇ ਤਿਆਰ ਕੀਤੇ ਹੋਣ, ਤਾਂ ਇਹਨਾਂ ਦੀ ਪ੍ਰਮਾਣਿਕਤਾ ਆਮ ਐਪਲੀਕੇਸ਼ਨ ਕੋਡ ਦੇ ਮੁਕਾਬਲੇ ਉਸੇ ਅਨੁਪਾਤ ਵਿੱਚ ਵਧੇਰੇ ਸਖ਼ਤ ਹੋਣੀ ਚਾਹੀਦੀ ਹੈ।

#	Description	Level
AC.7.1	Verify that AI-generated or AI-modified artifacts are clearly labeled and tracked as such. Artifact classes in scope include infrastructure-as-code (Terraform, CloudFormation, Pulumi, Bicep), CI/CD workflow files (GitHub Actions, GitLab CI, Jenkinsfile, Argo Workflows, Tekton), container and orchestration manifests (Dockerfile, Kubernetes, Helm), and security policy artifacts (IAM, OPA/Rego, NetworkPolicy, admission controllers).	1
AC.7.2	Verify that AI-generated infrastructure and pipeline configurations require human review and approval before they run in any environment beyond a hermetic sandbox.	2
AC.7.3	Verify that AI-generated infrastructure and workflow changes pass policy-as-code enforcement (OPA, Conftest, Checkov, tfsec, KICS, kube-linter) at the same level as, or stricter than, human-authored changes. Policy violations block promotion.	2
AC.7.4	Verify that changes to high-impact pipeline trigger configurations require both dual control and a security-team review, no matter who or what produced the change. The configurations in scope include GitHub Actions pull_request_target and workflow_run, self-hosted runner labels, workflow permissions: blocks, OIDC trust policies, and secret-environment mappings.	2
AC.7.5	Verify that drift detection compares deployed infrastructure and live workflow configurations against signed, AI-attributed baselines, and alerts on any unauthorized modification.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.7.1	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਦੁਆਰਾ ਤਿਆਰ ਜਾਂ AI ਦੁਆਰਾ ਸੋਧੇ ਆਰਟੀਫੈਕਟਾਂ ਉੱਤੇ ਸਪੱਸ਼ਟ ਲੇਬਲ ਲੱਗਦਾ ਹੈ ਅਤੇ ਉਹਨਾਂ ਨੂੰ ਉਸੇ ਤਰ੍ਹਾਂ ਟਰੈਕ ਕੀਤਾ ਜਾਂਦਾ ਹੈ। ਦਾਇਰੇ ਵਰਤੀਆਂ ਆਰਟੀਫੈਕਟ ਸ਼੍ਰੇਣੀਆਂ ਵੱਲੋਂ infrastructure-as-code (Terraform, CloudFormation, Pulumi, Bicep), CI/CD ਵਰਕਫਲੋ ਫਾਈਲਾਂ (GitHub Actions, GitLab CI, Jenkinsfile, Argo Workflows, Tekton), ਕੰਟੇਨਰ ਅਤੇ ਆਰਕੈਸਟ੍ਰੇਸ਼ਨ ਮੈਨੀਫੈਸਟ (Dockerfile, Kubernetes, Helm), ਅਤੇ ਸੁਰੱਖਿਆ ਨੀਤੀ ਆਰਟੀਫੈਕਟ (IAM, OPA/Rego, NetworkPolicy, admission controllers) ਸ਼ਾਮਲ ਹਨ।	1
AC.7.2	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਦੁਆਰਾ ਤਿਆਰ ਬੁਨਿਆਦੀ ਢਾਂਚਾ ਅਤੇ ਪਾਈਪਲਾਈਨ ਸੰਰਚਨਾਵਾਂ ਨੂੰ ਪੂਰੀ ਤਰ੍ਹਾਂ ਸੀਲਬੰਦ (hermetic) ਸੈਂਡਬਾਕਸ ਤੋਂ ਬਾਹਰ ਕਸਿ ਵੀ ਵਾਤਾਵਰਣ ਵੱਲੋਂ ਚੱਲਣ ਤੋਂ ਪਹਿਲਾਂ ਮਨੁੱਖੀ ਸਮੀਖਿਆ ਅਤੇ ਮਨਜ਼ੂਰੀ ਦੀ ਲੋੜ ਹੁੰਦੀ ਹੈ।	2
AC.7.3	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਦੁਆਰਾ ਤਿਆਰ ਬੁਨਿਆਦੀ ਢਾਂਚਾ ਅਤੇ ਵਰਕਫਲੋ ਤਬਦੀਲੀਆਂ ਕੋਡ-ਵਜੋ-ਨੀਤੀ ¹⁹⁹ (policy-as-code) ਲਾਗੂਕਰਨ (OPA, Conftest, Checkov, tfsec, KICS, kube-linter) ਨੂੰ ਮਨੁੱਖ-ਲਿਖਤ ਤਬਦੀਲੀਆਂ ਦੇ ਬਰਾਬਰ ਜਾਂ ਉਸ ਤੋਂ ਸਖ਼ਤ ਪੱਧਰ ਉੱਤੇ ਪਾਸ ਕਰਦੀਆਂ ਹਨ। ਨੀਤੀ ਦੀਆਂ ਉਲੰਘਣਾਵਾਂ ਤਰੱਕੀ ਨੂੰ ਰੋਕ ਦਿੰਦੀਆਂ ਹਨ।	2
AC.7.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਉੱਚ-ਪ੍ਰਭਾਵ ਵਾਲੀਆਂ ਪਾਈਪਲਾਈਨ ਟਰੀਗਰ ਸੰਰਚਨਾਵਾਂ ਵੱਲੋਂ ਤਬਦੀਲੀਆਂ ਲਈ ਦੋਹਰਾ ਨਿਯੰਤਰਣ ²⁰⁰ (dual control) ਅਤੇ ਸੁਰੱਖਿਆ-ਟੀਮ ਦੀ ਸਮੀਖਿਆ ਦੋਵੇਂ ਲਾਜ਼ਮੀ ਹਨ, ਭਾਵੇਂ ਤਬਦੀਲੀ ਕਸਿ ਨੇ ਵੀ ਜਾਂ ਕਸਿ ਵੀ ਚੀਜ਼ ਨੇ ਕੀਤੀ ਹੋਵੇ। ਦਾਇਰੇ ਵਰਤੀਆਂ ਸੰਰਚਨਾਵਾਂ ਵੱਲੋਂ GitHub Actions ਦੇ pull_request_target ਅਤੇ workflow_run, ਸਵੈ-ਹੋਸਟ ਕੀਤੇ ਰਨਰ ²⁰¹ ਲੇਬਲ, ਵਰਕਫਲੋ ਦੇ permissions: ਬਲਾਕ, OIDC ਭਰੋਸਾ ਨੀਤੀਆਂ, ਅਤੇ ਗੁਪਤ-ਭੇਦ ਤੋਂ ਵਾਤਾਵਰਣ ਦੀਆਂ ਮੈਪਿੰਗਾਂ ਸ਼ਾਮਲ ਹਨ।	2

¹⁹⁹ **policy-as-code** (EN) -> ਕੋਡ-ਵਜੋ-ਨੀਤੀ — a transparent compound built from already-settled ਨੀਤੀ (policy) and the ordinary loan ਕੋਡ, with word order following the Panjabi head-final pattern rather than transliterating the English order. Full discussion: OPEN-QUESTIONS.md Q113.

²⁰⁰ **dual control** (EN) -> ਦੋਹਰਾ ਨਿਯੰਤਰਣ — kept visibly separate from separation of duties because this requirement demands dual control **and** a security-team review as two distinct obligations in the same sentence. Full discussion: OPEN-QUESTIONS.md Q109.

²⁰¹ **runner** (CI runner) (EN) -> ਰਨਰ — kept as a loan because a runner is a named CI-platform component (a registered, labelled execution host); ਦੋੜਾਕ (literal “runner,” as in athlete) would make “persistent or long-lived runners” read as a statement about people. Full discussion: OPEN-QUESTIONS.md Q111.

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.7.5	ਤਸਦੀਕ ਕਰੋ ਕਿ ਡਰਾਫਟ ਪਛਾਣ ਤੈਨਾਤ ਬੁਨਿਆਦੀ ਢਾਂਚੇ ਅਤੇ ਜਊਦੀਆਂ ਵਰਕਫਲੋ ਸੰਰਚਨਾਵਾਂ ਦੀ ਤੁਲਨਾ ਦਸਤਖਤ ਕੀਤੀਆਂ, AI ਨੂੰ ਸਰੋਤ-ਨਰਿਧਾਰਤਿ ਬੇਸਲਾਈਨਾਂ ਨਾਲ ਕਰਦੀ ਹੈ, ਅਤੇ ਕਸਿ ਵੀ ਅਣਅਧਿਕਾਰਤ ਸੋਧ ਉੱਤੇ ਚੇਤਾਵਨੀ ਦਿੰਦੀ ਹੈ।	3

Mappings & References:

ਮੈਪਿੰਗ ਅਤੇ ਹਵਾਲੇ:

- **AC.7.1:** OWASP CI/CD Top 10 CICD-SEC-05 (Insufficient PBAC); SLSA v1.2 Build Track provenance; NIST SSDF PW.1.
- **AC.7.2:** NIST SP 800-204D (Approval gating); OWASP CI/CD Top 10 CICD-SEC-01; ISO/IEC 27001:2022 A.8.32 (Change Management).
- **AC.7.3:** OWASP ASVS v5 V10 (CI/CD Deployment Security); OWASP CI/CD Top 10 CICD-SEC-07 (Insecure System Configuration); NIST SSDF PW.4.
- **AC.7.4:** OWASP CI/CD Top 10 CICD-SEC-01, CICD-SEC-02; GitHub Security Lab “Preventing pwn requests” series; NIST SP 800-204D (Pipeline governance).
- **AC.7.5:** NIST SP 800-204D (Continuous monitoring); ISO/IEC 27001:2022 A.8.19.

AC.8 Autonomous Agent Change Control Constraints

AC.8 ਖੁਦਮੁਖਤਾਰ ਏਜੰਟ ਤਬਦੀਲੀ-ਨਿਯੰਤਰਣ ਪਾਬੰਦੀਆਂ

Autonomous AI agents that generate code or configuration get the same separation-of-duties treatment that humans do. They cannot approve, merge, or promote their own work. This applies at the policy layer and at the technical layer.

ਕੋਡ ਜਾਂ ਸੰਰਚਨਾ ਤਿਆਰ ਕਰਨ ਵਾਲੇ ਖੁਦਮੁਖਤਾਰ AI ਏਜੰਟਾਂ ਨਾਲ ਕਰਤੱਵਾਂ ਦੀ ਵੰਡ ਦਾ ਉਹੀ ਸਲੂਕ ਹੁੰਦਾ ਹੈ ਜੋ ਮਨੁੱਖਾਂ ਨਾਲ ਹੁੰਦਾ ਹੈ। ਉਹ ਆਪਣੇ ਹੀ ਕੰਮ ਨੂੰ ਮਨਜ਼ੂਰੀ ਨਹੀਂ ਦੇ ਸਕਦੇ, ਮਰਜ ਨਹੀਂ ਕਰ ਸਕਦੇ, ਜਾਂ ਤਰੱਕੀ ਨਹੀਂ ਦੇ ਸਕਦੇ। ਇਹ ਗੱਲ ਨੀਤੀ ਪਰਤ ਉੱਤੇ ਵੀ ਲਾਗੂ ਹੁੰਦੀ ਹੈ ਅਤੇ ਤਕਨੀਕੀ ਪਰਤ ਉੱਤੇ ਵੀ।

#	Description	Level
AC.8.1	Verify that autonomous agents cannot approve, merge, sign, or deploy artifacts that they themselves generated, and that this constraint is enforced by the source-control system, the CI system, and the artifact registry. Policy alone does not satisfy this control.	1

#	Description	Level
AC.8.2	Verify that AI systems run with scoped, non-human identities (service accounts, workload identities, OIDC-issued ephemeral tokens), and that those identities cannot be used to promote their own generated artifacts across environments.	2
AC.8.3	Verify that autonomous agents cannot bypass branch protection, required reviews, required status checks, signed-commit requirements, or merge queues. Any attempt by an agent to change these settings raises a security alert.	2
AC.8.4	Verify that separation of duties holds across the stages of an AI-generated change. Each stage (generation, review, approval, deployment) is performed by a distinct principal, whether human or system.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.8.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਖੁਦਮੁਖਤਾਰ ਏਜੰਟ ਉਹਨਾਂ ਆਰਟੀਫੈਕਟਾਂ ਨੂੰ ਮਨਜ਼ੂਰੀ ਨਹੀਂ ਦੇ ਸਕਦੇ, ਮਰਜ਼ ਨਹੀਂ ਕਰ ਸਕਦੇ, ਦਸਤਖਤ ਨਹੀਂ ਕਰ ਸਕਦੇ, ਜਾਂ ਤੈਨਾਤ ਨਹੀਂ ਕਰ ਸਕਦੇ ਜੋ ਉਹਨਾਂ ਨੇ ਆਪ ਤਿਆਰ ਕੀਤੇ ਸਨ, ਅਤੇ ਇਹ ਪਾਬੰਦੀ ਸਰੋਤ-ਨਿਯੰਤਰਣ ਸਸਿਟਮ, CI ਸਸਿਟਮ, ਅਤੇ ਆਰਟੀਫੈਕਟ ਰਜਿਸਟਰੀ ਦੁਆਰਾ ਲਾਗੂ ਕੀਤੀ ਜਾਂਦੀ ਹੈ। ਇਕੱਲੀ ਨੀਤੀ ਇਸ ਨਿਯੰਤਰਣ ਨੂੰ ਪੂਰਾ ਨਹੀਂ ਕਰਦੀ।	1
AC.8.2	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਸਸਿਟਮ ਸੀਮਤਿ ਦਾਇਰੇ ਵਾਲੀਆਂ, ਗੈਰ-ਮਨੁੱਖੀ ਪਛਾਣਾਂ (ਸੇਵਾ ਖਾਤੇ, ਵਰਕਲੋਡ ਪਛਾਣਾਂ, OIDC ਦੁਆਰਾ ਜਾਰੀ ਥ੍ਰੂ-ਚਰਿ ਟੋਕਨ) ਨਾਲ ਚੱਲਦੇ ਹਨ, ਅਤੇ ਇਹ ਪਛਾਣਾਂ ਆਪਣੇ ਹੀ ਤਿਆਰ ਕੀਤੇ ਆਰਟੀਫੈਕਟਾਂ ਨੂੰ ਵਾਤਾਵਰਣਾਂ ਵਿਚਕਾਰ ਤਰੱਕੀ ਦੇਣ ਲਈ ਨਹੀਂ ਵਰਤੀਆਂ ਜਾ ਸਕਦੀਆਂ।	2

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.8.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਖੁਦਮੁਖਤਾਰ ਏਜੰਟ ਬਰਾਂਚ ਸੁਰੱਖਿਆ, ਲੋੜੀਂਦੀਆਂ ਸਮੀਖਿਆਵਾਂ, ਲੋੜੀਂਦੀਆਂ ਸਥਿਤੀ ਜਾਂਚਾਂ, ਦਸਤਖਤ-ਕੀਤੇ-ਕਮਿਟੀ ਦੀਆਂ ਲੋੜਾਂ, ਜਾਂ ਮਰਜ਼ ਕਤਾਰਾਂ ਨੂੰ ਬਾਈਪਾਸ ਨਹੀਂ ਕਰ ਸਕਦੇ। ਕਮਿਟੀ ਏਜੰਟ ਵੱਲੋਂ ਇਹ ਸੈਟਿੰਗਾਂ ਬਦਲਣ ਦੀ ਕੋਈ ਵੀ ਕੋਸ਼ਿਸ਼ ਸੁਰੱਖਿਆ ਚੇਤਾਵਨੀ ਪੈਦਾ ਕਰਦੀ ਹੈ।	2
AC.8.4	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਦੁਆਰਾ ਤਿਆਰ ਕਮਿਟੀ ਤਬਦੀਲੀ ਦੇ ਸਾਰੇ ਪੜਾਵਾਂ ਵਿੱਚ ਕਰਤੱਵਾਂ ਦੀ ਵੰਡ ਕਾਇਮ ਰਹਿੰਦੀ ਹੈ। ਹਰ ਪੜਾਅ (ਤਿਆਰੀ, ਸਮੀਖਿਆ, ਮਨਜ਼ੂਰੀ, ਤੈਨਾਤੀ) ਇੱਕ ਵੱਖਰੀ ਪਛਾਣ-ਇਕਾਈ ²⁰² (principal) ਦੁਆਰਾ ਕੀਤਾ ਜਾਂਦਾ ਹੈ, ਭਾਵੇਂ ਉਹ ਮਨੁੱਖ ਹੋਵੇ ਜਾਂ ਸਸਿਟਮ।	3

Mappings & References:

ਮੈਪਿੰਗ ਅਤੇ ਹਵਾਲੇ:

- **AC.8.1:** OWASP Agentic Top 10 (2026) ASI03 (Identity and Privilege Abuse), ASI10 (Rogue Agents); OWASP ASVS v5 V10; NIST SP 800-53r5 AC-5 (Separation of Duties).
- **AC.8.2:** NIST SP 800-207 (Zero Trust Architecture); OWASP CI/CD Top 10 C1CD-SEC-02; ISO/IEC 27001:2022 A.5.15 (Access Control).
- **AC.8.3:** OWASP CI/CD Top 10 C1CD-SEC-01; GitHub Docs (Branch protection rules and rulesets); OWASP Agentic Top 10 (2026) ASI03.
- **AC.8.4:** NIST SSDF PO.2; ISO/IEC 27001:2022 A.5.3; NIST SP 800-53r5 AC-5.

AC.9 AI Artifact Origin Validation for Deployment

AC.9 ਤੈਨਾਤੀ ਲਈ AI ਆਰਟੀਫੈਕਟ ਮੂਲ ਦੀ ਪ੍ਰਮਾਣਿਕਤਾ

Deployment and promotion pipelines need to validate the cryptographic origin and the generation history of AI-generated artifacts. They do this before letting the artifact through.

ਤੈਨਾਤੀ ਅਤੇ ਤਰੱਕੀ ਪਾਈਪਲਾਈਨਾਂ ਨੂੰ AI ਦੁਆਰਾ ਤਿਆਰ ਆਰਟੀਫੈਕਟਾਂ ਦੇ ਕ੍ਰੋਨੋਲੋਜੀਕਲ ਮੂਲ ਅਤੇ ਤਿਆਰੀ ਇਤਹਾਸ ਨੂੰ ਪ੍ਰਮਾਣਿਤ ਕਰਨਾ ਪੈਂਦਾ ਹੈ। ਇਹ ਕੰਮ ਉਹ ਆਰਟੀਫੈਕਟ ਨੂੰ ਅੱਗੇ ਲੰਘਾਉਣ ਤੋਂ ਪਹਿਲਾਂ ਕਰਦੀਆਂ ਹਨ।

²⁰²**principal** (security principal) (EN) -> ਪਛਾਣ-ਇਕਾਈ — built on the already-settled ਪਛਾਣ (“identity”) rather than ਕਰਤਾ, which is rejected on Gurmat grounds as load-bearing devotional vocabulary for a divine doer. Full discussion: OPEN-QUESTIONS.md Q124.

#	Description	Level
AC.9.1	Verify that AI-generated artifacts carry signed origin and generation metadata (in-toto or SLSA provenance attestations, AI BOM entries) identifying the AI system that produced them, the generation context, the humans involved, and the associated audit records.	2
AC.9.2	Verify that deployment pipelines check the presence, signature, and integrity of origin and generation metadata on AI-generated artifacts before promotion, using a trusted verifier (Sigstore/cosign, in-toto verification).	3
AC.9.3	Verify that artifacts are rejected at deployment and quarantined for review when they are missing required origin and generation information, signed by untrusted keys, or produced by an unapproved AI system or environment.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.9.1	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਦੁਆਰਾ ਤਿਆਰ ਆਰਟੀਫੈਕਟ ਦਸਤਖਤ ਕੀਤਾ ਮੂਲ ਅਤੇ ਤਿਆਰੀ ਮੈਟਾਡਾਟਾ (in-toto ਜਾਂ SLSA ਮੂਲ-ਸਰੋਤ ਅਟੈਸਟੇਸ਼ਨ, AI BOM ਇੰਦਰਾਜ) ਨਾਲ ਲੈ ਕੇ ਚੱਲਦੇ ਹਨ, ਜੋ ਉਹਨਾਂ ਨੂੰ ਪੈਦਾ ਕਰਨ ਵਾਲੇ AI ਸਿਸਟਮ, ਤਿਆਰੀ ਦੇ ਸੰਦਰਭ, ਸ਼ਾਮਲ ਮਨੁੱਖਾਂ, ਅਤੇ ਸੰਬੰਧਿਤ ਆਡਿਟ ਰਕਿਰਡਾਂ ਦੀ ਪਛਾਣ ਕਰਾਉਂਦਾ ਹੈ।	2
AC.9.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਤੈਨਾਤੀ ਪਾਈਪਲਾਈਨਾਂ ਤਰੱਕੀ ਤੋਂ ਪਹਿਲਾਂ AI ਦੁਆਰਾ ਤਿਆਰ ਆਰਟੀਫੈਕਟਾਂ ਉੱਤੇ ਮੂਲ ਅਤੇ ਤਿਆਰੀ ਮੈਟਾਡਾਟਾ ਦੀ ਮੌਜੂਦਗੀ, ਦਸਤਖਤ, ਅਤੇ ਅਖੰਡਤਾ ਦੀ ਜਾਂਚ ਕਰਕੇ ਭਰੋਸੇਯੋਗ ਤਸਦੀਕਕਾਰ (Sigstore/cosign, in-toto ਤਸਦੀਕ) ਦੀ ਵਰਤੋਂ ਕਰਕੇ ਕਰਦੀਆਂ ਹਨ।	3

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.9.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਜਹਿਜ਼ੇ ਆਰਟੀਫੈਕਟਾਂ ਵੱਲੋਂ ਲੋੜੀਂਦੀ ਮੂਲ ਅਤੇ ਤਿਆਰੀ ਜਾਣਕਾਰੀ ਗੈਰ-ਮੌਜੂਦ ਹੈ, ਜੋ ਗੈਰ-ਭਰੋਸੇਯੋਗ ਭੁੱਜੀਆਂ ਨਾਲ ਦਸਤਖਤ ਕੀਤੇ ਗਏ ਹਨ, ਜਾਂ ਜੋ ਕਸਿ ਗੈਰ-ਪਰਵਾਨਤਿ AI ਸਸਿਟਮ ਜਾਂ ਵਾਤਾਵਰਣ ਨੇ ਪੈਦਾ ਕੀਤੇ ਹਨ, ਉਹਨਾਂ ਨੂੰ ਤੈਨਾਤੀ ਵੇਲੇ ਰੱਦ ਕੀਤਾ ਜਾਂਦਾ ਹੈ ਅਤੇ ਸਮੀਖਿਆ ਲਈ ਕੁਆਰੰਟੀਨ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	3

Mappings & References:

ਮੈਪਿੰਗ ਅਤੇ ਹਵਾਲੇ:

- **AC.9.1:** SLSA v1.2 (Provenance attestations); CycloneDX ML-BOM; in-toto Attestation Framework.
- **AC.9.2:** SLSA v1.2 (Verification Summary Attestations); Sigstore/cosign (Signature verification); OWASP SCVS.
- **AC.9.3:** SLSA v1.2 (Verifier requirements); NIST SP 800-204D (Promotion gating).

AC.10 Generation Audit Trail Completeness and Validation

AC.10 ਤਿਆਰੀ ਆਡਿਟ ਟ੍ਰੇਲ ਦੀ ਸੰਪੂਰਨਤਾ ਅਤੇ ਪ੍ਰਮਾਣਿਕਤਾ

AI-generated artifacts need complete and consistent origin and generation records, validated before integration or deployment. The reason matters. Policy-based enforcement of origin tracking only works if the recorded information is itself complete and consistent. When records are missing fields, or when the fields they do have contradict each other, detections get missed and enforcement opens gaps. So origin tracking is treated as a first-class requirement here, and validated before an artifact is accepted.

AI ਦੁਆਰਾ ਤਿਆਰ ਆਰਟੀਫੈਕਟਾਂ ਲਈ ਸੰਪੂਰਨ ਅਤੇ ਇਕਸਾਰ ਮੂਲ ਤੇ ਤਿਆਰੀ ਰਕਾਰਡ ਲੋੜੀਂਦੇ ਹਨ, ਜਨ੍ਹਾਂ ਦੀ ਏਕੀਕਰਨ ਜਾਂ ਤੈਨਾਤੀ ਤੋਂ ਪਹਿਲਾਂ ਪ੍ਰਮਾਣਿਕਤਾ ਕੀਤੀ ਜਾਵੇ। ਇਸ ਦਾ ਕਾਰਨ ਮਹੱਤਵ ਰੱਖਦਾ ਹੈ। ਮੂਲ-ਟਰੈਕਿੰਗ ਦਾ ਨੀਤੀ-ਆਧਾਰਤ ਲਾਗੂਕਰਨ ਉਦੋਂ ਹੀ ਕੰਮ ਕਰਦਾ ਹੈ ਜਦੋਂ ਦਰਜ ਕੀਤੀ ਜਾਣਕਾਰੀ ਖੁਦ ਸੰਪੂਰਨ ਅਤੇ ਇਕਸਾਰ ਹੋਵੇ। ਜਦੋਂ ਰਕਾਰਡਾਂ ਵਿੱਚ ਖੇਤਰ ਗੈਰ-ਮੌਜੂਦ ਹੋਣ, ਜਾਂ ਜਹਿਜ਼ੇ ਖੇਤਰ ਮੌਜੂਦ ਹਨ ਉਹ ਇੱਕ-ਦੂਜੇ ਦਾ ਖੰਡਨ ਕਰਦੇ ਹੋਣ, ਤਾਂ ਪਛਾਣਾਂ ਖੁੰਝ ਜਾਂਦੀਆਂ ਹਨ ਅਤੇ ਲਾਗੂਕਰਨ ਵਿੱਚ ਪਾੜੇ ਖੁੱਲ੍ਹ ਜਾਂਦੇ ਹਨ। ਇਸੇ ਲਈ ਇੱਥੇ ਮੂਲ-ਟਰੈਕਿੰਗ ਨੂੰ ਪਹਿਲਾਂ ਦਰਜੇ ਦੀ ਲੋੜ ਵਜੋਂ ਲਿਆ ਜਾਂਦਾ ਹੈ, ਅਤੇ ਕਸਿ ਆਰਟੀਫੈਕਟ ਨੂੰ ਸਵੀਕਾਰ ਕਰਨ ਤੋਂ ਪਹਿਲਾਂ ਇਸ ਦੀ ਪ੍ਰਮਾਣਿਕਤਾ ਕੀਤੀ ਜਾਂਦੀ ਹੈ।

#	Description	Level
AC.10.1	Verify that AI-generated artifacts carry the required origin and generation fields: model identity and version, tool or agent identity, generation context, prompt hash, human involvement, session identifiers, and correlation IDs.	1

#	Description	Level
AC.10.2	Verify that origin and generation metadata is checked for completeness and consistency: no missing or ambiguous fields, values normalized to a single representation, and a signature chain that validates back to a trusted root.	2
AC.10.3	Verify that artifacts with incomplete, inconsistent, or unverifiable origin and generation metadata are rejected before merge or deployment, and that the rejection event is logged so trends can be tracked. Rejection happens on the verifier side, against the attestation or proof model defined in SLSA and the verification criteria in ISO/IEC 42001.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.10.1	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਦੁਆਰਾ ਤਿਆਰ ਆਰਟੀਫੈਕਟ ਲੋੜੀਂਦੇ ਮੂਲ ਅਤੇ ਤਿਆਰੀ ਖੇਤਰ ਨਾਲ ਲੈ ਕੇ ਚੱਲਦੇ ਹਨ: ਮਾਡਲ ਦੀ ਪਛਾਣ ਤੇ ਵਰਜਨ, ਟੂਲ ਜਾਂ ਏਜੰਟ ਦੀ ਪਛਾਣ, ਤਿਆਰੀ ਦਾ ਸੰਦਰਭ, prompt ਹੈਸ਼, ਮਨੁੱਖੀ ਸਮੂਲੀਅਤ, ਸੈਸ਼ਨ ਪਛਾਣਕਰਤਾ, ਅਤੇ ਸਹਿ-ਸੰਬੰਧ ID।	1
AC.10.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਮੂਲ ਅਤੇ ਤਿਆਰੀ ਮੈਟਾਡਾਟੇ ਦੀ ਸੰਪੂਰਨਤਾ ਅਤੇ ਇਕਸਾਰਤਾ ਲਈ ਜਾਂਚ ਕੀਤੀ ਜਾਂਦੀ ਹੈ: ਕੋਈ ਗੈਰ-ਮੌਜੂਦ ਜਾਂ ਦੁਵਿਧਾਪੂਰਨ ਖੇਤਰ ਨਾ ਹੋਵੇ, ਮੁੱਲ ਇੱਕੋ ਪ੍ਰਤੀਨਿਧਤਾ ਵੱਲੋਂ ਸਧਾਰਨੀਕ੍ਰਿਤ ਹੋਣ, ਅਤੇ ਦਸਤਖਤ ਲੜੀ ਪਛਿ ਕਸਿ ਭਰੋਸੇਯੋਗ ਰੂਟ ਤੱਕ ਪ੍ਰਮਾਣਿਤ ਹੁੰਦੀ ਹੋਵੇ।	2
AC.10.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਅਧੂਰੇ, ਬੇਮੇਲ, ਜਾਂ ਤਸਦੀਕ ਨਾ ਕੀਤੇ ਜਾ ਸਕਣ ਵਾਲੇ ਮੂਲ ਤੇ ਤਿਆਰੀ ਮੈਟਾਡਾਟੇ ਵਾਲੇ ਆਰਟੀਫੈਕਟ ਮਰਜ ਜਾਂ ਤੈਨਾਤੀ ਤੋਂ ਪਹਿਲਾਂ ਰੱਦ ਕੀਤੇ ਜਾਂਦੇ ਹਨ, ਅਤੇ ਰੱਦਗੀ ਦੀ ਘਟਨਾ ਲੌਗ ਕੀਤੀ ਜਾਂਦੀ ਹੈ ਤਾਂ ਜੋ ਰੁਝਾਨ ਟਰੈਕ ਕੀਤੇ ਜਾ ਸਕਣ। ਰੱਦਗੀ ਤਸਦੀਕਕਾਰ ਵਾਲੇ ਪਾਸੇ ਹੁੰਦੀ ਹੈ, SLSA ਵੱਲੋਂ ਪਰਭਾਸ਼ਿਤ ਅਟੈਸਟੇਸ਼ਨ ਜਾਂ ਸਬੂਤ ਮਾਡਲ ਅਤੇ ISO/IEC 42001 ਦੇ ਤਸਦੀਕ ਮਾਪਦੰਡਾਂ ਦੇ ਵਰਤੋਂ।	3

Mappings & References:

ਮੈਪਿੰਗ ਅਤੇ ਹਵਾਲੇ:

- **AC.10.1:** CycloneDX ML-BOM schema; NIST SP 800-218A (Generative AI provenance); ISO/IEC 42001 Clause 7.5.
- **AC.10.2:** OWASP SCVS (Provenance and Pedigree); SLSA v1.2 VSA verification.
- **AC.10.3:** SLSA v1.2 (Verifier-side enforcement); ISO/IEC 42001 Clause 9.

AC.11 AI Code-Review & Assistant Bot Hardening

AC.11 AI ਕੋਡ-ਸਮੀਖਿਆ ਅਤੇ ਸਹਾਇਕ ਬੋਟਾਂ²⁰³ ਦਾ ਸਖ਼ਤੀਕਰਨ

AI code-review bots, PR-comment bots, MCP-driven assistants (Model Context Protocol), and IDE copilots are all reachable through untrusted repository content. The reachable surfaces include PR diffs, descriptions, comments, issues, and any workflow files supplied from a fork. This family covers the case where an attacker uses one of those surfaces to push a defender's own AI agent into approving, ignoring, or actively assisting a supply-chain attack.

AI ਕੋਡ-ਸਮੀਖਿਆ ਬੋਟ, PR-ਟਿੱਪਣੀ ਬੋਟ, MCP-ਚਾਲਤ ਸਹਾਇਕ (Model Context Protocol), ਅਤੇ IDE ਕੋਪਾਇਲਟ — ਇਹ ਸਾਰੇ ਗੈਰ-ਭਰੋਸੇਯੋਗ ਰਿਪੋਜ਼ਿਟਰੀ ਸਮੱਗਰੀ ਰਾਹੀਂ ਪਹੁੰਚਯੋਗ ਹਨ। ਪਹੁੰਚਯੋਗ ਸਤ੍ਹਾਵਾਂ ਵਿੱਚ PR diff, ਵੇਰਵੇ, ਟਿੱਪਣੀਆਂ, ਮੁੱਦੇ, ਅਤੇ ਕਸਿ ਫ਼ੋਰਕ ਤੋਂ ਦੱਤੀਆਂ ਕੋਈ ਵੀ ਵਰਕਫਲੋ ਫ਼ਾਈਲਾਂ ਸ਼ਾਮਲ ਹਨ। ਇਹ ਪਰਵਿਰ ਉਸ ਮਾਮਲੇ ਨੂੰ ਢੱਕਦਾ ਹੈ ਜਿਥੇ ਹਮਲਾਵਰ ਇਹਨਾਂ ਵਿੱਚੋਂ ਕਸਿ ਸਤ੍ਹਾ ਦੀ ਵਰਤੋਂ ਕਰਕੇ ਬਚਾਅ ਕਰਨ ਵਾਲੇ ਦੇ ਆਪਣੇ ਹੀ AI ਏਜੰਟ ਨੂੰ ਕਸਿ ਸਪਲਾਈ ਚੇਨ ਹਮਲੇ ਨੂੰ ਮਨਜ਼ੂਰੀ ਦੇਣ, ਅਣਡਿੱਠ ਕਰਨ, ਜਾਂ ਸਰਗਰਮੀ ਨਾਲ ਉਸ ਵਿੱਚ ਸਹਾਇਤਾ ਕਰਨ ਵੱਲ ਧੱਕ ਦਿੰਦਾ ਹੈ।

Relationship to AISVS C2.1, C9.3, and C9.5: AC.11.1 through AC.11.5 are applications of three AISVS chapter controls to the specific case of AI code-review and assistant bots operating over untrusted PR content. The three chapter controls are C2.1 (Prompt Injection Defenses), C9.3 (Component Isolation and Tool Authorization), and C9.5 (Agent Authorization, Delegation, and Continuous Enforcement). The appendix restates each one with bot-specific guidance. Counting rule is the same as elsewhere: a finding here is either an additional gap that the upstream chapter did not close, or it is already counted under the chapter. Not both.

AISVS C2.1, C9.3, ਅਤੇ C9.5 ਨਾਲ ਸੰਬੰਧ: AC.11.1 ਤੋਂ AC.11.5 ਤੱਕ ਤਿੰਨ AISVS ਅਧਿਆਇ ਨਿਯੰਤਰਣਾਂ ਦੇ ਉਸ ਖ਼ਾਸ ਮਾਮਲੇ ਉੱਤੇ ਲਾਗੂਕਰਨ ਹਨ ਜਿਥੇ AI ਕੋਡ-ਸਮੀਖਿਆ ਅਤੇ ਸਹਾਇਕ ਬੋਟ ਗੈਰ-ਭਰੋਸੇਯੋਗ PR ਸਮੱਗਰੀ ਉੱਤੇ ਕੰਮ ਕਰਦੇ ਹਨ। ਉਹ ਤਿੰਨ ਅਧਿਆਇ ਨਿਯੰਤਰਣ ਹਨ C2.1 (Prompt Injection Defenses), C9.3 (Component Isolation and Tool Authorization), ਅਤੇ C9.5 (Agent Authorization, Delegation, and Continuous Enforcement)। ਇਹ ਅੰਤਰਿਕਾ ਹਰੇਕ ਨੂੰ ਬੋਟ-ਵਿਸ਼ੇਸ਼ ਮਾਰਗਦਰਸ਼ਨ ਨਾਲ ਦੁਬਾਰਾ ਬਿਆਨ ਕਰਦੀ ਹੈ। ਗਣਿਤੀ ਦਾ ਨਿਯਮ ਬਾਕੀ ਥਾਵਾਂ ਵਾਲਾ ਹੀ ਹੈ: ਇੱਥੋਂ ਦਾ ਖੋਜ-ਨਤੀਜਾ ਜਾਂ ਤਾਂ ਇੱਕ ਵਾਧੂ ਪਾੜਾ ਹੈ ਜਿਸ ਨੂੰ ਉੱਪਰਲੇ ਅਧਿਆਇ ਨੇ ਬੰਦ ਨਹੀਂ ਕੀਤਾ, ਜਾਂ ਉਹ ਪਹਿਲਾਂ ਹੀ ਉਸ ਅਧਿਆਇ ਹੇਠ ਗਣਿਆ ਜਾ ਚੁੱਕਾ ਹੈ। ਦੋਵੇਂ ਨਹੀਂ।

²⁰³ **bot** (EN) -> ਬੋਟ — kept as a neutral loan distinct from ਸਹਾਇਕ (assistant), ਏਜੰਟ (agent, reserved elsewhere), and copilot (its own loan), because this appendix restricts what each of the four actors may do and the family's structure collapses if any two share one Panjabi word. Full discussion: OPEN-QUESTIONS.md Q119.

#	Description	Level
AC.11.1	Verify that AI review and assistant bots treat every piece of PR-supplied content (diff, title, description, comments, file contents, commit messages, linked external URLs) as untrusted input, and apply the AISVS C2.1 prompt-injection defenses: instruction-hierarchy enforcement, content sanitization, and indirect-injection detection.	1
AC.11.2	Verify that AI review and assistant bot system prompts and policy configurations are integrity-checked at load time (signed, hash-pinned), and that nothing in the repository, in branch contents, in PR-sourced environment variables, or in any other user-controllable input can modify them.	1
AC.11.3	Verify that AI review and assistant bots emit only structured, schema-validated output (JSON with an allow-list of fields and actions). Any free-form output is treated as untrusted and never executed as a command, a query, a shell snippet, or a workflow step.	1
AC.11.4	Verify that AI review and assistant bots run in network-isolated, least-privilege sandboxes: a dedicated namespace, default-deny egress with an allow-list to approved APIs only, no mounted repository secrets, and ephemeral credentials only.	2
AC.11.5	Verify that any privileged action a bot can take (approving a PR, merging, labeling, dismissing reviews, posting comments outside its sandbox, invoking external tools) goes through a separate, audited authorization path. That path is adjudicated by a policy engine, not by the LLM.	2

#	Description	Level
AC.11.6	Verify that AI review and assistant bots log all prompts (including externally sourced context), tool calls, and outputs to tamper-evident storage. Egress patterns (URLs, IPs, DNS, payload sizes) are continuously monitored for exfiltration indicators, with alerting tuned for webhook, paste-site, and bin-service destinations.	2
AC.11.7	Verify that AI review bots run in a zero-privilege, read-only shadow mode for untrusted fork PRs. In shadow mode, inline code-generation commentary is restricted and privileged workflow interaction is forbidden, until a repository maintainer has cleared an initial first-time-contributor verification gate.	2
AC.11.8	Verify that AI review and assistant bots are subject to continuous adversarial testing: indirect-prompt-injection corpora are replayed against the bot through simulated PRs, issues, and comments. Detection effectiveness is tracked over time, and a regression blocks the model or prompt update that caused it.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.11.1	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਸਮੀਖਿਆ ਅਤੇ ਸਹਾਇਕ ਬੋਟ PR ਤੋਂ ਆਈ ਹਰ ਸਮੱਗਰੀ (diff, ਸਰਿਲੇਖ, ਵੇਰਵਾ, ਟਿੱਪਣੀਆਂ, ਫ਼ਾਈਲ ਸਮੱਗਰੀ, ਕਮਟਿ ਸੁਨੇਹੇ, ਲਕਿ ਕੀਤੇ ਬਾਹਰੀ URL) ਨੂੰ ਗੈਰ-ਭਰੋਸੇਯੋਗ ਇਨਪੁੱਟ ਵਜੋਂ ਲੈਂਦੇ ਹਨ, ਅਤੇ AISVS C2.1 ਦੇ prompt ਇੰਜੈਕਸ਼ਨ ਬਚਾਅ ਲਾਗੂ ਕਰਦੇ ਹਨ: ਹਦਾਇਤ ਲੜੀ-ਕ੍ਰਮ ਦਾ ਲਾਗੂਕਰਨ, ਸਮੱਗਰੀ ਸੈਨੀਟਾਈਜ਼ੇਸ਼ਨ ²⁰⁴ , ਅਤੇ ਅਸਧਿ-ਇੰਜੈਕਸ਼ਨ ਦੀ ਪਛਾਣ।	1

²⁰⁴ **sanitization** (EN) -> ਸੈਨੀਟਾਈਜ਼ੇਸ਼ਨ — corrected from an earlier draft's ਸਫ਼ਾਈ ("cleaning"), which renders hygiene elsewhere in this same appendix; ਸੈਨੀਟਾਈਜ਼ੇਸ਼ਨ is the form already settled across the corpus for neutralising a payload rather than tidying. Full discussion: OPEN-

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.11.2	ਤਸਦੀਕ ਕਰੋ ਕੀ AI ਸਮੀਖਿਆ ਅਤੇ ਸਹਾਇਕ ਬੋਟਾਂ ਦੇ ਸਿਸਟਮ prompt ਅਤੇ ਨੀਤੀ ਸੰਰਚਨਾਵਾਂ ਦੀ ਲੋਡ ਹੋਣ ਵੇਲੇ ਅਖੰਡਤਾ ਜਾਂਚ ਕੀਤੀ ਜਾਂਦੀ ਹੈ (ਦਸਤਖਤ ਕੀਤੇ, ਹੈਸ਼-ਪਨਿ ਕੀਤੇ), ਅਤੇ ਰਪਿੰਜਟਰੀ ਵਚਿਲੀ ਕੋਈ ਚੀਜ਼, ਬਰਾਂਚ ਦੀ ਸਮੱਗਰੀ, PR ਤੋਂ ਆਏ ਵਾਤਾਵਰਣ ਵੇਰੀਏਬਲ, ਜਾਂ ਕੋਈ ਹੋਰ ਵਰਤੋਂਕਾਰ-ਨਯੰਤਰਤਿ ਇਨਪੁੱਟ ਉਹਨਾਂ ਨੂੰ ਸੋਧ ਨਹੀਂ ਸਕਦਾ।	1
AC.11.3	ਤਸਦੀਕ ਕਰੋ ਕੀ AI ਸਮੀਖਿਆ ਅਤੇ ਸਹਾਇਕ ਬੋਟ ਸਰਿਫ਼ ਢਾਂਚਾਗਤ, ਸਕੀਮਾ-ਪ੍ਰਮਾਣਤਿ ਆਊਟਪੁੱਟ ਹੀ ਦਿੰਦੇ ਹਨ (ਖੇਤਰਾਂ ਅਤੇ ਕਾਰਵਾਈਆਂ ਦੀ ਇਜਾਜ਼ਤ-ਸੂਚੀ ਵਾਲਾ JSON)। ਕਸਿ ਵੀ ਖੁੱਲ੍ਹੇ-ਰੂਪ ਆਊਟਪੁੱਟ ਨੂੰ ਗੈਰ-ਭਰੋਸੇਯੋਗ ਮੰਨਿਆ ਜਾਂਦਾ ਹੈ ਅਤੇ ਉਸ ਨੂੰ ਕਦੇ ਵੀ ਕਮਾਂਡ, ਕਊਰੀ, ਸੈੱਲ ਟੁਕੜੇ, ਜਾਂ ਵਰਕਫਲੋ ਪੜਾਅ ਵਜੋਂ ਨਹੀਂ ਚਲਾਇਆ ਜਾਂਦਾ।	1
AC.11.4	ਤਸਦੀਕ ਕਰੋ ਕੀ AI ਸਮੀਖਿਆ ਅਤੇ ਸਹਾਇਕ ਬੋਟ ਨੈੱਟਵਰਕ-ਪੱਖੋਂ ਅਲੌਗ-ਥਲੌਗ, ਘੱਟੋ-ਘੱਟ-ਵਸਿਸ਼-ਅਧਕਿਾਰ ਸੈਡਬਾਕਸਾਂ ਵਚਿੱ ਚੱਲਦੇ ਹਨ: ਇੱਕ ਸਮਰਪਤਿ ਨੇਮਸਪੇਸ, ਮੂਲ-ਰੂਪ-ਵਚਿੱ-ਇਨਕਾਰ ਵਾਲਾ ਬਾਹਰ ਜਾਣ ਵਾਲਾ ਟਰੈਫ਼ਿਕ (egress) ਜਸਿ ਵਚਿੱ ਸਰਿਫ਼ ਪ੍ਰਵਾਨਤਿ API ਦੀ ਇਜਾਜ਼ਤ-ਸੂਚੀ ਹੋਵੇ, ਕੋਈ ਮਾਊਟੋਂ ਕੀਤੇ ਰਪਿੰਜਟਰੀ ਗੁਪਤ ਭੇਦ ਨਾ ਹੋਣ, ਅਤੇ ਸਰਿਫ਼ ਬੇੜ੍ਹ-ਚਰਿ ਕ੍ਰੈਡੈਂਸੀਅਲ ਹੋਣ।	2
AC.11.5	ਤਸਦੀਕ ਕਰੋ ਕੀ ਕੋਈ ਬੋਟ ਜੋ ਵੀ ਵਸਿਸ਼-ਅਧਕਿਾਰ ਵਾਲੀ ਕਾਰਵਾਈ ਕਰ ਸਕਦਾ ਹੈ (ਕਸਿ PR ਨੂੰ ਮਨਜ਼ੂਰੀ ਦੇਣਾ, ਮਰਜ਼ ਕਰਨਾ, ਲੇਬਲ ਲਾਉਣਾ, ਸਮੀਖਿਆਵਾਂ ਖ਼ਾਰਜ ਕਰਨਾ, ਆਪਣੇ ਸੈਡਬਾਕਸ ਤੋਂ ਬਾਹਰ ਟਪਿਣੀਆਂ ਪਾਉਣਾ, ਬਾਹਰੀ ਟੂਲ ਸੱਦਣਾ), ਉਹ ਇੱਕ ਵੱਖਰੇ, ਆਡਿਟ ਕੀਤੇ ਅਧਕਿਾਰੀਕਰਨ ਰਾਹ ਵਚਿੱ ਲੰਘਦੀ ਹੈ। ਉਸ ਰਾਹ ਦਾ ਨਬਿੜਾ ਇੱਕ ਨੀਤੀ ਇੰਜਣ ਕਰਦਾ ਹੈ, LLM ਨਹੀਂ।	2
AC.11.6	ਤਸਦੀਕ ਕਰੋ ਕੀ AI ਸਮੀਖਿਆ ਅਤੇ ਸਹਾਇਕ ਬੋਟ ਸਾਰੇ prompt (ਬਾਹਰੀ ਸਰੋਤ ਵਾਲੇ ਸੰਦਰਭ ਸਮੇਤ), ਟੂਲ ਸੱਦੇ, ਅਤੇ ਆਊਟਪੁੱਟ ਛੇੜਛਾੜ-ਪ੍ਰਗਟ ਭੰਡਾਰਨ ਵਚਿੱ ਲੌਗ ਕਰਦੇ ਹਨ। ਬਾਹਰ ਜਾਣ ਵਾਲੇ ਟਰੈਫ਼ਿਕ ਦੇ ਪੈਟਰਨਾਂ (URL, IP, DNS, ਪੇਲੋਡ ਆਕਾਰ) ਦੀ ਡਾਟਾ ਬਾਹਰ ਕੱਢਣ (exfiltration) ਦੇ ਸੰਕੇਤਾਂ ਲਈ ਲਗਾਤਾਰ ਨਗਿਰਾਨੀ ਕੀਤੀ ਜਾਂਦੀ ਹੈ, ਅਤੇ ਚੇਤਾਵਨੀ webhook, paste-site, ਤੇ bin-service ਟਕਿਣਿਆਂ ਲਈ ਸੁਰ ਕੀਤੀ ਜਾਂਦੀ ਹੈ।	2

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.11.7	ਤਸਦੀਕ ਕਰੋ ਕਿ ਗੈਰ-ਭਰੋਸੇਯੋਗ ਫੋਰਕ PR ਲਈ AI ਸਮੀਖਿਆ ਬੋਟ ਜ਼ੀਰੋ-ਵਿਸ਼ਿਸ਼-ਅਧਿਕਾਰ, ਸਰਿਫ਼-ਪੜ੍ਹਨਯੋਗ ਸ਼ੈਡੋ ਮੋਡ²⁰⁵ (shadow mode) ਵਿੱਚ ਚੱਲਦੇ ਹਨ। ਸ਼ੈਡੋ ਮੋਡ ਵਿੱਚ, ਜਦੋਂ ਤੱਕ ਕੋਈ ਰਿਪੋਜ਼ਟਰੀ ਸੰਭਾਲਕਰਤਾ ਪਹਿਲੀ-ਵਾਰੀ-ਯੋਗਦਾਨਕਰਤਾ ਦਾ ਸ਼ੁਰੂਆਤੀ ਤਸਦੀਕ ਗੇਟ ਪਾਸ ਨਹੀਂ ਕਰਾ ਦਿੰਦਾ, ਉਦੋਂ ਤੱਕ ਇਨਲਾਈਨ ਕੋਡ-ਤਿਆਰੀ ਟਿਪਿਣੀ ਸੀਮਤ ਰਹਿੰਦੀ ਹੈ ਅਤੇ ਵਿਸ਼ਿਸ਼-ਅਧਿਕਾਰ ਵਾਲਾ ਵਰਕਫਲੋ ਮੇਲ-ਜੋਲ ਵਰਜਤ ਹੁੰਦਾ ਹੈ।	2
AC.11.8	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਸਮੀਖਿਆ ਅਤੇ ਸਹਾਇਕ ਬੋਟ ਲਗਾਤਾਰ ਵਿਰੋਧੀ ਟੈਸਟਿੰਗ ਦੇ ਅਧੀਨ ਹਨ: ਅਸਪਿ-prompt-ਇੰਜੈਕਸ਼ਨ ਕਾਰਪੋਰਾ ਨੂੰ ਨਕਲੀ PR, ਮੁੱਦਿਆਂ, ਅਤੇ ਟਿਪਿਣੀਆਂ ਰਾਹੀਂ ਬੋਟ ਦੇ ਵਿਰੁੱਧ ਮੁੜ ਚਲਾਇਆ ਜਾਂਦਾ ਹੈ। ਪਛਾਣ ਦੀ ਅਸਰਦਾਰੀ ਨੂੰ ਸਮੇਂ ਦੇ ਨਾਲ ਟਰੈਕ ਕੀਤਾ ਜਾਂਦਾ ਹੈ, ਅਤੇ ਕੋਈ ਰਿਗਰੈਸ਼ਨ ਉਸ ਮਾਡਲ ਜਾਂ prompt ਅੱਪਡੇਟ ਨੂੰ ਰੋਕ ਦਿੰਦਾ ਹੈ ਜਿਸ ਨੇ ਉਸ ਨੂੰ ਪੈਦਾ ਕੀਤਾ।	3

Mappings & References:

ਮੈਪਿੰਗ ਅਤੇ ਹਵਾਲੇ:

- **AC.11.1:** AISVS C2.1; OWASP LLM Top 10 (2025) LLM01; OWASP Agentic Top 10 (2026) ASI01, ASI06.
- **AC.11.2:** AISVS C2.1; OWASP LLM Top 10 (2025) LLM01; OWASP Agentic Top 10 (2026) ASI01.
- **AC.11.3:** AISVS C7.1; OWASP LLM Top 10 (2025) LLM05; OWASP Agentic Top 10 (2026) ASI02, ASI05.
- **AC.11.4:** AISVS C9.3; OWASP Agentic Top 10 (2026) ASI02, ASI03, ASI05; NIST SP 800-204D (Workload isolation).
- **AC.11.5:** AISVS C9.5, C5.2.5; OWASP ASVS v5 V4 (Access Control); OWASP Agentic Top 10 (2026) ASI02, ASI03.
- **AC.11.6:** OWASP ASVS v5 V8 (Logging & Error Handling); OWASP LLM Top 10 (2025) LLM02; ISO/IEC 27001:2022 A.8.15, A.8.16.
- **AC.11.7:** GitHub Security Lab “Preventing pwn requests” series (Parts 1-4); OWASP Agentic Top 10 (2026) ASI01, ASI03, ASI09; OWASP CI/CD Top 10 CICD-SEC-01.
- **AC.11.8:** MITRE ATLAS (Indirect prompt injection); AISVS C2.1, C11.1; OWASP SAMM Security Testing (ST).

AC.12 CI/CD Pipeline Hardening Specific to AI Augmentation

AC.12 AI ਵਾਧੇ ਲਈ ਵਿਸ਼ਿਸ਼ CI/CD ਪਾਈਪਲਾਈਨ ਸਖ਼ਤੀਕਰਨ

Two kinds of CI/CD pipeline control are in scope for this family: those that AI augmentation newly requires, and those that AI augmentation breaks. Generic CI/CD hygiene is not in scope here; it is covered elsewhere. Short-lived credentials, immutable action pinning, branch protection, SLSA Build Track L3 provenance, and multi-party

²⁰⁵**shadow mode** (EN) -> ਸ਼ੈਡੋ ਮੋਡ — kept as a loan because it names a fixed industry deployment pattern (the component still runs and evaluates, but holds no privilege); ਪਰਛਾਵਾਂ (“shadow”) was rejected because it carries an ominous/inauspicious shading in ordinary Panjabi usage. Full discussion: OPEN-QUESTIONS.md Q117.

production approval are all addressed by OWASP ASVS v5 V10, the OWASP Top 10 CI/CD Security Risks (CICD-SEC-01 through CICD-SEC-10), NIST SP 800-204D, and SLSA v1.2. Adopters implement those baselines and verify them against the originating standards. We do not repeat that assessment here.

ਇਸ ਪਰਿਵਾਰ ਦੇ ਦਾਇਰੇ ਵਿੱਚ ਦੋ ਕਸਿਮਾਂ ਦੇ CI/CD ਪਾਈਪਲਾਈਨ ਨਿਯੰਤਰਣ ਆਉਂਦੇ ਹਨ: ਉਹ ਜਿਹੜੇ AI ਵਾਧਾ ਨਵੇਂ ਸਰਿਓਂ ਲੋੜੀਂਦੇ ਬਣਾ ਦਿੰਦਾ ਹੈ, ਅਤੇ ਉਹ ਜਿਹੜੇ AI ਵਾਧਾ ਤੋੜ ਦਿੰਦਾ ਹੈ। ਆਮ CI/CD ਸਫ਼ਾਈ ਇੱਥੇ ਦਾਇਰੇ ਵਿੱਚ ਨਹੀਂ ਹੈ; ਉਸ ਨੂੰ ਹੋਰ ਥਾਂ ਢੱਕਿਆ ਗਿਆ ਹੈ। ਬੇੜ੍ਹ-ਚਰਿ ਕਰੈਡੈਂਸੀਅਲ, ਅਪਰਵਿਰਤਨਸ਼ੀਲ ਐਕਸ਼ਨ ਪਨਿਗਿੰ, ਬਰਾਂਚ ਸੁਰੱਖਿਆ, SLSA Build Track L3 ਮੂਲ-ਸਰੋਤ, ਅਤੇ ਬਹੁ-ਧਰੀ ਉਤਪਾਦਨ ਮਨਜ਼ੂਰੀ — ਇਹ ਸਾਰੇ OWASP ASVS v5 V10, OWASP Top 10 CI/CD Security Risks (CICD-SEC-01 ਤੋਂ CICD-SEC-10), NIST SP 800-204D, ਅਤੇ SLSA v1.2 ਦੁਆਰਾ ਸੰਬੋਧਿਤ ਕੀਤੇ ਗਏ ਹਨ। ਅਪਣਾਉਣ ਵਾਲੇ ਉਹ ਬੇਸਲਾਈਨਾਂ ਲਾਗੂ ਕਰਦੇ ਹਨ ਅਤੇ ਮੂਲ ਮਿਆਰਾਂ ਦੇ ਵਰਿਓਂ ਉਹਨਾਂ ਦੀ ਤਸਦੀਕ ਕਰਦੇ ਹਨ। ਅਸੀਂ ਉਹ ਮੁਲਾਂਕਣ ਇੱਥੇ ਨਹੀਂ ਦੁਹਰਾਉਂਦੇ।

#	Description	Level
AC.12.1	Verify that workflows triggered by untrusted contributions (GitHub Actions pull_request_target, workflow_run, and equivalent fork-aware triggers in other CI systems) never check out, build, test, or otherwise execute untrusted code in a context that has repository write permissions or access to repository, organization, package-registry, cloud, or deployment secrets. Where a privileged follow-up step is needed, the untrusted contribution is first processed in an unprivileged pull_request workflow, and only validated passive artifacts are passed forward to a separate privileged workflow.	1
AC.12.2	Verify that secrets, credentials, and pipeline job tokens are not persisted into workspaces that process AI-touched or fork-originated untrusted code. For example, set persist-credentials: false on checkout where the platform supports it, and scrub CI runners of cached credentials before AI tooling runs.	1

#	Description	Level
AC.12.3	Verify that secrets are not exposed to workflows running code from forks or first-time contributors. Environment-protection rules (or the platform equivalent, such as protected variables and deployment approvals) require a manual approval before any secret-bearing job runs for those contributions. This control pairs with AC.11.7 and AC.13.2. Bot-level enforcement under AC.11.7 does not substitute for the platform-level enforcement required here.	1
AC.12.4	Verify that self-hosted or persistent runners used by AI tooling are ephemeral (destroyed after each job), network-segmented, and isolated from production credentials. Persistent or long-lived runners do not process fork PRs or AI-generated untrusted artifacts under any circumstances.	2
AC.12.5	Verify that changes to workflow definition files (.github/workflows/*, .gitlab-ci.yml, Jenkinsfile, Argo, Tekton, and equivalents) are detected on every PR and route through an elevated review path that includes a security reviewer, regardless of who the contributor is or whether AI was involved. AI agents must not be granted bypass authority over this review path.	2

#	Description	Level
AC.12.6	Verify that pipeline audit logs (workflow runs, secret access, runner registration, permission grants, OIDC token issuance) are streamed in real time to centralized security monitoring. Detection rules are tuned for AI-augmented threat patterns: bulk PR creation from new accounts, workflow-file modifications in fork PRs, unexpected secret access from AI-runner pools, and unusual egress (webhooks, paste sites, bin services) from AI workloads.	2
AC.12.7	Verify that artifacts produced by untrusted PR workflows are treated as untrusted passive data when a privileged follow-up workflow consumes them. The privileged workflow never executes binaries, scripts, packages, caches, or generated workflow fragments that originated in an untrusted contribution.	2
AC.12.8	Verify that the remediation of a vulnerable workflow includes invalidating or re-validating any PR that was opened before the fix landed. Without this step, a later commit to the same PR can pick up the stale workflow definition and route around the fix.	2

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.12.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਗੈਰ-ਭਰੋਸੇਯੋਗ ਯੋਗਦਾਨਾਂ ਦੁਆਰਾ ਟ੍ਰਿਗਰ ਹੋਏ ਵਰਕਫਲੋ (GitHub Actions ਦੇ pull_request_target, workflow_run, ਅਤੇ ਹੋਰ CI ਸਿਸਟਮਾਂ ਵਿਚਲੇ ਬਰਾਬਰ ਦੇ ਫੋਰਕ-ਜਾਣੂ ਟ੍ਰਿਗਰ) ਕਦੇ ਵੀ ਗੈਰ-ਭਰੋਸੇਯੋਗ ਕੋਡ ਨੂੰ ਅਜਹੀ ਸੰਦਰਭ ਵਿੱਚ ਚੈਕ-ਆਊਟ, ਬਲਿਡ, ਟੈਸਟ, ਜਾਂ ਕਸਿ ਹੋਰ ਢੰਗ ਨਾਲ ਨਹੀਂ ਚਲਾਉਂਦੇ ਜਿਸ ਕੋਲ ਰਪਿਜ਼ਟਰੀ ਲਿਖਣ ਦੀਆਂ ਇਜਾਜ਼ਤਾਂ ਹੋਣ ਜਾਂ ਰਪਿਜ਼ਟਰੀ, ਸੰਸਥਾ, ਪੈਕੇਜ-ਰਜਿਸਟਰੀ, ਕਲਾਊਡ, ਜਾਂ ਤੈਨਾਤੀ ਦੇ ਗੁਪਤ ਭੇਦਾਂ ਤੱਕ ਪਹੁੰਚ ਹੋਵੇ। ਜਿਥੇ ਵਸਿਸ-ਅਧਿਕਾਰ ਵਾਲਾ ਅਗਲਾ ਕਦਮ ਲੋੜੀਂਦਾ ਹੋਵੇ, ਉਥੇ ਗੈਰ-ਭਰੋਸੇਯੋਗ ਯੋਗਦਾਨ ਦੀ ਪ੍ਰਕਿਰਿਆ ਪਹਿਲਾਂ ਇੱਕ ਗੈਰ-ਵਸਿਸ-ਅਧਿਕਾਰ ਵਾਲੇ pull_request ਵਰਕਫਲੋ ਵਿੱਚ ਕੀਤੀ ਜਾਂਦੀ ਹੈ, ਅਤੇ ਸਰਿਫ਼ ਪ੍ਰਮਾਣਿਤ ਨਸ਼ਿਕਰਿਆ ਆਰਟੀਫ਼ੈਕਟ ਹੀ ਇੱਕ ਵੱਖਰੇ ਵਸਿਸ-ਅਧਿਕਾਰ ਵਾਲੇ ਵਰਕਫਲੋ ਨੂੰ ਅੱਗੇ ਦੱਸੇ ਜਾਂਦੇ ਹਨ।	1
AC.12.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਗੁਪਤ ਭੇਦ, ਕ੍ਰੈਡੈਂਸ਼ੀਅਲ, ਅਤੇ ਪਾਈਪਲਾਈਨ ਜੋਬ ਟੈਕਨ ਉਹਨਾਂ ਵਰਕਸਪੇਸਾਂ ਵਿੱਚ ਸੰਭਾਲ ਕੇ ਨਹੀਂ ਰੱਖੇ ਜਾਂਦੇ ਜਿਹੜੇ AI-ਫੂਹੇ ਜਾਂ ਫੋਰਕ ਤੋਂ ਆਏ ਗੈਰ-ਭਰੋਸੇਯੋਗ ਕੋਡ ਦੀ ਪ੍ਰਕਿਰਿਆ ਕਰਦੇ ਹਨ। ਮਸਿਲ ਵਜੋਂ, ਜਿਥੇ ਪਲੇਟਫਾਰਮ ਸਮਰਥਨ ਕਰਦਾ ਹੈ ਉਥੇ ਚੈਕਆਊਟ ਉੱਤੇ persist-credentials: false ਸੈੱਟ ਕਰੋ, ਅਤੇ AI ਟੂਲਿੰਗ ਚੱਲਣ ਤੋਂ ਪਹਿਲਾਂ CI ਰਨਰਾਂ ਵਿੱਚੋਂ ਕੈਸ਼ ਕੀਤੇ ਕ੍ਰੈਡੈਂਸ਼ੀਅਲ ਸਾਫ਼ ਕਰੋ।	1
AC.12.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਫੋਰਕਾਂ ਜਾਂ ਪਹਿਲੀ-ਵਾਰੀ ਯੋਗਦਾਨਕਰਤਾਵਾਂ ਦਾ ਕੋਡ ਚਲਾਉਣ ਵਾਲੇ ਵਰਕਫਲੋ ਨੂੰ ਗੁਪਤ ਭੇਦ ਨਹੀਂ ਦਿਖਾਏ ਜਾਂਦੇ। ਵਾਤਾਵਰਣ-ਸੁਰੱਖਿਆ ਨਿਯਮ (ਜਾਂ ਪਲੇਟਫਾਰਮ ਦਾ ਬਰਾਬਰ ਦਾ ਪ੍ਰਬੰਧ, ਜਿਵੇਂ ਸੁਰੱਖਿਅਤ ਵੇਰੀਏਬਲ ਅਤੇ ਤੈਨਾਤੀ ਮਨਜ਼ੂਰੀਆਂ) ਇਹਨਾਂ ਯੋਗਦਾਨਾਂ ਲਈ ਕੋਈ ਵੀ ਗੁਪਤ-ਭੇਦ ਵਾਲੀ ਜੋਬ ਚੱਲਣ ਤੋਂ ਪਹਿਲਾਂ ਦਸਤੀ ਮਨਜ਼ੂਰੀ ਦੀ ਲੋੜ ਪਾਉਂਦੇ ਹਨ। ਇਹ ਨਿਯੰਤਰਣ AC.11.7 ਅਤੇ AC.13.2 ਨਾਲ ਜੋੜੀ ਬਣਾਉਂਦਾ ਹੈ। AC.11.7 ਅਧੀਨ ਬੋਟ-ਪੱਧਰੀ ਲਾਗੂਕਰਨ ਇੱਥੇ ਲੋੜੀਂਦੇ ਪਲੇਟਫਾਰਮ-ਪੱਧਰੀ ਲਾਗੂਕਰਨ ਦਾ ਬਦਲ ਨਹੀਂ ਹੈ।	1
AC.12.4	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਟੂਲਿੰਗ ਦੁਆਰਾ ਵਰਤੇ ਜਾਂਦੇ ਸਵੈ-ਹੋਸਟ ਕੀਤੇ ਜਾਂ ਸਥਾਈ ਰਨਰ ਥ੍ਰੂ-ਚਰਿ ਹਨ (ਹਰ ਜੋਬ ਤੋਂ ਬਾਅਦ ਨਸ਼ਟ ਕੀਤੇ ਜਾਂਦੇ ਹਨ), ਨੈਟਵਰਕ-ਪੱਖੇ ਵੰਡੇ ਹੋਏ ਹਨ, ਅਤੇ ਉਤਪਾਦਨ ਕ੍ਰੈਡੈਂਸ਼ੀਅਲਾਂ ਤੋਂ ਅਲੱਗ-ਥਲੱਗ ਹਨ। ਸਥਾਈ ਜਾਂ ਲੰਮੇ ਸਮੇਂ ਵਾਲੇ ਰਨਰ ਕਸਿ ਵੀ ਹਾਲਤ ਵਿੱਚ ਫੋਰਕ PR ਜਾਂ AI ਦੁਆਰਾ ਤਿਆਰ ਗੈਰ-ਭਰੋਸੇਯੋਗ ਆਰਟੀਫ਼ੈਕਟਾਂ ਦੀ ਪ੍ਰਕਿਰਿਆ ਨਹੀਂ ਕਰਦੇ।	2

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.12.5	ਤਸਦੀਕ ਕਰੋ ਕਿ ਵਰਕਫਲੋ ਪਰਭਿਾਸ਼ਾ ਫਾਈਲਾਂ (.github/workflows/*, .gitlab-ci.yml, Jenkinsfile, Argo, Tekton, ਅਤੇ ਬਰਾਬਰ ਦੀਆਂ) ਵਰਤਣ ਵਾਲੀਆਂ ਤਬਦੀਲੀਆਂ ਹਰ PR ਉੱਤੇ ਪਛਾਣੀਆਂ ਜਾਂਦੀਆਂ ਹਨ ਅਤੇ ਇੱਕ ਉੱਚੇ ਸਮੀਖਿਆ ਰਾਹ ਵਿੱਚ ਲੰਘਦੀਆਂ ਹਨ ਜਿਸ ਵਿੱਚ ਇੱਕ ਸੁਰੱਖਿਆ ਸਮੀਖਿਅਕ ਸ਼ਾਮਲ ਹੁੰਦਾ ਹੈ — ਭਾਵੇਂ ਯੋਗਦਾਨਕਰਤਾ ਕੋਈ ਵੀ ਹੋਵੇ ਅਤੇ ਭਾਵੇਂ AI ਸ਼ਾਮਲ ਸੀ ਜਾਂ ਨਹੀਂ। AI ਏਜੰਟਾਂ ਨੂੰ ਇਸ ਸਮੀਖਿਆ ਰਾਹ ਉੱਤੇ ਬਾਈਪਾਸ ਕਰਨ ਦਾ ਅਧਿਕਾਰ ਨਹੀਂ ਦਿੱਤਾ ਜਾਣਾ ਚਾਹੀਦਾ।	2
AC.12.6	ਤਸਦੀਕ ਕਰੋ ਕਿ ਪਾਈਪਲਾਈਨ ਆਡਿਟ ਲੌਗ (ਵਰਕਫਲੋ ਰਨ, ਗੁਪਤ-ਭੇਦ ਪਹੁੰਚ, ਰਨਰ ਰਜਿਸਟਰੇਸ਼ਨ, ਇਜਾਜ਼ਤਾਂ ਦੇਣਾ, OIDC ਟੋਕਨ ਜਾਰੀ ਕਰਨਾ) ਅਸਲ ਸਮੇਂ ਵਿੱਚ ਕੇਂਦਰੀਕ੍ਰਿਤ ਸੁਰੱਖਿਆ ਨਿਗਰਾਨੀ ਨੂੰ ਭੇਜੇ ਜਾਂਦੇ ਹਨ। ਪਛਾਣ ਨਿਯਮ AI-ਵਧਾਏ ਖ਼ਤਰਾ ਪੈਟਰਨਾਂ ਲਈ ਸੁਰ ਕੀਤੇ ਜਾਂਦੇ ਹਨ: ਨਵੇਂ ਖਾਤਿਆਂ ਤੋਂ ਥੋਕ PR ਬਣਾਉਣਾ, ਫੋਰਕ PR ਵਿੱਚ ਵਰਕਫਲੋ-ਫਾਈਲ ਸੋਧਾਂ, AI-ਰਨਰ ਪੂਲਾਂ ਤੋਂ ਅਣਕਿਆਸੀ ਗੁਪਤ-ਭੇਦ ਪਹੁੰਚ, ਅਤੇ AI ਵਰਕਲੋਡਾਂ ਤੋਂ ਅਸਧਾਰਨ ਬਾਹਰ ਜਾਣ ਵਾਲਾ ਟਰੈਫਿਕ (webhook, paste site, bin service)।	2
AC.12.7	ਤਸਦੀਕ ਕਰੋ ਕਿ ਜਦੋਂ ਕੋਈ ਵਸਿਸ਼-ਅਧਿਕਾਰ ਵਾਲਾ ਅਗਲਾ ਵਰਕਫਲੋ ਗੈਰ-ਭਰੋਸੇਯੋਗ PR ਵਰਕਫਲੋ ਦੁਆਰਾ ਪੈਦਾ ਕੀਤੇ ਆਰਟੀਫੈਕਟਾਂ ਦੀ ਵਰਤੋਂ ਕਰਦਾ ਹੈ, ਤਾਂ ਉਹਨਾਂ ਨੂੰ ਗੈਰ-ਭਰੋਸੇਯੋਗ ਨਸ਼ੀਕਰਿਆ ਡਾਟਾ ਮੰਨਿਆ ਜਾਂਦਾ ਹੈ। ਵਸਿਸ਼-ਅਧਿਕਾਰ ਵਾਲਾ ਵਰਕਫਲੋ ਕਦੇ ਵੀ ਅਜਿਹੀਆਂ ਬਾਈਨਰੀਆਂ, ਸਕ੍ਰਿਪਟਾਂ, ਪੈਕੇਜਾਂ, ਕੈਸ਼ਾਂ, ਜਾਂ ਤਿਆਰ ਕੀਤੇ ਵਰਕਫਲੋ ਟੁਕੜਿਆਂ ਨੂੰ ਨਹੀਂ ਚਲਾਉਂਦਾ ਜੋ ਕਿਸੇ ਗੈਰ-ਭਰੋਸੇਯੋਗ ਯੋਗਦਾਨ ਵਿੱਚ ਆਏ ਹੋਣ।	2
AC.12.8	ਤਸਦੀਕ ਕਰੋ ਕਿ ਕਿਸੇ ਕਮਜ਼ੋਰ ਵਰਕਫਲੋ ਦੀ ਦਰੁਸਤੀ ਵਿੱਚ ਹਰ ਉਸ PR ਨੂੰ ਅਯੋਗ ਕਰਨਾ ਜਾਂ ਮੁੜ-ਪ੍ਰਮਾਣਿਤ ਕਰਨਾ ਸ਼ਾਮਲ ਹੈ ਜੋ ਦਰੁਸਤੀ ਲਾਗੂ ਹੋਣ ਤੋਂ ਪਹਿਲਾਂ ਖੋਲ੍ਹੀ ਗਈ ਸੀ। ਇਸ ਕਦਮ ਤੋਂ ਬਿਨਾਂ, ਉਸੇ PR ਉੱਤੇ ਬਾਅਦ ਵਿੱਚ ਕੀਤਾ ਕਮਿਟ ਪੁਰਾਣੀ ਵਰਕਫਲੋ ਪਰਭਿਾਸ਼ਾ ਚੁੱਕ ਸਕਦਾ ਹੈ ਅਤੇ ਦਰੁਸਤੀ ਦੇ ਦੁਆਲੇ ਲੰਘ ਸਕਦਾ ਹੈ।	2

Mappings & References:

ਮੈਪਿੰਗ ਅਤੇ ਹਵਾਲੇ:

- AC.12.1: OWASP CI/CD Top 10 C1CD-SEC-01, C1CD-SEC-04; GitHub Security Lab “Preventing pwn requests” series; NIST SP 800-204D (Pipeline isolation).

- **AC.12.2:** OWASP CI/CD Top 10 CICD-SEC-02, CICD-SEC-06; GitHub Docs (Automatic token authentication and permissions); NIST SP 800-53r5 AC-6 (Least Privilege).
- **AC.12.3:** OWASP CI/CD Top 10 CICD-SEC-01; GitHub Docs (Approving workflow runs from public forks; Protected environments); GitLab Docs (Protected variables).
- **AC.12.4:** OWASP CI/CD Top 10 CICD-SEC-06; NIST SP 800-204D (Runner isolation); ISO/IEC 27001:2022 A.8.22 (Segregation of Networks).
- **AC.12.5:** OWASP CI/CD Top 10 CICD-SEC-01; NIST SSDF PW.7; ISO/IEC 27001:2022 A.8.32.
- **AC.12.6:** OWASP ASVS v5 V8 (Logging); OWASP CI/CD Top 10 CICD-SEC-10 (Insufficient Logging and Visibility); ISO/IEC 27001:2022 A.8.16.
- **AC.12.7:** GitHub Security Lab “Preventing pwn requests” series; OWASP CI/CD Top 10 CICD-SEC-01; NIST SP 800-204D (Cross-workflow trust boundaries).
- **AC.12.8:** GitHub Security Lab “Preventing pwn requests” Part 4 (Alvaro Munoz, 2025); OWASP CI/CD Top 10 CICD-SEC-01; NIST SSDF RV.1.

AC.13 Adversarial AI Detection in Inbound Contributions

AC.13 ਅੰਦਰ ਆਉਣ ਵਾਲੇ ਯੋਗਦਾਨਾਂ ਵਿੱਚ ਵਰਿਧੀ AI ਦੀ ਪਛਾਣ

The previous families were about defending your own AI from misuse. This one flips the lens. Here the AI is on the attacker’s side, and you are trying to spot the signal in inbound contributions and content. The scenario worth defending against is the one where an attacker uses AI to run fork-and-PR campaigns at scale, with malicious payloads tailored to the target repository.

ਪਛਿਲੇ ਪਰਿਵਾਰ ਤੁਹਾਡੇ ਆਪਣੇ AI ਨੂੰ ਦੁਰਵਰਤੋਂ ਤੋਂ ਬਚਾਉਣ ਬਾਰੇ ਸਨ। ਇਹ ਪਰਿਵਾਰ ਨਜ਼ਰੀਆ ਉਲਟਾ ਦਿੰਦਾ ਹੈ। ਇੱਥੇ AI ਹਮਲਾਵਰ ਦੇ ਪਾਸੇ ਹੈ, ਅਤੇ ਤੁਸੀਂ ਅੰਦਰ ਆਉਣ ਵਾਲੇ ਯੋਗਦਾਨਾਂ ਤੇ ਸਮੱਗਰੀ ਵਿੱਚ ਉਸ ਦਾ ਸੰਕੇਤ ਪਛਾਣਨ ਦੀ ਕੋਸ਼ਿਸ਼ ਕਰ ਰਹੇ ਹੋ। ਜਿਸ ਦੁਰਵਰਤੋਂ ਤੋਂ ਬਚਾਅ ਕਰਨਾ ਬਣਦਾ ਹੈ ਉਹ ਇਹ ਹੈ ਕਿ ਹਮਲਾਵਰ AI ਦੀ ਵਰਤੋਂ ਕਰਕੇ ਵੱਡੇ ਪੈਮਾਨੇ ਉੱਤੇ ਫੋਰਕ-ਅਤੇ-PR ਮੁਹਿੰਮਾਂ ਚਲਾਉਂਦਾ ਹੈ, ਜਿਨ੍ਹਾਂ ਵਿੱਚ ਖ਼ਤਰਨਾਕ ਪੈਲੋਡ ਨਸ਼ਿਆਂ ਰਾਹੀਂ ਮੁਤਾਬਕ ਢਾਲੇ ਹੁੰਦੇ ਹਨ।

#	Description	Level
AC.13.1	Verify that contribution-velocity and contributor-reputation analytics flag anomalies: bulk PR creation from newly created accounts, coordinated fork waves immediately preceding PRs, PR volumes that are inconsistent with human authorship, and reuse of payload patterns across unrelated repositories.	1
AC.13.2	Verify that PRs from first-time or low-reputation contributors require maintainer approval before any privileged workflow processes them. Privileged workflows here include AI review bots, secret-bearing jobs, and external-integration calls.	1

#	Description	Level
AC.13.3	Verify that automated PR pipeline gates detect known indicators of LLM-generated or LLM-assisted malicious payload patterns: registry-confusable or typosquatted dependency names, package references that do not resolve to any published version, and dependencies whose creation, first-publication, or maintainer-change timestamps look anomalous relative to the PR.	2
AC.13.4	Verify that detection rules are tagged to MITRE ATT&CK (T1195 Supply Chain Compromise and CI/CD-relevant sub-techniques) and to MITRE ATLAS techniques, maintained for the inbound contribution analysis use case, and reviewed against current threat intelligence.	2
AC.13.5	Verify that confirmed or high-confidence adversarial contributions trigger automated containment: block the PR, quarantine the fork, suspend the contributor, notify maintainers, and freeze affected workflow files. Triage decisions feed back into detection tuning.	3
AC.13.6	Verify that PR analytics include structural AST profiling and stylometric or entropy-based heuristics tuned to identify LLM-generated code patterns. Detection in this category is still maturing, so compensating controls are accepted in place of high-precision automated detection: mandatory human review on flagged PRs, sandboxed execution of suspect payloads, and deferred merge until additional signals accrue.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.13.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਯੋਗਦਾਨ-ਰਫ਼ਤਾਰ ਅਤੇ ਯੋਗਦਾਨਕਰਤਾ-ਸਾਖ ਦਾ ਵਸ਼ਿਲੇਸ਼ਣ ਅਸਧਾਰਨਤਾਵਾਂ ਨੂੰ ਨਸ਼ਿਨਬੱਧ ਕਰਦਾ ਹੈ: ਨਵੇਂ ਬਣੇ ਖਾਤਿਆਂ ਤੋਂ ਬੋਕ PR ਬਣਾਉਣਾ, PR ਤੋਂ ਐਨ ਪਹਿਲਾਂ ਤਾਲਮੇਲ ਨਾਲ ਆਈਆਂ ਫ਼ੋਰਕ ਲਹਿਰਾਂ, ਅਜਿਹੀ PR ਮਾਤਰਾ ਜੋ ਮਨੁੱਖੀ ਲੇਖਣੀ ਨਾਲ ਮੇਲ ਨਹੀਂ ਖਾਂਦੀ, ਅਤੇ ਗ਼ੈਰ-ਸੰਬੰਧਿਤ ਰਪਿੰਜਟਰੀਆਂ ਵੱਲੋਂ ਉਹੀ ਪੇਲੇਡ ਪੈਟਰਨ ਮੁੜ ਵਰਤੇ ਜਾਣਾ।	1
AC.13.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਪਹਿਲੀ-ਵਾਰੀ ਜਾਂ ਘੱਟ-ਸਾਖ ਵਾਲੇ ਯੋਗਦਾਨਕਰਤਾਵਾਂ ਦੀਆਂ PR ਲਈ ਕਸਿ ਵੀ ਵਸ਼ਿਸ਼-ਅਧਿਕਾਰ ਵਾਲੇ ਵਰਕਫ਼ਲੋ ਵੱਲੋਂ ਉਹਨਾਂ ਦੀ ਪ੍ਰਕਿਰਿਆ ਕਰਨ ਤੋਂ ਪਹਿਲਾਂ ਸੰਭਾਲਕਰਤਾ ਦੀ ਮਨਜ਼ੂਰੀ ਲਾਜ਼ਮੀ ਹੈ। ਇੱਥੇ ਵਸ਼ਿਸ਼-ਅਧਿਕਾਰ ਵਾਲੇ ਵਰਕਫ਼ਲੋ ਵੱਲੋਂ AI ਸਮੀਖਿਆ ਬੋਟ, ਗੁਪਤ-ਭੇਦ ਵਾਲੀਆਂ ਜੋਬਾਂ, ਅਤੇ ਬਾਹਰੀ-ਏਕੀਕਰਨ ਸੱਦੇ ਸ਼ਾਮਲ ਹਨ।	1
AC.13.3	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਵੈਚਾਲਤਿ PR ਪਾਈਪਲਾਈਨ ਗੇਟ LLM ਦੁਆਰਾ ਤਿਆਰ ਜਾਂ LLM-ਸਹਾਇਤ ਪ੍ਰਾਪਤ ਖ਼ਤਰਨਾਕ ਪੇਲੇਡ ਪੈਟਰਨਾਂ ਦੇ ਜਾਣੇ-ਪਛਾਣੇ ਸੰਕੇਤ ਪਛਾਣਦੇ ਹਨ: ਰਜਿਸਟਰੀ ਵੱਲੋਂ ਭੁਲੇਖਾ ਪਾਉਣ ਵਾਲੇ ਜਾਂ typosquatted ²⁰⁶ ਡੋਮੇਨਾਂ ਨਾਂ, ਅਜਿਹੇ ਪੈਕੇਜ ਹਵਾਲੇ ਜੋ ਕਸਿ ਵੀ ਪ੍ਰਕਾਸ਼ਤਿ ਵਰਜਨ ਨਾਲ ਨਹੀਂ ਮਲਿਦੇ, ਅਤੇ ਉਹ ਡੋਮੇਨਾਂ ਜਿਨ੍ਹਾਂ ਦੀ ਸਰਿਜਣਾ, ਪਹਿਲੀ-ਪ੍ਰਕਾਸ਼ਨ, ਜਾਂ ਸੰਭਾਲਕਰਤਾ-ਬਦਲੀ ਦੇ ਸਮਾਂ-ਚਨ੍ਹਿਹ PR ਦੇ ਮੁਕਾਬਲੇ ਅਸਧਾਰਨ ਲੱਗਦੇ ਹਨ।	2
AC.13.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਪਛਾਣ ਨਯਿਮ MITRE ATT&CK (T1195 Supply Chain Compromise ਅਤੇ CI/CD ਨਾਲ ਸੰਬੰਧਿਤ ਉਪ-ਤਕਨੀਕਾਂ) ਅਤੇ MITRE ATLAS ਤਕਨੀਕਾਂ ਨਾਲ ਟੈਗ ਕੀਤੇ ਗਏ ਹਨ, ਅੰਦਰ ਆਉਣ ਵਾਲੇ ਯੋਗਦਾਨ ਦੇ ਵਸ਼ਿਲੇਸ਼ਣ ਵਾਲੇ ਵਰਤੋਂ-ਮਾਮਲੇ ਲਈ ਬਰਕਰਾਰ ਰੱਖੇ ਜਾਂਦੇ ਹਨ, ਅਤੇ ਮੌਜੂਦਾ ਖ਼ਤਰਾ ਖੁਫ਼ੀਆ ਜਾਣਕਾਰੀ ਦੇ ਵਰਿੱਧ ਸਮੀਖਿਆ ਕੀਤੇ ਜਾਂਦੇ ਹਨ।	2
AC.13.5	ਤਸਦੀਕ ਕਰੋ ਕਿ ਪ੍ਰਸ਼ਟ ਜਾਂ ਉੱਚ-ਭਰੋਸੇ ਵਾਲੇ ਵਰਿੱਧੀ ਯੋਗਦਾਨ ਸਵੈਚਾਲਤਿ ਘੇਰਾਬੰਦੀ ²⁰⁷ (containment) ਸ਼ੁਰੂ ਕਰਦੇ ਹਨ: PR ਨੂੰ ਰੋਕੋ, ਫ਼ੋਰਕ ਨੂੰ ਕੁਆਰੰਟੀਨ ਕਰੋ, ਯੋਗਦਾਨਕਰਤਾ ਨੂੰ ਮੁਅੱਤਲ ਕਰੋ, ਸੰਭਾਲਕਰਤਾਵਾਂ ਨੂੰ ਸੂਚਤਿ ਕਰੋ, ਅਤੇ ਪ੍ਰਭਾਵਤਿ ਵਰਕਫ਼ਲੋ ਫ਼ਾਈਲਾਂ ਨੂੰ ਜਮਾ ਦਿਓ। ਛਾਂਟੀ ਦੇ ਫ਼ੈਸਲੇ ਵਾਪਸ ਪਛਾਣ ਦੀ ਸੁਰ-ਸੈਟਿੰਗ ਵੱਲੋਂ ਜਾਂਦੇ ਹਨ।	3

²⁰⁶**typosquatted** (EN) -> retained in Latin — a named supply-chain technique catalogued by OWASP CI/CD Top 10 C1CD-SEC-03, which this requirement cites, so a practitioner searching for it needs the English string rather than a translated description. Full discussion: OPEN-QUESTIONS.md Q116.

²⁰⁷**containment** (EN) -> ਘੇਰਾਬੰਦੀ (“cordon off, encircling”) — deliberately not ਰੋਕਥਾਮ (“prevention”), which would state the opposite of the

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.13.6	ਤਸਦੀਕ ਕਰੋ ਕਿ PR ਵਸ਼ਿਲੇਸ਼ਣ ਵੱਲੋਂ ਢਾਂਚਾਗਤ AST ਪ੍ਰੋਫਾਈਲਿੰਗ ਅਤੇ LLM ਦੁਆਰਾ ਤਿਆਰ ਕੋਡ ਪੈਟਰਨ ਪਛਾਣਨ ਲਈ ਸੁਰੱਖਿਤ ਸਟਾਈਲੋਮੈਟ੍ਰਿਕ ²⁰⁸ (stylometric) ਜਾਂ ਐਂਟਰੋਪੀ-ਆਧਾਰਿਤ ਅਨੁਮਾਨ-ਨੇਮ ਸ਼ਾਮਲ ਹਨ। ਇਸ ਸ਼੍ਰੇਣੀ ਵੱਲੋਂ ਪਛਾਣ ਅਜੇ ਪੱਕ ਰਹੀ ਹੈ, ਇਸ ਲਈ ਉੱਚ-ਸੁੱਧਤਾ ਵਾਲੀ ਸਵੈਚਾਲਤ ਪਛਾਣ ਦੀ ਥਾਂ ਭਰਪਾਈ ਕਰਨ ਵਾਲੇ ਨਿਯੰਤਰਣ ਪ੍ਰਵਾਨ ਹਨ: ਨਿਸ਼ਾਨਬੱਧ PR ਉੱਤੇ ਲਾਜ਼ਮੀ ਮਨੁੱਖੀ ਸਮੀਖਿਆ, ਸ਼ੱਕੀ ਪੇਲੋਡਾਂ ਦਾ ਸੈਂਡਬਾਕਸ ਵੱਲੋਂ ਐਗਜ਼ੀਕਿਊਸ਼ਨ, ਅਤੇ ਹੋਰ ਸੰਕੇਤ ਇਕੱਠੇ ਹੋਣ ਤੱਕ ਮਰਜ਼ ਨੂੰ ਟਾਲਣਾ।	3

Mappings & References:

ਮੈਪਿੰਗ ਅਤੇ ਹਵਾਲੇ:

- **AC.13.1:** OWASP CI/CD Top 10 C1CD-SEC-01; NIST AI RMF MANAGE; MITRE ATLAS (Reconnaissance).
- **AC.13.2:** GitHub Docs (Approving workflow runs from public forks); OWASP CI/CD Top 10 C1CD-SEC-01; NIST SSDF PW.4.
- **AC.13.3:** OWASP LLM Top 10 (2025) LLM03; OWASP CI/CD Top 10 C1CD-SEC-03 (Dependency Chain Abuse); NIST SSDF PW.4.
- **AC.13.4:** MITRE ATT&CK T1195; MITRE ATLAS (Technique catalogue); OWASP SAMM Threat Assessment (TA).
- **AC.13.5:** NIST AI RMF MANAGE; ISO/IEC 27001:2022 A.5.25 (Assessment of Information Security Events); OWASP SAMM Incident Management (IM).
- **AC.13.6:** MITRE ATLAS (Adversarial ML output detection, research-edge); OWASP LLM Top 10 (2025) LLM03; NIST SSDF PW.8.

AC.14 Compromise Containment & Automated Remediation

AC.14 ਸਮਝੌਤੇ ਦੀ ਘੇਰਾਬੰਦੀ ਅਤੇ ਸਵੈਚਾਲਤ ਦਰੁਸਤੀ

Things go wrong eventually. When an AI-adjacent compromise (a prompt-injected bot, a leaked CI secret, a malicious AI-generated artifact in a build) is suspected or confirmed, the goal is to contain the damage and shorten the recovery.

ਗੱਲਾਂ ਆਖਰ ਵਗਿੜਦੀਆਂ ਹੀ ਹਨ। ਜਦੋਂ ਕਸਿ AI-ਨਾਲ ਲੱਗਦੇ ਸਮਝੌਤੇ (compromise) ਦਾ ਸ਼ੱਕ ਪਵੇ ਜਾਂ ਪੁਸ਼ਟੀ ਹੋ ਜਾਵੇ — ਜਵਿੰ prompt-ਇੰਜੈਕਟ ਕੀਤਾ ਬੋਟ, ਲੀਕ ਹੋਇਆ CI ਗੁਪਤ ਭੇਦ, ਜਾਂ ਬਲਿਡ ਵੱਲੋਂ AI ਦੁਆਰਾ ਤਿਆਰ ਕੋਈ ਖ਼ਤਰਨਾਕ ਆਰਟੀਫੈਕਟ — ਤਾਂ ਟੀਚਾ ਹੁੰਦਾ ਹੈ ਨੁਕਸਾਨ ਦੀ ਘੇਰਾਬੰਦੀ ਕਰਨਾ ਅਤੇ ਮੁੜ-ਬਹਾਲੀ ਦਾ ਸਮਾਂ ਘਟਾਉਣਾ।

requirement since this control is explicitly the post-compromise phase. Full discussion: OPEN-QUESTIONS.md Q114.

²⁰⁸ **stylometric** (EN) -> ਸਟਾਈਲੋਮੈਟ੍ਰਿਕ — kept as a loan because stylometry is a named forensic-linguistics discipline, not a description, matching the corpus's treatment of other named disciplines like federated learning. Full discussion: OPEN-QUESTIONS.md Q115.

#	Description	Level
AC.14.1	Verify that an incident-response playbook exists for AI-in-pipeline compromise. At minimum it covers: revoking AI-agent credentials, rotating every secret that touched the compromised workflow run, quarantining the compromised artifacts, notifying downstream consumers, notifying regulators where applicable, and preserving prompts, responses, and audit logs for forensics.	1
AC.14.2	Verify that any secret that touched a workflow run associated with a suspicious PR, a prompt-injection event, or an AI-agent anomaly is automatically rotated, and that downstream issuers (cloud IAM, package registries, signing-key custodians) are notified of the rotation.	1
AC.14.3	Verify that AI agent identities (keys, tokens, OIDC trust grants) can be rapidly revoked and quarantined, with a target time-to-revoke that is written down and tested at least once a year.	2
AC.14.4	Verify that build provenance and AI BOM records are used during incident response to identify every downstream artifact produced under the suspect AI agent or the compromised pipeline run, so that recall, rebuild, or quarantine can be targeted.	2
AC.14.5	Verify that automated remediation is tested in tabletop or live-fire exercises at least once a year. The scenarios include a prompt-injected reviewer bot, fork-PR secret exfiltration, and an AI-generated malicious workflow file.	3

#	ਵੇਰਵਾ	ਪੱਧਰ
AC.14.1	ਤਸਦੀਕ ਕਰੋ ਕਿ ਪਾਣੀਪਲਾਈਨ ਵਚਿਲੇ AI ਦੇ ਸਮਝੋਤੋ ਲਈ ਇੱਕ ਘਟਨਾ-ਜਵਾਬ ਪਲੇਬੁੱਕ (incident-response playbook) ਮੌਜੂਦ ਹੈ। ਘੱਟੋ-ਘੱਟ ਇਹ ਗੱਲਾਂ ਢੱਕੀਆਂ ਹੋਣ: AI-ਏਜੰਟ ਕ੍ਰੈਡੈਂਸੀਅਲ ਰੱਦ ਕਰਨਾ, ਸਮਝੋਤਾਗਰਸਤ ਵਰਕਫਲੋ ਰਨ ਨੂੰ ਛੂਹਣ ਵਾਲਾ ਹਰ ਗੁਪਤ ਭੇਦ ਬਦਲਣਾ, ਸਮਝੋਤਾਗਰਸਤ ਆਰਟੀਫੈਕਟਾਂ ਨੂੰ ਕੁਆਰੰਟੀਨ ਕਰਨਾ, ਡਾਊਨਸਟਰੀਮ ਵਰਤੋਂਕਾਰਾਂ ਨੂੰ ਸੂਚਤਿ ਕਰਨਾ, ਜਿਥੇ ਲਾਗੂ ਹੋਵੇ ਉਥੇ ਨਿਯਮਕਾਂ ਨੂੰ ਸੂਚਤਿ ਕਰਨਾ, ਅਤੇ ਫੋਰੈਂਸਿਕ ਲਈ prompt, ਜਵਾਬ, ਤੇ ਆਡਟਿ ਲੌਗ ਸਾਂਭ ਕੇ ਰੱਖਣਾ।	1
AC.14.2	ਤਸਦੀਕ ਕਰੋ ਕਿ ਕਿਸੇ ਸ਼ੱਕੀ PR, prompt ਇੰਜੈਕਸ਼ਨ ਦੀ ਘਟਨਾ, ਜਾਂ AI-ਏਜੰਟ ਦੀ ਅਸਧਾਰਨਤਾ ਨਾਲ ਜੁੜੇ ਵਰਕਫਲੋ ਰਨ ਨੂੰ ਛੂਹਣ ਵਾਲਾ ਹਰ ਗੁਪਤ ਭੇਦ ਆਪਣੇ-ਆਪ ਬਦਲਿਆ (rotate) ਜਾਂਦਾ ਹੈ, ਅਤੇ ਡਾਊਨਸਟਰੀਮ ਜਾਰੀਕਰਤਾਵਾਂ (ਕਲਾਊਡ IAM, ਪੈਕੇਜ ਰਜਿਸਟਰੀਆਂ, ਦਸਤਖਤ-ਕੁੰਜੀ ਦੇ ਰਾਖਿਆਂ) ਨੂੰ ਇਸ ਬਦਲੀ ਬਾਰੇ ਸੂਚਤਿ ਕੀਤਾ ਜਾਂਦਾ ਹੈ।	1
AC.14.3	ਤਸਦੀਕ ਕਰੋ ਕਿ AI ਏਜੰਟ ਪਛਾਣਾਂ (ਕੁੰਜੀਆਂ, ਟੋਕਨ, OIDC ਭਰੋਸਾ ਗ੍ਰਾਂਟਾਂ) ਨੂੰ ਤੇਜ਼ੀ ਨਾਲ ਰੱਦ ਅਤੇ ਕੁਆਰੰਟੀਨ ਕੀਤਾ ਜਾ ਸਕਦਾ ਹੈ, ਅਤੇ ਰੱਦ ਕਰਨ ਦਾ ਨਸ਼ਾਨਾ-ਸਮਾਂ ਲਖਿਤੀ ਰੂਪ ਵਿੱਚ ਦਰਜ ਹੈ ਤੇ ਸਾਲ ਵਿੱਚ ਘੱਟੋ-ਘੱਟ ਇੱਕ ਵਾਰ ਪਰਖਿਆ ਜਾਂਦਾ ਹੈ।	2
AC.14.4	ਤਸਦੀਕ ਕਰੋ ਕਿ ਘਟਨਾ ਜਵਾਬ ਦੌਰਾਨ ਬਲਿਡ ਮੂਲ-ਸਰੋਤ ਅਤੇ AI BOM ਰਕਿਾਰਡਾਂ ਦੀ ਵਰਤੋਂ ਸ਼ੱਕੀ AI ਏਜੰਟ ਜਾਂ ਸਮਝੋਤਾਗਰਸਤ ਪਾਣੀਪਲਾਈਨ ਰਨ ਅਧੀਨ ਪੈਦਾ ਹੋਏ ਹਰ ਡਾਊਨਸਟਰੀਮ ਆਰਟੀਫੈਕਟ ਦੀ ਪਛਾਣ ਕਰਨ ਲਈ ਕੀਤੀ ਜਾਂਦੀ ਹੈ, ਤਾਂ ਜੋ ਵਾਪਸੀ, ਮੁੜ-ਬਲਿਡ, ਜਾਂ ਕੁਆਰੰਟੀਨ ਨੂੰ ਨਸ਼ਾਨਾਬੱਧ ਕੀਤਾ ਜਾ ਸਕੇ।	2
AC.14.5	ਤਸਦੀਕ ਕਰੋ ਕਿ ਸਵੈਚਾਲਤਿ ਦਰੁਸਤੀ ਨੂੰ ਸਾਲ ਵਿੱਚ ਘੱਟੋ-ਘੱਟ ਇੱਕ ਵਾਰ ਟੈਬਲਟੋਪ ਜਾਂ ਲਾਈਵ-ਫਾਇਰ ਮਸ਼ਕਾਂ ਵਿੱਚ ਪਰਖਿਆ ਜਾਂਦਾ ਹੈ। ਇਹਨਾਂ ਦਰਸ਼ਿਾਂ ਵਿੱਚ prompt-ਇੰਜੈਕਟ ਕੀਤਾ ਸਮੀਖਿਅਕ ਬੋਟ, ਫੋਰਕ-PR ਰਾਹੀਂ ਗੁਪਤ ਭੇਦ ਬਾਹਰ ਕੱਢਣਾ, ਅਤੇ AI ਦੁਆਰਾ ਤਿਆਰ ਖਤਰਨਾਕ ਵਰਕਫਲੋ ਫਾਈਲ ਸ਼ਾਮਲ ਹਨ।	3

Mappings & References:

ਮੈਪਿੰਗ ਅਤੇ ਹਵਾਲੇ:

- **AC.14.1:** ISO/IEC 27001:2022 A.5.24, A.5.26; NIST AI RMF MANAGE; OWASP SAMM Incident Management (IM).
- **AC.14.2:** OWASP ASVS v5 V6 (Cryptography), V14; OWASP CI/CD Top 10 C1CD-SEC-06; NIST SSDF RV.2.

- **AC.14.3:** AISVS C9.4 (Agent and Orchestrator Identity); NIST SP 800-207 (Zero Trust Architecture); ISO/IEC 27001:2022 A.5.18 (Access Rights).
- **AC.14.4:** OWASP SCVS (Bill-of-materials analysis); CycloneDX ML-BOM tracing; NIST SSDF RV.1.
- **AC.14.5:** NIST SSDF RV.1; ISO/IEC 27001:2022 A.5.28 (Collection of Evidence); OWASP SAMM Incident Management (IM).